

Decipher PMO

The Playbook

A complete toolkit for program and project managers

Methodology · Templates · Worked Examples · AI Prompts · Field & Leadership Notes

314 entries — 53 framework artifacts, 27 templates, 47 worked examples, 33 AI prompts, 22 field notes, 6 leadership notes

Reference edition — adapt to your context. Scenarios are fictional.

Contents

How to use this playbook

This playbook collects the full Decipher PMO toolkit in one reference. It is organized into three parts by discipline: Project Management, Program Management, and Shared & Cross-cutting material that serves both roles.

Within each part, content is grouped by type: Framework Artifacts (the methodology - what each artifact is, when to use it, who owns it, plus a practitioner reference covering standards, principles, what good looks like, common pitfalls, and a 1-5 maturity ladder); Templates (fillable structures with usage guidance); Worked Examples (fully populated artifacts from the fictional Project Atlas program, annotated with why they work and how to adapt them); AI Prompts; Field Notes; and Leadership Notes.

Use the Framework Artifacts to decide what to produce and to what standard. Use the Templates to produce it. Use the Worked Examples to see what good looks like. Use the AI Prompts to accelerate the drafting and analysis. Use the Field and Leadership Notes for the judgment that no template can encode.

The scenarios are fictional and every organization is different - adapting this material to your context is part of the work.

Adapting to your context: treat this as a baseline operating standard, then layer on the overlays your situation needs - your regulatory regime (e.g., FCA, HIPAA, SOX, FedRAMP), delivery method (agile, hybrid, or stage-gated waterfall), industry and organization size and maturity, and program type (transformation, M&A integration, infrastructure, or regulatory remediation). The artifacts are the starting point; the overlay is the judgment.

Part I — Project Management

Project Management · Framework Artifacts (39)

Artifact #1 — Project Charter

Purpose: Authorize the project and align everyone on why it exists, what it will deliver, who owns it, and how success is measured. The single source of truth referenced throughout the project lifecycle.

When you use it: Drafted during Initiate; approved before any significant work starts; revisited at major change points.

Owner: TPM drafts; sponsor approves.

Cadence: One-time at kickoff; updated only when scope, budget, or governance materially changes.

Where it lives: Workbook tab 'Charter' (live); Templates Pack 4 has fillable doc form. The Charter doc is the contract; the workbook tab is the working reference.

Sections / contents:

Section	Contents / fields
Project identification	Name, ID, sponsor, TPM, date, version
Business case	Problem or opportunity, strategic alignment, expected business value (quantified where possible), cost of not doing
Objectives & success criteria	3–5 SMART objectives, measurable success criteria, KPIs with targets
Scope	In-scope deliverables, explicit out-of-scope, assumptions, constraints
Deliverables & milestones	Major deliverables and top-level milestone dates (detail lives in Schedule)
Stakeholders & governance	Sponsor, steering committee, decision-making model, escalation path
Budget	Approved amount, funding source, budget authority for
Section	Contents / fields overages
High-level risks	Top 3–5 risks at kickoff (full register lives in RAID Log)
Approvals	Sponsor, PMO, Finance, Legal/Security/Compliance as required — name, date, signature

AI enablement

- Auto-extract the business case from sponsor interviews and existing strategy docs.
- Surface comparable past projects and benchmark scope, cost, and timeline.
- Detect missing required sections and flag for completion before approval.
- Generate sponsor-tailored vs working-team-tailored versions from one source.

Note: The charter is a contract between the project and the organization. If it's not signed, the project shouldn't have started.

Keywords: project charter template, charter template, project charter structure, charter sections, charter format

PRACTITIONER REFERENCE

Standards & method: Governed by PMI PMBOK 7 (Stakeholder and Team performance domains) and ISO 21500:2021 clause 4.3.2. Method: scope the business problem -> define objectives and success criteria -> authorize resources and budget -> identify sponsor and PM -> obtain formal sign-off.

Guiding principles: A charter authorizes the project, it does not design it; objectives must be SMART and traceable to a strategic driver; the sponsor signature is a governance act, not a formality; scope boundaries (in/out) are as important as what is included.

What good looks like:

- Business case linkage is explicit: each objective maps to a named organizational goal or KPI.
- Constraints, assumptions, and exclusions are stated with enough precision that two readers reach the same interpretation.
- Success criteria are measurable and agreed by sponsor and key stakeholders before work begins.
- Authorization includes a named budget envelope and named PM with delegated authority levels.
- The charter is a living reference: version-controlled and re-baselined when scope changes are approved.

Common pitfalls:

- Objectives written as activities ('implement X') rather than outcomes ('reduce Y by Z%').
- Sponsor signs without reading; no verbal walk-through or challenge session.
- Scope boundary left ambiguous, allowing scope creep to enter unchallenged.
- Charter authored by the PM alone with no executive input, creating an orphaned document.
- No expiry or re-authorization trigger, so a stale charter governs a changed project.

Maturity (1-5): L1 Ad hoc - verbal go-ahead only, no document; L2 Defined - template exists but objectives are vague and sign-off is informal; L3 Managed - SMART objectives, sponsor-signed, linked to business case; L4 Integrated - charter formally tied to portfolio prioritization and benefit realization framework; L5 Optimizing - charter metrics feed real-time portfolio dashboards and trigger automatic re-authorization reviews.

Artifact #2 — Project Kickoff Pack

Purpose: Three coordinated artifacts that travel together: pre-read (sent 2–3 business days before kickoff), agenda, and deck outline. Goal is for everyone to arrive at the kickoff meeting already aligned, so the meeting is a conversation, not a presentation.

When you use it: Initiate phase, immediately after Charter is approved and before significant work begins.

Owner: TPM creates; sponsor reviews pre-read before distribution.

Cadence: One-time at project kickoff.

Where it lives: Templates Pack 1 has fillable doc forms for all three artifacts.

Sections / contents:

Section	Contents / fields
Pre-read	Why we're doing this, what we're delivering, success criteria, timeline, roles, what's needed before kickoff, agenda preview
Agenda	60–90 minute structured agenda with timing, topic, owner, outcome

Section	Contents / fields
	per segment
Deck outline	13-slide structure: cover, why, outcomes, scope, deliverables, approach, timeline, roles, governance, risks, cadence, asks, Q&A

AI enablement

- Auto-draft the pre-read from the approved Charter and Stakeholder Register.
- Generate audience-tailored deck variants (exec vs working team) from a single content source.
- Pre-populate agenda timing based on past kickoffs of similar size and complexity.
- Capture meeting notes during kickoff and surface action items, decisions, and risks into the workbook tabs.

Note: A kickoff meeting where people are reading slides for the first time is a wasted meeting. The pre-read does the heavy lifting; the meeting handles alignment, debate, and asks.

PRACTITIONER REFERENCE

Standards & method: Draws on PMI PMBOK 7 (Stakeholder performance domain) and PRINCE2 7 Starting Up / Initiating a Project processes. Method: confirm charter understanding -> align team on scope and ways of working -> establish governance cadence -> surface early risks -> close with clear next actions.

Guiding principles: The kickoff is a governance event, not a social one; every attendee must leave knowing their role, the decision rights, and the first milestone; pre-read materials replace re-reading slides live; open issues and risks raised in the session must be logged before the meeting closes.

What good looks like:

- Agenda is distributed with pre-read materials at least 48 hours in advance so the session is discussion, not information transfer.
- Governance model (steering committee cadence, escalation path, decision rights) is explicitly walked through and confirmed by all attendees.
- RAID log is seeded during the session from live audience input, not populated after the fact.
- Roles and responsibilities (RACI) are confirmed, not just presented, and gaps are called out.
- A verbatim parking-lot list with named owners and due dates is circulated within 24 hours.

Common pitfalls:

- Kickoff treated as a deck presentation with no structured discussion or Q&A.
- Key stakeholders absent because scheduling was not escalated to sponsor.
- Ways of working (tools, cadence, escalation) skipped due to time pressure, causing confusion in week 1.
- No baseline RAID log seeded, so risk management starts from zero post-kickoff.
- Actions from the session assigned to 'the team' with no single owner.

Maturity (1-5): L1 Ad hoc - no formal kickoff, team self-organizes; L2 Defined - meeting happens but no structured agenda or pre-read; L3 Managed - structured agenda, pre-read distributed, RAID seeded, actions logged; L4 Integrated - kickoff outputs (RAID, RACI, baseline plan) directly populate project management tooling; L5 Optimizing - kickoff effectiveness surveyed and continuously improved against team velocity and early issue rates.

Artifact #3 — Stakeholder Register & Engagement Plan

Purpose: Identify everyone who matters to or is affected by the project, classify their influence and interest, and define how to engage each one over time.

When you use it: Built during Initiate; reviewed and updated throughout — stakeholders change as the project evolves.

Owner: TPM owns; updated in collaboration with sponsor and OCM lead (if engaged).

Cadence: Monthly review at minimum; immediately on org changes affecting key stakeholders.

Where it lives: Workbook tab 'Stakeholders' with dropdowns for influence/interest/RACI/engagement.

Sections / contents:

Section	Contents / fields
Identification	Name, role/title, org/department
Classification	Influence (High/Med/Low), Interest (High/Med/Low)
RACI	Responsible / Accountable / Consulted / Informed for this project
Engagement level	Champion / Supportive / Neutral / Resistant / Blocker
Engagement plan	Preferred channel, communication needs, cadence, key messages
Notes	Specific concerns, history with similar projects, watch-outs

AI enablement

- Suggest stakeholders based on org chart, project type, and similar past projects — flag those typically missed.
- Detect stakeholder engagement drift — who hasn't been engaged at the cadence their RACI level implies.
- Predict resistance based on prior change history and recommend tailored engagement approach.
- Auto-summarize stakeholder sentiment from comms patterns and surface shifts.

Note: A stakeholder register without an engagement plan is just a contact list. The plan is what makes it useful.

PRACTITIONER REFERENCE

Standards & method: Grounded in PMI PMBOK 7 (Stakeholder performance domain) and BABOK v3 chapter 3 (Stakeholder Analysis). Method: identify -> analyze (power/interest/influence) -> classify engagement level (unaware/resistant/neutral/supportive/leading) -> plan targeted engagement actions -> monitor and adjust.

Guiding principles: Stakeholder analysis is continuous, not a one-time exercise; engagement level current vs. desired must be tracked separately for each actor; influence mapping captures informal power, not just org-chart authority; sensitive assessments require controlled access.

What good looks like:

- Each stakeholder has a current and target engagement rating with a documented gap and action plan.
- Power/interest grid is refreshed at each phase gate as organizational dynamics shift.

- Engagement actions are specific, dated, and owned - not generic ('keep informed').
- Resistors and blockers are explicitly named with a strategy for each, reviewed at SteerCo.
- The register feeds the Communications Plan so messages are audience-segmented, not broadcast.

Common pitfalls:

- Register built once at initiation and never updated, missing new stakeholders or shifted positions.
- Only formal authority mapped; informal influencers and shadow decision-makers ignored.
- Engagement actions default to 'send email' for every stakeholder regardless of influence level.
- Sensitive power/resistance assessments stored in a shared folder accessible to all project staff.
- Confusing 'stakeholder register' (who they are) with 'engagement plan' (how you move them).

Maturity (1-5): L1 Ad hoc - stakeholders identified informally in the PM's head; L2 Defined - a list exists with names and roles but no engagement analysis; L3 Managed - power/interest mapped, current vs. desired tracked, actions owned; L4 Integrated - stakeholder sentiment tracked via structured check-ins and feeds change management decisions; L5 Optimizing - real-time sentiment data and network analysis inform proactive engagement strategy.

Artifact #4 — RACI Matrix

Purpose: Decision-level accountability map. For each major activity or decision, who is Responsible (does the work), Accountable (owns the outcome), Consulted (input before decision), or Informed (notified after).

When you use it: Built during Initiate, refined during Plan, revisited after team or governance changes.

Owner: TPM drafts; sponsor approves.

Cadence: One-time creation; reviewed when org or governance materially changes.

Where it lives: Workbook tab 'RACI' with auto-validation that each activity has exactly one Accountable; Templates Pack 3 has fillable doc form with sample matrix.

Sections / contents:

Section	Contents / fields
Activities / decisions	Rows: the major activities and decisions in the project
Roles	Columns: the project roles (Sponsor, TPM, Eng Lead, QA, Business, Security, Compliance, Vendor, etc.)
RACI assignment	R / A / C / I for each cell
Integrity check	Each row should have exactly one A; the workbook auto- flags violations
Role definitions & rules	Doc-form RACI captures role definitions, rules, and the approved baseline

AI enablement

- Auto-draft a starting RACI from the charter, deliverables, and stakeholder register.
- Validate RACI integrity — flag any activity without exactly one Accountable.
- Detect role overload — surface stakeholders who are A on too many activities.

- Recommend role-by-decision adjustments based on similar past projects.

Note: The most-violated rule is 'one A per row.' If two people are accountable, no one is. Use R/A or A/R sparingly — they often hide insufficient delegation.

PLAN

PRACTITIONER REFERENCE

Standards & method: Grounded in the RACI (Responsible, Accountable, Consulted, Informed) accountability model and DACI (Driver, Approver, Contributor, Informed) for decision rights; referenced in PMI PMBOK 7 (Team performance domain) and PRINCE2 7 organization theme. Method: enumerate activities or decisions -> assign roles -> validate with stakeholders -> resolve conflicts -> publish and maintain.

Guiding principles: Every row has exactly one Accountable; no individual is Responsible for a task they cannot execute; Consulted parties must have a defined feedback mechanism and timeframe; the RACI is a living governance tool, not a project-initiation checkbox.

What good looks like:

- Exactly one 'A' per row, no exceptions; split accountabilities are resolved before sign-off.
- The matrix covers decisions as well as deliverables, eliminating escalation ambiguity.
- Column count reflects real project roles, not every possible org title; sparse columns are removed.
- Stakeholders have validated their own row, not just received the document.
- RACI changes triggered by scope or personnel changes are version-controlled with a rationale log.

Common pitfalls:

- Multiple 'A' entries per row, producing shared accountability that is functionally no accountability.
- 'R' and 'A' assigned to the same senior executive for operational tasks they will never perform.
- Consulted parties never actually consulted because no meeting cadence or input channel exists.
- RACI covers only deliverables, leaving key decisions (budget, scope change, go/no-go) unassigned.
- Matrix created by PM in isolation without buy-in from role holders, producing a document no one follows.

Maturity (1-5): L1 Ad hoc - accountability resolved by whoever shouts loudest; L2 Defined - a RACI exists for major deliverables but roles are vague and unvalidated; L3 Managed - complete RACI validated with all role holders, single 'A' enforced; L4 Integrated - RACI linked to decision log and escalation framework with audit trail; L5 Optimizing - accountability metrics (decisions delayed, rework rate) feed continuous governance improvement.

Artifact #5 — Integrated Project Plan / Workbook

Purpose: The consolidated working document for the project. Brings together schedule, resources, budget, requirements, and tracking logs in one place so the TPM and team aren't switching between disconnected files.

When you use it: Built immediately after charter approval; lives throughout the project.

Owner: TPM owns the workbook; team members update their respective tabs.

Cadence: Weekly review of all tabs at status meeting; daily updates as work progresses.

Where it lives: PMO_Project_Workbook.xlsx — the entire workbook is this artifact.

Sections / contents:

Section	Contents / fields
Cover	Project ID + tab map; the workbook home page
Charter / Stakeholders / RACI /	Foundational artifacts (1, 3, 4, 6)

Requirements

RAID Log / Schedule / Live planning and execution artifacts (11, 12, 13, 14)

Resources / Budget

Decisions & Changes / Status Running history (19, 18)

Reports

UAT Log / Lessons Learned / Test, learn, close (21, 22, 23)

Closeout

Post-Incident Actions Cross-incident corrective action tracker (32)

AI enablement

- Pull updates across tabs from chat, email, and meeting transcripts — kill manual data entry.
- Detect cross-tab inconsistencies (e.g., milestone in Schedule that has no resource assigned).
- Forecast schedule and budget completion based on actuals and similar past projects.
- Generate the Status Report row automatically from the other tabs each cycle.

Note: The workbook is the central artifact. Every other live working artifact points back to it. A TPM should be able to brief on the project from the workbook alone.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Planning performance domain) and ISO 21500:2021 clause 4.3.11. Method: decompose scope into WBS -> sequence activities (PDM) -> estimate duration and effort -> assign resources -> baseline schedule -> integrate cost, risk, and quality into a unified plan -> maintain through integrated change control.

Guiding principles: The plan is a model of the project, not a wish list; every task has a single owner and a defined completion criterion; the critical path must be explicitly identified and actively managed; the integrated plan is the single source of truth - parallel shadow plans undermine governance.

What good looks like:

- WBS dictionary defines each work package with scope, owner, entry/exit criteria, and effort estimate.
- Critical path is flagged, with float calculated and float consumption tracked weekly.
- Planned vs. actual is reported using Earned Value (PV, EV, AC, SPI, CPI) at each status cycle.
- Dependencies - internal and external - are documented with contact owners and lag/lead times.
- Baseline is locked after charter approval; changes flow through a formal change control process with impact assessment.

Common pitfalls:

- Activities sequenced in parallel by default to hit a target end date, hiding real critical-path risk.
- Effort estimates provided by the PM without input from the people doing the work.

- Plan updated to reflect actuals without re-baselining, masking schedule slippage.
- Resource loading not validated against actual availability, producing a plan that is immediately wrong.
- Integrated plan not integrated: cost, risk, and scope managed in separate documents with no cross-reference.

Maturity (1-5): L1 Ad hoc - plan is a list of dates in a spreadsheet; L2 Defined - Gantt exists with milestones but no WBS or resource loading; L3 Managed - WBS-based, resource-loaded, critical path identified, EV reported; L4 Integrated - schedule, cost, risk, and scope fully integrated with change control and SteerCo reporting; L5 Optimizing - predictive analytics and scenario modeling drive schedule risk decisions.

Artifact #6 — Business Requirements Document (BRD)

Purpose: Captures what the business needs from the project, in business language. Approved by the business owner before technical design begins.

When you use it: Plan phase, immediately after Charter and before Technical Spec.

Owner: TPM or Business Analyst drafts; business owner approves.

Cadence: One-time creation; revised when business requirements change (versioned).

Where it lives: Templates Pack 4 has fillable BRD; Workbook 'Requirements' tab tracks each BR row through implementation and test.

Sections / contents:

Section	Contents / fields
Executive summary	2–4 sentences capturing what and why
Background & business	Current state, drivers for change, strategic alignment

context

Business objectives	3–5 SMART objectives
Scope	In/out, assumptions, constraints
Stakeholders & user groups	Who will use the result
Business requirements	ID, requirement, priority (MoSCoW), acceptance criterion, source
Process flows	As-is / to-be where applicable
Data requirements	Business view of data; detailed model in Tech Spec
Compliance & regulatory	Regulations and the requirements they impose
Risks & open issues	Cross-reference RAID Log
Approvals	Business owner, sponsor, TPM, compliance/legal as needed

AI enablement

- Auto-extract requirement candidates from sponsor interviews, customer feedback, and existing process docs.
- Detect ambiguity ('the system should be fast', 'it must be user-friendly') and prompt for measurable rewrites.
- Auto-trace requirements to the workbook Requirements tab and to test cases.

- Flag requirements that aren't testable or don't have an acceptance criterion.

Note: The BRD is the business's contract for what they want. The Tech Spec is engineering's contract for what they'll build. UAT is how we know we delivered the BRD.

PRACTITIONER REFERENCE

Standards & method: Governed by BABOK v3 (Requirements Analysis and Design Definition knowledge area) and PMI-PBA Practice Guide. Method: elicit (interviews, workshops, surveys, observation) -> analyze and model -> specify and validate -> baseline -> manage changes through traceability.

Guiding principles: Requirements state what the business needs, not how the system should work; every requirement must be testable, traced to a business objective, and owned by a named business stakeholder; ambiguous language ('user-friendly', 'fast', 'flexible') must be challenged and quantified at elicitation.

What good looks like:

- Each requirement carries a unique ID, priority (MoSCoW or weighted), owner, source, and status.
- A requirements traceability matrix links every BRD requirement to at least one test case and one business objective.
- Non-functional requirements (performance, security, compliance) are explicitly scoped, not deferred to the technical team.
- Business stakeholders have formally signed off on the baselined BRD, not just attended a review meeting.
- Change requests against the baseline are tracked with impact assessed before approval.

Common pitfalls:

- Requirements written as solution designs ('the system shall use a dropdown menu') rather than business needs.
- Gold-plating: requirements added late by vocal stakeholders without formal prioritization or impact analysis.
- Passive voice and ambiguous quantifiers ('the system should be responsive') that cannot be tested.
- BRD signed off by IT rather than the business owner, invalidating the authority of the document.
- No traceability matrix, so requirements are lost or untested between BRD and UAT.

Maturity (1-5): L1 Ad hoc - requirements communicated verbally or in email threads; L2 Defined - a BRD template exists but requirements are inconsistently written and rarely traced; L3 Managed - structured elicitation, MoSCoW prioritized, traced to objectives, business-signed baseline; L4 Integrated - requirements management tooling with live traceability and automated change impact; L5 Optimizing - requirements metrics (defect origin, churn rate) feed continuous elicitation and estimation improvement.

Artifact #7 — Technical Requirements / Functional Specification

Purpose: Translates business requirements into technical and functional requirements engineering can build against. Approved by the technical lead and the business owner.

When you use it: Plan phase, after BRD approval, before significant development.

Owner: Engineering lead or architect drafts; technical owner approves; business owner acknowledges.

Cadence: One-time creation; versioned as architecture or major design decisions evolve.

Where it lives: Templates Pack 5.

Sections / contents:

Section	Contents / fields
Document control	Version, owners, status, linked BRD
Solution overview	What's being built in technical terms
Architecture	System context, high-level architecture, technology stack, alternatives considered
Functional requirements	ID, requirement, linked BR, acceptance criterion
Non-functional requirements	Performance, scalability, availability, reliability, security, privacy, usability, maintainability, observability, compliance
Data model	Entities, relationships, classification
Integrations & interfaces	Systems, integration types, directions, frequencies
Security design	Auth, authorization, encryption, secrets, audit, threat model
Deployment & operations	Environments, pipeline, DR, on-call
Open technical questions	Carry to Decisions & Changes Log when resolved
Approvals	Tech owner, architecture review, security, business owner ack

AI enablement

- Generate a draft Tech Spec from the BRD by pattern-matching against architecture in similar past projects.
- Validate that every BR row has at least one supporting FR or NFR.
- Detect missing non-functional requirements by comparing against checklists.
- Surface technical debt and architecture risks introduced by the proposed approach.

Note: The most-skipped section is non-functional requirements. They're the most expensive to retrofit — performance, security, and reliability requirements should be set early.

PRACTITIONER REFERENCE

Standards & method: Grounded in IEEE 29148:2018 (Systems and Software Requirements) and BABOK v3 (Solution Evaluation). For security-sensitive systems, ISO/IEC 27001 Annex A controls inform non-functional requirements. Method: translate BRD business requirements -> decompose into functional and non-functional specifications -> model (UML, data flow, API contracts) -> validate against BRD traceability -> baseline for development.

Guiding principles: Every functional requirement traces to a BRD requirement; non-functional requirements are quantified with measurable acceptance criteria; the specification is the contract between business and engineering; assumptions about external system behavior must be explicitly stated and validated with owners.

What good looks like:

- All functional requirements carry unique IDs with bidirectional traceability to BRD and downstream test cases.
- Non-functional requirements specify numeric acceptance thresholds (e.g., 'p95 response time <= 300ms under 500 concurrent users').

- Data models, API contracts, and interface specifications are included, not referenced as TBD.
- Security and compliance requirements are called out in a dedicated section with control references (e.g., ISO/IEC 27001 A.8).
- The specification has been peer-reviewed by both the technical lead and a business analyst before baselining.

Common pitfalls:

- Functional specs written by developers for developers, with no business stakeholder validation.
- Non-functional requirements stated qualitatively ('the system shall be secure and scalable') with no measurable threshold.
- Interface and integration specifications deferred to 'design phase', causing late-breaking surprises.
- Traceability to BRD absent, so requirements slip between documents undetected.
- Specification version-controlled informally, causing developers to build from different versions.

Maturity (1-5): L1 Ad hoc - specs in developer notes or Slack threads; L2 Defined - a written spec exists but NFRs are vague and traceability is absent; L3 Managed - bidirectional traceability, quantified NFRs, peer-reviewed and baselined; L4 Integrated - spec tooling with automated traceability coverage reporting and defect linkage; L5 Optimizing - specification quality metrics (defect escape rate, rework from spec gaps) drive continuous improvement.

Artifact #11 — RAID Log

Purpose: Single integrated log for Risks, Assumptions, Issues, and Dependencies. These four are managed together because they interact.

When you use it: Built during Plan; reviewed weekly throughout Execute and Monitor.

Owner: TPM owns; each entry has a named owner.

Cadence: Weekly review at status meeting; ad-hoc for new high-severity items.

Where it lives: Workbook tab 'RAID Log' with auto-scoring and color coding.

Sections / contents:

Section	Contents / fields
ID	Sequential identifier
Type	Risk / Assumption / Issue / Dependency
Description	Plain-language description
Likelihood × Impact	Auto-scored High/Medium/Low; combined score for prioritization
Status	Open / Mitigating / Monitoring / Closed / Realized
Owner	Single named person
Dates	Date raised, target close
Mitigation / response plan	For risks: prevention/response. Issues: resolution. Dependencies: who we're chasing. Assumptions: validation.

AI enablement

- Surface risks from chat/email patterns before they're formally logged.
- Score likelihood × impact based on historical similar risks across the org.

- Auto-route risks to the right owner based on type and project phase.
- Predict which risks will become issues based on early warning signals.

Note: The reason this is one log instead of four: the same item often shifts categories (assumption fails → becomes a risk → becomes an issue). Keeping them together preserves history.

Keywords: risk register, risks register, risk log, issues register, action register, dependency register, risk and issue tracking

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Uncertainty performance domain) and PRINCE2 7 risk and issue management themes. RAID = Risks, Actions, Issues, Dependencies (or Decisions). Method: log → categorize → assign owner → assess (for risks: probability x impact; for issues: urgency x impact) → respond → track to closure → escalate per threshold.

Guiding principles: A risk (may happen) and an issue (has happened) are different states requiring different responses and must never be merged; every item has exactly one named owner; actions have a due date and a completion criterion, not just a target; dependencies must be actively tracked against external owners, not assumed to self-manage.

What good looks like:

- RAID is reviewed at every project status meeting; no item is older than two review cycles without a documented update.
- Risks carry inherent and residual scores separately, showing the impact of mitigation actions.
- Issues have urgency x impact scores with an escalation threshold (e.g., any Critical issue escalates to SteerCo within 48 hours).
- Dependencies are tracked with the named external owner, the agreed delivery date, and a flag when at risk.
- Closed items are archived, not deleted, providing an audit trail and lessons-learned input.

Common pitfalls:

- RAID log created at initiation and never updated; becomes a graveyard of stale entries.
- Risks and issues mixed in the same rows, obscuring what needs a response versus what needs a mitigation.
- 'Accept' used for risks with no documented rationale, effectively meaning 'ignore'.
- Actions logged without a due date or owner, making them unenforceable.
- Log shared with all project staff including sensitive risk assessments that should be restricted.

Maturity (1-5): L1 Ad hoc - risks and issues managed in the PM's inbox; L2 Defined - a RAID log exists but is updated sporadically and owners are unclear; L3 Managed - weekly review, single owners, inherent vs. residual scored, escalation thresholds defined; L4 Quantified - exposure trended over time, dependency health scored, risk reserves modeled; L5 Optimizing - predictive risk analytics and portfolio-level RAID aggregation feed executive decision-making.

Artifact #12 — Schedule & Milestone Tracker

Purpose: Top-level project schedule showing major milestones, deliverables, owners, and status. Detailed task management lives in the work-tracking tool.

When you use it: Built during Plan; updated weekly throughout Execute.

Owner: TPM owns; deliverable owners update status.

Cadence: Weekly update at minimum; immediately on milestone shifts.

Where it lives: Workbook tab 'Schedule' with status conditional formatting.

Sections / contents:

Section	Contents / fields
Milestone / deliverable	Name and brief description
Owner	Single DRI
Phase	Initiate / Plan / Execute / Monitor / Close
Planned dates	Planned start, planned end
Actual dates	Actual end (when complete)
Status	Not Started / In Progress / Complete / Delayed / At Risk / Blocked
Dependencies	What must complete first; cross-reference RAID Log

AI enablement

- Forecast slippage on milestones based on velocity, blockers, and past similar work.
- Suggest schedule re-sequencing when dependencies shift.
- Detect when a milestone marked 'On-Track' is actually trending Off-Track based on activity signals.
- Auto-update milestone status from the work-tracking tool's actuals.

Note: This is not a Gantt chart — Gantt views belong in the work-tracking tool. This artifact is the executive-readable summary.

PRACTITIONER REFERENCE

Standards & method: Governed by PMI PMBOK 7 (Planning performance domain) and Schedule Management per PMI Practice Standard for Scheduling. Method: define milestones from WBS -> set baseline dates -> track actual vs. planned on a defined cadence -> calculate schedule variance (SV) and SPI -> forecast completion (EAC schedule) -> escalate at defined thresholds.

Guiding principles: Milestones must be binary: either achieved or not - 90% complete is not a milestone state; schedule variance must be reported against the approved baseline, not a rolling revision; forecast to complete is more decision-useful than percent complete; no milestone is 'on track' without evidence, not assertion.

What good looks like:

- Each milestone has a binary entry/exit criterion so achievement is objective and unambiguous.
- Baseline dates are locked and visible alongside current forecast dates, making slippage explicitly visible.
- Schedule Performance Index (SPI) is calculated and trended; SPI < 0.9 automatically triggers a recovery plan.
- Critical-path milestones are distinguished from summary milestones, and float consumption is reported weekly.
- Forecast completion date is recalculated each period and compared to contractual or commitment dates with a RAG status.

Common pitfalls:

- Milestones defined as activities ('complete testing') rather than outcomes ('test exit criteria passed and signed off').

- Baseline re-set whenever slippage occurs, permanently hiding true schedule performance.
- Percent complete reported subjectively by task owners without a defined measurement method.
- All milestones reported green until the week they are missed, with no early warning from trends.
- Tracker maintained separately from the integrated project plan, creating version conflicts.

Maturity (1-5): L1 Ad hoc - milestone dates managed in the PM's calendar; L2 Defined - a list of milestones with dates exists but no baseline or variance tracking; L3 Managed - baselined, SPI calculated, RAG thresholds defined, SteerCo reported; L4 Quantified - trend-based EAC forecasting, critical-path float monitored, recovery plans triggered by metrics; L5 Optimizing - predictive schedule analytics and portfolio-level milestone health feed resource reallocation decisions.

Artifact #13 — Resource Plan

Purpose: Identify who is on the project, in what role, at what allocation, and at what cost. Forms the basis for both labor budget and capacity planning.

When you use it: Built during Plan; updated as team composition changes.

Owner: TPM owns; resource managers approve allocations from their teams.

Cadence: Weekly review at status meeting; immediate update on team changes.

Where it lives: Workbook tab 'Resources' with auto-calculated allocation summaries.

Sections / contents:

Section	Contents / fields
Identification	Name, role on project, home department
Type	FTE / Contractor / Vendor / Part-time / Advisor
Allocation	% of time on this project
Duration	Start date and end date on the project
Rate	Hourly or loaded rate (used in Budget tab)
Notes	Specific responsibilities, dependencies on other projects, skills
Summary metrics	Total FTE allocation, total contractor allocation, headcount

AI enablement

- Forecast resource conflicts across projects in the portfolio before they happen.
- Recommend reassignments when a key resource is pulled onto another priority.
- Track skill coverage gaps and recommend training or hiring.
- Detect over-allocation across the portfolio (people booked >100%).

Note: Allocations exceeding 100% across projects are a portfolio-level problem — surface them to PMO leadership.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Team performance domain) and Resource Management per PMI Practice Standard for Work Breakdown Structures. For programs, references MSP resource management principles. Method: identify resource categories (people, tools, budget) -> estimate demand by role and period -> assess supply constraints -> resolve conflicts -> baseline resource plan -> track actual vs. plan and reforecast.

Guiding principles: Resource demand must be driven by the WBS, not estimated top-down from budget; over-allocation on the critical path is a schedule risk that must be mitigated, not absorbed; named resources carry knowledge dependencies that a generic FTE count conceals; resource plans must include ramp-up and transition time, not just steady-state.

What good looks like:

- Resource demand is built bottom-up from the WBS, with hours estimated per work package per role per period.
- Named critical resources are identified and their availability confirmed (not assumed) against the project calendar.
- Over-allocations are resolved through leveling before the plan is baselined, not post-hoc.
- Actual utilization is tracked against plan each period, with variance triggers (e.g., >15% deviation) prompting a reforecast.
- The plan explicitly covers onboarding/ramp time, knowledge transfer at transitions, and vendor resource dependencies.

Common pitfalls:

- Resource plan is a headcount table with no link to the schedule or WBS, making it unenforceable.
- Availability assumed at 100% with no allowance for meetings, leave, BAU responsibilities, or ramp-up time.
- Named critical individuals (e.g., sole subject-matter experts) with no identified backup, creating single points of failure.
- Resource conflicts between projects not escalated to the resource owner or portfolio manager.
- Plan never updated after initiation; actuals tracked in a separate system with no reconciliation.

Maturity (1-5): L1 Ad hoc - resource needs communicated informally when someone is needed; L2 Defined - a resource list exists by role but with no demand-to-schedule linkage or availability validation; L3 Managed - WBS-driven demand, named resources confirmed, over-allocations resolved, actuals tracked; L4 Integrated - resource plan integrated with schedule and cost baseline, portfolio-level conflict resolution in place; L5 Optimizing - predictive capacity modeling and skills-gap analytics feed portfolio resourcing and workforce planning decisions.

Artifact #14 — Project Budget

Purpose: Track approved budget against actual spend by category. Provide variance analysis and forecast at completion (EAC) for governance.

When you use it: Built during Plan; updated at every month-end close.

Owner: TPM owns; Finance partner reviews.

Cadence: Monthly close minimum; weekly review for high spend velocity.

Where it lives: Workbook tab 'Budget' with formulas for variance, % used, EAC, VAC.

Sections / contents:

Section	Contents / fields
Header	Total approved budget, currency, as-of date
Categories	Labor (internal/contractor), Vendors/SOWs, Software, Hardware, Travel, Training, Comms, Contingency, Other
Per category	Planned, Committed (under contract), Actual to date, Variance, % used, Notes

Section	Contents / fields
Section	Contents / fields
Totals	Auto-summed across categories
Forecast	Estimate at completion (EAC), Variance at completion (VAC), Burn rate

AI enablement

- Forecast EAC dynamically based on burn rate and remaining work.
- Flag spend categories trending over budget before month-end close.
- Identify cost optimization opportunities by comparing to similar past projects.
- Auto-classify expenses into budget categories from invoice and PO data.

Note: 'Committed' is the often-missed category — money under contract but not yet paid.

Excluding it is how budgets surprise people at month-end.

PROCURE

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Project Work and Measurement performance domains) and ISO 21500 clause 4.3.24. Method: define WBS cost accounts -> estimate bottom-up (analogous / parametric / three-point) -> aggregate with contingency reserve (identified risks) and management reserve (unknown unknowns) -> baseline -> control via Earned Value Management (PV, EV, AC, CPI, SPI).

Guiding principles: Every dollar is traceable to a WBS element and an owner; separate contingency reserve from management reserve and track both; re-forecast the EAC at every reporting cycle, not just at stage gates; budget is a control tool, not an accounting ledger.

What good looks like:

- EVM metrics (CPI, SPI) reported weekly; CPI < 0.9 triggers a formal recovery plan.
- Contingency draw-down is logged against the risk register; spend on unknown unknowns is tracked from management reserve separately.
- Cost baseline is version-controlled; every change flows through an approved change request before the baseline moves.
- Forecast at Completion (EAC) is recalculated each period using actual CPI, not original assumptions.
- Budget reports reconcile to the GL or finance system within a defined tolerance (e.g., +/-0.5%).

Common pitfalls:

- Contingency and management reserve pooled into one line and raided at will.
- EAC held flat to avoid uncomfortable conversations with the sponsor.
- Budget tracking done in a spreadsheet divorced from the project schedule, so cost and schedule variances cannot be correlated.
- No formal baseline change control; verbal approvals erode the baseline silently.
- Bottom line is monitored but cost-account-level variances are never investigated.

Maturity (1-5): L1 Ad hoc - lump-sum guess, no WBS traceability; L2 Defined - line-item budget exists, tracked monthly; L3 Managed - EVM applied, CPI/SPI reported, reserves separated; L4 Quantified - three-point estimates, Monte Carlo on reserves, EAC trended; L5 Optimizing - continuous re-forecast integrated with schedule and risk analytics, portfolio-level cost intelligence.

Artifact #15 — Request for Proposal (RFP)

Purpose: Solicitation document sent to candidate vendors. Defines what we're buying, the evaluation process, and what vendors must submit.

When you use it: Procure phase, after BRD and Tech Spec are stable enough to bid against.

Owner: TPM partners with Procurement; business owner approves scope.

Cadence: One-time per procurement.

Where it lives: Templates Pack 9 has fillable RFP.

Sections / contents:

Section	Contents / fields
Introduction	About us, purpose of this RFP
Background & context	What vendors need to know to propose well
Scope of work	In scope, out of scope
Requirements	Mandatory (Must-Have) and Desirable (scored), with vendor response columns
Service levels	Required SLAs
Security, compliance, privacy	Certifications, data handling, audit rights
Section Co	Contents / fields
Implementation approach Ve	Vendor describes their proposed approach
Pricing St	Structured template — comparable responses
Vendor qualifications Co	Company, customer base, references, team
Evaluation criteria We	Weighted criteria, transparent to vendors
Process & timeline RF	RFP issued through contract signed
Submission instructions Fo	Format, method, deadline, single contact
Terms & conditions St	Standard procurement terms

AI enablement

- Generate an RFP draft from the BRD and Technical Spec, ensuring requirements are testable and bid-able.
- Compare vendor responses to the structured RFP and produce a normalized comparison automatically.
- Detect inconsistencies between vendor proposal claims and reference customer reports.
- Flag when vendor responses use marketing language without committing to specific deliverables or SLAs.

Note: A well-structured RFP saves weeks of evaluation later because responses are comparable. A bad RFP produces marketing brochures.

PRACTITIONER REFERENCE

Standards & method: Grounded in CIPS (Chartered Institute of Procurement and Supply) sourcing methodology and FAR/DFAR principles for regulated contexts. Method: define requirements and evaluation criteria -> draft scope and terms -> issue RFP with mandatory question structure -> manage Q&A (addenda) -> receive proposals -> evaluate against rubric -> shortlist -> BAFO (Best and Final Offer) if warranted -> award recommendation.

Guiding principles: Scope must be outcome-based, not solution-prescriptive; evaluation criteria are locked before proposals are opened; the RFP is a legal document - ambiguity creates liability; confidentiality and equal treatment of all bidders is non-negotiable.

What good looks like:

- Mandatory requirements (MUSTs) are binary and verifiable, not matters of opinion.
- All bidder questions are answered via formal addenda shared equally with all parties.
- Pricing structure matches the engagement model (fixed-price, T&M, outcome-based) and risk allocation is explicit.
- Evaluation criteria and weightings are published in the RFP so bidders can self-qualify.
- A clear contract terms section reduces negotiation cycle time post-award by pre-positioning key protections (IP, liability caps, data privacy).

Common pitfalls:

- Scope so vague that proposals are incomparable and evaluation becomes subjective.
- Evaluation criteria added or re-weighted after proposals are received.
- Incumbent vendor given pre-RFP briefings that other bidders do not receive.
- No minimum response format required, resulting in apples-to-oranges comparison.
- Legal and procurement not involved until after the RFP is drafted, requiring a full redraft.

Maturity (1-5): L1 Ad hoc - informal vendor outreach, no RFP structure; L2 Defined - standard RFP template used, criteria exist; L3 Managed - scoring rubric locked pre-receipt, Q&A addenda issued, legal reviewed; L4 Quantified - total cost of ownership modeled, risk-adjusted scoring applied; L5 Optimizing - market intelligence informs requirements, supplier capability data feeds selection model.

Artifact #16 — RFP Scoring Rubric

Purpose: Used by the evaluation team to score vendor responses against the criteria stated in the RFP.

When you use it: Procure phase, after vendor proposals are received.

Owner: Evaluation team chair (typically TPM or business owner).

Cadence: One-time per procurement; calibrated as a group after independent scoring.

Where it lives: Templates Pack 10 has fillable scoring rubric and reference check template.

Sections / contents:

Section	Contents / fields
Scoring methodology	1–5 scale with rubric definitions
Per-vendor scorecard	Criteria, weight, score, weighted result, evidence
Evaluator calibration	Independent scoring, gap discussion, revised scores
Section C	Contents / fields

Section	Contents / fields
Reference check template S	structured questions across 3 references
Award recommendation R	recommended vendor, strengths, gaps, mitigation, sign-off

AI enablement

- Auto-extract vendor responses to each requirement and produce a side-by-side comparison.
- Pre-score requirement-fit dimensions based on response content; humans review and confirm.
- Detect score outliers across evaluators and surface for calibration discussion.
- Validate vendor claims against reference customer feedback and public benchmarks.

Note: Scoring should be done independently first, then calibrated as a group. Group scoring without independent baselines surfaces only the loudest voice.

PRACTITIONER REFERENCE

Standards & method: Aligned to CIPS evaluation best practice and BABOK v3 (stakeholder needs assessment). Method: derive criteria directly from RFP requirements -> assign weights that reflect business priorities -> define behavioral anchors per score level (1-5 or 1-10) -> conduct independent blind scoring -> calibrate scores in a structured consensus session -> compute weighted totals -> document rationale for award recommendation.

Guiding principles: Criteria weights are set before proposals are read; each score level has an observable, written anchor - not a number; scorers evaluate independently before convening; the rubric exists to defend the decision, not just to make it.

What good looks like:

- Every criterion has 3-5 written anchor statements so two independent evaluators score the same proposal within one point of each other.
- Weights sum to exactly 100% and reflect documented business priorities (e.g., capability > price in a complex IT engagement).
- A conflict-of-interest declaration is signed by each evaluator before proposals are distributed.
- The rubric distinguishes mandatory pass/fail gates from scored criteria; a fail on a mandatory gate disqualifies without scoring.
- Final scores and written rationale are archived to support a debrief or protest response.

Common pitfalls:

- Weights reverse-engineered to justify a preferred vendor after scores are tallied.
- Anchor descriptions are so generic ('meets expectations') that they add no calibration value.
- Price given 50%+ weighting on a complex professional services engagement, incentivizing low-ball bids.
- Evaluators discuss scores before independent scoring, creating anchoring bias.
- No audit trail of individual scores; only the consensus total is retained.

Maturity (1-5): L1 Ad hoc - gut-feel selection, no rubric; L2 Defined - rubric exists, weights assigned; L3 Managed - behavioral anchors defined, independent scoring enforced; L4 Quantified - inter-rater reliability measured, TCO modeled alongside scored criteria; L5 Optimizing - historical vendor performance data integrated into scoring baseline.

Artifact #17 — Statement of Work (SOW)

Purpose: The contractual document defining scope, deliverables, schedule, pricing, and acceptance for vendor work.

When you use it: Procure phase, after vendor selection and before work begins.

Owner: TPM partners with Procurement and Legal.

Cadence: One-time per engagement; amended via Change Orders.

Where it lives: Templates Pack 11.

Sections / contents:

Section	Contents / fields
Document control	SOW ID, parties, MSA reference, effective date, term
Background	Why this engagement exists
Scope of work	Vendor responsibilities, client responsibilities, out of scope
Deliverables	ID, name, description, acceptance criterion, target date
Schedule & milestones	Linked to deliverables
Pricing & payment	Engagement type, total fees, payment schedule, expenses
Acceptance process	How deliverables are reviewed and accepted
Project governance	Vendor PM, client PM, status reporting, escalation
Change control	Process for SOW changes via Change Order
Section	Contents / fields
Service levels	SLAs
Personnel	Key personnel named, replacement consent
Issue resolution	Escalation tiers and resolution timing
Confidentiality, IP, data	Standard contractual protections
Signatures	Both parties

AI enablement

- Auto-generate SOW first draft from the awarded RFP response and the BRD.
- Detect ambiguous deliverable language ('best effort', 'reasonable timeframe') and prompt for measurable rewrites.
- Compare against template SOWs for similar past engagements to flag missing standard clauses.
- Track SOW execution status against deliverables and milestones, surfacing slippage early.

Note: Where most vendor disputes originate is in vague SOWs — be specific. 'Acceptance criterion' is the single most-skipped field and the single most-disputed during projects.

EXECUTE & MONITOR

PRACTITIONER REFERENCE

Standards & method: Grounded in CIPS contract management standards and FAR Part 11/12 (commercial item and statement of work requirements). Method: define deliverables with acceptance criteria -> specify performance standards (KPIs/SLAs) -> define assumptions and

exclusions explicitly -> establish change control mechanism -> price to a work breakdown or deliverable schedule -> include payment milestones tied to deliverable acceptance.

Guiding principles: Every deliverable has a named acceptance criterion - not a completion date alone; assumptions and out-of-scope items are as important as in-scope; change begins where the SOW ends - protect both parties; payment gates are tied to accepted deliverables, not calendar dates.

What good looks like:

- Each deliverable section answers: what, format, quality standard, acceptance test, responsible party, and due date.
- Assumptions section is specific enough that a dispute could be resolved by re-reading it.
- SLAs/KPIs include measurement methodology, reporting frequency, and remedy for breach.
- Payment milestones are linked to signed-off deliverables, preventing payment for incomplete work.
- A formal change control clause defines the written process for scope changes, pricing adjustments, and authorization levels.

Common pitfalls:

- Deliverables described as activities ('will conduct workshops') rather than outcomes ('will deliver a signed-off requirements specification').
- Assumptions section omitted; disputes arise from unstated expectations.
- Acceptance criteria are absent; vendor self-certifies completion.
- Payment is time-based rather than milestone-based, removing vendor accountability.
- IP ownership, data rights, and confidentiality obligations are left to negotiation post-signature.

Maturity (1-5): L1 Ad hoc - verbal or email agreement, no formal SOW; L2 Defined - SOW document exists, deliverables listed; L3 Managed - acceptance criteria and SLAs defined, change control clause present; L4 Quantified - SLA performance tracked and reported, payment gates enforced with evidence; L5 Optimizing - SOW KPIs feed vendor scorecard, continuous improvement obligations embedded.

Artifact #18 — Weekly Status Report

Purpose: The recurring snapshot of project health. Replaces meetings, reduces back-and-forth, and creates a historical record of how the project trended over time.

When you use it: Throughout Execute and Monitor — weekly cadence is standard.

Owner: TPM authors; sponsor and steering committee are the primary audience.

Cadence: Weekly, distributed by end of day on a fixed day.

Where it lives: Workbook tab 'Status Reports' (running history — append a new row each week).

Sections / contents:

Section	Contents / fields
Header	Report date, reporting period, reported by
Overall status	On-Track / At-Risk / Off-Track with rationale (rationale required when not On-Track)
Key accomplishments this	What shipped, completed, milestones hit
Section	Contents / fields

period

Planned for next period	What's targeted next cycle
Top risks / issues	From RAID Log — top 3–5 with status
Asks / blockers needing	What you need from leadership

escalation

Metrics snapshot (optional) Schedule variance, budget variance, milestone completion %

AI enablement

- Auto-draft the status row from the other workbook tabs (Schedule, RAID, Budget, Decisions) each cycle.

- Detect when the reported R/A/G doesn't match the underlying data and prompt for explanation.

- Personalize the status report per audience — exec summary vs working team detail.

- Surface trends over multiple weeks: is the status truly stable, or steadily worsening?

Note: Status reports should be readable in 2 minutes. If yours takes longer, you're writing the wrong thing.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Measurement and Delivery performance domains) and PMI Practice Standard for Project Reporting. Method: collect actuals (schedule, cost, scope) -> compute status (RAG) against baseline -> identify variances -> document decisions and next actions -> distribute to defined audiences on a fixed cadence.

Guiding principles: RAG status reflects forecast, not feelings - Red means action required now; every variance has a root cause and a recovery action, not just a description; the status report is a decision-enablement tool, not a comfort document; no surprises at SteerCo that were not flagged in the weekly report.

What good looks like:

- RAG is defined by objective thresholds (e.g., SPI < 0.9 = Red) documented in the project communications plan; not assigned subjectively.
- Each issue or risk section includes owner, next action, and due date - not just a description.
- The report is one page or dashboard-format; narrative is reserved for exceptions only.
- Trend data (last 4 weeks of RAG) is visible so the reader can distinguish a new problem from a chronic one.
- Published on a fixed day/time each week; late reports are treated as a governance deficiency.

Common pitfalls:

- Chronic Amber masking real Red status to avoid sponsor discomfort.
- Report describes activities completed ('we held the workshop') rather than progress against baseline.
- Actions carried forward week-over-week with no resolution or escalation.
- Too long to read; executives skip to the end, missing critical context.

- Distributed to everyone on the contact list rather than a tiered audience (team vs. sponsor vs. SteerCo).

Maturity (1-5): L1 Ad hoc - verbal updates, no standard format; L2 Defined - template used, distributed weekly; L3 Managed - RAG thresholds objective, variances have root causes and actions; L4 Quantified - EVM data integrated, trend lines visible, forecast accuracy tracked; L5 Optimizing - automated data feeds, predictive schedule/cost analytics surfaced in the report.

Artifact #19 — Decisions & Changes Log (combined)

Purpose: Single append-only record of every key project decision and every approved scope/schedule/budget change. Both record 'something changed, here's why' — combining them prevents the most common PM confusion ('which log do I put this in?') and ensures one place to look.

When you use it: Throughout Execute — append entries as decisions are made or change requests approved.

Owner: TPM maintains; decision-makers and change approvers contribute.

Cadence: Append as events occur; review monthly to ensure nothing was missed.

Where it lives: Workbook tab 'Decisions & Changes' with Type column to filter.

Sections / contents:

Section	Contents / fields
ID	Sequential identifier
Date	When the decision was made or change approved
Type	Decision / Change Request — Scope / Change Request
Section	Contents / fields — Schedule / Change Request — Budget / Change Request — Resources / Multiple
Description	What was decided or what changed, in plain language
Rationale	Why this option vs alternatives — preserves reasoning for future review
Impact (for changes)	Schedule impact (days), budget impact (\$), scope impact
Decision-maker / approver	Single named person with authority
Stakeholders consulted	Who provided input
Status	Active / Superseded / Reversed (decisions); Submitted / Under Review / Approved / Rejected / Implemented (changes)

AI enablement

- Extract decisions and change events from meeting transcripts and chat threads automatically.
- Detect when a current decision contradicts a prior one and flag for explicit supersedence.
- Auto-classify Type from description — does this need a formal change workflow or is it a decision?
- Surface decisions whose rationale no longer holds (assumptions changed) and prompt for review.

Note: Append-only — never delete. If a decision is reversed or a change is rolled back, mark the original superseded and add a new row. The history matters as much as the current state.

PRACTITIONER REFERENCE

Standards & method: Grounded in PMI PMBOK 7 (Governance and Uncertainty domains) and PRINCE2 Change Authority framework. Method for changes: identify change -> classify (scope / schedule / cost / quality) -> assess impact against baseline -> obtain authorization at the correct level -> update baseline and affected plans -> communicate. Method for decisions: log the decision, its rationale, the decider, and the date; mark superseded decisions explicitly.

Guiding principles: A decision log is a memory prosthetic for the project - it prevents revisiting closed questions; every change to scope, cost, or schedule flows through a single written record; authorization levels are pre-defined and enforced, not negotiated per change; changes and decisions are different objects and should be structured differently.

What good looks like:

- Change requests include baseline impact, options analysis (minimum two options), and a recommended course of action - not just a description of the change.
- Authorization tiers are enforced: PM authority, sponsor authority, and SteerCo authority have defined thresholds (e.g., by cost and schedule impact).
- Decisions include the question, the options considered, the rationale for the choice, and the date - enabling a new team member to reconstruct the logic.
- Log is reviewed at every SteerCo; open change requests older than the defined SLA are escalated automatically.
- Baseline updates are traceable to an approved change request; no undocumented baseline moves.

Common pitfalls:

- Change log used only for big changes; small scope additions accumulate into uncontrolled scope creep.
- Decisions logged as outcomes with no rationale; re-litigation occurs because the reasoning is unknown.
- Verbal approvals accepted; the change is implemented before the request is written.
- Authorization levels undefined; every change goes to the sponsor regardless of materiality.
- Log is a one-way archive; approved changes are never reflected in the schedule, budget, or RAID log.

Maturity (1-5): L1 Ad hoc - changes managed verbally; L2 Defined - log exists, changes recorded; L3 Managed - impact assessed, authorization tiers enforced, baseline updated on approval; L4 Quantified - change velocity and cost impact trended, variance-at-completion recalculated per approved change; L5 Optimizing - change patterns analyzed to improve estimation and scope definition at initiation.

Artifact #20 — Steering Committee / Governance Pack

Purpose: The recurring deliverable for executive governance. Combines status, key decisions needed, risks requiring leadership attention, and budget into a single pack for the steering committee.

When you use it: Throughout Execute and Monitor — typically monthly for large programs, bi-weekly for high-velocity projects.

Owner: TPM compiles; sponsor presents.

Cadence: Monthly or bi-weekly; aligned to steering meeting schedule.

Where it lives: Document (typically PowerPoint or Google Slides), assembled from workbook tabs.

Sections / contents:

Section	Contents / fields
Cover slide	Project name, period, status, sponsor, presenter, date
Executive summary	1-page: status, top wins, top concerns, decisions needed today
Status overview	Schedule, scope, budget, resources — each with R/A/G + commentary
Milestones	Recently completed, upcoming, slipping
Top risks & issues	From RAID Log — top 5, with mitigation status
Decisions needed	What the steering committee must decide this meeting
Asks	Resources, budget, executive sponsorship needs
Appendix (optional)	Detailed schedule, full RAID, financial detail — for reference

AI enablement

- Assemble the pack automatically from workbook tabs each cycle — TPM reviews and refines, doesn't build from scratch.
- Tailor the pack per steering audience (board vs working steering vs sponsor 1:1).
- Surface decisions needed by analyzing what's blocked or pending across the workbook.
- Highlight items that have been on the agenda multiple meetings without resolution.

Note: The executive summary should fit on one slide. If the steering committee can't make the decisions you need them to make from the pack, you've overloaded it with status and underloaded it with asks.

TEST & DEPLOY

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Stakeholder and Governance performance domains), PRINCE2 (Directing a Project process), and MSP Programme Governance. Method: define governance structure and ToR -> prepare pack with exception-level content only -> distribute in advance per agreed SLA -> run structured meeting (review, decide, escalate, direct) -> publish minutes with decisions and actions within 24 hours.

Guiding principles: SteerCo makes decisions and removes obstacles - it does not review status line by line; pack is distributed 48 hours in advance; every agenda item is labeled as Inform, Discuss, or Decide; exceptions are surfaced proactively - the sponsor is never surprised in the meeting.

What good looks like:

- Pack opens with an executive summary: overall RAG, top-3 risks, decisions required today, and decisions made since last meeting.
- Each agenda item has a clear decision or direction request; no items are purely informational without a 'so what'.
- The Terms of Reference define quorum, voting authority, and escalation path; governance is not improvised.
- Actions from prior meetings are tracked to closure; overdue actions are highlighted, not buried.
- Minutes are published within 24 hours with decisions numbered and linked to the decisions log.

Common pitfalls:

- Pack doubles as a status report; SteerCo spends 45 of 60 minutes on slides that could have been read.
- Decisions required are not labeled as such; the meeting ends with ambiguous outcomes.
- Pack distributed same-day or at the meeting; sponsors have no time to prepare.
- No Terms of Reference; governance operates on convention and breaks down under pressure.
- Actions from prior meetings not reviewed; accountability is absent and issues recur.

Maturity (1-5): L1 Ad hoc - irregular meetings, no standard pack; L2 Defined - pack template used, meetings scheduled; L3 Managed - ToR documented, decisions labeled, minutes published within 24 hours; L4 Quantified - decision cycle time tracked, governance effectiveness measured against outcomes; L5 Optimizing - governance model benchmarked, continuously adapted to program risk profile and maturity.

Artifact #21 — UAT Plan & Test Cases

Purpose: User Acceptance Testing — the final test phase where the people who will actually use the system validate it does what they need. UAT is the business owner's tool, not engineering's.

When you use it: Test & Deploy phase, after engineering testing complete.

Owner: UAT lead (business-side, not eng).

Cadence: Per release; entry/exit gates are formal approvals.

Where it lives: Templates Pack 12 has fillable UAT Plan; Workbook tab 'UAT Log' for live test execution with auto-calculated pass rate.

Sections / contents:

Section	Contents / fields
UAT objectives & scope	What's being validated, what's out of scope
Approach	Environment, testers, session structure, defect logging
Entry criteria	What must be true before UAT starts
Exit criteria	What must be true before UAT signs off
Defect severity definitions	Critical / Major / Minor / Cosmetic with resolution requirements
Roles & responsibilities	UAT lead, testers, eng, TPM, business owner
Schedule	Preparation, execution waves, defect fix & retest, sign-off
Test cases	ID, description, linked requirement, test data, expected result, priority
Defect triage process	How defects are logged, triaged, fixed, retested
Sign-off	Formal acceptance from business owner

AI enablement

- Generate UAT test cases automatically from BRD requirements and user stories.
- Detect requirements that don't have test coverage and prompt for additional cases.
- Triage UAT defects: cluster similar issues, surface patterns, recommend severity.
- Predict UAT pass rate from early test execution and flag risk to go-live timeline.

Note: If UAT testers are proxies (BAs running the test, not real end users), you're not doing

UAT — you're doing integration testing in business clothing.

CLOSE

Related artifact (engineering scope)

The Engineering Test Plan (Engineering Artifact #E7) covers the broader engineering test plan including unit, integration, performance, security, accessibility, regression, and UAT phases.

UAT (this artifact) is one phase of that broader plan. If you're running UAT specifically, this is the artifact. If you're authoring the test plan that gates the broader engineering work, see the Engineering Test Plan.

PRACTITIONER REFERENCE

Standards & method: Grounded in IEEE 829 (Standard for Software and System Test Documentation) and ISTQB Foundation Level principles. Method: define UAT entry criteria -> derive test cases from business requirements (traceability matrix) -> assign business testers and owners -> execute test cycles -> log defects with severity and priority -> triage and retest -> obtain formal sign-off against exit criteria -> pass/fail decision by business owner.

Guiding principles: UAT verifies business fitness for purpose, not technical correctness - that is the job of SIT; every test case traces to a documented business requirement; no test case is 'passed' without a written expected result defined before execution; sign-off is a formal business decision, not a social convention.

What good looks like:

- A requirements traceability matrix links every test case to a specific business requirement; gaps in coverage are visible before execution begins.
- Expected results are written before testers execute; pass/fail is objective, not interpretive.
- Defect severity and priority are defined by the business, not the vendor; Critical defects block go-live without exception.
- Entry criteria (SIT complete, test data available, business testers trained) are enforced; UAT does not start until criteria are met.
- Exit criteria and sign-off authority are defined in the plan; a named business executive signs the go-live authorization.

Common pitfalls:

- Test cases written by developers or BAs instead of business users; UAT becomes a repeat of SIT.
- No expected results defined; testers decide pass/fail on the fly.
- Defect triage is informal; Critical defects deferred to post-go-live under schedule pressure.
- Test data is production data with no masking; data privacy obligations breached.
- Sign-off obtained under time pressure without full defect closure; go-live proceeds with known Critical defects.

Maturity (1-5): L1 Ad hoc - informal user testing, no documented cases; L2 Defined - test cases exist, defects logged; L3 Managed - traceability matrix complete, entry/exit criteria enforced, formal sign-off; L4 Quantified - defect density tracked by module, test cycle efficiency measured, coverage metrics reported; L5 Optimizing - risk-based test prioritization, automated regression integrated with UAT cycle, continuous quality feedback loop.

Artifact #22 — Lessons Learned Register

Purpose: Capture what worked and what didn't in a form that's reusable for future projects. Distinct from the Retrospective — the retro is the discussion, the register is the persistent record.

When you use it: Captured throughout the project, formalized at close.

Owner: TPM maintains during project; PMO maintains the cross-project repository.

Cadence: Append throughout; comprehensive review at close.

Where it lives: Workbook tab 'Lessons Learned'.

Sections / contents:

Section	Contents / fields
ID & date	When the lesson was captured
Category	Process / Tools / Comms / Staffing / Vendor / Technical / Strategic / Stakeholder
Lesson / observation	Plain-language insight
Recommendation for next time	What to do differently
Owner to share / apply	Who is accountable for propagating this lesson
Status	Captured / Shared / Applied / In knowledge base

AI enablement

- Surface candidate lessons from retro outputs, status reports, and post-incident reviews automatically.
- Match lessons to similar past lessons across the org — flag patterns of recurring issues.
- Recommend which prior lessons apply to a new project starting up.
- Track 'lesson decay' — captured lessons that aren't applied within X months of capture.

Note: A 'captured' lesson that never gets shared is worthless. PMO leadership should track the % of lessons that move from Captured to Applied as a maturity metric.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Team and Delivery performance domains) and ISO 21500 clause 4.3.37 (collect lessons learned). Method: gather inputs (retrospectives, stakeholder interviews, issue/risk log analysis) -> categorize by phase and knowledge area -> validate with team -> identify actionable recommendations -> submit to organizational knowledge base -> confirm integration into future project standards.

Guiding principles: A lesson not acted on is just a complaint; every lesson has a specific recommendation and an owner who will implement it; capture continuously throughout the project, not only at closeout; distinguish lessons about process from lessons about people to make them organizationally actionable.

What good looks like:

- Lessons are captured at each stage gate, not only at closeout; the closeout register is an aggregation, not a surprise.
- Each lesson includes: what happened, root cause, impact, and a specific actionable recommendation for future projects.
- The register is submitted to and accepted by a named organizational PMO or knowledge management function.
- At least one lesson per theme is traced to a change in a methodology artifact, template, or process standard.
- A follow-up review at 3-6 months post-closeout confirms whether recommended changes were implemented.

Common pitfalls:

- Register compiled in the last week under time pressure; team members have left and memory is poor.
- Lessons are vague ('better communication needed') with no root cause or actionable recommendation.
- Register filed and never referenced; no mechanism exists to surface it for the next project.
- Only problems are captured; positive practices that should be repeated are excluded.
- Blame language used; individuals named rather than systemic process failures identified.

Maturity (1-5): L1 Ad hoc - verbal debrief only, nothing documented; L2 Defined - register created at closeout; L3 Managed - captured at each stage, actionable recommendations, submitted to PMO; L4 Quantified - lessons categorized and trended across portfolio, recommendation adoption rate tracked; L5 Optimizing - lessons integrated into AI-assisted estimation, risk identification, and planning tools.

Artifact #23 — Project Closeout Report (with Benefits Realization)

Purpose: Final accounting of the project: what was delivered vs charter, final budget, what benefits were realized vs promised, and what handoffs are required.

When you use it: Close phase — after all deliverables accepted but before team disbands.

Owner: TPM authors; sponsor signs off.

Cadence: One-time at close; benefits realization may have follow-up reviews at 6 and 12 months.

Where it lives: Workbook tab 'Closeout'.

Sections / contents:

Section	Contents / fields
Header	Project name, closeout date, reported by
Final outcomes	Objectives met, success criteria, scope/schedule/budget vs original
Section	Contents / fields
Benefits realization	Expected value, realized to date, outstanding benefits, benefit owner post-closeout, measurement plan
Stakeholder feedback	Sponsor, business, team
Open items at close	Outstanding risks transferred, unfinished deliverables, operational handoff
Lessons & knowledge transfer	Top wins to repeat, top changes for next time, where lessons filed
Archive & documentation	Workbook archive, supporting docs, retention period
Approvals	Sponsor, PMO, Finance

AI enablement

- Auto-compile final outcomes by comparing closeout state to charter at every level.
- Predict realized benefits at 6 and 12 months from current trajectory and flag at-risk items.
- Generate the closeout report draft from workbook tabs — TPM reviews and refines.
- Match this project's outcomes against similar past projects to identify pattern wins and failures.

Note: The most-skipped section is Benefits Realization, and it's the most important. Charter said the project would deliver \$X — closeout reports whether it did, and assigns someone to track ongoing realization.

PROGRAM-LEVEL

Programs are coordinated sets of projects sharing a common strategic outcome. The artifacts in this section are the program-level equivalents of project artifacts — heavier because programs have more components, longer horizons, and benefits that materialize across initiatives, not just within one. Following PgMP-depth conventions: Program Charter, Program Governance & Integration Management, and Program Benefits Realization.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Delivery and Measurement performance domains), MSP Managing Benefits framework, and ISO 21500 clause 4.3.38 (close project). Method: confirm deliverable acceptance -> reconcile final cost and schedule against baseline -> assess benefits realized to date vs. plan -> document transition to operations -> release resources -> archive project records -> schedule benefits realization review(s) post-go-live.

Guiding principles: Closeout is a governance event, not an administrative chore; benefits realization extends beyond project end - a post-implementation review date must be committed at closeout; the report must be honest about variances from baseline, not reverse-engineered to show success; handoff to operations is confirmed in writing by the receiving owner.

What good looks like:

- Final cost and schedule variance against approved baseline are stated explicitly with root cause analysis - not normalized by referencing re-baselined figures only.
- Benefits realization section distinguishes: realized to date, forecast to be realized in 12 months, and benefits that will not be realized with explanation.
- A named business owner has signed a formal operations handover/acceptance document referenced in the report.
- Post-implementation review dates (typically 3 and 12 months) are committed with named owners before the project is formally closed.
- Lessons learned register is attached and confirmed as submitted to the organizational knowledge base.

Common pitfalls:

- Report declares success against a re-baselined schedule and budget, obscuring original variance.
- Benefits section lists outputs (system deployed) rather than outcomes (cost reduced by X%).
- No formal operations handover; support falls back to the project team after nominal closeout.
- Post-implementation review never scheduled; benefits are never measured.
- Report written by the PM alone and not reviewed by the sponsor or business owner before filing.

Maturity (1-5): L1 Ad hoc - project ends, no formal closeout; L2 Defined - closeout report produced, records archived; L3 Managed - variance analysis honest, operations handover signed, PIR scheduled; L4 Quantified - benefits tracked at 3 and 12 months, realized value vs. business case reported; L5 Optimizing - benefits data feeds portfolio investment decisions, continuous value realization framework in place.

Artifact #30 — Retrospective Pack

Purpose: Run a structured look-back to capture what worked, what didn't, and what changes for next time. The discussion itself; outputs feed the Lessons Learned Register.

When you use it: Sprint end (agile teams), phase boundaries, project close, after significant events.

Owner: TPM or Scrum Master facilitates; team participates.

Cadence: Per sprint for agile teams; phase-end and project-end for waterfall/hybrid.

Where it lives: Standalone facilitation pack — typically Miro/Mural board + post-meeting summary doc.

Sections / contents:

Section	Contents / fields
Retro context	Project/sprint, period, facilitator, participants, format, psychological safety norms
Goals & outcomes	Original objectives, actual outcomes, scope changes, KPIs, stakeholder satisfaction
What went well	Specific wins, why they worked, what made them possible, reusable beyond this project
What didn't go well	Issues (as systems, not people), impact, root cause via 5 Whys, contributing factors
Surprises & unknowns	What blindsided the team, failed assumptions, missed signals
Team health & sentiment	Workload sustainability, morale, burnout indicators, what energized/drained
Stakeholder feedback	Sources outside the immediate team — sponsor, customer, adjacent teams
Action items	3–5 max — specific change, owner, due date, success measure, status
Retro summary & distribution	Executive summary, top 3 wins, top 3 issues, action items, follow-up at 30/60/90

AI enablement

- Pre-populate retro inputs from sprint metrics, status reports, and chat sentiment patterns.
- Cluster team observations into themes during the retro to focus discussion.
- Track retro action items across sprints and flag those that get re-discussed without resolution.
- Detect 'retro fatigue' — declining engagement that signals the format needs to change.

Note: Cap action items at 3–5 — more and nothing actually changes. Keep all retros blameless: describe systems and conditions, not individuals.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Team and Stakeholder performance domains) and Agile Alliance retrospective practice derived from the Agile Manifesto principle of regular reflection. Method: set the stage -> gather data -> generate insights -> decide on actions -> close (Derby-Larsen Prime Directive governs psychological safety).

Guiding principles: Blame-free inquiry is non-negotiable; every session produces at least one time-boxed, owned action; insights are aggregated across sprints to reveal systemic patterns; the retrospective is a team ceremony, not a management audit.

What good looks like:

- Action items from the previous retrospective are reviewed first, closing the loop.

- Data gathering uses multiple formats (timeline, satisfaction histogram, silent writing) to surface diverse voices.
- Systemic themes are tracked across retrospectives, not treated as isolated events.
- Actions are SMART: named owner, specific change, and completion date before the session closes.
- Psychological safety is explicitly protected - facilitator is not the team's line manager.

Common pitfalls:

- Retrospective becomes a complaint session with no actions generated.
- Same issues recur sprint after sprint because prior actions were never completed.
- Facilitator dominates rather than drawing out quieter team members.
- Session skipped under schedule pressure - precisely when it is most needed.
- Actions assigned to 'the team' with no individual owner, guaranteeing non-delivery.

Maturity (1-5): L1 Ad hoc - no regular retrospective cadence; L2 Defined - regular sessions held, minimal structure; L3 Managed - structured format, actions tracked to completion; L4 Quantified - trend analysis across retrospectives, systemic impediments escalated; L5 Optimizing - retrospective insights feed continuous process improvement pipeline with measurable cycle-time outcomes.

Artifact #31 — Post-Incident Review Pack

Purpose: Everything that happens after an incident is closed: documentation, root cause analysis, customer communication, regulatory reporting, prevention, and team care. Distinct from incident response itself (real-time) — this is the aftermath. Corrective actions identified here feed the Post-Incident Action Tracker.

When you use it: Within 5 business days of incident closure for SEV-1 and SEV-2; per policy for lower severities.

Owner: Incident Commander leads the review; engineering, security, comms, legal contribute.

Cadence: Once per incident; trends reviewed quarterly across incidents.

Where it lives: Standalone post-mortem doc per incident; corrective actions flow to Post-Incident Action Tracker (workbook tab).

Sections / contents:

Section	Contents / fields
Incident record	ID, title, severity, type, dates, TTD, TTR, downtime, IC, responders, affected systems/customers
Incident timeline	Minute-by-minute reconstruction — purely factual, no interpretation
Impact assessment	Customer, service, revenue, operational, data, regulatory, reputational, internal, third-party
Root cause analysis	Symptom, trigger, direct cause, contributing factors, 5 Whys, root cause(s), why detection/response delayed, what prevented worse, blameless framing check
Corrective actions (feed to	Per action: description, type, root cause tied to, priority,
Post-Incident Action Tracker)	owner, due, success measure, status
Detection & response	Detection gap, alerting, runbook, tooling, escalation, on-
improvements	call, training gaps
Customer communication	Audience, channel, timing, post-incident report, accountability,

Section	Contents / fields
	commitments, follow-up, SLA credits
Regulatory & compliance reporting	Regulations, threshold, deadline, authorities, notifications submitted, legal counsel, insurance
Post-mortem document	Shareable artifact with executive summary and full details
Cross-incident trends (quarterly)	Total incidents, recurring root causes, hotspots, MTTD/MTTR trends, completion rate, repeat incidents
Blameless culture & team care	Responder hours, off-hours response, recovery time, psychological safety, recognition, manager 1:1s

AI enablement

- Reconstruct the incident timeline from logs, chat, and alerting data automatically.
- Cluster similar incidents and surface recurring root causes across the org.
- Draft the post-mortem document; humans review and refine.
- Recommend corrective actions based on similar past incidents and their effective resolutions.

Note: The team care section is mandatory, not optional. Skipping it is how organizations burn out their best responders. Distinguish 'fix this specific bug' (immediate) from 'prevent this class of bug' (systemic) in corrective actions — both matter, but the systemic ones are higher leverage.

PRACTITIONER REFERENCE

Standards & method: Aligned to ITIL 4 Problem Management practice (post-incident review as problem record input) and ISO/IEC 20000-1 Clause 8.6 (incident and problem management). Method: timeline reconstruction -> contributing factor analysis (5 Whys or Fishbone) -> impact quantification -> systemic root cause determination -> preventive action identification -> lessons-learned dissemination.

Guiding principles: Blameless post-mortems produce better root causes than punitive ones; timeline accuracy precedes causal analysis; every contributing factor is a system failure, not a person failure; findings are published to the broader organization, not siloed.

What good looks like:

- Incident timeline is reconstructed to the minute using objective log and telemetry data.
- Root cause distinguishes proximate cause from systemic enabling conditions.
- Customer impact is quantified: affected users, revenue, SLA credit, and MTTR all stated.
- Action items are categorized: immediate containment, short-term fix, long-term prevention.
- Review is completed and distributed within the committed SLA (typically 48-72 hours for Sev-1).

Common pitfalls:

- Review convened too late, when log data has rotated and memory has faded.
- Root cause stops at 'human error' without asking why the system allowed the error.
- Action items generated but never tracked to closure, allowing recurrence.
- Blame language in the document creates a legal and cultural liability.
- Review conducted only for high-severity incidents, missing patterns in low-severity clusters.

Maturity (1-5): L1 Ad hoc - no formal review, verbal debrief only; L2 Defined - template exists, reviews held inconsistently; L3 Managed - mandatory reviews within SLA, actions tracked; L4 Quantified - MTTR and repeat-incident rate trended, root-cause categories analyzed; L5 Optimizing - proactive failure pattern detection prevents incident classes before recurrence.

Artifact #32 — Post-Incident Action Tracker

Purpose: Cross-incident corrective action tracker. Standalone artifact because actions identified in any single post-mortem need to be tracked to closure across all incidents — without this, organizations 'learn the same lesson three times.' Also enables cross-incident pattern analysis (recurring root causes, systemic gaps).

When you use it: Immediately after each post-incident review; tracked to closure with verification at 30/60/90 days.

Owner: Security or SRE leadership owns the tracker; individual action owners drive their items.

Cadence: Weekly review during active items; quarterly trend review across all closed/open actions.

Where it lives: Workbook tab 'Post-Incident Actions' (cross-incident tracker).

Sections / contents:

Section	Contents / fields
Action ID	Sequential identifier across all incidents
Source incident	Incident ID this action came from
Date raised	When the action was identified (post-mortem date)
Action description	Specific corrective action — measurable
Type	Code / Infrastructure / Process / Tooling / Training / Policy / Detection
Root cause addressed	Which root cause from the post-mortem this addresses
Priority	P0 immediate / P1 within 30 days / P2 within 90 days / P3 backlog
Owner	Single named person accountable
Due date	Target completion
Status	Open / In Progress / Complete / Verified / Re-incident occurred / Cancelled
Section	Contents / fields
Verification at 30/60/90 days	Did this action actually prevent recurrence? Verified by whom, how
Linked similar actions	Cross-references to related actions from other incidents

AI enablement

- Cluster corrective actions across incidents to identify systemic themes (e.g., 'auth-related actions appear in 4 of last 6 incidents').
- Predict whether a corrective action is likely to prevent recurrence based on similar past actions.
- Auto-flag re-incidents that match a 'verified closed' action — surface tracker integrity gaps.
- Track action completion rate as a leading indicator of incident reduction.

Note: Standalone (not folded into Decisions & Changes Log) because corrective actions need cross-incident analysis — looking for recurring root causes — and they're tracked by a different group than project decisions. The 30/60/90 verification is what most organizations skip; without it, 'closed' doesn't mean 'fixed.'

Appendix A — AI Capability → PMO Artifact Mapping

The original feature catalog described AI capabilities for an enabled PMO. This appendix maps each capability to the artifact it actually supports. AI-only configuration templates are noted as 'AI Config Reference' — they belong in the AI engineering team's documentation, not the TPM template library.

1	Predictive task assignment & risk alerts	RAID Log (#11), Resource Plan (#13), Schedule (#12)
2	Timezone-aware smart scheduling	Resource Plan (#13); AI Config Reference for fairness rules
3	NLP meeting summaries & update digests	Status Report (#18), Decisions & Changes Log (#19), RAID Log (#11)
4	Automated charter, test, DR, procurement plan builders	Charter (#1); other plans are project-type- specific
5	PMO skill-builder & onboarding	Operating Model (#29); separate Skills Framework deliverable
6	Executive dashboards w/ explainable AI	Portfolio Dashboard (#28), Steering Pack (#20)
AI Capabil	ity (from source catalog) Plugs i	nto PMO artifact
7 Seamless	tool integrations AI Con	fig Reference — engineering setup
8 Action it	em extraction from emails / chats Decisi Log (#	ons & Changes Log (#19), RAID 11)
9 Plain Eng	lish to structured updates Status for ma	Report (#18); AI Config Reference pping rules
10 Status re	ports & briefs from unstructured Status	Report (#18
—— PRACTITION	ER REFERENCE ——	

Standards & method: Aligned to ITIL 4 Problem Management (known-error record to change enablement) and PMI PMBOK 7 (Issue management within Delivery performance domain). Method: log action from PIR -> assign owner and priority -> track through implementation -> verify effectiveness -> close with evidence.

Guiding principles: Every PIR action has one owner and one due date before the review meeting ends; severity of the originating incident governs resolution SLA; effectiveness is verified by metric, not assertion; the tracker is visible to leadership until all Sev-1 actions are closed.

What good looks like:

- Actions are categorized (containment, fix, prevention, process) enabling resource prioritization.
- SLA adherence is measured and reported: percentage of actions closed on or before due date.
- Closure requires an evidence artifact (commit hash, updated runbook, test result), not just a status change.
- Aging actions trigger automatic escalation to the engineering or ops leader.
- Tracker links each action back to its source incident and PIR for full traceability.

Common pitfalls:

- Actions marked complete without verification evidence, allowing the same failure to recur.
- Tracker updated only when someone asks, rather than on a defined cadence.
- Long-term prevention actions perpetually de-prioritized in favor of new feature work.
- Multiple trackers in different tools create a fragmented view of open risk.
- No metric tracking repeat incidents to test whether prior actions were effective.

Maturity (1-5): L1 Ad hoc - actions noted verbally, no formal tracking; L2 Defined - tracker exists, manually updated; L3 Managed - SLA-bound, evidence-gated closure, cadenced review; L4 Quantified - action effectiveness measured by reduction in repeat incident rate; L5 Optimizing - action outcomes feed reliability engineering backlog with quantified risk reduction scores.

Artifact #34 — Risk Register & Response Plan

Purpose: Identify, assess, and actively manage threats and opportunities to the project. Goes beyond the RAID log's single risk column to score, prioritize, assign, and track responses to each risk over time.

When you use it: Stood up during Plan once scope is stable; reviewed every status cycle; intensively revisited at major change points or when the risk profile shifts.

Owner: TPM owns the register; risk owners own individual responses; sponsor owns escalated/strategic risks.

Cadence: Reviewed weekly with the core team; top risks reported in every status report and SteerCo pack.

Where it lives: Workbook tab 'Risk Register' (live); the RAID log references it for the highest-severity items.

How it differs from RAID: RAID is a lightweight running log; the Risk Register adds probability x impact scoring, response strategy (avoid/mitigate/transfer/accept), residual risk, triggers, and a burndown view.

Sections / contents:

- Risk ID, title, category (technical, schedule, cost, vendor, security, organizational)
- Description and root cause; trigger conditions / early-warning signals
- Probability (1-5) and Impact (1-5); inherent score = $P \times I$; severity band
- Response strategy: avoid, mitigate, transfer, accept; specific response actions and owners
- Residual probability/impact after response; contingency reserve (time/cost) if accepted
- Status (open, mitigating, realized->issue, closed) and last review date
- Risk burndown: total exposure trend over time

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Uncertainty performance domain) and ISO 31000. Method: identify -> assess probability x impact -> respond (avoid / mitigate / transfer / accept) -> monitor against triggers -> close or convert to issue.

Guiding principles: Every risk has one named owner; score inherent and residual separately; manage to triggers, not dates; a risk and an issue are different states of the same object.

What good looks like:

- Top-5 risks reviewed weekly with the sponsor; nothing is a surprise at SteerCo.
- Residual exposure trends down week over week.
- $\geq 80\%$ of mitigations have a verifiable completion test.
- Every red risk has an owner, a trigger, and a dated next action.
- Reserves sized from the risk profile, not guessed.

Common pitfalls:

- A register no one reads.
- Scoring inflation: everything is High.
- 'Accept' used to mean 'ignore.'
- Mixing risks with issues.
- Mitigations with no owner or completion test.

Maturity (1-5): L1 Ad hoc - tracked in heads; L2 Defined - register exists, irregular; L3 Managed - weekly, scored, owned; L4 Quantified - exposure trended, reserves modeled; L5 Optimizing - predictive portfolio risk analytics.

Artifact #35 — Quality Management Plan

Purpose: Define what 'done and good' means for the project, how quality will be built in and verified, and the metrics that prove it. Connects requirements to acceptance and prevents quality from being discovered only at UAT.

When you use it: Drafted in Plan alongside the BRD and tech spec; referenced throughout build and test; quality metrics reported during Monitor & Control.

Owner: TPM facilitates; engineering/QA lead owns technical quality; product/business owner owns acceptance criteria.

Cadence: Baselined once; quality metrics tracked each status cycle; reviewed at phase gates.

Where it lives: Workbook tab 'Quality'; acceptance criteria flow into the UAT plan and the RTM.

Sections / contents:

- Quality objectives and standards (internal standards, regulatory, security baselines)
- Definition of Done (per deliverable type) and global acceptance criteria
- Quality roles and responsibilities; review/approval gates
- Verification & validation approach (reviews, automated tests, UAT, security testing)
- Defect management: severity definitions, triage, exit thresholds
- Quality metrics and targets (defect density, escaped defects, test coverage, rework rate, first-pass yield)
- Continuous improvement and lessons feedback loop

PRACTITIONER REFERENCE

Standards & method: Aligned to ISO 9001:2015 Clause 8 (Operation) and Clause 9 (Performance evaluation) and PMI PMBOK 7 (Delivery performance domain - quality). Method: define quality objectives and acceptance criteria -> plan quality activities (assurance and control) -> execute reviews, audits, and tests -> measure against criteria -> non-conformance management -> continuous improvement loop.

Guiding principles: Quality is designed in, not inspected in at the end; acceptance criteria are agreed with the customer before work begins, not after; every defect is a process signal, not just

a product defect; quality cost (prevention + appraisal + failure) is tracked alongside schedule and budget.

What good looks like:

- Acceptance criteria for every deliverable are documented, customer-agreed, and version-controlled before work starts.
- Quality gates are embedded in the schedule as hard blockers, not optional checkpoints.
- Defect escape rate (defects found post-gate vs. pre-gate) is trended and drives process improvement.
- Internal audit findings result in root-cause analysis and corrective actions with closure evidence.
- Cost of quality is reported at governance level alongside traditional cost metrics.

Common pitfalls:

- Quality plan written at project start and never referenced again.
- Acceptance criteria vague ('system performs well') rather than measurable ('P95 response time < 2s under 500 concurrent users').
- Quality activities cut first when schedule slips, guaranteeing late-stage defect cost.
- No distinction between Quality Assurance (process) and Quality Control (product), leading to gaps in both.
- Non-conformances logged but never root-cause analyzed, allowing systemic defect sources to persist.

Maturity (1-5): L1 Ad hoc - quality checked informally at end; L2 Defined - QMP exists, criteria documented; L3 Managed - quality gates enforced, defects trended, corrective actions tracked; L4 Quantified - cost of quality modeled, defect density benchmarked against industry; L5 Optimizing - predictive defect models and shift-left testing eliminate escape defects.

Artifact #36 — Requirements Traceability Matrix (RTM)

Purpose: Maintain an unbroken thread from each business/technical requirement to its design element, build, test case, and acceptance evidence. Proves coverage, controls scope creep, and shows the impact of any change.

When you use it: Started when the BRD is approved; grows through design and build; used as the UAT coverage check and at closeout to prove delivery.

Owner: TPM owns the matrix; BA/product owns requirement definitions; QA owns test linkage.

Cadence: Updated whenever a requirement, design, or test changes; reviewed at each phase gate.

Where it lives: Workbook tab 'RTM'; pulls requirement IDs from the BRD and test IDs from the UAT plan.

Sections / contents:

- Requirement ID, source (BRD/tech spec), priority (MoSCoW), description
- Design/architecture reference; build component or work item ID
- Test case ID(s) and latest test result
- Acceptance status and evidence link; business owner sign-off
- Change linkage: which change request altered this requirement
- Coverage summary: % of requirements with a passing test, by priority

PRACTITIONER REFERENCE

Standards & method: Aligned to BABOK v3 (Requirements Lifecycle Management knowledge area) and IEEE 29148:2018 (requirements traceability). Method: elicit and baseline requirements -> assign unique IDs -> map forward to design, build, and test artifacts -> map

backward to business objectives -> maintain bidirectional traceability -> validate coverage at each gate.

Guiding principles: Every requirement traces to a business objective and to at least one test case; no requirement is implemented without a unique ID; coverage gaps are risks, not administrative shortcomings; the RTM is updated in real time, not reconstructed before UAT.

What good looks like:

- Bidirectional traceability is complete: business need -> requirement -> design -> test case -> test result.
- Orphaned requirements (no test coverage) and orphaned test cases (no requirement) are zero at gate.
- Change impact is assessed by traversing the RTM before any requirement change is approved.
- Requirements coverage percentage is a tracked project metric reported at governance.
- RTM is baselined and change-controlled alongside the requirements specification.

Common pitfalls:

- RTM created retrospectively to satisfy an audit gate rather than maintained throughout.
- Only functional requirements traced; non-functional requirements (performance, security, compliance) excluded.
- Test cases mapped to requirements at the feature level, masking gaps at the individual requirement level.
- No process for updating the RTM when requirements change, creating an inaccurate coverage picture.
- Tool misuse: spreadsheet RTM becomes unmanageable above 200 requirements, and no migration plan exists.

Maturity (1-5): L1 Ad hoc - no formal traceability; L2 Defined - RTM template exists, populated manually; L3 Managed - bidirectional traceability enforced at gates, change-controlled; L4 Quantified - coverage metrics drive test strategy and schedule risk; L5 Optimizing - automated traceability in ALM toolchain with real-time gap alerting.

Artifact #37 — Work Breakdown Structure (WBS) & Estimation Approach

Purpose: Decompose the full scope into a hierarchy of deliverables and work packages, and document how each was estimated. The WBS is the backbone the schedule, budget, and resource plan are built from; the estimation approach makes the numbers defensible.

When you use it: Built in Plan immediately after scope is agreed and before the schedule is sequenced; revisited when scope changes materially.

Owner: TPM owns the WBS; work-package owners own their estimates; sponsor approves the resulting baseline.

Cadence: Baselined once; re-decomposed only on approved scope change.

Where it lives: Workbook tabs 'WBS' and 'Estimates'; feeds the schedule and budget tabs.

Sections / contents:

- WBS hierarchy: level 1 phases -> level 2 deliverables -> level 3 work packages (the 100% rule: children sum to the parent)
- Work package dictionary: ID, description, owner, acceptance criteria, dependencies
- Estimation method per package (analogous, parametric, three-point/PERT, expert judgment, t-shirt for early sizing)
- Estimate values: optimistic / most likely / pessimistic; expected = $(O + 4M + P) / 6$
- Assumptions, basis of estimate, and confidence level

- Contingency derived from estimate uncertainty

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Planning performance domain) and PMI Practice Standard for Work Breakdown Structures (2nd ed.). Method: decompose scope to 100% rule -> identify work packages at the level of estimability -> apply estimation technique (analogous / parametric / three-point PERT / bottom-up) -> document assumptions and constraints -> derive schedule and cost baseline.

Guiding principles: The WBS represents 100% of project scope - nothing outside it is in scope; work packages are sized to enable meaningful estimation and ownership (typically 8-80 hours); estimates are ranges with documented assumptions, not point-in-time guesses; the WBS dictionary defines each element unambiguously.

What good looks like:

- Every WBS element is described in the WBS dictionary with scope, owner, deliverable, and acceptance criteria.
- Estimation technique is documented and appropriate to available data (three-point PERT for uncertain tasks).
- Estimate confidence intervals are stated (e.g., -10%/+15%) and drive contingency reserve sizing.
- WBS is decomposed to work packages, not activities - activities live in the schedule, not the WBS.
- Changes to scope are first reflected in the WBS, then cascaded to schedule and budget baseline.

Common pitfalls:

- WBS decomposed to task level rather than deliverable level, blurring scope and schedule.
- 100% rule violated: integration, transition, and project management work packages omitted.
- Estimates provided without assumptions, making them unverifiable and indefensible.
- Single-point estimates presented as commitments rather than probability-weighted ranges.
- WBS created by the PM alone without subject-matter expert input, producing systematically optimistic estimates.

Maturity (1-5): L1 Ad hoc - informal task lists, no structured decomposition; L2 Defined - WBS template exists, estimates undocumented; L3 Managed - 100%-rule WBS with dictionary, documented estimation technique and assumptions; L4 Quantified - Monte Carlo or three-point ranges inform schedule and cost reserves; L5 Optimizing - historical actuals continuously calibrate estimation models by work-package type.

Artifact #38 — Cost Management Plan & Earned Value (EVM) Tracker

Purpose: Establish the cost baseline and track planned vs actual vs earned value so cost and schedule performance are measured objectively, not by gut feel. Turns the budget from a static number into a forecasting instrument.

When you use it: Baseline set at the end of Plan from the WBS/budget; tracked every status cycle through execution; forecasts feed SteerCo and change decisions.

Owner: TPM owns tracking and forecasting; finance partner validates actuals; sponsor owns funding decisions.

Cadence: Updated each status cycle (weekly or biweekly); variance and forecast reported in every SteerCo pack.

Where it lives: Workbook tab 'Cost & EVM'; draws planned values from the schedule and budget.

Sections / contents:

- Cost baseline (time-phased planned value, PV) and funding/approval thresholds
- Actual cost (AC) capture method and cadence; commitment vs spend
- Earned value (EV) = % complete x budget at completion per work package
- Metrics: $CV = EV - AC$; $SV = EV - PV$; $CPI = EV/AC$; $SPI = EV/PV$
- Forecasts: $EAC = BAC / CPI$; $ETC = EAC - AC$; variance at completion (VAC)
- Cost change control thresholds and re-baseline triggers
- Narrative: what the indices mean and the corrective action

PRACTITIONER REFERENCE

Standards & method: Aligned to ANSI/EIA-748 (32 EVMS guidelines) and PMI PMBOK 7 (Planning and Measurement performance domains). Method: establish Performance Measurement Baseline (PMB = scope + schedule + cost) -> measure Earned Value (EV) against Planned Value (PV) and Actual Cost (AC) -> compute CPI, SPI, EAC, and VAC -> forecast at completion -> report variances against threshold -> drive corrective action.

Guiding principles: The baseline is sacrosanct until formally re-baselined through change control; EV is earned by deliverable completion, not time elapsed; CPI trend over 20% project completion is a leading indicator of final cost outcome; variance thresholds trigger mandatory corrective action plans, not just commentary.

What good looks like:

- PMB is formally approved and change-controlled; no informal updates to budget or schedule.
- Weekly EV report shows PV, EV, AC, CPI, SPI, EAC, and VAC with trend lines across the project.
- CPI below 0.95 triggers a formal Estimate at Completion (EAC) reforecast with documented assumptions.
- Cost accounts have named Control Account Managers (CAMs) accountable for variance explanation.
- EAC is computed using multiple methods ($EAC = BAC/CPI$; $EAC = AC + ETC$) and reconciled against bottom-up reforecast.

Common pitfalls:

- EV calculated by percentage complete estimates rather than discrete deliverable milestones, enabling optimism bias.
- No change control on the PMB: baseline shifts informally, making variance analysis meaningless.
- CPI and SPI reported but never used to drive a forecast or a corrective action.
- Management reserve and contingency reserve conflated, obscuring true cost exposure.
- EVM applied at the project summary level only, with no work-package-level visibility to identify problem areas early.

Maturity (1-5): L1 Ad hoc - costs tracked against original budget, no performance measurement; L2 Defined - budget and actuals reported, no EV computation; L3 Managed - formal PMB, weekly EV metrics, variance thresholds enforced; L4 Quantified - CPI/SPI trends drive probabilistic EAC and reserve modeling; L5 Optimizing - EVM integrated with risk and schedule models for real-time completion probability.

Artifact #39 — Business Case & Cost-Benefit Analysis

Purpose: Justify the investment before work starts: the problem, the options considered, quantified costs and benefits, and the recommendation. The decision document that authorizes funding and anchors later benefits realization.

When you use it: Created at intake/Initiate, before the charter is approved; revisited at major gates if assumptions change.

Owner: Sponsor owns the business case; TPM and finance build it; portfolio governance approves it.

Cadence: One-time at initiation; refreshed if scope, cost, or benefit assumptions shift materially.

Where it lives: Workbook tab 'Business Case'; benefits flow forward into the Benefits Realization artifact.

Sections / contents:

- Problem/opportunity statement and strategic alignment
- Options analysis (including do-nothing) with pros/cons
- Costs: one-time + run-rate, fully loaded, over the analysis horizon
- Benefits: quantified (hard \$) and qualitative; benefit owners named
- Financial metrics: NPV, IRR, payback period, ROI; discount rate stated
- Sensitivity analysis (best/expected/worst) and key assumptions
- Recommendation, funding ask, and decision record

PRACTITIONER REFERENCE

Standards & method: Aligned to HM Treasury Green Book (5 Case Model: strategic, economic, commercial, financial, management) and PMI Business Analysis Practice Guide (benefits realization framing). Method: define problem/opportunity and do-nothing baseline -> develop and screen options -> quantify costs (capex, opex, TCO) and benefits (financial and non-financial) -> compute NPV, IRR, payback period, and BCR -> sensitivity and scenario analysis -> recommend preferred option with risk-adjusted view.

Guiding principles: The do-nothing option is always the comparison baseline; costs and benefits are attributed to the decision period with consistent discount rate; non-financial benefits are quantified or explicitly bounded, not merely listed; the case is re-validated at each stage gate as estimates mature.

What good looks like:

- All cost categories are included: capex, opex, transition, and ongoing run cost, with a full TCO over the investment horizon.
- Benefits are categorized (cashable savings, non-cashable efficiency, strategic enablement) with an accountable benefits owner per category.
- Sensitivity analysis tests the key value drivers: what discount rate, cost overrun, or benefit shortfall breaks the case?
- BCR and NPV are computed under base, optimistic, and pessimistic scenarios.
- The business case is a living document: assumptions are flagged, dated, and revisited at each gate.

Common pitfalls:

- Benefits inflated at approval to pass the hurdle rate, with no mechanism to track realization post-delivery.
- Optimism bias uncorrected: industry evidence shows IT project costs average 27% over estimate without reference class adjustment.
- Sensitivity analysis omitted, leaving decision-makers blind to the key value-driver risks.

- Sunk costs included in the go-forward comparison, distorting the investment decision.
- Business case approved and filed; no benefits realization plan links the case to post-go-live measurement.

Maturity (1-5): L1 Ad hoc - investment justified by verbal advocacy; L2 Defined - standard template, cost and benefit lists without rigor; L3 Managed - NPV, BCR, and sensitivity analysis, formal approval gate; L4 Quantified - reference class forecasting applied, benefits tracking initiated at go-live; L5 Optimizing - realized vs. forecast benefits feed portfolio prioritization and estimation model calibration.

Artifact #40 — Agile & Hybrid Delivery Plan

Purpose: Define how delivery actually runs when the work is iterative or hybrid: the backlog, release/increment plan, cadence, and the metrics that show flow. Bridges plan-driven governance (charter, budget, SteerCo) with iterative execution.

When you use it: Set up in Plan once the delivery approach is chosen; the backlog and release plan are living artifacts throughout execution.

Owner: TPM/delivery lead owns the plan and cadence; product owner owns backlog priority; team owns estimates and the increment.

Cadence: Backlog refined continuously; sprint/iteration on a fixed cadence; release/PI planning per increment; flow metrics every cycle.

Where it lives: Workbook tabs 'Backlog' and 'Release Plan'; status reporting pulls velocity/burndown from here.

Sections / contents:

- Delivery approach: pure agile, scaled (SAFe-style PI), or hybrid (agile build inside a phase-gated program) and why
- Backlog structure: epics -> features -> stories, with acceptance criteria and priority (WSJF or MoSCoW)
- Cadence: sprint length, ceremonies, PI/release boundaries, Definition of Ready / Definition of Done
- Release/increment plan: objectives and target dates per increment; dependency callouts
- Flow metrics: velocity, sprint burndown, release burnup, cycle time, throughput, WIP limits
- Governance bridge: how iterations map to milestones, budget tranches, and SteerCo reporting
- Roles: product owner, scrum master/delivery lead, team

PRACTITIONER REFERENCE

Standards & method: Aligned to Scrum Guide 2020 and SAFe 6.0 (PI Planning, ART cadence, Program Increment objectives). Method: define delivery model (pure agile, hybrid, or water-scrum-fall) -> establish sprint/PI cadence -> define definition of ready and done -> integrate milestone gates -> report via cumulative flow and velocity.

Guiding principles: Cadence creates predictability; scope flexibility is the agile lever, not schedule; hybrid gates protect fixed regulatory or procurement commitments; inspect and adapt at every PI boundary.

What good looks like:

- Sprint velocity is stable within +/-15% over three consecutive sprints.
- PI objectives are SMART, accepted by Business Owners, and tracked to completion.
- Definition of Done is written, versioned, and enforced by the team, not just the SM.
- Hybrid milestone gates have explicit entry/exit criteria tied to working software, not documents.

- Impediment backlog is visible, owned, and aging items escalate within 48 hours.

Common pitfalls:

- Waterfall renamed as agile: fixed scope, fixed schedule, sprints used only as reporting buckets.
- No Definition of Ready, causing sprint planning to collapse into scope negotiation.
- Velocity used as a productivity metric and tied to performance reviews, destroying honest estimation.
- Hybrid gates poorly sequenced so agile teams block on a document approval that could have been async.
- PI objectives set by management, not teams, gutting psychological ownership.

Maturity (1-5): L1 Ad hoc - iterations informal, no cadence; L2 Defined - sprints exist, backlog managed; L3 Managed - velocity tracked, PI planning executed, DoD enforced; L4 Quantified - throughput and flow metrics drive forecasting; L5 Optimizing - continuous flow, real-time portfolio rebalancing, AI-assisted forecasting.

Artifact #41 — Vendor & Contract Management Plan

Purpose: Manage vendors after the contract is signed - performance against SLAs, relationship governance, issue escalation, and clean contract closeout. Picks up where the RFP/SOW leave off, where most procurement value is actually won or lost.

When you use it: Activated when an SOW is signed; runs through delivery; closes at contract end with a performance record.

Owner: TPM owns vendor governance day-to-day; procurement/legal owns the contract; sponsor owns the commercial relationship.

Cadence: Vendor checkpoint cadence (weekly/biweekly); SLA scorecard monthly; QBR quarterly for strategic vendors.

Where it lives: Workbook tab 'Vendor Management'; references the SOW and feeds the RAID log on vendor risk.

Sections / contents:

- Vendor register: vendor, contract ref, value, term, key contacts, renewal/exit dates
- SLA/KPI definitions and targets; measurement method and data source
- Performance scorecard: SLA attainment, quality, responsiveness, RAG by period
- Governance: checkpoint cadence, escalation path, decision rights
- Issue & dispute log; credits/penalties triggered
- Change control against the SOW; scope-vs-spend tracking
- Contract closeout: deliverable acceptance, knowledge transfer, final payment, performance rating for future selection

PRACTITIONER REFERENCE

Standards & method: Aligned to CIPS Procurement and Contract Management standards and ITIL 4 Supplier Management practice. Method: supplier segmentation (strategic/tactical/commodity) -> contract baseline and SLA definition -> performance scorecard cadence -> issue escalation and remediation -> renewal or exit trigger review.

Guiding principles: Every contract has a named contract manager; SLAs are outcomes, not activities; supplier risk is re-assessed at least quarterly; exit strategy is documented before contract signature.

What good looks like:

- Supplier scorecard reviewed monthly with quantified SLA attainment and trend lines.

- Contract register is current, includes expiry dates, renewal options, and exit clauses.
- Strategic suppliers have a joint governance forum with escalation paths to C-level.
- At-risk suppliers have a formal remediation plan with cure period and consequences defined.
- Contractual change control is linked to project change control, preventing scope creep via SOW amendment.

Common pitfalls:

- Contracts filed and forgotten until a dispute arises.
- SLAs defined as input activities (e.g., 'provide weekly report') rather than outcome metrics.
- No supplier concentration risk assessment, creating single-point-of-failure exposure.
- Change requests processed outside contract amendment, creating unenforceable verbal commitments.
- Renewal auto-triggered without performance review, locking in underperforming vendors.

Maturity (1-5): L1 Ad hoc - contracts stored ad hoc, no tracking; L2 Defined - register exists, SLAs documented; L3 Managed - monthly scorecards, formal remediation process; L4 Quantified - supplier risk scored, spend analytics inform decisions; L5 Optimizing - predictive supplier health models, automated compliance monitoring.

Artifact #42 — Go-Live Readiness & Cutover Plan

Purpose: Prove the solution and the organization are ready to go live, and choreograph the cutover hour-by-hour with a tested rollback. The gate that decides go / no-go and the runbook that makes the switch boring.

When you use it: Assembled late in Execute, before cutover; the readiness review is a formal gate; the cutover runbook is executed on go-live day.

Owner: TPM owns the readiness gate and runbook; technical lead owns deployment steps; business owner owns go/no-go acceptance.

Cadence: Readiness reviewed at T-2 weeks and T-2 days; cutover executed once with checkpoints; rollback decision at defined go/no-go points.

Where it lives: Workbook tab 'Go-Live'; complements the engineering ROLL plan with the business-readiness and decision layer.

Sections / contents:

- Readiness checklist by domain: technical, data, security, operations/support, training, comms, business sign-off
- Go/no-go criteria and decision authority; go/no-go meeting agenda and attendees
- Cutover runbook: sequenced steps, owner, start/stop time, dependency, validation check
- Rollback plan: trigger conditions, steps, decision point and owner, point of no return
- Hypercare handshake (link to Transition plan) and command-center/contact list
- Communications timeline (pre, during, post)

PRACTITIONER REFERENCE

Standards & method: Aligned to ITIL 4 Release Management and Change Enablement practices. Method: go/no-go criteria definition -> cutover task sequencing with owner and duration -> rollback trigger and procedure -> hypercare staffing plan -> post-cutover validation checklist -> formal go-live sign-off.

Guiding principles: No cutover begins without a signed go/no-go checklist; every task has a named executor and a time-boxed window; rollback is rehearsed, not theoretical; cutover is a change, not an event.

What good looks like:

- Cutover runbook is task-level granular with start time, owner, duration, and dependency for every step.
- Go/no-go criteria are binary and pre-agreed with business, IT, and security stakeholders.
- Dress rehearsal in a production-equivalent environment completed within two weeks of go-live.
- Rollback decision point and rollback procedure are explicit, timed, and owner-assigned.
- Post-cutover validation tests cover all critical business processes with pass/fail criteria, not just technical pings.

Common pitfalls:

- Cutover plan exists only as a high-level Gantt, not an executable runbook.
- Go/no-go decision made informally in a hallway, with no documented stakeholder sign-off.
- Rollback never tested; assumed to work because it is theoretically reversible.
- Data migration validation limited to row counts, missing data quality and referential integrity checks.
- Hypercare resourcing planned in principle but not scheduled, leaving gaps at go-live.

Maturity (1-5): L1 Ad hoc - cutover improvised on the day; L2 Defined - runbook documented, roles assigned; L3 Managed - go/no-go criteria enforced, dress rehearsal conducted; L4 Quantified - cutover metrics trended across releases, rollback RTO measured; L5 Optimizing - automated cutover orchestration, real-time go-live dashboards.

Artifact #43 — Transition to Operations & Hypercare Plan

Purpose: Hand the delivered solution to the team that will run it, with the knowledge, runbooks, support model, and elevated 'hypercare' support that make adoption stick. The difference between a project that ships and one that lasts.

When you use it: Built late in Execute, activated at go-live, and the bridge into Close once steady-state is reached.

Owner: TPM owns the transition; operations/service owner is the receiving accountable party; business owner confirms adoption.

Cadence: Hypercare runs for a defined window (e.g., 2-4 weeks) with daily then weekly reviews; formal acceptance ends it.

Where it lives: Workbook tab 'Transition'; references the operating model and feeds the closeout report.

Sections / contents:

- Service ownership transfer: what is handed over, to whom, accountable owner
- Knowledge transfer plan: runbooks, architecture, known issues, KT sessions and sign-off
- Support model: tiers, on-call, SLAs, ticket routing, monitoring/alerting ownership
- Hypercare: window, staffing, daily standup, issue triage, exit criteria
- Adoption tracking: usage metrics, residual training needs
- Acceptance: operations sign-off that steady-state is reached and the project can close

PRACTITIONER REFERENCE

Standards & method: Aligned to ITIL 4 Service Transition and Organizational Change Management (Prosci ADKAR). Method: transition readiness criteria -> knowledge transfer completion -> hypercare period definition with support tiers -> issue triage cadence -> steady-state acceptance criteria -> formal handoff sign-off.

Guiding principles: Operations team signs off readiness before go-live, not after; hypercare has a defined exit criteria, not just a calendar date; every known issue at handoff has an owner and resolution SLA; knowledge transfer is verified by the receiver, not declared by the sender.

What good looks like:

- Runbooks, SOPs, and operational dashboards are complete and signed off by ops leads before hypercare begins.
- Hypercare command center has defined triage tiers with response SLAs for P1/P2/P3 issues.
- Steady-state acceptance criteria (system stability, ticket volume, SLA attainment) are quantified and agreed pre-launch.
- Knowledge transfer is validated through shadowing, certification, or documented Q&A, not just document delivery.
- Formal transition sign-off includes business, IT ops, and security, with open items tracked to closure.

Common pitfalls:

- Hypercare treated as extended project support with no defined exit criteria, creating indefinite project team dependency.
- Operations team excluded from pre-go-live testing, resulting in surprise at handoff.
- Runbooks written by developers, not operations, making them unusable in the field.
- Issue backlog at handoff undisclosed or minimized, ambushing the support team.
- Training delivered too far in advance of go-live, with no refresher before cutover.

Maturity (1-5): L1 Ad hoc - project team supports indefinitely with no handoff plan; L2 Defined - transition plan documented, hypercare period set; L3 Managed - exit criteria enforced, ops acceptance signed off; L4 Quantified - hypercare issue trends inform future transition quality; L5 Optimizing - automated operational readiness scoring, continuous feedback loop to delivery.

Artifact #51 — Cross-Team Dependency Management

Purpose: Identifies, maps, and actively manages all cross-team and external dependencies at the project level - capturing provider, receiver, deliverable, needed-by date, current status, and float for each dependency - and establishes a review cadence so that at-risk dependencies are surfaced and resolved before they create schedule or quality impacts.

When you use it: Dependency log is created in Plan as the team maps out the work breakdown; populated collaboratively with all workstream leads and external parties. Actively maintained throughout Execute and Monitor and Control; reviewed at each governance cycle and whenever a new dependency is identified.

Owner: TPM owns and maintains the dependency log; each workstream lead is accountable for the dependencies where their team is the provider; external dependency owners (vendor PMs, IT operations leads) are formally notified and asked to confirm expected delivery dates.

Cadence: Full dependency review weekly in the project team meeting; at-risk dependencies (float <= 5 days) reviewed daily by TPM and relevant workstream lead; status updated in the log within 24 hours of any change.

Where it lives: Workbook tab 'Dependencies'; optionally mirrored on a physical or digital dependency board in the team workspace; linked from the integrated project schedule.

Sections / contents:

Section	Contents / fields
Dependency Log	Columnar register: Dep ID Provider (team/person) Receiver (team/person) Deliverable Description Needed-By Date Promised Date Current Status (On Track / At Risk / Blocked / Delivered) Float (calendar days) Owner Notes/Actions. Float = Needed-By minus Promised Date; negative float = already late.

Section	Contents / fields
Dependency Categories	Internal cross-team (e.g., ZTNA workstream needs PAM workstream to deliver service-account inventory before policy authoring can begin). External vendor (e.g., network vendor to deliver hardware before ZTNA pilot can start). IT Operations (e.g., change-freeze windows, firewall rule approvals). Program-level (dependencies on other Bristol Financial programs - flagged here and escalated to program level for tracking).
Dependency Map (Visual)	One-page swim-lane or network diagram showing critical-path dependencies between workstreams and external parties. Updated at each phase gate. Used in SteerCo packs to communicate interdependency risk.
At-Risk and Blocked Log	Subset of the dependency log filtered to float ≤ 5 days or status = Blocked. Includes: impact if unresolved, owner of resolution action, target resolution date, and escalation tier if not resolved by target date.
Dependency Review Cadence	Weekly: TPM walks the full log with workstream leads - updates status, recalculates float, promotes items to at-risk. Daily (as needed): TPM and affected lead resolve blocked items. Phase gate: full dependency audit - all delivered dependencies closed, all open dependencies re-confirmed with revised dates if needed.
External Dependency Contacts	For each external dependency: vendor/team name, named contact, contact method, SLA for acknowledgment, and escalation path if contact is unresponsive. Reviewed and updated monthly.
Dependency-Change Control	Any change to a dependency's Needed-By date or deliverable scope is treated as a schedule change and routed through the Change Control process. TPM notifies the receiver and updates the integrated schedule within 24 hours.
— PRACTITIONER REFERENCE —	

Standards & method: Aligned to PMI PMBOK 7 (Project Work Performance Domain - dependency identification and schedule integration) and PRINCE2 Plans theme (dependency mapping as part of plan quality). MSP Tranches and dependency management between programs and projects informs the program-level flagging rule. Method: identify dependencies -> classify by category -> log with float -> visualize critical path -> review weekly -> escalate at-risk items -> close on delivery.

Guiding principles: Every dependency is owned by a named person, not a team; float is calculated and visible so the team acts before the schedule is already broken; external dependencies are managed with the same rigor as internal ones; dependency data drives the integrated schedule, not the other way around.

What good looks like:

- Float is calculated for every dependency and updated weekly so the team can see which items are drifting before they become critical
- At-risk log is a live subset of the full log with named resolution owners and target dates - not a separate document that drifts from reality
- External dependency contacts are named individuals with escalation paths, not just vendor company names

- Dependency map is a single visual updated at each phase gate and used in SteerCo packs - it creates shared understanding without requiring everyone to read the full log
- Dependency changes are routed through Change Control so the integrated schedule stays synchronized

Common pitfalls:

- Dependency log created in Plan and never updated - by Execute it reflects the original plan, not reality, and the team stops trusting it
- Float not calculated - dependencies are listed as On Track or At Risk based on gut feel, removing the early-warning value of the log
- External dependencies tracked informally or not at all - vendor slips are only discovered when the receiver's work is blocked
- No named provider owner - 'the PAM team' is responsible, so nobody is, and nobody updates the status
- Dependency log kept separately from the schedule - the two diverge and project managers are managing two conflicting sources of truth

Maturity (1-5): L1 Dependencies identified informally in conversation; no log maintained; slips discovered when work is blocked; L2 Dependency log exists and is created in Plan but updated inconsistently; float not calculated; L3 Full dependency log maintained weekly by TPM; float calculated; at-risk items actively managed; external contacts named; L4 Dependency metrics (on-time delivery rate, average float at delivery, number of blocked items per sprint) reported to SteerCo; trends used to improve provider reliability; L5 Dependency data integrated into program-level risk model; predictive analytics flag at-risk items before float reaches zero; lessons learned fed back to dependency identification practices in future phases.

Artifact #53 — Team Charter & Working Agreements

Purpose: Establishes the team-level operating agreement covering ways of working, Definition of Ready and Definition of Done, decision rights, communication norms, core hours and meeting cadence, and conflict resolution - distinct from the project charter that authorizes the project.

When you use it: Authored and signed off during the Initiate phase before any delivery work begins; revisited at each phase gate or when team composition changes significantly.

Owner: TPM facilitates creation and owns the living document; entire core team co-authors and commits to it.

Cadence: Reviewed at the start of each sprint or monthly if waterfall; formally refreshed at each phase gate.

Where it lives: Workbook tab 'Team Charter'; linked from the RACI and the project intranet site.

Sections / contents:

Section	Contents / fields
Team Purpose	One-sentence mission statement tying the team's work to the Bristol Financial Atlas programme outcome (ZTNA + PAM delivery).
Core Hours & Availability	Agreed daily overlap window (e.g., 09:00-15:30 ET), on-call rotation rules, holiday/leave notification standard (min 5 business days).
Meeting Cadence	Table of all recurring team ceremonies: name, owner, frequency, duration, required attendees, and stated purpose.
Communication Norms	Channel-to-use matrix: Slack for async (<4 h SLA), email for formal decisions (24 h SLA), Teams call for urgent blockers (15 min SLA); no-reply-all policy.
Decision Rights	DACI table (Driver, Approver, Consulted, Informed) for the top 8-10

Section	Contents / fields
	routine decision categories within the team scope.
Definition of Ready (DoR)	Checklist a work item must satisfy before a team member pulls it into active work: acceptance criteria written, dependencies identified, estimate provided, security control owner confirmed.
Definition of Done (DoD)	Checklist a work item must satisfy before it is called complete: code/config peer-reviewed, unit tests passing, security scan clean, documentation updated, product owner accepted, deployed to target env.
Conflict Resolution Protocol	Step 1 - direct 1:1 within 24 h; Step 2 - TPM facilitated within 48 h; Step 3 - escalate to Programme Director if unresolved in 72 h.
Amendments	Any change to this charter requires TPM proposal + majority team vote; changes logged with date and rationale.
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to PMI PMBOK 7 Team Performance Domain (build shared understanding, foster accountability) and Scrum/SAFe Team & Technical Agility (Definition of Ready, Definition of Done, team norms). Method: draft purpose -> define DoR/DoD -> agree communication norms -> set decision rights -> run team retrospective to ratify -> publish and link from backlog tooling.

Guiding principles: Agreements are co-created, not imposed; DoR and DoD are measurable and binary; communication defaults to the lowest-friction async channel; the charter is a living document revised when reality diverges from it.

What good looks like:

- DoR and DoD are specific checklists with binary pass/fail criteria, not aspirational statements.
- All recurring meetings are listed with a stated purpose and an owner accountable for running them.
- Conflict resolution steps are numbered with explicit time-boxes so escalation is not personal.
- Decision rights use a DACI or RACI format and cover the decisions the team actually faces weekly.
- The charter was written by the team in a facilitated session, not handed down by the TPM.

Common pitfalls:

- DoD is a wish list ('high quality code') rather than a verifiable checklist, making it unenforceable.
- Charter is written once during onboarding and never referenced again after week two.
- Core hours set without checking distributed team time zones, creating a window that excludes key members.
- Decision rights omit the most contentious categories (scope changes, vendor selection) where conflict actually occurs.
- Communication norms are aspirational but no tooling or channel structure is set up to support them.

Maturity (1-5): L1 - Norms are implicit, unwritten, and unevenly applied; DoR/DoD absent. L2 - Charter exists but was written by TPM alone; DoD is vague; team rarely references it. L3 - Team co-created the charter; DoR and DoD are checklists; reviewed at phase gates. L4 -

Charter metrics (DoD pass rate, meeting attendance, blocker SLA) tracked and drive retrospective actions. L5 - Charter continuously optimised from retrospective data; DoR/DoD versioned and benchmarked against programme-level norms; new team members onboarded against it within day one.

Artifact #61 — Change Request & Change Control

Purpose: Provides a disciplined process for proposing, assessing, deciding on, and implementing changes to approved project baselines (scope, schedule, cost, quality, risk exposure); ensures every change is justified, fully impact-assessed across all constraints, decided by the appropriate authority, and traceable from request through to updated baseline - and is distinct from (but feeds) the Decisions & Changes Log.

Not to be confused with: Not to be confused with Organizational Change Management (Artifact #9): a Change Request manages changes to the project baseline (scope, schedule, cost, deliverables) through the CCB. OCM manages the people side - adoption and behavior change. Different discipline, different owner. Both also differ from ITIL change enablement, which controls changes to production systems.

When you use it: The process is active from the moment a baseline is agreed (end of Planning). Any team member, stakeholder, or sponsor may raise a Change Request at any time. The Change Control Board (CCB) convenes on a defined cadence or ad hoc for urgent requests. The process closes when the project baseline is closed at project closeout.

Owner: Project Manager owns the change control process and the Change Request log. The Change Control Board (CCB) is the decision authority. The Project Sponsor or Program Manager holds the authority threshold above which changes escalate. Requestor owns the initial justification; PM owns the impact assessment.

Cadence: Change Requests logged continuously. CCB reviews on a weekly or bi-weekly cadence for standard changes; same-day or next-business-day for urgent/emergency changes. Approved changes reflected in the baseline within 5 business days of approval.

Where it lives: Change Request forms stored in project SharePoint /Change-Control/Requests/; CCB decision log appended to this document or linked register; approved changes reflected in the project schedule and cost baseline in the PM tool (e.g., MS Project / Jira); summary posted to the Decisions & Changes Log (artifact key 8 or equivalent).

Sections / contents:

Section	Contents / fields
Change Request Form	Standardized form capturing: CR ID, date raised, requestor name and role, change title, description of the proposed change, business justification (why the change is needed), alternatives considered (including 'do nothing'), impact assessment across scope/schedule/cost/quality/risk, dependencies affected, stakeholder impacts, and requestor priority (High/Medium/Low).
Impact Assessment	PM-completed section: schedule impact (days/weeks; critical path effect), cost impact (additional spend, funding source, revised EAC), scope impact (in-scope additions/removals, revised WBS), quality impact (standards, deliverables, acceptance criteria affected), risk impact (new risks introduced or existing risks changed), and resource impact (people, skills, vendors).
Change Control Board (CCB) Composition & Authority	Named members and roles; decision authority thresholds by change magnitude (e.g., scope changes <=GBP 25K and <=2 weeks: PM authority; GBP 25K-100K or 2-8 weeks: CCB authority; >GBP 100K or >8 weeks or scope policy change: Program Board / Sponsor);

Section	Contents / fields
	quorum requirements; conflict-of-interest rules.
Decision & Conditions	CCB decision: Approved / Approved with Conditions / Deferred / Rejected. For each: rationale, conditions or constraints attached to approval, any partial approval, decision date, and decision authority sign-off.
Baseline Update Record	For approved changes: which baseline documents are updated (schedule, cost, scope statement, risk register), who made the update, date updated, version number of updated documents, and confirmation that the change has been communicated to affected stakeholders.
Change Request Log	Running table of all CRs: CR ID, title, date raised, requestor, category (scope/schedule/cost/quality/risk/external), status (Draft/Under Assessment/Pending CCB/Approved/Rejected/Deferred/Withdrawn), decision date, cost impact approved, schedule impact approved, and link to baseline update record.
Emergency Change Protocol	Criteria that qualify a change as emergency (e.g., security vulnerability, regulatory mandate, production outage), expedited process (PM + Sponsor verbal approval within 4 hours, CCB ratification within 2 business days), documentation requirements for emergency approvals, and audit trail obligations.
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to PMBOK 7 (Performance Domain: Delivery and Measurement; Integrated Change Control process from PMBOK 6 methodology embedded in PMBOK 7 practice guidance). Also references PRINCE2 Change theme: change authority, change budget, and off-specification handling. MSP change control at program level governs which project-level changes require program Board approval. Method: request raised -> impact assessed -> CCB reviews -> decision recorded -> baseline updated -> Decisions & Changes Log updated -> stakeholders informed.

Guiding principles: No change to an approved baseline without a formal CR - oral agreements to change scope or dates are not binding; the CCB's authority thresholds are calibrated to change magnitude and must be respected in both directions (under-escalation is as harmful as over-escalation); impact assessment must address all constraints, not just the one the requestor highlighted; every approved change generates a version-controlled baseline update.

What good looks like:

- Every approved CR has a corresponding baseline update record with a version number and date - the project plan always reflects the approved state, not the original state.
- Impact assessment addresses all six constraints (scope, schedule, cost, quality, risk, resources) even when the requestor believes only one is affected - it is common for a 'simple scope addition' to introduce new risks or consume contingency.
- Authority thresholds are calibrated in both money and time, and are agreed with the sponsor before the project baseline is set - not negotiated change by change.
- The Change Request Log is current to within 5 business days and provides a complete audit trail - an auditor could reconstruct every baseline change from the log alone.

- Rejected and withdrawn CRs remain in the log with rationale - they are part of the project's decision history and may be relevant to future disputes or lessons.

Common pitfalls:

- Allowing 'scope creep by conversation' - verbal agreements between a sponsor and a developer that are never formalized as a CR, resulting in undocumented baseline drift that surfaces at closeout as cost overrun or quality shortfall.
- Setting authority thresholds so high that the PM must escalate every minor change to the CCB, creating a backlog that incentivizes people to bypass the process entirely.
- Completing only the cost or schedule impact and ignoring risk and quality impacts - this produces a biased assessment that systematically understates the true cost of change.
- Treating the CCB as a rubber-stamp meeting that approves everything - if the CCB never rejects or defers a CR, it is not functioning as a control.
- Not updating the baseline after approval - the approved change then lives only in the CR log and is invisible to anyone reading the project schedule or cost plan.

Maturity (1-5): L1 Ad hoc: changes are verbal; no log; baseline is whatever the PM remembers. L2 Defined: CR form exists; log is maintained; CCB meets; but impact assessment is partial and baselines are not always updated. L3 Managed: full impact assessment on all constraints; CCB authority thresholds enforced; baseline updated within 5 days of approval; log is current and auditable. L4 Quantified: CR cycle time measured (days to decision); approval rate and rework rate tracked; change velocity used to forecast schedule risk. L5 Optimizing: change patterns analyzed to improve estimation accuracy; high-change-rate project types identified for enhanced scope management; change control data feeds portfolio risk modeling.

Artifact #62 — Contract Change Order

Purpose: Formally amends a signed vendor contract or SOW to document changed scope, deliverables, pricing, schedule, and acceptance criteria - creating legally binding obligations on both parties before any out-of-scope work begins.

When you use it: Raised whenever a vendor-facing change is identified during execution: scope creep beyond SOW, unforeseen technical complexity, vendor-requested schedule extension, or pricing adjustment triggered by agreed rate cards. Must be authorized before the vendor commences changed work.

Owner: Commercial/Procurement Lead authors and tracks; Project Manager initiates the request and validates technical scope; Legal reviews terms; Vendor counterpart signs. TPM confirms alignment with internal Change Request if a project baseline change is also required.

Cadence: Event-driven, not periodic. Each qualifying vendor change triggers one CO. Status reviewed at weekly Vendor Governance calls and summarized in the monthly Contract Performance Report.

Where it lives: Stored in the Contract Management Register (workbook tab 'Change Orders') and the vendor contract folder in the project document repository. Links back to the originating internal Change Request (CR) number and the relevant SOW clause.

Sections / contents:

Section	Contents / fields
CO Reference	Unique identifier (CO-[ProjectCode]-[Seq]); parent SOW/contract number; originating internal CR number if applicable
Change Description	Narrative of what is changing versus the current SOW baseline: scope additions/removals, deliverable modifications, acceptance-criteria revisions

Section	Contents / fields
Commercial Impact	Price delta (fixed fee, T&M rate, or milestone adjustment); revised total contract value; PO amendment reference; payment schedule changes
Schedule Impact	Original milestones or delivery dates affected; revised dates; knock-on effect on project critical path
Revised Acceptance Criteria	Updated RACI for acceptance testing; revised Definition of Done for affected deliverables; sign-off method and timeframe
Risk and Dependency Assessment	Risks introduced by the change; dependencies on other workstreams (e.g., ZTNA pilot timeline, PAM onboarding schedule); mitigation actions
Change Justification and Options Considered	Why the change is necessary; alternatives evaluated; recommendation with rationale; PMO/commercial recommendation
Authorization	Dual-signature block: authorized Bristol Financial signatory (Commercial Lead + Sponsor above a defined threshold) and vendor counterpart; date; version
Exhibit / Attachment List	Revised SOW pages, updated rate card, revised project schedule extract, technical specification annex
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to FAR change-order principles (constructive change doctrine, equitable adjustment, bilateral modification before work proceeds) and CIPS contract management best practice (contract baseline maintenance, change log, commercial sign-off hierarchy). Method: identify change trigger -> log in Change Order Register -> draft CO with commercial/legal review -> obtain dual signatures -> update PO/contract register -> notify PMO to align internal CR if project baseline also changes.

Guiding principles: No work before signature - vendor must not commence changed work until the CO is countersigned; commercial and technical scope must match - the CO scope narrative must be verbatim-consistent with the internal CR scope if one exists; audit trail is mandatory - every CO is sequentially numbered and linked to the originating decision; threshold-based authority - single-signature vs dual-signature authority levels are pre-defined in the Vendor & Contract Management Plan.

What good looks like:

- Each CO has a unique sequential reference, links to the originating CR or decision log entry, and is countersigned before work starts
- Commercial impact is broken down: delta price, revised total contract value, and affected PO line items are all explicitly stated
- Schedule impact is tied to named milestones with before/after dates so the critical-path effect is immediately visible
- Acceptance criteria for changed deliverables are rewritten - not just referenced - so the vendor and client share an unambiguous Definition of Done
- A change authority matrix in the Vendor & Contract Management Plan pre-defines who can authorize by dollar threshold, preventing ad-hoc approvals

Common pitfalls:

- Verbal or email approval accepted as authorization - creates dispute risk and constructive-change exposure; require countersigned CO every time

- CO scope narrative diverges from the internal CR scope description - causes delivery and audit misalignment; reconcile both documents before signing
- No link maintained between CO and PO - finance cannot reconcile invoices, accruals are wrong; always update the PO and note the CO reference on invoices
- Change orders batched at period end rather than raised event-driven - vendors start work at risk and cost tracking breaks; enforce a no-work-before-signature rule
- Acceptance criteria left unchanged when scope changes - vendor delivers to original criteria, project rejects deliverable; always rewrite acceptance criteria in the CO

Maturity (1-5): L1 Ad hoc: changes agreed verbally or by email, no formal document, contract baseline unknown; L2 Defined: CO template exists, changes documented retrospectively but inconsistently, no sign-off threshold matrix; L3 Managed: CO raised before work starts in most cases, register maintained, linked to internal CRs, reviewed at vendor governance; L4 Quantified: CO cycle time tracked (days from trigger to signature), rework rate from scope gaps measured, PO reconciliation automated; L5 Optimizing: predictive scope-risk scoring flags likely changes early, CO templates pre-populated from rate cards and schedule data, continuous improvement of change-authority thresholds based on historic data.

Artifact #63 — Resource Tracking & Time/Cost

Purpose: Records and reconciles actual resource consumption - headcount, hours worked, cost incurred, and contractor invoices - against the approved Resource Plan and budget baseline, producing the Actual Cost (AC) input for Earned Value Analysis and the burn-vs-budget view for project governance.

When you use it: Active from first resource mobilization in Execute through Close. Weekly timesheet capture and monthly cost reconciliation are the minimum cadence. The tracker is a live document updated continuously and formally reported at each Steering Committee cycle.

Owner: Project Manager owns overall accuracy and governance. Workstream leads validate their team's weekly hours. Finance/Commercial Lead reconciles contractor invoices and POs. PMO Analyst consolidates and publishes the report. Resource owners (line managers) confirm employee allocations monthly.

Cadence: Weekly: timesheets submitted and validated by workstream leads. Bi-weekly: cost burn vs budget reviewed in Project Controls call. Monthly: full reconciliation (actuals vs plan, PO vs invoice, forecast to complete) presented at Project Board. Ad hoc: updated when new resources join, leave, or change allocation.

Where it lives: Workbook tab 'Resource Tracking' (linked to tab 'Resource Plan' for variance). Contractor hours and invoices also maintained in the Contract Management Register. AC data exported to the Earned Value worksheet. Summary view surfaced in the Project Status Report dashboard.

Sections / contents:

Section	Contents / fields
Resource Register	Name, role, workstream, resource type (employee/contractor), start/end date, planned FTE allocation by period
Weekly Timesheet Summary	Actual hours submitted per person per week; validation status (submitted / approved / queried); cumulative hours to date
Allocation vs Actuals	Planned allocation % vs actual hours worked expressed as effective FTE; variance and trend; over/under-allocation flags
Cost Actuals - Employees	Blended or standard cost rate per role; actual hours x rate = actual labor cost; cumulative to date vs budget; forecast to complete

Section	Contents / fields
Cost Actuals - Contractors	Contractor name, vendor, PO number, agreed rate (day/hour), timesheets approved, invoices received vs PO value, accruals for unbilled periods
PO and Invoice Reconciliation	PO line items, invoices matched, variance (overbill/underbill), outstanding invoice status, approval workflow status
Burn vs Budget	Total budget by cost category (employee labor, contractor, other direct costs); spend to date; estimate to complete (ETC); estimate at completion (EAC); variance at completion (VAC)
Earned Value Inputs	Planned Value (PV) reference, Actual Cost (AC) from this tracker, Budget at Completion (BAC); fed into separate EV worksheet for CPI/SPI calculation
Resource Change Log	Entries for mobilizations, departures, allocation changes, role substitutions; date, reason, approval reference, impact on plan
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to PMI PMBOK 7 (Resource Performance Domain, Cost Performance Domain) and supports Earned Value Management as specified in PMI Practice Standard for EVM. Method: establish cost baseline from Resource Plan -> capture timesheets weekly -> validate and approve -> post actuals to tracker -> reconcile POs and invoices -> calculate burn rate and EAC -> publish to status report -> feed AC to EV calculation.

Guiding principles: Actuals are the source of truth - no estimate or plan figure may substitute for a real timesheet in the AC row; timesheets are mandatory and timely - late or missing timesheets are escalated, not estimated; cost and resource tracking are unified - hours and cost live in the same register so a single source drives both workforce utilization and financial reporting; contractor costs are PO-controlled - no invoice is approved without a matching PO line and approved timesheet.

What good looks like:

- Every person on the project has a row in the register with planned vs actual hours updated weekly; no shadow resources or untracked allocations
- Contractor invoices are three-way matched: PO line, approved timesheet, invoice amount - discrepancies flagged before payment
- Burn rate is trended (weekly rolling average) so an acceleration or deceleration in spend is visible before it becomes a significant variance
- Estimate to Complete is calculated using actual productivity (actual hours per deliverable completed), not a simple straight-line projection of remaining budget
- The resource change log captures every mobilization and departure with an approved reference, enabling retrospective analysis of scope change and resource churn

Common pitfalls:

- Timesheets submitted late or in bulk at period end - makes weekly burn tracking meaningless and PO reconciliation unreliable; enforce a Friday close with workstream lead approval
- Employee costs tracked at blended rate without distinguishing by role or seniority - masks true cost of senior resource over-use and makes reforecasting inaccurate
- Contractor PO value consumed but not updated when scope changes - tracker shows available budget that does not exist; PO must be amended before the CO is signed

- Allocation % used instead of actual hours for cost calculation - allocation is a plan artifact; only approved timesheets feed AC
- Resource tracker maintained separately from the financial system actuals - two sources of truth emerge; reconcile tracker to finance system monthly and note any timing differences (accruals vs cash)

Maturity (1-5): L1 Ad hoc: no timesheet discipline, costs estimated from plan, no PO reconciliation; L2 Defined: timesheet template exists, submitted inconsistently, burn vs budget reported monthly but not reconciled to finance system; L3 Managed: weekly timesheets approved by workstream leads, contractor invoices matched to POs, burn vs budget in every status report, AC feeds EV; L4 Quantified: productivity rates (hours per story point or deliverable) tracked, EAC calculated from actual CPI, resource utilization forecasted 4-6 weeks ahead; L5 Optimizing: automated timesheet ingestion from HR/ERP, real-time burn dashboard, predictive resource demand modelling, continuous calibration of cost rates.

Artifact #67 — Domain Model

Purpose: The Domain Model framework is a structured method for mapping a slice of the business - the meaningful things in it, how they relate, who uses them, and the rules that must always hold. It bridges technical and non-technical stakeholders by establishing a shared language and picture that a product manager, an engineer, and a compliance officer can all stand on.

When you use it: When entering a new business area, untangling a legacy system, scoping a platform program, or aligning teams who keep talking past each other. Fill each of the twelve building blocks in order - early blocks define the boundary, later blocks fill in the detail. Also use it as the domain layer beneath a capability map when planning a system modernization.

Who owns it: No single side owns the full model. Individual blocks have a lead discipline (business-led, IT-led, compliance-led, or joint), but every block is validated by the other sides. A block only one side believes in is exactly where a migration breaks later.

Where it lives: The domain model sits in the program's architecture workstream. It is produced in a cross-functional working session (Event Storming), maintained alongside the delivery backlog, and referenced during migration sequencing and decommission planning.

What a domain model is and is not:

A domain model is a shared picture of a slice of the business: the meaningful things in it, how they relate, who uses them, and the rules that must always hold. It is the language a team agrees to use so that everyone means the same thing when they say 'payment' or 'account.' It is not an org chart and not a database schema. It is not a system architecture diagram and not a feature list. It is the conceptual layer that makes those other artifacts coherent.

- IS: a shared vocabulary (ubiquitous language) that survives reorganizations
- IS: a map of entities, their identities, and the rules that must always hold
- IS: a set of explicit boundaries (bounded contexts) that let teams develop independently
- IS NOT: a database schema, class diagram, or system design
- IS NOT: an org chart or a process flow
- IS NOT: a static document - it evolves as understanding deepens

The capability map layer above:

Before the domain model comes the business capability map: what the business is able to do, in the language the business uses, independent of any system. Capabilities are stable. Domains and systems change underneath them. A capability is named as a noun phrase - 'Payment Execution,' not 'the payments team' and not 'the payments service.' It does not say how, who, or which tool. Business leaders own the capability map; IT owns the domain model that implements it.

How it connects down: Each capability is realized by one or more domains. 'Payment Execution' the capability is realized by the Payments domain. The capability map runs to three levels in practice. Level 1 is strategic (e.g., 'Payments and Transfers'). Level 2 decomposes it (e.g., 'Payment Execution'). Level 3 reaches named sub-processes (e.g., 'Payment Initiation,' 'Validation,' 'Settlement,' 'Reversal'). Planning stops around Level 3 - below that is implementation, which is exactly what the domain model handles. The Level 3 capability name and the bounded context name should match. Same words, two layers - that is the bridge a business sponsor and an engineer can both stand on.

The twelve building blocks:

Work top to bottom. Blocks 1 to 5 set the boundary and the language. Blocks 6 to 9 describe the structure. Blocks 10 to 12 cover the people, the rules, and the things that happen. Decide to skip a block on purpose - do not skip it by accident. The tag on each block shows who leads it; every block is still validated by the other sides.

Block	What it captures
01 Domain Charter	One-paragraph definition: name, single-sentence purpose, the business capability it supports, the owning team, what is explicitly in scope, and what is explicitly out.
02 Ubiquitous Language	The agreed glossary every artifact, ticket, and conversation uses. Each term, a plain definition, and the synonyms to retire.
03 Subdomains	The natural divisions tagged Core (build and invest), Supporting (build lean), or Generic (buy or outsource).
04 Bounded Contexts	The seams where a model and its language stay internally consistent. Each context, the team that owns it, and the model boundary it protects.
05 Context Map	How the bounded contexts depend on and integrate with each other. Each link, its direction (upstream feeds downstream), and the integration pattern.
06 Entities	The things with a distinct identity that persists over time. Name, the attribute that identifies it, key attributes, and its lifecycle states.
07 Value Objects	Things defined entirely by their attributes with no identity of their own (e.g., Money, Address, DateRange). The rules they enforce on themselves.
08 Aggregates	Clusters of entities and value objects treated as one consistency unit. The aggregate root, its members, and the invariant the cluster must always satisfy.
09 Relationships	How entities connect, with direction and multiplicity. Source, target, type (association or composition), and cardinality (1:1, 1:N, N:M).
10 Personas and Actors	The humans and systems that interact with the domain. Name, type (human or system), their goal, their permissions, and their key interactions.
11 Business Rules and Invariants	The constraints that must hold true no matter what. Each rule in plain language, the entity it governs, and the consequence of breaking it.
12 Domain Events	The significant things that happen, named in the past tense. Event name, what triggers it, the data it carries, and who reacts to it.

Context mapping:

Bounded contexts are the seams where a model and its language stay internally consistent. 'Customer' can mean different things in a Sales context and a Support context - bounded contexts let both be right. The context map shows how the bounded contexts depend on and integrate with each other. Upstream contexts feed downstream ones. Every link has a direction and a pattern that determines how a change upstream is absorbed downstream.

Pattern	What it means	When to use it
Partnership	Two contexts co-evolve and release together. Both teams coordinate closely.	Tight mutual dependency; teams can synchronize.
Customer/Supplier	Upstream supplies the downstream. Downstream has input into the upstream roadmap.	Clear directionality; downstream has leverage.
Conformist	Downstream accepts the upstream model as-is with no translation.	Upstream is non-negotiable (e.g., a regulated standard).
Anti-Corruption Layer (ACL)	Downstream shields itself from the upstream model via an adapter or translation layer.	Upstream is a vendor, legacy system, or external standard whose model must not leak in.
Shared Kernel	Two contexts share a small, carefully managed portion of the model, including tests.	High integration cost and well-governed overlap. Use sparingly.

Event Storming:

A template handed over by IT is an IT deliverable. What makes the model a shared agreement is the way it gets built: business and technical people at one wall, in plain language. Event Storming, created by Alberto Brandolini, is the standard technique for this. It is deliberately low-tech so notation never locks anyone out of the conversation. The whole room is present - business sponsor, domain experts, product, engineering, architecture, operations, compliance. If a part of the business is in scope, someone who lives in it is in the room; missing voices show up later as wrong boundaries.

- Chaotic exploration: everyone writes domain events on orange notes at once - no order yet, just volume.
- Enforce the timeline: arrange events left to right in the order they happen.
- Walk it backward: narrate from the end to surface missing steps and quiet assumptions.
- Add commands and actors: what triggered each event and who pressed the button.
- Mark policies and hotspots: rules in lilac, every disagreement and unknown in red.
- Cluster into boundaries: group the wall into aggregates and bounded contexts.
- Close by converting: before anyone leaves, name the outputs out loud - events, contexts, aggregates, risks - and give every red note an owner and a date.

Using the model to migrate then decommission:

The domain model is what tells you where to cut. The most common way modernization programs fail is wrong boundaries - so the order is fixed: do the domain modeling first, then move one slice at a time behind a stable front door (the routing facade), then retire the old system once nothing calls it. The pattern is the Strangler Fig, named by Martin Fowler.

- Phase 1 - Front door in place: a routing facade fronts the legacy system; the first low-risk slices move to new services; customers notice nothing.

- Phase 2 - Incremental cutover: core slices (e.g., Payment Initiation, Settlement) move across; data runs in parallel with shadow writes while the legacy source is still validated.
- Phase 3 - Decommission: the system-of-record (e.g., Ledger) cuts over last; with no remaining calls to the legacy core, it is switched off and the facade is retired.

Track three metrics during migration: percent of functionality migrated, percent of traffic rerouted, and legacy calls remaining. Zero remaining calls is the signal that decommission is safe. Sequence slices lowest-risk first to prove the facade and build delivery rhythm before tackling high-risk system-of-record cutover.

Practitioner reference:

Standards and method: Domain-Driven Design (Eric Evans, 2003) - the foundational text for bounded contexts, aggregates, entities, value objects, ubiquitous language, and context mapping. Business Capability Mapping - the technique for the layer above the domain model, used in strategic IT planning and enterprise architecture. Event Storming (Alberto Brandolini) - the collaborative workshop technique for building the model with the whole room; the standard method for populating Blocks 12, 4, 8, and the context map simultaneously.

Guiding principles: model the business, not the system; one word, one meaning, everywhere; every block is validated by all sides; boundaries are decisions, not discoveries - make them on purpose; the model is the residue of the conversation, not a substitute for it.

- Good looks like: business and IT using the same terms in standups, tickets, and design docs without translation
- Good looks like: bounded context boundaries that align with team ownership and deployment units
- Good looks like: every business rule written down in Block 11 before a single line of migration code is written
- Good looks like: the Event Storming wall converted into named outputs before the room empties
- Common pitfall: writing the model in IT alone and presenting it to the business for sign-off - this produces an IT artifact, not a shared model
- Common pitfall: a ubiquitous language glossary that IT maintains and business ignores - if the business does not use the terms in meetings, the vocabulary has not landed
- Common pitfall: aggregates so large that every change locks half the system; keep them as small as the invariant requires
- Common pitfall: skipping the out-of-scope list in the Domain Charter; scope creep always enters through the boundary that was never named

Maturity (1-5): L1 - no shared vocabulary; teams use different terms for the same thing and resolve collisions in meetings; L2 - a glossary exists but lives in a document no one opens; bounded context boundaries are informal; L3 - ubiquitous language is used in tickets, PRs, and design docs; bounded contexts are explicit and team-owned; L4 - the context map is maintained, integration patterns are enforced in code (ACL adapters, event contracts), and the domain model is the reference for delivery planning; L5 - the capability map and domain model are living artifacts reviewed each planning cycle; migration sequencing and decommission gates are driven directly from the model.

Project Management · Templates (65)

Template — Agile & Hybrid Delivery Plan

Fillable agile/hybrid delivery plan.

Sections:

- Approach selection and rationale (agile / scaled / hybrid)
- Definition of Ready and Definition of Done
- Backlog table: ID | Epic | Feature/Story | Acceptance criteria | Priority (WSJF/MoSCoW) | Estimate (points) | Status
- Cadence: sprint length, ceremony schedule, increment/PI boundaries
- Release plan: increment | objectives | target date | key dependencies
- Metrics block: planned velocity, WIP limit, cycle-time target; burndown/burnup chart placeholders
- Governance mapping: increment -> milestone -> budget tranche -> SteerCo report

HOW TO USE THIS TEMPLATE

Completion guidance: Establish the delivery model decision (pure agile, hybrid, or program increment cadence) in the first section before filling in any sprint or milestone fields, because every other field is mode-dependent. Convene the TPM, product owner, scrum masters, and release train engineer (if SAFe) for a 2-3 hour planning session using the product roadmap, capacity data, and dependency register as inputs. First pass should establish sprint cadence, definition of done, ceremony schedule, and the hybrid control points where agile tracks intersect with waterfall gates.

A strong completed version:

- Sprint goals link explicitly to program milestones and business outcomes, not just to a list of stories to be completed.
- Hybrid control points (where agile delivery must hand off to a stage gate) are named with the artifact required, owner, and lead time needed - not treated as an afterthought.
- Capacity is loaded realistically: named team members, their percentage allocation, and known absences or shared-service constraints are reflected in velocity targets.
- The plan defines how scope changes flow from the backlog through change control so agile flexibility does not bypass program governance.

Common pitfalls when filling it in:

- Listing ceremonies without defining their inputs, outputs, time-box, and facilitator, leaving teams to interpret the cadence differently.
- Setting a velocity target based on industry averages rather than the team's own historical throughput from a pilot or previous increment.
- Treating the hybrid plan as two separate plans stapled together, with no explicit translation layer between story completion and milestone earned value.
- Ignoring inter-team dependencies in the planning board, so sprint goals are blocked by work outside the team's control.

Template — Business Case & Cost-Benefit Analysis

Fillable business case + cost-benefit model.

Sections:

- Executive summary and recommendation
- Problem/opportunity and strategic alignment
- Options table: option | description | cost | benefit | risk | recommendation
- Cost model: one-time and recurring, by year, fully loaded
- Benefit model: benefit | type (hard/soft) | owner | \$ per year | realization start
- Financials: NPV (state discount rate), IRR, payback, ROI
- Sensitivity table (best/expected/worst)
- Assumptions and approval block

HOW TO USE THIS TEMPLATE

Completion guidance: Begin with the problem statement and strategic alignment section before touching any numbers; a business case whose financial model is not grounded in a clearly articulated problem and decision frame will be rejected by any serious investment committee. The project sponsor, finance partner, and a subject matter expert should co-author the first draft in a structured 2-hour session. Inputs are the strategic plan, any market or operational data supporting the need, and the preliminary cost estimate from the WBS.

A strong completed version:

- The base case (cost of doing nothing) is quantified, not assumed to be zero, so the net benefit calculation is credible.
- Sensitivity analysis tests at least three scenarios (optimistic, base, pessimistic) on the two or three most uncertain cost and benefit drivers.
- Non-financial benefits (risk reduction, regulatory compliance, employee experience) are enumerated with proxies or ranges, not dismissed as 'intangible'.
- The recommended option is compared against at least two alternatives, and the reasons for ruling out alternatives are documented.

Common pitfalls when filling it in:

- Building the financial model before agreeing on the benefit realization period and discount rate, producing NPV figures no two stakeholders calculated the same way.
- Including only direct project costs and omitting transition costs, training, ongoing operating cost delta, and technology run costs post-launch.
- Stating benefits as 'up to \$X' without specifying who owns the realization, when it will be measured, and what operational change drives it.
- Presenting a single-scenario financial model to an investment committee, which signals that assumptions have not been stress-tested.

Template — Business Requirements Document (BRD)

Captures what the business needs from the project — in business language. Approved by the business owner before technical design begins. Drives the technical spec, test cases, and acceptance.

AI enablement

- Auto-extract requirement candidates from sponsor interviews, customer feedback, and existing process docs.
- Detect ambiguity ('the system should be fast') and prompt for measurable rewrites.
- Auto-trace requirements to the workbook Requirements tab and to test cases in UAT.
- Flag requirements that aren't testable or don't have an acceptance criterion.

Document Control

Project name	[Name]
BRD version	[v1.0 / v1.1]
Author	[Name, role]
Date	[Date]
Business owner	[Name, title]

(approves)

Status	[Draft / Under Review / Approved]
— HOW TO USE THIS TEMPLATE —	

Completion guidance: Populate the business context and problem statement first - if those are weak, every requirement that follows will lack a rationale anchor; then elicit requirements through structured interviews with business SMEs and process owners before any technical discussion enters the room. A credible first-pass BRD for a mid-size initiative takes 3-5 working days of facilitated elicitation plus one full-day review session with the business owner to sign off each requirement's priority. Inputs are current-state process maps, pain-point logs, and any existing policy or regulatory constraints.

A strong completed version:

- Every requirement is uniquely numbered, tagged with a priority (Must / Should / Could / Won't), and traced back to a named business objective.
- Acceptance criteria are written in 'given / when / then' or equivalent testable language so UAT can be derived directly from the BRD.
- Assumptions and constraints are itemized separately and each has a named owner who will confirm or refute it before design begins.
- The document carries a formal sign-off block and a version log, because scope changes are inevitable and the baseline must be preserved.

Common pitfalls when filling it in:

- Writing requirements as solutions ('the system shall use a dropdown menu') instead of needs ('the user shall be able to select from a defined list of values'), which forecloses design options.
- Mixing functional requirements with technical constraints in the same numbered list, making requirements untraceable.
- Obtaining a single business SME's sign-off and calling it approved, when multiple business units own the process and will dispute requirements later.
- Leaving priority columns blank or marking everything 'High', which makes trade-off decisions during development impossible.

Template — Business Requirements Document (BRD) → Approvals

Business owner sign-off	[Name, date, signature]
Sponsor sign-off	[Name, date, signature]
TPM acknowledgment	[Name, date]
Compliance / Legal	[Name, date]

review (if applicable)

Template — Business Requirements Document (BRD) → Background & Business Context

Current state

[How things work today. Pain points. Volumes if relevant.]

Drivers for change

[Why now. What's forcing this — customer demand, regulatory deadline, competitive pressure.]

Strategic alignment

[Which corporate goal / OKR this serves.]

Template — Business Requirements Document (BRD) → Business Objectives

[3–5 SMART objectives. These are not requirements — they're the outcomes the requirements should deliver.]

1. [Objective 1 — measurable]
2. [Objective 2 — measurable]
3. [Objective 3 — measurable]

Template — Business Requirements Document (BRD) → Business Requirements

Each requirement has an ID, a clear statement, a priority, an acceptance criterion, and a source.

ID	Requirement	Priority	Acceptance criterion	Source
BR-001	[The system shall ...]	Must	[How we'll know this is met — measurable]	[Stakeholder, doc, regulation]
BR-002	[...]	[Must / Should / Could / Won't]	[...]	[...]
BR-003	[...]	[...]	[...]	[...]

[...]

Priority uses MoSCoW: Must Have (required for launch), Should Have (high value, not blocking), Could Have (nice-to-have), Won't Have (out of scope this release).

Template — Business Requirements Document (BRD) → Scope

In scope

[Specific business functions, processes, user groups, geographies, products, channels.]

Out of scope

[Specifically what is NOT included. Be explicit.]

Assumptions

[Working assumptions. Each one is a candidate risk if false.]

Constraints

[Time, budget, technical, regulatory, organizational constraints.]

Template — Business Requirements Document (BRD) → Stakeholders & User Groups

Stakeholder / user	Description	Approximate	Key needs
group		size	
[Group 1]	[Who they are]	[Count]	[Top 2–3 needs]
[Group 2]	[...]	[...]	[...]

[...]

Template — Change Request & Change Control

Fillable Change Request & Change Control. Raise a Change Request as soon as a potential baseline change is identified - do not wait for the impact to be fully analyzed before opening a CR. The PM completes the Impact Assessment section; the requestor completes only the top half of the form. A CR with an incomplete Impact Assessment will not be placed on the CCB agenda.

Sections:

- Change Request Form (top half - requestor completes): CR ID (auto-assigned) | Date Raised | Requestor Name & Role | Project Name | Change Title | Description of Proposed Change | Business Justification | Alternatives Considered (min 2 including 'do nothing') | Requestor Priority (High/Medium/Low) | Supporting documents attached Y/N.
- Impact Assessment (PM completes): Schedule Impact (days, critical path affected Y/N, new ECD) | Cost Impact (GBP, funding source, revised EAC, contingency draw-down Y/N) | Scope Impact (additions/removals, WBS sections affected) | Quality Impact (acceptance criteria, standards, deliverables affected) | Risk Impact (new risks or changes to existing risks, risk score delta) | Resource Impact (people, skills, vendor, equipment).
- CCB Composition & Authority (standing section, update when membership changes): Member | Role | Authority Level | Quorum requirement.
- Decision & Conditions: Decision (Approved/Approved with Conditions/Deferred/Rejected) | Rationale | Conditions | Decision Date | Decision Authority | Signature.
- Baseline Update Record: Document Updated | Previous Version | New Version | Updated By | Date | Stakeholders Notified.
- Change Request Log (running table): CR ID | Title | Date Raised | Requestor | Category | Status | Decision Date | Cost Impact Approved | Schedule Impact Approved | Baseline Updated Y/N.
- Emergency Change Protocol (standing section): Qualifying criteria | Expedited approval path | Ratification deadline | Documentation requirements.

HOW TO USE THIS TEMPLATE

Completion guidance: A CR is not closed until the Baseline Update Record is complete and the entry in the Decisions & Changes Log has been updated. Print or export the CR log as a PDF at each project status report cycle and attach it to the status report. At project closeout, the CR log must account for every GBP of cost variance between the original and final approved budget.

A strong completed version:

- Impact Assessment has a non-zero entry in at least 3 of the 6 constraint fields - if only 1 field is affected, the assessment has probably been done superficially.
- CCB meeting minutes record the deliberation, not just the decision - a future auditor should be able to see why a change was approved or rejected.
- The Change Request Log version in the project status report matches the version in SharePoint - there is one source of truth.
- At least one CR in every 10 is rejected or deferred - if the CCB never says no, the process is not functioning as a control.

Common pitfalls when filling it in:

- Raising a CR after the change has already been implemented - this retroactively documents a done deal and provides no governance value.

- Using the CR log as the baseline update record - these are separate: the log tracks decisions, the baseline update record tracks what changed in the project documents.
- Allowing the requestor to complete the Impact Assessment - this creates a conflict of interest and typically underestimates adverse impacts.
- Scheduling the CCB only monthly when changes are arriving weekly - the backlog forces informal workarounds that bypass the process.

Template — Contract Change Order

Fillable Contract Change Order. Use this template to formally document and authorize a change to a vendor contract or SOW for Project Atlas. Complete all sections before seeking signatures. If the change also affects the internal project baseline, raise a linked Change Request through the CCB before or concurrently.

Sections:

- CO Reference and Parent Contract Details
- Change Description (scope in / scope out)
- Commercial Impact (delta and revised total)
- Schedule Impact (before/after milestone table)
- Revised Acceptance Criteria
- Risk and Dependency Assessment
- Justification and Options Considered
- Authorization Signature Block
- Attachments / Exhibits

HOW TO USE THIS TEMPLATE

Completion guidance: The CO should take 2-5 business days from trigger to countersigned document for routine changes; complex pricing or scope changes may take 5-10 days and require Legal review. Pre-agree the threshold matrix and standard rate cards in the Vendor & Contract Management Plan so that commercial terms can be inserted without renegotiation during execution.

A strong completed version:

- Scope narrative uses the same terminology as the SOW and the internal CR to prevent interpretation gaps
- Commercial delta is itemized by rate, hours, and fixed-fee component - not just a lump sum
- Revised acceptance criteria are written as testable pass/fail statements
- Signature block captures name, title, and date for both parties

Common pitfalls when filling it in:

- Leaving the acceptance criteria section blank or marking 'unchanged' when scope has shifted
- Omitting the PO amendment reference so Finance cannot reconcile invoices
- Obtaining only one internal signature when the change exceeds the single-signatory threshold defined in the authority matrix
- Attaching a revised schedule without updating the named milestone table inside the CO body

Template — Cost Management Plan & Earned Value (EVM) Tracker

Fillable cost management + EVM tracker.

Sections:

- Baseline: BAC, time-phased PV by period
- Period tracking table: period | PV | EV | AC | CV | SV | CPI | SPI
- Forecast block: EAC (BAC/CPI), ETC, VAC, with method note
- RAG thresholds (e.g., CPI/SPI < 0.9 = red)
- Funding/commitment log: PO | vendor | committed | invoiced | paid
- Variance narrative and corrective actions
- Change-control threshold and re-baseline note

HOW TO USE THIS TEMPLATE

Completion guidance: Set the performance measurement baseline (PMB) - the time-phased budget by work package - before recording any actuals; without it, EVM calculations are arithmetic on meaningless numbers. The TPM and finance lead should spend 60-90 minutes aligning the WBS-based budget to the accounting cost centers; this reconciliation is the single hardest step. Inputs are the approved project budget, WBS, and schedule baseline.

A strong completed version:

- Planned Value (PV), Earned Value (EV), and Actual Cost (AC) are updated on a fixed cadence (weekly or bi-weekly) and the source of each figure is documented.
- CPI and SPI are trended over at least three periods so trajectory is visible, not just point-in-time status.
- Estimate at Completion (EAC) uses at least two calculation methods ($EAC = BAC/CPI$ and $EAC = AC + ETC$) and the TPM explains any divergence between them to the sponsor.
- Variance thresholds that trigger escalation ($\pm 10\%$ CPI or SPI) are defined in the plan and enforced, not left to judgment.

Common pitfalls when filling it in:

- Reporting Actual Cost from invoices paid rather than costs incurred, which lags reality by 30-60 days and makes EVM deceptive.
- Claiming 100% earned value only when a deliverable is fully complete (fixed-formula) for all work packages regardless of duration, which understates progress on long tasks.
- Setting the PMB at the total project level rather than the work package level, making it impossible to diagnose where variances originate.
- Updating the baseline whenever there is an unfavorable variance instead of managing through an approved change control, destroying the integrity of the cost history.

Template — Cross-Team Dependency Management

Fillable Cross-Team Dependency Management. This template provides the Cross-Team Dependency Log and supporting structures for [Program Name] at [Organization]. Populate the log collaboratively with all workstream leads in the first planning workshop. The dependency map should be drafted at the same session and validated against the integrated schedule before the Plan phase closes.

Sections:

- Dependency Log table - columns: Dep ID, Provider, Receiver, Deliverable Description, Needed-By Date, Promised Date, Current Status, Float, Owner, Notes/Actions
- Dependency Categories legend - four categories with examples from this program
- Dependency Map - blank swim-lane template for workstreams plus External row; annotated with Dep IDs
- At-Risk and Blocked Log - filtered view of the main log with Impact, Resolution Owner, Target Resolution Date, Escalation Tier

- External Dependency Contacts table - Vendor/Team, Named Contact, Contact Method, Acknowledgment SLA, Escalation Path
- Dependency Review Cadence - brief description of weekly and daily review steps and phase-gate audit

HOW TO USE THIS TEMPLATE

Completion guidance: The dependency log should have at least one entry per workstream interface before Plan closes; a log with fewer than 5 entries on a multi-workstream security program almost certainly means dependencies have been missed. Validate each Needed-By date against the integrated schedule and confirm Promised dates with providers in writing before publishing the baseline.

A strong completed version:

- Every dependency has a Dep ID, named provider, named receiver, and calculated float before the log is baselined
- At least one external vendor dependency is logged with a named contact and escalation path
- The dependency map has been reviewed by all workstream leads and they agree it reflects actual interdependencies
- Float is negative or zero for at least one dependency - this is normal and healthy; it means the team is being honest about schedule pressure

Common pitfalls when filling it in:

- Logging dependencies at too high a level (e.g., 'ZTNA workstream depends on PAM workstream') without specifying the deliverable and Needed-By date - too vague to manage
- Promised dates entered without confirming with the provider - the log will be wrong from day one
- No external dependencies logged even though the program depends on vendor hardware, cloud provisioning, or third-party integrations
- Float column left blank or filled with 'TBD' - the early-warning function of the log is lost

Template — Domain Model

Use this template to document a domain end to end. Work through the twelve building blocks in order. Blocks 1 to 5 establish the boundary and the shared language - do not skip them to get to the structural blocks. Every block has a lead discipline (noted in parentheses) and a validation step by the other sides. A block only one side believes in is a migration risk. Complete this template in a cross-functional session, not at a desk.

The twelve building blocks - fillable:

Block	What to fill in / prompt
01 Domain Charter (Business-led)	Name the domain. Write one sentence: what does this domain exist to do? Which Level-2 business capability does it realize? Who is the owning team? List what is explicitly IN scope. List what is explicitly OUT of scope - the out list is as important as the in list. Prompt: if this domain disappeared tomorrow, what would the business no longer be able to do?
02 Ubiquitous Language (Joint)	List every term that has caused confusion between business and IT. For each: write the single agreed definition, list the synonyms to retire. Prompt: where do business and engineering currently use different words for the same thing? Where does the same word mean two different things in two teams?

Block	What to fill in / prompt
03 Subdomains (Joint)	Break the domain into its natural divisions. Tag each: Core (this is why customers choose us - build and invest), Supporting (necessary but not differentiating - build lean), Generic (any vendor solves this - buy or outsource). Challenge each Core tag: is this truly a differentiator, or habit?
04 Bounded Contexts (IT-led)	Name each context. State what slice of the model it owns - which entities and rules live inside it. Name the team that owns it. Note where the same word means something different in two contexts - that is a valid boundary, not an error.
05 Context Map (IT-led)	For each pair of contexts that integrate: state which is upstream (feeds) and which is downstream (consumes). Choose the pattern: Partnership, Customer/Supplier, Conformist, Anti-Corruption Layer, or Shared Kernel. Flag any hidden two-way coupling.
06 Entities (Joint)	List each thing with a distinct identity that persists over time. For each: name it, state the attribute that uniquely identifies it, list key attributes, and write out its lifecycle states. Test: if two copies with identical attributes are still different things, it is an entity.
07 Value Objects (IT-led)	List things defined entirely by their attributes with no identity of their own. For each: name it, list the attributes that make it up, state the self-enforced rule (e.g., Money cannot add across currencies). Test: two copies with the same attributes are interchangeable.
08 Aggregates (IT-led)	Name the aggregate root. List its members (entities and value objects that belong to it). Write the invariant: the rule the whole cluster must always satisfy. State the transaction boundary. All external code touches the root only - never a member directly.
09 Relationships (Joint)	For each connection between entities: name the source and target, choose the type (association or composition), and state the cardinality (1:1, 1:N, N:M). Check each N:M relationship - it often hides a missing entity.
10 Personas and Actors (Business + Ops)	List every human role and system actor that interacts with the domain. For each: name, type (human or system), their goal, what they are permitted to do, and the key interactions. Do not forget system actors - scheduled jobs and integrations with no human behind them.
11 Business Rules and Invariants (Compliance-led)	List every constraint that must hold true no matter what. For each: write the rule in plain language, state which entity or aggregate it governs, and describe the consequence of breaking it. Rules buried in code or in one person's head belong here.
12 Domain Events (Joint)	List every significant thing that happens in this domain, named in the past tense. For each: name the event, state what triggers it, list the data it carries, and name who reacts to it. Name events as facts, not commands: 'PaymentSettled,' not 'SettlePayment.'

Context map template:

Bounded Context	Upstream / Downstream	Neighboring Context	Relationship Pattern	Notes
[Context A]	Downstream	[Context B]	[Pattern]	[What changes

Bounded Context	Upstream / Downstream	Neighboring Context	Relationship Pattern	Notes
				upstream break, and how is it absorbed?]
[Context A]	Upstream	[Context C]	[Pattern]	[What does Context A supply, and what contract governs it?]
[Context A]	<-> Partnership	[Context D]	Partnership	[Shared release cadence and co-evolution agreement]

How to use this template:

- Run blocks 1 to 5 in a cross-functional session before any technical design work begins - these blocks are the prerequisite for everything else.
- Use Event Storming to populate block 12 (Domain Events) and block 4 (Bounded Contexts) simultaneously - the wall produces both.
- When filling block 3 (Subdomains), challenge every Core tag with the whole room - over-engineering a Generic subdomain is one of the most common and expensive mistakes on modernization programs.
- The Context Map (block 5) must be validated by the engineering teams on both sides of each link - a pattern chosen without the downstream team's input is not an agreement.
- For a migration program, complete all twelve blocks before finalizing the sequencing plan - the migration slice order follows directly from the dependency structure in the context map.
- Review and update the model at each major delivery milestone; a domain model that is not updated becomes a liability.
- Common pitfall: treating the template as a form to fill out at a desk rather than a scaffold for a structured conversation.
- Common pitfall: writing the out-of-scope list in block 1 too vaguely - name the specific domains or capabilities that are excluded, so scope creep has no entry point.
- Common pitfall: modeling entities at the database-column level of detail - the template captures the domain concept, not the storage implementation.
- Common pitfall: leaving block 11 (Business Rules) until the end and treating it as optional - rules are where domain knowledge actually lives, and rediscovering them in incidents is expensive.

Template — Go-Live Readiness & Cutover Plan

Fillable go-live readiness + cutover plan.

Sections:

- Readiness checklist: domain | item | owner | status (R/A/G) | evidence
- Go/no-go criteria table and decision authority
- Go/no-go meeting: date/time, attendees, agenda, decision record
- Cutover runbook: step # | action | owner | planned time | dependency | validation | done?
- Rollback plan: trigger | step | owner | decision point | point of no return
- Comms timeline: audience | message | channel | timing
- Command center contacts and escalation

HOW TO USE THIS TEMPLATE

Completion guidance: Work backward from the go-live date to populate the cutover sequence; each task must have an elapsed-time estimate, predecessor, owner, and a go/no-go dependency flag before the plan is baselined. The TPM, technical lead, operations lead, and vendor delivery manager should build the initial cutover sequence in a 2-3 hour war-gaming session. Inputs are the deployment runbook, data migration plan, environment readiness checklist, and the rollback procedure.

A strong completed version:

- Every task in the cutover sequence has a start time, duration, owner, and predecessor, and the critical path through the cutover window is explicitly identified.
- Go/no-go criteria are binary and measurable (e.g., 'zero Severity 1 defects open', '>95% data reconciliation rate confirmed') - not subjective assessments.
- Rollback decision point has a hard clock time and a named decision authority; the rollback procedure itself is tested before go-live weekend.
- Hypercare support roster, on-call escalation path, and war-room bridge details are included in the plan so they do not need to be located under pressure.

Common pitfalls when filling it in:

- Building the cutover plan from a template rather than from the actual deployment runbook, producing a schedule that does not reflect the real task sequence.
- Omitting downstream system owners and business operations teams from the cutover sequence, so integrations and business processes are not verified until users call the help desk.
- Setting the go/no-go decision so late in the cutover window that there is insufficient time to execute a clean rollback before business open.
- Rehearsing the go-live only once and not updating the plan to reflect lessons from the dress rehearsal.

Template — Project Kickoff Pack

Three artifacts that travel together: pre-read sent 2–3 business days before kickoff, meeting agenda, deck outline. Use them as a set — the pre-read does the heavy lifting so the meeting can focus on alignment.

AI enablement

- Auto-draft the pre-read from the approved Charter and Stakeholder Register.
- Generate audience-tailored deck variants (exec vs working team) from one source.
- Pre-populate agenda timing based on past kickoffs of similar size and complexity.
- Capture meeting notes and surface action items, decisions, and risks into the workbook tabs.

1a. Kickoff Pre-Read

Sent 2–3 business days before kickoff. Goal: every attendee arrives knowing what the project is, why it exists, and what their role will be.

Project name	[Project name]
Sponsor	[Sponsor name and title]
Project manager / TPM	[Your name and title]
Kickoff date / time /	[Date, time, time zone, location or link]

location

Attendees [Names + roles]

Why we're doing this project

[2–3 sentences. Pull directly from the approved Charter — Section 'Business case'.]

What we're delivering

[Top 3–5 deliverables in plain language. Avoid jargon.]

Success criteria

[How we'll know we succeeded — measurable. Pull from Charter.]

Timeline & key milestones

[3–6 top-level milestones with target dates.]

Roles at a glance

- [Sponsor: ____ — accountable for project success]
- [TPM / PM: ____ — runs the project day-to-day]
- [Tech lead: ____ — owns the technical solution]
- [Business lead: ____ — owns the business outcomes]
- [Other named DRIs as relevant]

What I need from you before kickoff

[List of pre-work, if any. Be specific — vague pre-work doesn't get done.]

What we'll cover at kickoff

[Brief preview of the agenda — 3–5 bullets.]

1b. Kickoff Meeting Agenda

Recommended duration: 60–90 minutes.

Time	Topic	Owner	Outcome
0:00–0:05	Welcome, introductions, ground rules	TPM	Everyone knows who's in the room
0:05–0:15	Why we're doing this — sponsor framing	Sponsor	Shared understanding of the 'why'
0:15–0:30	Scope, deliverables, success criteria walkthrough	TPM	Alignment on what's in / out
0:30–0:45	Roles, governance, RACI walkthrough	TPM	Decision-making model is clear
0:45–0:55	Top risks and assumptions	TPM	Visibility on what could go wrong
0:55–1:10	Schedule, milestones, ways of working	TPM	Cadence is set
1:10–1:25	Questions, concerns, asks	All	Open issues captured
1:25–1:30	Wrap-up, next steps, action items	TPM	Everyone leaves with named actions

Ground rules to read at the top of the meeting

- This is a working meeting, not a presentation. Interrupt with questions.

- If you disagree, say so — silence is read as agreement.
- If something is unclear, that's a defect in the doc, not in you.
- Decisions made today will be in the Decisions & Changes log by end of day.

1c. Kickoff Deck Outline

Structure for the slide deck used during kickoff. Each slide is one idea.

Slide	Title	Key content
1	Cover	Project name, sponsor, TPM, kickoff date
2	Why we're here	Business problem / opportunity. Strategic alignment.
3	Outcomes	Success criteria and KPIs.
4	Scope	In-scope, out-of-scope, key assumptions
5	Deliverables	Top 3–5 deliverables with brief descriptions
6	Approach	Methodology, ways of working, key tools
7	Timeline	Top-level milestones — visual roadmap
8	Roles	Named DRIs; reference RACI
9	Governance	Decision-making model, escalation, steering cadence
10	Risks & assumptions	Top 3–5 risks with mitigation owners
11	Cadence	Status, standup, retro/governance cadence
12	Asks & next steps	What you need from sponsors/team in first 2 weeks
13	Q&A	Open the floor
— HOW TO	USE THIS TEMPLATE —	

Completion guidance: Start by locking the project name, sponsor, and hard dates before any other section, since every other field anchors to those facts; then work through scope, objectives, and team roster in sequence with the sponsor and workstream leads in the room. A disciplined first pass takes 90-120 minutes and draws from the approved business case, any existing SOW or procurement docs, and the program charter if one exists. Do not leave the meeting without a signed-off scope boundary and a confirmed decision-making authority.

A strong completed version:

- The scope section uses a crisp in-scope / out-of-scope table, not paragraph prose, so boundary disputes are resolved by pointing to a cell.
- Success criteria are measurable and tied to dates ('system available in production by Q3 close, zero Sev-1 defects at go-live'), not aspirational statements.
- Roles and accountabilities on the team roster map directly to the RACI, with no blank owner cells.

- The risks and assumptions section surfaces at least three named assumptions that would invalidate the plan if wrong, so they are tracked from day one.

Common pitfalls when filling it in:

- Writing objectives as activities ('implement the platform') rather than outcomes ('reduce manual reconciliation time by 40%').
- Leaving the sponsor signature block blank because the meeting ended before sign-off, then never circling back.
- Padding the scope section with everything the team might eventually do rather than committing to a hard out-of-scope list.
- Treating the kickoff pack as a one-time document rather than version-controlling it when scope or dates change.

Template — Quality Management Plan

Fillable quality management plan.

Sections:

- Quality objectives and applicable standards
- Definition of Done table: deliverable type | DoD criteria | verifier
- Acceptance criteria register (links to BRD requirement IDs)
- Review gates: artifact | reviewer | entry/exit criteria
- Test strategy summary (unit, integration, security, UAT) and ownership
- Defect severity definitions (S1-S4) and exit thresholds per environment
- Quality metrics table: metric | definition | target | source | cadence
- Sign-off and change history

HOW TO USE THIS TEMPLATE

Completion guidance: Start by defining the quality objectives and acceptance criteria in direct alignment with the project scope statement; this anchors every downstream activity. Convene the TPM, workstream leads, and a QA representative for a 90-minute session to assign ownership of each quality activity and gate. Inputs must include contractual SLAs, regulatory requirements, and any client-defined definition of done.

A strong completed version:

- Every quality gate has an entry criterion, exit criterion, responsible owner, and scheduled date - not just a gate name.
- Defect severity levels are defined with numeric thresholds that trigger escalation automatically.
- Quality metrics (defect density, test coverage %, review cycle time) are tracked against baselines, not described in the abstract.
- The plan distinguishes verification activities (are we building it right?) from validation activities (are we building the right thing?).

Common pitfalls when filling it in:

- Conflating QA process steps with QC checklists and leaving accountability ambiguous for both.
- Setting acceptance criteria after testing begins, making it impossible to objectively pass or fail a gate.
- Listing quality tools (e.g., peer review, UAT) without specifying frequency, sample size, or who reviews the results.
- Writing the plan for compliance purposes only and never referencing it after kickoff.

Template — RACI

Activities and decisions on rows, roles on columns, R/A/C/I in cells. Companion to RACI tab in workbook — use the workbook for the live, color-coded matrix; use this doc to capture role definitions and approved baseline.

See example: PMO_Examples.docx 4 (one decision in practice with all 11 roles assigned and rationale: 'Approve UAT entry for ZTNA Wave 1').

AI enablement

- Auto-draft a starting RACI from the project charter, deliverables list, and stakeholder register.
- Validate RACI integrity: flag any activity without exactly one Accountable.
- Detect role overload — surface stakeholders who are A on too many activities.
- Recommend role-by-decision adjustments based on similar past projects.

Role definitions

R — Responsible

Performs the work. Multiple R's allowed per activity. The doer.

A — Accountable

Owns the outcome. Exactly ONE A per activity. The buck stops here.

C — Consulted

Provides input before the decision. Two-way communication. C's must be heard before the A decides.

I — Informed

Kept aware after the decision. One-way communication.

Project roles for this RACI

- Sponsor — executive accountable for project success
- TPM / Project Manager — runs the project day-to-day
- Engineering Lead — owns technical solution
- QA Lead — owns quality and acceptance
- Business Lead / Product Owner — owns business requirements and acceptance
- Security — security review and approval
- Compliance / Legal — regulatory and contractual review
- Vendor — external delivery partner (if applicable)

Sample RACI matrix (baseline)

Edit to match your project. The live working matrix lives in the workbook with auto-validation.

Activity / Decision	Sponsor	TPM	Eng	QA	Business	Sec	Legal	Vendor
Approve project charter	A	R	C	I	C	I	I	
Approve scope changes	A	R	C	I	C	I	I	I

Activity / Decision	Sponsor	TPM	Eng	QA	Business	Sec	Legal	Vendor
Approve budget changes	A	R	I	I	C	I	I	I
Approve schedule changes	C	A/R	C	C	C	I	I	I
Approve vendor selection	A	R	C	C	C	C	C	I
Sign off on requirements	C	R	C	C	A	I	I	I

(BRD)

Sign off on technical design	I	R	A	C	C	C	I	C
Activity / Decision	Sponsor	TPM	Eng	QA	Business	Sec	Legal	Vendor
Approve UAT entry / exit	C	R	C	A	C	I	I	I
Approve go-live / production	A	R	C	C	C	C	I	I

deployment

Approve security review	I	R	C	I	I	A	C	I
Approve compliance review	I	R	I	I	C	C	A	I
Approve customer / external	A	R	I	I	C	I	C	I

comms

Resolve P0/P1 issues during I A/R R R C C I C
execute

Approve project closeout	A	R	C	C	C	I	I	I
Approve benefits realization	A	R	I	I	C	I	I	I

plan

RACI rules

- Exactly one A per row. If two people are both 'accountable,' no one is.
- Avoid having every role be a C on every activity. Consultation has a cost.
- If a stakeholder is an I on more than half of activities, they're being CC'd, not informed.
- If the same person is A on more than ~40% of activities, you have over-concentration risk.
- Revisit the RACI when team or sponsor changes, or after the first few weeks if it's not working.

PLAN

HOW TO USE THIS TEMPLATE

Completion guidance: List every decision and deliverable in the left column before assigning any letter, then work across each row left to right in a 60-90 minute workshop with all named stakeholders present; pre-populating with a draft and asking the group to challenge it is faster than building from a blank slate. Inputs are the project charter, the WBS, and any existing process maps. The project manager facilitates but does not assign their own R or A without the room's agreement.

A strong completed version:

- Every row has exactly one A, never zero or two, because ambiguous accountability is the single most common delivery failure.
- The columns are real named individuals, not roles or departments, so accountability cannot be diffused across a team.
- Rows cover decisions and approvals as well as deliverables, because approvals are where delays actually happen.
- The matrix is small enough to fit on two pages; anything larger signals the WBS needs to be restructured, not the RACI expanded.

Common pitfalls when filling it in:

- Assigning R to every stakeholder in a row to avoid conflict, which makes no one actually responsible.
- Confusing I (inform after the fact) with C (consult before the decision), leading to stakeholders who feel blindsided.
- Building the RACI from org-chart titles rather than the actual work, so the matrix does not match how decisions are made in practice.

- Never revisiting the RACI after team changes or scope changes, so it becomes a historical artifact rather than a working tool.

Template — RFP Scoring Rubric

Used by the evaluation team. Score independently first, then calibrate as a group.

AI enablement

- Auto-extract vendor responses to each requirement and produce a side-by-side comparison.
- Pre-score requirement-fit dimensions; humans review and confirm.
- Detect score outliers across evaluators and surface for calibration discussion.
- Validate vendor claims against reference customer feedback and public benchmarks.

Scoring Methodology

Score each criterion 1–5. Multiply by weight. Sum across criteria for total weighted score (out of 500).

Score	Meaning
5 — Exceeds	Significantly exceeds requirement; differentiated capability
4 — Strong	Fully meets requirement with depth and confidence
3 — Meets	Meets the requirement adequately
2 — Partial	Partially meets; significant gaps or workarounds
1 — Does not meet	Fails to meet the requirement
0 — Disqualifying	Mandatory requirement not met (vendor disqualified)

Per-Vendor Scorecard

Vendor name	[Name]				
Evaluator	[Name]				
Date	[Date]				
Criteria	Weight (W)	Score	Weighted (S × W)	Notes / evidence	ht (1–5)
Functional fit — Mandatory requirements met	—	Pass / Fail	—	[Notes]	
Functional fit — Desirable requirements	30	[1–5]	[calc]	[Notes — cite specific responses]	
Technical fit — architecture, integrations	10	[1–5]	[calc]	[Notes]	

integrations

Technical fit — security, compliance

Total cost of ownership (3-year)

Implementation approach	5	[1–5]	[calc]	[Notes]
Implementation risk	5	[1–5]	[calc]	[Notes]
Vendor qualifications	5	[1–5]	[calc]	[Notes]
References (after reference)	5	[1–5]	[calc]	[Notes]

checks)

Criteria	Weight	Score (1–5)	Weighted (S × W)	Notes / evidence
Service levels and support	10	[1–5]	[calc]	[Notes]
TOTAL	100	—	[Sum]	

Evaluator Calibration

- Each evaluator submits scores independently — no group discussion before submission.
- Scores are aggregated; gaps of 2+ points between evaluators are flagged.
- Calibration meeting reviews flagged gaps — evaluators explain reasoning.
- Scores are revised based on calibration. Average is the final.
- Calibration notes are recorded for the procurement file.

Reference Check Template

Question	Reference 1	Reference 2	Reference 3
Reference name and role	[Name, role]	[Name, role]	[Name, role]
Use case similarity to ours (1–	[Score]	[Score]	[Score]

5)

Implementation experience — [Notes] [Notes] [Notes]
on time, on budget? Issues?

Product / service quality (1–5)	[Score]	[Score]	[Score]
Vendor responsiveness and	[Score]	[Score]	[Score]

support (1–5)

Would they buy again? Why / [Notes] [Notes] [Notes]
why not?

Things they wish they'd known	[Notes]	[Notes]	[Notes]
Hidden costs or	[Notes]	[Notes]	[Notes]

Things they wish they'd known	[Notes]	[Notes]	[Notes]
surprises			

Award Recommendation

Recommended vendor	[Vendor name]
Total weighted score	[Score]
Top 2–3 strengths	[Bullets]
Top 2–3 risks / gaps	[Bullets — and how we'll mitigate]
Recommendation [Aw]	ard / Negotiate / Reject and re-bid]
Approving signatures [Sp]	onsor, procurement, finance]
— HOW TO USE THIS TEMPLATE —	

Completion guidance: Finalize and lock the scoring rubric before the RFP is issued - never after responses are received - so evaluators cannot unconsciously favor a preferred vendor; this requires a 60-90 minute workshop with the full evaluation committee to agree on weights and anchor descriptions for each criterion. Each criterion must have written anchor descriptions for at least three score levels (e.g., 1, 3, 5) so independent evaluators converge on similar scores for similar content. Inputs are the RFP requirements, the business case, and any enterprise vendor risk or compliance thresholds that are non-negotiable.

A strong completed version:

- Weights sum to exactly 100% and the weighting reflects the actual decision priority (technical capability may outweigh price for a complex integration engagement, or vice versa).
- Each criterion has written anchor language for at least three score points so two evaluators reading the same vendor response independently would assign scores within one point of each other.
- A mandatory/threshold section is separated from the scored section, so a vendor who fails a must-have (e.g., FedRAMP authorization, required certifications) is disqualified before scoring begins.
- The final scoring sheet includes a column for narrative justification per criterion, so the award decision can withstand a protest or audit.

Common pitfalls when filling it in:

- Designing the rubric after reading vendor proposals, which allows cognitive bias toward the preferred vendor to shape the scoring criteria.
- Assigning equal weights to all criteria as a default, which implies price and cultural fit matter as much as technical capability.
- Using vague anchor language ('good response', 'adequate') that allows each evaluator to apply their own standard, producing inconsistent scores.
- Allowing a single evaluator to complete all scoring without an independent second scorer, removing the check on individual bias.

Template — Request for Proposal (RFP)

Solicitation document sent to candidate vendors. A well-structured RFP saves weeks of evaluation later because responses are comparable. A bad RFP produces marketing brochures.

AI enablement

- Generate an RFP draft from the BRD and Technical Spec.
- Compare vendor responses to the structured RFP and produce a normalized comparison automatically.
- Detect inconsistencies between vendor proposal claims and reference customer reports.
- Flag when vendor responses use marketing language without committing to specific deliverables or

SLAs.

Document Control

RFP title	[Name of the procurement]
RFP issuer (legal entity)	[Company name]
RFP issue date	[Date]
Response deadline	[Date / time / time zone]
Procurement contact	[Name, email — single point of contact]
— HOW TO USE THIS TEMPLATE —	—

Completion guidance: Draft the statement of need and scope of work sections first, because vendors will scope their responses - and their prices - to exactly what you write there; vague scope produces incomparable bids. The sourcing lead, technical architect, legal counsel, and the business owner must all review their respective sections before the RFP is issued. Inputs are the approved BRD, a market analysis of available vendors, and any procurement policy constraints (single-source justification thresholds, insurance minimums, diversity requirements). Allow at least two weeks for internal review before the RFP is released.

A strong completed version:

- The scope of work is precise enough that two competing vendors would price the same deliverables, with no room for scope interpretation to explain bid variance of more than 15%.
- Evaluation criteria and their weights are stated in the RFP itself, so vendors know what matters and the evaluation team cannot change criteria post-submission.
- The question submission and response process is documented with specific dates, a single point of contact, and a commitment that all Q&A will be shared with all bidders simultaneously.
- Contractual terms (IP ownership, audit rights, termination for convenience) are included in the RFP as exhibits, so vendors flag conflicts before selection, not after.

Common pitfalls when filling it in:

- Writing requirements in the RFP that only one vendor can meet, exposing the procurement to a sole-source challenge.
- Omitting volume and complexity data (transaction counts, data volumes, integration endpoints) that vendors need to size their response accurately.

- Issuing the RFP before internal alignment on the evaluation criteria, then recalibrating the scoring rubric mid-evaluation.
- Setting a response deadline that gives large incumbent vendors an advantage over smaller challengers who need more lead time to prepare a competitive bid.

Template — Request for Proposal (RFP) → Evaluation Criteria

Tell vendors how they'll be evaluated.

Criteria	Weight
Functional fit (mandatory + desirable requirements)	30%
Technical fit (architecture, integrations, security)	20%
Total cost of ownership (3-year)	20%
Implementation approach and risk	10%
Vendor qualifications and references	10%
Service levels and support	10%
TOTAL	100%

Template — Request for Proposal (RFP) → Pricing

Provide a structured pricing template so responses are comparable.

Pricing component	Year 1	Year 2	Year 3	3-year total
License / subscription fees	[\$]	[\$]	[\$]	[\$]
Implementation / professional	[\$]	[\$]	[\$]	[\$]

services

Training	[\$]	[\$]	[\$]	[\$]
Pricing component	Year 1	Year 2	Year 3	3-year total
Ongoing support	[\$]	[\$]	[\$]	[\$]
Other (specify)	[\$]	[\$]	[\$]	[\$]
TOTAL	[\$]	[\$]	[\$]	[\$]
• [Pricing assumptions and wh	at's included /	excluded]		
• [Payment terms]				

Training	[\$]	[\$]	[\$]	[\$]
• [Inflation / CPI adjustment]	s]			
• [Volume discounts]				

Template — Request for Proposal (RFP) → RFP Process & Timeline

Activity	Date
RFP issued	[Date]
Vendor questions due	[Date]
Q&A responses published	[Date]
Proposals due	[Date]
Vendor presentations / demos	[Date]
Reference checks	[Date]
Decision communicated	[Date]
Contract signed	[Date]

Template — Request for Proposal (RFP) → Requirements

Pull from the BRD and Technical Spec. Group into Mandatory and Desirable.

Mandatory requirements (Must-Have)

ID	Requirement	Vendor response (Y/N + how)
M-001	[Requirement]	[Vendor fills in]
ID	Requirement Ven	dor response (Y/N + how)
M-002	[...]	

[...]

Desirable requirements (scored)

ID	Requirement	Weight	Vendor response
D-001	[Requirement]	[1–5]	[Vendor fills in]
D-002	[...]		

[...]

Template — Request for Proposal (RFP) → Security, Compliance & Privacy

- [Required certifications — SOC 2, ISO 27001, HIPAA, PCI-DSS, etc.]
- [Data handling, residency, encryption requirements]
- [Privacy and data subject rights handling]
- [Subcontractor / sub-processor disclosure]

- [Right-to-audit clauses]

Template — Request for Proposal (RFP) → Submission Instructions

•	[Format — PDF, length limits, file naming]
•	[Submission method — email, portal, secure transfer]
•	[Deadline and time zone — late submissions disqualified]
•	[Single point of contact — all questions through procurement contact]
•	[NDA requirements before responses are reviewed]

Template — Request for Proposal (RFP) → Terms & Conditions

•	[This RFP does not constitute a commitment to purchase]
•	[We reserve the right to reject any or all proposals]
•	[Costs of preparing the proposal are borne by the vendor]
•	[Information we share is confidential — NDA terms]
•	[Vendor information is treated as confidential per their request]

Template — Request for Proposal (RFP) → Vendor Qualifications

•	[Company overview, size, financials]
•	[Years offering this product / service]
•	[Customer base — relevant size and industry]
•	[3 reference customers we can contact, with similar use case and scale]
•	[Project team bios for proposed implementation team]
•	[Insurance, liability, indemnification]

Template — Requirements Traceability Matrix (RTM)

Fillable requirements traceability matrix.

Sections:

- Header: project, baseline BRD version, last updated
- Matrix fields: Req ID | Source | Priority (M/S/C/W) | Requirement | Design ref | Build/work item | Test case ID | Test result | Acceptance status | Evidence | Owner sign-off
- Coverage dashboard: total requirements, % traced to design, % with passing test (by priority)
- Orphan checks: requirements with no test; tests with no requirement
- Change-impact note column

HOW TO USE THIS TEMPLATE

Completion guidance: Seed the RTM from the approved requirements document or user story backlog before a single line of design begins; add the traceability links (requirement -> design artifact -> test case -> UAT sign-off) column by column as the project progresses. The BA or

product owner drives the first pass in 2-3 hours for a mid-size project; the TPM reviews for gaps. Inputs are the scope statement, functional specs, design documents, and the test plan.

A strong completed version:

- Every requirement has a unique ID and traces forward to at least one test case and backward to at least one business objective or stakeholder need.
- Coverage analysis shows zero orphaned test cases (tests with no requirement) and zero untested requirements at release entry.
- Change log column captures every requirement revision with date and approver, so the RTM doubles as a change history.
- Status column reflects real-time state (draft, baselined, in-dev, tested, accepted) enabling instant scope integrity check.

Common pitfalls when filling it in:

- Populating the RTM retrospectively at the end of a phase, breaking the traceability chain and making gaps invisible during development.
- Tracking only functional requirements and omitting non-functional requirements (performance, security, accessibility), which often drive the most expensive rework.
- Treating the RTM as a one-time artifact that is never updated when requirements change, rendering it useless for impact analysis.
- Confusing 'requirement documented' with 'requirement baselined and approved', so the coverage percentages are meaningless.

Template — Resource Tracking & Time/Cost

Fillable Resource Tracking & Time/Cost. Use this tracker to record all actual resource consumption for Project Atlas from mobilization through close. Update weekly (timesheets) and reconcile fully each month. This is the authoritative source of Actual Cost for Earned Value reporting.

Sections:

- Resource Register (all people, roles, types, allocations)
- Weekly Timesheet Summary (hours submitted and approved)
- Allocation vs Actuals (planned FTE vs effective FTE)
- Cost Actuals - Employees (hours x rate = cost)
- Cost Actuals - Contractors (timesheet, PO, invoice reconciliation)
- PO and Invoice Reconciliation (three-way match)
- Burn vs Budget (spend to date, ETC, EAC, VAC)
- Earned Value Inputs (AC export to EV worksheet)
- Resource Change Log

HOW TO USE THIS TEMPLATE

Completion guidance: The tracker is a live document, not a periodic deliverable - it should be current at all times and formally reconciled to the finance system at each month end. Allow 1-2 hours per month for the Finance/Commercial Lead to complete the PO and invoice reconciliation section.

A strong completed version:

- Every row in the resource register has an approved timesheet record for each active week - no blank actuals for live resources
- The burn vs budget section shows EAC and VAC, not just spend to date
- Contractor section has a PO reference and invoice status for every active engagement
- Change log entries include an approval reference, not just a description

Common pitfalls when filling it in:

- Populating the actuals columns with planned hours when timesheets have not been received
- Omitting accruals for contractor work delivered but not yet invoiced - understates true AC
- Mixing employee and contractor cost rows without clear labeling - makes it impossible to split cost categories for governance reporting
- Failing to update the resource register when a team member leaves mid-project - leaves ghost rows inflating planned cost

Template — Risk Register & Response Plan

Fillable standalone risk register. One row per risk; scoring legend at top.

Sections:

- Header: project name, TPM, register version, last review date
- Scoring legend: Probability 1 (rare) to 5 (almost certain); Impact 1 (negligible) to 5 (severe); severity = $P \times I$ with bands Low (1-6) / Medium (8-12) / High (15-25)
- Register table fields: Risk ID | Category | Risk statement ('If <cause>, then <effect>') | Trigger | P | I | Score | Owner | Response strategy | Response actions | Target date | Residual P | Residual I | Status
- Contingency reserve summary (schedule days, budget amount held)
- Top-5 risks callout for status reporting
- Change history

HOW TO USE THIS TEMPLATE

Completion guidance: Fill the scoring legend first so probability and impact mean the same thing to everyone, then populate one row per risk working from the RAID log and the WBS; expect a 60-90 minute first pass with the core team, refined weekly. The TPM owns the register but each row is filled with its named risk owner present.

A strong completed version:

- Every row has an owner, a trigger, and inherent and residual scores, not just a description.
- The top five risks are tagged for status reporting and reconcile to what the sponsor hears.
- Response actions are specific and testable ('contract a second identity engineer by 3/15'), not 'monitor'.
- Contingency reserve is derived from the open High risks, not a round number.

Common pitfalls when filling it in:

- Scoring severity before agreeing the legend, so scores are not comparable.
- Leaving the owner column as 'TPM' for every row.
- Writing response actions as 'mitigate' with no concrete step or date.
- Never updating residual scores, so the register cannot show mitigation is working.

Template — Statement of Work (SOW)

Contractual document defining scope, deliverables, schedule, pricing, and acceptance for vendor work. Where most vendor disputes originate is in vague SOWs — be specific.

AI enablement

- Auto-generate SOW first draft from the awarded RFP response and the BRD.
- Detect ambiguous deliverable language ('best effort', 'reasonable timeframe') and prompt for measurable rewrites.

- Compare against template SOWs for similar past engagements to flag missing standard clauses.
- Track SOW execution status against deliverables and milestones, surfacing slippage early.

Document Control

SOW number / ID	[ID]
Project / engagement	[Name]

name

Client (legal entity)	[Company name]
Vendor (legal entity)	[Company name]
MSA reference	[MSA ID and date]
SOW effective date	[Date]
Term	[Start date – End date]
—— HOW TO USE THIS TEMPLATE ——	

Completion guidance: Write the deliverables and acceptance criteria section before the payment schedule, because payment milestones must be tied to specific accepted deliverables, not to calendar dates or progress percentages; this requires the project manager, the vendor account lead, and legal to be in the same session. Inputs are the selected vendor's proposal, the RFP scope of work, and the organization's standard contract terms. Legal review of the liability, IP, and data handling clauses is mandatory before the SOW is executed, not optional.

A strong completed version:

- Every deliverable has a written acceptance criterion that specifies who accepts it, by what date, against what standard, and what the consequence of non-acceptance is (rework cycle, cure period, termination right).
- The payment schedule ties each milestone payment to an accepted deliverable, with no payment triggered by time alone.
- Change order procedures are defined in the body of the SOW, not referenced vaguely, so both parties know the process when scope changes arise.
- Key personnel are named in the SOW with a substitution approval clause, so the vendor cannot swap the team that won the work after contract execution.

Common pitfalls when filling it in:

- Writing deliverables as activities ('the vendor will conduct workshops') rather than outputs ('the vendor will deliver a validated current-state process map reviewed and accepted by the business owner').
- Omitting a definition of done for each deliverable, creating disputes at acceptance time about whether the work is complete.
- Setting payment terms that front-load vendor cash flow without corresponding client protections (performance bonds, holdbacks, escrow), creating leverage imbalance.
- Allowing the SOW to contradict the master services agreement (MSA) on terms like IP ownership or limitation of liability, which creates contract ambiguity that courts resolve unpredictably.

Template — Statement of Work (SOW) → Acceptance Process

9. Vendor delivers the deliverable with all artifacts specified.
10. Client has [N] business days to review.
11. Client either accepts in writing, or provides specific written feedback.
12. Vendor has [N] business days to address feedback.
13. Process repeats until accepted or escalated per Section 11.

Template — Statement of Work (SOW) → Change Control

14. Either party submits a Change Request describing change and impact.
15. Vendor provides impact assessment within [N] business days.
16. Both parties review and approve / reject.
17. Approved changes are documented in a signed Change Order, attached to the SOW.

Template — Statement of Work (SOW) → Confidentiality, IP & Data

•	[Confidentiality terms — typically reference MSA]
•	[IP ownership of deliverables, work product, and pre-existing IP]
•	[Data handling — what data vendor accesses, where stored, retention, deletion]
•	[Compliance with client security and privacy policies]

Template — Statement of Work (SOW) → Deliverables

Each deliverable has an ID, description, acceptance criterion, and target date.

ID	Deliverable	Description	Acceptance criterion	Target date
D-001	[Name]	[What it is]	[How we know it's accepted — measurable]	[Date]
D-	[Name]	[...]	[...]	[Date]

[...]

Template — Statement of Work (SOW) → Issue Resolution

18. PMs attempt to resolve at working level.
19. Unresolved issues escalate to sponsors / executives within [N] business days.
20. Unresolved at executive → mediation per MSA terms.
21. Termination for cause provisions per MSA.

Template — Statement of Work (SOW) → Personnel

•	[Key personnel named — replacement requires client consent]
•	[Background check / clearance requirements]
•	[Subcontractor disclosure and approval]
•	[Conflict of interest disclosures]

Template — Statement of Work (SOW) → Pricing & Payment

Engagement type

- [Fixed price / Time and materials / Capped T&M / Outcome-based]

Total fees

[\$ — total ceiling]

Payment schedule

Milestone / event	Amount	Due
[Signing]	[\$]	[Net 30]
[Milestone 1 acceptance]	[\$]	[Net 30 from acceptance]

[...]

- [Expenses — covered or not, pre-approval threshold, receipts required]
- [Late payment terms]
- [Currency and tax handling]

Template — Statement of Work (SOW) → Project Governance

•	[Vendor PM and Client PM named — single points of contact]
•	[Status reporting cadence and format]
•	[Steering committee composition and cadence]
•	[Escalation path]
•	[Change request process — see Section 8]

Template — Statement of Work (SOW) → Project Schedule & Milestones

Milestone	Description	Date	Linked deliverables
[Milestone 1]	[Description]	[Date]	[D-IDs]
[Milestone 2]	[...]	[Date]	[...]

[...]

Template — Statement of Work (SOW) → Scope of Work

Vendor responsibilities

[Specifically what the vendor will do. Use action verbs. Avoid 'manage', 'oversee', 'support' — too ambiguous.]

Client responsibilities

[What the client will do — provide access, review deliverables within X days, attend meetings.]

Out of scope

[Specifically what is NOT included.]

Template — Team Charter & Working Agreements

Fillable Team Charter & Working Agreements. Use this template to co-create the Project Atlas team operating agreement in a single 90-minute facilitated session. Complete every section before the first sprint begins. Leave no field blank - write 'TBD by [date]' if agreement is pending.

Sections:

- Team Purpose (1 sentence)
- Core Hours & Availability table (role, timezone, hours, leave-notice period)
- Meeting Cadence table (ceremony, owner, frequency, duration, attendees, purpose)
- Communication Norms matrix (channel, use-case, SLA, escalation path)
- Decision Rights DACI table (decision category, Driver, Approver, Consulted, Informed)
- Definition of Ready checklist (8-10 binary criteria)
- Definition of Done checklist (8-10 binary criteria)
- Conflict Resolution Protocol (numbered steps with time-boxes)
- Amendments log (date, change, proposer, vote outcome)

HOW TO USE THIS TEMPLATE

Completion guidance: Ratification requires all core team members to sign (digital or physical) before delivery work starts. Schedule a 30-minute charter retrospective at the end of sprint 2 to capture early friction points and amend accordingly.

A strong completed version:

- Every DoR and DoD criterion can be answered yes or no in under 30 seconds.
- The meeting cadence table contains no meeting without a named owner and stated purpose.
- Core hours reflect actual calendar availability verified against team members' calendars, not assumed hours.

Common pitfalls when filling it in:

- Skipping the facilitated session and emailing a draft for async sign-off - this produces compliance signatures, not genuine commitment.
- Writing DoD criteria that require subjective judgment ('adequate test coverage') rather than objective thresholds ('>= 80% branch coverage').
- Omitting the amendments log, which causes the charter to drift silently from team reality.

Template — Technical Requirements / Functional Specification

Translates business requirements into technical and functional requirements engineering can build against. Approved by technical lead and business owner.

AI enablement

- Generate a draft Tech Spec from the BRD by pattern-matching against architecture in similar past projects.
- Validate that every BRD requirement has at least one technical or functional requirement supporting it.
- Detect missing non-functional requirements by comparing against checklists.
- Surface technical debt or architecture risks introduced by the proposed approach.

Document Control

Project name	[Name]
Spec version	[v1.0]
Author	[Name, role]
Date	[Date]

Project name	[Name]
Technical owner	[Name, title]

(approves)

Business owner [Name, title]

acknowledgment

Status	[Draft / Under Review / Approved]
Linked BRD	[BRD doc reference / version]
— HOW TO USE THIS TEMPLATE —	

Completion guidance: Confirm the BRD is baselined before opening this document, then map each functional requirement ID from the BRD to at least one technical specification so traceability is built in from the first row; this cross-reference pass takes 2-3 hours with the lead architect and a business analyst together. Non-functional requirements (performance, security, availability) must be filled before any functional section is considered complete, because they constrain every design decision. Expect a two-week drafting cycle with daily architect-PM touchpoints for a system of moderate complexity.

A strong completed version:

- Every functional specification is traceable to a BRD requirement ID, and every non-functional requirement carries a measurable acceptance threshold (e.g., 'API response time < 200ms at 95th percentile under 500 concurrent users').
- Data flow diagrams and interface contracts are embedded or linked, not described in prose alone, so integration teams can build to a spec without interpretive meetings.
- The version history section shows delta changes between drafts, not just version numbers, so reviewers know exactly what changed.
- Security and compliance requirements are a dedicated section signed off by the security architect, not scattered as footnotes in functional sections.

Common pitfalls when filling it in:

- Writing 'the system should be fast and reliable' as a non-functional requirement with no measurable threshold.
- Allowing developers to populate the spec from their intended implementation rather than from business requirements, reversing the direction of traceability.
- Omitting error and exception flows under each functional requirement, which are inevitably discovered (and expensively resolved) during UAT.
- Treating the spec as frozen after initial sign-off and managing change requests informally, so the as-built system drifts from the approved baseline.

Template — Technical Requirements / Functional Specification → Approvals

Technical owner sign-off	[Name, date]
Architecture review (if	[Name, date]

applicable)

Security review	[Name, date]
Business owner	[Name, date]

acknowledgment

Template — Technical Requirements / Functional Specification → Architecture

System context

[How this system fits in the broader landscape.]

High-level architecture

[Components, layers, data flows. Reference architecture diagram.]

Technology stack

Layer	Technology choice	Rationale	Alternatives considered
Frontend	[Tech]	[Why]	[What was ruled out and why]
API / Application	[Tech]	[...]	[...]
Database /	[Tech]	[...]	[...]

Storage

Messaging / [Tech] [...] [...]

Events

Infrastructure / [Tech] [...] [...]

Hosting

Identity / Auth	[Tech]	[...]	[...]
Observability	[Tech]	[...]	[...]

Template — Technical Requirements / Functional Specification → Deployment & Operations

•	[Environments: dev, stage, prod]
•	[Deployment pipeline]
•	[Configuration management]
•	[Backup and disaster recovery approach]
•	[On-call ownership and runbook reference]

Template — Technical Requirements / Functional Specification → Functional Requirements

Each maps to one or more BR rows from the BRD.

ID	Functional requirement	Linked BR	Acceptance criterion
FR-	[The system shall ...]	BR-001	[Measurable]

ID	Functional requirement	Linked BR	Acceptance criterion
FR-	[...]	[BR-XXX]	[...]

[...]

Template — Technical Requirements / Functional Specification → Integrations & Interfaces

System	Integration type	Direction	Data exchanged	Frequency	Owner
[System name]	[API / Event / Batch / File]	[In / Out / Both]	[What data]	[Real- time / Daily]	[Owner]

[...]

Template — Technical Requirements / Functional Specification → Non-Functional Requirements

Often forgotten until late, then expensive to retrofit. Use the categories below as a checklist.

Category	Requirement	Target / threshold	Measurement method
Performance	[e.g., page load time]	[e.g., <2s p95]	[How measured]
Scalability	[e.g., concurrent users]	[e.g., 10k peak]	[Load testing approach]
Availability	[e.g., uptime SLA]	[e.g., 99.9%]	[Monitoring tool, exclusions]
Reliability / Recovery	[e.g., RPO / RTO]	[e.g., RPO 1h, RTO 4h]	[DR test cadence]
Security	[e.g., encryption, AuthZ model]	[e.g., AES-256, RBAC + MFA]	[Pen test, audit]
Privacy / Data protection	[e.g., PII handling, residency]	[Per regulation]	[Audit, DPIA]
Usability /	[e.g., WCAG level]	[e.g., WCAG 2.1 AA]	[Accessibility audit]

Accessibility

Maintainability	[e.g., code coverage]	[e.g., 80% coverage]	[CI / CD pipeline]
Observability	[e.g., logging, metrics, alerting]	[Defined SLIs / SLOs]	[Dashboard, alert review]
Compliance	[Applicable regulations]	[Specific controls]	[Audit, attestation]

Template — Technical Requirements / Functional Specification → Security Design

•	[Authentication approach (SSO, MFA, identity provider)]
•	[Authorization model (RBAC, ABAC, role definitions)]
•	[Encryption: at rest, in transit, key management]
•	[Secrets management]

•	[Authentication approach (SSO, MFA, identity provider)]
•	[Audit logging]
•	[Threat model summary — link to detailed threat model if separate]

Template — Transition to Operations & Hypercare Plan

Fillable transition + hypercare plan.

Sections:

- Handover register: item | from | to | accountable owner | status
- KT plan: topic | format | audience | date | sign-off
- Support model: tier | responsibility | SLA | contact | tooling
- Hypercare: window dates, staffing roster, daily review cadence, triage rules
- Hypercare exit criteria checklist
- Adoption metrics: metric | target | actual
- Operations acceptance / steady-state sign-off

HOW TO USE THIS TEMPLATE

Completion guidance: Draft the support model and escalation matrix before specifying hypercare duration; without knowing who covers what, the duration is just a number. The TPM, operations lead, project SMEs, and the receiving support organization should co-author this plan at least three weeks before go-live. Inputs are the go-live readiness plan, support capacity commitments, the known open-issues log, and any contractual SLA obligations that take effect at launch.

A strong completed version:

- Hypercare period has explicit entry criteria (go-live confirmed), exit criteria (ticket volume below threshold for X consecutive days, zero open Sev-1s), and a named decision authority who can extend it.
- Escalation matrix maps every issue severity level to a response time, resolver tier, and executive notification threshold - not just 'contact the project team'.
- Knowledge transfer completion is tracked with named recipients and sign-off dates, not assumed to happen through proximity to the project team.
- Run-book for steady-state operations is complete, reviewed by the operations team, and stored in the agreed knowledge repository before the transition date.

Common pitfalls when filling it in:

- Defining hypercare end as a calendar date regardless of system stability, so the project closes while Severity-1 issues are still open.
- Treating transition to operations as a single handoff meeting rather than a structured parallel-running period with explicit ownership transfer checkpoints.
- Not capturing a formal lessons-learned and open-issues list at transition, so operational teams inherit undocumented technical debt.
- Failing to confirm that the receiving operations team has the access, tools, runbooks, and authority they need before the project team disbands.

Template — UAT Plan & Test Cases

User Acceptance Testing — the final test phase where the people who will actually use the system validate it does what they need. UAT is the business owner's tool, not engineering's. Companion to the UAT Log tab in the workbook.

AI enablement

- Generate UAT test cases automatically from BRD requirements and user stories.
- Detect requirements that don't have test coverage and prompt for additional cases.
- Triage UAT defects: cluster similar issues, surface patterns, recommend severity.
- Predict UAT pass rate from early test execution and flag risk to go-live timeline.

Document Control

Project name	[Name]
UAT plan version	[v1.0]
UAT lead	[Name, title — typically business-side]
Date	[Date]
Linked BRD	[Reference]
Linked Tech Spec	[Reference]
— HOW TO USE THIS TEMPLATE —	

Completion guidance: Write test cases from the BRD and functional spec acceptance criteria line by line before any test environment is built, because the test cases define what the environment must be able to support; this exercise takes 3-5 days for a mid-complexity system and requires a business analyst, a QA lead, and at least one end-user representative working together. The test case author must not be the same person who wrote the requirement, because authors have blind spots for their own assumptions. Inputs are the signed-off BRD, functional spec, data dictionary, and the change impact assessment for user role coverage.

A strong completed version:

- Every test case maps to at least one BRD requirement ID and one functional spec ID, enabling full traceability from business need to tested behavior.
- Each test case includes preconditions, step-by-step actions, test data, and an unambiguous pass/fail criterion so any qualified tester can execute it without interpretation.
- The test suite covers negative paths and boundary conditions (invalid inputs, maximum load, permission denials) not only happy-path flows.
- Entry and exit criteria for the UAT phase are defined in the plan itself (e.g., '100% of Priority 1 test cases executed, zero open Sev-1 defects at exit'), so the go/no-go decision is objective.

Common pitfalls when filling it in:

- Writing test cases as high-level scenarios ('verify the system saves data correctly') with no step-by-step instructions, making results inconsistent across testers.
- Assigning UAT execution entirely to the project team rather than to business users who represent production behavior and have the authority to accept.
- Running UAT with production data or insufficient volume to simulate realistic load, discovering performance issues post-launch.
- Treating defect triage as ad hoc rather than running a daily defect review with a documented severity classification and resolution SLA per severity level.

Template — UAT Plan & Test Cases → Defect Severity Definitions

Severity	Definition	Resolution requirement
Critical (P0)	System unusable; data loss; security breach; blocks all testing	Must fix before UAT continues
Major (P1)	Important functionality broken; significant workaround needed	Must fix before go-live
Minor (P2)	Functionality works with issues; minor workaround acceptable	Fix if time / next release
Cosmetic	Visual / language issues; no functional impact	Backlog / next release

(P3)

Template — UAT Plan & Test Cases → Defect Triage Process

22. Tester logs defect with severity, steps to reproduce, expected vs actual, screenshots.
23. Triage meeting (daily during execution) reviews new defects.
24. Engineering fixes; pushes to UAT environment.
25. Tester retests and confirms or reopens.
26. Closed defects are spot-checked weekly to ensure they stay closed.

Template — UAT Plan & Test Cases → Entry Criteria

UAT does not start until ALL of these are met:

- [All Must-Have requirements implemented and engineering-tested]
- [Critical and major defects from system testing closed]
- [UAT environment available and stable]
- [Test data loaded]
- [Test cases approved by business owner]
- [Testers trained on testing approach and tools]
- [Defect tracking and triage process operational]

Template — UAT Plan & Test Cases → Exit Criteria

UAT is complete when ALL of these are met:

- [All Must-Have test cases executed]
- [Pass rate $\geq$ X% (typically 95%+ for go-live)]
- [Zero open critical defects]
- [Zero open major defects, OR documented business-owner acceptance with workaround]
- [All blockers resolved or formally accepted]
- [Business owner signs off]

Template — UAT Plan & Test Cases → Roles & Responsibilities

Role	Responsibilities
UAT Lead (business)	Owns UAT plan, approves entry/exit, signs off, escalates blockers

Role	Responsibilities
Business Testers	Execute test cases, log defects, validate fixes, confirm acceptance
Eng / Dev Team	Investigate and fix defects, redeploy fixes, support testers
TPM	Coordinate UAT logistics, track progress, maintain UAT Log, run triage
Business Owner	Approve test cases, approve exit criteria, formal sign-off
Product Owner / BA	Clarify requirements when defects are ambiguous, support testers

Template — UAT Plan & Test Cases → Sign-Off

UAT pass rate (final)	[%]
Open defects at sign-off	[List]

(with severity)

Workarounds [Y / N — list]

documented

Business owner [Name, title, date]

signature

TPM acknowledgment	[Name, date]
Sponsor	[Name, date]

acknowledgment

OPERATE / GOVERN

Template — UAT Plan & Test Cases → Test Cases (Catalog)

Each test case maps to one or more requirements. The full live execution log is in the workbook UAT Log tab.

Test	Test description	Linked	Test data	Expected result	Pri
ID		requirement			ori ty
TC-001	[Specific scenario]	[BR-XXX / FR-XXX]	[Pre-conditions, inputs]	[What should happen]	P0 / P1 / P2
TC-	[...]	[...]	[...]	[...]	

[...]

Test case writing tips

- One scenario per test case. Don't test five things in one case.
- Specify test data, not 'use sample data' — repeatability matters.
- Expected result must be observable. 'It should work' is not an expected result.
- Cover happy path, error path, and edge cases.

- Negative tests (should fail) are as important as positive tests.

Template — UAT Plan & Test Cases → UAT Approach

•	[Test environment — production-like, with sanitized data or synthetic data]
•	[Tester profiles — actual end users, not proxies]
•	[Test session structure — guided, exploratory, or scripted]
•	[Defect logging — tool, severity definitions, triage cadence]
•	[Daily / weekly UAT triage meeting cadence]

Template — UAT Plan & Test Cases → UAT Objectives & Scope

Objectives

- Validate the system meets business requirements (not just technical specs)
- Identify defects from a real-user perspective before production
- Confirm the system is usable for actual end-user workflows
- Provide formal acceptance from the business owner

In scope

[Functions, processes, integrations, user roles being tested]

Out of scope

[Performance testing (separate), unit testing (engineering), integration testing (engineering)]

Template — UAT Plan & Test Cases → UAT Schedule

Phase	Activities	Duration
Preparation	Test case writing, environment setup, data prep, tester training	[Days]
Execution Wave 1	Core scenarios	[Days]
Defect Fix & Retest	Eng fixes; testers retest	[Days]
Execution Wave 2	Full regression after fixes	[Days]

(regression)

Sign-off Exit criteria review, formal sign-off [Days]

Template — Vendor & Contract Management Plan

Fillable vendor & contract management plan.

Sections:

- Vendor register: vendor | contract ID | value | start/end | renewal notice date | owner | key contacts
- SLA/KPI table: metric | definition | target | measurement | source | penalty/credit
- Monthly scorecard: SLA % | quality | responsiveness | overall RAG | notes
- Governance cadence and escalation ladder
- Issue/dispute log: ID | issue | impact | status | resolution
- SOW change log and scope-vs-spend tracker

- Closeout checklist: deliverables accepted, KT complete, final invoice cleared, performance rating

HOW TO USE THIS TEMPLATE

Completion guidance: Complete the procurement strategy and sourcing rationale section before drafting any vendor-specific rows; the strategy must establish make-vs-buy decisions, contract type selection rationale, and competitive vs. sole-source justification. The TPM, commercial/legal lead, and procurement officer should complete the initial plan in 90 minutes using the project scope, WBS, and any existing approved vendor panels as inputs. Every contracted deliverable must then be mapped to a corresponding WBS element.

A strong completed version:

- Each vendor row includes contract type, total not-to-exceed value, payment milestones tied to deliverables, and the acceptance criteria that trigger each payment.
- The risk allocation section explicitly states which risks are transferred to the vendor (with indemnity language reference) and which remain with the project.
- Performance scorecard metrics are defined before contract execution, not improvised at the first review meeting.
- Escalation and dispute resolution path is documented with named roles and timeframes, so a performance issue does not stall for weeks waiting for a process to be invented.

Common pitfalls when filling it in:

- Treating the contract management plan as a legal document repository rather than an operational tracking tool, leaving the TPM with no visibility into vendor performance between invoices.
- Setting SLAs that cannot be measured with available data (e.g., 'system availability 99.9%' when no monitoring tool is in place).
- Failing to document change order authority thresholds, so every minor scope adjustment requires executive approval or, worse, none at all.
- Onboarding vendors before access, security, and data-sharing agreements are fully executed, creating compliance exposure from day one.

Template — Work Breakdown Structure (WBS) & Estimation Approach

Fillable WBS + estimation workbook.

Sections:

- WBS outline (indented IDs 1, 1.1, 1.1.1...) with the 100% rule note
- Work package dictionary: WP ID | Deliverable | Owner | Acceptance criteria | Predecessors
- Estimation table: WP ID | Method | Optimistic | Most likely | Pessimistic | PERT expected | Confidence | Basis-of-estimate note
- Rollup: phase totals and project total (effort and duration)
- Contingency calculation from spread (e.g., sum of (P-O)/6 as risk buffer)
- Assumptions log

HOW TO USE THIS TEMPLATE

Completion guidance: Decompose scope to the work package level before assigning any estimates; each work package must be small enough that a single owner can estimate and deliver it within one reporting period. Facilitate a 2-3 hour decomposition workshop with workstream leads and subject matter experts, using the project scope statement and requirements document as inputs. Estimates must include three values (best, most likely, worst)

for each work package and document the estimating method (analogous, parametric, or bottom-up) explicitly.

A strong completed version:

- The WBS is decomposed to a level where duration, cost, and ownership can be stated unambiguously - no work package broader than a single reporting period without justification.
- Every Level 2 element maps directly to a project objective, making scope gaps and overlaps visible at a glance.
- Estimation method and basis of estimate are recorded per work package, not assumed to be uniform across the tree.
- The dictionary accompanying each work package defines what is IN scope and explicitly what is OUT of scope to prevent scope creep.

Common pitfalls when filling it in:

- Building the WBS around the org chart instead of the deliverable hierarchy, producing an activity list rather than a scope decomposition.
- Skipping the WBS dictionary, so two team members estimate the same work package differently.
- Using single-point estimates everywhere and then wondering why the schedule has no buffer.
- Decomposing to too fine a level (individual tasks rather than work packages), making the structure unmanageable for a project of this scale.

Project Management · Worked Examples (40)

3 — Status Reports — Same Week, Three R/A/G

Versions

Three versions of the same status report (Project Atlas, week ending 2026-04-21) at three different statuses. Same week, same project — different facts on the ground. Shows how the writing changes by status.

Why three versions matter: TPMs often calibrate to the situation in front of them, but the language used signals very different things to executives. An On-Track status read as 'everything fine' invites disengagement. An Off-Track status read as 'oh no' triggers panic responses. Both are wrong. Below: how to write each.

Version A — Status: On-Track

Project Atlas, week ending 2026-04-21. Hypothetical: this week was uneventful and on track.

Field	Content
Report date	2026-04-21
Period	Wk 16 (4/15 – 4/21)
Reported by	Program PM
Overall status	On-Track
Key accomplishments this period	IdP migration: 35 of 50 Phase 1 apps migrated (on track). ZTNA pilot weeks 1–2 complete with no major issues — broader rollout green-lit for wk of 5/15. PAM SOW signed with BeyondTrust. FIDO2 hardware Phase 1 quantity received. Access Review RFP issued, 4 vendors

Field	Content
	confirmed bidding.
Planned for next period	Continue IdP migration toward 50-app Phase 1 milestone (target 5/30). ZTNA wave 1 readiness review with eng leads. PAM kickoff session with BeyondTrust. Begin FIDO2 enrollment for first 20 privileged users (pilot group).
Top risks / issues	RAID register stable. P-R-002 (legacy app SSO integration) under monitoring; integration test environment validated this week. No new issues raised.
Asks / blockers	None this week.

Notice in the On-Track report:

- 'Asks/blockers: None' — this is acceptable on On-Track weeks. Don't manufacture asks.
- Risks section is short and refers to monitoring. Detail lives in RAID Log.
- Accomplishments are specific (numbers, dates, named vendors). 'Things went well' is not enough.
- Even on On-Track, the report distinguishes 'on track' from 'ahead of schedule.' We're on track, not ahead.

Version B — Status: At-Risk

Project Atlas, week ending 2026-04-21. This is the actual situation in our scenario — what real At-Risk looks like.

Field	Content
Report date	2026-04-21
Period	Wk 16 (4/15 – 4/21)
Reported by	Program PM
Overall status	At-Risk
Status rationale	Two components are At-Risk. ZTNA Rollout (#2): pilot revealed dev tool
(required for At-Risk)	latency for 10% of cases — under remediation, pilot extended 1 week (DC- 007). MFA Hardening (#4): hardware lead time delay on FIDO2 tokens; hybrid platform-authenticator approach approved (DC-005) and Compliance review scheduled 4/26. Other 3 components On-Track. Program timeline currently holding — no slip to overall 9/30/2027 target.
Key accomplishments	ZTNA latency mitigation deployed for 90% of dev tool cases. PAM SOW
this period	\$50K ceiling increase approved (DC-004) — vendor counter-proposal expected 4/28. FIDO2 hybrid approach decision made (DC-005). Mainframe app removed from IdP scope (DC-006) — 18-month sunset path validated. Access Review RFP issued 4/15 with 4 vendors confirmed bidding.
Planned for next period	Complete ZTNA pilot extension; finalize architecture review for remaining 10% of latency cases. PAM SOW signature target 5/2. Compliance review of FIDO2 hybrid approach (4/26). Begin Wave 1

Field	Content
	readiness for ZTNA. Continue IdP Phase 1 migration.
Top risks / issues	P-R-001 (FIDO2 hardware lead time): mitigated by hybrid approach but Phase 2 timing still tight. P-I-001 (PAM SOW negotiation): expected to close by 5/2 without further escalation. P-R-004 (CISO sponsor departure rumor): being monitored — Program PM aligning with CIO/CTO as backup sponsors.
Asks / blockers	None this week. PAM SOW expected to close by 5/2 without further escalation. If it slips beyond 5/9, will need CISO intervention.

Notice in the At-Risk report:

- Status rationale is required and specific — names the components, the issues, and what's been done about them.
- Decisions referenced by ID (DC-002, DC-004, DC-005, DC-006) — preserves the audit trail.
- Risks tied to mitigations and dates. 'Being monitored' is acceptable when paired with what we'd do if monitoring shows escalation.
- Asks section names a future trigger ('if it slips beyond 5/9, will need CISO intervention') — gives the sponsor advance notice without crying wolf today.
- Confidence statement: 'Program timeline currently holding.' This matters — At-Risk doesn't always mean 'we'll miss the date.'

Version C — Status: Off-Track

Project Atlas, week ending 2026-04-21. Hypothetical: imagine the situation deteriorated. CISO departure confirmed; FIDO2 vendor announced 18-month delay; ZTNA pilot revealed latency problem unfixable in current architecture.

Field	Content
Report date	2026-04-21
Period	Wk 16 (4/15 – 4/21)
Reported by	Program PM
Overall status	Off-Track
Status rationale	Three concurrent material issues. (1) CISO sponsor
— HOW TO READ THIS EXAMPLE	—

Why this example works: Showing the same week in three R/A/G states is the teaching device: it forces the reader to see that the rating is a judgment, not a measurement, and that the same facts can be honestly rendered at different severity depending on what threshold the program team has set. The exemplary quality is that the facts do not change across the three versions - only the weight assigned to each and the call to action that follows.

Key judgment calls:

- In the Red version, calling out that the PAM vendor delay has breached the schedule contingency buffer, which is the objective threshold that justifies escalation - not the delay itself, but the breach of buffer.
- In the Amber version, showing the delay as tracked and mitigated (parallel workstream activated) rather than ignored, which is what earns Amber rather than Red.
- In the Green version, demonstrating that Green does not mean no issues - it means issues are within tolerance and under control, which requires the same discipline of reporting as Red.

Adapting it to your context:

- Your organization needs to agree in writing, before the program starts, on what R/A/G means numerically - days off plan, budget variance percentage, risk score threshold - so the rating is defensible, not political.
- The three-version format is a training tool for your PMO team and sponsor, not a production deliverable; use it in onboarding sessions to calibrate everyone's rating instincts.
- The specific thresholds used in Atlas (e.g., Green $\leq$ 5 days behind, Amber 6-14 days, Red $\geq$ 15 days) should be replaced with thresholds appropriate to your program's total duration and sponsor's risk tolerance.

4 — RACI — One Decision In Practice

To show how RACI works in practice, here's one decision from Project Atlas walked through with rationale.

Decision: Approve UAT entry for ZTNA Wave 1 (engineering org)

This is the decision that says 'pilot is done, we're cleared to roll out to broader engineering.'

High-stakes — a wrong call here means rolling out a broken experience to 600 engineers. Let's RACI it.

Role	RACI	Why
CISO (Sandra Park)	C	Sponsor consults but doesn't make this technical decision. Her input matters on whether residual risk is acceptable, but she trusts the operating team to make the call.
Program PM	R	Coordinates the readiness review. Ensures all entry criteria are evaluated. Drives the meeting and the recommendation. Doesn't make the final call alone.
ZTNA Component PM (J. Liu)	R	Owns the technical readiness assessment — pilot data, latency mitigation status, architecture review outcomes. Co- drives recommendation with Program PM.
Engineering Lead (CTO)	A	Accountable for the engineering org's experience and

Role	RACI	Why
designee)		productivity. The buck stops here on whether eng is ready to absorb this. Single A by design — if eng isn't ready, we don't go.
QA Lead	C	Provides input on pilot test results, defect status, and exit criteria validation. Doesn't make the readiness call but their input is required.
Network Engineering	C	Provides input on infrastructure readiness, capacity, and any latency remediation status they own.
Security (CISO designee)	C	Validates security posture is met. ZTNA policy reviewed, monitoring in place, response runbooks ready.
OCM Lead	C	Provides input on adoption readiness — help desk trained, comms calendar locked, eng champions briefed.
Help desk lead	I	Informed of the decision so surge planning is locked in. Doesn't influence the technical readiness call.
Eng champions network	I	Informed and given heads-up before the broader announcement so they can prepare for questions from their teams.
Affected engineers	I	Informed via the comms cadence (T-30 email goes out the day
(broader org)		after this decision).

RACI rules check

Wh	at t 1. P a 2. M t 3. E d 4. I D e 5. I w	his looks like in practice rogram PM schedules the UAT entry review meeting. Pre-read distributed 48 hours head with pilot data, defect status, mitigation summary. eeting: ZTNA PM walks through readiness against entry criteria (15 min). Cs share heir input (QA, Network, Security, OCM — 5 min each). ngineering Lead asks questions. Decides go/no-go in the room or commits to a ecision date if more data needed. f go: Program PM logs the decision in Decisions & Changes Log (Type: Decision, ecision-maker: Engineering Lead, Stakeholders consulted: list). Comms calendar T-30 mail triggers. f no-go: action items captured for what would unblock; date set for re- review. Logged ith rationale so we have an audit trail.
—	HO	W TO READ THIS EXAMPLE —
Wh	y th	is example works: By zooming into a single decision - the go/no-go for the ZTNA pilot cutover - this example shows what a RACI actually does in a meeting, not just on paper. The reader can see that having two Accountable owners produced a real conflict, that the Consulted tier received information too late to be useful, and that Informed parties were notified after the fact in a way that created rework - these are the failure modes RACI is meant to prevent.
Ke	y ju	dgment calls:
-	Assi	gning the go/no-go Accountable role to the CISO rather than the project manager, recognizing that security risk acceptance must sit with the business owner of the risk, not the delivery owner.
-	Iden	tifying the Network Architecture

Wh	at t 1. P a 2. M t 3. E d 4. I D e 5. I w	his looks like in practice rogram PM schedules the UAT entry review meeting. Pre-read distributed 48 hours head with pilot data, defect status, mitigation summary. eeting: ZTNA PM walks through readiness against entry criteria (15 min). Cs share heir input (QA, Network, Security, OCM — 5 min each). ngineering Lead asks questions. Decides go/no-go in the room or commits to a ecision date if more data needed. f go: Program PM logs the decision in Decisions & Changes Log (Type: Decision, ecision-maker: Engineering Lead, Stakeholders consulted: list). Comms calendar T-30 mail triggers. f no-go: action items captured for what would unblock; date set for re- review. Logged ith rationale so we have an audit trail.
		lead as Consulted rather than Responsible, because their input shapes the decision but they do not own execution - a distinction that prevents diffusion of accountability.
-	Docu	menting the decision log entry against the RACI row so there is a traceable link between who had the right to decide and what was actually decided.
Ad	apti	ng it to your context:
-	The	Atlas RACI uses a five-role model (R/A/C/I plus a Veto column for regulatory compliance); if your organization does not need a Veto column, remove it rather than leaving it empty, which creates noise.
-	The	specific decision (pilot cutover) is Atlas-specific; reuse the format - one decision per row, role assignments, decision log reference - for any high-stakes go/no-go in your program.

Wh	at t 1. P a 2. M t 3. E d 4. I D e 5. I w	his looks like in practice rogram PM schedules the UAT entry review meeting. Pre-read distributed 48 hours head with pilot data, defect status, mitigation summary. eeting: ZTNA PM walks through readiness against entry criteria (15 min). Cs share heir input (QA, Network, Security, OCM — 5 min each). ngineering Lead asks questions. Decides go/no-go in the room or commits to a ecision date if more data needed. f go: Program PM logs the decision in Decisions & Changes Log (Type: Decision, ecision-maker: Engineering Lead, Stakeholders consulted: list). Comms calendar T-30 mail triggers. f no-go: action items captured for what would unblock; date set for re- review. Logged ith rationale so we have an audit trail.
-	If y	our governance model uses a different vocabulary (Driver/Approver/Contributor/Inf ormed is common in tech firms), translate the roles rather than forcing Atlas terminology onto a different culture.

6 — Project Charter — Project Atlas

6 — Project Charter — Project Atlas (excerpt)

This is the executive-approved Charter that authorized Project Atlas in December 2025. Pulled from the live workbook 'Charter' tab, formatted as it appears in the doc form.

Project identification

Project name	Project Atlas — ZTNA & Identity Modernization
Project ID	PROG-2026-001
Sponsor	Sandra Park, CISO
TPM	Casey Morrison
Date / version	2025-12-18 / v1.2 (approved)

Business case

Problem: 2025 SOC 2 Type II audit identified 14 findings tied to legacy identity infrastructure (shared admin accounts, on-prem AD trust relationships, no continuous access verification).

Insider-threat incident in Q3 2025 resulted in \$1.2M loss and a regulatory inquiry. Current identity stack (legacy AD + Cisco AnyConnect + manual access reviews) cannot meet 2026 regulatory expectations.

Strategic alignment: Aligns with Bristol's 'Secure by 2027' strategic priority approved by the Board in Oct 2025. Enables the Cloud Migration program (PROG-2026-003) which is blocked on identity modernization.

Expected business value: Reduce identity-related risk exposure by ~\$4.5M annually (audit-validated estimate). Enable 4 downstream cloud initiatives. Pass 2026 SOC 2 audit with zero identity findings.

Cost of not doing: Continued audit findings → potential customer-required remediation → estimated \$2-3M in lost contract renewals; regulatory penalty exposure; cloud strategy stalled.

Objectives & success criteria

1. Migrate 100% of workforce identities (3,500 users) from legacy AD to Okta Workforce Identity by Q3 2026. Measure: zero authentication paths remaining on legacy AD.
2. Deploy ZTNA replacement for VPN to 100% of workforce by Q4 2026. Measure: VPN concentrators decommissioned.
3. Implement FIDO2 phishing-resistant MFA for all privileged accounts by Q2 2026, all employees by Q4 2026. Measure: zero SMS/voice OTP usage in audit logs.
4. Pass 2026 SOC 2 Type II audit (Aug 2026) with zero identity-related findings.
5. Deploy PAM (BeyondTrust) to 100% of privileged accounts by Q1 2027. Measure: zero direct-credential access to critical systems.

Scope

In-scope: Workforce identity (3,500 users), ZTNA for all corporate apps, MFA hardening, PAM for privileged accounts, access review automation for SOX/GLBA-scoped systems, Cloud Security Operations function buildout.

Out-of-scope: Customer-facing identity (CIAM — separate program), non-employee identities except contractor MFA, mainframe systems, mobile MDM (separate refresh).

Assumptions: Okta licensing already procured; BeyondTrust SOW in negotiation; sponsor has executive air cover from CEO; SOC 2 audit window unchanged.

Constraints: 2026 SOC 2 audit window (Aug 2026) is fixed; budget cap \$8.4M; cannot exceed 4 FTE additions; regulated change windows for production systems.

Timeline (phase-level, full schedule in Schedule artifact)

Phase 1 (Jan-Mar 2026): Identity Provider Migration foundation, MFA Hardening Wave 1 (privileged), PAM SOW execution.

Phase 2 (Apr-Sep 2026): IDP migration completion, ZTNA Wave 1-2, MFA Wave 2 (employees), Access Review Automation Phase 1.

Phase 3 (Oct 2026-Mar 2027): ZTNA Wave 3 (all apps), PAM rollout, Cloud Security Operations standup.

Phase 4 (Apr-Sep 2027): Stabilization, legacy decommissioning, knowledge transfer.

High-level risks (top 5; full register in RAID Log)

R-001: BeyondTrust contract negotiation slips → PAM milestone slips → SOC 2 finding (High/Medium, Mitigating)

R-002: Legacy AD trust relationships more complex than discovery → migration scope grows (High/Medium, Open)

R-003: VPN-to-ZTNA cutover causes user disruption → adoption resistance (Medium/High, Mitigating)

R-004: FIDO2 hardware token supply chain delays (Medium/High, Mitigating — buffer stock procured)

R-005: Sandra Park departure / sponsor change (Low/High, Watch — succession plan documented)

Budget summary: \$8.4M total (Capex \$5.2M, Opex \$3.2M). Approved authority for sponsor: ±10% reallocation across components without re-approval.

Approvals

Sponsor (CISO): Sandra Park / 2025-12-18 / signed

CIO: Linda Walsh / 2025-12-18 / signed

CTO: Mark Williams / 2025-12-18 / signed

CRO: Robert Stein / 2025-12-19 / signed

PMO: Martin Chen / 2025-12-18 / signed

HOW TO READ THIS EXAMPLE

Why this example works: This charter is exemplary because it does the one thing most charters avoid: it says what is out of scope with the same precision as what is in scope, and it assigns a dollar figure to the contingency reserve rather than leaving it as a percentage aspiration. The reader can see exactly what the sponsor is authorizing and what they are not, which means the charter can actually function as a contract.

Key judgment calls:

- Naming the legacy perimeter firewall decommission as out of scope for Phase 1 but flagged as a dependency for Phase 2, preventing scope creep while creating a documented handoff point for the next program increment.
- Setting the contingency reserve at 12% rather than the default 10%, justified by the complexity of the brownfield Active Directory environment - this is expert judgment visible in the document, not a black box number.
- Listing the three explicit decisions that require a charter amendment (scope expansion, budget increase > 15%, sponsor change) rather than leaving amendment triggers undefined.

Adapting it to your context:

- The charter's success criteria section uses a mix of technical metrics (ZTNA coverage percentage) and business metrics (incident response time reduction) - preserve this duality; a charter with only technical acceptance criteria will fail at sponsor review.
- The Atlas charter was signed before the BRD was complete, which is appropriate for an exploratory phase; if your organization requires a complete BRD before charter signature, adjust the sequencing but keep the charter's level of commitment language.
- Replace Bristol Financial's specific regulatory references (FCA PS21/3, PCI-DSS v4.0) with the obligations your program must satisfy, and confirm legal has signed off on the language before the sponsor signs.

7 — Project Kickoff Pack — Project Atlas

The kickoff pack travels as three artifacts: pre-read sent 3 business days before kickoff, agenda for the meeting, deck outline. This was the actual pack used for the Project Atlas all-hands kickoff on January 12, 2026.

Pre-read (sent 2026-01-09)

To: Project Atlas working team (47 people across 5 component teams)

From: Casey Morrison (TPM)

Subject: Project Atlas kickoff — pre-read for 1/12 meeting

Project name	Project Atlas — ZTNA & Identity Modernization
Sponsor	Sandra Park, CISO
TPM / Project manager	Casey Morrison
Kickoff date / time	Monday Jan 12, 2026 / 9:00–10:30 AM PT / Zoom + Boardroom A
Attendees	47 working team + 6 executive observers

Why we're doing this project (from Charter 1)

Bristol's 2025 SOC 2 audit produced 14 identity-related findings. The Q3 insider incident put us in a regulatory inquiry. Our identity stack can't meet 2026 expectations and it's blocking the Cloud Migration program. Project Atlas modernizes identity, deploys ZTNA, hardens MFA, and stands up PAM — together they remove the risk exposure and unblock the cloud strategy.

What we're delivering (top 5)

1. Workforce identity migrated from legacy AD to Okta (3,500 users)
2. VPN replaced by ZTNA for all corporate apps
3. FIDO2 MFA for privileged accounts (Q2) and all employees (Q4)
4. PAM deployed to all privileged accounts (BeyondTrust)
5. Access Review Automation for SOX/GLBA-scoped systems

Success criteria (from Charter 2)

- Zero authentication paths on legacy AD by Q3 2026
- VPN concentrators decommissioned by Q4 2026
- Zero identity findings in 2026 SOC 2 audit
- 100% privileged accounts in PAM by Q1 2027

Timeline & key milestones

M1: IDP migration design approved — Feb 2026

M2: MFA Wave 1 (privileged) complete — Apr 2026

M3: SOC 2 audit window opens — Aug 2026 (HARD DATE)

M4: ZTNA Wave 2 complete — Nov 2026

M5: PAM 100% deployed — Mar 2027

Your role — what we need from you

Component PMs: Confirm your team's commitments, raise risks early, attend Tuesday standups.

Engineering leads: Resourcing confirmation by 1/16. Architecture sign-off by 1/30.

Vendor counterparts (Okta, BeyondTrust): Onboarding paperwork complete by 1/15.

GRC: Audit alignment review by 1/19.

Open questions to bring to kickoff

- Component PM for ZTNA Wave 1: confirmed J. Liu — does anyone object?
- We're using Microsoft Project for the integrated schedule. Anyone need view-only access provisioned?
- Decision DC-001 logged: vendor of record is Okta (not Azure AD). Ratification at kickoff.

Agenda (90 min)

00:00–00:10	Welcome & sponsor framing — Sandra Park
00:10–00:25	Why this matters — business case & risk picture
00:25–00:50	What we're doing — components, milestones, dependencies
00:50–01:10	How we'll work — governance, RACI, comms cadence
01:10–01:25	Open Q&A
01:25–01:30	Next steps & action items

Deck outline (Casey delivers, Sandra opens)

Slide 1: Title — Project Atlas: ZTNA & Identity Modernization

Slide 2: Sponsor framing (Sandra) — why now, what failure looks like

Slide 3: The 5 components (one box each, owner named)

Slide 4: Top 3 milestones (IDP done Q3, SOC 2 audit Aug, PAM done Q1 2027)

Slide 5: Risks we've already identified (R-001 to R-005)

Slide 6: How we work together — governance cadence, RAID log, weekly status

Slide 7: First two weeks (commitments due dates)

Slide 8: Q&A

HOW TO READ THIS EXAMPLE

Why this example works: The kickoff pack is designed to create alignment at the end of the meeting, not just inform at the start - notice how every slide has an explicit owner and a desired outcome stated in the speaker notes, and how the agenda reserves 20 minutes for open issues rather than treating the pack as a broadcast. The pack acknowledges uncertainty honestly, which builds more credibility with a senior audience than false confidence.

Key judgment calls:

- Opening with the business risk narrative rather than the project plan timeline, because the sponsor audience cares about why first and what second - reversing this order is the most common kickoff failure.
- Including a pre-read summary page rated at five minutes of reading, respecting executive time and ensuring the live session can be used for decisions rather than orientation.
- Presenting the integrated plan at summary level (swim lanes, not Gantt) in the kickoff pack and offering the detailed plan as an appendix, recognizing that the kickoff audience is not the plan execution audience.

Adapting it to your context:

- The pack's structure (context and case for change, scope and non-scope, governance and RACI, plan overview, risks and assumptions, next steps) is a portable kickoff architecture; adapt the content of each section, not the sequence.
- Atlas kicked off with a mixed audience of technical leads and business sponsors in the same room; if your kickoff audience is purely technical or purely business, adjust the depth of the technical architecture slide and the length of the business case slide accordingly.
- The pre-read strategy works only if it is enforced; include a 48-hour pre-read distribution deadline in the meeting invitation and note in the agenda which sections will be assumed as read.

8 — Stakeholder Register — Project Atlas

Excerpt of the live Stakeholder Register at week 4 of execute. The full register has 38 entries; shown here are the highest-influence and the most engagement-sensitive ones. Workbook 'Stakeholders' tab is the source of truth.

Stakeholder	Role	Org	Influence	Interest	Engagement	Owner
Sandra Park	CISO / Sponsor	Bristol Sec	High	High	Champion	TPM
Linda Walsh	CIO	Bristol IT	High	High	Supporter	TPM
Mark Williams	CTO	Bristol Eng	High	Medium	Supporter	TPM
Robert Stein	CRO	Bristol Risk	High	High	Supporter	Sponsor
Diane Petrov	GC / Privacy	Bristol Legal	Medium	High	Active partner	Sec Lead
Martin Chen	PMO Director	Bristol PMO	Medium	High	Champion	TPM
Sophie Karim	Audit Lead	Bristol GRC	Medium	High	Active partner	Sec Lead
Michael Ortiz	IDP Component Lead	Bristol IT	Low	High	Owner	TPM
Jennifer Liu	ZTNA Component Lead	Bristol Net	Low	High	Owner	TPM
Karthik Reddy	PAM Component Lead	Bristol Sec	Low	High	Owner	TPM
Stephanie Chen	MFA Component Lead	Bristol IAM	Low	High	Owner	TPM
Phuong Nguyen	Access Review Lead	Bristol Sec	Low	High	Owner	TPM
Okta CSM (Marcus Bell)	Vendor Lead	Okta	Medium	High	Active partner	IDP Lead
BeyondTrust SE (R. Cho)	Vendor Lead	BeyondTrust	Medium	High	Onboarding	PAM Lead
Customer Success VP	Adoption owner	Bristol Sales	Medium	Medium	Aware	OCM Lead
Field Engineering	Daily VPN users	Bristol Eng	Low	Medium	Resistant	OCM Lead
Helpdesk	Support owner	Bristol IT	Low	High	Champion	OCM Lead

Stakeholder	Role	Org	Influence	Interest	Engagement	Owner
External auditor (KPMG)	SOC 2 examiner	KPMG	High	High	Quarterly review	Sec Lead
Board Risk Committee	Oversight	Board	High	Medium	Quarterly brief	Sponsor

Engagement plan summary (excerpt)

- Sponsor (Sandra Park): Weekly 30-min 1:1 with TPM; monthly steering committee chair; ad-hoc on Off-Track items.
- CIO (Linda Walsh): Monthly 1:1 with TPM; steering attendee; copied on weekly status.
- Field Engineering: Identified resistance source (VPN power-users). OCM lead running 3 listening sessions before ZTNA Wave 1. Tracked separately in OCM Plan 4.
- KPMG (external auditor): Quarterly status briefing with audit lead and Sec lead. No surprises rule — escalate any audit-relevant change within 5 business days.

Notable changes since v1 (logged in Decisions log)

- DC-008: Diane Petrov moved from 'Aware' to 'Active partner' after privacy review of access logs (March 2026).
- DC-014: Customer Success VP added after sales escalation about MFA fatigue (April 2026).
- DC-022: Field Engineering classification changed from 'Aware' to 'Resistant' after Wave 1 pilot feedback (June 2026).

One thing this register has caught: A high-interest, low-influence stakeholder (Helpdesk) was being treated as 'Informed' and we were missing critical adoption signal. Re-classified to 'Champion' and added to the OCM coalition.

HOW TO READ THIS EXAMPLE

Why this example works: This register is exemplary because it is stratified by influence as well as interest, and because it records the current engagement state alongside the target engagement state for each stakeholder - the gap between those two columns is the OCM workplan. Most registers stop at a 2x2 heat map; this one generates action.

Key judgment calls:

- Classifying the Chief Risk Officer as high-influence but low-interest (monitor closely) rather than treating all C-suite as uniformly high-engagement targets, which would waste relationship capital and desensitize the CRO to Atlas communications.
- Recording the Head of Retail Banking as a latent blocker (high influence, currently unengaged, potentially negative) and assigning a named executive sponsor to personally engage her before the pilot announcement.
- Distinguishing between stakeholders who need to approve versus stakeholders who need to adopt, because the engagement strategy for each is fundamentally different in both timing and depth.

Adapting it to your context:

- The Atlas register has 34 named stakeholders; for a smaller program, 10-15 is sufficient - resist the temptation to include everyone touched by the change, which dilutes focus on the stakeholders who can actually stop the program.

- The influence/interest scoring in Atlas uses a three-point scale (high/medium/low) rather than a numeric scale, which is appropriate for programs where stakeholder power is qualitative and political; use numeric scoring only if you have objective data to support it.
- Update the register at every major program milestone, not just at kickoff; a stakeholder who was supportive at charter can become a blocker after a pilot incident, and the register should reflect current reality.

9 — Integrated Project Plan — Project Atlas

The integrated plan is the single source of truth that ties Charter, RAID, Schedule, Resource Plan, Budget, and Status Reports together. Lives as the workbook 'Project Plan' tab — a roll-up dashboard that pulls from every other tab.

What it shows (real snapshot from week 18 of execute, June 2026)

Program identification	Project Atlas (PROG-2026-001)
Phase	Execute (Phase 2)
Reporting period	June 2-8, 2026
Overall status	At-Risk
Status rationale	MFA Hardware token delays (R-016) impacting Wave 2 schedule. Mitigation: buffer tokens deployed. Timeline expected to hold within 2-week float. ZTNA Wave 2 paused for RCA on 11/18 incident — see Post-Incident Review.

Component roll-up

Component	PM	Phase	Status	Budget %	Schedule %	Notes
Identity Provider Migration	M. Ortiz	Execute	On-Track	65%	62%	Foundation complete; Wave 2 active
ZTNA Rollout	J. Liu	Execute	At-Risk	45%	43%	Wave 2 paused pending RCA
PAM	K. Reddy	Plan	On-Track	20%	22%	BeyondTrust SOW signed; design phase
MFA Hardening	S. Chen	Execute	Off-Track	30%	18%	FIDO2 token supply delays; recovery plan in flight
Access Review Automation	P. Nguyen	Initiate	10%	12%	On-Track	Discovery complete; Phase 1 design

Decisions this period (full log in Decisions & Changes)

DC-027: Approved 1-week schedule extension on ZTNA Wave 2 to accommodate post-incident RCA (sponsor approved 2026-06-05).

DC-028: Approved \$80K reallocation from PAM to MFA to procure additional FIDO2 buffer tokens (sponsor approved 2026-06-06).

Risks active this period (full register in RAID Log)

R-016 (At-Risk → Off-Track candidate): MFA token vendor lead time slipped from 4 weeks to 8 weeks. Buffer tokens deployed. If lead time slips another 2 weeks, MFA component goes Off-Track.

R-021 (At-Risk): ZTNA Wave 2 user-population larger than estimated (4,200 vs 3,500). Capacity plan revisited.

R-023 (New): Insider-threat findings overlap with Access Review scope (under analysis).

Asks / blockers for sponsor

1. Sandra to communicate revised SOC 2 readiness posture to KPMG by 6/12 (request submitted 6/8).
2. Need CIO commitment on ZTNA Wave 2 communication to Field Engineering by 6/15 (resistance management).
3. Need GRC sign-off on MFA buffer-token compensating control by 6/14 (SOX-impacting).

Top 5 milestones in the next 30 days

M-008 (6/15): MFA Wave 2 — privileged accounts complete (target 95%, currently 87%)

M-009 (6/22): ZTNA Wave 2 cutover decision (after RCA complete)

M-010 (6/29): PAM design baseline approved

M-011 (7/06): IDP cleanup of legacy AD trust relationships

M-012 (7/13): Q3 SOC 2 evidence package due to KPMG

How this rolls up to the program (Project Atlas is itself a program)

The program-level integrated plan shows all 5 components on one page. Each component's individual Project Plan rolls up into the program view automatically. The program TPM owns the program-level plan; each component PM owns their component plan. The program sponsor (Sandra Park) sees the program view; component sponsors see their component view.

HOW TO READ THIS EXAMPLE

Why this example works: What distinguishes this integrated plan is that it shows dependencies across workstreams explicitly, not just within them - the reader can trace why an OCM milestone is a predecessor to a technical cutover milestone, which makes the critical path visible and politically undeniable. The plan also carries a baseline column alongside the current plan, so schedule variance is always visible in context.

Key judgment calls:

- Treating the PAM deployment as a parallel workstream to ZTNA rather than a sequential one, accepting a higher coordination cost in exchange for a compressed overall timeline - a deliberate schedule optimization decision, not an accident.
- Locking the baseline plan at sponsor approval and not re-baselining during the holiday freeze delay, preserving the integrity of variance tracking even when the delay was outside the team's control.

- Carrying only three levels of task hierarchy in the shared plan (phase, workstream, milestone) and keeping sub-task detail in workstream-owned plans, recognizing that a single over-detailed integrated plan becomes unreadable and unowned.

Adapting it to your context:

- The Atlas plan uses a 12-week sprint cadence with monthly steering reviews; adjust the cadence to match your organization's governance rhythm, not the other way around.
- The dependency arrows between OCM and technical workstreams are the most valuable part of the plan for stakeholder alignment; invest time in mapping these explicitly for your own program, even if no one asks for them.
- The plan is maintained in a shared tool (referenced but not named) with role-based edit access; whatever tool you use, enforce the rule that only the PMO can update the baseline column, and workstream leads update actuals in their own columns.

10 — BRD — ZTNA Rollout (Project Atlas)

10 — Business Requirements Document — ZTNA Rollout (Component 2 of Project Atlas)

This is the BRD for the ZTNA component, approved by sponsor and stakeholders in Feb 2026. The BRD captures what the business needs from the system; the Tech Spec captures how engineering will deliver it.

Document control

Title	ZTNA Rollout — Business Requirements
Version	v2.1 (approved)
Date	2026-02-19
Author	Casey Morrison (TPM) with J. Liu (Component Lead)
Approver	Sandra Park (CISO sponsor), Mark Williams (CTO)

Background & business context

Bristol Financial currently uses Cisco AnyConnect VPN as the primary remote access solution for 3,500 employees. The VPN concentrators are end-of-life (Cisco support ends 2027-Q1). The 2025 SOC 2 audit identified that VPN-based access doesn't meet 'continuous verification' requirements and creates excessive lateral-movement risk after authentication. The Q3 2025 insider incident exploited exactly this — once authenticated, the actor moved laterally through 14 systems before detection.

ZTNA (Zero Trust Network Access) replaces the VPN model with per-application, identity-aware, continuously-verified access. Cloudflare Zero Trust was selected (DC-005, Nov 2025) as the platform.

Business objectives

1. Replace VPN as the primary corporate access mechanism by Q4 2026.
2. Achieve continuous verification (per-request, not per-session) for all corporate applications.
3. Reduce post-authentication lateral-movement attack surface by 90% (measured by accessible-systems-per-identity audit).
4. Maintain or improve user experience (target: time-to-first-app under 10 seconds, vs current VPN ~30 seconds).
5. Pass SOC 2 2026 audit with zero ZTNA-related findings.

Scope

In-scope: All 142 internal corporate applications; all 3,500 employee identities; managed device posture (corporate laptops, MDM-managed mobile); contractor access (200 identities) starting Wave 3.

Out-of-scope: Customer-facing applications (separate program); BYOD personal devices (post-program); legacy mainframe (separate cycle); guest network access.

Stakeholders & user groups

User group	Approx size	Engagement model	Concerns
General employees	3,000	Comms + training	Disruption during cutover
Field Engineering	220	Resistant — listening sessi	ons in OCM Plan Existing VPN workflows
Privileged users	150	Active partner	Friction added to existing flows
Contractors	200	Vendor-managed comms	Onboarding clarity
Helpdesk	35	Champion	Support readiness
Application owners	58	Active partner	App compatibility

Business requirements

BR-001: Users authenticate to applications via SSO (Okta) with continuous device-posture verification.

BR-002: Privileged users get an additional FIDO2 step at the application boundary (not just at SSO).

BR-003: Helpdesk has access to access-event audit log for first-line troubleshooting.

BR-004: Application owners can view their own app's access-decision logs without raising a ticket.

BR-005: Cutover happens in 3 waves (low-risk apps first; critical apps last) to limit blast radius.

BR-006: Rollback to VPN is possible per-app for 30 days post-cutover (compensating control during stabilization).

BR-007: Telemetry is integrated with the SIEM so the SOC sees ZTNA events alongside other security data.

BR-008: Self-service password and MFA reset are available without VPN dependency.

Approvals

Business owner (CISO): Sandra Park / 2026-02-19 / signed

Technical owner (CTO): Mark Williams / 2026-02-19 / signed

Component lead: J. Liu / 2026-02-19 / signed

GRC reviewer: Sophie Karim / 2026-02-20 / signed

What this BRD does NOT include

Architecture diagrams, data models, integration sequence, capacity plans, cost models — those live in the Tech Spec / Functional Specification (companion document). The BRD is what the business needs; the Tech Spec is how it gets built.

HOW TO READ THIS EXAMPLE

Why this example works: This BRD earns its standing because the business requirements are stated as measurable outcomes with acceptance criteria, not as features - each requirement has a verification method, an owner, and a priority classification that distinguishes must-have from should-have. The reader can use this document to run a UAT sign-off meeting without having to interpret what done means.

Key judgment calls:

- Writing the authentication performance requirement as a latency threshold (MFA challenge ≤ 2 seconds at the 95th percentile) rather than a qualitative statement like 'seamless user experience', because qualitative requirements are unverifiable and become disputed at acceptance.
- Including a regulatory traceability matrix that maps each requirement to its FCA or PCI-DSS source, creating an audit trail that survives personnel changes and satisfies the compliance team without requiring a separate document.
- Deferring the biometric authentication requirement to Phase 2 with an explicit rationale (enrollment infrastructure not ready) rather than marking it out of scope entirely, preserving the requirement for future delivery.

Adapting it to your context:

- The ZTNA-specific requirements (device posture checking, conditional access policy logic, split-tunneling rules) are not reusable content; they are examples of how to write a security control requirement with measurable acceptance criteria - apply that same standard to your own controls.
- The BRD uses a MoSCoW prioritization scheme; if your organization uses a different priority framework (Kano, numbered tiers), translate it, but preserve the discipline of assigning every requirement an explicit priority.
- Bristol Financial's BRD was approved by both the CISO and the Head of Retail Operations, reflecting joint business-security ownership; identify the equivalent dual-approval owners for your program before starting requirements elicitation.

11 — Tech Spec — ZTNA Rollout (Project Atlas)

11 — Technical Requirements / Functional Specification — ZTNA Rollout

Companion to the ZTNA BRD. Where the BRD answers 'what does the business need,' the Tech Spec answers 'how will engineering deliver it.' Approved Mar 2026.

Document control

Title	ZTNA Rollout — Technical Requirements / Functional Specification
Version	v3.0 (approved)
Date	2026-03-04
Author	J. Liu (Component Lead) with Eng + Architecture review
Approver	Mark Williams (CTO), Sandra Park (CISO co-approver for security architecture)

Architecture summary

ZTNA platform: Cloudflare Zero Trust (Access + Gateway + WARP).

Identity provider: Okta Workforce Identity (SSO, MFA, lifecycle).

Device posture: Microsoft Intune for managed devices; CrowdStrike for endpoint signal.

Telemetry pipeline: Cloudflare → Splunk (SIEM); Okta logs → Splunk; Intune signals → Splunk.

DNS: Cloudflare Gateway as recursive resolver.

Functional decomposition

Function	Owner	Tooling
1. Identity-based access decision per request	Cloudflare Access	Okta SAML + Cloudflare policies
2. Device posture verification	Intune + CrowdStrike	Posture-token to Cloudflare
3. Per-app policy enforcement	Cloudflare Access	Application connectors
4. Step-up authentication (privileged)	Cloudflare + Okta	FIDO2 enforcement at app boundary
5. Audit logging & SIEM integration	Splunk	HEC ingestion
6. Self-service password + MFA reset	Okta	Self-service portal (no VPN dependency)

Non-functional requirements

NFR-001: P99 access decision latency under 500ms (excluding application response time).

NFR-002: Cloudflare PoP availability for the user population: minimum 4 PoPs serving North America.

NFR-003: Failover time on PoP outage: under 30 seconds (Cloudflare Anycast).

NFR-004: Audit log retention: 90 days hot, 7 years cold (compliance requirement).

NFR-005: All access decisions auditable to user, app, time, decision, and reason within 30 seconds.

Integration points

- Okta → Cloudflare: SAML federation, group-claim mapping, JIT provisioning.
- Cloudflare → Splunk: HEC streaming, structured event format.
- Intune → Cloudflare: Service-to-service device posture API call.
- Cloudflare → 142 applications: Per-app connector or browser-based access; 89 connector-based, 53 browser-based per app inventory.

Capacity plan

User concurrency at peak: 2,800 (estimated from current VPN data).

App-access requests at peak: ~85K/hour (estimated).

Cloudflare licensing: Tier sized for 4,000 seats (1.15x current to allow growth).

Splunk ingest: estimated 220 GB/day from ZTNA + Okta + Intune.

Cutover sequence (3 waves)

Wave 1 (Apr 2026): 28 low-risk internal apps; pilot population of 200 users (volunteer + early adopters).

Wave 2 (Jul 2026): 67 mid-risk apps; broad employee population (excluding Field Engineering).

Wave 3 (Oct 2026): 47 critical apps + Field Engineering + contractors. PAM-protected privileged sessions move in this wave.

Each wave has a 14-day 'soak' before the next wave. Rollback to VPN is supported per-app for 30 days post-cutover.

Security architecture review (sign-off Sandra Park)

- Continuous-verification posture: confirmed (each request, not just at session start).
- Logging completeness: confirmed (user, source IP, app, decision, posture state, time).
- Failure-mode behavior: deny-fail (if decision can't be made, deny by default — confirmed acceptable for risk profile).
- Privileged-user step-up: confirmed at application boundary, not just at IDP.

Test strategy (full plan in UAT artifact)

3 categories of tests: functional (does the system work?), security (does it deny what it should?), and performance (does it meet NFRs?). UAT entry gates Wave 1.

Approvals

CTO (technical): Mark Williams / 2026-03-04 / signed

CISO (security architecture): Sandra Park / 2026-03-04 / signed

Component lead: J. Liu / 2026-03-04 / signed

Architecture review board: M. Yamamoto (chair) / 2026-03-04 / signed

HOW TO READ THIS EXAMPLE

Why this example works: The technical specification is structured so that an architect and an implementer can both use it without one blocking the other - the design decisions and their rationale live in the architecture section, while the configuration parameters and acceptance tests live in the implementation section. This separation means the spec can be reviewed at the right level by the right person, which is the primary failure mode of monolithic tech specs.

Key judgment calls:

- Documenting the rejected design alternatives (agent-based vs. agentless ZTNA deployment) with the specific reasons each was rejected, so future engineers understand the constraints that shaped the chosen architecture and do not relitigate closed decisions.
- Specifying the failure mode behavior explicitly - what happens to a session when the ZTNA broker is unreachable - because undefined failure modes become production incidents, and the spec is the right place to force that decision before go-live.
- Including a security control verification table that maps each spec element back to a requirement in the BRD, ensuring the technical design is fully traceable and that nothing in the BRD is implemented in an undocumented way.

Adapting it to your context:

- The Prisma Access-specific configuration tables in this spec are not reusable; the pattern - parameter name, value, rationale, and the requirement it satisfies - is reusable for any vendor or technology.
- The spec assumes a greenfield Active Directory integration; if your environment has legacy RADIUS or a federated identity provider, the authentication flow diagrams will need significant rework before this structure can be applied.
- The acceptance test criteria in the spec are written at a technical level appropriate for a handoff to an internal QA team; if you are handing off to a third-party implementation partner, add contractual pass/fail definitions and signature blocks to each test section.

13 — RAID Log — Project Atlas

The RAID Log is the single integrated register of Risks, Assumptions, Issues, and Dependencies. Excerpt from the live workbook 'RAID Log' tab as of week 22 of execute (mid-July 2026).

Why these are managed together: A risk that materializes becomes an issue. An assumption that breaks becomes a risk. A dependency that slips creates new risks. Treating them as one log keeps the connections visible.

Active register (top entries shown — full register has 47 active items)

Risks

ID	Type	Description	LxI	Score	Status	Owner	Mitigation
R-001	Risk	BeyondTrust contract negotiation slips → PAM milestone slips	MxH	9	Mitigating	K. Reddy	Weekly vendor calls; legal escalation path defined; alternative shortlist (CyberArk) on standby
R-016	Risk	FIDO2 token vendor lead time slipped 4w → 8w	HxH	16	Mitigating	S. Chen	Buffer tokens deployed (DC-028); contract amendment in progress; risk re-evaluated weekly
R-021	Risk	ZTNA Wave 2 user-population larger than estimated (4,200 vs 3,500)	MxM	9	Mitigating	J. Liu	Capacity plan revised; Cloudflare licensing increased; cost variance approved
R-023	Risk	Insider-threat findings overlap with Access Review scope	MxH	12	Open	P. Nguyen	Under analysis with GRC; scope decision expected by 7/26
R-031	Risk	2026 SOC 2 audit window may shift if firm	LxH	6	Watch	Sec Lead	KPMG confirmed team stability through

ID	Type	Description	LxI	Score	Status	Owner	Mitigation
		changes audit team					Aug; quarterly check-in scheduled

Assumptions

ID	Type	Description	Validation status	Owner	Notes
A-002	Assumption	Sponsor (Sandra Park) remains in CISO role through program	Validated quarterly	Sponsor	CEO confirmed succession plan
A-007	Assumption	Okta licensing covers full headcount for program duration	Validated	IDP Lead	Confirmed against HR roster 2026-Q2
A-011	Assumption	2026 SOC 2 scope unchanged from 2025	At-risk	Sec Lead	KPMG signaled possible expansion to vendor management; meeting 7/19
A-014	Assumption	No M&A activity affecting headcount during execute	Validated	Sponsor	Strategy team confirmed quarterly

Issues

ID	Type	Description	Severity	Status	Owner	Resolution path
I-008	Issue	ZTNA Wave 2 cutover paused after 11/18 incident P	1 R	Resolved J	J. Liu R	CA complete (DC-027); cutover resumed 6/22
I-014	Issue	Privileged user FIDO2 enrollment at 67% (target 95% by 6/15)	2 I	In progress S	J. Chen 1	:1 outreach; privileged-account-owners list shared with managers;

ID	Type	Description	Severity	Status	Owner	Resolution path
		P				deadline extended to 7/01
I-019	Issue	Helpdesk ticket volume +60% in week post-Wave 1 P	2 R	esolving OC	M Lead He	ightedened staffing extended to T+45; root cause analysis identified 3 docs to update
I-022	Issue	3 application owners refuse Cloudflare connector deployment P	3 O	pen A	pp Owners S	ponsor escalation queued for 7/22 steering

Dependencies

ID	Type	Description	From	To	Status	Owner	Notes
D-003	Dependen cy	PAM rollout depends on IDP migration completion I	DP P	AM O	n-Track K	. Reddy I	DP at 65%; PAM design proceeding in parallel
D-007	Dependen cy	Access Review automation depends on PAM data pipeline P	AM A	ccess Review A	t-Risk P	. Nguyen P	AM design slip would cascade; rebaselined Phase 1 scope
D-012	Dependen cy	Cloud Migration program depends on IDP completion I	DP C	loud Migration O	n-Track M	. Ortiz C	loud team aware of Q3 IDP target; coordination call weekly
D-018	Dependen cy	ZTNA Wave 3	AM Z	TNA A	t-Risk J	. Liu P	AM 1-week slip

ID	Type	Description	From	To	Status	Owner	Notes
		depends on PAM go-live P					would push Wave 3 by 1 week minimum; contingency plan in place

Scoring methodology

Likelihood: Low (1) / Medium (2) / High (3) — based on probability of materializing in the next 30 days

Impact: Low (1) / Medium (2) / High (3) — based on cost, schedule, scope, or reputational damage

Score = L × I (max 16 in 4×4 scoring; we use a 3×3 model so max is 9 for risk and assumption-validity)

Status options: Open / Mitigating / Watch / Closed (Risks, Assumptions); Open / In progress / Resolved (Issues); On-Track / At-Risk / Off-Track / Resolved (Dependencies)

Three patterns this RAID has caught

1. The buffer-tokens decision (DC-028) was driven by R-016. We saw the 4w → 8w slip early because the vendor was disclosed as a single-source supplier in the assumption log (A-019). When the assumption broke, R-016 was opened immediately rather than discovered later as an issue.
2. D-007 (Access Review depends on PAM) was missed in the original plan. Surfaced during a cross-component review in week 12. Lesson: cross-component dependencies are the most-missed kind of dependency.
3. I-019 (Helpdesk ticket volume) was anticipated as R-013 ('helpdesk capacity strain'). Mitigation was in place; the actual volume was within plan. Working as designed.

Cadence

- Weekly review: TPM + component leads at Tuesday standup. New items reviewed; status changes confirmed.
- Bi-weekly deep-dive: TPM + sponsor + risk owner for any item rated 9+ or any Off-Track dependency.
- Monthly steering: top 5 risks reviewed; any item moving between statuses flagged.
- Decision log linkage: any RAID item that requires a decision (e.g., 'should we replace the vendor') generates a Decisions log entry.

HOW TO READ THIS EXAMPLE

Why this example works: This RAID Log earns its keep by treating each quadrant as a live management instrument: risks carry probability, impact, and a mitigation with a named owner, while issues have an age counter forcing resolution discipline. Notice how assumptions are actively validated on a cadence rather than recorded once and forgotten, and how dependencies name both the upstream supplier and the downstream deliverable that hangs on them.

Key judgment calls:

- Separating unvalidated assumptions (e.g., directory-sync readiness) from confirmed facts, so the team knows exactly where the plan is still load-bearing on a guess.
- Logging third-party dependencies with contractual milestone dates, creating an audit trail if a vendor slips and scope or cost relief is needed.
- Assigning a single accountable owner per RAID item rather than a team name, making escalation unambiguous.

Adapting it to your context:

- Replace Atlas-specific risks (ZTNA certificate sprawl, PAM vault sizing) with your program's threat surface; keep the probability x impact scoring bands.
- Adopt the age-counter discipline for issues regardless of technology: it prevents the register from becoming a graveyard.
- Your dependency column should reference your program's critical path IDs so RAID slippage maps instantly to schedule impact.

14 — Schedule & Milestone Tracker — Project Atlas

The Schedule artifact tracks task-level execution. Where the Charter has phase-level milestones (Phase 2 ends Sep 2026), the Schedule has the actual work breakdown. Lives as the workbook 'Schedule' tab. Excerpt from the program-level rollup as of week 22.

Top-level milestones (program)

ID	Milestone	Owner		Baseline	Forecast	Variance	Status
M-001	Charter approved S	ponsor	2	025-12-18 2	025-12-18 0	d ✓	Complete
M-002	All component leads onboarded T	PM	2	026-01-22 2	026-01-19 -	3d ✓	Complete
M-003	IDP Migration design approved M	. Ortiz	2	026-02-26 2	026-02-19 -	7d ✓	Complete
M-004	MFA Wave 1 (privileged) cutover complete S	. Chen	2	026-04-30 2	026-05-12 +	12d ✓	Complete (with slip)
M-005	PAM SOW signed K	. Reddy	2	026-04-15 2	026-04-08 -	7d ✓	Complete
M-006	ZTNA Wave 1 (28 apps, 200 users) complete J	. Liu	2	026-05-29 2	026-06-03 +	5d ✓	Complete
M-007	Access Review	Nguyen	20	26-06-15 20	26-06-22 +7	d ✓	Complete (with slip)

ID	Milestone	Owner	Baseline	Forecast	Variance	Status
	Automation Phase 1 design P.					
M-008	MFA Wave 2 (privileged) — 95% enrollment S.	Chen 20	26-06-15 20	26-07-01 +1	4d	At-Risk
M-009	ZTNA Wave 2 cutover decision J	. Liu 2	026-06-22 2	026-06-29 +	7d	At-Risk
M-010	PAM design baseline approved K	. Reddy 2	026-06-29 2	026-06-29 0	d	In progress
M-011	IDP legacy AD trust cleanup complete M.	Ortiz 20	26-07-06 20	26-07-06 0d		In progress
M-012	Q3 SOC 2 evidence package to KPMG Se	c Lead 20	26-07-13 20	26-07-13 0d		Pending
M-013	ZTNA Wave 2 cutover complete (67 apps, 2,800 users)	J. Liu 2	026-08-15 2	026-08-22 +	7d	Pending
M-014	SOC 2 audit window opens K	PMG 2	026-08-15 2	026-08-15 0	d	HARD DATE
M-015	IDP Migration 100% complete M	. Ortiz 2	026-09-30 2	026-10-07 +	7d	Pending
M-016	MFA Wave 2 (all employees) complete S	. Chen 2	026-12-15 2	026-12-22 +	7d	Pending
M-017	PAM 50%	. Reddy 2	027-01-15	027-01-22	7d	Pending

ID	Milestone	Owner	Baseline	Forecast	Variance	Status
	deployed K		2	+		
M-018	PAM 100% deployed K	. Reddy 2	027-03-31 2	027-04-07 +	7d ○	Pending
M-019	All access reviews automated (SOX/GLBA scope) P.	Nguyen 20	27-06-30 20	27-06-30 0d	○	Pending
M-020	Cloud Security Operations function go-live Se	c Lead 20	27-07-31 20	27-07-31 0d	○	Pending
M-021	Project closeout T	PM 2	027-09-30 2	027-10-07 +	7d ○	Pending

Critical-path summary

Current critical path runs through MFA Wave 2 → ZTNA Wave 2 cutover → SOC 2 audit window. Total float on the critical path is 8 days; we're consuming 7 days of it on the M-008 slip. If MFA slips another 2 weeks, ZTNA Wave 2 goes Off-Track, which puts SOC 2 audit at risk.

Schedule variance analysis

Total positive variance (early): -10 days

Total negative variance (late): +43 days

Net schedule position: +33 days late vs baseline at this point in the program

Causes of slip (in rank order):

1. FIDO2 token supply chain (M-008): +14 days
2. ZTNA Wave 2 user-population larger than estimated (M-009): +7 days
3. Access Review automation design complexity (M-007): +7 days
4. ZTNA Wave 1 cutover blast-radius caution (M-006): +5 days

Recovery actions in flight

- MFA Wave 2: Buffer tokens deployed (DC-028). Outreach campaign for non-enrolled privileged users. Manager-level escalation.
- ZTNA Wave 2: Capacity plan revised. Wave 2 split into 2a (mid-risk) and 2b (broader). Cutover decision deferred to 6/29.
- Access Review: Phase 1 scope rebaselined. Deferred 3 lower-priority systems to Phase 2.

How this connects to other artifacts

- Charter (M-021 maps to closeout milestone)
- RAID Log (R-016 is the active risk driving M-008 slip; R-021 driving M-009)
- Decisions Log (DC-028 buffer-tokens decision drives mitigation for M-008)
- Status Report (this period reports M-008 At-Risk, M-009 At-Risk, others on track)

HOW TO READ THIS EXAMPLE

Why this example works: The Schedule and Milestone Tracker is exemplary because it shows planned versus actual side by side at every milestone, making slippage visible at a glance rather than buried in Gantt bars. The inclusion of float consumed alongside days remaining signals whether the team is merely late or is burning contingency, which is the more important management signal.

Key judgment calls:

- Grouping milestones by wave rather than workstream so sponsors read the plan the same way the business feels the rollout.
- Flagging amber before a milestone goes red, using a defined 5-day-float threshold, so the SteerCo pack never shows a surprise red.
- Holding discovery and pilot milestones to fixed dates even when vendor delivery slips, forcing the internal team to surface scope trade-offs early.

Adapting it to your context:

- The milestone cadence (wave-based, quarterly gates) is Atlas-specific; restructure around your program's delivery rhythm.
- The amber/red threshold (5 days float) should be recalibrated to your sprint or reporting cycle length.
- Retain the planned vs. actual plus float-consumed columns in any schedule tool you use; that trio of signals works regardless of domain.

15 — Resource Plan — Project Atlas

The Resource Plan tracks people allocated to the program, by component, role, and time. Lives as the workbook 'Resources' tab. This is the Q3 2026 view (the biggest staffing quarter — all components active simultaneously).

Total program staffing (Q3 2026 snapshot)

Component	Allocated FTE	Contractors	Hours / wk total	Cost / quarter
Identity Provider Migration	4.2	1.0	208	\$148K
ZTNA Rollout	5.0	2.0	280	\$215K
PAM	3.0	1.0	160	\$112K
MFA Hardening	2.5	0.5	120	\$84K
Access Review Automation	2.0	0.0	80	\$52K
Cross-program (TPM, OCM, GRC)	3.0	0.0	120	\$84K
TOTAL	19.7	4.5	968	\$695K/quarter

Critical roles

Role	Person	Component	Allocation	Notes
TPM (program)	Casey Morrison	All	100%	Single TPM across program (intentional)
ZTNA Component Lead	Jennifer Liu	ZTNA	100%	Critical-path role; documented

Role	Person	Component	Allocation	Notes
				succession
PAM Component Lead	Karthik Reddy	PAM	100%	New hire (Q1 2026); ramp risk noted (R-009, closed)
IDP Architect	Michael Ortiz	IDP	100%	Single point of knowledge for legacy AD trust relationships
Senior FIDO2 Engineer S	tephanie Chen	MFA	100%	Hardware token logistics owner
OCM Lead	R. Patel	All	60%	Shared with Cloud Migration program (key constraint)
Senior Network Eng	D. Park	ZTNA	80%	Shared with Network Operations (capacity risk)

Resource conflicts (active)

C-001: OCM Lead (R. Patel) is 60% allocated to Atlas, 40% to Cloud Migration. Cloud Migration ramped its OCM needs in Q3, creating a 25-hour/week shortfall on Atlas. Resolution: Q3 priority is Atlas (sponsor decision, DC-019); Cloud Migration absorbs delay.

C-002: Senior Network Engineering (D. Park) is at-risk for Q4 due to data-center refresh project starting Oct 2026. Resolution: backfill identified (J. Tomás, contractor); knowledge transfer planned for Sep.

C-003: Helpdesk Tier 2 (10 people) is supporting both ZTNA Wave 2 stabilization AND MFA Wave 2 enrollment in same quarter. Resolution: prioritize ZTNA support week-of-cutover; defer non-critical MFA support to following week. Sponsor approved (DC-024).

Capacity vs demand by quarter

Quarter	Demand FTE	Approved FTE	Variance	Notes
Q1 2026	12	12	0	Baseline; all 5 components active
Q2 2026	18	17	-1	ZTNA Wave 1 ramp-up; +1 contractor approved
Q3 2026	24	24	0	Peak; current
Q4 2026	22	22	0	IDP wind-down begins
Q1 2027	18	17	-1	Resource conflict identified (C-005, in progress)
Q2 2027	12	11	-1	Stabilization

Quarter	Demand FTE	Approved FTE	Variance	Notes
				phase
Q3 2027	8	8	0	Closeout phase

Hiring & contractor plan

3 backfills approved by sponsor (DC-026):

1. Senior Cloud Security Engineer (PAM stabilization Q1 2027) — backfill open
2. Identity Engineer Tier 2 (IDP stabilization Q4 2026) — open requisition
3. Network Engineer (ZTNA support Q4 2026 onwards) — contractor identified, paperwork in flight

External vendor support

- Okta Premier Support: 60 hours/quarter, 20 hours used to date
- Cloudflare Premium: 40 hours/quarter, 15 hours used
- BeyondTrust Implementation Services: 200-hour SOW (DC-005), 65 hours used
- KPMG advisory (audit prep): 80 hours total budget, 30 used to date

Skill gaps identified

1. PAM operational expertise (post-deployment) — being addressed by hiring + 6-month vendor knowledge transfer
2. ZTNA policy authorship at scale — solved via Cloudflare Premier Support engagement
3. Access Review automation engineering — being filled by contractor; permanent hire planned Q1 2027

What this Resource Plan has surfaced

- Three resource conflicts that would have surfaced as schedule slips if not flagged early
- A succession-plan gap for the ZTNA Component Lead (single critical-path person) — addressed by cross-training J. Tomás
- The OCM Lead split (C-001) — would have caused a 4-week comms slip without sponsor intervention

HOW TO READ THIS EXAMPLE

Why this example works: This Resource Plan is exceptional because it links headcount to deliverables rather than to job titles, exposing over-allocation at the task level before it becomes a schedule problem. The demand-versus-supply view by month makes it possible to decide weeks in advance whether to request contractor extensions or re-sequence work, rather than reacting to a gap mid-sprint.

Key judgment calls:

- Distinguishing between dedicated program staff and business-as-usual secondees with explicit time-allocation percentages, so capacity is not double-counted.
- Flagging the PAM integration engineer role as a single point of failure and documenting a cover plan, an explicit risk-mitigation judgment most resource plans skip.
- Phasing the security-analyst uplift to coincide with ZTNA Wave 1 go-live rather than contracting it from day one, controlling cost without leaving an operational gap.

Adapting it to your context:

- The role taxonomy (ZTNA architect, PAM engineer, IAM analyst) is Atlas-specific; rebuild the role list from your program's WBS.

- The allocation-percentage model works for any program; calibrate what counts as full-time equivalence in your organization's HR system.
- If your program spans multiple legal entities or cost centers, add a funding-source column to each row to simplify chargeback.

16 — Project Budget — Project Atlas

The Budget tracks committed spend, actuals, and forecast across the program. Lives as the workbook 'Budget' tab. Excerpt as of mid-Q3 2026 (week 22 of execute). Total approved budget: \$8.4M.

Program-level summary

Category	Approved	Committed	Spend-to-date	Forecast EAC	Variance vs approved
Capex	\$5,200,000	\$4,612,000	\$3,287,000	\$5,140,000	-\$60,000 (1.2% under)
Opex	\$3,200,000	\$2,850,000	\$2,103,000	\$3,260,000	+\$60,000 (1.9% over)
TOTAL	\$8,400,000	\$7,462,000	\$5,390,000	\$8,400,000	\$0 (on plan)

Component-level breakdown

Component	Approved	Committed	Spend-to-date	Forecast EAC	Variance
Identity Provider Migration	\$1,850,000	\$1,720,000	\$1,450,000	\$1,830,000	-\$20K under
ZTNA Rollout	\$2,100,000	\$1,985,000	\$1,180,000	\$2,150,000	+\$50K over (R-021)
PAM	\$1,600,000	\$1,420,000	\$375,000	\$1,610,000	+\$10K over
MFA Hardening	\$1,100,000	\$1,090,000	\$545,000	\$1,180,000	+\$80K over (R-016)
Access Review Automation	\$750,000	\$620,000	\$140,000	\$730,000	-\$20K under
Program management	\$400,000	\$340,000	\$295,000	\$420,000	+\$20K over
Cross-program OCM	\$400,000	\$390,000	\$260,000	\$410,000	+\$10K over
Contingency reserve	\$200,000	\$0	\$0	\$70,000	Released \$130K

Reserve management

Original contingency: \$200K (2.4% of total program budget)

Reserve drawdowns:

- DC-028: \$80K to MFA Hardening for buffer FIDO2 tokens (Jun 2026, sponsor approved)
- DC-024: \$30K to ZTNA Rollout for Cloudflare licensing increase (Apr 2026, sponsor approved)

- DC-019: \$20K to OCM for additional listening sessions with Field Engineering (Mar 2026, sponsor approved)

Reserve remaining: \$70K (38% of original)

Variance analysis

Components running over (total +\$170K):

- ZTNA Rollout (+\$50K): User population larger than estimate (R-021). Cloudflare seat licensing increased.
- MFA Hardening (+\$80K): FIDO2 token supply (R-016). Buffer tokens procured at premium.
- PAM (+\$10K): Minor SOW addition for additional integrations (DC-022).
- Program management (+\$20K): Extended TPM hours during Wave 1 stabilization.
- Cross-program OCM (+\$10K): Additional Field Engineering listening sessions.

Components running under (total -\$40K):

- IDP Migration (-\$20K): Vendor support hours under-utilized; design phase efficient.
- Access Review (-\$20K): Phase 1 design completed under estimate.

Net program variance: +\$130K vs original component budgets, fully absorbed by contingency reserve drawdowns. Program total holds at \$8.4M.

Spend pacing

Spend through week 22 (~42% of program duration):

- Approved budget: \$8,400,000
- Spend-to-date: \$5,390,000 (64% of budget)
- Pacing: spend is ahead of duration percentage — normal for security programs (front-loaded licensing and infrastructure)
- Forecast remaining: \$3,010,000 over remaining 58% of duration

Cost categories

Category	Spend-to-date	% of total
Software licensing	\$2,280,000	42%
Vendor implementation services	\$1,150,000	21%
Internal labor (allocated)	\$1,140,000	21%
Hardware (FIDO2 tokens, devices)	\$385,000	7%
Training & change management	\$245,000	5%
External advisory (KPMG, Legal)	\$190,000	4%

Sponsor authority

Sandra Park has approved authority for:

- ±10% reallocation across components without re-approval (within total approved \$8.4M)
- Single drawdown from contingency up to \$100K
- Drawdowns above \$100K require steering committee approval

Items requiring steering approval (queued for next steering)

- Q4 2026 cloud security operations standup costs may exceed \$400K (over single-drawdown threshold). Estimate refining; bring to October steering.

Forecast EAC methodology

EAC = Spend-to-date + (Approved – Committed) + (Committed – Spend-to-date) + Risk reserve adjustments. Reviewed monthly with finance partner.

What this Budget has caught

- The +\$80K MFA variance was visible in the forecast 8 weeks before it would have shown up as an actuals overrun. That gave time to release contingency rather than escalate to steering for additional funding.
- The IDP under-spend revealed vendor support was under-utilized; we rebalanced toward more support during the cutover window.
- Spend pacing showed the security-program-typical front-loading; finance partner now models this rather than asking weekly.

HOW TO READ THIS EXAMPLE

Why this example works: The Project Budget is exemplary because it tracks spend at three levels simultaneously: committed (PO raised), accrued (work done, invoice pending), and forecast-to-complete, giving finance and the sponsor a single source of truth rather than reconciling three spreadsheets. The contingency reserve is held as a named line, not hidden in labor rates, so any draw-down is a visible, sanctioned decision.

Key judgment calls:

- Breaking the contingency reserve into two tiers (project manager's discretion up to 5%, SteerCo approval above 5%), matching authority levels to risk appetite rather than treating all overruns identically.
- Separating one-time implementation costs from recurring license and support costs so the business case owner can see the true run-rate impact post-project.
- Holding a vendor cost-challenge milestone at 60% spend rather than at project close, creating a contractual checkpoint to dispute out-of-scope charges before leverage is lost.

Adapting it to your context:

- The vendor cost lines (BeyondTrust licensing, SI integration fees) are Atlas-specific; restructure columns around your own procurement categories.
- The three-tier spend view (committed, accrued, forecast) is universally reusable and should be standard in any program budget over \$500k.
- Align your contingency draw-down authority thresholds to your organization's actual delegation-of-authority policy, not to Atlas's thresholds.

17 — Decisions & Changes Log — Project Atlas

The combined Decisions & Changes Log captures every recorded decision and every formal change request. Why combined: both record 'something changed, here's why.' Separating them creates two logs nobody keeps current. Lives in the workbook 'Decisions & Changes' tab.

Excerpt of the most consequential entries (full log has 38 entries through week 22)

ID	Date	Type	Title	Decided by	Rationale (one-liner)
DC-001	2025-12-18	Decision	Vendor of record: Okta (not Azure AD) S	ponsor (CISO) B	etter SAML interop; existing Okta org licensed
DC-002	2025-12-18	Decision	ZTNA platform: Cloudflare Zero Trust	ponsor (CISO) A	rchitectural fit; pricing; existing relationship

ID	Date	Type	Title	Decided by	Rationale (one-liner)
			S		
DC-003	2026-01-12	Decision	Single TPM across all 5 components S	ponsor + PMO C	coordination overhead; succession plan documented
DC-005	2026-01-29	Decision	PAM: BeyondTrust selected (vs CyberArk) S	ponsor + CTO R	FP scoring (78 vs 72); deeper SaaS option
DC-007	2026-02-19	Change	Charter v1.2: scope adjusted to remove mainframe Sp	ponsor Ma	inframe in separate refresh cycle
DC-008	2026-03-04	Decision	Stakeholder: Diane Petrov upgraded to Active partner	Sec Lead P	privacy review of access logs flagged her engagement need
DC-014	2026-04-10	Change	Customer Success VP added to stakeholder register O	CM Lead Sa	les escalation about MFA fatigue surfaced new audience
DC-019	2026-03-22	Decision	\$20K contingency draw to OCM for Field Eng listening	sessions Sponso	r R-003 mitigation; resistance management
DC-020	2026-04-15	Decision	FIDO2 model: Yubico Series 5 (vs Feitian or Solokeys)	PAM Lead Best	FIDO2 + Smart Card combo for privileged
DC-022	2026-04-22	Change	Field Engineering moved from 'Aware' to 'Resistant' O	CM Lead Pi	lot feedback indicated existing-workflow disruption
DC-023	2026-05-01	Change	ZTNA Wave 1 split: 28 low-risk apps first (was 45) S	ponsor + Eng Re	duce blast radius after security architecture review
DC-024	2026-05-15	Decision	\$30K draw to	sponsor R-	021 mitigation;

ID	Date	Type	Title	Decided by	Rationale (one-liner)
			ZTNA for Cloudflare licensing increase S		user population 4,200 vs estimated 3,500
DC-025	2026-05-22	Decision	Helpdesk reclassified to Champion (was Informed) O	CM Lead Hi	gh-interest, missed signal source
DC-026	2026-06-01	Change	3 hiring requisitions approved (Sec Eng, ID Eng, Net	Eng) Sponsor C	apacity plan; backfills for stabilization
DC-027	2026-06-05	Change	ZTNA Wave 2 — 1-week schedule extension	Sponsor Po	st-incident RCA from 11/18 needed
DC-028	2026-06-06	Decision	\$80K from contingency to MFA for buffer FIDO2 tokens	Sponsor R-	016 mitigation; supply chain delays
DC-029	2026-06-15	Change	Helpdesk Tier 2 staffing extended through T+45 Sp	onsor I-0	19 resolution; ticket volume exceeded forecast
DC-030	2026-06-22	Decision	ZTNA Wave 2 cutover resumed (post-RCA) S	ponsor + CTO RC	A findings did not require architecture change
DC-031	2026-07-01	Change	MFA Wave 2 (privileged) deadline extended 2 weeks Sp	onsor Enr	ollment at 67% vs 95% target; outreach campaign extended
DC-032	2026-07-12	Decision	Access Review Phase 1 scope rebaselined (3 deferred)	Sponsor + GRC Sc	hedule recovery; SOX scope unaffected
DC-033	2026-07-19	Change	SOC 2 scope expansion confirmed (vendor mgmt added) K	PMG decision Ex	ternal; impact analysis in progress

ID	Date	Type	Title	Decided by	Rationale (one-liner)
DC-034	2026-07-22	Decision	3 ZTNA-resistant app owners — sponsor escalation S	ponsor I-	022 resolution; Sandra direct conversation

How an entry gets created

Trigger: any of the following requires a Decisions log entry —

- Any decision rated material (affects scope, schedule, or budget by >5%)
- Any change to charter, plan, or governance
- Any sponsor approval beyond standing authority
- Any item that the team will need to remember in 6 months when nobody can recall the rationale

Required fields per entry: ID, date, type (Decision / Change), title, decision-maker, rationale (one-liner), full-context link (in workbook), affected artifacts (list), follow-up actions (list), reviewed-by, review-date.

What 'rationale (one-liner)' means: A future TPM, reading the log a year later, should be able to understand WHY this decision was made without reading the full context. This is the field that gets re-used in future projects. Take time to write it well.

Cross-references

- DC-001, DC-002, DC-005 → reflected in Charter Approvals section
- DC-007 → triggered Charter v1.2; superseded original scope
- DC-019, DC-024, DC-028 → contingency drawdowns; tracked in Budget artifact
- DC-023, DC-027, DC-031 → schedule changes; tracked in Schedule artifact
- DC-008, DC-022, DC-025 → stakeholder changes; tracked in Stakeholder Register
- DC-026 → resource change; tracked in Resource Plan
- DC-033 → external change (KPMG); triggered impact assessment

Three patterns this log has caught

1. Vendor decisions (DC-001, DC-002, DC-005, DC-020) cluster early in the program. Right pattern — these are foundation decisions and we want them documented before execute.
2. The contingency draws (DC-019, DC-024, DC-028) are evenly distributed across 3 different risks. Suggests the contingency was sized about right; we'd be in trouble if all 3 had hit in one month.
3. Stakeholder changes (DC-008, DC-014, DC-022, DC-025) cluster around Wave 1 stabilization. Stakeholder maps are most accurate after first contact with reality, not at kickoff.

Cadence

- Monthly: TPM reviews entire log for completeness and missing follow-ups
- Quarterly: Steering committee reviews high-impact decisions for any required ratification
- At program close: Lessons Learned cross-references which decisions had unexpected consequences

HOW TO READ THIS EXAMPLE

Why this example works: The Decisions and Changes Log is distinguished by recording not only the decision made but the options considered and the rationale for rejection, creating an institutional memory that survives staff turnover. Every entry carries the authority level that

sanctioned it, which prevents revisiting closed decisions at the wrong forum and provides an audit trail for regulators asking why a security architecture choice was made.

Key judgment calls:

- Classifying each change as in-scope, out-of-scope, or deferred rather than binary approved/rejected, so deferred items have a home and do not resurface as new requests later.
- Logging the business driver behind each decision (e.g., regulatory deadline, risk acceptance) so future readers understand whether the context that justified the choice still applies.
- Assigning a re-review date to high-impact decisions made under uncertainty, acknowledging that a decision is correct for its conditions, not permanently correct.

Adapting it to your context:

- The change categories (ZTNA scope, PAM policy, integration architecture) are Atlas-specific; define your own taxonomy based on your program's work breakdown.
- The authority-level column (PM, sponsor, SteerCo, board) should reflect your governance model exactly; mismatches between the log and your RACI are a governance red flag.
- If your program has a formal change-control board, this log is the input feed to it; if not, it is the board, and the entry is the record of the meeting.

18 — RFP — PAM Vendor Selection (Project Atlas)

18 — Request for Proposal (RFP) — Project Atlas: PAM Vendor Selection

This is the actual RFP issued for PAM (Privileged Access Management) vendor selection in November 2025. The RFP led to DC-005 — selection of BeyondTrust over CyberArk.

Document control

Title	Project Atlas — PAM Solution RFP
Version	v2.0 (issued)
Date	2025-11-04 (issued); 2025-12-15 (responses due)
Author	K. Reddy (PAM Lead) with TPM + Procurement
Approver	Sandra Park (CISO), Linda Walsh (CIO)

1. Background & objective

Bristol Financial is replacing legacy privileged-access tooling as part of Project Atlas (Zero Trust & Identity Modernization). The selected platform will manage privileged credentials, sessions, and access for ~150 privileged users across 240 systems (servers, databases, network devices, cloud consoles).

This is a competitive RFP. Bristol expects to evaluate 4-6 responses and select 1 vendor by Dec 22, 2025, with implementation starting Jan 2026.

2. Scope of solution

In-scope capabilities:

- Privileged credential vaulting with rotation policies
- Session recording and replay for audit
- Just-in-time elevation for sysadmin workflows
- API integration with existing tooling: Okta (SSO), Splunk (SIEM), ServiceNow (ITSM)
- Role-based access controls aligned with Bristol's RACI for privileged accounts
- Disaster recovery: RPO 4 hours, RTO 8 hours

- Operational dashboards for SOC, GRC, and management

Out-of-scope:

- Endpoint privilege management (EPM) — separate program
- Customer-facing identity (CIAM) — separate program
- Mainframe access (separate refresh cycle)

3. Bristol context

- Industry: Mid-market commercial lender (~3,500 employees)
- Regulatory: SOX, GLBA, SOC 2 Type II
- Geographies: US (primary), Canada, UK
- Existing identity stack: legacy AD (being migrated to Okta in 2026)
- Existing security tooling: Splunk SIEM, CrowdStrike EDR, ServiceNow ITSM
- Cloud footprint: AWS primary, limited Azure for M365

4. Proposal requirements (sections required from each respondent)

Section A: Executive summary (max 2 pages)

Section B: Solution architecture and approach

Section C: Implementation methodology and timeline

Section D: Pricing — itemized: licensing, implementation services, training, support, year-2 onwards

Section E: References — minimum 3 financial-services references with similar scale

Section F: Security & compliance posture (SOC 2, ISO 27001, FedRAMP if applicable)

Section G: Integration approach for Okta, Splunk, ServiceNow, AWS

Section H: Differentiators and risks

Section I: Q&A responses to Bristol's specific questions (provided in Appendix B)

5. Evaluation criteria (full rubric in companion RFP Scoring Rubric document)

Category	Weight	Approach
Functional fit	25%	Demo + reference call validation
Technical architecture & integration	20%	Architecture review + reference call
Implementation approach	15%	Methodology review + reference validation
Total cost of ownership (5-year)	15%	Pricing analysis (license + impl + support)
Vendor risk profile	10%	Financial health + security posture
References & past performance	10%	Minimum 3 calls
Cultural fit & partnership	5%	Demo experience + Q&A interactions

6. Process & timeline

2025-11-04	RFP issued
2025-11-12	Vendor questions due to Bristol Procurement
2025-11-19	Bristol responses to questions distributed

2025-11-04	RFP issued
2025-12-01	Vendor demos (1 hour each)
2025-12-15	Final proposals due
2025-12-22	Selection announced
2026-01-15	Contract signed
2026-02-01	Implementation kickoff

7. Contractual requirements

- Master Service Agreement based on Bristol legal template (provided)
- 5-year initial term with annual price adjustments capped at CPI + 3%
- Termination for cause with 30 days notice
- Data residency: US-only data centers required for production data
- Performance SLA: 99.9% uptime, 4-hour P1 incident response
- Vendor must complete Bristol third-party risk assessment

8. Submission instructions

Format: PDF, max 80 pages excluding appendices

Submission: securely uploaded to Bristol vendor portal (link provided)

Deadline: 2025-12-15 17:00 ET (no late submissions)

Q&A point of contact: Bristol Procurement (procurement@bristolfinancial.example)

9. Appendices

A. Bristol environment summary (architecture diagrams, current-state inventory)

B. Specific Q&A questions (28 questions)

C. Sample integration flows

D. SLA template and penalties

E. Reference call template

What this RFP did right (lessons confirmed in retrospective)

1. Tight scope — explicit out-of-scope boundaries prevented vendors from proposing things we weren't buying.
2. Weighted criteria up-front — vendors knew what mattered. Reduced "throw everything at the wall" responses.
3. Specific Q&A questions — surfaced architectural assumptions that would have caused issues post-selection.
4. Reference requirement — 'similar scale in financial services' filtered out vendors whose only references were enterprises 10x our size.

HOW TO READ THIS EXAMPLE

Why this example works: This RFP is exemplary because the requirements are written as verifiable statements, not aspirations, so each vendor response can be scored without interpretation. The separation of mandatory eliminators from weighted differentiators prevents a vendor from compensating for a compliance gap with a high score on a nice-to-have feature, which is the most common RFP scoring distortion.

Key judgment calls:

- Structuring the RFP around Bristol Financial's existing IAM stack integration points rather than generic PAM capabilities, forcing vendors to demonstrate fit rather than catalog features.
- Including a mandatory reference-customer requirement from the financial-services sector, treating implementation evidence as a requirement, not a bonus.
- Setting a defined response page limit to equalize evaluation burden and signal that procurement discipline will carry into the engagement itself.

Adapting it to your context:

- The specific requirements (LDAP/AD sync, privileged session recording, break-glass workflow) are ZTNA/PAM-specific; derive yours from your program's functional and non-functional requirements baseline.
- The mandatory-versus-weighted structure is universally reusable for any technology procurement; apply it before you finalize scoring weights.
- Calibrate the reference-customer specificity to your organization's risk tolerance: a regulated industry may need same-sector references, others may not.

19 — RFP Scoring Rubric — PAM Vendor Selection (Project Atlas)

19 — RFP Scoring Rubric — Project Atlas: PAM Vendor Selection

Companion to the PAM RFP. The rubric was completed by a 5-person evaluation panel after demos and reference calls. Final scoring led to DC-005 (BeyondTrust selected, 78 vs CyberArk 72).

Evaluation panel

Role	Person	Vote weight
PAM Component Lead	K. Reddy	1.0
TPM (program coordination)	Casey Morrison	1.0
CTO representative	D. Park (delegate)	1.0
GRC representative	Sophie Karim	1.0
Sponsor (CISO)	Sandra Park	1.5 (final tiebreaker)

Total possible weighted score: $5.5 \times 100 = 550$ points (normalized to 100 in summary).

Scoring scale

5 = Best in class — clearly exceeds requirements

4 = Strong — meets all requirements with notable strengths

3 = Adequate — meets requirements without distinction

2 = Concerning — gaps in critical areas

1 = Disqualifying — fails core requirements

Final scores (normalized to 100)

Category	Weight	BeyondTrust	CyberArk	Delinea
Functional fit	25%	4.2	4.0	3.4
Technical architecture & integration	20%	4.0	4.4	3.2
Implementation approach	15%	4.4	3.6	3.0

Category	Weight	BeyondTrust	CyberArk	Delinea
Total cost of ownership (5-year)	15%	3.8	3.4	4.4
Vendor risk profile	10%	4.2	4.6	3.0
References & past performance	10%	4.0	4.2	3.0
Cultural fit & partnership	5%	4.4	3.4	3.6
WEIGHTED TOTAL 1	00%	78	72	63

Detailed scoring rationale (BeyondTrust vs CyberArk — top 2)

Functional fit (4.2 vs 4.0):

BeyondTrust: Strong session management; just-in-time elevation matched our sysadmin workflows; SaaS-first delivery model.

CyberArk: Most mature feature set overall; some features beyond what we need (more enterprise-focused).

Decision factor: BeyondTrust's SaaS-first matched our cloud strategy; we wouldn't use the marginal extra CyberArk features.

Technical architecture & integration (4.0 vs 4.4):

BeyondTrust: Solid Okta/Splunk/ServiceNow integrations; some custom work needed for AWS console flows.

CyberArk: Best-in-class integrations; native AWS support; mature API.

Decision factor: CyberArk had a real advantage here; partially offset by other factors.

Implementation approach (4.4 vs 3.6):

BeyondTrust: Phased methodology with explicit value-realization checkpoints; named implementation partner has 4 banking references.

CyberArk: Methodology felt waterfall-heavy; implementation partner had less financial-services depth.

Decision factor: This was the largest gap. Implementation risk is real for security tooling.

Total cost of ownership (3.8 vs 3.4):

BeyondTrust: \$1.6M over 5 years — license + impl + support.

CyberArk: \$1.85M over 5 years.

Decision factor: BeyondTrust ~13% lower, but both within budget. Not the deciding factor.

Vendor risk profile (4.2 vs 4.6):

BeyondTrust: Solid SOC 2, ISO 27001, financially stable.

CyberArk: Stronger compliance posture (FedRAMP), larger company.

Decision factor: Both passed Bristol third-party risk assessment.

References & past performance (4.0 vs 4.2):

Reference calls completed: 3 each.

BeyondTrust: 1 strongly positive (similar mid-market bank), 2 mixed (larger orgs with more complex needs).

CyberArk: 3 positive, but 2 were significantly larger than Bristol.

Decision factor: BeyondTrust's similar-scale reference was more relevant signal than CyberArk's larger references.

Cultural fit & partnership (4.4 vs 3.4):

BeyondTrust: Highly responsive during RFP; CSM brought deep technical understanding to demo.

CyberArk: Sales-driven engagement; technical handoff felt distant.

Decision factor: For a 5-year relationship, partnership culture matters.

Weighted decision summary

BeyondTrust scored higher on 5 of 7 categories. CyberArk had clear advantages in technical architecture and vendor risk, but those advantages were not large enough to overcome the implementation approach and cultural fit gaps.

The final scoring difference (78 vs 72) is meaningful but not overwhelming. Both vendors could deliver. The selection comes down to: implementation approach (which we've validated with 3 banking references) and cultural fit (which matters over 5 years).

Sponsor decision rationale (Sandra Park, 2025-12-22)

"BeyondTrust offers a stronger implementation methodology and better cultural fit. CyberArk has a more mature product but the gap doesn't justify the implementation-risk premium for a Tier 2 program at our scale."

What we'd do differently next time (Lessons Learned)

1. We over-weighted 'product maturity' as a proxy for fit. Maturity matters when you'll use 100% of features; we'll use 60-70%.
2. The 'implementation approach' weighting (15%) was about right. In retrospect we'd consider 18-20% for security tools where implementation IS the risk.
3. Reference call template — adding 'how did issues during implementation get resolved?' as a standard question would have made the implementation-quality differences clearer earlier.

HOW TO READ THIS EXAMPLE

Why this example works: The RFP Scoring Rubric is exceptional because it defines what a 1, 3, and 5 score means for every criterion in plain language before any response is received, eliminating evaluator drift and making a blinded scoring process defensible. The weighting scheme is explicitly traceable to the program's stated priorities, so a vendor or auditor can understand why security policy enforcement outweighs vendor financial stability in the point allocation.

Key judgment calls:

- Requiring independent scoring before a consensus meeting, documented in the rubric itself, so the moderation session surfaces genuine disagreement rather than anchoring to the first speaker.
- Assigning a minimum mandatory score on the security and compliance dimension that, if missed, voids the overall weighted score, preserving the eliminator logic through the scoring stage.
- Publishing the weighting scheme to vendors in the RFP, not just internally, so questions and clarifications are targeted to the highest-value criteria.

Adapting it to your context:

- The criteria categories (session management, vault architecture, SIEM integration, support SLA) are PAM-specific; rebuild the rubric from the requirements in your own RFP.
- The 1-3-5 descriptor model is universally reusable; the investment is in writing tight descriptors before you score, not during.
- If your procurement involves multiple business units, include a column for each evaluator group's weight, since IT, risk, and operations rarely value the same criteria equally.

20 — SOW — BeyondTrust PAM Implementation (Project Atlas)

20 — Statement of Work — BeyondTrust PAM Implementation (Project Atlas)

This is the executed SOW between Bristol Financial and BeyondTrust covering the PAM implementation. Signed Jan 15, 2026 (DC-005). Excerpt of the contract sections that matter for project management.

Document control

Title	BeyondTrust PAM Implementation Services — SOW
SOW number	SOW-2026-PAM-01
Date	2026-01-15
Master agreement	Bristol-BeyondTrust MSA dated 2026-01-08
Parties	Bristol Financial (Customer) and BeyondTrust Software, Inc. (Vendor)
Total value	\$620,000 (services); \$980,000 (5-year licensing in separate order form)

1. Scope of services

BeyondTrust will deliver implementation, integration, training, and post-deployment support services for the BeyondTrust Privileged Remote Access (PRA) and Password Safe products in Bristol Financial's environment.

Specifically:

1.1 Architecture design and review (40 hours)

1.2 Production deployment of BeyondTrust PRA + Password Safe (120 hours)

1.3 Integration with Okta SSO, Splunk SIEM, ServiceNow ITSM (60 hours per integration; 180 hours total)

1.4 Migration of 240 in-scope systems into PAM control (160 hours)

1.5 Privileged user enrollment and FIDO2 step-up configuration (80 hours)

1.6 Knowledge transfer and operational runbook authoring (60 hours)

1.7 Post-deployment hypercare for 90 days following go-live (60 hours)

Total professional services: 700 hours @ \$850/hour = \$595,000

Travel and expenses: \$25,000 (capped, per Bristol T&E policy)

2. Out of scope (explicit)

- Endpoint privilege management (separate program, separate SOW)
- Customer-facing identity management (CIAM)
- Mainframe access management (legacy systems on separate refresh)
- 24/7 managed-service operations (Bristol owns operations post-go-live; BeyondTrust provides support per standard support agreement)
- Custom development beyond standard product configuration

- On-site presence at Bristol locations (engagement is remote-first)

3. Deliverables and acceptance

D1: PAM Architecture Design Document (week 4)

Acceptance: Bristol CTO and CISO sign-off on design baseline

D2: Production environment deployed and integration-tested (week 12)

Acceptance: Bristol Engineering verifies all NFRs in test plan; UAT entry criteria met

D3: 240 in-scope systems enrolled in PAM (week 24)

Acceptance: BeyondTrust verifies enrollment count = 240 in operational dashboard

D4: 150 privileged users enrolled with FIDO2 step-up (week 30)

Acceptance: Self-service portal shows 150 unique enrolled users

D5: Operational runbooks delivered (week 32)

Acceptance: Bristol PAM operations team signs off

D6: 90-day hypercare period closed (week 45)

Acceptance: Hypercare exit criteria met (defined separately)

4. Schedule

Phase 1 — Design (weeks 1-4): Architecture and integration design

Phase 2 — Build (weeks 5-12): Production deployment + integrations

Phase 3 — Migrate (weeks 13-24): System and user enrollment

Phase 4 — Stabilize (weeks 25-35): Hypercare and runbook completion

Critical milestone dates:

M-PAM-01: Architecture sign-off — 2026-02-12

M-PAM-02: Production environment ready for UAT — 2026-04-08

M-PAM-03: PAM 50% deployed — 2027-01-22 (per program M-017)

M-PAM-04: PAM 100% deployed — 2027-04-07 (per program M-018)

5. Pricing and payment terms

Total contracted value: \$620,000 (services + T&E)

Payment milestones (% of total):

20% — On execution of SOW: \$124,000 (paid 2026-01-22)

20% — On Phase 1 completion (D1): \$124,000

30% — On Phase 2 completion (D2): \$186,000

20% — On Phase 3 completion (D3): \$124,000

10% — On hypercare closure (D6): \$62,000

Payment terms: Net 30 from invoice date.

6. Roles and responsibilities

BeyondTrust:

- Senior Engagement Manager: Risha Cho (named, dedicated 30%)
- Solutions Architect: J. Ferreira (named, dedicated 50%)
- Implementation Engineers: 2 named, dedicated 80% each
- Knowledge Transfer Lead: P. Sandoval (named, dedicated 20%)

Bristol:

- PAM Component Lead: K. Reddy (DRI for engagement)
- TPM (program coordination): Casey Morrison

- Sponsor (executive escalation): Sandra Park, CISO
- Architecture review: D. Park (CTO delegate)
- Security review: Sec Lead

7. Performance & service levels

- Weekly status report from BeyondTrust to Bristol PAM Lead, every Friday
- Monthly steering review with sponsor and Engagement Manager
- Issue resolution SLA: P1 within 4 hours; P2 within 1 business day; P3 within 5 business days
- BeyondTrust commits to a single Engagement Manager throughout the engagement (no rotation without 30-day notice)

8. Risks and dependencies

Vendor-side risks acknowledged:

- BeyondTrust requires Bristol's identity migration (IDP component) to be at minimum 50% complete by week 8 to begin user enrollment
- BeyondTrust requires Splunk HEC token to be provisioned by week 5

Bristol-side dependencies acknowledged:

- Bristol provides production access for engineering team by week 5
- Bristol completes Bristol third-party risk assessment before SOW execution (completed 2026-01-12)
- Bristol provides 200 test accounts for UAT by week 10

9. Termination

- Either party may terminate for material breach with 30-day notice
- Bristol may terminate for convenience with 60-day notice + payment for work completed through termination date
- Termination for change of control: 90 days notice; both parties may negotiate continuation

10. Approvals

Bristol Financial:

- Sponsor (CISO): Sandra Park / 2026-01-15 / signed
- Procurement: D. Marshall / 2026-01-15 / signed
- Legal: Diane Petrov / 2026-01-15 / signed
- Component Lead: K. Reddy / 2026-01-15 / signed

BeyondTrust:

- Engagement Manager: Risha Cho / 2026-01-15 / signed
- VP Professional Services: M. Greenwood / 2026-01-15 / signed

What this SOW did right (lessons confirmed in retrospective)

1. Named individuals on both sides (rather than 'BeyondTrust will provide a Solutions Architect') — prevented mid-engagement turnover.
2. Explicit out-of-scope list — prevented scope creep when adjacent needs surfaced.
3. Acceptance criteria tied to deliverables, not just milestones — payment milestones and acceptance milestones are the same set.
4. Hypercare exit criteria defined separately and signed before go-live — prevented post-deployment ambiguity.

HOW TO READ THIS EXAMPLE

Why this example works: This SOW stands out because every deliverable is defined with an explicit acceptance criterion and a measurement method, not just a name, so there is no

ambiguity about when Bristol Financial can withhold payment or trigger a contractual remedy. The responsibility matrix embedded in the SOW captures both vendor and client obligations, preventing the project manager from discovering mid-engagement that Bristol was expected to provide something it has not provisioned.

Key judgment calls:

- Defining the PAM deployment in phases tied to payment milestones rather than a single completion payment, giving Bristol Financial financial leverage throughout the engagement.
- Including a knowledge-transfer deliverable as a formal, scored acceptance item, not an informal handoff, because vendor dependency post-go-live is a documented risk in the RAID Log.
- Specifying change-order triggers and pricing methodology in the SOW itself, closing the most common dispute vector before the engagement starts.

Adapting it to your context:

- The deliverable list (vault deployment, connector configuration, runbook authoring, admin training) is BeyondTrust/PAM-specific; derive yours from your own RFP requirements and vendor proposal.
- The payment-milestone structure is universally reusable; align milestone payments to your program's acceptance gates, not to the vendor's preferred billing schedule.
- Ensure your SOW's acceptance criteria link back to the RFP scoring rubric so the vendor cannot deliver a technically passing product that scores below the threshold that won the contract.

21 — Steering Committee Pack — Project Atlas (June 2026)

This is the actual Steering Committee deck and pre-read used at the June 2026 monthly steering meeting. Cadence: monthly, 90 minutes, sponsor chairs. The pack has 3 elements: pre-read (sent 2 business days prior), deck (used in meeting), action items log (updated during meeting).

Pre-read (sent 2026-06-12, meeting on 2026-06-16)

To: Project Atlas Steering Committee

From: Casey Morrison (TPM)

Subject: Steering pre-read — June meeting (Mon 6/16, 2-3:30 PM)

Attendees expected:

- Sandra Park, CISO (sponsor, chair)
- Linda Walsh, CIO
- Mark Williams, CTO
- Robert Stein, CRO
- Martin Chen, PMO Director
- Casey Morrison, TPM (presenter)

Decisions requested at this meeting:

1. Approve \$80K contingency draw for FIDO2 buffer tokens (DC-028 ratification)
2. Approve 1-week schedule extension on ZTNA Wave 2 (DC-027 ratification)
3. Approve revised Q4 2026 cloud security operations budget (estimate \$420K, +\$20K over single-drawdown threshold)

Read before the meeting:

- Status report (this period) — pages 4-7 of the deck
- RAID Log top 5 risks — page 8

- Decisions log entries DC-027 and DC-028 — page 11

Deck outline (16 slides, 60-min walkthrough + 30-min discussion)

Slide 1 — Title slide. Project Atlas Steering Committee — June 2026

Slide 2 — Agenda

- Status overall (5 min)
- Component status (15 min)
- Top risks and open decisions (20 min)
- Open discussion (30 min)
- Next meeting + action items (10 min)

Slide 3 — One-slide status summary

Overall: At-Risk

Rationale: MFA Wave 2 at-risk due to FIDO2 supply (mitigation in flight); ZTNA Wave 2 paused for incident RCA (resumed 6/22 after sponsor approval)

Schedule: -7 days vs baseline (consuming float; remaining 1-day float)

Budget: On plan; \$130K of contingency drawn (38% remaining)

Top concern: If MFA Wave 2 slips another 2 weeks, ZTNA Wave 2 cascades and SOC 2 audit window is at risk

Slide 4 — Component status (color-coded)

IDP Migration (M. Ortiz): On-Track (65% complete)

ZTNA Rollout (J. Liu): At-Risk (paused → resumed; 1-week slip)

PAM (K. Reddy): On-Track (design phase, on schedule)

MFA Hardening (S. Chen): Off-Track (FIDO2 supply; mitigation in flight)

Access Review Automation (P. Nguyen): On-Track (Phase 1 design complete)

Slide 5 — Schedule view (Gantt)

[Visual showing milestones M-001 through M-021; M-008 and M-009 highlighted as at-risk]

Slide 6 — Critical path narrative

Current critical path: MFA Wave 2 → ZTNA Wave 2 → SOC 2 audit window opens

Float remaining: 1 day

Implication: Any further MFA delay puts ZTNA cutover at risk; ZTNA delay puts SOC 2 at risk

Slide 7 — Top 5 risks (from RAID)

R-016: FIDO2 token vendor lead time slipped (H/H, 16) — buffer tokens deployed

R-021: ZTNA Wave 2 user-population variance (M/M, 9) — capacity revised

R-023: Insider-threat findings overlap with Access Review scope (M/H, 12) — under analysis

R-001: BeyondTrust contract negotiation slip (M/H, 9) — closed as mitigated

R-031: SOC 2 audit team change risk (L/H, 6) — KPMG confirmed

Slide 8 — Open issues

I-014: Privileged FIDO2 enrollment 67% vs 95% target (in progress; deadline extended)

I-019: Helpdesk ticket volume +60% post-Wave 1 (resolving; staffing extended)

I-022: 3 app owners refusing connector deployment (open; sponsor escalation queued)

Slide 9 — Decisions for ratification

DC-027: ZTNA Wave 2 1-week extension (sponsor pre-approved 6/5; ratifying with steering)

DC-028: \$80K contingency to MFA for buffer tokens (sponsor pre-approved 6/6; ratifying)

Slide 10 — Decisions requested

1. Q4 cloud security operations standup budget approval (\$420K, requires steering — single drawdown threshold \$400K)
2. Acknowledgment of M-008 (MFA Wave 2) deadline extension to 7/01

Slide 11 — Resourcing & capacity

Q3 staffing at peak (24 FTE allocated, 24 demand)

Hiring requisitions: 3 approved (DC-026); 1 contractor onboarded

Resource conflicts: 3 active (C-001, C-002, C-003); all with mitigation plans

Slide 12 — Budget snapshot

Approved: \$8.4M

Spend-to-date: \$5.39M (64%)

Forecast EAC: \$8.4M (on plan)

Contingency drawn: \$130K of \$200K (38% remaining)

Slide 13 — Open issues for steering

1. SOC 2 audit window pressure: KPMG-confirmed 8/15 start; current schedule has 1-day float
2. App owners refusing connectors: Three identified, sponsor escalation needed
3. Q4 cloud operations standup: Budget authority required

Slide 14 — Decisions log review (entries since last meeting)

DC-019, DC-022, DC-023, DC-024, DC-025, DC-026, DC-027, DC-028, DC-029, DC-030

Slide 15 — Asks for sponsor / steering

Sandra: communicate revised SOC 2 readiness to KPMG by 6/19

Linda: commitment on ZTNA Wave 2 communication to Field Eng by 6/15

Robert: GRC sign-off on MFA buffer-token compensating control by 6/14

Slide 16 — Next meeting

Date: 2026-07-21

Pre-read deadline: 2026-07-17

Special topic: SOC 2 audit readiness deep-dive (KPMG joining for 30 min)

Action items (logged in companion tracker)

A-2026-06-001: Communicate SOC 2 readiness posture to KPMG (Sandra, due 6/19)

A-2026-06-002: ZTNA Wave 2 comms to Field Engineering (Linda, due 6/15)

A-2026-06-003: GRC sign-off MFA compensating control (Robert + Sec Lead, due 6/14)

A-2026-06-004: Bring revised Q4 cloud ops budget to July steering (Casey, due 7/14)

A-2026-06-005: Sponsor escalation to 3 app owners refusing connectors (Sandra, due 6/22)

Meeting outcomes (post-meeting summary, distributed within 24 hours)

Decisions ratified: DC-027, DC-028 (both unanimous)

New decisions: DC-031 (revised Q4 cloud ops budget approved at \$420K — Sandra + Linda + Mark approved)

Action items: 5 created (above)

Risks accepted: R-023 (insider threat scope overlap) — sponsor accepts; analysis to continue, ratification at July meeting

Concerns surfaced: Robert raised question about whether 1-day schedule float is enough headroom for SOC 2 audit window. Action: TPM to model 'what would we do if MFA slips another week' and present at July meeting.

What this Steering pack does right (lessons confirmed)

- 1. Pre-read sent 2 business days early — meeting time spent on discussion, not catch-up.
- 2. Decisions requested up-front (slide 9 + 10) — steering knows what they're being asked to approve before reviewing context.
- 3. Action items logged in real-time during meeting — TPM publishes within 24 hours.
- 4. Single-page status summary (slide 3) — executives can absorb in 30 seconds.

HOW TO READ THIS EXAMPLE

Why this example works: This SteerCo pack is exemplary because it opens with a three-line program health summary that lets a sponsor form a view before reading a single slide, and every status indicator links to an action or a decision request rather than floating as an assessment. The exception reporting approach, covering only deviations from plan rather than comprehensive progress narration, respects sponsor time and forces the PM to make editorial judgments about what actually matters.

Key judgment calls:

- Limiting decision requests to two per pack, pre-socialized with the sponsor before the meeting, so the formal session approves rather than deliberates and the meeting stays under 60 minutes.
- Including a forward-look section with the next milestone and its confidence level alongside a look-back, giving the sponsor the information needed to manage upward to the board.
- Surfacing cost-to-complete and contingency-remaining in every pack, not just at financial review gates, so no budget surprise is ever more than 30 days old.

Adapting it to your context:

- The Atlas-specific content (ZTNA wave status, PAM vendor milestone) should be replaced with your program's critical path items; the one-page-per-topic structure is reusable.
- Calibrate the number of decision requests per meeting to your sponsor's bandwidth and your governance calendar; two per meeting is a guideline, not a rule.
- If your SteerCo includes non-technical executives, add a one-sentence plain-English translation below each technical status item, as Atlas does for the certificate-management amber.

22 — UAT Plan & Test Cases — ZTNA Wave 1 (Project Atlas)

UAT Plan for ZTNA Wave 1 (28 low-risk apps, 200 pilot users). UAT entry approval gates production cutover. Approved 2026-04-22; UAT executed 2026-04-25 to 2026-05-22.

Document control

Title	ZTNA Wave 1 UAT Plan & Test Cases
Version	v1.3 (final)
Date	2026-04-22
Author	J. Liu (ZTNA Component Lead) with QA Lead
Approver	Sandra Park (sponsor), Mark Williams (CTO), Sophie Karim (GRC)

UAT entry criteria (must all be met before UAT begins)

E-001: All 28 in-scope applications integrated with Cloudflare and tested in dev

E-002: Okta SSO + FIDO2 step-up working end-to-end in test environment

E-003: 200 pilot users provisioned and notified

E-004: Audit logging integrated with Splunk and validated

E-005: Helpdesk runbook delivered and Tier 1 trained (per Training Plan)

E-006: Rollback to VPN tested and procedure documented

E-007: All P1 and P2 defects from system-test phase closed

UAT exit criteria (gate production cutover)

X-001: 95% of test cases passed (88 of 93 minimum; current: 88 = 94.6% — narrowly passing)

X-002: Zero P1 defects open

X-003: P2 defects open: ≤ 3 (current: 2)

X-004: User satisfaction survey: $\geq 4.0/5$ (current: 4.1)

X-005: Helpdesk readiness: 70% Tier 1 first-call resolution rate on simulated calls (current: 73%)

X-006: Rollback procedure tested at least once (executed 2026-05-15, successful)

Test categories

Category	Test cases	Priority distribution
1. Functional access tests	38	High: 12, Medium: 18, Low: 8
2. Security & policy tests	22	High: 15, Medium: 7, Low: 0
3. Performance & latency tests	12	High: 5, Medium: 5, Low: 2
4. Integration tests	16	High: 9, Medium: 5, Low: 2
5. Operational tests	5	High: 3, Medium: 2, Low: 0
TOTAL	93	High: 44, Medium: 37, Low: 12

Test case examples (illustrative — full catalog in workbook 'UAT Test Cases' tab)

TC-001 (Functional, High): Authenticate to Confluence via Cloudflare Access

Setup: User in pilot group, FIDO2 token enrolled, on managed laptop

Steps: 1. Navigate to confluence.bristolfinancial.example

2. Verify Okta redirect

3. Complete SSO + posture check

4. Verify access decision logged in Splunk

Expected: User loads Confluence; access decision logged within 30 seconds

Pass criteria: Page loads within 5 seconds; Splunk event matches user ID and app

TC-014 (Security, High): Deny access for non-managed device

Setup: User in pilot group, accessing from unmanaged personal device

Steps: 1. Navigate to internal app from personal laptop

2. Verify posture check fails

3. Verify access denied with reason "Device not managed"

Expected: Deny decision; clear reason shown; logged in Splunk

Pass criteria: User sees deny page; Splunk event = "deny_unmanaged_device"

TC-031 (Performance, High): P99 access decision latency

Setup: 50 concurrent users hitting top-10 apps

Steps: Run synthetic load test for 30 minutes; capture all latency measurements

Expected: P99 latency < 500ms (NFR-001)

Pass criteria: 99th percentile of all 1000+ measurements < 500ms

TC-058 (Integration, High): Splunk audit log completeness

Setup: Multiple users access multiple apps over 1 hour

Steps: Capture all access decisions in Splunk for the test window

Expected: Every access decision is logged with user, app, time, decision, posture state

Pass criteria: 100% of access events have all 5 required fields populated

UAT execution summary

Date range:	2026-04-25 to 2026-05-22 (4 weeks)
Test cases run:	93
Pass:	88 (94.6%)
Fail:	5 (5.4%) — all addressed before exit
Defects opened:	14 total
Defects closed:	14 (12 fixed, 2 deferred to Wave 2 with sponsor approval)
Defects open:	0 P1, 2 P2 (within exit criteria)

Defects of note (most consequential 5)

D-008: Confluence integration failed for users with apostrophes in last name (e.g., O'Brien)

Root cause: Cloudflare connector escaping bug

Fix: Vendor patch deployed 2026-05-09; re-test passed

Lesson: Need to widen test data set for Wave 2

D-019: P99 latency at 600ms during peak (NFR-001 violated)

Root cause: Cloudflare PoP routing for west-coast users routed to wrong edge

Fix: Cloudflare CSM updated routing config; re-test passed at 380ms P99

Lesson: Validate PoP routing during pre-UAT testing

D-024: Helpdesk Tier 1 unable to read access denied logs

Root cause: Splunk role-based access not provisioned

Fix: GRC + Identity team provisioned read-only access

Lesson: Helpdesk readiness depends on tools access; verify before training, not during UAT exit decision

Decision: PASS — production cutover approved

Decided by: Sandra Park (sponsor), Mark Williams (CTO), Sophie Karim (GRC)

Decision date: 2026-05-23

Conditions: 2 deferred P2 defects must be addressed in Wave 2

What this UAT did right (lessons confirmed)

1. UAT was not "smoke test before go-live" — it was a structured 4-week effort with documented criteria.

2. Exit criteria were quantitative ($\geq 95\%$ pass rate, ≤ 3 P2 open) — not subjective.

- 3. Defects were triaged daily during the 4-week window, not all at the end.
- 4. The rollback procedure was tested before UAT exit, not after — proved it actually works.

HOW TO READ THIS EXAMPLE

Why this example works: This UAT Plan is distinguished by tracing every test case back to a specific functional requirement and a risk, so a test-coverage gap is also visibly a risk-coverage gap. The entry and exit criteria are stated as binary pass/fail conditions rather than as completion percentages, preventing the common failure mode of declaring UAT complete with 95% test execution while critical-path scenarios remain untested.

Key judgment calls:

- Requiring business-side sign-off on test case definitions before execution begins, not just on results, so disputes about what done looks like are resolved before effort is sunk.
- Including negative test cases (failed authentication, break-glass misuse, revoked certificate behavior) at the same priority level as happy-path cases, reflecting the security program context.
- Defining a defect triage SLA within the UAT plan itself so the test cycle does not stall waiting for an engineering prioritization meeting that was never scheduled.

Adapting it to your context:

- The test scenario content (ZTNA policy enforcement, PAM session recording, MFA fallback) is Wave 1 Atlas-specific; derive your own scenarios from the acceptance criteria in your SOW and the risk register.
- The requirement-to-test traceability matrix is universally reusable; build it before you write test cases, not as a retrospective documentation exercise.
- Recalibrate the defect SLA thresholds (critical: 4 hours, major: 24 hours) to your team's actual capacity during the UAT window.

23 — Lessons Learned Register — Project Atlas (mid-program)

23 — Lessons Learned Register — Project Atlas (mid-program review)

Lessons Learned is captured throughout the project, not only at close. Excerpt of the live register at the 50% mark (week 22, mid-July 2026). Captured at retrospectives, post-incident reviews, and ad-hoc when something notable happens.

Why mid-program: Lessons captured at close don't help the project they came from. Mid-program lessons inform the second half. Closeout lessons inform future projects.

Active register (selected high-impact entries)

ID	Date	Source	Category	Lesson	Status
L-001	2026-01-22	Kickoff retrospective	Comms	Send pre-read 3 business days before kickoff (we did 2; some attendees came unprepar	ed) Adopted
L-002	2026-02-19	Charter approval workshop	Governance	Sponsor + CIO joint sign-off was high-value; CTO would have	th forces alignment. Pattern to repeat

ID	Date	Source	Category	Lesson	Status
				signed alone — having bo	
L-003	2026-03-04	Stakeholder review	Stakeholders	Helpdesk classified as 'Informed' missed critical adoption signal; reclassified to '	Champion' Applied (DC-025)
L-004	2026-04-15	Wave 1 mid-pilot review	OCM	Field Engineering resistance was visible 4 weeks before cutover — earlier listening	sessions would have surfaced it sooner Pattern for Wave 2
L-005	2026-04-22	ZTNA Wave 1 cutover	Engineering	Always test the rollback procedure BEFORE cutover, not as a 'just-in-case' Adopted	
L-006	2026-05-22	ZTNA Wave 1 retrospective	Engineering	Splunk role-based access for helpdesk should be provisioned at training time, not at	go-live Applied
L-007	2026-05-22	ZTNA Wave 1 retrospective	Capacity	Cutover blast-radius (28 apps) was right call; future waves should size similarly A	pplied to Wave 2
L-008	2026-06-05	Post-incident review	Process	RCA decision (DC-027) needed sponsor authority faster; the 1-week schedule slip cost	~\$30K in idle resources Open — process review
L-009	2026-06-08	Vendor relationship review	Procurement	Single-vendor dependency for FIDO2 hardware was	Id require dual-source supply Open — RFP template

ID	Date	Source	Category	Lesson	Status
				a R-016 blind spot; future RFPs shou	update
L-010	2026-06-15	Stakeholder review	OCM	CISO sponsor conversations with resistant app owners (DC-034) resolved 3 issues that	PM-level escalation couldn't Pattern to repeat
L-011	2026-06-22	Cross-component dependency	Planning	D-007 (Access Review depends on PAM data) was missed in original plan; cross-compone	nt dependency reviews should be a standing agenda item Adopted
L-012	2026-07-01	Capacity planning	Resource	Helpdesk Tier 2 was double-booked (C-003); resource conflicts should be modeled at q	uarterly granularity, not just monthly Open — resource model update
L-013	2026-07-12	Schedule recovery review	Planning	Phase 1 scope rebaseline (DC-032) saved 2 weeks; should be normal practice when sche	dule pressure emerges, not exceptional Adopted
L-014	2026-07-19	External (KPMG)	Risk	SOC 2 scope expansion was external; building a quarterly external-change check-in in	to the schedule would prevent surprise Open — schedule template update

Lessons by category (count, status)

Category	Count	Adopted	Pattern	Open
Comms	1	1	0	0
Governance	1	0	1	0
Stakeholders	2	1	1	0

Category	Count	Adopted	Pattern	Open
OCM	2	0	2	0
Engineering	3	3	0	0
Capacity	1	1	0	0
Process	1	0	0	1
Procurement	1	0	0	1
Planning	3	1	1	1
Risk	1	0	0	1
Resource	1	0	0	1

Top 3 lessons by impact (mid-program assessment)

L-005 (test rollback before cutover): Saved the program approximately 3 weeks of recovery time for the 11/18 incident. The rollback worked because it had been validated before, not during, the incident.

L-009 (dual-source FIDO2 supply): Single-source dependency cost the program \$80K (DC-028) and 2 weeks of M-008 schedule. Pattern for future RFP templates: require dual-source supply.

L-010 (CISO direct outreach to resistant app owners): Sandra Park's 1:1 conversations resolved 3 stakeholder issues that PM-level escalation could not. The sponsor-to-stakeholder pattern is high-value when used sparingly.

How lessons enter and leave the register

Captured: at retrospectives (every 6 weeks), post-incident reviews (every incident), ad-hoc when team members surface them, at sprint reviews where notable patterns emerge.

Reviewed: monthly by TPM + sponsor. Each lesson categorized:

- Adopted: applied to the program; no further action
- Pattern to repeat: documented for future use
- Open: requires action by named owner

Adopted lessons are checked at next major milestone — did the change work? L-005 was adopted in May; validated at the 11/18 incident in June.

Cross-references

- L-003 connects to DC-025 (helpdesk reclassification)
- L-005 was applied at DC-027 (rollback decision)
- L-009 will inform RFP template revision (Lessons Learned → Procurement Guide)
- L-013 was applied at DC-032 (Access Review rebaseline)

Cadence

Every 6 weeks: full retrospective produces 4-8 new lessons

Monthly: TPM reviews open items for follow-up

Quarterly: Sponsor reviews 'Pattern to repeat' lessons for organizational-level adoption

At program close: Final review + transfer to PMO Lessons Library

HOW TO READ THIS EXAMPLE

Why this example works: This Lessons Learned Register is exceptional because it is captured mid-program while context is still fresh and decisions are still reversible, not as a post-mortem

exercise done after the team has dispersed. Each lesson has an action linked to it with an owner, converting the register from a retrospective record into a live improvement tool that the current program actually benefits from.

Key judgment calls:

- Categorizing lessons by root cause (process, tooling, governance, vendor, team) rather than by phase, so patterns across workstreams are visible and systemic fixes are distinguishable from one-off corrections.
- Including positive lessons (what worked and should be repeated) alongside negative ones at equal weight, avoiding the survivorship bias that makes lessons-learned registers purely corrective.
- Assigning a propagation owner whose job is to share relevant lessons with other programs in the portfolio, treating the register as an organizational asset, not just an Atlas artifact.

Adapting it to your context:

- The specific lessons (directory-sync lead time underestimated, PAM pilot scope too broad) are Atlas/ZTNA-specific; the capture cadence (every four weeks or after each wave) is reusable.
- In your organization, identify who owns the cross-program propagation role before you start capturing; without that role, mid-program lessons die in a SharePoint folder.
- If your program culture resists candid retrospectives, run the mid-program session with an external facilitator the first time to establish psychological safety, then internalize the practice.

24 — Project Closeout Report — Project Atlas (draft at 50%)

24 — Project Closeout Report — Project Atlas (anticipated, drafted)

Note: Project Atlas is mid-execute (Q3 2026); final closeout will not occur until Sep 2027. This is the DRAFT closeout report template populated with the projected final state, used for sponsor review at the 50% milestone to validate that benefits realization tracking is on course.

Document control

Title	Project Atlas — Project Closeout Report (DRAFT for mid-program review)
Version	v0.4 (draft, not approved)
Date	2026-07-15
Author	Casey Morrison (TPM)
Status	Draft for sponsor review at July steering; final at Sep 2027 program close

1. Executive summary

Project Atlas authorized \$8.4M to deliver 5 components (IDP migration, ZTNA, PAM, MFA hardening, Access Review automation) plus standup of Cloud Security Operations function. Program duration: 21 months (Jan 2026 to Sep 2027).

At program close (projected): all 5 components delivered; SOC 2 2026 audit passed with zero identity findings; Cloud Security Operations function operational with 14 FTE + 3 contractors. Cumulative \$4.5M annual risk exposure reduction estimate validated.

Variance from baseline: budget on plan (\$8.4M); schedule +21 days late (consumed 26 of 30 days of float); scope slightly reduced via DC-032 (3 lower-priority systems deferred to follow-on Phase 2).

2. Outcomes vs Charter objectives

Charter objective	Result
Migrate 100% workforce identity from legacy AD by Q3 2026 ✓	Met (Oct 2026, +7d)
Deploy ZTNA replacement for VPN to 100% workforce by Q4 2026 ✓	Met
FIDO2 MFA: privileged Q2 2026, all employees Q4 2026 P	artially met — privileged Q3 (+14d slip), employees on track
Pass SOC 2 2026 with zero identity findings ✓	Met (Aug 2026 audit; zero findings)
PAM 100% deployed by Q1 2027 ✓	Met (Apr 2027, +7d)

3. Benefits realization

Benefit	Baseline	Target	Actual	Status
Identity-related risk exposure reduction \$	4.5M	\$4.5M	\$4.6M	✓ Met (slightly exceeded)
SOC 2 audit findings (identity) 1	4	0	0	✓ Met
VPN concentrators decommissioned 0	/8	8/8	8/8	✓ Met
Privileged accounts in PAM 0	/150	150/150	150/150	✓ Met
Cloud Security Operations function FTE 0		14	14+3 ✓	Met
Cloud Migration program unblocked No	Y	es Y	es ✓	Met

Realization timeline (when each benefit materializes):

- Audit findings: Aug 2026 audit cycle
- VPN decommission: Nov 2026
- PAM coverage: Apr 2027

- Risk reduction: cumulative; full effect by Q3 2027 close
- Cloud Security Operations: ramped over Q3 2027

4. Schedule performance

Baseline duration: 21 months (Jan 2026 to Sep 2027)

Actual duration: 21 months + 3 weeks (estimated; final at close)

Variance: +21 days (within float; net program duration unchanged)

Schedule causes:

- FIDO2 token supply chain (M-008): +14d
- Access Review design complexity (M-007): +7d
- ZTNA Wave 1 blast-radius caution (M-006): +5d
- ZTNA Wave 2 RCA pause (M-013): +7d

Mitigation: Project finished within float; SOC 2 audit window met on time.

5. Cost performance

Approved budget: \$8,400,000

Final spend: \$8,400,000 (estimate; expected at close)

Variance: \$0 (on plan)

Component variances absorbed by contingency reserve; net program cost held at approved.

6. Scope performance

Charter scope: 5 components + Cloud Security Operations function

Delivered scope: 5 components + Cloud Security Operations function

Scope changes: 1 (DC-032 — Access Review Phase 1 rebaseline; 3 lower-priority systems deferred to internal Phase 2 in Q4 2027)

7. Quality metrics

UAT pass rate (across 4 cutovers): 95.2% average

Production incidents post-cutover: 1 P1 (11/18, ZTNA Wave 2; resolved in 6 hours), 7 P2 (all resolved within SLA)

Helpdesk first-call resolution rate post-launch: 73% (target was 70%)

User adoption (workforce-wide): 96% (target was 95%)

8. Stakeholder satisfaction

Sponsor (Sandra Park): "On budget, on outcome, with one schedule slip we recovered. Best identity program I've seen at scale."

CIO (Linda Walsh): "Field Engineering complaint volume dropped after 8 weeks; net benefit clear by month 6."

External auditor (KPMG): "Zero identity findings is unusual at this scale; documentation quality made the audit straightforward."

User survey (post-launch, n=2,400): NPS +28 (target was +20)

9. Lessons learned summary

48 lessons captured during program (live register has running count). Top 5 organizational-level lessons:

1. Test rollback procedures before cutover — saved 3+ weeks of recovery on 11/18 incident
2. Single-source vendor dependencies must be flagged at intake — FIDO2 supply lesson
3. Sponsor-to-stakeholder direct outreach is a high-value, sparingly-used escalation path
4. Cross-component dependency reviews should be a standing program agenda item

5. Helpdesk should be classified as Champion (not Informed) for security-tooling rollouts
Full Lessons Learned register transferred to PMO Lessons Library.

10. Knowledge transfer & operations

The Cloud Security Operations function is the durable owner of program-built systems:

- IDP (Okta) operations: Identity Engineering team (2 FTE)
- ZTNA (Cloudflare) operations: Network Security team (2 FTE)
- PAM (BeyondTrust) operations: Privileged Access team (3 FTE)
- MFA (FIDO2) operations: IAM Operations team (1 FTE)
- Access Review automation: GRC Operations team (2 FTE)
- Cross-cutting: Security Operations (4 FTE) — incident response, threat hunting, monitoring

Operations runbooks delivered (per Operating Model Document).

11. Closure approvals (anticipated)

Sponsor (CISO): Sandra Park (signature pending Sep 2027)

CIO: Linda Walsh

CTO: Mark Williams

CRO: Robert Stein

PMO: Martin Chen

External auditor (KPMG): closure letter pending

Why this draft now

Reviewing the closeout report at 50% (mid-program) is a deliberate practice. It forces the team to validate:

- That benefits we expected at outset are still on track to be measured
- That scope decisions are still aligned with what the Charter said we'd deliver
- That stakeholders we identified are still the right ones at close
- That the operational hand-off plan is still credible

We discovered 3 things from this exercise:

1. The "\$4.5M risk reduction" estimate was based on 2025 audit findings; we should re-validate against 2026 audit at the next quarterly check
2. The Cloud Migration program (downstream beneficiary) was not in our stakeholder map — added (DC-035)
3. Knowledge transfer to operations teams was understaffed in the original plan; resourcing will need to reflect the 6-month overlap

What this Closeout Report did right (lessons confirmed)

1. Drafted at 50% — caught 3 issues that would have surfaced at close (too late)
2. Benefits realization measured against a baseline (the original Charter's \$4.5M estimate)
3. Stakeholder satisfaction quantified — NPS, user survey, sponsor quote
4. Lessons learned summary references the running register, not a fresh post-program brain dump

HOW TO READ THIS EXAMPLE

Why this example works: The Closeout Report draft at 50% completion is exemplary precisely because it is written as a living document rather than a post-hoc narrative: objectives, benefits, and success metrics are stated in advance so the final version cannot quietly revise what success was supposed to look like. The deliberate incompleteness of the document, with

placeholders for final metrics and open lessons, models the discipline of separating what is known from what is still to be confirmed.

Key judgment calls:

- Locking the benefits-realization measurement methodology at mid-program so the metrics used to declare success are not selected retrospectively to favor a favorable reading.
- Including an explicit transition-to-operations section that names the receiving team, handover checklist, and warranty period, treating operational continuity as a closeout deliverable, not an afterthought.
- Documenting in-flight risks that will survive into BAU with their current residual scores, so the operations team inherits a live risk picture rather than a clean fiction.

Adapting it to your context:

- Start your closeout report template at program initiation, not at closeout; the Atlas approach of drafting at 50% is good, but locking success criteria at kickoff is better.
- The handover checklist items (runbook sign-off, SIEM integration verification, license transfer) are Atlas-specific; build yours from your program's operational-readiness criteria.
- If your organization has a PMO that conducts independent closeout reviews, write the benefits section to satisfy that audience from the start, since retrofitting the evidence is harder than collecting it progressively.

30 — Retrospective Pack — ZTNA Wave 1 Cutover (Project Atlas)

This is the Retrospective conducted after ZTNA Wave 1 cutover (May 22, 2026). Retros happen at major program milestones, not just at close. Format: 90 minutes, facilitator-led, 8-12 attendees, structured around what worked / what didn't / what we'll change. Produces 2-3 lessons learned per retro.

Document control

Title	ZTNA Wave 1 Cutover Retrospective
Date	2026-05-29 (one week post-cutover)
Facilitator	R. Patel (OCM Lead, neutral facilitator)
Attendees	J. Liu (component lead), Casey Morrison (TPM), 2 ZTNA engineers, 1 helpdesk rep, 1 GRC rep, 1 user rep
Output	4 lessons learned (L-005, L-006, L-007 in Lessons Register; 1 deferred)

1. Retrospective structure (90 minutes)

00:00 — Welcome & ground rules (5 min)

05:00 — Recap: What was the goal? What did we deliver? (10 min)

15:00 — What worked well? Round-robin (15 min)

30:00 — What didn't work? Round-robin (20 min)

50:00 — What should we change for Wave 2? Brainstorm + cluster (25 min)

75:00 — Action item commitments (10 min)

85:00 — Summary & follow-up (5 min)

Ground rules (read at start):

- Focus on systems/process, not people
- Everyone speaks (round-robin format)
- Specific examples beat generalizations

- Hindsight bias acknowledged — we know what we know now, not what we knew then
- Action items must have a named owner and a date

2. Recap (5 min)

Goal: Cutover 28 low-risk applications to Cloudflare Zero Trust for 200 pilot users; UAT-pass production cutover; rollback tested.

Delivered: 28 apps live; 200 users active; 14 defects opened, 12 closed; UAT pass rate 94.6%; cutover went over scheduled window by 5 days.

3. What worked well (key items, condensed)

W-1 (J. Liu, R. Patel, GRC): 'Test rollback before cutover' was vindicated. The 11/18 incident wouldn't have been resolvable in 6 hours without the validated rollback procedure.

W-2 (Casey, J. Liu): The 28-app blast radius was right. Original plan was 45 apps; we split to 28+17 after security architecture review (DC-023). Wave 1 manageable; Wave 2 will be similar size.

W-3 (J. Liu, ZTNA engineer): Cloudflare Premier support engagement paid off. PoP routing fix (D-019) would have been a 2-week defect without their CSM.

W-4 (Helpdesk rep): Tier 1 training was thorough. Most user issues resolved at first contact. Ticket volume was higher than baseline but not crisis-level.

W-5 (User rep): Communication ahead of cutover was clear. Users knew what was changing and what to do if something broke.

W-6 (Casey, J. Liu): Single Slack channel for cutover coordination — engineers, helpdesk, OCM, sponsor all on the same thread. Decisions documented in real-time.

4. What didn't work (key items, condensed)

D-1 (J. Liu, helpdesk rep): Splunk role-based access for helpdesk was not provisioned at training time. Helpdesk completed training but couldn't actually use the audit logs they were trained on. Tier 1 first-call resolution rate dipped during week 1 because of this.

D-2 (Casey, J. Liu): Some defects we found in UAT (D-008 apostrophes-in-name) had real production impact. Test data set was too narrow. We should have caught this in pre-UAT testing.

D-3 (J. Liu): Cloudflare PoP routing wasn't validated for west-coast users. We assumed AnyCast routing would handle this; it didn't. Cost us 4 days of latency complaints.

D-4 (User rep): Field Engineering listening sessions started 4 weeks before cutover; should have started earlier. Some resistance was visible from Wave 1 pilot but had no ear before that.

D-5 (Helpdesk rep): Helpdesk Tier 2 was reactive, not proactive. Issues weren't being reported up; helpdesk discovered patterns 2 weeks late. Need a daily 'what are we seeing' touch point.

D-6 (GRC rep): Audit logging was tested in dev but not validated in production until cutover day. We got lucky; could have lost first day's audit trail.

5. What we'll change for Wave 2

Cluster theme A: Pre-UAT validation (D-2, D-3, D-6)

- Action: Wider test data set including edge cases (apostrophes, hyphens, long names) — owner: J. Liu, due before Wave 2 UAT entry
- Action: Validate PoP routing in dev for all geographic user populations — owner: ZTNA engineer + Cloudflare CSM, due 2 weeks before Wave 2 UAT
- Action: Audit logging validated in production-equivalent environment, not dev — owner: Sec Lead, due before Wave 2 cutover

Cluster theme B: Operational readiness (D-1, D-5)

- Action: Splunk RBAC for helpdesk provisioned at training time, NOT cutover day — owner: GRC + Identity team, applied retroactively for Wave 1 (closed); standing requirement for Wave 2
- Action: Daily helpdesk standup during cutover week (not weekly) — owner: OCM Lead, established as standing process

Cluster theme C: Stakeholder engagement (D-4)

- Action: Listening sessions for resistant audiences begin 8 weeks before cutover (not 4) — owner: OCM Lead; applied for Wave 2
- Action: Field Engineering specific listening cadence: every 2 weeks until cutover — owner: OCM Lead

Cluster theme D: What worked, keep doing (W-1 through W-6)

- All 6 items confirmed as standing practice for Wave 2 and beyond

6. Action items committed (with owners and dates)

A-RETRO-001: Wider test data set including edge cases (J. Liu, due 2026-06-30)

A-RETRO-002: PoP routing validation for all geographies (ZTNA engineer + Cloudflare, due 2026-07-15)

A-RETRO-003: Production audit logging validation (Sec Lead, due 2026-07-30)

A-RETRO-004: Splunk RBAC at training time policy (GRC, applied; standing)

A-RETRO-005: Daily helpdesk standup during cutover (OCM Lead, applied for Wave 2; standing)

A-RETRO-006: Listening sessions begin T-8 (OCM Lead, applied for Wave 2; standing)

7. Lessons captured (transferred to Lessons Learned register)

L-005: Test rollback before cutover (validated by 11/18 incident) — Adopted (cross-program)

L-006: Splunk RBAC at training time (cross-program practice) — Applied

L-007: 28-app blast radius pattern for cutovers (Wave 2 sizing) — Applied to Wave 2

Deferred: Pre-UAT test data widening — incorporated into A-RETRO-001 action; will be a lesson if validated successful in Wave 2.

8. Sentiment

Net sentiment: Mostly positive (5 of 7 attendees rated retrospective high-value)

Concern raised: Cutover-week pace was draining; suggest 1-week recovery before Wave 2 planning resumes (sponsor accepted)

9. Follow-up

Distributed: Retrospective summary distributed to attendees + sponsor within 24 hours

Action item review: At Wave 2 kickoff (June 18), confirm action items A-RETRO-001 to A-RETRO-006 are being tracked

Next retrospective: After ZTNA Wave 2 cutover (Aug 2026)

What this retrospective did right (lessons confirmed)

1. Held one week post-cutover — recent enough to remember, distant enough for perspective
2. Neutral facilitator (OCM Lead, not the component PM) — created space for honest 'what didn't work'
3. Round-robin format — ensured everyone spoke, not just the most-vocal
4. Action items have owners and dates — not just 'we should do better'
5. Lessons captured in shared register — made accessible to future programs (cross-program leverage)

HOW TO READ THIS EXAMPLE

Why this example works: This retrospective pack earns its quality by separating observations from judgments and judgments from actions: raw data (cycle times, defect counts, cutover duration) appears first, interpretation second, and improvement actions third, each with an owner and due date. A reader should notice that the pack surfaces what the team would actually repeat, not just what went wrong, making it a genuine knowledge asset.

Key judgment calls:

- Running the retrospective within five business days of cutover while evidence is fresh, rather than scheduling it at program end when context is lost.
- Categorizing findings by process domain (testing, change control, communication, tooling) rather than by who was involved, which keeps the conversation systemic rather than personal.
- Carrying forward only actions with a named owner and a fixed date, and explicitly closing out suggestions that the team voted not to pursue.

Adapting it to your context:

- Reuse the data-first structure: gather your own cycle-time and defect metrics before the facilitated discussion, so the conversation is grounded in evidence.
- Adapt the process domain categories to your delivery method; if you are running agile sprints, substitute sprint ceremonies for the ZTNA-specific categories.
- Store the pack in the program document library and reference it explicitly during Wave 2 planning so learnings are actually applied.

31 — Post-Incident Review Pack — 11/18 Authentication Outage

31 — Post-Incident Review Pack — ZTNA Wave 2 Authentication Outage (11/18 Incident)

Post-Incident Review (PIR) for the ZTNA Wave 2 authentication outage on November 18, 2025. PIR happens within 5 business days of any P1 or P2 incident. Output: root cause, actions, lessons learned. NOT a blame exercise.

Document control

Title	PIR — ZTNA Wave 2 Authentication Outage (Incident I-008)
Incident ID	INC-2026-031
Severity	P1
Date of incident	2025-11-18 (note: pre-dates Atlas execute; happened in Cloudflare proof-of-concept which was the basis for selecting it)
Date of PIR	2025-11-23 (5 business days post)
Facilitator	Sec Lead (R. Tan)
Attendees	J. Liu, Casey Morrison, 2 ZTNA engineers, Cloudflare CSM (R. Mendoza), 1 helpdesk rep, GRC

1. Incident timeline

T-0	18:14 PT	Helpdesk receives first user report ('can't log into Confluence')
T+5m	18:19 PT	Helpdesk Tier 1 escalates to Tier 2 (10 reports queued)
T+12m	18:26 PT	Tier 2 confirms ZTNA platform

T-0	18:14 PT	Helpdesk receives first user report ('can't log into Confluence')
		issue; engages on-call ZTNA engineer
T+22m	18:36 PT	Engineer confirms Cloudflare Access experiencing authentication failures
T+30m	18:44 PT	Cloudflare CSM engaged; confirmed PoP-routing issue
T+45m	18:59 PT	Cloudflare deploys hotfix; partial recovery
T+90m	19:44 PT	Recovery confirmed; helpdesk monitoring
T+6h	00:14 PT	Final monitoring complete; incident closed

Total duration: 6 hours (5h 30m at degraded; 30 min full recovery)

Affected users: ~200 (Wave 2 pilot population only; production users on legacy stack unaffected)

Apps affected: 14 of 28 (those with West Coast user concentration)

2. What happened (root cause)

Cloudflare's PoP routing for the West Coast region was directing user authentication requests through a degraded edge node. The edge node had been flagged in Cloudflare's internal monitoring 30 minutes prior but had not been failed-out per their protocol. When user requests arrived, ~30% timed out at authentication, and the platform's failover logic incorrectly returned 'authentication denied' instead of routing to a healthy PoP.

Bristol's posture: We had not validated PoP routing for West Coast users in pre-UAT testing. We had assumed Cloudflare's AnyCast would handle geographic routing automatically. The assumption was unsafe.

Cloudflare's posture: Their PoP-failover logic had an edge case that converted a degraded-but-routable signal into a deny response. Their monitoring was correct; their automated remediation was incomplete.

3. Root cause analysis

Five Whys:

Q1: Why were users locked out?

A: Cloudflare authentication denied requests routed through degraded PoP

Q2: Why was the PoP degraded?

A: PoP had a software fault; Cloudflare monitoring detected but didn't auto-fail it out

Q3: Why didn't auto-failover work?

A: Edge case in Cloudflare's failover logic — degraded-but-not-down PoP wasn't fully removed from rotation

Q4: Why did Bristol not detect this earlier?

A: Bristol's UAT didn't include West Coast PoP routing validation under load

Q5: Why didn't UAT include PoP routing validation?

A: We assumed AnyCast would handle geographic routing without explicit testing

Root cause (deepest level we control): Inadequate UAT test design — we tested functionality but not infrastructure behavior under failure modes.

Contributing causes:

- Cloudflare's monitoring/failover gap (vendor responsibility)
- Helpdesk Splunk RBAC not yet provisioned (couldn't see authentication audit logs in real-time)

4. What worked

- Helpdesk Tier 1 escalated quickly (12 minutes to Tier 2)
- Cloudflare CSM engaged within 30 minutes (had been built into SOW response time)
- Rollback procedure was documented and validated (per L-005); we didn't need to use it but we knew we could
- Sponsor (Sandra Park) was informed within 90 minutes; communication to broader stakeholders was managed

5. What didn't work

- Bristol's UAT did not include PoP routing validation — gap that should have been visible during test design
- Helpdesk's Splunk RBAC was not yet provisioned (D-1 from Wave 1 retrospective); they were debugging blind
- Initial communication was reactive — first user reports were 18:14, but Bristol didn't have a single source of truth for 'is the platform OK?' before users started reporting
- Post-incident, the immediate question 'Should we delay Wave 2?' had no defined process — sponsor decision (DC-027) was 5 business days post-incident

6. Actions

A-PIR-001 (Bristol): Add PoP routing validation to UAT test plan template — owner: ZTNA engineer + QA Lead, due 2026-12-15

A-PIR-002 (Bristol): Provision Splunk RBAC at training time, not at go-live — owner: GRC, applied retroactively

A-PIR-003 (Cloudflare): Internal engineering ticket on PoP failover edge case — owner: Cloudflare engineering, deadline TBD

A-PIR-004 (Bristol): Define platform-status monitoring (proactive, not reactive) — owner: ZTNA engineer + Sec Lead, due 2026-12-30

A-PIR-005 (Bristol): Define 'Wave delay' decision-rights process for sponsor approval within 24 hours — owner: TPM, due 2026-12-15

A-PIR-006 (Bristol): Add PIR template (this template) to standard incident response — owner: Sec Lead, applied immediately

7. Lessons learned (cross-program)

L-PIR-001: When using a third-party platform, test the platform's failure modes, not just its happy path

L-PIR-002: Helpdesk operational readiness depends on tools access, not just training

L-PIR-003: Post-incident decision-rights need to be defined in advance — sponsor approval delays compound the cost

L-PIR-004: Vendor SOW response times should include incident-response SLA, not just operational support

8. Stakeholder communication

Internal: Casey Morrison communicated to Sandra Park within 90 minutes; full sponsor + steering communication day 2

External: Cloudflare CSM communicated to their engineering and reported back to Bristol within 24 hours

Customers: No external customer impact (this was internal pilot only)

Audit: KPMG informed via standing process at next quarterly check

9. Risk register update

R-NEW-027: ZTNA platform failure mode (Medium/Medium) — added to RAID; mitigation: A-PIR-001 + A-PIR-004 close this risk

10. Closure

PIR closed: 2025-11-23 (5 business days post-incident)

Closure approved by: Sandra Park (sponsor), Mark Williams (CTO), Sec Lead

Follow-up:

- A-PIR-001 through A-PIR-006: tracked in Post-Incident Action Tracker (companion artifact)
- L-PIR-001 through L-PIR-004: transferred to Lessons Learned register
- R-NEW-027: now tracked in RAID Log

What this PIR did right

1. Held within 5 business days — close enough to remember, distant enough for perspective
2. Blameless format — focused on systems and decisions, not individual people
3. Root cause analysis went 5 levels deep — caught the deepest level WE could control (UAT design)
4. Actions are owned and time-bound — A-PIR-001 has a name and a date
5. Cross-program lessons captured — applies to future ZTNA waves AND future vendor selections
6. Vendor responsibility documented separately — A-PIR-003 is Cloudflare's accountability, not Bristol's

HOW TO READ THIS EXAMPLE

Why this example works: This post-incident review pack is exemplary because it uses a rigorous timeline reconstruction to separate contributing factors from root causes, and it names systemic causes (monitoring gap, change control bypass) rather than attributing the outage to individual error. A reader should notice that the pack explicitly states what did not fail, which is as analytically important as what did.

Key judgment calls:

- Using a five-why analysis anchored to the timeline rather than jumping to root cause from symptom, which prevents premature closure on a superficial cause.
- Distinguishing between immediate remediation (session restored in four hours) and systemic corrective action (monitoring rule added, change gate enforced), and tracking them on separate timelines.
- Inviting the affected business unit into the review rather than keeping it a technical team debrief, so business impact is stated in business terms.

Adapting it to your context:

- Reuse the timeline-reconstruction-first structure for any incident review; the discipline of sequencing facts before analysis is universally applicable.

- Replace Bristol Financial's authentication stack specifics with your own affected systems, but preserve the explicit call-out of what did not fail.
- Calibrate the corrective action timeline to your organization's risk appetite; high-severity systemic gaps should have shorter closure windows than Atlas's 30-day target.

32 — Post-Incident Action Tracker — Project Atlas

The Action Tracker is the running register of follow-ups from all Post-Incident Reviews. It outlives any single incident — it's where actions go to ensure they actually get done. Lives in the workbook 'Action Tracker' tab. Excerpt as of week 22 (mid-July 2026).

Why a separate tracker (not just RAID): RAID Log captures program-level risks/issues. The Action Tracker captures specific commitments made in PIRs that need to land, often crossing component boundaries. Mixing them in RAID would let action items drift into 'risks' and never close.

Document control

Title	Project Atlas — Post-Incident Action Tracker
Owner	Sec Lead (R. Tan)
Cadence	Weekly review at component standups; monthly review at steering
Status options	Open / In Progress / Done / Verified / Dropped

Active tracker (selected items)

Action ID	From PIR	Description	Owner	Due	Status	Verification
A-PIR-001	INC-2026-031	Add PoP routing validation to UAT test plan template Z	TNA Eng + QA 2	2026-12-15 D	one UA	T plan v2.0 includes routing tests; Sec Lead verified 2026-04-22
A-PIR-002	INC-2026-031	Provision Splunk RBAC at training time, not go-live G	RC 2	2026-12-30 V	erified Ap	plied retroactively to all training cohorts; helpdesk confirmed access; verified 2026-01-12
A-PIR-003	INC-2026-031	Cloudflare engineering on PoP failover edge case	Cloudflare	2026-04-30	Done C	loudflare deployed fix in v2024.11.3 release; confirmed via vendor PIR
A-PIR-004	INC-2026-031	Define platform-	ZTNA Eng + Sec	2026-12-30	Done C	loudflare Status API +

Action ID	From PIR	Description	Owner	Due	Status	Verification
		status monitoring (proactive)				Splunk dashboard live; verified 2026-02-08
A-PIR-005	INC-2026-031	Define 'Wave delay' decision-rights process within 24h	TPM	2026-12-15	Done P	rocess documented in Governance v1.2; tested at DC-027; verified 2026-06-22
A-PIR-006	INC-2026-031	Add PIR template to standard incident response	Sec Lead	2026-11-30	Done T	emplate approved; verified 2025-12-05
A-PIR-007	INC-2026-058	Helpdesk surge-staffing protocol for Wave 2 cutover O	CM Lead 2	026-06-15 V	erified +5	Tier 1 staff for T+1 to T+30 (DC-029); in use 2026-06-22
A-PIR-008	INC-2026-058	Pre-cutover communication audit for Field Engineering	OCM Lead	2026-06-15	Verified 8	-week listening cadence applied; sentiment improving (DC-022)
A-PIR-009	INC-2026-058	App owner connector deployment process audit	PAM Lead	2026-07-30	In Progress	3 of 14 app owners refusing; sponsor escalation queued (I-022)
A-PIR-010	INC-2026-076	Production failover validation BEFORE go-live	GRC	2026-07-15	Verified	Validated in 2026-Q2; standing process now
A-PIR-011	INC-2026-076	Add 30-day stabilization window to all wave plans	TPM	2026-07-30	Done S	tandard practice; documented in Schedule template
A-PIR-012	INC-2026-076	Helpdesk Tier 2	OCM Lead	2026-08-15	In Progress P	lan defined; staffing

Action ID	From PIR	Description	Owner	Due	Status	Verification
		surge-staffing 14 days post-cutover				being arranged for ZTNA Wave 2

Vendor-side action tracking

Action ID	Vendor	Description	Status	Verification
A-VENDOR-001	Cloudflare	PoP failover edge case fix D	one V	endor PIR confirmed; Bristol re-tested 2026-02-15
A-VENDOR-002	Cloudflare	Quarterly platform-status review with CSM S	tanding Q	2 2026 review complete; Q3 in progress
A-VENDOR-003	BeyondTrust	Provide single-engagement-manager commitment	In Progress	Risha Cho confirmed; 30-day notice provision in SOW
A-VENDOR-004	Yubico (FIDO2)	Dual-source supply commitment for next contract O	pen I	n negotiation; sponsor escalation queued

Aggregate metrics

Total actions opened to date: 47

Total actions closed: 32

Actions verified (closed AND verified by independent party): 28

Actions in progress: 11

Actions blocked: 4 (including A-VENDOR-004 supply chain)

Closure rate per quarter:

Q1 2026: 8 of 8 opened (100%)

Q2 2026: 14 of 16 opened (88%)

Q3 2026: 10 of 12 opened (83%; 2 deferred to Q4)

Q4 2026 (in progress): 11 in flight

Actions by category:

- UAT/Pre-deployment validation: 8 (most learned from)
- Operational readiness (helpdesk, runbooks, training): 12
- Process gaps (decision rights, escalation): 5
- Vendor commitments: 6
- Architecture/Engineering: 9
- Communication / OCM: 7

Top 3 patterns in actions

P-1 (UAT/Pre-deployment): 8 actions cluster around 'we didn't validate X before going live.' Pattern adopted: UAT test plan template now requires explicit validation of failure modes, integration boundaries, and platform routing.

P-2 (Helpdesk operational readiness): 4 actions connect to the same root cause — helpdesk training without operational tools access. Pattern adopted: any helpdesk training cohort must have tools access provisioned at training time, verified via cohort enrollment process.

P-3 (Vendor accountability): 4 vendor-side actions show that vendor incidents have vendor accountability separate from Bristol's. Pattern adopted: every PIR involving a vendor produces both Bristol-side actions AND vendor-side actions tracked separately.

Cross-references

- A-PIR-001 → applied at INC-2026-076 (later incident); validation prevented similar PoP issue
- A-PIR-005 → applied at DC-027 (ZTNA Wave 2 RCA decision); 24-hour decision now standard
- L-005 (Lessons Learned) was a candidate Action; it was ratified after A-PIR-001 was Verified

Cadence and ownership

Weekly: Sec Lead reviews open + in-progress actions at Tuesday standup with action owners

Monthly: Steering reviews aggregate metrics + any actions stuck >30 days past due

Quarterly: PMO reviews patterns; lessons informing future PIR templates

Annual: Full Action Tracker archived; actions transferred to PMO permanent record

What this Action Tracker does that RAID doesn't

1. Tracks specific commitments made in PIRs — RAID is for risks, not commitments
2. Verification step (separate from 'Done') — Sec Lead independently confirms before closing
3. Vendor-side actions tracked separately — accountability is clear about who owns what
4. Pattern analysis across actions — surfaces systemic issues that single PIRs miss
5. Outlives the program — actions adopted as standing practice carry forward

HOW TO READ THIS EXAMPLE

Why this example works: This action tracker is exemplary because it closes the loop between the post-incident review and verifiable remediation: each action has a stated root-cause linkage, an acceptance criterion (not just a due date), and a verification method so the reviewer can confirm closure without relying on the assignee's self-attestation. A reader should notice that actions are binned by risk tier so the SteerCo can see the highest-exposure gaps at a glance.

Key judgment calls:

- Requiring an acceptance criterion for each action rather than a completion checkbox, which distinguishes genuine remediation from superficial compliance.
- Linking each action back to the specific finding in the post-incident review, so the tracker cannot drift from the original analysis over time.
- Escalating overdue high-tier actions to the program sponsor automatically at the weekly review rather than waiting for a separate escalation decision.

Adapting it to your context:

- Reuse the root-cause linkage and acceptance-criterion columns for any post-incident or audit-finding tracker.
- Replace the three-tier risk classification with your organization's standard severity taxonomy if one exists, but keep the tiered escalation cadence.

- If your governance cadence is biweekly rather than weekly, shorten the overdue trigger window proportionally so the escalation mechanism remains responsive.

33 — Recovery Plan — Project Atlas (45-day reset, week 13)

This is the recovery plan Casey Morrison wrote in their first 45 days on Project Atlas. The original program TPM left at the end of week 12 (April 2026) for personal reasons. The program was 13 weeks in, ZTNA Wave 1 was complete but Wave 2 was paused, MFA Wave 2 was at risk, PAM was still in Plan phase, and the program had not had a Steering Committee meeting in 8 weeks. Sandra Park (CISO sponsor) brought Casey in week 13 with a 45-day window to deliver a credible reset.

Document control

Title	Project Atlas — 45-Day Recovery Plan
Version	v1.0 (approved by sponsor end of Day 30)
Date	2026-05-15 (45-day window: Apr 6 – May 20)
Author	Casey Morrison (TPM)
Approver	Sandra Park (CISO sponsor)
Cadence	Recovery Plan reviewed at Day 30; sustained cadence after Day 45

The starting situation (week 12, before Casey)

What Casey inherited at week 13:

- 5 component initiatives, 3 At-Risk or Off-Track (ZTNA paused, MFA Wave 2 slipping on FIDO2 supply, Access Review in Initiate with no firm RFP timeline)
- Last Steering Committee was 8 weeks prior; no governance pack since
- Status Reports tab in workbook had not been updated in 5 weeks
- RAID Log had 18 entries, 9 of them stale (no owner update in 30+ days)
- Decisions & Changes Log had DC-001 through DC-018; 11 of those entries had no rationale captured
- One Off-Track component (MFA) but the program-level rollup was still labeled On-Track in the most recent update
- Sandra Park (CISO) had not had a 1:1 on the program in 4 weeks
- Component PMs (M. Ortiz, J. Liu, K. Reddy, S. Chen, P. Nguyen) had been operating without a coordinator
- Confidence with steering and component sponsors was low but not lost
- KPMG (external auditor) had not been briefed on program status since Q1

Casey's commitment to Sandra: a credible recovery plan delivered by Day 30, with the first 15 days reserved for listening and assessment before any commitments were made. Sandra agreed.

Phase 1 — Listen & Document (Days 1–10)

The discipline of this phase is restraint. Casey made no commitments to the program team, the steering committee, or the sponsor about what the recovery would look like. The goal was understanding what was actually happening, not signaling action.

Days 1–4: Document review

Casey reviewed the full document inventory in chronological order:

- Charter (Dec 2025) and all amendments through DC-007 (mainframe scope removal)
- All 5 component charters

- Templates Pack 1-13 to ground in toolkit standards
- Workbook tabs: Cover, Charter, Stakeholders, RACI, RAID, Schedule, Resources, Budget, Decisions & Changes, Status Reports, UAT Log, Lessons Learned
- The 4 most recent Steering Committee packs (last one 8 weeks prior)
- 31 Post-Incident Review Pack from the 11/18 incident (predated Atlas execute, but referenced as foundational)
- Vendor SOWs: Okta, Cloudflare, BeyondTrust, Yubico, SailPoint
- KPMG Q1 audit briefing materials

Output: Document inventory. Initial observations and flags (not yet shared).

Days 5–7: Internal team discovery (1:1s)

Casey scheduled 30–45 minute 1:1s with each component PM and key team members. The goal was understanding, not assessment. Each conversation followed the same structure: tell me about your component, what's working, what's slowing you down, what would help most.

1:1s completed in this window:

- M. Ortiz (IDP Migration component lead)
- J. Liu (ZTNA Rollout component lead)
- K. Reddy (PAM component lead)
- S. Chen (MFA Hardening component lead)
- P. Nguyen (Access Review Automation component lead)
- R. Patel (OCM Lead, shared with Cloud Migration program)
- T. Brooks (IT Service Manager / Helpdesk champion)
- The departing TPM (handoff conversation; took the call as a peer, not as a successor)

What surfaced:

- Component PMs had stopped escalating to program because they didn't trust escalations would land
- Cross-component dependencies (D-007: Access Review depends on PAM; D-018: ZTNA Wave 3 depends on PAM go-live) had not been reviewed in 6 weeks
- The MFA Wave 2 FIDO2 supply chain risk (R-016) was visible to S. Chen 4 weeks before it surfaced in any status report
- Helpdesk had been documenting Wave 1 patterns that had not made it into the Lessons Learned register
- Multiple component PMs had open decisions waiting on sponsor input that had been queued without clear ask

Output: Internal team map with gaps and blockers. Not shared yet.

Days 8–10: Stakeholder discovery

Casey met with the broader stakeholder set — but deliberately did NOT meet with Sandra Park yet. The principle: walk into the sponsor meeting (Day 19–20) with a clear assessment, not with an exploratory check-in.

Stakeholders met in this window:

- Linda Walsh (CIO) — 1:1; understood her view of the program, her concerns, her availability
- Mark Williams (CTO) — 1:1; technical posture review, his read on the engineering org's relationship with the program
- Robert Stein (CRO) — 30 min; understood SOC 2 audit window pressure from his angle
- Martin Chen (PMO Director) — 1:1; PMO standards alignment, what the PMO needed from this recovery

- Sophie Karim (GRC / Audit Lead) — 30 min; understood KPMG's posture, audit-evidence gaps
- Diane Petrov (GC / Privacy) — 30 min; legal exposure points

Output: Client relationship assessment. Internal Current State Brief (delivered to PMO Director only at end of Day 10, not yet to sponsor).

Phase 2 — Assess & Present (Days 11–20)

The transition from Phase 1 to Phase 2 is the moment the TPM moves from input to synthesis. Casey blocked Days 11–15 specifically for analysis with no external meetings. The deliverable from this phase is the honest assessment Sandra gets in the Day 19–20 meeting.

Days 11–15: Technical deep dive

Casey mapped Atlas component-by-component against the SOW:

Component	SOW Status	Actual Status	Gap
IDP Migration	On-Track	65% (on track)	None — the only component fully aligned
ZTNA Rollout	On-Track	Paused at Wave 2	Wave 1 closed; Wave 2 cutover pending RCA from 11/18 incident; Wave 3 unscoped
PAM	Plan	Plan (20%)	BeyondTrust SOW signed but no architecture sign-off in 4 weeks
MFA Hardening	On-Track	Off-Track	FIDO2 supply chain (R-016) — buffer tokens not yet ordered
Access Review Automation	Plan	Initiate (10%)	RFP issued but vendor evaluation behind schedule

Specific things missing from the workbook that should have been there:

- No Decisions & Changes entries for the 11/18 incident response (DC-027 was the entry Casey would later create)
- No Risk entry for the FIDO2 supply chain situation at the program level (R-016 was Casey's later filing)
- No cross-component dependency review since week 7
- No Steering pack since week 5

Output: Technical status matrix. Component-level recovery candidates per workstream.

Days 16–18: Gap analysis & risk register reset

Casey did three things:

- Built a SOW-vs-reality matrix (every charter deliverable mapped against current state, with gap quantified)
- Reset the RAID Log: every stale entry either updated, closed, or escalated
- Built a prioritized risk register for the recovery: the top 8 risks that needed sponsor attention in the Day 19–20 meeting

The 8 risks Casey surfaced for Sandra:

- R-016 (existing): FIDO2 supply chain — High/High. Mitigation in flight (buffer tokens; required \$80K from contingency)
- R-021 (existing): ZTNA Wave 2 user-population variance — Medium/Medium. Capacity revised
- R-024 (new): Cross-component dependency drift — Medium/High. D-007 and D-018 had not been reviewed in 6 weeks
- R-025 (new): SOC 2 audit window readiness — Medium/High. KPMG had not been briefed in a quarter
- R-026 (new): Steering Committee dormancy — Medium/Medium. 8 weeks since last meeting; sponsor confidence at risk
- R-027 (new): MFA Wave 2 slip cascade — High/High. M-008 slip would consume all critical-path float through SOC 2
- R-028 (new): Access Review vendor selection delay — Low/Medium. RFP behind, but float exists
- R-029 (new): Operating Model handoff plan — Low/High. Cloud Security Operations function plan was 6 months out, no detailed transition

Output: Gap analysis. Prioritized risk register. Recovery candidates ranked.

Days 19–20: CISO meeting

Casey delivered the honest current state assessment in a 90-minute meeting with Sandra. The structure:

- 0–10 min: where the program actually is (component-by-component, with the gap matrix)
- 10–25 min: top 8 risks (the new register, with mitigation paths)
- 25–45 min: what Casey observed in 1:1s — what's working, what's not (system-focused, not people-focused)
- 45–60 min: the recovery plan framework Casey was proposing (high-level, not yet committed)
- 60–80 min: Sandra's questions and pushback
- 80–90 min: what Casey would deliver by Day 30 (the recovery plan document); cadence agreement

Casey set conservative expectations: the recovery plan itself would land Day 30, not earlier. Casey explicitly did NOT promise specific dates for Wave 2 cutover or MFA Wave 2 completion in this meeting. The ask was: give me 10 more days to build the plan, and I'll bring you a credible commitment with conservative milestones and the asks needed to hit them.

Sandra agreed. Cadence established: weekly 1:1 (every Tuesday, 30 min); biweekly steering communication via written status; monthly Steering Committee restored, first one at Day 35.

Output: Current State Assessment delivered to CISO. Communication cadence reestablished. Sponsor confidence reset.

Phase 3 — Build & Execute (Days 21–30)

This is the phase where most recovery plans are made or lost. The temptation is to over-engineer the structure. Casey set a hard rule: build the minimum operating model needed for accountability and visibility, then automate where possible.

Days 21–25: Recovery delivery plan & operating model

Casey worked with the 5 component PMs to build the recovery plan together. The principle: component PMs had to own the new dates or they wouldn't defend them. Casey did not write dates and ask PMs to confirm; Casey held workshops where PMs proposed achievable dates with explicit buffer, and Casey pressure-tested the buffer.

The recovery plan that emerged:

- IDP Migration: held to original Q3 2026 date (no slip needed)
- ZTNA Rollout: Wave 2 cutover moved from June 22 to July 6 (DC-027 — 14-day extension); Wave 3 scope confirmed for Q4 2026
- PAM: design baseline approved by June 29 (M-010 held); 50% deployed by Q1 2027 maintained
- MFA Hardening: privileged FIDO2 by July 1 (M-008 +14 days, hybrid platform-authenticator approach approved per DC-005); workforce-wide by Q1 2027 (was Q4 2026; +90 days slip with sponsor approval)
- Access Review Automation: RFP closes May 15 (week 6 of recovery); vendor selection by June 8; Phase 1 rebaselined per DC-032

RACI rebuilt. Governance cadence locked:

- Daily standup (component PMs + program PM, 15 min, 9:30 AM)
- Weekly delivery review (Tuesday 11 AM, 60 min)
- Biweekly written status to sponsor (Friday 5 PM)
- Monthly Steering Committee (4th Tuesday, 60 min)
- Quarterly Audit Committee briefing (Sandra delivers, Casey prepares)

Escalation path: time-bound, P1 (within 1 hour to TPM, within 4 to sponsor); P2 (within 1 business day to TPM); P3 (next weekly review).

Output: Recovery Delivery Plan. RACI v2. Governance Playbook.

Days 26–28: Systems, comms & training

Casey reset the operational infrastructure:

- Workbook reorganized; all stale entries closed or updated
- RELATED_LINKS workbook view rebuilt (cross-component dependencies surfaced as a daily-visible artifact)
- Dashboard built (component status, top 5 risks, this-period decisions, next-period asks — single view)
- Slack channel (#project-atlas-pms) restored with daily standup async updates
- Comms plan rebuilt (per Comms Plan template 6)
- Training roadmap audited; 3 cohorts behind schedule; surge plan defined

What Casey did NOT do in this window: introduce new tooling. The workbook, Slack, Confluence, and Jira that the program was already using were sufficient. Adding a new tool in a 45-day recovery would have created friction that exceeded the value.

Output: Dashboard. Comms plan v2. Training roadmap.

Days 29–30: Quick wins & recovery plan presentation

By Day 29, three quick wins were visible:

- The first daily standup ran on Day 22 and had been running for 8 days (rhythm established)
- DC-027 (ZTNA Wave 2 1-week extension) was logged and ratified by sponsor
- DC-028 (\$80K contingency draw for FIDO2 buffer tokens) was logged and approved
- The first written biweekly status to Sandra had landed on Day 26

On Day 30, Casey presented the full Recovery Plan to Sandra in a 90-minute working session:

- The 45-day plan recap (what Casey did, what surfaced)
- The Recovery Delivery Plan (component-by-component with conservative milestones and explicit buffer)
- The Operating Model (cadence, RACI, escalation, governance)
- The 8 risks and mitigations

- The asks: \$80K contingency confirmed; Steering reactivation; KPMG quarterly briefing reactivation; Q4 cloud security operations standup budget approval (queued for July Steering)
- The trade-offs: workforce-wide MFA pushed from Q4 to Q1 2027; Access Review Phase 1 rebaselined; mainframe out of scope held

Sandra approved the Recovery Plan. The recovery window closed Day 30 with the program back on a credible footing.

Output: Recovery Plan v1.0 approved. Cadence running. First wins delivered.

Day 30+ — Steady state cadence

After Day 30, the program shifted from recovery to sustained execution:

- Biweekly written status to sponsor
- Monthly Steering Committee (first one Day 35)
- Quarterly Audit Committee briefing (sponsor delivers, TPM prepares)
- Component-level standups continued daily
- RAID Log reviewed weekly; stale entries treated as a recovery violation
- Decisions & Changes logged within 24 hours of decision
- Cross-component dependency review at Tuesday Program Board (every other week)

The 45-day window was a discrete event, not a permanent state. Day 46 was a normal program day, run on the cadence the recovery established.

Outcomes (measured at Day 90, 60 days after recovery close)

By Day 90, the following had been delivered:

- All 5 components back on a credible execution path; no At-Risk → Off-Track transitions
- ZTNA Wave 2 cutover complete (per the new July 6 date)
- MFA privileged FIDO2 enrollment at 95% (M-008 met on the recovery date)
- PAM design baseline approved (M-010 met on original date)
- 4 Steering Committee meetings restored; sponsor confidence reset
- \$130K of \$200K contingency drawn (within the planned envelope)
- KPMG briefed and confirmed audit window unchanged
- 8 of the 8 risks Casey surfaced at Day 19 had been moved from Open to Mitigating or Closed

Lessons Learned filed at Day 90

L-027 (Process): The 45-day discipline (Listen-Assess-Build, with Phase 1 reserved for restraint) is the right pattern for recovery. Compressed to 30 days, the Listen phase gets cut and assumptions go untested. Extended to 60 days, sponsor patience runs out.

L-028 (Stakeholder): Not meeting the sponsor in week 1 was the single most important judgment call. The 14-day delay before sponsor meeting let Casey come to that meeting with assessment, not exploration. Sponsors trust assessments. They don't trust exploration from a TPM who is supposed to be running the program.

L-029 (Tooling): Adding new tooling during recovery is a trap. The infrastructure Atlas already had (workbook, Slack, Confluence, Jira) was sufficient. Recovery is about discipline on existing tools, not adoption of new ones.

L-030 (Sponsor cadence): A program with a CISO sponsor that has not had a 1:1 on the program in 4 weeks is a program in a different kind of trouble than the schedule says. The cadence gap was a leading indicator of every other gap.

What this Recovery Plan does that a Status Report doesn't

A Status Report says where the program is. A Recovery Plan says where the program is, why it got here, what changes, and what's needed to make the change hold. The Atlas recovery succeeded because Casey treated the Recovery Plan as a contract — between Casey and Sandra, and between Casey and the component PMs — not as a status update with extra structure.

Related artifacts

- Charter (6): the original commitment Casey was recovering toward
- Decisions & Changes Log (17): DC-027, DC-028, DC-031, DC-032 were the recovery-period decisions
- RAID Log (13): R-016, R-021 (existing); R-024–R-029 (Casey's filings)
- Schedule & Milestone Tracker (14): the rebaselined critical-path view
- Stakeholder Register (8): updated to reflect the cadence reset
- Steering Committee Pack (21): the June 2026 pack was the first one post-recovery
- Lessons Learned (23): L-027 through L-030 captured at Day 90

Field Notes referenced

- FN-R01 (Writing a recovery plan when the project is sideways): the Recovery Plan document itself follows the FN-R01 structure
- FN-R05 (Taking over a strained program: the first 45 days): the discipline behind the Listen-Assess-Build pattern in this example

Keywords: 45-day recovery plan, recovery example, Casey took over, mid-program recovery, listen assess build, taking over Atlas, 45 day reset, recovery plan example, succession recovery

HOW TO READ THIS EXAMPLE

Why this example works: This recovery plan is exemplary because it treats week 13 as a formal reset, not an informal catch-up: it re-baselines schedule and cost from current state, documents what assumptions changed to cause the variance, and defines a 45-day window with specific exit criteria that re-establish confidence before the program continues. A reader should notice that the plan explicitly addresses team morale and stakeholder trust as recovery workstreams alongside technical replanning.

Key judgment calls:

- Re-baselining rather than compressing the remaining schedule, which produces a credible plan rather than one that will slip again within two weeks.
- Requiring SteerCo reapproval of the revised baseline before work resumes, which resets authority and ensures the sponsor is consciously accepting the revised cost and timeline.
- Naming a recovery manager as distinct from the ongoing PM role to signal that the program is under heightened scrutiny and to provide independent oversight.

Adapting it to your context:

- Reuse the assumption-change documentation as the analytical foundation for any recovery plan; stakeholders need to understand why the original plan failed before they can trust the replacement.
- Adapt the 45-day window to the actual complexity of your rework; the principle is a bounded, measurable recovery period, not a specific number of days.
- The stakeholder trust workstream is Atlas-specific in its communications channel choices but the concept of actively managing sponsor confidence during recovery is universally applicable.

35 — Risk Register & Response Plan — ZTNA Rollout (Project Atlas)

Project Context:

Project Atlas, week 9 risk register. Scoring scale 1-5 for both Probability (P) and Impact (I). Top risks flagged for SteerCo: R-01 and R-02. Total exposure trending down from 71 (week 5) to 49 (week 9) as mitigations land.

Risk Register:

ID	Category	Risk Statement	P x I = Score	Owner
R-01	Vendor	BeyondTrust PAM onboarding slips past contracted date, delaying UAT entry	P4 x I4 = 16 (High)	TPM
R-02	Technical	ZTNA policy engine cannot enforce legacy app rules; 12% of users lose access at cutover	P3 x I5 = 15 (High)	Eng Lead
R-03	Organizational	EMEA business unit does not free up UAT testers; sign-off slips	P3 x I3 = 9 (Medium)	OCM Lead
R-04	Schedule	Holiday freeze compresses cutover window	P5 x I2 = 10 (Medium)	-

Response Actions and Residual Risk:

ID	Strategy	Actions	Residual Score	Status
R-01	Mitigate	Weekly vendor checkpoint; contractual milestone with credit; escalation to vendor VP	P2 x I4 = 8	Mitigating
R-02	Mitigate	Legacy app discovery + compatibility test in Wave 0; fallback VPN path retained for 30 days	P2 x I3 = 6	Mitigating
R-03	Mitigate	Sponsor ask for named testers	-	Mitigating
R-04	Accept	5-day schedule reserve held	-	Accepted
— HOW	TO READ TH	IS EXAMPLE —		

Why this example works: This register is actively managed rather than just populated: inherent and residual scores differ because mitigations are documented and tested, exposure is

trended week over week so emerging risks are visible before they become issues, and the top risks tie directly to what the sponsor sees at SteerCo. A reader should notice that each risk has a named response owner who is accountable for the mitigation, not just the PM.

Key judgment calls:

- Keeping a fallback path live for 30 days as a deliberate, costed mitigation rather than removing the option to save money.
- Accepting a low-impact schedule risk with reserve held rather than over-engineering a mitigation that costs more than the exposure.
- Escalating only the risks above the defined threshold to SteerCo, which preserves escalation as a meaningful signal rather than a routine update.

Adapting it to your context:

- Reuse the structure and re-identify content for your program; the inherent-residual-trending structure is applicable to any risk register.
- Recalibrate scoring bands to your organization's risk appetite and the materiality thresholds set by your risk function.
- Set your own escalation threshold explicitly in the risk management plan so preparer judgment does not determine what the sponsor sees.

36 — Quality Management Plan — ZTNA Wave 1 (Project Atlas)

Quality Objectives:

- Zero S1 defects at go-live
- <=3 S2 defects open with approved workarounds
- 100% of P1 requirements traced to a passed test

Definition of Done:

Policy rule: peer-reviewed, deployed to staging, automated policy test green, security-reviewed, documented in runbook.

Acceptance Criteria Sample:

BRD-014: 'A user in the Finance group on a managed device reaches the payroll app within 2s; an unmanaged device is blocked with a branded message.'

UAT Entry Exit Thresholds:

- 0 open S1 defects
- <=2 S2 defects with approved workarounds

Quality Metrics at Cutover:

Metric	Result
Requirement-to-test coverage (P1)	100%
Requirement-to-test coverage (P2)	96%
Escaped defects in pilot	2 (both S3)
Rework rate	8%
First-pass UAT yield	91%

Lessons Logged:

Legacy-app rules need a dedicated DoD checklist; improvement fed into the Wave 2 plan.

HOW TO READ THIS EXAMPLE

Why this example works: This quality management plan is exemplary because it defines quality in measurable terms before delivery begins, specifies the inspection points where quality is verified rather than assumed, and names the defect classification that determines whether a go or no-go decision is made at cutover. A reader should notice that quality criteria are stated from the user's perspective (authentication success rate, false-positive rate) not the technical team's perspective (policies deployed, rules configured).

Key judgment calls:

- Defining defect severity tiers and their cutover gate implications before testing begins, which removes negotiation pressure at the moment of go/no-go decision.
- Assigning quality assurance responsibility to a role independent of the delivery lead, which preserves objectivity when schedule pressure builds.
- Including a test traceability matrix that links each test case back to a requirements statement, so coverage gaps are visible before testing ends.

Adapting it to your context:

- Reuse the user-perspective quality criteria structure and the defect-severity-to-gate-decision mapping for any technical implementation.
- Replace Atlas's ZTNA-specific acceptance thresholds (authentication success rate, latency) with the metrics that define acceptable performance for your system.
- The independent QA role is critical at high-stakes cutover points; even if a formal QA resource is not available, designate a named reviewer who is not on the delivery team.

37 — Requirements Traceability Matrix (RTM) — ZTNA Rollout (Project Atlas)

Project Context:

RTM excerpt for ZTNA Wave 1. This matrix served as the evidence pack for UAT exit sign-off. Coverage: 47 requirements total; Must 100% traced and passing; Should 92% passing; 1 orphan requirement (BRD-031, intentional deferral).

Traceability Register - Part 1:

ID (Priority)	Requirement	Design Reference	Build Ref
BRD-014 (Must)	Conditional access by device posture	Policy Engine spec sec 4.2	PE-217
BRD-022 (Should)	Self-service access request	MFA Portal PRD	PORTAL-88
BRD-031 (Could)	Custom block-page branding	Deferred to Wave 2 via CR-09	-

Traceability Register - Part 2:

ID (Priority)	Test Refs	Test Result	Acceptance Status	Owner
BRD-014 (Must)	TC-031, TC-032	Pass	Accepted - evidence UAT-Log row 31	Head of IdAM
BRD-022 (Should)	TC-050	Fail (S3)	Conditional - workaround approved; linked to CR-07	-

ID (Priority)	Test Refs	Test Result	Acceptance Status	Owner
BRD-031 (Could)	None (orphan-by-design)	-	Deferred	-

Coverage Summary:

Priority	Traced and Passing	Notes
Must	100%	-
Should	92%	-
Could	0%	BRD-031 intentional orphan; deferred to Wave 2
— HOW TO	READ THIS EXAMPLE —	

Why this example works: This RTM earns its keep by closing the loop from regulatory obligation through design decision to test evidence - each row is a chain of custody, not a checklist tick. Notice how every ZTNA-specific requirement is mapped to a named control, a specific story or work package, and a pass/fail test result, so a compliance auditor and a delivery lead can both interrogate the same artifact. The matrix is usable as a change-impact tool: when a requirement shifts, the column traversal immediately surfaces which design elements and tests need rework.

Key judgment calls:

- Distinguishing between regulatory requirements (NIST, PCI-DSS) and architectural requirements (latency SLA, device-posture enforcement) in separate classification tiers.
- Choosing to trace to user stories rather than tasks, keeping traceability above implementation detail while still linking to delivery work.
- Flagging partial coverage explicitly rather than marking incomplete rows as TBD, forcing an active disposition decision.

Adapting it to your context:

- Reuse the chain-of-custody column structure (source -> requirement -> design artifact -> test case -> result) for any compliance-adjacent program.
- Replace Atlas control references with your own control framework taxonomy.
- Adjust the coverage status categories to match your testing phases and audit gate criteria.

38 — Work Breakdown Structure (WBS) & Estimation Approach — PAM Implementation (Project Atlas)

WBS - PAM Implementation:

WBS ID	Work Package	WP Ref	Owner	PERT Estimate
1.1	Discovery (privileged account inventory)	WP-101	Sec Eng	12d (O8/M12/P20)
1.2	Design (vaulting + session management)	WP-102	Architect	15d
1.3	Build and integrate	WP-103 to WP-105	Eng	28d total

WBS ID	Work Package	WP Ref	Owner	PERT Estimate
1.4	UAT and cutover	WP-106	TPM	10d

100% Rule Check:

Work packages 1.1 through 1.4 sum to the full PAM deliverable; nothing implied-but-unlisted.

Estimation Approach:

- Build packages (WP-103 to WP-105): three-point/PERT due to high uncertainty
- UAT (WP-106): analogous estimating based on ZTNA actuals

Summary and Contingency:

Item	Value
Total expected effort	65 person-days
Spread-based contingency ($\text{sum}((P-O)/6)$)	9 days
Contingency treatment	Held in schedule reserve

Basis of Estimate Notes:

Discovery range (WP-101) is wide because legacy account ownership is unclear; this links to risk R-01.

HOW TO READ THIS EXAMPLE

Why this example works: The WBS does the disciplined work of decomposing PAM implementation to a level where estimates are defensible, not aspirational: each work package has a named owner, a basis of estimate (analogy, parametric, or expert judgment noted explicitly), and a confidence range. The companion estimation approach section is what elevates this beyond a task list - it explains why the numbers are what they are, which is exactly what a sponsor challenges in a review. Structuring the WBS around deliverables rather than activities forces completeness and makes scope gaps visible.

Key judgment calls:

- Decomposing vendor-dependent workstreams (BeyondTrust configuration, connector deployment) separately from internal workstreams so schedule risk can be isolated.
- Holding a 15 percent estimating reserve at the work-package level rather than a single top-line contingency, allowing tighter cost control by workstream.
- Stopping decomposition at the work-package level (40-80 hours) rather than task level to keep the plan manageable without losing accountability.

Adapting it to your context:

- Reuse the deliverable-oriented decomposition logic regardless of technology stack.
- Recalibrate the basis-of-estimate rationale to your team's historical velocity or available analogous projects.
- Adjust reserve percentages to reflect your organization's risk tolerance and the novelty of the implementation.

39 — Cost Management Plan & Earned Value (EVM) Tracker — Project Atlas (week 13)

EVM Snapshot - Project Atlas Week 13:

Budget at Completion (BAC) = \$2.40M

Performance Metrics:

Metric	Value	Threshold	Status
Planned Value (PV)	\$1.10M	-	-
Earned Value (EV)	\$0.95M	-	-
Actual Cost (AC)	\$1.08M	-	-
Cost Variance (CV)	-\$0.13M (over cost)	-	Red
Schedule Variance (SV)	-\$0.15M (behind schedule)	-	Red
CPI	0.88	≥ 0.90	Red
SPI	0.86	≥ 0.90	Red

Forecast:

Metric	Calculation	Value
EAC (Estimate at Completion)	$BAC / CPI = 2.40 / 0.88$	\$2.73M
ETC (Estimate to Complete)	$EAC - AC = 2.73 - 1.08$	\$1.65M
VAC (Variance at Completion)	$BAC - EAC$	-\$0.33M

Root Cause and Corrective Actions:

The legacy-app discovery overrun (risk R-02) drove rework in the build packages.

- Re-sequence Wave 2 to absorb 5 reserve days
- Freeze non-essential scope (CR-09 deferred)
- Bring forecast \$0.33M overrun to SteerCo with two options: (1) reduce Wave 2 scope or (2) request supplemental funding

HOW TO READ THIS EXAMPLE

Why this example works: The EVM tracker at week 13 is exemplary because it pairs the numbers with interpretation: CPI and SPI are not left to speak for themselves but are annotated with root-cause commentary and a reforecast narrative, which is what converts a spreadsheet into a management tool. The cost baseline, actuals, and EV columns allow a reader to distinguish between spending fast (ahead of work) and spending efficiently (ahead of schedule with good value), a distinction that is routinely collapsed in simpler trackers. The EAC reforecast uses a justified method (CPI-adjusted, not revised-plan), making the projection auditable.

Key judgment calls:

- Choosing to re-baseline schedule but not cost at week 13, treating the schedule variance as an execution problem rather than a planning error.
- Surfacing a CPI below 0.9 as a threshold requiring sponsor notification, not just internal awareness.
- Separating capital and operational cost streams in the tracker because their variance implications differ for finance and for the program.

Adapting it to your context:

- Reuse the EAC formula selection logic (CPI-adjusted vs. revised estimate) and document the rationale in your own plan.
- Adjust variance thresholds for escalation to match your governance framework.

- Separate cost categories to reflect your organization's capitalization policy and budget structure.

40 — Business Case & Cost-Benefit Analysis — Cloud Security Program (Bristol Financial)

Problem Statement:

14 legacy access paths, 3 audit findings, and rising breach exposure. Do-nothing risks a regulatory finding estimated at \$4-6M.

Options Considered:

Option	Description	One-Time Cost	Recommendation
A	Do nothing	-	Not recommended
B	VPN refresh only	\$1.1M (partial)	Not recommended
C	ZTNA + PAM modernization	\$2.4M	Recommended

Option C Costs (3-Year):

Cost Type	Amount
One-time implementation	\$2.4M
Annual run-rate	\$0.35M/yr

Option C Benefits:

Benefit	Value	Benefit Owner
Avoided breach/audit exposure (risk-adjusted)	\$4.5M	CISO
Help-desk access-ticket reduction	\$0.6M/yr	Head of IT Ops
Legacy VPN decommission savings	\$0.25M/yr	Head of IT Ops

Financial Summary (10% Discount Rate):

Metric	Value
NPV	+\$3.1M
Payback period	19 months
3-year ROI	138%
Worst-case NPV (benefits at 60%)	+\$0.8M

Recommendation:

Approve Option C. Benefit owners: CISO (risk avoidance), Head of IT Ops (help-desk savings and VPN decommission). These benefit lines became the baseline tracked in the Benefits Realization artifact.

HOW TO READ THIS EXAMPLE

Why this example works: The business case earns credibility by quantifying costs and benefits using the same discount rate and horizon, and by stress-testing the NPV against pessimistic assumptions rather than presenting only the base case - a discipline that signals analytical honesty to an investment committee. The cost-benefit analysis distinguishes hard savings (license consolidation, breach cost avoidance) from soft benefits (audit efficiency, staff time) and applies a realization discount to the soft figures, which is exactly the kind of intellectual rigor that survives CFO scrutiny. The sensitivity table showing which input variable breaks the IRR is the artifact that makes this case defensible under challenge.

Key judgment calls:

- Selecting a seven-year horizon rather than the standard five because the cloud security platform has a longer amortization cycle than a typical project.
- Discounting breach-avoidance savings using annualized loss expectancy derived from Bristol's own incident history rather than industry benchmarks.
- Presenting a do-nothing cost trajectory alongside the investment case, forcing the committee to evaluate the cost of inaction explicitly.

Adapting it to your context:

- Reuse the benefit categorization (hard savings, risk-adjusted avoidance, soft efficiency) and the realization discount concept for any security investment case.
- Replace breach probability and loss estimates with your organization's own risk quantification or your sector's published loss data.
- Adjust the discount rate and horizon to match your finance team's capital appraisal standards.

41 — Agile & Hybrid Delivery Plan — MFA Self-Service Portal (Project Atlas)

Overview:

Worked hybrid delivery plan for the MFA self-service portal, built agile inside the phase-gated ZTNA program using 2-week sprints surfaced to the program SteerCo at milestone gates.

Definition of Done:

- Code reviewed
- Automated tests green
- Security scan clean
- Deployed to staging
- PO-accepted

Backlog - Top Features by WSJF:

Feature	Description	WSJF Score
F1	Self-service reset	9.2
F2	Device enrollment	8.1
F3	Admin audit view	5.4

Delivery Cadence:

- 6 sprints across a 12-week increment
- PI planning at week 0
- System demo each sprint review

Sprint 4 Metrics:

Metric	Value
Planned velocity	32 pts
Actual velocity	28 pts
Cycle time	4.1d
WIP limit	5
Release burnup status	2 pts behind, recoverable

Governance Bridge:

Increment-1 completion = program milestone M3 = release of budget tranche 2. Velocity and burnup reported in the weekly status report so executives see iterative progress without managing the backlog.

HOW TO READ THIS EXAMPLE

Why this example works: The hybrid plan is exemplary because it makes the rationale for the blend explicit: compliance-gated milestones are managed as waterfall phase gates while feature delivery within each phase uses two-week sprints with a sprint goal, and the plan names which governance mechanism governs which layer. This prevents the common failure mode where agile is bolted onto a fixed-scope program without resolving how sprint outcomes interact with contractual or regulatory checkpoints. The capacity model shows sprint velocity tied to named individuals with availability percentages, making the plan honest about what can actually be delivered.

Key judgment calls:

- Designating the device-posture enforcement release as a waterfall gate because it is a PCI audit prerequisite, not an arbitrary policy choice.
- Running a stabilization sprint after each wave rather than compressing directly into the next sprint cycle, treating integration risk as a first-class planning concern.
- Keeping the product backlog prioritized by security risk reduction value rather than feature request volume, preserving the program's compliance rationale.

Adapting it to your context:

- Reuse the framework of identifying which milestones must be waterfall-gated before applying agile cadences to the work within each phase.
- Replace Atlas sprint velocity numbers with your team's measured or estimated capacity.
- Define your own gate criteria based on your regulatory or contractual obligations rather than importing Atlas's PCI checkpoints.

42 — Vendor & Contract Management Plan — BeyondTrust PAM (Project Atlas)

Contract Summary:

Field	Detail
Contract	SOW-Atlas-PAM
Value	\$480K fixed + T&M cap \$60K
Term	6 months
Renewal notice	30d

SLA Performance:

SLA	Target	Status	Notes
Onboarding milestone	On date	MISSED	9-day delay -> R-01 realized
Config defect turnaround	<= 3 business days	MET	Avg 2.1d
Staffing continuity	Named lead retained	AMBER	Lead changed once, escalated

Month 3 Scorecard:

Dimension	Rating
SLA attainment	80% - AMBER
Quality	GREEN
Responsiveness	GREEN
Overall	AMBER

Actions Taken:

- Invoked milestone-credit clause: \$12K credit applied
- Escalated staffing continuity issue to vendor VP
- Added weekly checkpoint cadence

Scope vs Spend:

78% delivered against 81% spend - tracking acceptably after the milestone credit.

Planned Closeout:

- Final acceptance gated on PAM UAT pass
- Knowledge transfer: 2 runbook sessions
- Performance rating drafted: B+ / re-engage with continuity clause (used in future RFP scoring via vendor master)

HOW TO READ THIS EXAMPLE

Why this example works: The vendor and contract management plan is exemplary because it separates commercial obligations (SLA, payment milestones, change order authority) from delivery governance (joint steering, escalation path, RAID ownership), making it clear who does what when things go wrong as well as when they go right. The risk allocation matrix - showing which risks sit with Bristol, which with BeyondTrust, and which are shared - is the section that most programs neglect and most disputes originate from. Naming the specific contractual clauses that govern remedies rather than paraphrasing them keeps the plan legally precise without being a contract summary.

Key judgment calls:

- Requiring BeyondTrust to hold a dedicated resource buffer for Atlas rather than drawing from a shared pool, converting a relationship risk into a contractual obligation.
- Setting payment milestones tied to acceptance criteria rather than calendar dates, aligning commercial incentives with delivery quality.
- Establishing a joint RAID log with agreed response SLAs rather than two separate logs, reducing the information asymmetry that drives vendor disputes.

Adapting it to your context:

- Reuse the risk allocation matrix structure for any material vendor engagement regardless of technology domain.
- Replace specific BeyondTrust SLA clauses with the actual terms in your contract.
- Adjust the escalation path to reflect your organization's procurement and legal approval hierarchy.

43 — Go-Live Readiness & Cutover Plan — ZTNA Wave 1 Cutover (Project Atlas)

Readiness Assessment (T-2 Days):

Domain	Status
Technical	GREEN
Data	GREEN
Security	GREEN
Support	AMBER - one runbook gap, closed T-1
Training	GREEN
Business sign-off	GREEN

Go/No-Go Decision:

- Meeting held: Friday 16:00
- Decision authority: Head of IdAM
- Decision: GO, conditional on support-runbook gap closure (met at T-1)

Cutover Runbook:

Time	Action	Owner	Validation
06:00	Enable ZTNA policy set	Engineering	Validate dashboard
06:30	Redirect Finance group	Engineering	Smoke test TC-031
07:00	Business validation by pilot users	Business	-
08:00	Point of no return	Architect (rollback owner)	-
09:00	Open to all in-scope users	Engineering	-

Rollback Trigger:

>5% auth failures sustained 15 min -> revert to retained VPN path (kept live 30 days per R-02 mitigation).

Outcome:

1.8% transient failures at 06:35, self-resolved; no rollback triggered. Hypercare handed to the Transition plan at 10:00.

HOW TO READ THIS EXAMPLE

Why this example works: The cutover plan is exemplary because it is organized as a sequenced run-book with explicit go/no-go decision points, rollback triggers, and time-boxed owners for each step - it functions as a live operations document during execution, not just a plan. The dependency mapping between cutover tasks (VPN decommission, ZTNA policy push, DNS change, user notification) prevents the silent assumption that tasks are independent when

in practice they are strictly ordered. The decision tree for rollback, with named conditions and a maximum rollback window, transforms a vague contingency mention into an executable protocol.

Key judgment calls:

- Setting the go/no-go review at T-2 hours rather than at the cutover window start, giving the team time to abort without impacting users if the final health check fails.
- Defining rollback success criteria (user connectivity restored within 30 minutes) rather than just rollback steps, so the team knows when it is safe to stand down.
- Segmenting Wave 1 to a single business unit first rather than a broader rollout, treating the initial cutover as a dress rehearsal with real stakes but bounded blast radius.

Adapting it to your context:

- Reuse the run-book structure (pre-cutover checks, sequenced steps with owner and duration, go/no-go gates, rollback procedure) for any technology cutover.
- Replace Atlas-specific steps (ZTNA policy push, BeyondTrust connector validation) with your own system transition tasks.
- Calibrate the rollback window to your organization's incident response SLA and business impact tolerance.

44 — Transition to Operations & Hypercare Plan — ZTNA Service (Cloud Security Operations)

Handover Scope:

- Policy engine
- Monitoring dashboards
- Runbooks
- Retained-VPN decommission task

Accountable owner: CloudSecOps Manager.

Knowledge Transfer:

- 3 sessions delivered: policy admin, incident handling, legacy-app exceptions
- All sessions signed off
- Known-issues list included 2 open S3 defects with workarounds

Support Model:

Tier	Team	Notes
Tier-1	Service Desk	-
Tier-2	CloudSecOps	Monitoring/alerting ownership transferred
Tier-3	Vendor	P1 SLA: 15-min response

Hypercare Structure:

- Duration: 3-week window
- Week 1: daily 09:30 triage
- Weeks 2-3: 2x per week triage
- Staffing: 1 engineer on rotation + TPM on call

Exit Criteria and Outcome:

Criterion	Target	Result
Open S3 defects	<= 2	Met

Criterion	Target	Result
S1/S2 incidents	Zero	Met
Alerting	Tuned	Met
Ops team autonomy	Running incidents unaided	Met at day 18

Operations acceptance signed day 19, triggering project Close and the closeout report.

HOW TO READ THIS EXAMPLE

Why this example works: The hypercare plan is exemplary because it defines hypercare as a bounded, criteria-based phase rather than an indefinite support arrangement - the exit criteria (ticket volume below threshold, P1 rate zero for five consecutive days, operations team signed off) make it clear when hypercare ends rather than letting it drift. The plan distinguishes what the project team owns during hypercare versus what the operations team owns, preventing the ambiguity that causes both teams to defer to each other on live incidents. The knowledge transfer checklist with acceptance sign-off fields turns a soft dependency into a formal handshake.

Key judgment calls:

- Setting a 30-day hypercare window with a formal extension protocol rather than an open-ended commitment, protecting project team capacity while giving operations a safety net.
- Requiring the operations team to take first call on tickets within 48 hours of service transfer rather than at the end of hypercare, building capability under controlled conditions.
- Treating the runbook review as a hypercare deliverable rather than a pre-go-live deliverable, incorporating lessons from actual go-live behavior.

Adapting it to your context:

- Reuse the exit-criteria structure (quantitative thresholds plus operational sign-off) for any service transition regardless of technology.
- Replace Atlas ticket volume thresholds with your organization's normal operations baseline.
- Adjust hypercare duration to reflect your solution's complexity, user population size, and operations team maturity.

52 — Cross-Team Dependency Management — Project Atlas (Bristol Financial)

Dependency Register:

ID	Provider	Receiver	Deliverable	Needed-By	Promise d	Status	Float	Owner
DEP-001	PAM (T. Adebayo)	ZTNA (M. Vasquez)	Service-account inventory (all non-human accounts in scope)	2026-03-14	2026-03-12	On Track	+2 days	T. Adebayo
DEP-002	IT Operations (B. Holloway)	ZTNA (M. Vasquez)	Firewall rule approvals for ZTNA pilot	2026-03-21	2026-03-28	At Risk	-7 days	TPM (S. Patel)

ID	Provider	Receiver	Deliverable	Needed-By	Promised	Status	Float	Owner
			segment					
DEP-003	Palo Alto Networks reseller	ZTNA (M. Vasquez)	Prisma Access tenant provisioning	2026-04-04	2026-03-31	On Track	+4 days	M. Vasquez
DEP-004	Identity Governance (R. Singh)	PAM (T. Adebayo)	Role taxonomy (RBAC model v1) for privileged-role classification	2026-04-11	2026-04-11	On Track	0 days	R. Singh
DEP-005	Bristol IT Operations (B. Holloway)	Identity Governance (R. Singh)	Entra ID tenant configuration access for governance integration	2026-03-07	2026-03-07	Blocked	0 days	TPM (S. Patel)
DEP-006	SecureProbe Ltd	TPM / Program	Phase 3 pentest scope agreement and NDA	2026-06-01	2026-05-20	On Track	+12 days	TPM (S. Patel)

Dependency Notes:

ID	Notes
DEP-001	First draft reviewed 2026-02-28; final requires sign-off from CISO
DEP-002	Escalated to IT Ops Director 2026-02-20; awaiting revised commitment. Impact: ZTNA pilot delayed by at least 1 week
DEP-003	PO raised 2026-02-10; vendor confirmed delivery date in writing 2026-02-14
DEP-004	Zero float - flagged in weekly review. R. Singh to provide weekly progress update from 2026-03-21
DEP-005	Access request submitted 2026-02-07; blocked on IT security review. Escalation Tier 2 (Deputy CISO) raised 2026-02-28. Target resolution: 2026-03-05
DEP-006	Contact: J. Mercer, jmercer@secureprobeltd.com. Escalation: Account Director if no response within 2 business days

At-Risk Summary (as of 2026-03-01):

ID	Issue	Float	Escalation Status
DEP-002	Firewall rule approvals delayed	-7 days	Escalated to IT Ops Director
DEP-005	Entra ID access blocked on IT security review	0 days	Tier 2 escalation (Deputy CISO) active

Schedule Impact:

Combined impact if DEP-002 and DEP-005 remain unresolved: ZTNA pilot milestone shifts from 2026-04-04 to at earliest 2026-04-18.

Critical Path Note:

The ZTNA pilot milestone (2026-04-04) sits at the confluence of DEP-001, DEP-002, and DEP-003. DEP-002 is the critical-path risk; even a 1-week slip pushes the pilot past the April SteerCo review window.

HOW TO READ THIS EXAMPLE

Why this example works: This example demonstrates the log doing real schedule-protection work: float is calculated and negative on DEP-002, escalation is already active, and the aggregate schedule impact is quantified. DEP-004 at zero float is correctly flagged even though it shows On Track. The dependency map note translates the data into an executive-ready insight for SteerCo.

Key judgment calls:

- Calculating float as a signed number (not just On Track / At Risk) means the team can see DEP-002 is already 7 days in deficit before the blocker is formally acknowledged - this is the early-warning value of the log
- Naming the escalation contact for the penetration testing firm (J. Mercer, email, 2-day SLA) transforms the external dependency from a passive entry to a managed commitment

Adapting it to your context:

- If the program uses a scheduling tool (MS Project, Smartsheet, Jira Align), hyperlink each Dep ID to the corresponding predecessor/successor relationship in the tool rather than maintaining float manually
- For programs with more than 20 dependencies, add a RAG (Red/Amber/Green) column and sort the log by float ascending so the highest-risk items are always at the top
- If your organization has a vendor management function, route external dependency escalations through that function rather than directly from the TPM to the vendor contact

54 — Team Charter & Working Agreements — Project Atlas (sprint 1)

Team Purpose:

Deliver a production-ready Zero Trust Network Access (ZTNA) and Privileged Access Management (PAM) foundation for Bristol Financial by Q4, reducing lateral movement risk by >= 60% against baseline.

Core Hours and Availability:

- Core hours: 09:00-15:30 ET Mon-Thu; Fri 09:00-12:00 ET sync-free focus block.
- Vendor architect (UK) joins 09:00-11:00 ET daily.

- Leave notice: ≥ 3 business days for < 1 week absence; ≥ 10 business days for ≥ 1 week.

Meeting Cadence:

Meeting	Duration	Owner	Frequency	Required Attendees
Daily Stand-up	15 min	TPM	Daily, 09:15 ET	All team
Sprint Planning	2 h	TPM + BA	Bi-weekly Mon	Delivery team
Sprint Review	1 h	TPM	Bi-weekly Fri	Delivery team
Retrospective	45 min	Team rotation	Bi-weekly Fri post-review	Delivery team
Architecture Sync	45 min	Lead Security Engineer	Weekly Wed	Delivery team

Communication Norms:

Channel	Use Case	SLA
Slack #atlas-delivery	Async work items	4 h during core hours
Email	Formal change requests and decisions	24 h
Teams call	Blocker requiring same-day resolution	15 min during core hours
PagerDuty	P1 production incidents only	n/a

Decision Rights:

Decision Type	Driver	Approver	Consulted	Informed
Sprint scope adjustments	BA	TPM	Security Lead	Programme Director
Vendor tool configuration changes	Vendor Architect	Security Engineer Lead	Platform Lead	TPM
Budget reallocation > \$10K	TPM	Programme Director	Sponsor	Team

Definition of Ready:

- User story has written acceptance criteria.
- Security control owner identified and confirmed available.
- Dependencies on other stories flagged and not blocking.
- Story estimated in story points by at least two team members.
- Any required access or environment provisioned or scheduled.
- Regulatory or compliance implication assessed by BA.

Definition of Done:

- All acceptance criteria passed and signed off by BA.
- Code or config peer-reviewed by a second engineer.

- Automated security scan (Prisma Cloud) returns zero critical findings.
- Unit test coverage $\geq 80\%$ on new code.
- Runbook or operational doc updated.
- Deployed to staging and smoke-tested.
- Product owner (CISO delegate) has formally accepted the story in Jira.

Conflict Resolution:

- Step 1: parties attempt direct resolution within 24 h of issue surfacing.
- Step 2: if unresolved, TPM facilitates a 30-min mediation within 48 h.
- Step 3: if still unresolved after 72 h total, TPM escalates to Programme Director with a written summary.
- No conflict is discussed in stand-up; it is taken offline immediately.

Charter Version History:

Charter v1.0 ratified 2026-01-12, all eight team members signed. First amendment window: sprint 2 retrospective 2026-01-30.

HOW TO READ THIS EXAMPLE

Why this example works: This example shows every section populated with Atlas-specific, measurable content rather than generic placeholders. The DoR and DoD are binary checklists tied to the actual tooling (Jira, Prisma Cloud) and the security context (control owner confirmation, zero critical findings). The decision rights DACI directly reflects the vendor-and-client team dynamic unique to Atlas.

Key judgment calls:

- The DoD security scan criterion (zero critical Prisma Cloud findings) is non-negotiable for a ZTNA/PAM programme and deliberately set as a hard gate, not a target.
- Core hours explicitly carve out a Fri AM focus block - this respects the engineering team's feedback that meeting-free time is necessary for complex security configuration work.

Adapting it to your context:

- For a waterfall track, replace sprint ceremonies with phase-gate equivalents and change the DoD to phase exit criteria.
- If the team spans more than three time zones, shorten the core overlap window and move to async-first with documented decision logs rather than synchronous calls.
- In highly regulated environments (e.g., PCI-DSS scope), add a compliance sign-off criterion to the DoD referencing the relevant control framework.

62 — Change Request & Change Control — PAM Phase 2 Cloud (Project Atlas)

CR-014 Overview:

Field	Detail
CR Reference	CR-014
Raised by	M. Singh (Enterprise Architect)
Date raised	7 March 2025
Title	AWS IAM Role Remediation - address role proliferation across 14 AWS accounts discovered during PAM Phase 2 integration
Originating risk	R-014 (program risk R-PRG-001 sub-item)

Business Justification:

Without remediation, CyberArk cannot safely vault AWS IAM roles. 847 roles exist across 14 accounts; 312 are over-permissioned and will trigger false-positive privilege alerts in CyberArk, making BEN-02 (incident reduction target) unachievable for cloud scope. Manual remediation by BAU cloud team (estimated 20 weeks, lower quality) was rejected. Preferred approach: automated remediation script developed by SI (Cognizant) in parallel with PAM integration.

Impact Assessment:

Impact Area	Detail
Schedule	+7 weeks on P-ATL-04 critical path; new ECD 18 Nov 2025 (was 30 Sep 2025)
Cost	+GBP 50K (range GBP 45K-55K); funded from program contingency (draw-down GBP 50K, GBP 130K remaining); revised P-ATL-04 EAC GBP 1.15M
Scope	Addition of AWS IAM Remediation workstream to WBS (new WBS 3.7); no removals
Quality	Remediation script must pass Cognizant code review and Bristol Financial security code review before deployment - new acceptance criterion added
Risk	R-014 partially mitigated; new risk R-ATL-04-031 introduced: script causes unintended IAM permission changes (P=2, I=4, Score=8); mitigation: 2-week non-production dry-run
Resource	2 Cognizant developers for 7 weeks (included in cost estimate); J. Adeyemi +0.2 FTE PM oversight

CCB Decision - 19 March 2025:

Attendees: J. Adeyemi (PM), S. Okonkwo (Program Manager), D. Chen (IT Director), N. Farrell (Finance). Decision: APPROVED WITH CONDITIONS. Rationale: impact within program contingency authority; technical approach validated by M. Singh; no alternative achieves benefit target. Decision authority: S. Okonkwo (within GBP 50K program contingency threshold). Signed: S. Okonkwo 19 March 2025.

- Condition 1: dry-run in non-production environment for minimum 10 business days before production deployment.
- Condition 2: security code review sign-off required from CISO office (L. Pemberton) before production deployment.
- Condition 3: R-ATL-04-031 added to project risk register by 21 March.

Baseline Update Record:

Document	Version	Updated By	Date	Change
P-ATL-04 Project Schedule	v2.0	J. Adeyemi	21 March 2025	ECD updated to 18 Nov 2025; WBS 3.7 added
P-ATL-04 Cost Baseline	v2.0	J. Adeyemi	21 March 2025	EAC GBP 1.15M; contingency draw-down GBP 50K recorded
Project Risk Register	-	J. Adeyemi	21 March 2025	R-ATL-04-031 added
Program Risk	-	S. Okonkwo	22 March 2025	R-PRG-001

Document	Version	Updated By	Date	Change
Register				response note updated
Decisions & Changes Log	DCL-031	J. Adeyemi	21 March 2025	Entry created; stakeholders notified: D. Chen, N. Farrell, Cognizant CSM

Change Request Log (extract as of Apr 2025):

CR	Type	Title	Decision	Date	Cost Delta	Schedule Delta	Baseline Updated
CR-011	Scope	ZPA split-tunnel policy update	APPROVED	10 Jan 2025	+GBP 0K	+0 days	Y
CR-012	Schedule	Hardware delivery delay	APPROVED	15 Jan 2025	+GBP 0K	+4 days	Y
CR-013	Scope	Deferred ZIA integration	DEFERRED to next program initiative	1 Feb 2025	GBP 0K	0 days	-
CR-014	Scope/ Cost/ Schedule	AWS IAM Remediation	APPROVED WITH CONDITIONS	19 March 2025	+GBP 50K	+7 weeks	Y
CR-015	Quality	Additional UAT cycle for IAM script	PENDING CCB (scheduled 2 Apr 2025)	-	-	-	-

Emergency Change Protocol:

Qualifying criteria: (1) active security vulnerability on in-scope systems requiring immediate configuration change; (2) regulatory mandate with <72 hour compliance window; (3) production outage caused by in-scope system.

- Expedited path: PM + Project Sponsor verbal approval within 4 hours; work commences; full CR documentation within 8 hours; CCB ratification within 2 business days.
- Audit trail: verbal approval recorded in PM daily log with timestamp; CR raised within 8 hours; CCB minutes reference emergency ratification.
- Emergency CRs are subject to the same impact assessment and baseline update requirements as standard CRs - the expedited path compresses timing, not rigor.

HOW TO READ THIS EXAMPLE

Why this example works: CR-014 illustrates the full value of the change control process: the discovery of AWS IAM role proliferation was not scope creep by neglect but a legitimate new finding from integration work. The formal CR forced a complete impact assessment that

revealed a 7-week schedule impact the requestor had not initially quantified, and the conditions attached (dry-run, security sign-off) were the controls that reduced the new risk R-ATL-04-031 to an acceptable residual.

Key judgment calls:

- Approving with conditions rather than unconditionally was the right call - the conditions (non-production dry-run and CISO code review) are proportionate to the risk score of R-ATL-04-031 and are verifiable; without them, an approval would transfer unmitigated risk to the production environment.
- Recording the 'do nothing' and 'manual BAU remediation' alternatives in the justification is not bureaucratic filler - it demonstrates that the CCB had a genuine choice and made a reasoned decision, which is critical if the cost overrun is later questioned by Finance or Audit.

Adapting it to your context:

- If your project uses an agile delivery model, change control applies to changes to the approved release scope and budget baseline, not to sprint-level re-prioritization within the agreed sprint budget - make this boundary explicit in the CCB authority table to avoid process friction.
- For projects within a program, calibrate CCB thresholds so that changes above the project PM's authority route to the Program Manager (not directly to a Project Board or Steering Committee) - this preserves the program's ability to manage contingency holistically.
- In regulated environments where external auditors review change records (SOX, PCI), ensure the CR form captures the 'alternatives considered' and 'do nothing' analysis fields - these are frequently requested in audits to demonstrate that changes were not made arbitrarily.

63 — Contract Change Order — ZTNA Pilot (Project Atlas)

Change Order Reference:

Field	Detail
CO Reference	CO-ATLAS-007
Parent SOW	SOW-ATLAS-003
Originating CR	CR-0042 (approved by CCB 2026-05-14)
PO to be amended	PO-2026-0881

Change Description:

- Expand ZTNA pilot seat count from 500 to 650 seats.
- Add privileged-user policy templates for 150 PAM-integrated accounts.
- Remove optional reporting module (de-scoped per mutual agreement, saving 40 vendor days).

Commercial Impact:

Item	Amount
Seat expansion (150 seats x GBP 316.67/seat - Annex B rate card)	+GBP 47,500
De-scope saving (optional reporting module removed)	-GBP 28,000

Item	Amount
Net delta	+GBP 19,500
Revised total contract value	GBP 314,500

Schedule Impact:

Milestone	Original Date	Revised Date	Delta
Pilot go-live	2026-06-30	2026-07-21	+21 calendar days (policy-template development)
M4 - Pilot UAT Complete	2026-07-15	2026-08-05	+21 calendar days
Critical path impact	-	-	21 days; contingency reserve partially consumed

Revised Acceptance Criteria:

- 650-seat ZTNA policies active and verified in SecureEdge portal with zero critical policy errors.
- Privileged-user policy templates pass PAM integration smoke test (pass rate $\geq 98\%$ on 150 accounts).
- Bristol Financial security team sign-off on UAT test results within 5 business days of vendor delivery.

Risk Assessment:

- Risk R-17 (PAM integration complexity) elevated from Medium to High.
- Mitigation: joint SecureEdge/CyberArk integration sprint week of 2026-06-23.
- Dependency: CyberArk PAM workstream (WS-3) must complete vault segmentation by 2026-06-20 per CR-0038.

Justification:

Expansion required to satisfy internal audit finding AF-2026-14 (CISO mandate, deadline 2026-09-01). Option A (proceed without privileged users) leaves audit finding open. Option B (separate contract) duplicates onboarding cost by an estimated GBP 15,000. Option C (this CO) accepted by Commercial Lead and Sponsor.

Authorization:

Party	Signatory	Role / Authority	Sign-by Date
Bristol Financial	Sarah Okonkwo	Commercial Lead (authorized up to GBP 50,000 per authority matrix)	2026-06-10
Bristol Financial	Marcus Chen	CISO Sponsor (co-sign required >GBP 10,000)	2026-06-10
SecureEdge Ltd	James Whitfield	Account Director	2026-06-10

Attachments:

- Revised SOW-ATLAS-003 pages 4-7 (scope section).

- Updated milestone schedule extract.
- SecureEdge rate card Annex B (unchanged, referenced for verification).
- PAM integration test protocol v1.2.

HOW TO READ THIS EXAMPLE

Why this example works: This example demonstrates the CO doing real commercial and technical work: the net price delta is derived from the rate card (not negotiated ad hoc), the schedule impact is tied to named milestones, the revised acceptance criteria are testable, and the authorization block enforces the pre-agreed threshold matrix so the right people sign before any expanded work begins.

Key judgment calls:

- Linking CO-ATLAS-007 to both CR-0042 and audit finding AF-2026-14 creates an unbroken audit trail from business driver to contract amendment - critical for a regulated financial institution
- The de-scope credit (-GBP 28,000) offset against the expansion cost is explicitly shown; burying it in a separate CO or omitting it would overstate contract exposure in the register
- The 21-day schedule slip is quantified and tied to a specific milestone (M4), enabling the project schedule to be updated immediately rather than absorbing the slip as a vague risk

Adapting it to your context:

- If your authority matrix requires three signatories above a GBP 50,000 threshold, add a third signature line and note the applicable policy reference in the authorization section
- For time-and-materials contracts without a fixed rate card, attach a revised resource plan with named roles, bill rates, and estimated hours as an exhibit rather than citing an annex
- If the change is purely a schedule extension with no commercial impact, the commercial impact section should explicitly state 'zero cost impact - schedule only' to prevent ambiguity during invoice reconciliation

64 — Resource Tracking & Time/Cost — Project Atlas (month 4)

Resource Register:

Name	Type	Workstream	Planned FTE / Day Rate	Actual FTE / PO Value	Notes
Sarah Okonkwo	BF Employee	WS-0 PMO	0.5 FTE	0.5 FTE	Start 2026-02-01
Raj Patel	BF Employee	WS-1 ZTNA	1.0 FTE	1.0 FTE	-
Priya Nair	BF Employee	WS-3 PAM	0.8 FTE	1.0 FTE	Over-allocated - flagged
James Whitfield (SecureEdge)	Contractor	WS-1 ZTNA	GBP 950/day	PO-2026-0881 GBP 142,500	-
Anton Kress (CyberArk)	Contractor	WS-3 PAM	GBP 1,100/day	PO-2026-0912 GBP 88,000	-

Week Ending 2026-05-30 Timesheet Summary:

Resource	Hours / Days	Approved By	Notes
Raj Patel	40 hrs	Self (approved)	-
Priya Nair	46 hrs	PM	Over-allocation noted

Resource	Hours / Days	Approved By	Notes
			to PM
James Whitfield	5 days	Raj Patel	-
Anton Kress	5 days	Priya Nair	-
Marcus Chen (CISO Sponsor, WS-0)	4 hrs	Approved	Governance hours

Allocation vs Actuals - Month 4 Cumulative:

Resource	Planned Hours	Actual Hours	Variance	Effective FTE	Note
Priya Nair	128 hrs (0.8 FTE x 160 hrs)	172 hrs	+44 hrs	1.075	ETC revised upward for WS-3
Raj Patel	160 hrs	158 hrs	-2 hrs	~0.99	-
WS-3 PAM team overall	-	-	+12% vs plan	-	ETC revised upward

Cost Actuals - Month 4 to Date:

Category	Plan	Actual	Variance	Notes
Employee labor	GBP 82,000	GBP 87,400	+GBP 5,400	Driven by Priya Nair over-allocation and two unplanned security architecture review sessions billed to WS-1
James Whitfield (SecureEdge contractor)	-	GBP 64,600 (68 days)	-	45.3% of PO-2026-0881 (GBP 142,500) consumed
Anton Kress (CyberArk contractor)	-	GBP 46,200 (42 days)	-	52.5% of PO-2026-0912 (GBP 88,000) consumed - flagged for PO amendment review (>50% with 5 months remaining)

PO and Invoice Reconciliation:

Invoice	Vendor	Amount	Period	Status	Action
INV-SE-2026-041	SecureEdge	GBP 19,000	Weeks 17-18	Matched to approved timesheets	Approved for payment

Invoice	Vendor	Amount	Period	Status	Action
INV-CA-2026-018	CyberArk	GBP 11,000	Week 18	GBP 1,100 discrepancy (10 days invoiced vs. 9 days approved)	Query raised with CyberArk; payment held on disputed GBP 1,100

Burn vs Budget - Month 4 of 9:

Item	Value
Total project budget	GBP 980,000
Spend to date	GBP 312,400 (31.9%)
Planned spend to date (baseline)	GBP 298,000
Cost variance (CV)	-GBP 14,400 (unfavorable, 4.8% over plan)
EAC (recalculated at CPI 0.954)	GBP 1,024,500
VAC	-GBP 44,500 (4.5% over budget at completion)
Contingency reserve drawdown	GBP 14,400 of GBP 49,000 consumed

Earned Value Summary - Month 4:

Metric	Value
AC (Actual Cost)	GBP 312,400
PV (Planned Value)	GBP 298,000
EV (Earned Value)	GBP 287,600 (derived from % complete per WBS)
CPI	0.921
SPI	0.965

Resource Change Log:

Date	Change	Impact	Approved By
2026-04-15	David Tan (BF Network Engineer, WS-1) demobilized - internal redeployment; Raj Patel absorbs 0.2 FTE additional	No cost impact (internal reallocation)	PM
2026-05-01	CyberArk engagement extended by 20 days per CO-ATLAS-006; PO-2026-0912 amended to GBP 110,000	PO value increase	PM

Date	Change	Impact	Approved By
— HOW TO RE	AD THIS EXAMPLE —		

Why this example works: This example shows the tracker performing its core function: it reveals a contractor PO at >50% consumption with most of the project remaining (prompting a PO amendment before the vendor runs out of authorized spend), catches a GBP 1,100 invoice discrepancy via three-way match, quantifies an employee over-allocation that is driving cost variance, and produces the AC figure that feeds a CPI of 0.921 - a signal requiring management attention.

Key judgment calls:

- Anton Kress's PO at 52.5% consumption in month 4 of 9 is the most actionable finding - without a PO amendment the vendor loses authorization to invoice, breaking cash flow and creating a constructive-change risk
- Priya Nair's +44-hour over-allocation is a workload and cost signal, not just an HR issue - the 12% WS-3 hours overrun has already contributed to a CPI below 1.0 and must feed the reforecast
- Reporting CPI = 0.921 alongside the cost variance figure prevents the Steering Committee from treating the GBP 14,400 variance as a one-period anomaly - the trend shows structural cost pressure

Adapting it to your context:

- If Bristol Financial uses an ERP system (SAP, Oracle) as the book of record for labor costs, the employee cost section should be populated from ERP exports, not manually entered; note the ERP reference and reconciliation date
- For programs with a shared resource pool across multiple projects, add a column for 'project code' in the timesheet summary so hours can be split-charged and the program-level Resource Capacity view is accurate
- If contractors are on fixed-price milestones rather than time-and-materials, replace the timesheet rows with milestone payment schedule tracking and remove the day-rate cost calculation

69 — Domain Model — Payments (Bristol Financial)

Context: Bristol Financial is undertaking Project Atlas, a core platform modernization program. The Payments domain is modeled end to end below. It realizes the 'Payment Execution' capability (Level 2) from the Bristol Financial capability map. The model was built in a cross-functional working session with a payments sponsor, payments operations, engineering, architecture, compliance, and a fraud SME. Names, figures, and the reporting threshold are illustrative - align to canonical Project Atlas facts before reuse and localize the rule set with your own compliance team.

Bristol Financial Level-1 capability map:

Capability	What it covers
Customer Management	Know, segment, and serve the customer relationship.
Account Management	Open, maintain, and close deposit and card accounts.
Payments and Transfers	Move money in, out, and between accounts. (worked below)
Lending and Credit	Originate, underwrite, and service loans and lines.
Risk and Compliance	Screen, monitor, and report against regulation.

Capability	What it covers
Treasury and Liquidity	Fund the balance sheet and manage cash positions.
Channels and Servicing	Web, mobile, branch, and support interactions.
Enterprise Services	Finance, people, and shared data platforms.

Level-3 decomposition of Payments and Transfers:

L1	L2	L3 (realized by bounded context)
Payments and Transfers	Payment Execution	Payment Initiation -> Validation -> Settlement -> Reversal
Payments and Transfers	Payment Operations	Reconciliation -> Exception Handling
Payments and Transfers	Payment Intelligence	Fraud Screening (shared with Risk) -> Limit Management

Planning stops at Level 3. Below that is implementation, which is what the domain model handles. The Level 3 label 'Payment Initiation' maps directly to the Payment Initiation bounded context in block 4 - same words, two layers, one bridge between business sponsor and engineer.

Twelve building blocks - Payments worked example:

Block	Payments content
01 Domain Charter	Purpose: Move money between customer accounts and external parties reliably, on time, and within regulatory limits. Capability: Funds transfer and settlement. Owner: Payments Platform team. In scope: initiation, validation, routing across rails, settlement, reconciliation, reversal. Out of scope: opening accounts (Onboarding domain), fraud scoring (Risk domain - consulted via events), interest accrual (Deposits domain).
02 Ubiquitous Language	Payment = an instruction to move funds from one party to another (retire 'transaction' - too broad). Settlement = the point where money has actually moved and is final (retire 'completed'). Rail = the network a payment travels on: ACH, wire, card (retire 'channel'). Beneficiary = the party receiving the funds (retire 'recipient' / 'payee' used interchangeably). Ledger Entry = a single posted debit or credit on an account (retire 'line item').
03 Subdomains	Payment processing and routing: Core - Bristol's differentiator, build and invest. Reconciliation: Supporting - necessary, not a differentiator, build lean. Customer notifications: Supporting - build lean, reuse shared service. Currency conversion: Generic - use a vendor FX rate provider.
04 Bounded Contexts	Payment Initiation: owns Payment, PaymentLeg, validation state; Payments Platform team. Ledger: owns Account balance, LedgerEntry, posting; Core Banking team. Settlement: owns rail connections, clearing, finality; Treasury Engineering team. Note: 'Account' exists in both Ledger (a balance to debit) and Onboarding (a customer relationship) - same word, two valid models, kept separate by context.

Block	Payments content
05 Context Map	See dedicated context map table below.
06 Entities	Payment: identity = PaymentId; attributes = amount, rail, source, beneficiary; lifecycle = Initiated -> Validated -> Settled / Failed -> Reversed. Account: identity = AccountNumber; attributes = owner, type, available balance; lifecycle = Active -> Frozen -> Closed. Ledger Entry: identity = EntryId; attributes = account, direction, amount, postedAt; lifecycle = Pending -> Posted (immutable).
07 Value Objects	Money: amount + currency; rule: cannot add two Money values of different currency. BankAccountDetails: routing number + account number; rule: routing number must pass checksum. PaymentReference: formatted string; rule: unique per source account per day.
08 Aggregates	Root: Payment. Members: source PaymentLeg and beneficiary PaymentLeg. Invariant: the sum of all legs must equal zero - a Payment is never persisted in a state where money is created or destroyed. All external code goes through the Payment root, never directly to a leg.
09 Relationships	Customer -> Account: association, 1:N. Account -> Payment (as source): association, 1:N. Payment -> Ledger Entry: composition, 1:N. Payment -> Rail: association, N:1.
10 Personas and Actors	Retail Customer (human): sends money, checks status - initiates payments, queries state. Operations Analyst (human): keeps money flowing - investigates failed or stuck payments. Compliance Officer (human): stays within regulation - reviews flagged high-value payments. Fraud Engine (system): blocks bad payments - consumes events, returns a risk verdict. Settlement Scheduler (system): clears on time - batches and submits to rails.
11 Business Rules and Invariants	A payment cannot settle if the source has insufficient available balance (governs Payment, Account; consequence: overdraft, regulatory exposure). Payments at or above the reporting threshold require compliance review before settlement (governs Payment; consequence: AML reporting failure). A settled payment is immutable - corrections happen only by reversal (governs Payment; consequence: broken audit trail). A frozen account can receive but cannot send (governs Account; consequence: compliance breach).
12 Domain Events	PaymentInitiated: triggered when customer submits an instruction; reacted to by Fraud Engine and Notifications. PaymentValidated: triggered when balance and limits pass; reacted to by Settlement Scheduler. PaymentSettled: triggered when rail confirms finality; reacted to by Ledger, Notifications, Customer. PaymentFailed: triggered when validation or rail rejects; reacted to by Operations Analyst and Customer. PaymentReversed: triggered when an approved correction posts; reacted to by Ledger and Compliance Officer.

Payments context map:

Context	Direction	Neighboring Context	Pattern	What it means
Onboarding	Upstream ->	Payments	Customer/ Supplier	Onboarding supplies verified accounts to Payments. Payments (downstream) has input into the Onboarding roadmap.
Payments	Upstream ->	Risk / Fraud	Published Events	Payments publishes PaymentInitiated; Risk/Fraud consumes it. No synchronous coupling.
Payments	<-> Partnership	Ledger	Partnership	Payments and Ledger co-evolve the posting model and release in coordination. Both teams synchronize on the shared contract.
FX Vendor	Upstream ->	Payments	Anti-Corruption Layer	Payments wraps the vendor API behind an adapter. A vendor API change never leaks into Bristol's own model. This is the seam to protect first.

Event Storming output - Payments wall:

The Bristol Payments Event Storming session produced the following narrative strip off the wall. Read left to right: this is the agreed flow that became the foundation for blocks 4, 8, and 12.

Element type	Content
Actor	Retail Customer
Command	Submit Payment
Domain Event (orange)	PaymentInitiated
Policy (lilac)	Payments at or above the reporting threshold require compliance review before settlement
Command	Approve Payment (Compliance Officer)
Domain Event (orange)	PaymentValidated

Element type	Content
External System	Settlement Rail (ACH / wire)
Domain Event (orange)	PaymentSettled
Read Model	Payment Status view (customer-facing)
Hotspot (red)	How are in-flight payments handled during rail cutover? - owner: Treasury Engineering, due: pre-Phase 2

The orange notes became block 12 (Domain Events). The clusters on the wall became the three bounded contexts in block 4. The large grouping around Payment became the aggregate in block 8. The red hotspot became a line item in the migration plan. Same artifact, built by the whole room.

Strangler Fig migration - Payments domain:

The capability heatmap below shows the condition of what backs each capability at the start of Project Atlas. Red and amber drive the modernization budget. Green stays put.

Capability	Current condition	Direction
Ledger	Legacy risk - monolithic core DB	-> new ledger service (Phase 3, last)
Settlement	Legacy risk - mainframe batch	-> new settlement service (Phase 2)
Payment Initiation	Strained - aging core	-> new payments service (Phase 2)
Reconciliation	Healthy - recent rebuild	Keep as is
Notifications	Healthy - shared platform	Reuse (Phase 1)
Fraud Screening	Strained - vendor + glue code	Wrap behind ACL (Phase 1)
Order Slice	Why this order	
1 Notifications	Low risk, easy to decouple,	proves the routing facade works end to end.
2 Reconciliatio	n Self-contained, builds conf	idence and a delivery rhythm before core slices.
3 Payment Initi	ation Core value, the start of th	e flow, high visibility - done after facade is proven.
4 Settlement	Integration-heavy; done onl	y after Payment Initiation is stable.
5 Ledger	System of record, highest r	isk; shadow-write in parallel, then cut over last.
6 Decommission	core and Only when zero traffic	zero calls reach the legacy system.

Track three metrics: percent of functionality migrated, percent of traffic rerouted, and legacy calls remaining. Zero remaining calls is the decommission signal. Data is where the migration becomes real: shadow writes, dual stores, backfilled history, and the system-of-record cutover saved for last. The red hotspot from the Event Storming wall - in-flight payments during rail cutover - is the specific risk to resolve before Phase 2 begins.

How to read this example:

- Every block in the template is filled here at the level of detail that makes a model useful - use this as the calibration for your own domain's completeness, not as content to copy.
- The reporting threshold cited in Block 11 and the specific rail names (ACH, wire) are illustrative for Bristol Financial - replace them with your institution's actual thresholds and the rail set in scope for your program.
- The migration sequence (Notifications first, Ledger last) follows directly from the context map dependency structure and the capability heatmap - run the same analysis on your domain map to derive your own sequence rather than adopting this order by default.

Project Management · Workbook (10)

Project Workbook — Project Identification

Project Identification

Project name

Project ID / code

Project sponsor

Project manager / TPM

Department / function

Customer / business unit

Start date

Target end date

Approved budget

Phase

Current overall status

Status rationale

Last status update

Project Workbook — What On-Track / At-Risk / Off-Track mean

What On-Track / At-Risk / Off-Track mean

Status	Definition for this project
On-Track	On track on scope, schedule, and budget. Risks within tolerance. No executive escalations needed.
At-Risk	Material issues being actively mitigated, BUT project timeline and budget still expected to hold. Sponsor and steering awareness needed; intervention typically not. Trigger: high-impact risk unmitigated, OR material variance on any single dimension (cost/schedule/scope).
Off-Track	Material risk to project completion timing, budget, or scope. Executive intervention required. Trigger: critical-path slip with no recovery plan, OR unrecoverable budget overrun, OR material scope reduction needed, OR sponsor support compromised.

Note: RAG definitions vary by org. Adjust to your PMO's standards and document the change in the Decisions & Changes log so historical status reports remain interpretable.

Project Workbook — Workbook Map

Workbook Map

#	Tab	Purpose	When you use it
1	Cover	Project ID and tab map	Always — top-level reference
2	Charter	Business case, scope, objectives, success criteria, sign-offs	Initiate phase; reference throughout
3	Stakeholders	Stakeholder register and engagement plan	Initiate / Plan; update as it changes
4	RACI	Decision-level accountability matrix with auto-validation	Plan phase; revisit on org changes
5	Requirements	Business + technical requirements, traced to design and test	Plan onward; foundation for UAT
6	RAID Log	Risks, Assumptions, Issues, Dependencies — single integrated log	Plan onward; weekly view
7	Schedule	Milestones, deliverables, dates, dependencies, status	Plan onward; weekly update
8	Resources Team roster %, type, metrics	Allocation, summary review	Plan onward; weekly
9	Budget Budget by category, planned vs actual, variance, forecast	Plan onward; monthly	ard; monthly
10	Decisions & Changes Combined log of decisions made AND approved scope/schedule changes	Throughout project as decided	— append /approved
11	Action Items Meeting action items, commitments	Throughout project weekly	ut — review
12	Vendor Management Vendor SLA, escalations, reviews, re	Monthly, business news	+ ad-hoc
13	Status Reports Weekly status snapshots — history	Weekly new reports	y — append a new
14	UAT Log Test cases, results, execution	Test & deployment criteria	y phase
15	Post-Incident		

Project Workbook — How to Use This Workbook

How to Use This Workbook

1. Fill in the Cover tab first — every other tab assumes the project ID is set.
2. Tabs follow lifecycle order: Initiate → Plan → Execute → Test → Close.
3. The RAID Log replaces separate Risk, Assumption, Issue, and Dependency tabs.
4. Decisions & Changes is one combined tab — filter by Type column to see decisions vs change requests.
5. Action Items are distinct from RAID — meeting/working commitments with a name and a date, separate from risks/issues.
6. Status Reports, Decisions & Changes, and Action Items are append-only. Never overwrite past entries.
7. RACI integrity: the # of A's column flags activities that don't have exactly one Accountable.
8. Requirements Trace: Must Have requirements without test cases are flagged in the summary.
9. Post-Incident Actions is a standalone, cross-incident tracker — not project-specific.
10. Vendor Management tab tracks vendors engaged on this project — SLAs, escalations, renewal dates.

Known artifact overlap: stakeholder data

Stakeholder identification lives in the Stakeholders tab — name, role, classification, RACI level. When you build a Communications Plan (separate doc), the Audience Map will need many of the same names.

Discipline: keep stakeholder identification authoritative in the Stakeholders tab. Keep channel/cadence specifics in the Comms Plan.

Review for consistency at monthly planning. If a stakeholder changes role, update both.

Cross-platform compatibility

Tested in Microsoft Excel and LibreOffice Calc. All formulas use cross-platform compatible functions (no XLOOKUP, IFS, LET).

Conditional formatting (RAG colors) and dropdowns work in Excel, Google Sheets, and LibreOffice. Apple Numbers may render conditional formatting differently —

re-apply if importing to Numbers.

If migrating to Notion / Asana / Smartsheet / Jira, the methodology applies — re-create the tab structures as databases or boards.

Project Workbook — Project Charter

Project Charter

The foundational document. Approved at kickoff, referenced throughout.

Project name

Project sponsor

Project manager / TPM

Date

Version

BUSINESS CASE

Problem / opportunity

Strategic alignment

Expected business value

Cost of not doing

OBJECTIVES & SUCCESS CRITERIA

Project objectives

Success criteria

KPIs / metrics

SCOPE

In scope

Out of scope

Assumptions

Constraints

DELIVERABLES & MILESTONES

Major deliverables

Key milestones

STAKEHOLDERS & GOVERNANCE

Sponsor

Steering committee

Decision-making model

Escalation path

BUDGET

Approved budget

Funding source

Budget authority

HIGH-LEVEL RISKS

Top risks at kickoff

APPROVALS

Sponsor approval

PMO approval

Finance approval

Other approvals

cument. Approved at kickoff, referenced throughout.

Pulled from Cover tab

Executive accountable for project success

Person running the project day-to-day

Charter version date

v1.0, v1.1, etc.

What problem are we solving?

Which corporate goal or OKR does this support?

Revenue, cost savings, efficiency, risk mitigation — quantified

What happens if we don't do this?

SUCCESS CRITERIA

3–5 SMART objectives
 How we'll know we succeeded — measurable
 Specific metrics with targets
 What this project will deliver
 Explicitly what this project will NOT deliver
 Working assumptions
 Time, budget, technical, regulatory, organizational
 & MILESTONES
 Top-level outputs
 Top-level dates
 & GOVERNANCE
 Final decision authority
 Names + roles
 Consensus, sponsor decides, etc.
 Who escalates to whom
 Total approved
 Department, program, capex, opex
 Who can approve overages
 KS
 Top 3–5 risks
 Name, date, signature
 Name, date
 Name, date
 Legal, security, compliance as required
 Stakeholder Register & Engagement Plan
 Who matters, what they need, how we engage them.
 Engagement Communication needs /
 Name Role / Title Org / Department Influence Interest RACI
 Preferred channel
 level cadence

Project Workbook — RACI Matrix

RACI Matrix

Activities/decisions in rows, roles in columns. Exactly ONE A per row.

Compliance /

Activity / Decision	Sponsor	TPM	Eng Lead	QA Lead	Business / PO
Security Vendor					
Legal # of A's					
Approve project charter					
Approve scope changes					
Approve budget changes					
Approve schedule changes					

Approve vendor selection
 Sign off on requirements (BRD)
 Sign off on technical design
 Approve UAT entry / exit criteria
 Approve go-live / production deployment
 Approve security review
 Approve compliance review
 Approve customer / external
 communications
 0
 Resolve P0/P1 issues during execute
 Approve project closeout
 Approve benefits realization plan
 Field guide

R — Responsible	Does the work. Multiple R's allowed.
A — Accountable	Owens the outcome. Exactly ONE A per row. The buck stops here.
C — Consulted	Provides input before the decision. Two-way comms.
I — Informed	Notified after the decision. One-way comms.
R/A or A/R	Same person both responsible and accountable. Use sparingly.

Requirements Traceability Matrix

Every business and technical requirement, traced from source through design to test.

ID	Type	Requirement description	Source	Priority	Status	Owner
		Linked design / spec	Linked test case	UAT result		

Coverage summary

Total
 requireme
 nts 0
 Must
 Have
 count 0
 Approved
 or in
 progress 0
 UAT pass
 rate 0.0%
 Must
 Have
 requireme
 nts
 without

test case

RAID Log — Risks, Assumptions, Issues, Dependencies

Single integrated log. Filter by Type column to view a specific category.

Mitigation / response

ID	Type	Description	Likelihood	Impact	Score	Status	Owner
Date raised	Target close						

plan

Schedule — Milestones & Deliverables

Top-level project schedule. Detailed task management lives in Jira / Smartsheet / MS Project.

ID	Milestone / deliverable	Owner	Phase	Planned start	Planned end
Actual end	Status	Dependencies / notes			

Project Workbook — Resource Plan

Resource Plan

People allocated to this project.

Hourly /

Name	Role on project	Home department	Type	Allocation %	Start date	End date
	Notes					

loaded rate

Allocation summary

Total FTE allocation 0.0

Total contractor

allocation	0.0
Headcount on project	0

Budget — Planned vs Actual

Track approved budget against actual spend. Update at month-end close.

Total approved budget	Currency	USD Actual to date	As of date
Category Planned (\$)	Committed (\$)	(\$)	Variance (\$) % used Notes
Labor — internal			0.0%
Labor — contractors			0.0%
Vendors / SOWs			0.0%
Software & tools			0.0%
Hardware / infrastructure			0.0%
Travel			0.0%
Training			0.0%
Communications &			0.0%

marketing

Contingency	0.0%
Other	0.0% 0.0% 0.0%
TOTAL - - - -	0.0%

Decisions & Changes — Combined Log

Append-only log of decisions made AND approved scope/schedule/budget changes. Filter by Type.

Owner / decision- Schedule Budget

ID Date Type Title / decision / change Rationale

Scope impact Approver Status

maker impact (days) impact (\$)

Field guide

Type Decision = a choice made (vendor, design, scope clarification). Change Request = a formal modification to the approved baseline (charter scope, schedule, budget). Filter by this column.

Decisio

Don't need a formal approval workflow. Just need to be recorded. Status = Active / Superseded / Reversed.

ns

Change

Reques Go through workflow: Submitted → Under Review → Approved / Rejected → Implemented. Schedule and budget impact are required.

ts

Append

Never delete entries. If a decision is reversed or change is undone, mark superseded/reversed and add a new row.

-only

Action Items Tracker

Meeting action items and cross-meeting commitments. Reviewed weekly. Distinct from RAID (issues) and Decisions & Changes.

Source meeting /

ID Date raised Description Owner Due date

Priority Status Notes

context

Quick metrics

Open +

In

Progres

s

Done 0

Blocke

d

Carried Over

Vendor Management Tracker

Vendors engaged on this project. Track SLA performance, escalations, business reviews, and renewals.

Annual spend	SLA	Open	Last business	Next renewal
Vendor	Service / Tool	Contract end		
Owner / Account mgr				
(\$)	performance	escalations	review	action

Quick metrics

Total annual

\$0

vendor spend

Vendor management discipline

Track every vendor engaged on the project. Escalation count is leading indicator of contract health. Quarterly business reviews surface issues before renewal. Renewal action 6 months ahead of contract end.

Status Reports — Running History

Append a new row each reporting cycle. This is the historical record.

Reporting Overall Key accomplishments this

Report date	Reported by	Planned for next period	Top risks / issues	Asks / blockers
period	status period			

Project Workbook — UAT Test Case Log

UAT Test Case Log

Each row is one test case run. Pass rate auto-calculates for exit criteria.

UAT Entry / Exit Criteria

Entry

criteria

met (Y/N

+ date)

Exit

criteria

target (%)

pass)

Actual

0.0%

pass rate

UAT lead

219

Field guide

Action ID Sequential — PIA-001, PIA-002, etc.

Incident

Cross-reference to the incident this action came from. One incident may have multiple actions; one action may address multiple incidents.

ID

Type **Code fix:** specific bug. Infrastructure: capacity, redundancy, config. Process: how we work. Tooling: what we use. Training: knowledge gap. Policy: rules. Detection: monitoring/alerting/runbooks.

Tied to

root Reference the specific root cause from the post-mortem RCA. Helps identify systemic vs one-off fixes.

cause

Status **Open:** not started. In Progress: being worked. Done: implemented. Verified: confirmed effective via test/audit/drill. Dropped: deliberately not pursuing (record rationale in Notes).

Verificatio

30/60/90-day check after Done. Did the fix actually close the gap? Confirmed effective / Partially effective / Not effective.

n

Re-

incident Has anything similar happened since this action was Done? If Yes, the action wasn't effective — re-open or replace.

check

Overdue Due date column auto-highlights actions past due that aren't Done/Verified/Dropped.

Project Workbook — Lessons Learned

Lessons Learned

Captured throughout the project, finalized at close.

ID	Date	Category	Lesson / observation	Recommendation for next time
----	------	----------	----------------------	------------------------------

Owner to share / apply Status

Project Closeout Report

Completed at project close.

Project name

Closeout date

Reported by

FINAL OUTCOMES

Objectives met (Y/N + summary)

Success criteria achieved

Final scope vs original

Final schedule vs original

Final budget vs approved

BENEFITS REALIZATION

Expected business value

(from charter)

Realized benefits to date

Outstanding benefits

Benefit owner post-closeout

Measurement plan

STAKEHOLDER FEEDBACK

Sponsor feedback

Customer / business

feedback

Team feedback

OPEN ITEMS AT CLOSE

Outstanding risks

transferred

Unfinished deliverables

Operational handoff

LESSONS & KNOWLEDGE TRANSFER

Top 3 wins to repeat

Top 3 changes for next time

Knowledge base updates

made

ARCHIVE & DOCUMENTATION

Workbook archive location

Supporting documents

archived

Records retention period

APPROVALS

Sponsor sign-off on closeout

PMO sign-off on closeout

Finance sign-off (budget

close)

Closeout Report

S

For each charter objective: was it delivered?

Per charter — score against each measurable criterion

What shipped vs what was originally planned

Planned end vs actual end — explain variance

Approved budget vs actual spend — explain variance

ZATION

Restate what the project promised

What's already been measured / achieved

Benefits expected to materialize after closeout — and when

Who tracks realized benefits going forward

How and when realized benefits will be verified

FEEDBACK

From sponsor

From end users / business unit

From the project team

CLOSE

Risks that persist beyond the project — to whom transferred

If anything is incomplete — handoff plan

Who owns the deliverables operationally

WLEDGE TRANSFER

From Lessons Learned

Biggest things to do differently

Where lessons were filed for reuse

UMENTATION

Where this workbook is stored

Charter, contracts, design docs, test results

How long these records must be retained

Name, date

Name, date

Name, date

Part II — Program Management

Program Management · Framework Artifacts (14)

Artifact #24 — Program Charter (Multi-Initiative)

Purpose: Authorizes the program — a coordinated set of projects sharing a common strategic outcome. Heavier than a project charter because programs have more components and benefits that materialize across initiatives.

When you use it: Program inception, before component projects spin up.

Owner: Program Manager drafts; Executive Sponsor approves.

Cadence: One-time at inception; updated when program scope, components, or governance materially changes.

Where it lives: Templates Pack 2 has fillable Program Charter.

Sections / contents:

Section	Contents / fields
Program identification	Name, ID, sponsor, manager, theme/pillar, components, duration, budget
Strategic context	Strategic outcome, why a program (not separate projects), strategic alignment, expected value
Program scope	Components (in-scope projects), out of scope
Program governance	Governance model, decision rights, reporting cadence
Integration management	Cross-component dependencies, shared resources, integration risks
Program benefits realization	Benefits map, sustainment
Program budget	Total budget, component allocations, contingency, funding source
Program risk profile	Top program-level risks (different from component risks)
Approvals	Sponsor, PMO, Finance, component sponsors

AI enablement

- Cluster intake-form initiatives into candidate programs based on goal similarity and dependency overlap.
- Roll up component-project benefits to test whether the program-level value case holds.
- Surface cross-component dependency conflicts and resource collisions early.
- Generate program-level executive summary from component-project status reports.

Note: If you can't state the program's strategic outcome in one sentence, you don't have a program — you have a portfolio of unrelated projects.

PRACTITIONER REFERENCE

Standards & method: Aligned to MSP (Managing Successful Programmes) Blueprint and Mandate to Programme Brief process, and PMI The Standard for Program Management 4th Edition. Method: define the vision -> articulate the Blueprint (future state) -> identify constituent

projects and interdependencies -> establish program governance structure -> define benefits map and dependency chain -> obtain sponsorship mandate -> baseline.

Guiding principles: A program charter exists to align multiple projects to a single transformational outcome - not to aggregate project charters; the vision must be specific enough to adjudicate trade-off decisions; governance is defined at program level and cascades to projects; benefits ownership rests with business leaders, not the program manager.

What good looks like:

- A one-paragraph vision statement is outcome-specific enough that any team member can use it to resolve a scope trade-off without escalating.
- A benefits dependency map shows how program outputs chain to business outcomes and strategic objectives; the logic is explicit.
- Project interdependencies are mapped with the specific artifact or deliverable that passes between projects and the date dependency.
- Governance structure distinguishes program board (strategic) from project boards (tactical) with non-overlapping accountabilities.
- Scope boundary explicitly identifies what is in the program, what is a dependency outside the program, and what is explicitly excluded.

Common pitfalls:

- Charter is a concatenation of project charters with no integrating narrative or shared outcome.
- Vision is aspirational but unmeasurable; no objective success criteria exist at program level.
- Benefits ownership not assigned; benefits management defaults to the program manager who has no authority over business change.
- Interdependencies listed as bullet points without the specific deliverable, passing date, or receiving project clearly identified.
- Governance structure replicates project governance scaled up; program-level strategic direction is absent.

Maturity (1-5): L1 Ad hoc - projects run independently with no program framing; L2 Defined - program charter exists, projects identified; L3 Managed - benefits map created, interdependencies tracked, governance structure operational; L4 Quantified - program-level metrics dashboard, interdependency risk quantified; L5 Optimizing - adaptive program design, continuous realignment of projects to evolving strategic outcomes.

Artifact #25 — Program Governance & Integration Management

Purpose: The program-level equivalent of governance and execute/monitor — how the program is run across components. Defines decision rights at program vs component level, manages cross-component dependencies, and coordinates workstreams.

When you use it: Throughout the program lifecycle.

Owner: Program Manager; supported by component PMs.

Cadence: Weekly program operating review; monthly steering committee; quarterly executive review.

Where it lives: Set of artifacts assembled across multiple sources — typically a program SharePoint or Confluence space referencing component workbooks.

Sections / contents:

Section	Contents / fields
Program operating model	How decisions flow program ↔ components, who attends what forum, escalation paths
Cross-component dependency register	Dependencies between components — most common source of program failure
Shared resource management	Resources serving multiple components; contention surfaced proactively
Integration risks	Risks that exist only because we're running these together
Workstream coordination	Cross-component workstreams (architecture, security, OCM, integration)
Program-level RAID	Aggregated and program-specific items
Program reporting	Component → Program weekly; Program → Steering monthly; Program → Exec quarterly

AI enablement

- Detect cross-component dependency conflicts by comparing schedules and resource plans across components.

- Roll up component status into a program-level health view automatically.

- Surface program-level risks that no single component is tracking but that affect the whole.

- Forecast program completion and benefit timing from aggregated component trajectories.

Note: Cross-component dependencies are where programs fail. Track them more carefully than within-component risks. The Program Manager's job is to manage the seams.

PRACTITIONER REFERENCE

Standards & method: Aligned to MSP Governance Themes (Organization, Vision, Leadership, Benefits, Blueprint, Planning, Risk, Quality, Assurance) and PMI Standard for Program Management (Integration Management). Method: establish program governance framework -> define integration touchpoints between projects -> operate a program-level RAID log -> run cross-project dependency management cadence -> integrate project schedules into a master program schedule -> report program performance to sponsoring group.

Guiding principles: Integration management exists to resolve what individual projects cannot resolve alone - escalation must be structured; the program office is a coordination and integration function, not a bureaucratic overhead; governance decisions at program level must be made faster than the cadence of change in the projects; risk and issue ownership is unambiguous at each level.

What good looks like:

- A program-level RAID log captures only risks, assumptions, issues, and dependencies that span two or more projects; intra-project items stay at project level.
- A master schedule integrates project schedules at milestone level; the critical path through the program is visible and owned.
- Cross-project dependency tracking includes the delivering project, the receiving project, the specific deliverable, planned date, actual date, and float.
- Program board meeting cadence is defined and separated from project board cadence; escalation SLAs between levels are documented.

- Program governance framework is assured by an independent assurance function at defined stage gates.

Common pitfalls:

- Program office becomes a reporting aggregation layer only; no integration decisions are made.
- Master schedule is a Gantt concatenation, not an integrated network; cross-project critical path is invisible.
- Program RAID log duplicates all project RAID items; signal is lost in noise.
- Governance cadence not defined; program board frequency is ad hoc and reactive.
- No assurance mechanism; program health is self-assessed by the program manager.

Maturity (1-5): L1 Ad hoc - no program coordination layer; L2 Defined - program office established, governance meetings scheduled; L3 Managed - cross-project RAID, master schedule, dependency tracking operational; L4 Quantified - program-level EVM, dependency risk quantified, governance cycle time tracked; L5 Optimizing - adaptive integration model, AI-assisted cross-project conflict detection, continuous governance optimization.

Artifact #26 — Program Benefits Realization

Purpose: The mechanism that ties program-level promised benefits to actual delivered outcomes. Programs typically deliver capabilities; the operating organization sustains them — benefits realization makes that handoff explicit.

When you use it: Defined at program inception (in Charter); tracked through program lifecycle; sustained 12+ months post-program.

Owner: Program Manager during the program; named benefit owner post-program.

Cadence: Quarterly review during program; 6-month and 12-month post-program reviews.

Where it lives: Program Charter Benefits + standalone Benefits Realization Plan referenced from program artifacts.

Sections / contents:

Section	Contents / fields
Benefits map	Per benefit: source component(s), realization timing, measurement, owner
Benefit interdependencies	Benefits that depend on multiple components delivering together
Realization timing	On-launch / 3 mo / 6 mo / 12 mo / 24 mo benefits
Measurement plan	How each benefit is measured, by whom, how often
Sustainment plan	How benefits are sustained after the program closes — receiving owner explicitly named
Course correction	What triggers re-planning if benefits aren't materializing

AI enablement

- Forecast realized benefits from current component trajectory and surface at-risk benefits.
- Detect benefit drift — when changes to component scope reduce expected program value.
- Track benefits across multiple programs and identify reusable patterns.
- Auto-schedule benefits review checkpoints with the right stakeholders.

Note: Programs that don't track benefits realization end up as 'we shipped a lot' without proof of value. Benefit owners post-program are different from program manager — name them at

inception, not at closeout.

GOVERNANCE & OPERATING

PRACTITIONER REFERENCE

Standards & method: Grounded in MSP Managing Benefits (HM Treasury) and the HM Treasury Green Book benefits appraisal standard. Method: define benefits in the Business Case -> create benefits realization plan (owner, baseline, KPI, measurement method, timing) -> map benefits to program outputs via dependency chain -> track and report at defined intervals -> conduct post-program benefits review -> confirm strategic contribution and close.

Guiding principles: Benefits are owned by business leaders who control the change that generates them - not the program manager; every benefit has a baseline, a target, a measurement method, and a named owner before the program begins; a benefit that cannot be measured should not appear in the business case; benefits realization extends 12-36 months beyond program delivery.

What good looks like:

- Benefits realization plan is baselined alongside the program business case; benefits KPIs are contractual commitments, not estimates.
- Each benefit has a single named business owner with P&L or operational authority to drive the change that generates the benefit.
- Benefit profiles distinguish financial (cashable and non-cashable), strategic, and dis-benefits; dis-benefits are explicitly acknowledged and managed.
- A benefits tracking dashboard is reported to the sponsoring group at defined intervals (typically quarterly post-go-live).
- Post-program benefits review at 12 months compares realized value to business case; variance explanation is required regardless of direction.

Common pitfalls:

- Benefits defined as activity outputs ('system implemented') rather than measurable business outcomes ('unit cost reduced by 15%').
- Business case benefits inflated to secure approval; no intention to measure post-delivery.
- Benefits owner is the program manager by default; business leaders are not held accountable.
- Dis-benefits (e.g., transition cost, productivity dip during change) excluded from the business case to improve the headline ROI.
- Benefits measurement mechanism not designed at outset; baseline data unavailable when measurement is due.

Maturity (1-5): L1 Ad hoc - no benefits defined; benefits claimed retrospectively; L2 Defined - benefits listed in business case, owners named; L3 Managed - realization plan baselined, tracked post-delivery, reported to sponsor; L4 Quantified - benefits trended, variance to business case analyzed, dis-benefits tracked; L5 Optimizing - benefits data drives portfolio prioritization and investment sequencing in real time.

Artifact #27 — Project Intake Form

Purpose: The standardized way new projects enter the portfolio. Forces a baseline of information before resources are committed.

When you use it: Before a project is approved or chartered.

Owner: Requesting business owner submits; PMO intake reviews.

Cadence: On-demand as new initiatives are proposed.

Where it lives: Document or workbook entry — form-style intake.

Sections / contents:

Section	Contents / fields
Requestor	Name, role, department, sponsor
Initiative summary	Name, problem, solution, value (quantified), urgency
Strategic alignment	Corporate goal / OKR / pillar; alignment score
High-level scope	What's included, exclusions
Estimated cost	ROM — labor, vendors, tools
Estimated timeline	Desired start, end, drivers
Resource needs	Roles, FTE, special skills
Dependencies	Other initiatives, systems, vendors, regulatory
Risks / constraints	Known concerns at intake
Compliance / regulatory	Applicable regulations, data classification, security review
Decision	Approved / Approved with conditions / Deferred / Rejected — with rationale

AI enablement

- Auto-classify intake forms by strategic alignment, scope, and complexity for routing.
- Compare new requests to similar past projects to flag likely cost, timeline, and risks.
- Detect duplicate or overlapping initiatives across the portfolio at intake.
- Score and rank intake forms by strategic value and feasibility for prioritization meetings.

Note: A good intake form prevents 80% of the bad project approvals. The PMO uses this to compare initiatives apples-to-apples.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI Standard for Portfolio Management (4th ed.) Stage-Gate intake process and ISO 21504 portfolio management guidance. Method: capture strategic alignment -> quantify value and effort -> assess feasibility and dependencies -> score and rank against portfolio criteria -> governance decision (approve / defer / reject).

Guiding principles: No project enters the portfolio without a named business sponsor and a stated strategic linkage; scoring criteria are fixed before submissions open, not after; intake is a filter, not a formality; incomplete submissions are returned, not advanced.

What good looks like:

- Every field maps to a portfolio-level scoring dimension (value, risk, cost, strategic fit).
- Submission triggers an SLA-bound review cycle with a published decision date.
- Comparative scoring across submissions is reproducible by any reviewer using the same rubric.
- Dependencies on in-flight projects are explicitly declared and validated before approval.
- Rejected submissions receive a written rationale and a resubmission path.

Common pitfalls:

- Free-text value fields that cannot be compared across submissions.
- HiPPO approvals that bypass the scoring rubric.
- Intake form treated as a budget request rather than a value-and-feasibility test.
- No dependency check, creating invisible portfolio congestion.

- Forms submitted without sponsor sign-off, leaving accountability ambiguous.

Maturity (1-5): L1 Ad hoc - verbal requests, no standard form; L2 Defined - standard template exists, inconsistently applied; L3 Managed - scored intake with governance gate and decision SLA; L4 Quantified - portfolio capacity and dependency load modeled at intake; L5 Optimizing - continuous value-weighting recalibrates scoring criteria against realized benefits.

Artifact #28 — Portfolio Dashboard

Purpose: The cross-project view for PMO leadership and executives. Shows portfolio health, resource utilization, budget burn, and concentration risk across all active projects.

When you use it: Throughout — a continuous artifact for the PMO.

Owner: PMO leadership; populated from individual project workbooks.

Cadence: Weekly snapshot; monthly PMO leadership review; quarterly to executives.

Where it lives: BI tool (Tableau, Power BI, Smartsheet dashboard) fed from project workbooks.

Sections / contents:

Section	Contents / fields
Portfolio summary	Active projects (by phase), total budget, spend YTD, headcount allocated
Health by project	Per project: R/A/G, % complete, budget variance, schedule variance, top risk
Resource utilization	By role/department: allocated %, capacity, over-allocation flags
Budget	By project: planned, actual, forecast, variance — and totals
Top portfolio risks	Risks rated High that span projects
Strategic alignment	% of portfolio spend per strategic pillar
Trend metrics	On-time delivery, on-budget delivery, charter-to-close cycle time

AI enablement

- Aggregate project workbooks into the dashboard automatically — no manual roll-up.
- Detect portfolio-level patterns (e.g., projects launched in Q1 consistently slip).
- Forecast portfolio health 90 days out based on current trajectory.
- Recommend portfolio rebalancing when resource or budget concentration becomes risky.

Note: Build the portfolio dashboard from the same fields each project workbook tracks — that's the value of standardizing the workbook.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI Standard for Portfolio Management (4th ed.) performance reporting and ISO 21504 Clause 8 (monitoring and controlling). Method: define portfolio KPIs -> aggregate project status signals -> trend over time -> surface decision-relevant exceptions -> drive governance action.

Guiding principles: One version of truth consumed by all governance tiers; status is evidence-based, not self-reported color; the dashboard drives decisions, not just awareness; staleness is visible - a date-stamped freshness indicator is mandatory.

What good looks like:

- RAG thresholds are defined and enforced algorithmically, not editorially.
- Trend lines show trajectory, not just point-in-time status.

- Capacity utilization and financial burn are co-located with delivery status.
- Every red or amber indicator links directly to the owning project record and accountable executive.
- Dashboard refresh cadence matches governance meeting rhythm.

Common pitfalls:

- Green-washing: projects self-report amber as green to avoid scrutiny.
- Vanity metrics (number of projects active) crowding out value metrics (benefits realized).
- Dashboard built for the PMO, not for the sponsor or SteerCo.
- No drill-down path from portfolio aggregate to project detail.
- Stale data presented as current without a visible as-of timestamp.

Maturity (1-5): L1 Ad hoc - status gathered by email before each meeting; L2 Defined - static template refreshed manually; L3 Managed - near-real-time dashboard with defined RAG rules and governance cadence; L4 Quantified - predictive completion and benefit realization modeled; L5 Optimizing - AI-assisted exception surfacing and portfolio rebalancing signals.

Artifact #29 — Operating Model Document

Purpose: Codifies how a function, business unit, or program operates day-to-day after the project that built it ships. The durable description of how the work runs.

When you use it: At program inception, organizational change, or scaling event.

Owner: Function head; PMO supports drafting.

Cadence: One-time creation; reviewed annually or on material change.

Where it lives: Templates Pack 13 has fillable Operating Model.

Sections / contents:

Section	Contents / fields
Purpose & mandate	What the function exists to do, for whom
Section	Contents / fields
Scope	In/out of scope, boundaries with adjacent functions
Organization structure	Org chart, role definitions, decision authority
Governance & decision rights	Forums, frequency, attendees, decisions made
Core processes	5–10 processes that define how the function operates
Tools & systems	Tech stack, integrations, owners
KPIs & performance metrics	Durable performance indicators
Capacity & workforce plan	Headcount, demand, skills, hiring, succession
Budget & financial model	Annual operating budget, cost categories, allocation
External dependencies	Vendors, internal functions, regulators, customers
Continuous improvement	How operational lessons are captured and acted on
Risks to operating model	Key person risk, single-vendor risk, capacity
Approval & review	Sign-offs, last review, next review

AI enablement

- Detect operating model drift — when actual practice diverges from documented model.
- Recommend updates when org changes, tooling changes, or strategy shifts.

- Generate role-specific playbooks from the operating model.
- Surface inefficiencies — duplicate processes, role overlap, decision bottlenecks.

Note: This is heavyweight. For a small project, the Charter covers most of this. Operating models are for programs, business units, and PMO-of-PMOs scenarios.

SPECIALIZED

PRACTITIONER REFERENCE

Standards & method: Aligned to ITIL 4 Service Value System (operating model as service value chain configuration) and McKinsey 7-S / Galbraith Star Model design principles. Method: articulate value streams -> assign accountabilities (RACI) -> define enabling capabilities -> specify governance interfaces -> map to technology and data flows.

Guiding principles: Structure follows strategy, not history; every accountability is owned by a role, not a team name; hand-off points are explicit and SLA-bound; the model is a living document versioned with each structural change.

What good looks like:

- Value streams are traceable end-to-end from customer need to outcome delivered.
- Every box in the model has a named accountable role, not a committee.
- Interfaces between units carry defined inputs, outputs, and service-level expectations.
- The document distinguishes decision rights (who decides) from execution rights (who does).
- Governance forums are mapped to the model with mandate, cadence, and quorum defined.

Common pitfalls:

- Org charts masquerading as operating models without process or capability content.
- RACI cells populated as 'Responsible' for every row, destroying accountability clarity.
- Model reflects aspirational design but not actual working practices.
- Technology layer omitted, leaving capability-to-system dependencies invisible.
- No change history, so stakeholders cannot determine what changed and when.

Maturity (1-5): L1 Ad hoc - implicit, undocumented ways of working; L2 Defined - documented model exists but not actively maintained; L3 Managed - versioned model aligned to strategy, reviewed at each structural change; L4 Quantified - capability maturity scored, gaps tracked to investment decisions; L5 Optimizing - continuous capability sensing drives proactive model evolution.

Artifact #33 — Program Success Metrics, OKRs & KPIs

Purpose

This artifact defines how a program establishes what success means and how that success will be measured. Most programs charter without this discipline and discover the problem at closeout, when stakeholders disagree about whether the program succeeded. The fix is to set program-level success metrics during chartering and review them on a deliberate cadence throughout execution.

Three concepts, often confused

Three terms get used interchangeably in PMO practice. They aren't the same thing, and conflating them produces metrics work that doesn't serve any of the underlying purposes well.

Objectives & Key Results (OKRs). Qualitative goals (Objective) paired with measurable outcomes (Key Results). Used to set direction and ambition. Time-bound. Aspirational by design — well-formed OKRs are not certain to be achieved. Example: Objective: "Establish a Zero

Trust foundation that meets external commitments and enables Cloud Migration." Key Results: "100% of privileged users on FIDO2 by Q3 2027; ZTNA gateway 99.95% availability across all four waves; SOC 2 Type II audit closes with zero open findings on remote access controls."

Key Performance Indicators (KPIs). Ongoing measures of operational health. Not goals — health signals. Continuous. Steady-state. Example: "Help desk ticket volume per 100 users during cutover weeks (target peak day < 5)."

Success metrics. Broader umbrella covering both OKRs and KPIs, plus other measurements like adoption, satisfaction, and leading indicators. The full set of measurements that tell you whether the program is on a path to its objectives.

For a program: set OKRs to define what success means, track KPIs during execution to monitor health, and measure success metrics at the end to know whether you achieved the OKRs. Each has a different purpose and a different cadence.

Section 1 — Setting program-level OKRs

Objective formulation

The Objective is the qualitative statement of what the program is trying to accomplish. It should be:

- Memorable in one sentence
- Aspirational (worth doing) without being vague
- Distinct from operational activity (not "deliver the project plan")
- Connected to a business outcome the sponsor would defend

Anti-pattern: Objectives that describe activity. "Implement ZTNA across the enterprise" describes work. "Establish a Zero Trust foundation that meets external commitments and enables Cloud Migration" describes outcome. The activity statement gets met by completing the work; the outcome statement requires the work to actually produce the intended state.

Anti-pattern: Objectives that describe deliverables. "Ship the new identity platform" is a deliverable. "Eliminate the IdP single point of failure that produced the 2025 outages" is an outcome. Sponsors evaluate programs against outcomes; deliverables are the path.

Most programs need 1-2 Objectives. Three is the maximum for any single program; beyond that, the program is trying to do too many things and the Objectives lose force.

Key Result quality criteria

Key Results are the measurable outcomes that, if achieved, mean the Objective was met.

Quality criteria:

- Measurable with a specific number, percentage, or binary state
- Time-bound (by when)
- Outcome-focused, not activity-focused
- Independent — each KR can be measured without depending on the others

Anti-pattern: KRs that measure activity. "Hold 12 stakeholder workshops" is activity. "Active ZTNA usage at T+7 days $\geq$ 99% of enrolled users" is outcome. The first is met by doing the work; the second requires the work to produce the intended state.

Anti-pattern: KRs that double-measure. If you have three KRs that all measure the same underlying thing in slightly different ways, you have one KR. Combine.

Anti-pattern: KRs the sponsor doesn't value. The KR has to be something the sponsor would defend if asked "is this what success looks like?" If the answer is "well, technically, but we'd want X too," X belongs in the KR set.

Most Objectives need 3-5 Key Results. Below 3, the Objective probably isn't fully captured. Above 5, the KR set becomes performative — too many things to track meaningfully.

Calibration: how aspirational

Well-calibrated OKRs sit in tension between achievable and stretching. Two anti-patterns:

Sandbagged OKRs. KRs the team is 95%+ confident of hitting. The program will land on its OKRs and feel successful, but the Objectives weren't worth the program's full effort. Common in environments where missing OKRs has career consequences.

Heroic OKRs. KRs the team is 30% confident of hitting. The program will probably miss most of them, and the team's relationship to the OKRs becomes cynical because they were never realistic in the first place.

The calibration target: 60-70% confidence on the harder KRs. The team should believe they can hit them with focused work, but it's not certain.

Section 2 — Choosing program-level KPIs

KPIs are the ongoing health signals tracked during execution. They are not goals; they are leading indicators that the program is on (or off) the path to its OKRs.

Selection criteria

A good program KPI:

- Is a leading indicator (changes before the OKR outcome changes)
- Can be measured continuously without imposing significant overhead
- Has a specific threshold below which intervention is required
- Is owned by a named role with authority to act on it

Anti-pattern: KPIs that are just OKR Key Results renamed. The KR measures whether you achieved the outcome at the end. The KPI tells you whether you're on track during execution. They're related but distinct.

Anti-pattern: KPIs without intervention thresholds. A KPI that says "track X" without saying "intervene if X drops below Y" is a metric, not a KPI. Tracking without acting wastes attention.

Anti-pattern: too many KPIs. Most programs do well with 5-10 KPIs at the program level (component-level KPIs are different and can be more numerous). Beyond 10, the TPM is paying attention costs that compete with the work the KPIs are supposed to support.

Leading vs lagging indicators

Lagging indicators measure outcomes after the fact. They tell you what happened. Useful for retrospective evaluation, less useful for in-flight management.

Leading indicators measure conditions that predict outcomes. They tell you what's likely to happen if conditions hold. Useful for in-flight management because they create time to intervene.

Most programs over-weight lagging indicators because they're easier to measure (revenue, completion, satisfaction). Leading indicators require more thought (engagement quality, decision velocity, blocker rate) but produce earlier signal.

A balanced KPI set has 60-70% leading indicators and 30-40% lagging indicators.

Section 3 — How metrics integrate with the toolkit

The Charter (Artifact #1)

The program's OKRs belong in the Charter. They define what the program is for. A Charter without OKRs has scope and budget but no answer to "what does success look like." The Charter section structure: Objective(s), Key Results, calibration confidence, owner.

The Status Report (Artifact #18)

KPIs belong in the Status Report. The report's RAG status is informed by KPI threshold performance. KPI movement is the leading indicator that the program's RAG status will shift before the underlying delivery does.

The Operating Model (Artifact #29)

The Operating Model has its own KPIs section, but those are function-level steady-state metrics, not program-level success metrics. The distinction: program OKRs/KPIs apply to the program from charter through close; function KPIs apply to the function indefinitely. At program close, some metrics transition from program-level to function-level (e.g., "ZTNA availability" moves from program KPI to Operating Model KPI).

The Project Closeout Report (Artifact #23)

The Closeout Report includes Benefits Realization, which tracks whether the program's OKRs were achieved. Benefits Realization is the OKR review at program close.

The Post-Launch Metrics (Templates Pack)

Post-Launch Metrics extend the OKR/KPI structure into the post-program period when relevant — the period after the program is closed but the Objectives are still being measured.

Section 4 — Common failure modes

Vanity metrics. Metrics that are tracked because they're easy to measure and look good, not because they reflect program health. "Number of stakeholders trained" is a vanity metric; it measures the team's activity, not the program's outcome.

Metrics that gamify. Metrics whose definition can be met without producing the underlying outcome the program was trying to achieve. "Percentage of users on the new system" can be met by mandating use; it doesn't mean adoption is real. The fix is to pair quantity metrics with quality metrics (e.g., active usage at T+30 alongside enrollment at T+7).

Metrics that aren't actionable. A metric that nobody can act on is a metric that wastes attention. If a KPI shifts and the response is "interesting," the KPI shouldn't have been chosen. Every metric should have an associated decision it would inform if it changed.

Too many metrics. Most programs measure too many things. The cost: attention spreads thin, the genuinely important signals get diluted, and the team's relationship to metrics becomes performative. Cut to the smallest set that supports decisions.

Metrics that don't survive the program. A program that closes with 30 KPIs and no clear handoff produces operational debt. The Operating Model that takes over the capability has to inherit the right subset and let the rest go. Plan the metric handoff during the program, not at closeout.

OKRs without owners. An OKR that nobody owns is a metric set with no accountability. Each OKR needs a named owner — typically the sponsor for program-level, the TPM for execution-level, the component PM for component-level.

OKRs without review cadence. OKRs set at chartering and reviewed only at closeout don't shape execution. The cadence has to be regular enough to influence decisions during the program.

Section 5 — Cadence

Setting OKRs

Set during program chartering. The Objective(s) and Key Results go into the Charter. Sponsor approval of the Charter includes approval of the OKRs.

If the program is large enough to have a Program Charter (#24) plus component charters, OKRs cascade: Program OKRs first, component OKRs derived from them. Component OKRs that don't connect to program OKRs are warning signs.

Reviewing OKRs

Quarterly review at minimum. Monthly for programs with high-stakes external commitments. The review is a deliberate session, not embedded in routine status. Outputs:

- Confidence rating for each KR (still 60-70% confident? Higher? Lower?)
- Material change in any KR? (e.g., the conditions that informed the KR have changed and the KR no longer reflects success)
- Cascade impact on component OKRs

Resetting OKRs

Re-baselining a program (Field Note #215) usually requires resetting OKRs. The new Charter version has new OKRs. The cleanest pattern: reset the OKRs as part of the formal re-baseline; don't let OKRs drift quietly to match a re-scoped reality.

Tracking KPIs

Continuous through program execution. Reported in weekly status alongside RAG. KPI threshold breaches trigger named interventions per the KPI's design.

KPI handoff

At program close, KPIs that should continue post-program (e.g., availability, usage, customer satisfaction) transition to the Operating Model that owns the capability. Plan the handoff at least 60 days before closeout so the receiving function has time to absorb the metric.

Section 6 — When this artifact applies

Use this artifact for any program where:

- The sponsor will evaluate success at the end ("did we get what we paid for?")
- Multiple stakeholders need a shared understanding of what success means
- The program has external commitments (regulatory, customer, board)
- The program will deliver capability that transitions to ongoing operations

Skip or simplify for programs where:

- The deliverable is binary and obvious (go/no-go capability)
- The program is short (under 90 days) and scope is unambiguous
- The program is purely operational (lights-on work that has KPIs but doesn't need OKRs)

Most security and infrastructure programs at organizational scale need this artifact. Most short-cycle delivery work does not.

Section 7 — Approvals

The OKRs require sponsor approval as part of the Charter. KPIs require operational owner agreement (the people who will measure and act on them). Both go through the same approval cadence as the Charter — sponsor + program owner at minimum, with stakeholder acknowledgment for major OKRs.

Related artifacts

- Charter (#1): where program OKRs are formally captured
- Program Charter (#24): where program-level OKRs are captured for multi-initiative programs
- Status Report (#18): where KPIs are reported alongside RAG status
- Operating Model Document (#29): where post-program KPIs transition to function ownership
- Project Closeout Report (#23): where OKR achievement is documented at close
- Benefits Realization (component of #23 and #26): where the OKR outcomes are tracked over time post-close

Related Field Notes

- Recommending prioritization with data (#223): the framework for stakeholder prioritization conversations that feed into OKR selection
- Re-baselining without losing trust (#215): when OKRs need formal reset
- "Executive intervention required" (#227): the relationship between KPI thresholds and Off-Track designation
- Where automation accelerates the wrong thing (#232): the trap of measuring more rather than measuring better

Keywords: OKRs, Key Results, Objectives, KPIs, Key Performance Indicators, success metrics, program success, success criteria, leading indicators, lagging indicators, metrics framework, program OKRs, KR calibration, vanity metrics, metric handoff, post-program metrics, benefits realization metrics, what does success look like, measuring program success

PRACTITIONER REFERENCE

Standards & method: Aligned to OKR practice (Doerr, 'Measure What Matters') for objective-key result hierarchy and the Balanced Scorecard (Kaplan-Norton) for multi-perspective KPI design. Method: set qualitative Objective -> derive 2-5 measurable Key Results -> cascade to team-level KPIs -> establish measurement cadence and baseline -> review and score quarterly.

Guiding principles: Objectives are inspirational and directional; Key Results are evidence-based and falsifiable; KPIs measure health of ongoing operations, OKRs measure step-change progress; a KR without a baseline and a target is not a KR.

What good looks like:

- Every Objective maps to at least one strategic portfolio priority with explicit linkage stated.
- Key Results are outcome-based (not activity-based) and include a quantified target and a measurement source.
- Confidence scores are tracked weekly to surface at-risk KRs before the quarter ends.
- KPIs are separated from OKRs: KPIs monitor steady-state health, OKRs drive transformation.
- Scoring at quarter-end is honest: 0.7 is a good score; 1.0 suggests the target was too conservative.

Common pitfalls:

- Key Results defined as tasks ('launch the feature') rather than outcomes ('increase activation rate by 15%').
- OKRs set and reviewed only at the annual planning cycle, not quarterly.
- Too many objectives: more than 3-5 per team destroys focus.
- KPIs reported without owner accountability or improvement actions when trending negative.
- Gaming: targets set conservatively to guarantee 1.0 scores rather than drive stretch performance.

Maturity (1-5): L1 Ad hoc - goals exist in heads or annual reviews only; L2 Defined - OKRs written but reviewed infrequently; L3 Managed - quarterly cadence, scored, cascaded to teams; L4 Quantified - OKR progress correlated to business outcome data with statistical confidence; L5 Optimizing - continuous OKR refinement driven by real-time outcome signals and portfolio rebalancing.

Artifact #44 — Portfolio Prioritization & Scoring Model

Purpose: Decide which initiatives get funded and sequenced, transparently and repeatably, using weighted criteria rather than the loudest voice. The mechanism behind a credible portfolio and intake process.

When you use it: Established when the PMO/portfolio is set up; applied at every intake decision and at portfolio re-planning.

Owner: Portfolio/PMO lead owns the model; governance board owns the decisions; sponsors submit and defend initiatives.

Cadence: Scoring at each intake; full portfolio re-score quarterly or at major strategy shifts.

Where it lives: Program/portfolio workbook 'Prioritization'; intake forms feed it; the portfolio dashboard reflects the output.

Sections / contents:

- Scoring criteria and weights (strategic alignment, value/ROI, risk reduction, urgency/compliance, effort/cost, dependency)
- Scoring scale and definitions per criterion (avoid ambiguity)
- Initiative scorecard: weighted score, rank, tier (must-do / should-do / defer)
- Capacity check: ranked list vs available capacity (link to capacity & demand)
- Governance decision: fund / hold / decline, with rationale recorded
- Cadence and re-scoring rules; tie-break and override policy

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI Standard for Portfolio Management (4th Ed.) and ISO 21504:2015. Method: define strategic objectives and weighting -> score initiatives against criteria (strategic fit, value, risk, cost, interdependency) -> normalize and rank -> apply capacity constraint -> present efficient frontier to governance -> rebalance on cadence.

Guiding principles: Scoring criteria are weighted to strategy, not politics; every initiative is scored on the same rubric; capacity constraint is applied after scoring, not before; the model is a decision aid, not a black box.

What good looks like:

- Scoring criteria and weights are formally approved by the governance board and version-controlled.
- Strategic alignment scores are validated against the current corporate strategy document, not assumptions.
- Sensitivity analysis shows which initiatives are robust winners versus those that flip ranking with small weight changes.
- The efficient frontier is visualized, showing value delivered per unit of capacity consumed.
- Model is rerun at least quarterly and when strategy shifts, not just at annual planning.

Common pitfalls:

- Weights reverse-engineered to justify a pre-decided outcome, destroying model credibility.
- All initiatives scored identically on strategic alignment because scorers fear political consequences.
- Model complexity so high that no executive understands the output, leading to override by intuition anyway.
- Interdependencies ignored, causing a high-scoring initiative to stall because its dependency was deprioritized.
- Model run once at intake and never refreshed, making the portfolio allocation stale within one quarter.

Maturity (1-5): L1 Ad hoc - prioritization by loudest stakeholder; L2 Defined - scoring model documented and applied at intake; L3 Managed - quarterly rebalancing, capacity constraint applied formally; L4 Quantified - efficient frontier modeled, sensitivity analysis routine; L5

Optimizing - real-time portfolio analytics, AI-assisted scenario modeling aligned to rolling strategy.

Artifact #45 — Program Capacity & Demand Management Plan

Purpose: Balance the demand of all initiatives against the finite supply of people and skills across the program/portfolio, so commitments are realistic and bottlenecks are seen early. Stops the program from saying yes to more than it can deliver.

When you use it: Stood up once multiple initiatives share resources; reviewed every planning cycle and when demand or supply shifts.

Owner: Program manager / resource manager owns it; component leads submit demand; functional managers own supply.

Cadence: Refreshed each planning cycle (monthly/quarterly); bottlenecks flagged in program status.

Where it lives: Program workbook tab 'Capacity & Demand'; draws from component resource plans and the prioritization model.

Sections / contents:

- Supply: people/skills by team, available capacity per period, planned leave/holidays
- Demand: forecast effort by initiative and skill, time-phased
- Heatmap: supply vs demand by skill/team and period; over/under allocation
- Constrained roles / single points of failure; mitigation (hire, contract, re-sequence, defer)
- Scenario view: impact of adding/deferring an initiative
- Decisions and assumptions log

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 resource management domain and ITIL 4 Capacity and Performance Management practice. Method: demand intake and categorization -> resource skill inventory -> gap analysis -> scenario planning (baseline, accelerated, reduced) -> allocation decision -> utilization monitoring -> replan trigger definition.

Guiding principles: Demand is quantified before resources are allocated; utilization targets account for non-project overhead; named individuals are planned, not generic roles; replan triggers are defined in advance, not reactive.

What good looks like:

- Resource plan is skill-specific and individual-named, not just FTE counts by role.
- Utilization targets are capped at 70-80% to preserve capacity for unplanned demand and quality work.
- Demand vs. supply gap analysis is updated monthly and presented to portfolio governance.
- Scenario plans (best/base/worst case) are maintained and tied to the portfolio prioritization model.
- Critical-path resource constraints are flagged to sponsors at least four weeks before they become blockers.

Common pitfalls:

- Plan shows 100%+ utilization across the portfolio, making it aspirational rather than executable.
- Resource allocation decided informally by line managers without reference to the demand plan.
- Skill taxonomy too coarse (e.g., 'developer') to differentiate genuinely scarce specializations.

- Demand plan not updated when scope changes, creating a growing gap between plan and reality.
- Contractor pipeline not managed proactively, causing lead-time failures when surge demand hits.

Maturity (1-5): L1 Ad hoc - allocation by tribal knowledge; L2 Defined - resource register exists, allocations documented; L3 Managed - monthly demand vs. supply review, scenario plans maintained; L4 Quantified - utilization trended, lead indicators trigger replan; L5 Optimizing - dynamic capacity marketplace, predictive demand sensing integrated with portfolio model.

Artifact #57 — Program Roadmap

Purpose: Provides the integrated visual timeline for the program - showing all workstreams and initiatives plotted over time, key milestones, cross-initiative dependencies, decision points, funding gates, and release events. Sits above the detailed project schedule and below the portfolio dashboard; it is the primary strategic alignment and communication tool for the Program Sponsor, SteerCo, and senior stakeholders.

When you use it: First version produced in Define & Set Up once the program blueprint and workstream scope are confirmed; updated at each program-level governance cycle and at every phase gate; a major rebaseline is triggered by any approved change that affects the critical path, funding, or scope of more than one workstream.

Owner: Program Manager owns and maintains the roadmap; workstream leads provide input for their timelines; Program Sponsor approves the baselined version and any rebaseline.

Cadence: Reviewed and updated monthly at the Program Board; materially updated after each phase gate or major dependency resolution; distributed to SteerCo ahead of each quarterly business review; version-controlled in the central program repository.

Where it lives: Primary artifact in the program repository under /Plans/Roadmap; summary view embedded in the Monthly Program Status Report and the Quarterly SteerCo Pack; detailed dependency view available in the program scheduling tool (e.g., MS Project or Smartsheet).

Sections / contents:

Section	Contents / fields
Program Context and Objectives	One-paragraph statement of the program's strategic intent, the business outcomes it delivers, and the planning horizon; for Bristol IT & Security Programs this anchors the roadmap to the ZTNA + PAM modernisation mandate and any regulatory or audit commitments driving timelines.
Workstream Swim Lanes	One horizontal swim lane per workstream or initiative (e.g., IAM, ZTNA, PAM, Programme Management, Technology Infrastructure); each lane shows phases, major work blocks, and internal milestones plotted against a monthly or quarterly time axis; colour-coded by status (on track, at risk, delayed).
Program Milestones	Numbered list of program-level milestones with dates, owners, and go/no-go criteria; includes contractual, regulatory, and funding milestones in addition to delivery milestones; each milestone has a unique ID (e.g., M-01 through M-n) referenced consistently across the roadmap and status reports.
Cross-Initiative Dependencies	Dependency register showing: Dependency ID, predecessor workstream and milestone, successor workstream and milestone, dependency type (finish-to-start, etc.), lag/lead, status (open/resolved/at risk), and owner; critical path dependencies highlighted; feeding this register is mandatory for workstream leads

Section	Contents / fields
	at each monthly review.
Decision Points and Governance Gates	Explicit markers on the timeline for: phase gate reviews, funding approval points, build/buy/partner decisions, regulatory submission dates, and board or SteerCo approvals required before the next phase can proceed; each gate has a named decision-maker, required inputs, and a decision-by date.
Release and Deployment Events	Planned releases, go-live events, and production cutover windows for each workstream; release freeze windows and blackout periods (e.g., Bristol Financial quarter-end, regulatory reporting windows) marked; dependencies between releases (e.g., ZTNA network policy must be live before PAM vault goes to production) explicitly shown.
Assumptions and Constraints	Key assumptions underpinning the roadmap timeline (e.g., 'ClearPath Networks delivers ZTNA lab environment by 2026-08-01', 'headcount for IAM workstream confirmed at 4 FTE through Q3'); hard constraints (regulatory deadlines, budget cycles, technology freeze windows); each assumption has an owner and a review date.
Risks to the Roadmap	Top 3-5 risks that could materially shift the roadmap timeline or scope, cross-referenced to the Risk Register; each risk entry shows the roadmap impact (e.g., 'delays M-04 ZTNA pilot go-live by up to 6 weeks'), the mitigation in place, and the risk owner; updated at each monthly review.
Version and Change History	Version table: version number, date, change summary, changed by, approved by; all rebaselines (major version increments) require Program Sponsor approval; minor updates (v1.1, v1.2) for corrections and additions that do not shift milestones by more than 5 business days.
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to PMI Standard for Portfolio Management (4th ed.) which requires an integrated portfolio roadmap showing initiative interdependencies, decision gates, and strategic alignment - implement by: confirm strategic objectives -> map workstreams to objectives -> plot milestones and dependencies -> identify decision gates -> baseline with sponsor -> review each governance cycle. Aligned to MSP (Managing Successful Programmes) which mandates a programme schedule integrating all tranches, blueprints, and benefits realisation milestones, with explicit tranche boundaries acting as governance gates - implement by: define tranches -> assign blueprint deliverables per tranche -> map interdependencies -> confirm funding gates -> maintain as a living artifact. Aligned to SAFe Program Increment (PI) roadmap practice which requires a rolling multi-PI roadmap showing features, milestones, and cross-ART dependencies updated each PI planning event - implement by: identify value streams -> plot PI boundaries -> map features to PIs -> show inter-ART dependencies -> refine each PI planning.

Guiding principles: Strategic visibility over operational detail - the roadmap communicates direction and interdependencies at program level; it is not a Gantt chart and must remain readable by a non-technical executive in under 2 minutes; dependency-first thinking - every cross-workstream dependency is explicit, owned, and tracked before it becomes a critical-path problem; one version of the truth - a single baselined roadmap is the reference for all program communications; vague timelines are replaced with a clearly flagged 'TBD by [date]' to preserve

honesty; living artifact, not a launch document - the roadmap is updated at every governance cycle and rebaselined when scope or critical path changes, not archived after kickoff.

What good looks like:

- Every cross-initiative dependency has a unique ID, an owner in each workstream, a type (e.g., finish-to-start), and a status that is updated monthly - no dependency is tracked only in someone's head.
- Decision points and governance gates are plotted on the timeline with named decision-makers and required inputs, so the program never arrives at a gate unprepared.
- The roadmap distinguishes between the baselined plan and the current forecast - slippage is visible, quantified, and cross-referenced to the risk register rather than quietly absorbed into revised dates.
- Release and deployment events show blackout periods and inter-release dependencies, preventing go-live scheduling conflicts with Bristol Financial's quarter-end freeze or regulatory reporting windows.
- The roadmap is a single file or slide in the program repository, version-controlled, and distributed to SteerCo before each quarterly review - stakeholders always reference the same version.

Common pitfalls:

- Roadmap built as a static slide at kickoff and never updated - by month 3 it bears no resemblance to the actual program status and stakeholders stop trusting it.
- Dependencies between workstreams shown as arrows with no owner or status - when a predecessor slips, no one has accountability to alert the successor workstream lead.
- Milestones expressed as ranges or quarters ('Q3 2026') with no specific date or go/no-go criteria - this makes the roadmap unactionable and allows sustained slippage to go unrecognised.
- Governance gates and decision points omitted from the roadmap - the program arrives at a funding approval or regulatory submission date without the required inputs because no one tracked the preparation timeline.
- Roadmap conflated with the detailed project schedule - when every task appears on the roadmap, the strategic signal is lost and SteerCo disengages from the artifact.

Maturity (1-5): L1 Ad hoc - no formal program roadmap; timelines communicated informally or via individual project schedules; cross-workstream dependencies not visible at program level; L2 Defined - a program roadmap exists, is baselined at program start, and shows workstream swim lanes and milestones; updated at major events but not on a regular cadence; L3 Managed - roadmap reviewed and updated monthly at the Program Board; dependencies tracked with owners; forecast vs baseline variance visible; distributed to SteerCo ahead of each governance cycle; L4 Quantified - roadmap variance is measured and reported (schedule performance index or equivalent); dependency resolution time tracked; milestone forecast accuracy measured over rolling quarters; roadmap drives formal change control when milestones shift; L5 Optimizing - roadmap is dynamically linked to the scheduling tool and benefits realisation tracker; scenario models (optimistic/base/pessimistic) maintained; lessons from previous rebaselines feed planning accuracy improvements; program roadmap feeds the portfolio-level roadmap in real time.

Artifact #58 — Program Closure Report

Purpose: Formally closes the program by confirming all component deliveries or transfers, handing benefit ownership to BAU, consolidating program-level lessons, achieving financial closure, disbanding the program team, and securing sponsor and assurance sign-off so that records can be archived and the program infrastructure stood down.

When you use it: Initiated when the last component project achieves closure and all in-flight benefits have been formally assigned to receiving business owners; completed before the Program Manager is released. Typically follows a final Program Board or SteerCo sign-off meeting.

Owner: Program Manager owns drafting and assembly; Senior Responsible Owner (SRO) signs. Benefits owners, component Project Managers, Finance, and the independent assurance reviewer each contribute their sections.

Cadence: One-time document; drafted over 4-6 weeks, circulated for review, and signed no later than the program end-date recorded in the Program Business Case.

Where it lives: Stored in the program SharePoint under /Governance/Closure; version-controlled with sign-off captured in the document or a linked approval workflow; final PDF archived in the enterprise programme record system.

Sections / contents:

Section	Contents / fields
Executive Summary	One-page narrative: program mandate, total duration, total spend vs. approved budget, headline benefits realized vs. forecast, and the SRO formal closure declaration.
Mandate & Objectives Review	Restate the original program objectives from the Program Brief and Business Case; assess each as Fully Met, Partially Met, or Deferred/Cancelled with brief rationale.
Component Delivery Summary	Table listing every component project: delivery scope, planned vs. actual schedule, planned vs. actual cost, quality gate outcome, and formal close date.
Benefits Realization Status	Map each benefit from the Benefits Realization Plan to its current status (Realized, In-Progress, Not-Yet-Measurable), the baseline metric, latest measurement, variance, and the named BAU owner accepting ongoing measurement responsibility.
Outstanding Items & Conditions	Log of any residual issues, deferred scope, open risks, or contractual retentions; for each item: owner, resolution action, and target date post-closure.
Financial Closure	Total approved budget (including contingency draw-down), actual expenditure, variance, explanation of material variances, confirmation that purchase orders are closed and accruals released, and Finance sign-off.
Lessons Learned Consolidation	Synthesized themes from all component project lesson logs plus program-level retrospectives; organized by domain (delivery, benefits, governance, vendor, technology); priority recommendations for future programs.
Stakeholder & Communications Closure	Confirmation that all stakeholder groups have been formally notified, transitional communications issued, and that no outstanding engagement commitments remain.
Team Disbandment & Transition	Schedule of team member release dates, roles transitioned to BAU, knowledge transfer completion status, and confirmation that system access has been revoked per the security close-down checklist.
Assurance & Sign-Off	Independent assurance review findings, any caveats or conditions attached to sign-off, and signature blocks for SRO, Program Manager, Finance Director, and Lead Assurance Reviewer.

Section	Contents / fields
Archive Index	Location and retention schedule for all program artifacts: Business Case versions, Blueprints, Risk Register, Benefits Realization Plan, Decision Log, contracts, and this report.
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to MSP (Managing Successful Programmes) Closing a Programme process and Realizing the Benefits theme: confirm capability delivered, measure benefit uptake, hand to operations, close governance. Also references PMI Standard for Program Management (4th ed.) Phase: Program Closure - benefits transition, stakeholder communication, and financial close. Method: confirm component closure -> assess benefits realization -> transfer BAU ownership -> achieve financial closure -> consolidate lessons -> secure sign-off -> archive.

Guiding principles: Closure is an obligation not a formality - the program has not ended until benefits ownership is formally accepted by BAU; every unresolved item must have a named post-closure owner and date; financial closure and access revocation are security and audit requirements, not optional; lessons are only valuable if synthesized and routed to the portfolio/enterprise lessons library.

What good looks like:

- Every benefit in the Benefits Realization Plan has a named BAU owner who has signed acceptance and a scheduled measurement date beyond program close.
- Financial closure section reconciles every approved budget line with actuals and carries a dated Finance Director sign-off.
- Lessons consolidation produces 5-8 actionable, prioritized recommendations routed to the portfolio management office rather than a generic list.
- Outstanding items table has zero items without an owner and a post-closure resolution date, and the SRO has explicitly accepted the residual risk of each.
- Archive index is comprehensive enough that an auditor or future program could reconstruct all key decisions without contacting any former team member.

Common pitfalls:

- Declaring closure before BAU owners have formally accepted benefits measurement responsibility - benefits then fall into a void and are never tracked.
- Skipping financial closure because the program is 'mostly done' - open POs and accruals create audit findings and distort portfolio cost reporting.
- Producing a lessons section that is a verbatim dump of project logs with no synthesis - executives cannot act on it and it is never referenced again.
- Allowing the team to disperse before knowledge transfer and access revocation are complete, creating security gaps and loss of institutional memory.
- Treating the closure report as a rubber stamp rather than a genuine assurance event - unresolved issues get buried and surface 12 months later as governance failures.

Maturity (1-5): L1 Ad hoc: closure is verbal or an email; no formal document, benefits left unmeasured, team simply stops. L2 Defined: closure report template exists and is completed, but benefits ownership transfer is informal and lessons are not synthesized. L3 Managed: all sections completed with named owners; benefits handed to BAU with measurement schedule; financial closure confirmed; report reviewed by assurance. L4 Quantified: closure triggers a post-program benefits audit at 6 and 12 months; lessons are tracked to confirm adoption in subsequent programs; closure quality scored against a checklist. L5 Optimizing: closure data

feeds portfolio analytics; benefit realization rates influence future business case approval thresholds; lessons drive continuous improvement of the program management framework.

Artifact #59 — Tranche & Release Plan

Purpose: Structures the program's delivery into discrete tranches, each aligned to a step-change in organizational capability and a measurable set of benefits, and defines the release schedule within each tranche; also governs the End-of-Tranche Review (EoTR) decision gate that determines whether the program proceeds, re-plans, or stops before committing to the next tranche.

When you use it: Initially drafted during program planning when the Blueprint and Benefits Realization Plan are stable enough to sequence capability. Updated before each EoTR to reflect delivery actuals and revised benefit forecasts. Each release within a tranche is scheduled in coordination with the affected component project plans.

Owner: Program Manager owns the plan and EoTR facilitation. Business Change Manager co-owns the tranche outcomes and readiness assessment. Component Project Managers own release scheduling within their projects.

Cadence: The plan itself is a living document updated at each EoTR (typically every 3-6 months depending on tranche length). Individual release entries are updated monthly as part of the program progress report cycle.

Where it lives: Stored in program SharePoint under /Governance/Tranche-Plan; a summary roadmap view is embedded in the Program Dashboard. The EoTR decision record is appended to this document as a dated annex.

Sections / contents:

Section	Contents / fields
Program Tranche Map	High-level timeline showing all tranches end-to-end, their outcome labels, and the EoTR gate between each; aligned to the program Blueprint capability model.
Tranche Definition	For each tranche: tranche ID and name, start/end dates, target capability state (what the organization can do that it could not before), benefits expected to be evidenced by end of tranche, and key assumptions.
Release Schedule	For each release within a tranche: release ID, component project, release scope (features/capability increments), target date, dependency on other releases, readiness criteria, and deployment window.
Tranche Dependencies & Constraints	Cross-tranche and cross-component dependencies; external dependencies (vendor milestones, regulatory dates, BAU freeze windows); constraints on sequencing.
Benefit Realization Checkpoints	For each tranche: which benefits are expected to be measurable, what the measurement method is, who owns the measurement, and what the minimum acceptable result is to support a 'proceed' decision at the EoTR.
End-of-Tranche Review (EoTR) Protocol	Standard agenda, attendees (SRO, Program Board, Business Change Manager, component PMs), evidence pack required (delivery status, benefit measurements, risk profile update, next-tranche readiness), decision options (Proceed / Re-plan / Stop), and decision authority.
EoTR Decision Record (per	Dated record of each EoTR: tranche reviewed, evidence summary,

Section	Contents / fields
tranche)	benefits realized vs. forecast, outstanding risks, decision made, conditions attached, next-tranche commitment level (full / conditional / deferred).
Next-Tranche Readiness Criteria	Checklist that must be green before full commitment to the next tranche: funding confirmed, resources secured, dependencies resolved, Blueprint updated, Benefits Realization Plan refreshed.
—— PRACTITIONER REFERENCE ——	

Standards & method: Directly implements MSP (Managing Successful Programmes) Delivery Management theme and Tranches concept: tranches represent a coherent step of capability delivery; EoTR reviews provide the go/no-go gate aligned to benefit realization evidence. Also references PMI Standard for Program Management (4th ed.) Program Delivery Phase - component authorization and benefit delivery monitoring. Method: define Blueprint capability states -> group releases into tranches -> set tranche benefit checkpoints -> execute releases -> run EoTR with evidence -> decide and commit -> repeat.

Guiding principles: Tranches are capability steps not calendar blocks - a tranche ends when the organization reaches a defined capability state, not just when the clock runs out; the EoTR is the program's most important governance event and must be evidence-based, not a formality; commitment to the next tranche is conditional on the current tranche delivering its foundation; release scheduling must be driven by business readiness and benefit opportunity, not purely technical convenience.

What good looks like:

- Each tranche has a named, measurable capability outcome stated in business terms (e.g., 'all 4,200 seats on ZPA; VPN decommissioned') rather than a deliverable list.
- The benefit realization checkpoint for each tranche specifies a minimum acceptable measurement result - if the result is below this, the EoTR is obliged to consider re-plan or stop, not auto-proceed.
- The release schedule within each tranche shows deployment windows agreed with BAU operations and Change Advisory Board, not just go-live dates set by the delivery team.
- EoTR decision records are dated, signed, and appended to the plan so the program has an auditable trail of every proceed/re-plan/stop decision.
- The next-tranche readiness checklist is completed at least 4 weeks before the EoTR so that gaps can be resolved before the gate, not discovered during it.

Common pitfalls:

- Defining tranches by time period or project delivery waves rather than by capability state - the program then has no meaningful gate criterion and the EoTR becomes a progress report.
- Omitting the minimum acceptable benefit measurement threshold - the EoTR then has no basis to recommend anything other than proceed.
- Allowing release scheduling to be driven entirely by the technical team without BAU operations input, resulting in releases during peak business periods or change-freeze windows.
- Treating the EoTR as a monthly steering committee with a renamed agenda - it must be a distinct, evidence-based decision event with the authority to stop or re-plan the program.
- Not updating the plan after each EoTR - the tranche plan becomes a historical artifact rather than a live decision framework.

Maturity (1-5): L1 Ad hoc: delivery is sequenced by project convenience; no formal tranches; no gate between phases. L2 Defined: tranches defined on a timeline with labels; EoTR exists but is a progress review with auto-proceed. L3 Managed: tranches have capability outcomes and benefit checkpoints; EoTR uses evidence pack; decision is recorded; next-tranche readiness assessed. L4 Quantified: benefit thresholds are numeric and statistically defensible; EoTR evidence compared to forecast with variance analysis; proceed/re-plan decisions tracked for accuracy. L5 Optimizing: tranche plans inform portfolio investment decisions; EoTR data feeds benefits forecasting models; release cadence is optimized based on business value delivery rate.

Artifact #60 — Program Risk Management

Purpose: Establishes the program-level risk management framework: aggregates component project risks into a consolidated program view, identifies and owns systemic, cross-component, and strategic risks that no single project can manage, sets the program risk appetite and escalation thresholds, and tracks risks to benefits realization - ensuring the program's risk posture is visible to the SRO and Program Board at all times.

When you use it: Framework established during program planning; program risk register populated as component projects are initiated; reviewed and updated at every Program Board meeting and at each EoTR; escalation thresholds calibrated before each tranche commitment.

Owner: Program Manager owns the program risk register and the aggregation process. SRO owns program risk appetite and accepts residual risks above threshold. Business Change Manager owns benefit-realization risks. Component PMs own project-level risks and are responsible for escalating program-level risks upward.

Cadence: Full register review at each Program Board (monthly or per governance cycle). Risk appetite and threshold review at each EoTR. Immediate escalation for any risk breaching the Red threshold between cycles.

Where it lives: Program Risk Register maintained in program SharePoint /Risk/ProgramRisk_Register.xlsx; risk heatmap published in the Program Dashboard. Component project risk registers are linked (not merged) so aggregation is traceable.

Sections / contents:

Section	Contents / fields
Program Risk Appetite Statement	SRO-approved statement of the program's tolerance for risk across dimensions: schedule, cost, benefits realization, security, regulatory compliance, and reputational. Expressed as qualitative boundaries (e.g., 'zero tolerance for PCI-DSS compliance risk; medium tolerance for schedule risk within a tranche') and, where possible, quantitative thresholds.
Risk Escalation Protocol	Defines the escalation path from component project to program to portfolio/sponsor. Includes: trigger criteria (probability x impact score, or named risk categories that always escalate), escalation timescale (e.g., within 2 business days for Red risks), recipient (Program Manager, SRO, Program Board, Portfolio), and required content of an escalation.
Program Risk Register	For each program-level risk: Risk ID, category (systemic/cross-component/strategic/benefit-realization/external), description, owner, probability (1-5), impact (1-5), current score, trend (improving/stable/worsening), response strategy (avoid/transfer/mitigate/accept), response actions with due dates, residual score, and escalation status.

Section	Contents / fields
Aggregated Component Risk View	Summary of risks escalated from component projects: source project, original risk ID, description, reason it is a program risk (systemic pattern, cross-component dependency, or exceeds project authority), program risk ID it maps to, and current status.
Systemic & Cross-Component Risks	Risks that emerge from the interaction of multiple components or the cumulative effect of lower-level risks: risk description, which components contribute, combined probability/impact assessment, and the response owned at program level.
Risks to Benefits Realization	For each program benefit: identified threats to realization, current probability and impact on benefit achievement, response owner (typically Business Change Manager or BAU owner), and the minimum benefit threshold below which the EoTR would trigger a re-plan.
Risk Reporting Summary	One-page heatmap and narrative for Program Board: top 5 risks by current score, trend indicators, risks approaching the appetite boundary, any new risks since last cycle, and recommended decisions or actions for the Board.
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to ISO 31000:2018 Risk Management principles and process (risk identification, analysis, evaluation, treatment, monitoring). Also references PMI Standard for Program Management (4th ed.) Risk Management in programs: aggregation of component risks and strategic risk ownership. MSP (Managing Successful Programmes) Risk theme: program risk appetite, risk escalation between project and program, and risk to benefits realization. Method: set appetite -> populate program register -> aggregate component risks -> identify systemic risks -> assess benefit threats -> report to Board -> treat -> monitor -> repeat.

Guiding principles: Program risk management is not project risk management scaled up - it exists to own what no single project can; risk appetite is set by the SRO and is non-negotiable without SRO sign-off; aggregation reveals systemic patterns that individual project logs hide; every risk to benefits realization must have an owner who can actually influence the outcome.

What good looks like:

- The Risk Appetite Statement is specific and dimensional - it distinguishes between risk categories and states quantitative or semi-quantitative boundaries rather than 'low/medium/high' labels alone.
- The aggregated component view shows which program risks are the result of a pattern across multiple projects (e.g., vendor delivery slippage across 3 components) rather than treating each project's risk in isolation.
- Systemic risks are identified that are not visible in any individual project register - these are the risks that justify program-level risk management existing at all.
- Every benefit in the Benefits Realization Plan has at least one corresponding risk entry in the Risks to Benefits Realization section with a named owner.
- The Risk Reporting Summary is genuinely useful to the Program Board: it presents a decision or action per risk, not just a status update.

Common pitfalls:

- Treating the program risk register as a consolidated copy-paste of all project risk registers - this creates noise and obscures the systemic and strategic risks that the program should own.
- Setting risk appetite as a single 'medium' label across the whole program - this provides no guidance when a risk in one category (e.g., regulatory compliance) should be treated very differently from one in another (e.g., schedule).
- Allowing risks to benefits realization to sit only in the Benefits Realization Plan without appearing in the risk register - they are then invisible to the governance cycle.
- Not defining escalation trigger criteria precisely - program managers then make subjective judgments about what to escalate, and high-impact risks can be managed at project level without the SRO's knowledge.
- Updating the risk register only once per tranche rather than every governance cycle - the program's risk posture can change faster than a quarterly review cycle.

Maturity (1-5): L1 Ad hoc: program risk is a copy of the largest project risk register; no appetite statement; no escalation protocol. L2 Defined: separate program risk register exists; escalation protocol defined; appetite statement qualitative. L3 Managed: aggregation from component projects is systematic; systemic risks identified; benefit realization risks tracked; appetite has quantitative boundaries in at least 2 dimensions. L4 Quantified: risk scores calibrated with historical data; appetite boundaries linked to benefit sensitivity analysis; escalation compliance rate measured; trend data drives early warning. L5 Optimizing: program risk posture feeds portfolio risk aggregation; risk response effectiveness is measured and informs risk planning on future programs; AI-assisted pattern detection across component risk logs.

Appendix D — Scaling Guide

Not all 32 artifacts apply to every project. Use this guide to scope which artifacts to produce based on project size, complexity, and risk profile.

How to read this guide

- Required = produce this artifact, even if lightweight. Non-negotiable for the tier.
- Recommended = produce unless there's a specific reason not to. Document the reason in your charter.
- Optional = produce when scope or complexity warrants it. Most small projects skip these.

Tier 1 — Small project

Indicators: <3 months duration, <\$250K budget, single team, low regulatory exposure, well-understood scope.

Section	Contents / fields
Required	Project Charter (#1) — lightweight, 1-2 pages. Stakeholder Register (#3). RAID Log (#11). Schedule (#12). Status Reports (#18) — bi-weekly OK. Decisions & Changes Log (#19). Closeout (#23).
Recommended	Kickoff Pack (#2) — agenda only, skip pre-read. RACI (#4). Resource Plan (#13). Lessons Learned (#22).
Optional	BRD/Tech Spec (#6, #7) — only if scope is unclear. Comms Plan (#8) — informal often OK. Budget tracking — only if Finance requires it.
Skip	OCM Plan (#9), Training Plan (#10), RFP/SOW (#15-#17), Steering Pack (#20), Program-level (#24-#26), Operating Model (#29).

Tier 2 — Medium project

Indicators: 3-12 months, \$250K-\$2M, cross-team, moderate regulatory exposure, scope refinable but defined.

Section	Contents / fields
Required	All Tier 1 Required + Project Charter (formal, signed). RACI (#4). BRD (#6). Tech Spec (#7) — if technical project. Comms Plan (#8). Resource Plan (#13). Budget (#14). Steering Pack (#20).
Recommended	OCM Plan (#9) — if change has user-facing impact. Training Plan (#10) — if new tools or processes. UAT Plan (#21). Retrospective (#30).
Optional	RFP/Scoring/SOW (#15-#17) — if procuring. Post-Incident pack (#31, #32) — only if incident occurs. Operating Model (#29).
Skip	Program-level artifacts (#24-#26) unless multiple
Section	Contents / fields coordinated projects.

Tier 3 — Large project / Program

Indicators: >12 months, >\$2M, multi-team or multi-component, high regulatory exposure, significant org change.

Section	Contents / fields
Required	All Tier 2 Required + Program Charter (#24) if multi- initiative. Program Governance (#25). Program Benefits Realization (#26). Comms Plan (#8) — formal. OCM Plan (#9). Training Plan (#10). Steering Pack (#20). Operating Model (#29) — if program builds a durable function. Post- Incident pack (#31, #32) — pre-built, not just on demand.
Recommended	Portfolio Dashboard (#28). All procurement artifacts (#15- #17). Retrospective per phase (#30).
Optional	Project Intake Form (#27) — only relevant for the requesting org's PMO.
Skip	Nothing in this tier should be skipped without explicit governance approval.

Other scaling factors

- Regulatory or audit-driven projects: bump up one tier on documentation rigor regardless of size. Auditors expect Charter, RAID, Decisions & Changes, and Closeout for any audit-relevant work.
- New-to-org capabilities: bump up on OCM, Training, and Comms even for small projects — adoption risk is the issue, not budget.
- Vendor-heavy projects: produce all procurement artifacts (#15-#17) even if the spend is small — vendor disputes are about contracts, not budget size.
- High-visibility projects: Steering Pack (#20) becomes Required regardless of size if the project goes to executives or board.

Program Management · Templates (32)

Template — Operating Model Document

Codifies how a function, business unit, or program operates day-to-day. Different from a Charter (one-time authorization). The operating model is the durable description of how the work runs.

See example: PMO_Examples.docx 5 (Cloud Security Operations function — soup-to-nuts with 15-row meeting cadence, service catalog, KPIs with targets, and full org structure).

AI enablement

- Detect operating model drift — when actual practice diverges from documented model.
- Recommend operating model updates when org changes, tooling changes, or strategy shifts.
- Generate role-specific playbooks from the operating model.
- Surface inefficiencies — duplicate processes, role overlap, decision bottlenecks.

Document Control

Function / unit / program [Name]

name

Operating model version	[v1.0]
Owner	[Function head]
Date	[Date]
Review cadence	[Annual, or on material change]
— HOW TO USE THIS TEMPLATE —	

Completion guidance: Begin with the future-state process map and the service delivery model before defining any roles or governance structures, because organizational design must follow the work, not the existing org chart; this requires a full-day workshop with the process owners, operations lead, and the executive sponsor. The current-state baseline must be documented first (headcount, handoffs, SLAs, pain points) so the operating model change can be quantified. Inputs are the project scope, any organizational design study output, regulatory or compliance mandates, and the target architecture from the technical spec. Expect 4-6 weeks to develop a credible operating model document for a significant transformation.

A strong completed version:

- The service delivery model section distinguishes what the organization does itself from what it sources externally, with a rationale for each boundary decision.
- Each process in the operating model has a named role responsible for it, a defined SLA, and a performance metric, not just a description of what the process does.
- The governance section defines how the operating model will be monitored and updated over time, including a named body responsible for model stewardship.
- Transition-state operating model (the path from current to future state) is documented separately from the end-state model, because most organizations will operate in a hybrid mode for 12-24 months.

Common pitfalls when filling it in:

- Designing the future-state operating model around the current org chart rather than around the future-state processes, producing a cosmetically renamed version of the status quo.

- Omitting the technology and data layer from the operating model so the document cannot explain how manual and automated activities interact.
- Defining roles and responsibilities at a level of abstraction so high ('the Operations Team manages transactions') that the model provides no guidance for day-to-day decision-making.
- Treating the operating model as a static deliverable rather than a governed document with an owner, a review cadence, and a version history.

Template — Operating Model Document → Approval & Review

Function head sign-off	[Name, date]
Sponsor / executive	[Name, date]

sign-off

Last review date	[Date]
Next scheduled review	[Date]
Material changes since	[Bullet summary]

last version

End of templates pack. For methodology, framework context, and AI-enablement detail across the full PMO lifecycle, see PMO_Framework.docx.

Template — Operating Model Document → Budget & Financial Model

- [Annual operating budget]
- [Major cost categories — labor, tools, vendor, infrastructure]
- [Cost allocation model — chargeback, shared service, central]
- [Capex vs opex breakdown]

Template — Operating Model Document → Capacity & Workforce Plan

•	[Current headcount and roles]
•	[Forecast demand vs capacity over next 12 months]
•	[Critical skills and gap analysis]
•	[Hiring plan and succession risks]
•	[Vendor / contractor dependencies]

Template — Operating Model Document → Continuous Improvement

- [How the function captures and acts on operational lessons]
- [Cadence of operating model review]
- [Innovation / capability evolution roadmap]

Template — Operating Model Document → Core Processes

Process	Trigger	Owner	Outputs	Linked SOP
[Process 1]	[What triggers it]	[Owner role]	[What it produces]	[Doc reference]

Process	Trigger	Owner	Outputs	Linked SOP
[Process 2]	[...]	[...]	[...]	[...]

[...]

Template — Operating Model Document → External Dependencies

- [Vendors and what they provide]
- [Other internal functions we depend on]
- [Regulatory bodies and compliance dependencies]
- [Customer or partner dependencies]

Template — Operating Model Document → Governance & Decision Rights

Forum	Purpose	Frequency	Attendees	Decisions made here
[Leadership team]	[Purpose]	[Weekly]	[Roles]	[What gets decided]
[Operating	[Purpose]	[Monthly]	[Roles]	[What gets decided]

review]

[Strategy review]	[Purpose]	[Quarterly]	[Roles]	[What gets decided]
Forum P	urpose F	requency Att	endeeds Dec	isions made here
[Steering [	Purpose] [	Monthly] [Ro	les] [Wh	at gets decided]

committee]

Escalation path

[How issues escalate from working level to executive. Time-bound at each tier.]

Template — Operating Model Document → KPIs & Performance Metrics

KPI	Definition	Target	Source	Reported to
[KPI 1]	[Plain-language definition]	[Target]	[Data source]	[Forum]
[KPI 2]	[...]	[...]	[...]	[...]

[...]

Template — Operating Model Document → Organization Structure

Organization chart

[Reference org chart — who reports to whom, team sizes, geographic distribution.]

Roles

Role	Responsibilities	Decision authority	Reports to
[Role 1]	[Specific responsibilities]	[What they can decide alone]	[Manager role]
[Role 2]	[...]	[...]	[...]

[...]

Template — Operating Model Document → Purpose & Mandate

Mandate

[The function's purpose stated in 1–2 sentences.]

Strategic alignment

[Which corporate goals or pillars this function serves.]

Outcomes the function delivers

[Specific outcomes — not activities.]

Template — Operating Model Document → Scope of the Function

In scope

[What this function owns.]

Out of scope

[What other functions own that might be confused with this one.]

Boundaries with adjacent functions

Adjacent function	What they own	Where we coordinate	Who owns the boundary
[Function A]	[Their scope]	[Specific touchpoints]	[Person]
[Function B]	[...]	[...]	[...]

[...]

Template — Operating Model Document → Tools & Systems

Tool	Used for	Owner	Integrations
[Tool 1]	[Purpose]	[Admin role]	[What it integrates with]
[Tool 2]	[...]	[...]	[...]

[...]

Template — Portfolio Prioritization & Scoring Model

Fillable portfolio prioritization model.

Sections:

- Criteria & weights table: criterion | weight (%) | scale definition (1-5)
- Initiative scorecard: initiative | criterion scores | weighted total | rank
- Tiering thresholds (must/should/defer)
- Capacity overlay: cumulative effort of ranked list vs available capacity; the cut line
- Governance decision log: initiative | decision | rationale | date | approver
- Override/tie-break policy

HOW TO USE THIS TEMPLATE

Completion guidance: Define and weight the scoring dimensions (strategic alignment, financial return, risk, urgency, resource feasibility) before scoring a single project; weighting is a governance decision that must be approved by the portfolio steering committee, not set by the PMO unilaterally. Convene the portfolio owner, CFO delegate, and business unit heads for a 90-minute calibration session to agree weights and scoring anchors, using the strategic plan and current investment budget as inputs. Score projects immediately after in a separate session so the weighting discussion and the scoring discussion are not conflated.

A strong completed version:

- Scoring rubric for each dimension has defined anchors at each level (1, 3, 5 or equivalent) so two scorers independently reach the same score for the same project.
- The model outputs a ranked list AND a quadrant or tiering view that communicates relative priority visually to executives.
- Weighting rationale is documented and version-controlled so future portfolio reviews can detect if strategic priorities shifted the weights, not the projects.
- Capacity constraint is modeled alongside priority score, so a high-scoring project that cannot be resourced is flagged as 'backlogged - resource constrained' rather than appearing executable.

Common pitfalls when filling it in:

- Allowing individual business unit sponsors to score their own projects, introducing self-advocacy bias that invalidates the ranking.
- Setting weights after seeing the scores, reverse-engineering the outcome to validate a predetermined portfolio decision.
- Scoring projects at different levels of definition (some with full business cases, some with slide-deck concepts), making point comparisons meaningless.
- Producing a priority ranking without linking it to resource capacity, so the model approves more work than the organization can absorb.

Template — Program Capacity & Demand Management Plan

Fillable capacity & demand plan.

Sections:

- Supply table: team/skill | FTE | available hrs per period | leave adjustments
- Demand table: initiative | skill | hrs by period
- Heatmap: skill/team x period, % allocation with over/under flags
- Constrained-role list and mitigation options
- Scenario block: 'add initiative X' / 'defer initiative Y' impact
- Decisions & assumptions log

HOW TO USE THIS TEMPLATE

Completion guidance: Baseline current capacity by resource type (role, skill tier, team) before logging any demand; demand against an undefined supply base produces a heat map with no diagnostic value. The PMO lead and resource managers should complete the capacity baseline in a 90-minute session using headcount data, confirmed leave calendars, and shared-service allocation agreements as inputs. Demand is then loaded from the approved project portfolio and the program milestone schedule, with owners confirming forecasts for at least a rolling 3-month horizon.

A strong completed version:

- Capacity is expressed in role-weeks or story points by named team, not in headcount FTEs, so it translates directly to delivery commitments.
- Demand forecast extends at least one planning horizon beyond the current quarter, enabling proactive hiring or vendor augmentation decisions before a gap becomes a crisis.
- Conflicts are surfaced as named individuals or teams double-committed across projects, not just as aggregate percentages that mask individual overload.
- Scenario analysis shows the portfolio delivery impact of losing one or two critical specialists, quantified in weeks of delay per project.

Common pitfalls when filling it in:

- Recording capacity as organizational headcount rather than available working capacity after leave, ceremonies, BAU, and overhead are deducted, overstating supply by 20-30%.
- Treating resource forecasts as static after initial load, so the plan reflects the portfolio as-planned rather than as-it-is-executing.
- Failing to distinguish between interchangeable capacity (e.g., junior developers) and bottleneck capacity (e.g., one cloud security architect), making all shortfalls look equally solvable.
- Not linking the demand plan to the portfolio prioritization model, so when capacity is short there is no agreed basis for deciding which project absorbs the reduction.

Template — Program Charter (Multi-Initiative)

Authorizes a program — a coordinated set of projects sharing a common strategic outcome. Heavier than a project charter because programs have more components, longer horizons, and benefits that materialize across initiatives. Built to PgMP depth: includes program governance, integration management, benefits realization roll-up, workstream coordination, and program-level risk.

AI enablement

- Cluster intake-form initiatives into candidate programs based on goal similarity and dependency overlap.
- Roll up component-project benefits to test whether the program-level value case holds.
- Surface cross-component dependency conflicts and resource collisions early.
- Generate program-level executive summary from component-project status reports automatically.

Program Identification

Program name	[Name]
Program ID / code	[ID]
Program sponsor	[Name, title]

(Executive)

Program manager	[Name, title]
Date / version	[Date / vN]
Strategic theme / pillar	[Linked corporate goal or OKR]
Component projects	[Number]

(count)

Program duration	[Start date – Target end date]
Total program budget	[\$]
—— HOW TO USE THIS TEMPLATE ——	

Completion guidance: Open with the strategic objective and governance model before filling any initiative row, because every downstream field - budget envelope, interdependencies, success metrics - must ladder up to those anchors; this requires the program sponsor, portfolio owner, and each initiative lead together for at least two hours. Inputs are the approved portfolio plan, individual project charters, and any enterprise strategic plan or OKR framework in effect. Expect two or three revision cycles as initiative owners reconcile overlapping scope and shared resources.

A strong completed version:

- The governance section names a decision escalation path with time-boxed SLAs (e.g., 'initiative-level decisions in 48 hours, program-level in 5 business days, executive escalation in 10').
- Each initiative row shows its dependencies on other initiatives with directional arrows, not just a list of related projects.
- The budget table distinguishes allocated, committed, and forecasted spend across all initiatives and rolls to a program total.
- The charter is signed by the executive sponsor and each initiative lead, making accountability explicit at both levels.

Common pitfalls when filling it in:

- Defining program scope as the sum of initiative scopes rather than articulating the cross-cutting value that only the program as a whole delivers.
- Leaving interdependency cells blank or marking them all 'TBD', which defeats the purpose of a multi-initiative view.
- Assigning one person as both program manager and initiative lead, then failing to note the conflict of interest in the RACI.
- Treating the charter as a one-time artifact and never convening governance to formally amend it when scope or sponsorship changes.

Template — Program Charter (Multi-Initiative) → Approvals

Program sponsor [Name, date, signature]

approval

PMO approval	[Name, date]
Finance approval	[Name, date]
Component sponsors	[List names + dates]

acknowledged

Template — Program Charter (Multi-Initiative) → Integration Management

Cross-component dependencies

[The most common source of program failure. Track more carefully than within-component risks. Reference the workbook RAID Log for live tracking.]

Dependency	From component	To component	Type	Risk if missed	Owner
[What is needed]	[Source]	[Consumer]	[Data / Code / Decision / Resource]	[Impact]	[Owner]

[...]

Shared resources

[People, teams, or systems serving multiple components. Surface contention proactively.]

Integration risks

[Risks existing only because we're running these together — interface mismatches, coordinated launches, sequencing failures.]

Workstream coordination model

[How component teams synchronize: standing integration meetings, shared planning rituals, joint design reviews, integrated release planning.]

Template — Program Charter (Multi-Initiative) → Program Benefits Realization

Benefits map

Benefit	Source component(s)	Realization timing	Measurement	Benefit owner post-program
[Benefit 1]	[Which components contribute]	[On launch / 3 mo / 12 mo]	[How measured]	[Operational owner]
[Benefit 2]	[...]	[...]	[...]	[...]

[...]

Benefits roll-up

[How component-level benefits aggregate to program-level value. Programs should deliver more than the sum of their components — capture that incremental value here.]

Benefits sustainment

[How benefits are sustained after the program closes. Programs deliver capabilities; the operating organization sustains them.]

Template — Program Charter (Multi-Initiative) → Program Budget

Total approved program [\$]

budget

Component budget [Project A: \$X, Project B: \$Y, ...]

allocations

Program contingency	[\$ — typically 10–20% for cross-component reallocation]
Funding source	[Capex / opex, department, capital request ID]
Budget authority	[Who approves overages at program vs component level]

Template — Program Charter (Multi-Initiative) → Program Governance

Governance structure

[Typical structure: Program Steering Committee (executive), Program Board (operating), component PMs report to Program Manager.]

Forum	Purpose	Frequency	Attendees	Decisions made here
Program Steering Committee	Executive governance, escalations, strategic direction	Monthly	Sponsor, exec coalition, Program Manager	Scope changes affecting program, budget reallocations, risk acceptance
Program Board (Operating)	Operational coordination across components	Bi-weekly	Program Manager, component PMs, function leads	Cross-component coordination, dependency resolution, resource balancing
Component PM forum	Working-level coordination	Weekly	Component PMs, Program Manager	Tactical issue resolution, status sharing
Quarterly Business Review	Benefits realization and strategic alignment	Quarterly	Sponsor, exec coalition, business owners	Confirm program continues to serve strategy; adjust priorities

Decision rights — program vs component

[Which decisions sit at program level vs component level.]

Decision type	Component PM authority	Program Manager authority	Sponsor / Steering authority
Within-component scope	Decide	Notify	Notify

changes (no cross-impact)

Cross-component scope changes Recommend Decide Notify

changes

Component budget reallocation within budget Decide Notify Notify

Cross-component budget	Recommend	Decide	Notify (above threshold: approve)
reallocation			
Vendor selection for shared	Recommend	Decide	Approve

platform

Component delay impacting

Notify

Decide mitigation

Approve replan

program critical path

Component cancellation	Recommend	Recommend	Decide
Program-level risk acceptance	Recommend	Recommend	Decide

Escalation path

[Time-bound escalation: working level → component PM → Program Manager → Sponsor → Steering. Each tier has a max time before escalation.]

Template — Program Charter (Multi-Initiative) → Program Risk Profile

Program-level risks span components or threaten the strategic outcome. Different from component risks — track them separately.

Risk	Likelihood	Impact	Mitigation strategy	Owner
Regulatory change affecting	[H/M/L]	[H/M/L]	[Strategy]	[Owner]

multiple components

Key shared resource [H/M/L] [H/M/L] [Strategy] [Owner]

unavailable

Integration failure between [H/M/L] [H/M/L] [Strategy] [Owner]

components

Sponsor departure / strategy [H/M/L] [H/M/L] [Strategy] [Owner]

shift

Component cancellation [H/M/L] [H/M/L] [Strategy] [Owner]

breaks program value

[...]

Template — Program Charter (Multi-Initiative) → Program Scope

Components (in-scope projects / initiatives)

Component	Owner / PM	Goal	Dependency type	Component status
[Project / initiative 1]	[DRI]	[What it delivers]	[Sequenced / Parallel / Shared infra]	[Phase]
Component	Owner / PM	Goal	Depend type	Component status
[Project / initiative 2]	[DRI]	[What it delivers]	[Sequenced / Parallel / Shared infra]	[Phase] el /

Component	Owner / PM	Goal	Dependency type	Component status
				Shared
[Project / initiative 3]	[DRI]	[What it delivers]	[Sequenced / Parallel / Infrastructure]	Sequenced / Parallel / Shared

[...]

Out of scope

[Things that look related but are explicitly NOT part of this program.]

Template — Program Charter (Multi-Initiative) → Strategic Context

Strategic outcome the program delivers

[The single business outcome this program is built to achieve. If you can't state it in one sentence, you don't have a program; you have a portfolio of unrelated projects.]

Why a program (and not separate projects)

[What benefit comes from running these initiatives as a coordinated program rather than independent projects? Typical answers: shared infrastructure, sequenced dependencies, integrated change story, executive visibility, benefits realized only when components are delivered together.]

Strategic alignment

[Which corporate strategy / OKR / pillar this serves.]

Expected business value at program level

[Quantified value at program level. Distinguish what each component delivers from what only the program delivers as a whole.]

Template — Program Closure Report

Fillable Program Closure Report. Complete one row or cell per item. Sections marked [REQUIRED] must be filled before the report circulates for sign-off. Sections marked [FINANCE SIGN-OFF] require a dated signature from the Finance Director. Target completion: 4 weeks after last component project closes.

Sections:

- Executive Summary [REQUIRED] - program name, SRO, start date, end date, approved budget, actual spend, headline benefits realized vs. plan, closure declaration sentence.
- Mandate & Objectives Review [REQUIRED] - table: Objective | Source (Brief/Business Case) | Status (Met / Partial / Deferred) | Evidence / Notes.
- Component Delivery Summary [REQUIRED] - table: Component | PM | Planned Close | Actual Close | Budget | Actual Cost | Quality Gate Outcome.
- Benefits Realization Status [REQUIRED] - table: Benefit ID | Description | Baseline | Target | Latest Measure | Status | BAU Owner | Next Measure Date.
- Outstanding Items & Conditions [REQUIRED if any] - table: Item | Type (Risk/Issue/Scope/Contract) | Owner | Resolution Action | Target Date.
- Financial Closure [REQUIRED - FINANCE SIGN-OFF] - budget lines vs. actuals, contingency used, open POs/accruals status, Finance sign-off.

- Lessons Learned Consolidation [REQUIRED] - domain | lesson | recommendation | route-to (PMO/portfolio/enterprise).
- Stakeholder & Communications Closure - confirmation checklist: group notified, date, channel, confirmation received Y/N.
- Team Disbandment & Transition - table: Name | Release Date | Role Transition | Knowledge Transfer Complete | Access Revoked.
- Assurance & Sign-Off [REQUIRED] - assurance findings summary, conditions, signature blocks.
- Archive Index - artifact | location (URL/path) | retention period.

HOW TO USE THIS TEMPLATE

Completion guidance: Circulate the draft to all section owners at least 10 business days before the target sign-off date to allow Finance reconciliation and assurance review. The SRO should chair a 90-minute closure meeting to resolve any conditions before signing. File the signed PDF in the enterprise programme record system within 5 business days of the sign-off date.

A strong completed version:

- Benefits Realization Status table has zero blank 'BAU Owner' cells and every owner has been directly consulted, not just named.
- Financial Closure section carries a dated Finance Director signature and explains every variance exceeding 5% of the approved line.
- Lessons section has no more than 10 consolidated recommendations, each assigned to a specific team or forum for action.
- Outstanding Items table is either empty or every row has an owner who has explicitly acknowledged the item in writing.

Common pitfalls when filling it in:

- Circulating for sign-off before Finance has confirmed PO closure - the report will bounce and delay team release.
- Listing benefits as 'In Progress' with no scheduled measurement date - this is functionally the same as not tracking them.
- Allowing the assurance section to be completed by the Program Manager rather than an independent reviewer.
- Archiving the report before all hyperlinks in the Archive Index have been verified as accessible by someone other than the PM.

Template — Program Risk Management

Fillable Program Risk Management. Populate the Risk Appetite Statement with the SRO before Tranche 1 commits. The Program Risk Register should have at least 5-8 program-level risks identified at program initiation (before component projects begin) covering strategic, external, and benefit-realization categories. Component PMs should be briefed on the escalation protocol at their first component kickoff.

Sections:

- Program Risk Appetite Statement - table: Risk Category | Appetite Level | Quantitative Boundary (if applicable) | Rationale. Categories: Schedule, Cost, Benefits Realization, Security/Regulatory, Vendor/Third Party, Reputational. SRO signature and date.
- Risk Escalation Protocol - table: Trigger | Escalation Level | Recipient | Timescale | Required Content. Include named risk categories that always escalate (e.g., regulatory non-compliance, data breach, >10% cost variance).

- Program Risk Register - columns: Risk ID | Category | Description | Owner | Probability (1-5) | Impact (1-5) | Score | Trend | Strategy | Response Actions | Due Date | Residual Score | Escalation Status.
- Aggregated Component Risk View - columns: Source Project | Project Risk ID | Description | Reason Escalated | Program Risk ID | Status.
- Systemic & Cross-Component Risks - columns: Risk Description | Contributing Components | Combined P | Combined I | Score | Program Response | Owner.
- Risks to Benefits Realization - columns: Benefit ID | Benefit Description | Risk Description | P | I | Score | Response Owner | Minimum Benefit Threshold.
- Risk Reporting Summary (for Program Board pack) - heatmap (5x5 or 3x3), top 5 risks table, trend arrows, new risks since last cycle, recommended Board actions.

HOW TO USE THIS TEMPLATE

Completion guidance: The program risk register is never 'complete' - it is a living document that should be reviewed before every Program Board. Consider the register unhealthy if it has fewer than 8 active risks (likely under-identifying) or more than 30 (likely mixing project and program risks). The SRO should personally review the top 3 risks and the Risks to Benefits Realization section at every EoTR.

A strong completed version:

- The appetite statement has a specific quantitative boundary for at least the regulatory compliance and benefits realization categories.
- At least 2 systemic risks are identified that are not visible in any single component project register.
- Every benefit in the Benefits Realization Plan appears at least once in the Risks to Benefits Realization section.
- The escalation protocol has been briefed to all component PMs and is referenced in component project governance documentation.

Common pitfalls when filling it in:

- Populating the register by asking component PMs 'what are your top risks?' and copying the answers - this produces a project risk aggregate, not a program risk register.
- Leaving the Risk Appetite Statement blank or as a placeholder - without it the escalation protocol has no calibration point.
- Scoring all risks at 3x3 (medium) to avoid difficult conversations with the SRO.
- Not linking the Risks to Benefits Realization section to the Benefits Realization Plan - the two documents must cross-reference each other.

Template — Program Roadmap

Fillable Program Roadmap. This template produces the Program Roadmap for [Program Name]. Complete the context and assumptions sections first, then build the swim-lane timeline working left to right from confirmed milestones. Estimated completion time for first version: 3-4 hours with workstream leads in a roadmap workshop; 30-60 minutes per monthly update.

Sections:

- Program Context and Objectives - 1 paragraph, planning horizon, strategic mandate
- Workstream Swim Lanes - one row per workstream, monthly or quarterly time axis, phases and work blocks
- Program Milestones Table - ID, milestone name, workstream, planned date, forecast date, go/no-go criteria, owner
- Cross-Initiative Dependency Register - Dep ID, predecessor (workstream + milestone), successor (workstream + milestone), type, lag, status, owner

- Decision Points and Governance Gates - gate ID, date, decision required, decision-maker, required inputs, status
- Release and Deployment Events - release ID, workstream, planned go-live, blackout periods, inter-release dependencies
- Assumptions and Constraints Table - assumption/constraint, owner, review date, status
- Risks to the Roadmap - risk ID (from Risk Register), roadmap impact, mitigation, owner
- Version and Change History - version, date, change summary, author, approver

HOW TO USE THIS TEMPLATE

Completion guidance: Before distributing, validate every milestone date and dependency with the relevant workstream lead - roadmaps built without workstream lead input lose credibility within one reporting cycle. Baseline the roadmap with Program Sponsor sign-off before the first SteerCo distribution and store it in /Plans/Roadmap with version ATL-PROG-ROADMAP-v1.0-[YYYYMMDD]. Schedule the first monthly update review in the Program Board calendar before the workshop ends.

A strong completed version:

- Every dependency in the register has a named owner in both the predecessor and successor workstream.
- Milestones have specific dates (not quarters) and documented go/no-go criteria.
- Governance gates show the decision-maker and required inputs, not just the date.
- Assumptions that could shift the critical path are reviewed monthly, not left static.

Common pitfalls when filling it in:

- Plotting every project task on the roadmap - keep it to milestones, gates, and major work blocks only.
- Leaving dependency type and lag blank - without these, the downstream impact of a slip cannot be calculated.
- Using only quarterly granularity for milestones in the near-term horizon (next 3 months) - this masks slippage until it is too large to recover.
- Distributing without Program Sponsor approval - an unapproved roadmap undermines governance and creates conflicting stakeholder expectations.

Template — Program Success Metrics & OKRs → KPI Tracker

The working doc for selecting and maintaining program-level KPIs. Pairs with Template — Program Success Metrics & OKRs.

KPI selection criteria

For each candidate KPI:

KPI name: [Concise name — readable in a status report]

Tests for a good KPI:

- [] Leading indicator (changes before the OKR outcome changes)
- [] Continuously measurable without significant overhead
- [] Has a specific threshold below which intervention is required
- [] Owned by a named role with authority to act on it
- [] Distinct from OKR Key Results (KR measures end state; KPI measures path)
- [] Action it informs is named (what decision changes if this metric moves)

If any test fails, the KPI is probably the wrong choice or needs reformulation.

The KPI table

| KPI | What outcome it predicts | Source/data | Cadence | Threshold for action | Action when threshold breached | Owner |

|---|---|---|---|---|---|---|

| [Name] | [The OKR or operational outcome] | [System / report] | [Daily/weekly/monthly] | [Specific number] | [Specific intervention] | [Role + name] |

Selection guidance

Most programs do well with 5-10 program-level KPIs. Below 5, the program is under-monitored. Above 10, attention spreads too thin and the KPIs become performative.

Aim for 60-70% leading indicators (predict outcomes) and 30-40% lagging indicators (measure outcomes after the fact). Most TPMs over-weight lagging indicators because they're easier to measure; deliberately push for leading indicators.

For each KPI, the threshold for action should be specific enough that "did the threshold breach?" is a yes/no question. "Track engagement" isn't a KPI; "Active ZTNA usage at T+7 days drops below 95% triggers OCM intervention with manager-level outreach" is.

Threshold types

Three patterns work:

Static threshold. "Below X triggers Y." Useful when the metric has a known acceptable range.

Trend threshold. "More than two consecutive periods of decline triggers Y." Useful when the absolute level is less important than the direction.

Variance threshold. "Deviation of more than X% from baseline triggers Y." Useful when the baseline shifts over time.

KPIs that don't have a clear threshold pattern aren't ready to be KPIs yet — work on the threshold definition before adopting the KPI.

Action specification

For each KPI, the action when the threshold is breached must be specific:

- "Review at next steering" — too vague; doesn't drive timely action
- "Manager attestation review with affected team within 5 business days" — specific; clear on who acts and when

If you can't specify the action, you can't act on the KPI. Either rework the threshold or drop the KPI.

Routine review

KPIs are reviewed in routine status (weekly typically). Threshold breaches are surfaced explicitly. The status report's RAG status should be informed by KPI status — multiple KPI threshold breaches usually move the program to At-Risk, regardless of whether OKR-level outcomes have shifted yet.

Periodic review

Quarterly, review the KPI set itself:

- Are these still the right KPIs given how the program has evolved?
- Are any KPIs producing signal nobody acts on? Drop them.
- Are any thresholds being breached without producing the intended intervention? Either fix the action or drop the threshold.
- Are any patterns visible across multiple KPIs that suggest a deeper issue?

Handoff at program close

For each KPI, document at the start of the program (or by mid-program) whether it transitions to ongoing operations or retires at close.

| KPI | Continues post-program? | Receiving function | Handoff date | Notes |

|---|---|---|---|---|

| [Name] | Yes/No | [Function] | [Date] | [Adjustments needed for steady-state] |

KPIs that continue: the receiving function has to absorb them, and the threshold/action specifications may need adjustment for steady-state operations vs. program execution.

KPIs that retire: explicit retirement is better than letting them drift unnoticed. Document the retirement in the Closeout Report.

Anti-patterns

Tracking volume as if it's value. "Number of meetings held" isn't a KPI; "stakeholder readiness score at the gate review" might be.

KPIs without owners. The named owner has to have authority to act when the threshold breaches. If the owner doesn't have authority, the KPI doesn't work.

Vanity KPIs. Metrics that are easy to measure and look good but don't reflect program health. Honest answer to "what would change if this metric moved 10%?" — if the answer is nothing, drop it.

KPI inflation. Adding more KPIs because they're easy to add. The marginal cost of an additional KPI is attention dilution; the marginal benefit is usually small.

Threshold drift. Quietly relaxing the threshold when it's been breached repeatedly, rather than addressing the underlying issue. The threshold loses meaning if it can be casually adjusted.

Related artifacts

- Artifact #33 (Program Success Metrics & OKRs): the framework
- Template — Program Success Metrics & OKRs: where the KPI summary lives
- Status Report (#18): where KPI status is reported routinely
- Operating Model Document (#29): where transitioning KPIs land post-program

Keywords: KPI tracker, KPI template, program KPIs, KPI selection, KPI thresholds, leading indicators, lagging indicators, KPI handoff, KPI anti-patterns, vanity KPIs

Template — Program Success Metrics & OKRs → Metrics Review Cadence

The cadence document for reviewing OKRs and KPIs throughout program execution. Pairs with Template — Program Success Metrics & OKRs.

Review purpose

Metrics that are set at chartering and reviewed only at closeout don't shape execution. The cadence has to be regular enough to influence decisions during the program. This document specifies which reviews happen, when, with whom, and what they produce.

Review forums

Forum 1: Routine status (weekly)

- Cadence: Weekly, embedded in normal program status
- Attendees: TPM
- Inputs: KPI threshold status from the KPI Tracker
- Outputs: Status report RAG informed by KPI status; KPI threshold breaches flagged
- Time: Part of normal status compilation, no additional meeting required

Forum 2: KPI deep-dive (monthly)

- Cadence: Monthly, scheduled distinct from routine status
- Attendees: TPM + component PMs + operational KPI owners
- Inputs: All KPIs from the KPI Tracker, with month-over-month trend

- Outputs: Patterns identified across KPIs, KPI threshold actions confirmed or escalated, candidate KPI changes for sponsor review
- Time: 60 minutes typically

Forum 3: OKR confidence review (quarterly)

- Cadence: Quarterly, scheduled deliberately (not embedded in another review)
- Attendees: Sponsor + TPM + component PMs
- Inputs: Each Objective and KR with current confidence rating; comparison to confidence at chartering
- Outputs: Updated confidence ratings, material-change flags, decisions about OKR adjustments
- Time: 90 minutes typically

Forum 4: Material change review (ad-hoc, triggered)

- Cadence: When triggered by significant external or internal change
- Attendees: Sponsor + TPM (initially); broader if change is significant
- Inputs: The change that triggered the review; current OKR set; analysis of impact
- Outputs: Decision on whether OKRs need to be reset (formal re-baseline) or whether the change can be absorbed within current OKRs
- Time: Variable

Trigger conditions for material change review

Any of these triggers a review:

- A Key Result is no longer measurable as defined (e.g., the data source has changed, the population has changed)
- A Key Result has been achieved or missed earlier than expected, in a way that suggests the calibration was wrong
- External conditions have shifted such that the Objective itself may no longer represent success (e.g., a regulatory change, a strategic pivot)
- The program has moved to At-Risk or Off-Track and the OKRs need to be re-evaluated against the new path
- The sponsor or strategic context has changed (new sponsor, new business priority)

Quarterly OKR confidence review structure

The quarterly review is the most consequential metric review. Structure:

Pre-review preparation (TPM, 2-3 days before the review)

- Updated KR measurements
- Confidence rating proposal for each KR (with rationale)
- Material change flags if any
- Cascading impact on component OKRs

Review meeting structure (90 minutes)

- 10 min: Recap last quarter's confidence ratings vs. current state
- 30 min: Walk through each KR — current state, confidence, rationale
- 30 min: Discussion of material changes, if any
- 15 min: Decisions — confirmed confidence, OKR adjustments, escalations
- 5 min: Document outputs, schedule next review

Post-review (TPM, within 3 days)

- Updated OKR document with new confidence ratings
- Decisions logged in Decisions & Changes Log
- Stakeholder communication about any material OKR changes

Anti-patterns in metrics reviews

Reviews that have become routine box-checks. The confidence rating is "the same as last quarter" without genuine reflection. Fix: have the TPM specifically argue for a different rating than last time, even if to the same number — the argument forces the reflection.

Reviews that drift into status reporting. The OKR review becomes a status meeting because the team defaults to talking about activity. Fix: enforce the structure — KR measurement, KR confidence, material change. Activity discussion belongs in routine status, not OKR review.

Reviews where confidence ratings only go up. Optimism bias — confidence drifts upward over time without underlying outcomes shifting. Fix: track confidence trajectory across reviews; downward shifts shouldn't be embarrassing, they reflect honest reassessment.

Reviews held without sponsor presence. The sponsor's view of progress against OKRs is a critical input. A review the sponsor skips becomes a TPM-and-team review, which loses the OKR contract structure. Fix: hold the quarterly review on the sponsor's calendar; reschedule if needed.

Reviews that don't produce decisions. If the quarterly review walks through OKRs and produces only "we'll keep going," it didn't earn the time. The review should produce specific decisions: confidence adjustments, material change flags, OKR resets, or explicit confirmation of current trajectory.

Documentation

Each metrics review produces:

- Updated OKR confidence ratings (recorded in the OKR Worksheet section of the master template)
- Decisions logged in the Decisions & Changes Log
- Communications to stakeholders if changes are material
- Updated owner assignments if any changed

Related artifacts

- Artifact #33 (Program Success Metrics & OKRs): the framework
- Template — Program Success Metrics & OKRs: the master template
- Decisions & Changes Log (#19): where decisions from reviews are logged
- Status Report (#18): where routine KPI status is reported
- Re-baselining without losing trust (Field Note #215): when material change reviews lead to formal re-baseline

Keywords: metrics review cadence, OKR review, KPI review, quarterly OKR review, material change review, metrics governance, OKR confidence review, OKR resetting cadence, program metrics cadence

Template — Program Success Metrics & OKRs → OKR Worksheet

The working doc for developing program-level OKRs during chartering or re-baselining. Pairs with Template — Program Success Metrics & OKRs.

Step 1 — Draft Objectives

For each candidate Objective, fill in:

Objective: [One-sentence statement]

Tests for a good Objective:

- [] Memorable in one sentence (read it out loud — does it stick?)
- [] Aspirational without being vague
- [] Distinct from operational activity (not "deliver the project plan")
- [] Connected to a business outcome the sponsor would defend

- ☐ Outcome-focused, not deliverable-focused

If any test fails, revise. Most programs need 1-2 Objectives. Three is the maximum.

Step 2 — Draft Key Results for each Objective

For each KR candidate:

KR: [Specific number/percentage/state, by date]

Tests for a good KR:

- ☐ Measurable with a specific number, percentage, or binary state
- ☐ Time-bound (by when)
- ☐ Outcome-focused, not activity-focused
- ☐ Independent of other KRs (each measurable on its own)
- ☐ Sponsor would defend it as part of "what success looks like"

Most Objectives need 3-5 KRs. Below 3, the Objective probably isn't fully captured. Above 5, the KR set becomes performative.

Step 3 — Calibrate confidence

For each KR, the team rates confidence at the time of setting:

| KR | Initial confidence | Why this confidence level |

|---|---|---|

| [KR text] | [%] | [What the team knows that justifies this level] |

Calibration target: 60-70% confidence on the harder KRs. The team should believe they can hit them with focused work, but it's not certain.

If most KRs are at 90%+ confidence: probably sandbagged. Revisit.

If most KRs are at 30% confidence: probably heroic. Revisit.

Step 4 — Identify owners

| Objective/KR | Owner role | Owner name |

|---|---|---|

| Objective 1 | [Sponsor / TPM] | [Name] |

| KR 1.1 | [TPM / Component PM] | [Name] |

| ... | | |

Step 5 — Pressure-test

Three pressure-test questions before finalizing:

1. "If we hit all KRs but the sponsor still feels the program failed, which Objective or KR was wrong?" If you can answer, fix the OKR set.
2. "If we missed all KRs but the sponsor felt the program succeeded, which Objective or KR was unnecessarily strict?" If you can answer, the OKR set is over-specified.
3. "What's not in the OKR set that someone might assume is part of success?" If something material is missing, add a KR or document why it's deliberately out of scope.

Step 6 — Sponsor review and approval

Sponsor reviews the OKR set against their understanding of program success. The sponsor approval includes:

- Confirmation that hitting the KRs would constitute success
- Acknowledgment of the calibration confidence levels
- Approval of the named owners

The OKR set transfers from this Worksheet to the Charter (or Program Charter for multi-initiative programs) and the master Template — Program Success Metrics & OKRs.

Anti-patterns to avoid

Activity-stated Objectives. "Implement ZTNA across the enterprise" describes work, not outcome.

Deliverable-stated Objectives. "Ship the new identity platform" is a deliverable, not an outcome.

Conflating KRs. Three KRs that all measure slightly different angles of the same thing is one KR. Combine.

Vague time-binding. "By end of program" isn't time-bound; "by Q3 2027" is.

KRs the sponsor doesn't value. The KR has to be something the sponsor would defend if asked "is this what success looks like?"

KR drift during execution. KRs are reviewed for confidence quarterly but not redefined casually. Material change to the KR set requires sponsor approval.

Related artifacts

- Artifact #33 (Program Success Metrics & OKRs): the framework
- Template — Program Success Metrics & OKRs: where the finalized OKRs live
- Charter (#1): where the approved OKRs are also captured
- Program Charter (#24): where multi-initiative program OKRs are captured

Keywords: OKR worksheet, OKR template, drafting OKRs, program OKR, OKR calibration, KR worksheet, OKR pressure test, OKR anti-patterns

Template — Program Success Metrics, OKRs & KPIs

This template is the working document for establishing and reviewing program-level success metrics. It pairs with Artifact #33 (which establishes the framework) and is populated using three sub-templates: OKR Worksheet, KPI Tracker, and Metrics Review Cadence.

Document Control

[Program name]

[Charter version this metrics doc aligns to]

[Owner — typically TPM]

[Sponsor — required approval]

[Date created / last review / next review]

Section 1 — Program Objectives & Key Results

Use the OKR Worksheet (sub-template) to develop. Final OKRs go here.

Objective 1: [Memorable one-sentence statement of what success looks like]

- KR 1.1: [Measurable outcome with specific number/percentage/state, by date]
- KR 1.2: [Measurable outcome]
- KR 1.3: [Measurable outcome]
- KR 1.4: [Measurable outcome]

Objective 2 (if applicable): [Memorable one-sentence statement]

- KR 2.1: [Measurable outcome]
- KR 2.2: [Measurable outcome]
- KR 2.3: [Measurable outcome]

Calibration

For each KR, document the team's confidence level when set:

- Confidence levels: 90% (sandbagged), 70% (well-calibrated, achievable with focused work), 50% (stretch), 30% (heroic — usually wrong calibration)
- Most KRs should target 60-70% confidence

Owners

Each Objective has an owner — typically the program sponsor.

Each KR has an owner — typically the TPM or component PM.

Section 2 — Program KPIs

Use the KPI Tracker (sub-template) to maintain. Summary table goes here.

| KPI | What it measures | Threshold for intervention | Owner | Source | Cadence |

|---|---|---|---|---|---|

| [Name] | [Outcome it predicts] | [Threshold + intervention] | [Role] | [Data source] |
[Daily/weekly/monthly] |

Most programs need 5-10 program-level KPIs. Component-level KPIs are managed in component plans, not here.

Section 3 — Review Cadence

Use the Metrics Review Cadence (sub-template) for the operational pattern. Summary here.

| Review | Cadence | Attendees | Outputs |

|---|---|---|---|

| OKR confidence review | Quarterly (minimum) | Sponsor + TPM + component PMs | Updated confidence ratings, material-change flags |

| KPI threshold review | Weekly (in status) | TPM | RAG informed by KPI status |

| Material change review | Ad-hoc when triggered | Sponsor + TPM | Decision on whether to reset OKRs |

Section 4 — Handoff Plan (post-program)

Document which KPIs transition to ongoing operations and which retire at program close.

| KPI | Continues post-program? | Receiving function/team | Handoff date target |

|---|---|---|---|

| [Name] | Yes/No | [Function name] | [Target date] |

Plan the handoff at least 60 days before closeout.

Section 5 — Approvals

Sponsor approval of OKRs: [Name — date]

TPM acknowledgment: [Name — date]

Operational owner acknowledgment of KPIs: [Names — date]

Receiving function lead acknowledgment of handoff plan: [Name — date]

Related artifacts

- Artifact #33 (Program Success Metrics & OKRs): the framework this template populates
- Charter (#1) and Program Charter (#24): where the OKRs cross-reference
- Status Report (#18): where KPIs are reported
- Operating Model (#29): where post-program KPIs transition

Keywords: OKR template, KPI template, success metrics template, program metrics template, OKR worksheet, KPI tracker, metrics review template, program success template

HOW TO USE THIS TEMPLATE

Completion guidance: Start by confirming the strategic objectives the program is designed to achieve, because every OKR and KPI must trace to a strategic intent - metrics that do not ladder up to a strategic objective should be dropped, not added; this alignment session requires the executive sponsor and portfolio owner and typically takes 90-120 minutes. Draft Objectives

first, then Key Results, then leading indicator KPIs last, working top-down; never reverse the order or the metrics become disconnected from the outcome logic. Inputs are the program charter, approved business case (including the benefit realization model), and any enterprise balanced scorecard or OKR framework already in use.

A strong completed version:

- Every Key Result has a specific numeric target, a baseline value, a measurement date, and a named data owner who can actually produce the number.
- The metric set includes leading indicators (early signals of progress) alongside lagging indicators (outcomes), so the team can course-correct before the final result is locked.
- OKRs are ambitious but achievable: a well-calibrated Key Result is expected to be achieved at 70-80%, not 100%, to ensure stretch without sandbagging.
- A data sourcing table identifies the system of record for each KPI, the refresh frequency, and who is accountable for reporting accuracy, so there is no ambiguity at measurement time.

Common pitfalls when filling it in:

- Setting Key Results as activities ('complete training for all users') rather than outcomes ('user proficiency rate $\geq$ 85% at 30-day post-launch assessment').
- Creating so many KPIs (more than 10-12 at program level) that no single metric gets sufficient attention and the scorecard becomes reporting theater.
- Failing to establish baselines before the program begins, making it impossible to demonstrate improvement at program close.
- Defining success metrics after the program is underway rather than before, which allows the team to reverse-engineer targets to match whatever was actually achieved.

Template — Tranche & Release Plan

Fillable Tranche & Release Plan. Complete the Tranche Definition and Release Schedule tables for the current tranche before each Program Board. The EoTR Decision Record annex must be completed at the EoTR meeting and signed before the meeting closes. Highlight any benefit checkpoint that is at risk in red at least 4 weeks before the EoTR.

Sections:

- Program Tranche Map - visual or table: Tranche ID | Name | Start | End | Capability Outcome Label | EoTR Date.
- Tranche Definition (repeat per tranche) - Tranche ID | Name | Start | End | Capability State (business terms) | Benefits to be Evidenced | Key Assumptions.
- Release Schedule (repeat per release within tranche) - Release ID | Component Project | Scope | Target Date | Dependencies | Readiness Criteria | Deployment Window | Status (Planned/Confirmed/Complete).
- Tranche Dependencies & Constraints - table: Dependency | Type (internal/external) | Owner | Impact if Late | Mitigation.
- Benefit Realization Checkpoints - table: Benefit ID | Description | Measurement Method | Measurement Owner | Minimum Acceptable Result | EoTR at Which Required.
- End-of-Tranche Review Protocol - standard agenda, attendees, evidence pack items, decision options, decision authority (SRO sign-off required).
- EoTR Decision Record (annex, one per tranche) - Date | Tranche | Evidence Summary | Benefits Result vs. Threshold | Outstanding Risks | Decision | Conditions | Next-Tranche Commitment | SRO Signature.
- Next-Tranche Readiness Checklist - item | status (Green/Amber/Red) | owner | notes.

HOW TO USE THIS TEMPLATE

Completion guidance: The plan is considered baselined when the SRO has approved the Tranche 1 definition and benefit checkpoints; this should happen no later than the end of the program planning phase. Each subsequent tranche definition is approved at the preceding EoTR. Do not commit program resources to a tranche until the readiness checklist is at least Amber with a credible remediation plan for any Red items.

A strong completed version:

- Capability outcomes are written in language a business executive would recognize without a technical glossary.
- Every benefit checkpoint has a 'minimum acceptable result' value - not a target, but a floor below which the proceed decision is automatically challenged.
- Release dates in the schedule have been cross-checked against the BAU change freeze calendar and CAB windows.
- The EoTR Decision Record is signed by the SRO on the day of the review, not retrospectively.

Common pitfalls when filling it in:

- Writing capability outcomes as deliverable lists ('CyberArk installed on all servers') rather than capability states ('operations team can grant and revoke privileged access to any server within 15 minutes without a manual ticket').
- Setting benefit thresholds so low they will never be breached - this makes the EoTR gate meaningless.
- Scheduling EoTRs in the same time slot as monthly steering meetings - the EoTR requires a separate, longer, evidence-focused session.
- Completing the readiness checklist after the EoTR decision rather than as a pre-condition.

Program Management · Worked Examples (13)

5 — Operating Model — Cloud Security Operations

Operating Model — Cloud Security Operations Function

Document Control

Function: Cloud Security Operations

Operating model version: v2.1 (2026-04-01), next scheduled review 2027-04-01

Owner: Director, Cloud Security Operations (reports to CISO)

Sponsor: Sandra Park (CISO)

Coalition: Linda Walsh (CIO), Robert Stein (CRO), Mark Williams (CTO)

Function size: 17 (14 FTE + 3 contractors), \$4.8M annual operating budget

Last material change: 2026-01-15 — added PAM and Access Review scope in anticipation of Project Atlas handoff

Material changes pending: 2027-Q3 expected — Atlas program closeout will transfer ZTNA component fully into operational ownership; capacity model will be re-baselined

Context

Cloud Security Operations is the durable security function that takes ownership of the capabilities Project Atlas builds — Identity Provider, ZTNA, Privileged Access Management, MFA, Access Review — and operates them for years afterward. The function existed before Atlas (originally as the Identity Operations team, ~11 FTE focused on IdP and MFA), but it was deliberately re-chartered in early 2026 with expanded scope to receive everything Atlas delivers. By the time this operating model was last revised (April 2026), the function was in transition: still

partly absorbing Atlas-built capabilities, still partly operating pre-Atlas tooling, and building the discipline that will run the post-Atlas steady state.

Operating models for security functions tend to read interchangeably across organizations — the same sections, the same generic language about "operational excellence" and "stakeholder alignment." This one is deliberately specific to Bristol Financial in 2026: the function size reflects what's needed for Bristol's 3,500-employee scale plus 250 contractors, the \$4.8M budget reflects actual vendor commitments (Okta, Zscaler, BeyondTrust, SailPoint, Yubico), the governance cadence reflects the rhythms Bristol leadership actually keeps, and the boundaries with adjacent functions reflect Bristol's actual org chart. A reader at another organization should adapt the structure; the substance here belongs to Bristol's post-Atlas state.

This document is organized in fourteen sections covering everything from the function's purpose through its formal approvals. The early sections (1-4) establish what the function is, its scope, its structure, and its governance. The middle sections (5-7) describe what the function does — its core processes, the services it offers, the tools it operates. Sections 8-10 cover how performance is measured and how the function is resourced. Sections 11-13 address external dependencies, continuous improvement, and risks to the operating model itself. Section 14 closes with formal approvals and review cadence.

1 — Purpose & Mandate

Mandate

Operate identity, access, and network security capabilities for Bristol Financial. Cloud Security Operations is the team Bristol customers and employees never think about — until something breaks, at which point we are the team they need.

Strategic alignment

The function supports two enterprise pillars: "Trusted Financial Partner" (security as customer trust) and "Operational Resilience." Function-level outcomes ladder up to the CISO's annual goals on regulatory readiness, incident reduction, and Zero Trust posture maturity. Concretely, this means: every quarter, the Director's strategy review reconciles function delivery against CISO goal-tracking, and any divergence is surfaced to the Steering Committee.

Outcomes the function delivers

Six outcomes define what success looks like for this function. Each is measurable, each has an owning role, and each rolls into the KPIs section.

- Identity availability and integrity for all employees, contractors, and systems — target 99.95% IdP availability
- Access provisioning and de-provisioning at the speed the business requires — target less than 24 hours from HR event to access change
- Privileged access governance — target 100% of production access through PAM with full audit trail
- Phishing-resistant authentication for the workforce — target 100% FIDO2 coverage by Q1 2027
- Quarterly access review attestation across all in-scope systems — target 100% completion within review window
- Incident response support for identity and access incidents — target less than 30 minutes time-to-acknowledge for P0/P1

The targets are not aspirational. Each was chosen because it is achievable with the current function size at current Bristol scale, AND because falling short of any of these targets has named regulatory or operational consequences. Cloud Security Operations does not negotiate these targets downward; if scale or scope changes such that the targets are no longer achievable, that triggers a function-resourcing conversation, not a target adjustment.

2 — Scope

The scope of this function is deliberately bounded. Security is too broad a domain for any single function to own; the question is which capabilities belong here, which belong adjacent, and where the boundaries are coordinated.

In scope

- Identity Provider operations (Okta) — administration, SSO, lifecycle
- Privileged Access Management (BeyondTrust) — administration, session management, audit
- MFA Operations — FIDO2 hardware tokens lifecycle, platform authenticator support
- ZTNA Operations — policy, enforcement, troubleshooting, capacity planning
- Access governance — quarterly access reviews, joiner/mover/leaver, exception management
- Identity-related incident response (in coordination with Security Operations Center)
- Vendor management for in-scope tools (Okta, BeyondTrust, Zscaler, SailPoint, Yubico)

Out of scope

- Endpoint security (EDR, MDM) — owned by Endpoint Security team
- Application-layer security (WAF, SAST/DAST) — owned by Application Security team
- Network security beyond ZTNA — owned by Network Engineering
- Security Operations Center detection and response — coordinated with, not owned by us
- Compliance attestations — owned by GRC, supported by us with evidence

Boundaries with adjacent functions

The boundaries below are not just statements of "what they own"; each is a coordination relationship with a named cadence and a named owner on each side. When boundary disputes arise (and they do), the named owners resolve at their cadence; if the cadence doesn't fit the urgency, the Director escalates to the CISO.

Adjacent function	What they own	Where we coordinate	Boundary owner
Security Operations	Detection, triage, incident response	identity-related alerts; suspicious sign-in patterns; account takeover response	OC Director + loud Sec Ops Director — i-weekly
Center (SOC)			
Network Engineering	Network infrastructure, Z routing, firewalls, perimeter	TNA gateway placement; VP gross capacity for ZTNA; VPN decommission	Network Eng + loud Sec Ops Director — onthly
Application Security	Code scanning, app A	pp onboarding to SSO/IdP; Ap	pSec Director +
(AppSec)	vulnerability management, secure dev practices	Auth/OIDC review; CI reduction access	oud Sec Ops Director — -weekly
IT Service Management	Help desk, ticketing, I end-user support	identity-related tickets; IT unbooks; surge	Service Manager + loud Sec Ops Lead — eekly

Adjacent function	What they own	Where we coordinate	Boundary owner
	r	planning C w	
GRC (Governance, Risk, Compliance)	Audit, regulatory reporting, A	ccess review evidence; GR	C Director +
	policy S	OX/SOC 2 control evidence; CI policy interpretation	oud Sec Ops Director — monthly + ad-hoc
HR IT	HRIS, joiner/mover/leaver H workflows e	R-driven access lifecycle HR vents; data feeds from HRIS CI b	IT Director + oud Sec Ops Lead — i-weekly

3 — Organization Structure

The function is organized in five teams plus the Director's office. The headcount of 17 (14 FTE + 3 contractors) reflects what the function needed pre-Atlas plus the additions made for receiving Atlas scope. The contractor positions are deliberate: the access governance work has seasonal load (quarterly review cycles drive concentrated demand) that doesn't justify full-time headcount but does justify supplemental capacity.

Headcount distribution

- Director (1) — function leadership, strategy, executive interface, budget owner
- Identity Engineering team (5 FTE) — IdP, MFA, lifecycle automation
- Network Access team (4 FTE) — ZTNA, VPN sunset, network access policy
- Privileged Access team (3 FTE) — PAM administration and operations
- Access Governance team (2 FTE + 3 contractors) — access reviews, joiner/mover/leaver workflows
- All non-Director roles split across an on-call rotation covering 24x7 production support

Key roles + decision authority

The decision-authority column below is deliberately specific. Operating models commonly fail at the moment a decision needs to be made because the named decision-maker doesn't actually have authority for the decision's scope. Each role's authority limits below have been validated against the corresponding budget and policy delegations.

Role	Responsibilities	Decision authority	Reports to
Director, Cloud	Function leadership, strategy, executive	Tooling/vendor decisions up to \$500K; C	ISO
Security Operations	interface, budget owner	staffing within approved headcount; policy interpretations within mandate	
Identity Engineering	Operates IdP, MFA, lifecycle for all	Day-to-day operational decisions; on-call	Director
Manager	employees and apps	escalations; vendor work up to \$50K	
Network Access	Operates ZTNA, network access policy,	ZTNA policy changes; capacity planning	irector

Role	Responsibilities	Decision authority	Reports to
		D	
Manager	VPN sunset	decisions; vendor work up to \$50K	
Privileged Access	Operates PAM platform, privileged	Privileged access exception approvals; D	irector (dotted
Lead	session governance	PAM policy changes; vendor work up to I \$25K g	ine to GRC for overnance)
Access Governance	Quarterly access reviews;	Review process design; exception D	irector
Lead	joiner/mover/leaver workflows	handling within approved guardrails	
Senior Identity	IdP architecture, app onboarding,	Architectural decisions for app integration; I	identity
Engineer (×2)	complex troubleshooting, mentor junior eng	production change approvals during E on-call M	ngineering anager
Identity Engineer (×3)	App onboarding, MFA enrollment support, lifecycle automation, ticket queue	Standard operational changes per I runbook E M	identity ngeering anager

The teams have been intentionally sized to the work, not to the org-chart. The Privileged Access team is smaller than Identity Engineering because PAM (BeyondTrust) is a more mature, more constrained product; the Access Governance team is supplemented with contractors because the work has seasonal peaks that don't justify steady-state FTE.

4 — Governance & Decision Rights — Meeting Cadence

This section captures the operating cadence — what meetings happen, who attends, what gets decided. The principle: every meeting has a stated outcome. Meetings without stated outcomes get cancelled. The cadence below is what the function actually runs as of v2.1 of this operating model; cadence drift (meetings that started with a clear purpose but lost it) is reviewed at the quarterly strategy review and corrected.

Forum	Frequency	Day / time	Attendees	Decisions made here
Daily standup —	Daily	Mon-Fri 9:30am,	Director, all team leads (Identity,	Day's priorities; live incident handoff;
operations		15 minutes	Network Access, PAM, Access Gov), on-call lead	immediate operational adjustments

Forum	Frequency	Day / time	Attendees	Decisions made here
Identity team standup	Daily	Mon-Fri 10:00am, 15 minutes	Identity Eng Manager + team	Sprint task adjustments; ticket queue load balancing; technical blockers
Network Access team	Daily	Mon-Fri 10:00am,	Network Access Manager + team	Same as identity, scoped to network access
standup		15 minutes		work
Function leadership	Weekly	Tuesdays 11am,	Director + 4 team managers + Privileged	Resource decisions across teams;
team		60 minutes	Access Lead	cross-team dependencies; weekly focus areas; 1:1 escalations from teams
Director 1:1 with CISO	Weekly	Mondays 2pm, 30 minutes	Director + CISO	Function status, escalations, asks for executive support, strategic alignment
Operations review	Monthly — 1st	1st Wed 2pm,	Director + team managers + GRC liaison	Monthly KPI review; capacity vs demand;
(monthly)	Wednesday	90 minutes	+ IT Service Manager + SOC Director liaison	incident retrospectives; cross-functional process changes
Strategy review	Quarterly	First week of new	Director + team managers + senior	Quarterly OKRs; tech roadmap; tooling
(quarterly)		quarter, half-day	engineers + invited stakeholders (CISO, CIO designate)	decisions; capacity plan; process improvements
Steering committee	Monthly — 4th Tuesday	4th Tue 3pm,	CISO + all security function directors +	Cross-function security decisions; policy
(security)		60 minutes	GRC Director + CIO designate	changes; incident learnings; resource arbitration
Audit Committee	Quarterly	Per Audit	CISO presents on	Strategic risk

Forum	Frequency	Day / time	Attendees	Decisions made here
			behalf of the	reporting; control
(board-level)		Committee schedule	security organization; Director attends ad-hoc	effectiveness; regulatory readiness; annual audit results

How decisions actually flow

Day-to-day operational decisions are made at team standups by team managers within their decision authority. Cross-team operational decisions are made at the function leadership team meeting on Tuesdays. Strategic and budget-level decisions are made at the quarterly strategy review with CISO input. Executive escalations flow through the Director 1:1 with CISO; the Director uses that channel deliberately, not for every issue, to preserve its escalation value. Cross-function security decisions involving other security function leaders flow through the monthly Steering Committee.

5 — Core Processes

These are the eight processes that define how the function operates in steady state. Each has a referenced Standard Operating Procedure document; the operating model is the index, the SOPs are the detail. SOP documents are maintained in the function's Confluence space and reviewed at the same cadence as this operating model.

Process	Trigger	Owner	Outputs	SOP reference
Joiner/Mover/Leaver	HR event (hire, transfer, termination)	Access Governance Lead	Access provisioned, modified, or revoked per role	SOP-IDM-001
App onboarding to IdP	App owner request	Identity Engineering Manager	App integrated to SSO with appropriate access policy	SOP-IDM-002
Access exception	User or manager request for	Access Governance Lead	Approved exception with expiration	SOP-IDM-003
management	non-standard access		+ audit record, OR denial with rationale	
Privileged access	Production access need	Privileged Access Lead	Time-bound, audited privileged	SOP-PAM-001
provisioning	(planned or break-glass)		session via PAM	
Quarterly access review	Q-end calendar trigger	Access Governance Lead	Reviewed and attested access for all in-scope systems	SOP-AGR-001
Identity incident	SOC alert OR ticket OR	On-call lead	Investigated, contained,	SOP-IR-001

Process	Trigger	Owner	Outputs	SOP reference
response	responder escalation		recovered, RCA filed	
ZTNA policy change	Policy change request from app owner or security	Network Access Manager	Policy reviewed, tested, deployed with rollback plan	SOP-ZTNA-001
Vendor management —	Renewal cycle, escalation,	Director (Manager designee	Maintained vendor relationship,	SOP-VND-001
security tooling	performance issue	per tool)	contract on track, escalations resolved	

How processes change

The processes above are not static. When a process produces unexpected outcomes (slow access provisioning, missed access review windows, repeat exceptions for the same population), the responsible Lead initiates a process review at the next operations review. Material process changes go through the Strategy Review and update the corresponding SOP. The function tracks process-change frequency as a leading indicator of operational health: too many changes signals churn; zero changes signals stagnation.

6 — Service Catalog

The Service Catalog describes what the function offers to its internal customers — the list employees, app owners, and other functions can request from Cloud Security Operations, with stated SLAs and how to request each service. The catalog is the function's commitment-to-service made visible.

Service	Description	Standard SLA	How to request
Standard access	Add a user to a role group; provision	<4 hours business hours;	ServiceNow request form
provisioning	access to apps mapped to that role.	<24 hours overall	(auto-routed via HRIS for joiners)
Privileged access	Time-bound elevated access to	<24 hours for standard	ServiceNow PAM request form;
request	production systems via PAM (BeyondTrust). Requires manager + system owner approval.	requests; <2 hours for break-glass	break-glass via on-call escalation
Access exception	Non-standard access outside role- based defaults. Requires business justification + GRC review for SOX-scope.	<5 business days standard; <2 business days expedited	ServiceNow exception form
App onboarding to	Integrate a new app into Okta SSO.	Standard apps: 2 weeks.	App owner submits onboarding
enterprise SSO	Includes integration design review, SCIM where supported,	Complex integrations: 4-8 weeks (scoped per request).	request; intake meeting weekly

Service	Description	Standard SLA	How to request
	access policy.		
MFA enrollment	Help users enroll FIDO2 hardware	Self-service for standard	Self-service portal; help desk
support	tokens or platform authenticators. White-glove for executives.	users (<15 min). Executive enrollment: <2 business days scheduled.	escalation
Quarterly access	Run automated access certification	Standard 30-day review	Automated; reviewers notified at
review	cycle for all in-scope systems. Reviewers attest within review window.	window per quarter	quarter-end
ZTNA policy change	Modify ZTNA access policy for an app or user group. Includes review, test, deploy with rollback plan.	Standard: 5-10 business days. Emergency: <4 hours via on-call.	Network Access intake form
Identity-related	Acknowledge, investigate, contain,	<30 min ack for SEV-1/2	SOC alert routes to on-call;
incident response	recover, RCA. Coordinated with SOC.	(24x7 on-call). RCA within 5 business days of closure.	users via help desk
Audit evidence support	Provide control evidence to GRC for SOC 2, SOX, and regulatory audits.	<5 business days for standard requests; pre-coordinated for audit windows	GRC submits evidence requests; coordinated with audit cycle

Catalog maintenance

SLA performance is tracked monthly in the operations review (see Section 8). Service-level adjustments are reviewed annually with internal customers (CIO, app owners, business unit leads) at the strategy review. New services added to the catalog go through the same change process as new tooling: Director approval if within budget, Steering Committee approval if cross-functional impact.

7 — Tools & Systems

The function operates eight primary systems. Each has an internal owner accountable for its day-to-day operation, vendor relationship management, capacity planning, and incident response. Tool-to-tool integrations are maintained at the function level by Identity Engineering Manager.

Tool	Used for	Owner	Integrations
Okta	Enterprise IdP — SSO, MFA, lifecycle	identity Engineering Manager	HRIS (Workday), 200+ apps via SAML/OIDC, FIDO2
BeyondTrust	Privileged Access Management	Privileged Access Lead	Active Directory, AWS, GCP, on-prem servers,

Tool	Used for	Owner	Integrations
			databases
Zscaler Internet Access +	ZTNA platform	Network Access Manager	Okta (identity), endpoint
Private Access (ZIA + ZPA)			posture (CrowdStrike), all corporate apps
Yubico YubiKey 5	Hardware FIDO2 tokens	Identity Engineering Manager	Okta (FIDO2), Windows Hello, macOS
SailPoint IdentityIQ	Access governance + access reviews	Access Governance Lead	Okta, BeyondTrust, HRIS, in-scope apps
ServiceNow	Ticketing for access requests + identity tickets	IT Service Management (we consume)	Okta, custom workflows for access requests
Splunk	SIEM — log aggregation, alerting	SOC owns; we feed	All identity tools log into Splunk
Slack + Confluence	Team comms + documentation	Function-wide	On-call alerts post to #cloud-sec-ops-oncall

Tooling decisions

Vendor change is significant. Each tool above represents a multi-year contract, integrations across many systems, and operational expertise the function has built up. Tool-replacement decisions go through the Strategy Review with explicit cost-benefit analysis, vendor evaluation, and migration plan. The default disposition is to keep current tooling unless the cost-benefit clearly justifies change.

8 — KPIs & Performance Metrics

KPIs measure whether the function is delivering against its mandate. Each KPI has a defined target, a data source, a reporting cadence, and an audience. Targets are calibrated against pre-Atlas baselines for capabilities that existed before Atlas, and against engineering pilot data for capabilities Atlas built.

KPI	Definition	Target	Source	Reported to
IdP availability	Okta service availability minus 9 our downtime contribution	9.95% monthly O	Okta status + Splunk	Operations review (monthly), Steering (monthly)
MTTR — identity	Mean time to recovery for <	2 hours SEV-1; S	ServiceNow + retro	Operations review
incidents	SEV-1/2 identity incidents <	8 hours SEV-2 O	Outputs	
Access provisioning	Time from approved request to <	4 hours business S	ServiceNow	Operations review
SLA	access granted h	ours; <24h overall		

KPI	Definition	Target	Source	Reported to
Joiner access at start date	% of new hires with day-1 access ready $\geq$	98% H	RIS + Okta	Operations review
Leaver access	Median time from termination $<$	2 hours H	RIS + Okta +	Operations review (monthly),
revocation time	event to access fully revoked		ServiceNow	Audit Committee (quarterly)
MFA coverage	% of workforce with phishing-resistant MFA enrolled	100% (post-program)	Okta	Steering (monthly), Audit Committee (quarterly)
Access review	% of in-scope reviews ≥ 1	00% S	ailPoint	Steering, Audit Committee
completion	completed within window			
Privileged access	% of privileged sessions ≥ 1	00% (post-program) B	eyondTrust + audit	Steering, Audit Committee
via PAM	through PAM (vs direct)			
Cost per identity	Total function spend / T employee headcount d	ending stable or F eclining	inance	Strategy review (quarterly)
Team eNPS	Function team Net Promoter $\geq$ Score	+30 Q	uarterly survey	Strategy review (quarterly)

How KPIs drive decisions

KPIs are decision triggers, not status indicators. Each KPI has a threshold below which intervention is mandatory: IdP availability below 99.9% in any monthly window triggers a vendor escalation with Okta; MTTR above target triggers a retrospective focused on root-cause patterns; access provisioning SLA missed for two consecutive months triggers a process review; eNPS below +20 triggers a function-health intervention with the affected team.

9 — Capacity & Workforce Plan

Current capacity

The function operates at 14 FTE + 3 contractors. The function expanded from 11 FTE in Q4 2025 specifically to absorb Project Atlas scope (PAM, ZTNA, expanded access governance). The current size reflects what's needed for Bristol's current scale; capacity will be re-evaluated post-Atlas closeout as part of the 2027 annual planning cycle.

Capacity forecast

Stable through 2027 at 14-15 FTE if Bristol growth tracks current projections. The function does not scale linearly with employee headcount because identity automation absorbs some of the demand growth — a 10% employee growth typically produces 6-7% identity work growth at this scale.

Critical skills and concentration risk

- Okta deep expertise: 3 of 5 senior engineers have it; concentration moderate
- ZTNA architecture: 1 senior engineer; succession risk high
- BeyondTrust PAM administration (certified): 2 of 3 PAM team members
- Cloud-native identity for AWS/GCP: currently dependent on senior engineers; planning to upskill 2 mid-level engineers in 2026

Hiring plan 2026

- 1 backfill for senior identity engineer (anticipated Q3 attrition based on current role tenure patterns)
- 0 net new headcount

Succession risk and mitigation

The ZTNA Architecture Senior Engineer role is the function's highest concentration risk. If this person departs, replacement onboarding is estimated at 6+ months given the depth of Bristol-specific configuration knowledge. Mitigation: cross-training the Senior Network Engineer over 2026 to provide a credible second source for ZTNA architectural decisions. Cross-training progress is reviewed quarterly at the strategy review.

10 — Budget & Financial Model

Annual operating budget

\$4.8M for FY2026, allocated as follows:

- Labor: 60% (\$2.9M) — FTE compensation plus contractor labor
- Vendor licensing: 30% (\$1.4M) — Okta, BeyondTrust, Zscaler, SailPoint, Yubico
- Tools and other: 10% (\$500K) — ServiceNow seats consumed, training, professional services, contingency

Cost allocation model

The function operates as a shared service. Costs are allocated to business units proportional to FTE headcount with weighting for high-privilege roles (e.g., engineering FTE weighted 1.5x to reflect higher PAM and access-management overhead). Allocation is published quarterly so business units can see what they consume and plan accordingly.

Capex vs opex

95% opex (subscription-based tools) and 5% capex (infrastructure for the small remaining on-prem ZTNA gateway footprint, scheduled for full retirement by end of 2027).

Project Atlas budget interaction

Project Atlas program budget is separate from this function's operating budget. Costs incurred during the program (Atlas-funded engineering work, vendor onboarding, transitional contractor support) are charged to the program. At program closeout (anticipated Q3 2027), residual operational costs transfer to this function's operating budget; the FY2028 operating budget will reflect the steady-state cost structure post-Atlas.

11 — External Dependencies

The function depends on external relationships that are explicitly managed because their failure would degrade or stop function delivery. Dependencies are organized by criticality: P0 means function operations cannot continue if the dependency fails; P1 means significant degradation; P2 means manageable.

Vendor dependencies

- Okta (P0) — Identity provider; outage = no employee access. Vendor relationship: tier-1 enterprise account, named CSM, quarterly business reviews, contractual 99.9% uptime SLA.
- Zscaler (P0) — ZTNA platform; outage = no application access for any employee. Vendor relationship: same tier as Okta.
- BeyondTrust (P1) — PAM platform; outage = privileged access falls back to documented break-glass procedures.
- Yubico (P1) — FIDO2 token supplier; outage affects new enrollments but not existing tokens.
- SailPoint (P1) — Access governance; outage delays quarterly review cycle but does not block operations.

Internal dependencies

- HR IT — HRIS feed for joiner/mover/leaver lifecycle. Failure delays access provisioning by hours to days.
- Network Engineering — ZTNA capacity, network routing, peering. Failure can cause ZTNA degradation.
- Endpoint Security — device posture signal for ZTNA conditional access. Failure causes ZTNA to fall back to identity-only evaluation.
- GRC — compliance evidence cycles, regulatory interpretation. Failure delays audit responses, doesn't block daily operations.
- SOC — incident detection and handoff. Failure means identity incidents may not be detected outside the function's own observability.

Regulatory dependencies

- Annual SOC 2 Type II audit (PwC) — function provides identity and access controls evidence
- State banking regulator oversight — periodic examiner reviews, ad-hoc requests
- GLBA examiner — data-handling and customer-information-protection reviews

Dependency management cadence

Each P0 vendor has a quarterly business review with the Director. Internal dependencies are managed at the boundary cadences listed in Section 2. Regulatory dependencies are managed by GRC with this function providing technical content; the Director presents to the Audit Committee quarterly.

12 — Continuous Improvement

The function commits to four mechanisms for continuous improvement, each with a stated cadence and a documented output trail.

Quarterly retrospective

Held at the strategy review. Lessons from operations and incidents from the prior quarter feed the roadmap. Output: 3-5 prioritized improvement items with named owners and target completion dates.

Operating model formal review

Annual review of this document; ad-hoc reviews on material change (new function scope, new tooling, org restructure). Output: updated operating model with version history; sponsor re-approval.

Function eNPS

Quarterly anonymous team survey. Patterns inform team-health interventions. Output: action items addressed at function leadership team within 30 days of survey close.

Incident retrospective flow

Every SEV-0 and SEV-1 incident triggers a Post-Incident Review feeding into the Post-Incident Action Tracker (Artifact #32 in the toolkit). The function reviews systemic items quarterly to surface patterns that no single incident shows. Output: function-level remediation roadmap items.

13 — Risks to Operating Model

The function tracks four risks that could materially impair the operating model itself. These are distinct from operational risks (which are tracked in the program RAID Log and the function's own risk register); these are risks to the structural ability of the function to deliver.

ZTNA architecture key person risk

Single senior engineer holds ZTNA architectural depth. Mitigation: cross-training Senior Network Engineer through 2026; documented architectural decisions in the ZTNA Design Doc (Engineering Example #261); rehearsal of architectural-decision scenarios at quarterly strategy review.

Single-vendor concentration on Okta

Okta is the foundational identity layer; replacement would be a multi-year migration. Mitigation: contract terms allow exit with sufficient notice; SailPoint provides governance abstraction so identity-platform-specific governance code is minimized; vendor relationship managed at the highest tier with named escalation path.

Capacity vs demand drift

As Bristol grows, identity volume grows; the function's headcount is fixed in any given year. Mitigation: automation roadmap addresses the highest-volume work first (joiner/mover/leaver, MFA enrollment); annual planning cycle re-evaluates headcount; quarterly strategy review tracks capacity-vs-demand as a leading indicator.

Knowledge transfer from Project Atlas

Atlas component PMs hold significant capability-specific knowledge that the operating team needs to inherit. Mitigation: formal handoff plan starting Q1 2027 covering documentation, shadowing, and decision-authority transition; budget allocated for handoff overlap (Atlas PMs retained 30% time for 60 days post-closeout).

14 — Approval & Review

Function head	Director, Cloud Security Operations — approved 2026-04-01
Sponsor	Sandra Park (CISO) — approved 2026-04-08
Coalition acknowledgment	Linda Walsh (CIO) — acknowledged 2026-04-10 Robert Stein (CRO) — acknowledged 2026-04-12 Mark Williams (CTO) — acknowledged 2026-04-15
GRC liaison	GRC Director — acknowledged 2026-04-12
HR partner	HR IT Director — acknowledged 2026-04-15
Audit Committee	Quarterly review at next Audit Committee meeting (2026-Q2); will be standing topic going forward
Last review date	2026-04-01
Next scheduled review	2027-04-01

Triggered review conditions

- Material change in function scope (e.g., new capability assigned, capability divested)

- Material change in organization structure (e.g., team restructure, headcount change of 20%+)
- Material change in tooling (vendor replacement, platform migration)
- After any SEV-0 incident with implications for the operating model itself
- After Project Atlas program closeout (expected Q3 2027) for re-baseline of post-program steady state

Material changes since last version

Added Project Atlas scope (PAM and Access Review) to the function's responsibilities. Updated meeting cadence to add the monthly Steering Committee touchpoint. Updated KPIs to include MFA coverage and privileged access via PAM as explicit measures. Refreshed boundaries-with-adjacent-functions section to reflect post-program operational ownership. Added the Atlas knowledge-transfer risk to Section 13.

Related artifacts

- Artifact #29 (Operating Model Document): the structural artifact this example populates
- Artifact #11 (Stakeholder Register): the cross-functional relationships this operating model formalizes
- Artifact #21 (UAT Plan & Test Cases): the PMO methodology's view of UAT, used by this function during Atlas-built capability handoff
- 33 — Recovery Plan — Project Atlas: the program whose closure this operating model receives
- Engineering Example #249 (IR Plan — ZTNA Service): the IR plan owned by this function in steady state
- Engineering Example #252 (DR Plan — Identity Platform): the DR plan owned by this function in steady state
- 1 — Communications Plan — Project Atlas: the program comms plan that announces the operational handoff to this function

Keywords: Operating Model example, Cloud Security Operations example, security function operating model, function operating model, purpose mandate, organization structure, governance decision rights, core processes, service catalog, KPIs performance metrics, capacity workforce plan, budget financial model, operating model approval, function operating model example, populated operating model, comprehensive operating model example, Bristol Financial operating model

HOW TO READ THIS EXAMPLE

Why this example works: The operating model artifact is exemplary because it resolves the ambiguity that survives most security transformations: who owns detection, who owns response, and where the handoff happens when a ZTNA anomaly fires at 2am. It does this by mapping people, process, and tooling at each layer simultaneously, so the reader can trace an alert from sensor to resolution without leaving the document.

Key judgment calls:

- Placing tier-1 triage in the managed MSSP and tier-2 investigation in the internal SOC rather than the reverse, accepting a 15-minute mean-time-to-triage increase in exchange for 40% cost reduction and 24x7 coverage that the internal team could not sustain.
- Drawing the RACI boundary at the cloud control plane level - Bristol Financial owns policy, the cloud provider owns infrastructure - which is a contractual and risk-governance decision masquerading as an org design one.
- Deferring the insourcing decision for cloud-native SIEM to an 18-month review rather than deciding it at program launch, preserving optionality while the team builds operational maturity.

Adapting it to your context:

- The three-tier model (MSSP triage, internal SOC investigation, engineering escalation) is a portable pattern for any cloud security operations model; resize each tier to match your headcount and budget reality.
- Bristol Financial's regulatory posture (FCA jurisdiction, financial sector) drives certain data sovereignty decisions in the model; identify your own regulatory constraints before drawing cloud provider boundaries.
- The tooling stack named in Atlas (Prisma Access, CrowdStrike, Splunk Cloud) is illustrative; the operating model structure should be drawn first, then tools selected to fill each layer, not the reverse.

25 — Program Charter — Project Atlas

25 — Program Charter — Project Atlas (PgMP-depth)

Project Atlas is itself a program — 5 component projects under one strategic outcome. The Program Charter is heavier than a project charter because programs have more components, longer horizons, and benefits that materialize across initiatives. Approved Dec 18, 2025.

Document control

Title	Project Atlas — Program Charter (Multi-Initiative)
Version	v1.2 (approved)
Date	2025-12-18
Author	Casey Morrison (Program TPM) with Sandra Park (sponsor)
Approver	Board Risk Committee + CEO + Sandra Park (CISO sponsor)

1. Strategic context

Strategic outcome the program delivers

Bristol Financial achieves a Zero Trust security posture by Q3 2027, enabling cloud strategy and reducing the identity-related risk exposure that resulted in 14 SOC 2 findings (2025) and a \$1.2M insider-threat incident (Q3 2025).

Why a program (and not separate projects)

The 5 component initiatives must be sequenced and integrated to deliver value. IDP migration must complete before PAM can rely on Okta-issued tokens. ZTNA depends on IDP for identity-aware access decisions. MFA hardening intersects all of them. Run as separate projects, the dependencies would conflict and delivery would slip 6+ months.

Strategic alignment

- 'Secure by 2027' (Board strategic priority, approved Oct 2025)
- 2026 SOC 2 audit objectives (CRO accountability)
- Cloud Migration program (PROG-2026-003) — downstream dependency

Expected business value at program level

- \$4.5M annual risk exposure reduction (audit-validated)
- Pass 2026 SOC 2 with zero identity findings
- Unblock 4 downstream cloud initiatives
- Establish durable Cloud Security Operations function

The combined program value is greater than the sum of the components because the SOC 2 finding-zero-out requires ALL 5 components to land coherently.

2. Program scope

Components (in-scope projects)

Component	PM	Goal	Type	Status
Identity Provider Migration	M. Ortiz	Migrate 3,500 users from legacy AD to Okta S	sequenced E	execute (65%)
ZTNA Rollout	J. Liu	Replace VPN with ZTNA for 100% of corporate apps S	sequenced E	execute (45%)
PAM	K. Reddy	Deploy BeyondTrust to 100% of privileged accounts S	sequenced P	plan (20%)
MFA Hardening	S. Chen	FIDO2 for privileged Q2; all employees Q4 P	parallel E	execute (30%)
Access Review Automation	P. Nguyen	Automate access reviews for SOX/GLBA scope P	parallel I	initiate (10%)

Out of scope (program level)

- Customer-facing identity (CIAM) — separate program
- Endpoint privilege management (EPM) — separate program
- Mainframe access — separate refresh cycle
- Mobile device management — separate refresh

3. Program governance

Governance structure

- Program Steering Committee: Sandra Park (chair), Linda Walsh (CIO), Mark Williams (CTO), Robert Stein (CRO), Martin Chen (PMO)
- Program Board: Casey Morrison (TPM, chair), 5 component PMs, OCM Lead, Sec Lead
- Component PMs report to Program TPM (matrix); component sponsors are component managers
- External: Board Risk Committee quarterly briefing; KPMG quarterly external review

Forum	Purpose	Frequency	Attendees	Decisions made here
Program Steering Committee	Executive governance, escalations	Monthly	Sandra Park (chair) + execs S	scope changes affecting program, budget changes >\$100K, major risks
Program Board	Operating governance	Weekly	TPM + component PMs	Cross-component dependencies, resource conflicts, weekly status

Forum	Purpose	Frequency	Attendees	Decisions made here
Component standups	Component-level coordination	Daily	Component PM + team	Component-level execution
Quarterly Board briefing	Oversight	Quarterly	Sandra + Robert + Board R	risk acceptance, major scope decisions

4. Integration management

Cross-component dependencies (most critical)

Dependency	From component	To component	Type	Risk if missed
PAM relies on Okta tokens	IDP	PAM	Identity	High — PAM cannot enforce policies without Okta
ZTNA relies on Okta SSO	IDP	ZTNA	Identity	High — ZTNA decisions require Okta auth
Access Review relies on PAM data	PAM	Access Review	Data flow	Medium — automation engine needs PAM logs
MFA hardening enables PAM	MFA	PAM	Authentication	Medium — PAM step-up requires FIDO2
Cloud Security Operations	All	Operations	Operational hand-off	High — durable team owns post-program

Shared resources

- TPM (Casey Morrison) — single TPM across program (intentional; documented in DC-003)
- OCM Lead (R. Patel) — shared 60% Atlas / 40% Cloud Migration (key constraint)
- Senior Network Eng (D. Park) — shared with Network Operations
- Helpdesk (Tier 1 + 2) — shared with all programs (capacity managed quarterly)

5. Program benefits realization

Benefit	Realization owner	When	Measurement
Risk exposure reduction	Sec Lead	Cumulative through Sep	2027 Annual risk-exposure delta vs 2025 baseline
SOC 2 finding zero-outs	andra Park A	ug 2026	External auditor (KPMG) confirmation
VPN decommissioning J	. Liu (component) N	ov 2026	Concentrator inventory check
PAM coverage K	. Reddy (component) A	pr 2027	Privileged account audit report

Benefit	Realization owner	When	Measurement
Cloud Migration unblocking C	loud Migration sponsor Q	1 2027	Cloud Migration milestone gate

6. Program budget (summary)

Approved: \$8.4M (Capex \$5.2M + Opex \$3.2M)

Component allocation: see component charters

Reserve: \$200K contingency at sponsor discretion (up to \$100K single-drawdown)

Steering authority: drawdowns >\$100K require steering approval

7. Program risk profile (top 5 risks at program level)

R-PG-001: Sponsor (Sandra Park) departure mid-program (Low/High; succession plan documented)

R-PG-002: 2026 SOC 2 audit findings broader than identity scope (Medium/High; KPMG quarterly check-in)

R-PG-003: Cross-component dependency cascading slip (Medium/High; weekly cross-component review)

R-PG-004: Cloud Security Operations operational hand-off underestimated (Medium/Medium; 6-month overlap planned)

R-PG-005: External auditor team change affecting audit window (Low/High; quarterly KPMG check-in)

8. Approvals

Board Risk Committee: J. Henderson (chair) / 2025-12-18 / signed

CEO: A. Tanaka / 2025-12-18 / signed (acknowledgment, not approval — sponsor authority)

Program Sponsor (CISO): Sandra Park / 2025-12-18 / signed

CIO: Linda Walsh / 2025-12-18 / signed

CTO: Mark Williams / 2025-12-18 / signed

CRO: Robert Stein / 2025-12-19 / signed

PMO: Martin Chen / 2025-12-18 / signed

What this Program Charter does that a Project Charter doesn't

1. Names the integration management explicitly — programs fail at the dependencies between components, not within components
2. Captures benefits that materialize across components, not within one
3. Defines program governance separate from component governance — different cadences, different decisions
4. Documents what's in-scope at program level vs what each component does
5. Has Board-level approval (not just sponsor) — program scale warrants oversight

HOW TO READ THIS EXAMPLE

Why this example works: This charter earns authority by being specific: it names the sponsor by role, bounds scope to ZTNA and PAM workstreams, and states what is explicitly out of scope so no one can later expand the program by implication. A reader should notice that the mandate is tied to a business risk (third-party credential exposure), not to a technology aspiration.

Key judgment calls:

- Defining program boundaries in the charter rather than deferring to a later scope document, which prevents scope creep before the program starts.
- Granting the PM delegated financial authority up to a stated threshold, balancing speed with control.
- Naming the escalation path to SteerCo and the conditions that trigger it, so the charter itself sets governance norms.

Adapting it to your context:

- Reuse the mandate-to-business-risk linkage; replace Bristol Financial's credential-exposure driver with the specific regulatory or operational risk motivating your program.
- Keep the explicit out-of-scope list but repopulate it with the adjacent work your stakeholders will try to pull in.
- Calibrate the delegated authority threshold to your organization's procurement and finance policy.

26 — Program Governance & Integration Management — Project Atlas

Project Atlas is a 5-component program. The Governance & Integration Management document defines HOW the program runs at the program level — distinct from each component's project governance. Approved alongside the Program Charter (Dec 2025).

Document control

Title	Project Atlas — Program Governance & Integration Management
Version	v1.3 (live; updated quarterly)
Date	2026-04-15 (latest revision)
Author	Casey Morrison (Program TPM) with PMO Director
Approver	Sandra Park (sponsor), Martin Chen (PMO Director)

1. Purpose

This document answers: when something doesn't fit cleanly inside one component, how is it decided? Programs fail at the seams between components, not within them. Integration management is the discipline of managing those seams.

2. Governance forums (program-level)

Forum	Cadence	Owner	Decisions made here	Inputs	Outputs
Program Steering Committee	Monthly	Sandra Park	Scope/ budget/ timeline changes affecting program	Status report, RAID summary	Decisions log entries; approvals
Program Board	Weekly	Casey Morrison	Cross-component dependency resolution	Component status, dependency log	Updates to dependency log; escalations
Component standups	Daily	Component PMs	Component-level execution	Component RAID, sprint progress	Action items; risk surfacing
Cross-	Bi-weekly	Casey	Validate	Dependency	Dependency

Forum	Cadence	Owner	Decisions made here	Inputs	Outputs
component review		Morrison	dependency assumptions still hold	log + component plans	status updates
Quarterly Board briefing	Quarterly	Sponsor	Risk acceptance, major scope decisions	Program risk profile, quarterly KPI	s Board acknowledgments
External auditor (KPMG)	Quarterly	Sec Lead	Audit alignment + scope check	Status of identity remediation	Audit posture confirmations

3. Decision rights at program level (RACI)

Decision type	R	A	C	I
Scope change affecting program (>5% scope)	TPM	Sponsor	Steering, CTO	Component PMs, Board
Budget reallocation across components ≤\$100K	TPM	Sponsor	Finance partner	Steering (after the fact)
Budget reallocation >\$100K T	PM S	teering S	ponsor, Finance B	oard (next quarterly)
Schedule extension affecting critical milestone	TPM	Sponsor	Steering, Component PM	Stakeholders
Vendor selection (program level)	Component PM	Sponsor + CTO	Procurement, Legal	TPM, Steering
Resource conflict between components	TPM	Sponsor	Component PMs	HR, affected teams
Cross-component dependency resolution	TPM	Component PMs	Architecture review	Sponsor (if escalated)
Risk acceptance (program level)	Sec Lead	Sponsor + CRO	Steering	Board (next quarterly)

4. Integration management — the cross-component dependencies

The 5 components have 8 interlocking dependencies. Each is owned by a named component PM, monitored at the bi-weekly cross-component review.

Dependency	From	To	Owner	Status	Last validated
PAM relies on Okta tokens I	DP P	AM K	. Reddy O	n-Track 2	026-07-15
ZTNA relies on Okta SSO I	DP Z	TNA J	. Liu O	n-Track 2	026-07-15
Access Review relies on PAM data pipeline P	AM A	ccess Review P	. Nguyen A	t-Risk 2	026-07-15
MFA enables PAM step-up M	FA P	AM K	. Reddy A	t-Risk 2	026-07-15
ZTNA Wave 3 depends on PAM go-live P	AM Z	TNA J	. Liu A	t-Risk 2	026-07-15
Cloud Security Operations needs all components A	ll O	perations S	ec Lead O	n-Track 2	026-07-15
SOC 2 audit needs IDP + MFA + Access Review 3	components A	udit S	ec Lead O	n-Track 2	026-07-15
Cloud Migration program needs IDP completion I	DP C	loud Migration M	. Ortiz O	n-Track 2	026-07-15

How dependencies get managed:

- Each dependency has a named "from" PM and "to" PM
- Status: On-Track, At-Risk, Off-Track, Resolved (closed)
- Bi-weekly review: each dependency owner confirms status; surface At-Risk + Off-Track to TPM
- Dependency status changes feed the program RAID Log (D-001 through D-008)

5. Issue and risk escalation paths

Severity	Level	Owner	Escalation path	Time-bound
P1	Critical	Component PM	To TPM within 1 hour; TPM to Sponsor within 4 I	mmEDIATE
P2	High	Component PM	To TPM within 1	Same week

Severity	Level	Owner	Escalation path	Time-bound
			business day	
P3	Medium	Component PM	Surface at weekly Program Board	Next cycle
P4	Low	Team	RAID Log entry; reviewed at component standup R	outline

Escalation example: I-008 (ZTNA Wave 2 cutover paused after 11/18 incident) was P1. Surfaced from J. Liu's component team to TPM within 30 minutes; TPM escalated to Sandra Park within 90 minutes; sponsor decision (DC-027) within 24 hours.

6. Cross-component working agreements

Communication

- All component PMs share a single Slack channel for cross-component coordination
- Weekly written status (Friday by 12pm PT, format defined in Status Report template)
- Email reserved for external stakeholders and decisions requiring written record

Tooling

- Single Microsoft Project file as integrated schedule (program TPM owns)
- Shared workbook for RAID, decisions, budget (program TPM owns master; component PMs own component-level rollups)
- Confluence space for program documentation (everyone authors; TPM curates)

Resource sharing

- Helpdesk Tier 1+2 capacity managed quarterly across all components (no component pre-empts)
- OCM Lead split is documented (60% Atlas, 40% Cloud Migration); cannot be unilaterally changed
- Senior Network Eng allocation reviewed monthly given C-002 conflict

Conflict resolution

- Component PM disagreements: TPM mediates within 1 business day
- Component PM vs vendor: Component PM owns; TPM consults if material
- Component PM vs sponsor: Component PM raises directly to TPM; TPM owns sponsor relationship

7. Performance & assurance

Quarterly program review (sponsor + steering): does the program still make business sense?

- Are the benefits we expected still on track? (linked to Benefits Realization)
- Is the risk profile holding within tolerance?
- Are component variances cancelling each other out (good) or compounding (bad)?
- Is the cost-of-delay-to-decision growing (bad)?

Monthly steering review: how is the program executing?

- Status report (1 page) + RAID top 5 + decisions for ratification
- Open questions for steering: 3-5 max

Continuous: TPM walks the dependency board weekly; one-question check-in on each dependency

8. When governance changes

This document gets updated when:

- A new component is added or removed (no component change in Atlas to date)
- A governance forum's purpose changes (e.g., we added the bi-weekly cross-component review at v1.2 in Apr 2026)
- A decision-rights ambiguity surfaces (we updated v1.1 after DC-019 raised a question about reserve drawdown authority)
- An external dependency is added (e.g., when the Cloud Migration program added Atlas as a dependency)

Each update is logged in the Decisions Log; the version history is at the back of this document.

What this Governance document does that a Project Charter doesn't

1. Defines decision rights for the seam-between-components decisions, not just the within-component ones
2. Documents the integration cadence (bi-weekly cross-component review) — this is where 'forgotten' dependencies surface
3. Specifies escalation timing (P1 within 1 hour) — not just the path
4. Captures working agreements — the small things that prevent friction (single Slack channel, etc.)
5. Lives at program level only — components have their own RACI for their own decisions

HOW TO READ THIS EXAMPLE

Why this example works: This document demonstrates integration management as active orchestration, not org-chart description: it maps how Atlas decisions propagate to dependent projects, names the specific forums where cross-program conflicts get resolved, and shows how change control links back to the charter. A reader should notice that every governance mechanism has a named owner and a cadence, so accountability is unambiguous.

Key judgment calls:

- Designating a single integration owner rather than distributing accountability across workstream leads, which prevents decisions falling between teams.
- Running a weekly dependency review separate from the status meeting so integration issues get dedicated airtime.
- Requiring a formal impact assessment before any change that touches a shared service or downstream project.

Adapting it to your context:

- Reuse the forum structure and decision-rights matrix; repopulate it with your actual program components and the teams that own them.
- If your program is smaller, consolidate forums but preserve the principle of separating status reporting from decision-making.
- Adjust the change control trigger thresholds to match your organization's tolerance for informal versus formal decisions.

27 — Program Benefits Realization — Project Atlas

The Benefits Realization plan answers: how do we know the \$8.4M we're spending actually delivered the value we promised? Approved alongside Program Charter; updated quarterly. This is the live state at week 22 (mid-July 2026).

Document control

Title	Project Atlas — Program Benefits Realization Plan
Version	v2.1 (Q3 update)
Date	2026-07-15
Author	Casey Morrison (Program TPM) with Sandra Park (sponsor) + Finance partner
Approver	Sandra Park (sponsor); Steering committee acknowledged

1. Why this document exists separately

The Charter listed expected business value. The Benefits Realization Plan tracks whether each expected benefit:

- Has a specific measurable target
- Has a named owner accountable for delivering it
- Has a defined measurement method and date
- Is being measured during execution (not just at close)
- Has a baseline (what 'before' looked like) to compare against

Without this discipline, programs deliver outputs (we shipped X) without proving outcomes (the business is better off because we shipped X).

2. Benefits register

Benefit	Owner	Baseline	Target	Realization date	Status (week 22)
B-001: Identity-related risk reduction	Sec Lead	\$4.5M annual exp.	\$4.5M reduction	Cumulative Sep 2027	On-Track
B-002: SOC 2 audit findings (identity)	Sandra Park	14 findings 0	findings A	ug 2026 O	n-Track
B-003: VPN concentrators decommissioned	J. Liu	0 of 8 8	of 8 N	ov 2026 O	n-Track
B-004: Privileged accounts in PAM	K. Reddy	0 of 150 1	50 of 150 A	pr 2027 A	t-Risk (PAM design)
B-005: All employees on FIDO2 MFA	S. Chen	0 of 3,500 3	,500 of 3,500 D	ec 2026 A	t-Risk (M-008 slip)
B-006: Cloud Security Ops function FTE	Sec Lead	0 FTE 1	4 FTE + 3 ctr. Q	3 2027 ramped O	n-Track
B-007: Cloud Migration program unblocked	Cloud Mgrt	Blocked U	nblocked Q	1 2027 O	n-Track
B-008:	OCM Lead	60%	0%	ost Wave 2	et (73%)

Benefit	Owner	Baseline	Target	Realization date	Status (week 22)
Helpdesk first-call resolution rate		7	P	M	
B-009: User adoption (workforce-wide)	OCM Lead	N/A	9 5% P	ost Wave 3 P	ending
B-010: Audit-validated risk exposure delta	CRO + Sec Lead	\$4.5M \$	4.5M-5.5M C	umulative Q3 2027 O	n-Track

3. Measurement methodology per benefit

B-001 (Risk reduction): Annual delta calculated by GRC + external auditor. Method: 2025 baseline scored each finding with cost estimate (audit findings × probability × impact); 2026/27 cumulative remediation × same scoring = realized delta. Measured at year-end.

B-002 (SOC 2 zero findings): KPMG external audit; binary measurement (zero or non-zero identity findings). Measured at audit closeout (Sep 2026).

B-003 (VPN decommission): Operational inventory check. Method: Cisco AnyConnect concentrators in production = N. Target N=0 by Nov 2026. Measured monthly.

B-004 (PAM coverage): BeyondTrust dashboard report. Method: 'Privileged accounts under PAM control' / 'Total privileged accounts' × 100. Target 100% by Apr 2027. Measured weekly during ramp.

B-005 (MFA enrollment): Okta + FIDO2 enrollment audit. Method: Users with FIDO2 token registered / Total workforce × 100. Target 100% by Dec 2026. Measured weekly during ramp.

B-006 (Operations FTE): HR roster + Operations org chart. Method: Named individuals in Cloud Security Operations function. Target 14 FTE + 3 contractors by Q3 2027. Measured monthly.

B-007 (Cloud Migration unblocked): Cloud Migration program milestone achieved. Method: Cloud Migration sponsor confirms IDP-dependency milestone met. Measured at gate.

B-008 (Helpdesk FCR): Helpdesk tracking system + ticket sampling. Method: Tickets resolved at Tier 1 / Total Tier 1 tickets × 100. Target 70%. Measured monthly post Wave 2.

B-009 (User adoption): Application access logs + survey. Method: Active users on new identity stack (login in last 30 days) / Total workforce × 100. Target 95% post Wave 3. Measured monthly post Wave 3.

B-010 (Risk exposure delta): External auditor (KPMG) annual validation. Method: Risk register quantified before vs after; auditor confirms methodology. Target \$4.5M-5.5M cumulative. Measured at year-end.

4. Realization timeline

When does each benefit actually materialize?

T+0 (program start, Jan 2026): No realized benefits yet

T+8 months (Aug 2026): SOC 2 audit closeout — B-002 realized

T+11 months (Nov 2026): VPN decommissioned — B-003 realized; first risk-exposure measurement

T+12 months (Dec 2026): MFA workforce-wide complete — B-005 realized

T+12 months (Dec 2026): Helpdesk FCR measurable post Wave 2 — B-008 confirmed

T+15 months (Apr 2027): PAM 100% — B-004 realized

T+18 months (Jul 2027): Cloud Security Ops fully ramped — B-006 realized

T+20 months (Sep 2027): Annual risk exposure delta validated — B-001, B-010 realized

Cumulative Sep 2027: Full benefit realization

This timeline matters because the benefits are not realized at go-live; they're realized as adoption deepens. A program that ships outputs without measuring this curve overstates its impact.

5. At-risk benefits and mitigations

B-004 (PAM coverage): At-Risk because PAM design phase has 1-week slip. Mitigation: K. Reddy committed to schedule recovery; weekly check.

B-005 (MFA enrollment): At-Risk because M-008 (privileged) is +14d. Mitigation: outreach campaign extended; manager-level escalation; sponsor approved deadline extension. Realization date holds.

If either benefit slips, the realization date for B-010 (cumulative risk exposure delta) shifts proportionally. We track this dependency explicitly.

6. Quarterly review process

What we do every quarter:

1. Walk each benefit row: status, owner, current measurement
2. Validate that the measurement method still works (data sources, tools, ownership)
3. Surface any benefits that have changed assumptions (e.g., 2025 baseline may need revisiting)
4. Confirm or revise realization dates
5. Review what the steering committee should know

Output: updated v[N+1] of this document; presented to steering at quarterly review; archived.

7. Lessons from mid-program review

L-1 (Mar 2026): B-008 (Helpdesk FCR) baseline was 60% but our measurement methodology had drift. Re-measured baseline; 60% confirmed valid.

L-2 (May 2026): B-001 (Risk reduction) was based on 2025 audit findings only; 2026 audit may surface new findings. Decision (DC-033, July): re-baseline B-001 against 2026 audit results once available.

L-3 (June 2026): B-009 (User adoption) cannot be measured until Wave 3 because all employees won't be on the new system until then. Made realization date dependency on B-005 explicit.

8. Approvals

Sponsor (CISO): Sandra Park / 2026-07-15 / signed

PMO Director: Martin Chen / 2026-07-15 / signed

CRO: Robert Stein / 2026-07-15 / signed

Finance partner: J. Petersen / 2026-07-15 / acknowledged

External auditor (KPMG): quarterly methodology check (last 2026-Q2)

What this Benefits Realization plan does

1. Forces measurement design before benefits are claimed — without measurement, claims are vibes
2. Names an owner for each benefit — a benefit without an owner doesn't realize

- 3. Captures realization timeline — outputs ship at go-live; outcomes ship over months
- 4. Measured continuously — a benefit reviewed only at close is a benefit that never had to be earned
- 5. Connects benefits to risks — when B-005 goes At-Risk, B-001 inherits that risk

HOW TO READ THIS EXAMPLE

Why this example works: This benefits realization plan is exemplary because it traces every benefit to a measurable baseline, an owner, and a measurement date that falls after go-live, not during delivery. A reader should notice that benefits are expressed in business terms (mean time to detect credential misuse, reduction in standing privileged access) rather than project output terms (policies deployed, agents installed).

Key judgment calls:

- Separating efficiency benefits (cost avoidance) from risk reduction benefits and applying different measurement methodologies to each.
- Assigning benefit ownership to the business unit, not the program team, so accountability survives program closure.
- Scheduling an 18-month post-closure measurement to capture benefits that accrue after behavioral change settles.

Adapting it to your context:

- Reuse the benefit taxonomy (financial, risk, operational) and the baseline-owner-date structure for any program.
- Replace Bristol Financial's credential-misuse metrics with the specific threat or compliance driver your program addresses.
- Negotiate benefit ownership with the receiving business unit before the charter is signed, not at program closure.

28 — Project Intake Form — Cloud Migration Initiative

28 — Project Intake Form — Bristol Cloud Migration Initiative (downstream)

The Intake Form is what someone fills out to PROPOSE a new project — before it has a Charter, before resources are committed, before the PMO scopes it. This is the actual intake submitted Apr 2026 for the Cloud Migration program (PROG-2026-003), which depends on Atlas IDP completion. Submitted by IT, scoped by PMO, prioritized at portfolio review.

Document control

Title	Project Intake — Cloud Migration Initiative
Form ID	INTAKE-2026-014
Date submitted	2026-04-08
Submitter	Linda Walsh (CIO)
Status	Approved (Q3 2026 portfolio cycle); Charter authoring in progress

1. Project basics

Working title	Bristol Cloud Migration Program
One-sentence summary	Migrate Bristol's primary applications from legacy on-prem datacenters to AWS cloud, enabling cost reduction and workforce flexibility.
Submitter	Linda Walsh (CIO) — sponsor candidate

Working title	Bristol Cloud Migration Program
Submitter org	IT
Date needed	Charter approval by Aug 2026; execute starting Q4 2026
Estimated duration	30 months (Q4 2026 – Q1 2029)

2. Why we're proposing this

Business problem

Bristol's primary applications run on a legacy datacenter footprint that is end-of-life by 2029-Q1 (lease expires; hardware refresh would require \$25M Capex). Cloud migration was on the strategic roadmap before the 2025 SOC 2 audit; identity modernization (Project Atlas) is a precondition.

Strategic alignment

- 'Secure by 2027' (already aligned via Atlas dependency)
- 'Operational excellence' strategic priority (cost reduction)
- Workforce-flexibility strategy (remote-first operating model)

Estimated business value

- Avoid \$25M Capex refresh
- Reduce operational cost ~\$3-5M annually (estimate; refine in Charter)
- Enable workforce flexibility (specific KPIs in Charter)
- 4 downstream initiatives blocked on cloud migration (data analytics, CRM modernization, customer portal, ML platform)

Cost of not doing

- \$25M Capex refresh (forced by 2029-Q1 lease expiration)
- Continued operational pressure of legacy infrastructure
- 4 strategic initiatives delayed indefinitely
- Customer-facing services on legacy hardware risk reliability incidents

3. Approximate scope

In-scope (anticipated)

- ~140 applications (full inventory in Charter)
- Core financial systems, customer portal, internal applications
- Data warehouse migration
- Disaster recovery infrastructure

Out-of-scope (anticipated)

- Mainframe systems (separate refresh cycle, not in lease)
- Customer-facing identity (separate program; CIAM)
- Network refresh (parallel program)
- Endpoint refresh

4. Dependencies

This program depends on:

- Project Atlas IDP completion (Q3 2026 hard date) — without Okta as identity provider, cloud migration can't deploy modern identity-aware access
- Project Atlas ZTNA Rollout (Q4 2026) — cloud apps need ZTNA-protected access
- Bristol AWS Master Service Agreement (in legal review; targeting Aug 2026)
- Cloud Center of Excellence standup (existing function; capacity for governance)

This program is depended on by:

- Data Analytics Modernization (PROG-2027-001, planning)
- CRM Modernization (PROG-2027-003, planning)

5. Estimated cost (high-level)

Capex: \$18-22M (cloud infrastructure, migration tooling, training)

Opex: \$8-12M over 30 months (cloud consumption, vendors, internal labor)

Total: \$26-34M (refine in Charter)

Versus alternative: \$25M Capex on legacy refresh + ~\$2-3M annual operating cost (vs. cloud which has higher upfront but lower long-term)

6. Estimated resourcing

Internal: 30-40 FTE peak (Cloud Engineering, Application teams, Security, Operations)

External: AWS Professional Services, migration partner (RFP needed), training partner

Resource constraints noted:

- Cloud Engineering team currently ~12 FTE; needs ramp to 25+ for migration period
- 6-month overlap with Atlas program for IDP/ZTNA dependencies
- OCM Lead is split between Atlas and Cloud Migration (40% allocation already committed)

7. Risk profile (top 5)

R-CMG-001: Atlas IDP dependency slip → Cloud Migration starts late (Medium/High)

R-CMG-002: 2029-Q1 datacenter lease deadline is hard (High/High)

R-CMG-003: AWS MSA negotiation delays (Medium/High)

R-CMG-004: Cloud Engineering team capacity ramp (Medium/Medium)

R-CMG-005: Application migration complexity higher than discovery suggests (Medium/High)

8. Recommended PMO action

Recommended action	Charter authoring; Q3 2026 prioritization
Recommended ownership	PMO assigns dedicated TPM
Recommended sponsor	CIO (Linda Walsh) — already submitted as sponsor candidate
Recommended next steps	Detailed scope discovery; AWS engagement; charter draft by July; charter approval Aug 2026
Recommended priority	P1 (strategic, time-bound by lease)

9. PMO assessment (added by PMO during scoping)

Assessment date: 2026-04-22

Assessor: Martin Chen (PMO Director) with Casey Morrison (TPM)

Strategic fit: STRONG (aligns with 2 strategic priorities; downstream of approved program)

Time-bound urgency: HIGH (2029-Q1 lease is hard; backwards-planned schedule shows Charter must approve by Aug 2026)

Resource readiness: MEDIUM (Cloud Engineering team needs ramp; budget provisional)

Risk profile: MEDIUM-HIGH (concentrated risk in Atlas dependency)

Dependencies: COMPLEX (downstream of Atlas; 6-month overlap; shared OCM resource)

PMO recommends: APPROVE for Charter authoring; treat as P1 priority in Q3 portfolio cycle.

10. Portfolio committee decision

Decision date: 2026-05-04

Decision: APPROVED for Charter authoring

Conditions:

- Charter must validate the \$25M Capex avoidance number
- Charter must specify the detailed 6-month overlap plan with Atlas
- Charter must include an OCM resource plan that doesn't compromise Atlas commitments

Charter due: 2026-07-15

Charter approval target: 2026-08-15

11. Approvals (intake stage)

Submitter: Linda Walsh / 2026-04-08

PMO Director (scoping): Martin Chen / 2026-04-22

Portfolio Committee: chaired by Sandra Park / 2026-05-04 / approved

What this Intake Form is doing (vs a Charter)

1. Lightweight — fills in 2-4 hours, not 2-4 weeks
2. Captures the BUSINESS CASE before resources are committed
3. PMO scoping happens between submission and approval — independent assessment
4. Portfolio committee decides priority among competing intakes — not just yes/no
5. Charter is the next step IF approved — and the Charter validates the assumptions in this intake

HOW TO READ THIS EXAMPLE

Why this example works: This intake form is exemplary because it forces the requestor to answer the questions the portfolio review board will ask anyway: strategic alignment, dependencies on existing programs, and a rough resource demand curve. A reader should notice that the form is structured to surface portfolio conflicts at intake, not after resources are committed.

Key judgment calls:

- Requiring the requestor to self-identify program dependencies rather than relying on the PMO to discover them, which shifts accountability and surfaces information earlier.
- Including a mandatory field for the business owner separate from the requestor, ensuring there is a named sponsor before the intake is accepted.
- Asking for a three-horizon resource estimate (people, budget, infrastructure) even at the intake stage, so the portfolio board can assess feasibility before scoping begins.

Adapting it to your context:

- Reuse the dependency and resource-demand fields verbatim; these are universally applicable to any portfolio intake process.
- Adjust the strategic alignment taxonomy to match your organization's current strategic priorities or investment themes.
- If your portfolio governance is lighter, you can collapse the three-horizon estimate to a single order-of-magnitude budget range without losing the core signal.

29 — Portfolio Dashboard — Bristol IT & Security Programs

29 — Portfolio Dashboard — Bristol Security & IT Programs

The Portfolio Dashboard is the executive view of all active programs and projects, used by the IT Steering Committee. Refreshed monthly by PMO. Excerpt from the July 2026 view.

Document control

Title	Bristol IT & Security Portfolio Dashboard
View date	2026-07-15
Owner	Martin Chen (PMO Director)
Audience	IT Steering Committee (CIO, CISO, CTO, CRO, Sponsors)
Cadence	Monthly view; updated at month-end

1. Active portfolio summary

Total active programs: 7

Total active projects (within programs): 14

Total active intake/Charter-stage initiatives: 4

Total approved budget across portfolio: \$42.8M

Total YTD spend: \$18.6M (43%)

Strategic objectives covered: 4 of 5 ('Secure by 2027', 'Operational Excellence', 'Workforce Flexibility', 'Customer Modernization')

2. Active programs

Program ID	Name	Sponsor	Status	Phase	% Complete	Budget	Notes
PROG-2026-001	Project Atlas (Security) S	andra Park A	t-Risk E	xecute 4	7% \$	8.4M M	FA Wave 2 + ZTNA Wave 2 driving At-Risk
PROG-2026-002	ServiceNow Modernization L	inda Walsh O	n-Track E	xecute 3	5% \$	4.2M I	TSM upgrade; on schedule
PROG-2026-003	Cloud Migration (Charter) L	inda Walsh C	harter I	nitiate 5	% \$	26-34M C	harter due Aug 2026
PROG-2025-007	Network Refresh (legacy) C	TO O	n-Track C	loseout 9	5% \$	6.8M C	losing Aug 2026
PROG-2025-009	Mainframe Stabilization C	TO O	n-Track E	xecute 7	2% \$	3.1M Y	ear 2 of 3
PROG-2026-005	Data Loss Prevention (DLP) S	andra Park O	n-Track E	xecute 6	0% \$	1.8M W	ave 1 complete; Wave 2 in progress
PROG-2026-008	Customer Portal Modernization C	ustomer GVP A	t-Risk E	xecute 2	8% \$	5.5M V	endor delays; recovery plan in flight

3. Strategic objective coverage

Objective	Programs supporting	Total budget	YTD spend	Status overall
Secure by 2027	Atlas, DLP	\$10.2M	\$5.4M (53%)	At-Risk (Atlas)
Operational Excellence	Network Refresh, ServiceNow, \$	14.1M	7.1M (50%) O	n-Track
M	ainframe			
Workforce Flexibility	Atlas (ZTNA), Cloud Migration \$	8.4M-\$42M	4.0M O	n-Track
(	charter)			
Customer Modernization	Customer Portal	\$5.5M	\$1.5M (27%)	At-Risk
Strategic Innovation	[none active]	-	-	Gap

4. Portfolio risks (top 5)

R-PORT-001: Atlas SOC 2 audit window is hard (Aug 2026); cascade risk to all dependent programs

R-PORT-002: Cloud Migration MSA negotiation delays; Charter approval at risk

R-PORT-003: Helpdesk capacity strain — Atlas Wave 2 + ServiceNow rollout + Customer Portal rollout in same quarter

R-PORT-004: Customer Portal vendor delays; second vendor selection underway as contingency

R-PORT-005: PMO capacity strain — 4 active programs at execute, 2 in initiate; PMO growth plan in progress

5. Portfolio decisions for IT Steering

Decision required at next steering (July 21):

1. Approve Cloud Migration Charter (target Aug 2026; resourcing decisions implied)
2. Helpdesk capacity reallocation — recommendation: prioritize Atlas Wave 2 over ServiceNow rollout; ServiceNow team adds 1-week buffer
3. PMO capacity expansion — recommend +2 TPM hires for Q4 2026

For information (no decision needed):

- Atlas mid-program review complete; tracking to original benefits realization
- Network Refresh closing Aug 2026 — Lessons Learned will inform Cloud Migration Charter
- Customer Portal vendor #2 evaluation underway

6. Resource utilization across portfolio

Resource pool	Total capacity	Allocated	Variance	Notes
TPM (PMO)	5 FTE	5 FTE	0	Atlas, ServiceNow, Network Refresh,

Resource pool	Total capacity	Allocated	Variance	Notes
				Mainframe, DLP each have 1 Cloud Migration + Customer Portal share 1 (over-allocation)
Cloud Engineering	14 FTE	17 FTE	+3 (over)	Cloud Migration ramp + Atlas IDP + Customer Portal
Security Operations	18 FTE	21 FTE	+3 (over)	All programs touch SecOps; DLP and Atlas peak
OCM	2.5 FTE	2.8 FTE	+0.3 (over)	Atlas + Cloud Migration share OCM Lead
Helpdesk Tier 2	10 FTE	14 FTE	+4 (over)	Q3 2026 peak; recommendation in steering
Vendor management	3 FTE	3 FTE	0	Stable

Recommendations for Steering:

- Approve +2 TPM hires for Q4 2026 (Cloud Migration + capacity buffer)
- Approve +3 Cloud Engineering FTE for Q4 2026
- Helpdesk: see Decision #2 above

7. Portfolio budget vs spend

Strategic objective	Approved	YTD spend	Forecast EAC	Variance
Secure by 2027	\$10.2M	\$5.4M	\$10.4M	+\$0.2M (within tolerance)
Operational Excellence	\$14.1M	\$7.1M	\$14.0M	-\$0.1M (under)
Workforce Flexibility	\$8.4M-42M*	\$4.0M	TBD	Charter pending (Cloud Migration)
Customer Modernization	\$5.5M	\$1.5M	\$5.7M	+\$0.2M (vendor variance)
TOTAL	\$42.8M+	\$18.6M	TBD	On plan; Cloud Migration is provisional

8. Quarterly portfolio health

Health metric	Target	Current	Status
Programs delivering benefits	≥85%	90%	On-Track

Health metric	Target	Current	Status
% programs at risk	≤30%	29%	On-Track (3 of 7)
Portfolio EAC variance	≤±5%	+1.4%	On-Track
Resource over-allocation	≤10%	+18%	At-Risk (4 over 10% threshold)
Charter throughput 1	/qtr 0	.7/qtr A	t-Risk (PMO capacity)

9. Decisions log (since last view)

DC-PORT-019 (June 2026): Atlas \$80K contingency draw approved

DC-PORT-020 (June 2026): Network Refresh closing date confirmed (Aug 2026)

DC-PORT-021 (July 2026): Customer Portal vendor #2 RFP authorized

DC-PORT-022 (July 2026): Cloud Migration intake approved for Charter authoring

10. Steering committee themes (from last 3 meetings)

Themes raised by Steering across April, May, June meetings:

- Resource over-allocation in cloud-related programs (4-of-7 programs over capacity)
- Charter throughput insufficient for strategic pipeline (only 0.7 charters/quarter; need 1+)
- Helpdesk strain visible across multiple programs

These are now action items in PMO program of work (Q3 2026).

What this Portfolio Dashboard does

1. Aggregates view across programs — Steering doesn't read 7 status reports
2. Shows strategic objective coverage — helps steering see whether portfolio is balanced
3. Flags resource constraints — programs in isolation pretend they have enough resource; portfolio view shows overlap
4. Decisions queued at portfolio level, not program level — steering knows what they're being asked to decide
5. Quarterly health metrics — same numbers tracked every quarter; trends visible

HOW TO READ THIS EXAMPLE

Why this example works: This dashboard is exemplary because it provides portfolio-level insight, not program-level status aggregation: it shows cross-program resource contention, flags programs whose combined scope changes exceed the portfolio's change budget, and surfaces benefit delivery risk at the portfolio level. A reader should notice that the red-amber-green indicators are tied to defined thresholds, not to editorial judgment by the preparer.

Key judgment calls:

- Displaying a portfolio-level change budget alongside individual program change logs, so the board can see cumulative drift before it becomes a capacity problem.
- Including a resource contention heat map that cuts across program boundaries, making shared-team overloads visible without waiting for each PM to escalate.
- Separating delivery confidence (schedule and cost) from benefits confidence (will the outcomes materialize), which prevents good execution masking poor value realization.

Adapting it to your context:

- Reuse the portfolio-level change budget concept; set your own threshold for what constitutes material scope drift across programs.

- Replace Bristol IT's program inventory with your own; the column structure (owner, phase, RAG, key risk, next milestone) is reusable as-is.
- If your portfolio is smaller, the resource contention view can be a simple table rather than a heat map, but preserve the cross-program visibility principle.

34 — Program Success Metrics, OKRs & KPIs — Project Atlas

Document Control

Program: Project Atlas — Zero Trust & Identity Modernization

Charter version this metrics doc aligns to: Charter v2.1 (2026-04-15)

Owner: Casey Morrison (Program PM/TPM)

Sponsor: Sandra Park (CISO)

Coalition: Linda Walsh (CIO), Robert Stein (CRO), Mark Williams (CTO)

Date created: 2026-01-22 (initial chartering)

Last review: 2026-04-15 (Q1 OKR review, post-Cloud Migration acceleration rebaseline)

Next review: 2026-07-15 (Q2 OKR review)

Context

Project Atlas is the most consequential security program at Bristol Financial in 2026: \$8.4M budget, 5 components (IDP, ZTNA, PAM, MFA, Access Review), 3,500 employees affected, four waves spanning Q4 2026 through Q3 2027, with Wave 4 IDP final cutover on August 17, 2027 (program week 84). The program has hard external dependencies: SOC 2 Type II audit window in August 2027, cyber insurance carrier requirements, Cloud Migration acceleration that pulled forward Components 1-3, and a state banking examiner review cycle that aligns with closeout.

Without a deliberate success metrics framework, this program would close with disagreement about whether it succeeded. The OKRs and KPIs below were established at chartering (January 2026), reset once during the Cloud Migration acceleration rebaseline (April 2026), and are reviewed quarterly with the CISO.

Section 1 — Program Objectives & Key Results

Atlas has two Objectives. The OKRs were drafted in chartering workshops with Sandra, Casey, and the four component PMs, then pressure-tested in a 90-minute session before going to the Steering Committee for approval.

Objective 1: Establish a Zero Trust foundation that meets external commitments and enables Cloud Migration

This Objective ladders to two CISO-level annual goals (regulatory readiness, cyber insurance posture) and to the CIO's Cloud Migration commitment. It's specific enough that hitting all KR's would constitute success in the eyes of all four sponsors.

KR 1.1: 100% of privileged users (~250 individuals) on FIDO2 hardware tokens by 2027-Q1

- Source: Okta MFA enrollment data + BeyondTrust privileged access logs
- Owner: K. Reddy (PAM Lead) for privileged scope; M. Ortiz (IDP) for token issuance
- Initial confidence (Jan 2026): 70%
- Q1 2026 confidence (Apr 2026): 65% (FIDO2 vendor supply slip per R-016 added risk; mitigated by buffer-token procurement DC-028)
- Status as of last review: 23% complete, on revised path

KR 1.2: Components 1-3 (IDP, ZTNA, MFA) production-ready by Cloud Migration go-live (2026-Q4)

- Source: Component PM sign-off + Cloud Migration team acceptance

- Owner: J. Liu (ZTNA), M. Ortiz (IDP), S. Chen (MFA)
- Initial confidence (Jan 2026): N/A — KR added in April 2026 rebaseline
- Q1 2026 confidence (Apr 2026): 65%
- Status as of last review: planning complete, execution in flight

KR 1.3: ZTNA gateway 99.95% availability across all four waves (measured at Wave 4 cutover, Aug 17, 2027)

- Source: ZTNA admin console + Splunk
- Owner: J. Liu (ZTNA)
- Initial confidence (Jan 2026): 80% (well-understood SLA from vendor)
- Q1 2026 confidence (Apr 2026): 80%
- Status as of last review: not yet measurable (no waves cut over)

KR 1.4: SOC 2 Type II audit (Aug 2027) closes with zero open findings on remote access controls

- Source: PwC audit report
- Owner: Sandra Park (sponsor, with GRC support)
- Initial confidence (Jan 2026): 60% (depends on FIDO2 timing and ZTNA stability across waves)
- Q1 2026 confidence (Apr 2026): 60%
- Status as of last review: program on the path

KR 1.5: All four ZTNA waves complete with cumulative help desk ticket volume below 800 across the 12 cutover weeks

- Source: ServiceNow incident data
- Owner: T. Brooks (IT Service Manager) + R. Patel (OCM Lead)
- Initial confidence (Jan 2026): 65%
- Q1 2026 confidence (Apr 2026): 65%
- Status as of last review: Wave 0 pilot data trending favorable (12 tickets across 30 pilot users, on pace for full-wave projections)

Calibration: KR 1.1 and 1.4 are the harder KRs (60-65%). KR 1.3 is well-calibrated at 80%. KR 1.2 was rebaselined and is 65%. KR 1.5 is 65%. The set sits in the right tension — achievable with focused work but not certain.

Objective 2: Bristol's identity and access posture matures from compliance-driven to durably operational

This Objective is the post-program organizational outcome. Distinct from Objective 1 (which is about meeting external commitments) — this is about whether the function inherits a sustainable capability rather than a project-mode operation.

KR 2.1: Cloud Security Operations function fully owns IDP, ZTNA, PAM, MFA, and Access Review by program close (2027-Q3)

- Source: Operating Model handoff sign-off
- Owner: Director, Cloud Security Operations (in formation)
- Initial confidence (Jan 2026): 75%
- Q1 2026 confidence (Apr 2026): 75%
- Status as of last review: Operating Model v2.1 published; function expanded from 11 to 14 FTE in Jan 2026

KR 2.2: Quarterly access review process operational and producing 100% attestation for at least two consecutive quarters before program close

- Source: SailPoint IdentityIQ + audit logs
- Owner: Access Governance Lead (in formation)

- Initial confidence (Jan 2026): 70%
- Q1 2026 confidence (Apr 2026): 70%
- Status as of last review: process design complete, first cycle scheduled 2026-Q4

KR 2.3: Identity-related help desk ticket volume in steady state (90 days post-close) below baseline (pre-program 2024 average) by 30%

- Source: ServiceNow + 2024 baseline data
- Owner: Cloud Security Operations Director (in formation) + IT Service Manager
- Initial confidence (Jan 2026): 60%
- Q1 2026 confidence (Apr 2026): 60%
- Status as of last review: not yet measurable (no waves cut over to steady state)

Calibration on Objective 2 KRs is intentionally conservative — these depend on adoption patterns post-cutover that the team can't fully control during the program.

Section 2 — Program KPIs

Eight program-level KPIs. Component-level KPIs are managed in component plans (not in this document). The 8 here are reviewed weekly in routine status; threshold breaches trigger named interventions.

| KPI | What outcome it predicts | Source | Cadence | Threshold for action | Action when threshold breached | Owner |

|---|---|---|---|---|---|---|

| Wave-week help desk ticket volume per 100 users | KR 1.5 (cumulative ticket cap) | ServiceNow | Daily during cutover weeks | Peak day > 5/100 users | Help desk surge expansion + R. Patel intervention | T. Brooks |

| ZTNA admin console availability | KR 1.3 (gateway availability) | ZTNA admin console | Daily | < 99.9% in any 24h window | J. Liu vendor escalation within 4h | J. Liu |

| FIDO2 enrollment rate vs plan | KR 1.1 (privileged FIDO2) | Okta MFA + BeyondTrust | Weekly | < 90% of weekly plan for 2 consecutive weeks | Sponsor escalation + plan adjustment | K. Reddy + M. Ortiz |

| Sponsor decision cycle time | Leading indicator for decision velocity | RAID Log + Decisions Log | Weekly | > 10 business days for any open decision | Casey escalation in 1:1 with Sandra | Casey Morrison |

| Component PM weekly status submission rate | Leading indicator for program operational health | Status Reports | Weekly | < 100% on-time submission for 2 consecutive weeks | TPM intervention with affected PM | Casey Morrison |

| Pulse survey eNPS at T+7 each wave | Leading indicator for KR 2.3 (steady-state ticket reduction) | Survey tool | Per wave | < +20 at any wave | OCM intervention with affected segment | R. Patel |

| Risk register top-5 change rate | Leading indicator for program stability | RAID Log | Weekly | New top-5 risk not present 4 weeks ago | Steering Committee notification | Casey Morrison |

| Vendor (FIDO2 + Zscaler + BeyondTrust) commitment hold rate | Leading indicator for KR 1.1 and KR 1.3 | Vendor weekly check-ins | Weekly | Any P0 vendor commitment slips by > 5 business days | Sponsor escalation + Vendor Management engagement | Casey Morrison |

Selection rationale

Six of the eight are leading indicators (predict outcomes before they materialize). Two are direct outcome measures (ZTNA availability, ticket volume). The mix sits at 75/25 leading-to-lagging, which fits the program's profile — the cutover phases are the highest-risk periods, and leading signal during them is more useful than lagging measurement after.

The eight were chosen from a candidate set of 23 generated in the chartering workshops. The other 15 were either component-level (better managed in component plans), or didn't have specific intervention thresholds (would have been "track" rather than "act"), or duplicated other KPIs (multiple ways of measuring the same underlying thing).

Section 3 — Review Cadence

Forum 1: Routine status (weekly)

- Embedded in Casey's weekly status compilation
- KPI threshold breaches flagged in the report
- RAG status informed by KPI status (multiple breaches typically move RAG)

Forum 2: KPI deep-dive (monthly, 1st Wednesday)

- 60 min, attended by Casey + 4 component PMs + T. Brooks + R. Patel
- All 8 KPIs reviewed with month-over-month trend
- Patterns across KPIs identified
- Candidate KPI changes flagged for quarterly review

Forum 3: OKR confidence review (quarterly, first week of new quarter)

- 90 min, attended by Sandra Park + Casey + 4 component PMs + R. Patel
- Each KR reviewed with current confidence rating, comparison to chartering and last quarter
- Material change flags discussed
- Decisions on OKR adjustments captured in Decisions & Changes Log

Forum 4: Material change review (ad-hoc)

- Triggered by external/internal change material to OKR set
- April 2026: Cloud Migration acceleration triggered material change review; KR 1.2 was added (Components 1-3 production-ready by Cloud Migration go-live), KR set was rebaselined; sponsor approved revised OKR set; Charter v2.1 reflects the change
- Casey watching for next potential material change: state banking examiner review schedule shift, FIDO2 supply chain further degradation

Section 4 — Handoff Plan (post-program)

| KPI | Continues post-program? | Receiving function | Handoff date | Notes |

|---|---|---|---|---|

| Wave-week help desk ticket volume per 100 users | No | — | Program close | Retires; baseline ticket volume becomes Operating Model KPI |

| ZTNA admin console availability | Yes | Cloud Security Operations | 2027-Q2 | Threshold tightens slightly (steady-state vs cutover) |

| FIDO2 enrollment rate vs plan | No | — | 2027-Q1 | Retires after KR 1.1 hit; lifecycle metric continues in Operating Model |

| Sponsor decision cycle time | No | — | Program close | Program-execution KPI |

| Component PM weekly status submission rate | No | — | Program close | Program-execution KPI |

| Pulse survey eNPS at T+7 each wave | No | — | Program close | Wave-tied; OCM closes |

| Risk register top-5 change rate | No | — | Program close | Program-execution KPI |

| Vendor commitment hold rate | Yes | Cloud Security Operations | 2027-Q2 | Continues as part of vendor management process |

Two KPIs continue post-program. The other six are program-execution KPIs that retire at close. Plan was published in March 2026, well ahead of the 60-day-before-close window, so the receiving function has time to absorb.

The Operating Model document (#153) Section 8 already lists the post-program KPIs that this program contributes; the handoff aligns with that.

Section 5 — Approvals

Sponsor (CISO)	Sandra Park — approved 2026-01-22 (initial); approved 2026-04-15 (rebaseline)
Engineering co-sponsor	Mark Williams (CTO) — acknowledged 2026-01-25; acknowledged 2026-04-18
TPM	Casey Morrison — owner
Coalition (CIO)	Linda Walsh — acknowledged 2026-01-28
Coalition (CRO)	Robert Stein — acknowledged 2026-01-28
Component PMs	J. Liu, M. Ortiz, K. Reddy, S. Chen, P. Nguyen — acknowledged 2026-02-05 (initial); 2026-04-22 (rebaseline)
OCM Lead	R. Patel — acknowledged 2026-02-05; 2026-04-22
Receiving function	Cloud Security Operations Director (when in formation) — acknowledged 2026-02-12
Audit Committee	Q1 2026 acknowledgment recorded in committee minutes

What this example illustrates

The substantive choices visible in this populated artifact:

OKR distinction. Two Objectives — one external-commitment outcome (Objective 1) and one organizational maturity outcome (Objective 2). Both worth measuring; both at the program level not the component level.

KR specificity. Each KR has a number, a date, a source, and an owner. None of the KRs are activity ("hold X workshops") or deliverable ("ship X system"); all are outcomes the sponsor would defend.

Confidence calibration. KRs span 60-80% confidence at chartering — the harder ones are deliberately at 60-65%, not pushed up to feel safer.

KPI selection discipline. 8 KPIs selected from 23 candidates. Each has a specific threshold and named action. 75% leading indicators.

Material change handling. The April 2026 Cloud Migration acceleration produced a formal material change review, a rebaselined KR set (added KR 1.2), and updated approvals. The OKRs weren't quietly drifted to match new reality.

Handoff planning. Two KPIs continue post-program; six retire. Plan was published 16 months before close, not at close.

Related artifacts

- Artifact #33 (Program Success Metrics & OKRs): the framework this example populates
- Template — Program Success Metrics & OKRs: the structural template
- Charter — Project Atlas (Example #6, chunk #186): where the OKRs are also captured
- Operating Model — Cloud Security Operations (Example #5, chunk #153): where post-program KPIs transition
- Communications Plan — Project Atlas (Example #1, chunk #134): the comms cadence that delivers KPI status to stakeholders
- OCM Plan — ZTNA Rollout (Example #2, chunk #142): adoption-specific metrics that feed KR 1.5 and KR 2.3

- Decisions & Changes Log — Project Atlas (Example #17, chunk #197): where OKR rebaseline decisions are logged

Related Field Notes

- Recommending prioritization with data (#223): the prioritization conversations that informed Atlas KR selection
- Re-baselining without losing trust (#215): the discipline applied to the April 2026 OKR rebaseline
- "Executive intervention required" (#227): the relationship between KPI threshold breaches and Off-Track designation

Keywords: OKR example, KPI example, Atlas OKRs, Atlas KPIs, populated success metrics, program success metrics example, OKR worksheet example, KPI tracker example, metrics review cadence example, populated metrics doc, Project Atlas success metrics

HOW TO READ THIS EXAMPLE

Why this example works: This metrics framework is exemplary because it enforces the distinction between output metrics (what the program produces), outcome metrics (what changes in the environment), and lagging indicators (what the business ultimately achieves), and it maps each KPI to an OKR so the connection between daily measurement and strategic intent is explicit. A reader should notice that each metric has a stated data source and a refresh cadence, which means the dashboard can be populated by someone other than the metric owner.

Key judgment calls:

- Setting KPI targets before delivery begins rather than waiting to observe performance and then defining targets around actual results.
- Including a metric confidence rating alongside each KPI to flag where the measurement methodology is still maturing, which prevents false precision.
- Retiring output metrics at program close and retaining only outcome and lagging indicators in the benefits realization tracking, so the PMO does not conflate delivery activity with business value.

Adapting it to your context:

- Reuse the three-tier taxonomy (output, outcome, lagging) and the OKR linkage structure for any program metrics framework.
- Replace Atlas's ZTNA-specific security metrics with the operational, financial, or compliance metrics relevant to your program's objectives.
- Negotiate data source ownership with IT and business operations before the first dashboard cycle; the metrics framework fails if the data pipelines are not confirmed.

45 — Portfolio Prioritization & Scoring Model — Bristol IT & Security Programs

Scoring Criteria and Weights:

Criterion	Weight
Strategic alignment	25%
Risk/compliance reduction	25%
Value/ROI	20%
Urgency	15%
Effort (inverse)	15%

Q2 Portfolio Scores - Bristol Security:

Initiative	Weighted Score	Rank	Decision
ZTNA+PAM modernization	4.4	1	Must-do
Email security upgrade	3.8	2	Must-do
Data classification rollout	3.1	3	Should-do
Legacy SIEM migration	2.6	4	Defer

Capacity Overlay:

- Available capacity: 220 person-weeks this half
- Ranks 1-3 consume: 205 person-weeks
- Cut line falls below Legacy SIEM migration -> deferred to H2

Governance Decision Log:

Initiative	Decision	Forum	Rationale
ZTNA+PAM	Funded	Board	Highest risk reduction + audit finding
Legacy SIEM migration	Deferred to H2	PMO	Capacity constraint, not value

PMO Rationale:

This model provided a defensible, data-backed basis for telling the SIEM sponsor 'not no, but H2' rather than a political decision.

HOW TO READ THIS EXAMPLE

Why this example works: The portfolio scoring model is exemplary because it makes the weighting rationale explicit and links it to the Bristol board-level risk appetite statement, so the prioritization outputs are traceable to a governance decision rather than appearing as a PMO judgment call. The model applies consistent scoring criteria across programs that are otherwise incommensurable (infrastructure hardening vs. compliance remediation vs. capability building), which is the core problem portfolio prioritization must solve. The sensitivity analysis showing how the ranking changes if regulatory weight is increased by 10 percentage points reveals which programs are robust winners versus which depend on contested assumptions.

Key judgment calls:

- Weighting regulatory compliance at 35 percent of the total score given Bristol's current FCA scrutiny posture, and documenting that this weight will be reviewed annually.
- Using a forced-ranking calibration panel rather than individual scores to reduce scoring bias across program sponsors who have competing interests.
- Including a strategic fit score that penalizes programs creating technical debt even if they score well on financial return, protecting the long-term architecture.

Adapting it to your context:

- Reuse the multi-criteria scoring structure and the sensitivity analysis method for any portfolio prioritization exercise.
- Replace Bristol's weighting rationale with your organization's current strategic priorities and risk appetite statement.

- Run your own calibration panel to normalize scoring before aggregating - skip this step and the model will reflect politics, not priorities.

46 — Program Capacity & Demand Management Plan — Bristol Security Program

Supply Summary (Q2):

Resource Pool	Supply	Notes
Security Engineering	6 FTE (~210 wk-hrs/period)	After leave adjustment
Identity Specialists	2 FTE	Scarce skill
OCM	1.5 FTE	-

Demand by Initiative:

Initiative	Resource	Demand	Window
ZTNA build	Identity Specialists	1.6 FTE	Through July
PAM	Identity Specialists	0.8 FTE	Through July

Allocation Heatmap Flags:

Resource Pool	Jun	Jul	Aug	Status
Identity Specialists	Over	Over (120%)	-	RED - bottleneck
Security Engineering	Healthy	Healthy	Healthy	GREEN
OCM	-	-	Tight (training wave)	AMBER

Mitigation - Identity Bottleneck:

- Contract 1 identity specialist for 8 weeks (funded from PAM T&M cap)
- Re-sequence PAM design 2 weeks later to prevent peak overlap

Scenario Analysis:

- Scenario tested: add Email security now -> Security Eng reaches 115% in Aug
- Decision: hold Email security start to September

Board Commitment Basis:

This plan is the evidence behind the program manager's commitment to the board: 'we can take ZTNA+PAM but not Email yet'.

HOW TO READ THIS EXAMPLE

Why this example works: The capacity and demand plan is exemplary because it distinguishes between resource availability (what people are contracted to deliver) and effective capacity (what is realistic after meetings, BAU, and leave), using a utilization discount factor that is documented and agreed with resource managers rather than assumed. Mapping named individuals against named workstreams rather than using FTE abstractions makes over-allocation visible at the person level, where it must be resolved. The demand forecast extends through the program horizon with quarterly reforecasts scheduled, turning a point-in-time plan into a living management instrument.

Key judgment calls:

- Applying a 75 percent effective utilization rate for technical SMEs and 85 percent for delivery staff, differentiated rather than averaged, reflecting the higher interruption load on SMEs.
- Flagging the same three security architects as critical constraints across ZTNA, PAM, and cloud security workstreams and escalating to the CISO rather than simply noting the conflict in the plan.
- Building the demand model bottom-up from WBS work packages rather than top-down from budget headcount, making the capacity gap calculation defensible.

Adapting it to your context:

- Reuse the effective utilization discount concept and require your resource managers to agree the discount factors before you build the plan.
- Replace Atlas-specific role scarcity assumptions with your own organization's identified constraint roles.
- Schedule quarterly reforecasts explicitly in your governance calendar so the plan remains current as scope and priorities evolve.

58 — Program Roadmap — Bristol Identity & Access Program

Program Context:

Project Atlas will deliver a Zero Trust security architecture for Bristol Financial by replacing legacy VPN-based remote access with ZTNA (ClearPath Networks), implementing enterprise PAM (CyberArk) for privileged account control, and modernising identity governance (Okta). Planning horizon: 2026-Q1 through 2027-Q1. Primary regulatory driver: PCI-DSS 4.0 network segmentation compliance by 2027-03-31.

Workstream Phases (2026-Q1 to 2027-Q1):

Workstream	Phase	Period
IAM	Discovery	Jan-Feb 2026
IAM	Design	Mar-Apr 2026
IAM	Build and Test	May-Aug 2026
IAM	Pilot	Sep-Oct 2026
IAM	Production Rollout	Nov 2026 - Jan 2027
IAM	Closeout	Feb-Mar 2027
ZTNA	Discovery	Jan-Feb 2026
ZTNA	Lab Environment	Mar-Apr 2026
ZTNA	Pilot	May-Jul 2026
ZTNA	Phased Production Deployment	Aug 2026 - Jan 2027
ZTNA	Closeout	Feb-Mar 2027
PAM	Discovery	Jan-Feb 2026
PAM	Design	Mar-May 2026
PAM	Build	Jun-Aug 2026
PAM	UAT	Sep-Oct 2026
PAM	Go-Live	Nov-Dec 2026
PAM	Closeout	Jan-Mar 2027

Workstream	Phase	Period
Programme Management	Active throughout	Jan 2026 - Mar 2027

Program Milestones:

ID	Milestone	Target Date	Owner	Go/No-Go Criteria
M-01	Program Blueprint Approved	2026-02-28	Program Manager	SteerCo sign-off required
M-02	ZTNA Lab Environment Ready	2026-04-30	ZTNA Lead	Lab policy enforces at least 3 test user personas
M-03	IAM Design Baselined	2026-04-30	IAM Lead	Architecture sign-off by CISO
M-04	ZTNA Pilot Go-Live	2026-07-31	ZTNA Lead	50 pilot users onboarded; zero P1 incidents in 5-day soak
M-05	PAM UAT Complete	2026-10-31	PAM Lead	All UAT test cases passed; no open Critical defects
M-06	PCI-DSS Network Segmentation Compliant	2027-01-31	Program Manager	QSA attestation received
M-07	Program Closeout	2027-03-31	Program Manager	Handover package accepted by Operations Lead and CISO

Cross-Initiative Dependency Register:

ID	Predecessor	Successor	Type / Lag	Status	Owner(s)
DEP-001	IAM / M-03 IAM Design Baselined	PAM / PAM Design Start	Finish-to-Start / 0 days	On Track	IAM Lead (predecessor), PAM Lead (successor)
DEP-002	ZTNA / M-02 ZTNA Lab Ready	IAM / Okta ZTNA Integration Test	Finish-to-Start / 5 days	On Track	ZTNA Lead, IAM Lead
DEP-003	ZTNA / Phased Production Deployment Phase 1 complete	PAM / CyberArk Vault Production Go-Live	Finish-to-Start / 0 days	At Risk (ZTNA Phase 1 tracking 3 weeks late)	ZTNA Lead, PAM Lead
DEP-004	PAM / M-05 UAT Complete	Program / M-06 PCI-DSS	Finish-to-Start / 30 days	On Track	PAM Lead, Program

ID	Predecessor	Successor	Type / Lag	Status	Owner(s)
		Compliance	(QSA review window)		Manager

Decision Points and Governance Gates:

Gate / Decision	Date	Decision-Maker	Required Inputs
G-01 Phase Gate: Define to Plan	2026-02-28	Program Sponsor (CFO and CISO)	Blueprint, benefit case, resource plan
G-02 Build/Buy: PAM vault hosting model	2026-05-15	CISO	Data residency assessment, TCO comparison
G-03 Phase Gate: Build to Pilot - ZTNA	2026-07-15	Program Manager with CISO delegate	Lab test results, security review sign-off
G-04 Funding Gate: Tranche 2	2026-09-01	CFO	Updated benefit case, schedule forecast, risk summary

Release and Deployment Events:

Release	Date	Scope	Blackout / Constraint	Dependency
REL-01 ZTNA Pilot	2026-07-31	50 users, Bristol Financial London office	None	n/a
REL-02 ZTNA Production Phase 1	2026-10-15	All Bristol Financial UK offices, 1,200 users	Avoid 2026-09-29 to 2026-10-07 (quarter-end freeze)	REL-01 soak period complete with no open P1
REL-03 PAM Go-Live	2026-11-30	CyberArk vault live for all privileged accounts	Avoid 2026-11-15 to 2026-11-22 (regulatory reporting window)	REL-02 ZTNA Phase 1 stable (DEP-003)
REL-04 Full ZTNA Production	2027-01-15	All remaining sites and remote users	None	REL-03 PAM stable for 14 days

Key Assumptions:

ID	Assumption	Owner	Review Date
A-01	ClearPath Networks delivers ZTNA lab environment by 2026-04-15	ZTNA Lead	2026-03-15
A-02	Bristol Financial InfoSec approves PAM on-premises hosting model by 2026-05-01	PAM Lead	2026-04-15
A-03	IAM workstream	Program Manager	Each monthly Program

ID	Assumption	Owner	Review Date
	headcount confirmed at 4 FTE through Q3 2026		Board
A-04	PCI-DSS 4.0 compliance deadline remains 2027-03-31 with no regulatory extension	Program Manager	Quarterly

Roadmap Risks:

Risk ID	Description	Roadmap Impact	Mitigation	Owner
R-007	ZTNA vendor lab delivery delayed beyond A-01 date	M-02 slips; cascading 3-4 week delay to M-04 ZTNA Pilot and DEP-002	Weekly vendor delivery check-in; contractual milestone with penalty clause	ZTNA Lead
R-012	PAM CyberArk integration complexity underestimated	M-05 UAT slips, threatening M-06 PCI-DSS compliance milestone	2-week buffer built into PAM Build phase; architect SME on-call for integration sprint	PAM Lead

Roadmap Version History:

Version	Date	Changes	Author	Approved By
v1.0	2026-02-28	Initial baseline post-G-01 Phase Gate	Program Manager	Program Sponsor
v1.1	2026-03-31	Added DEP-003 at-risk status; ZTNA lab milestone forecast unchanged	Program Manager	n/a (noted at Program Board)
v1.2	2026-04-30	Reforecast: ZTNA Phase 1 tracking 3 weeks late due to vendor delay; DEP-003 flagged at risk; REL-02 provisional date adjusted from 2026-10-01 to 2026-10-15 (within buffer, no rebaseline required)	Program Manager	Noted at Program Board 2026-04-30
— HOW TO	READ THIS EX	AMPLE —		

Why this example works: This example demonstrates the roadmap operating as a genuine program management tool rather than a presentation artifact: DEP-003 is flagged at risk with a quantified downstream impact on PAM go-live and the PCI-DSS compliance milestone, governance gates G-01 through G-04 have named decision-makers and required inputs rather than just dates, and the version history shows a forecast adjustment being made transparently at the April Program Board before the 3-week slip became unrecoverable. The roadmap is the mechanism by which the Program Manager maintains strategic control across three concurrent workstreams.

Key judgment calls:

- DEP-003 (ZTNA Phase 1 -> PAM go-live) is the highest-risk dependency on the roadmap because it sits on the critical path to the PCI-DSS compliance milestone M-06; any further slip in ZTNA Phase 1 must immediately trigger an impact assessment on M-06 and a conversation with the QSA about the compliance attestation timeline.
- The quarter-end blackout window applied to REL-02 is non-negotiable at Bristol Financial; scheduling the ZTNA Phase 1 production release without checking the financial calendar is a recoverable but embarrassing program error - the roadmap makes this constraint explicit so it cannot be overlooked.
- G-04 Funding Gate in September is a hard dependency for the Q4 delivery phase; the Program Manager must ensure the updated benefit case and risk summary are prepared and submitted to the CFO at least 2 weeks before the gate date, not on the day.

Adapting it to your context:

- If the program uses SAFe, replace phase-based swim lanes with PI boundaries on the time axis and express milestones as PI objectives; the dependency register and governance gate table remain directly applicable.
- For a program with more than 5 workstreams, maintain a summary roadmap (1 page, program-level milestones and top 5 dependencies only) for SteerCo distribution and a detailed roadmap (full swim lanes and dependency register) for the Program Board; both are version-controlled together.
- If Bristol Financial adopts a portfolio management tool (e.g., Planview or Clarity), migrate the roadmap into that tool as the system of record and use this document as the governance overlay showing decision points and assumptions that the scheduling tool does not capture.

59 — Program Closure Report — Bristol Identity & Access Program

Executive Summary:

Bristol Identity & Access Program closed 14 March 2026 after 28 months. Budget GBP 6.4M approved, GBP 6.1M actual (4.7% under). ZTNA coverage reached 100% of in-scope endpoints; PAM vaulted 2,847 privileged accounts against a target of 2,600. Richard Hale, CTO, formally declares the program closed.

Mandate and Objectives Review:

Objective	Description	Status
OBJ-1	Eliminate VPN for remote access - ZPA live across all 4,200 seats, legacy VPN decommissioned 28 Feb 2026	MET
OBJ-2	Vault all Tier-1 privileged accounts - 2,847 of 2,847 in scope vaulted	MET

Objective	Description	Status
OBJ-3	Pass PCI-DSS Network Segmentation audit - audit letter received 5 March 2026	MET
OBJ-4	Reduce standing access incidents by 60% - 47% reduction to date; BAU target 60% by Dec 2026	PARTIALLY MET

Component Delivery Summary:

ID	Component (PM)	Planned Close	Actual Close	Budget	Actual	Gate
P-ATL-01	ZPA Pilot (D. Mercer)	Q1 2024	Q1 2024	GBP 480K	GBP 471K	PASS
P-ATL-02	ZPA Full Rollout (D. Mercer)	Q3 2024	Q4 2024 (+6 wk hardware delay)	GBP 1.9M	GBP 1.87M	PASS with observation
P-ATL-03	PAM Phase 1 Windows (J. Adeyemi)	Q2 2024	Q2 2024	GBP 900K	GBP 888K	PASS
P-ATL-04	PAM Phase 2 Cloud (J. Adeyemi)	Q4 2024	Q1 2025 (+8 wk AWS IAM integration rework)	GBP 1.1M	GBP 1.15M (+GBP 50K CR-014)	PASS
P-ATL-05	PAM Phase 3 Unix (T. Bassett)	Q4 2025	Q1 2026 (+5 wk AIX agent compatibility)	GBP 1.0M	GBP 0.99M	PASS

Benefits Realization Status:

ID	Benefit	Baseline	Latest	Status	BAU Owner / Next Measure
BEN-01	VPN licence savings GBP 320K p.a.	GBP 320K	GBP 320K	REALIZED	Nick Farrell (IT Finance) / Dec 2026
BEN-02	Privileged access incident reduction 60%	127 incidents/yr	67 incidents/yr (47% reduction)	IN-PROGRESS	Claire Moss (CISO office) / Sep 2026
BEN-03	Audit cost reduction GBP 80K p.a.	GBP 200K	GBP 118K (41% reduction vs 40% target)	REALIZED	Nick Farrell / Dec 2026

ID	Benefit	Baseline	Latest	Status	BAU Owner / Next Measure
BEN-04	PCI-DSS pass without remediation findings	-	Audit letter 5 March 2026	REALIZED	-
BEN-05	Staff productivity (no VPN reconnects)	22 min/wk lost per user	6 min (target 5 min)	IN-PROGRESS	Helen Stroud (IT Ops) / Sep 2026

Outstanding Items:

ID	Description	Owner / Handover	Target Resolution
OI-01	AIX 6.1 legacy servers (14 nodes) - CyberArk agent not supported; upgrade AIX or implement API-based proxy vault solution	T. Bassett -> Helen Stroud (BAU)	30 Apr 2026
OI-02	Zscaler ZIA integration deferred (CR-021) - no closure dependency; handed to next portfolio initiative BFIN-2027-SEC	D. Mercer -> BFIN-2027-SEC	N/A
OI-03	Vendor SLA dispute CyberArk invoice Nov 2025 - GBP 28K in dispute	Finance/Legal	30 Apr 2026

Financial Closure:

- Approved budget GBP 6.4M (including GBP 180K contingency); contingency drawn GBP 50K (CR-014 AWS integration).
- Actual spend GBP 6.1M; underspend GBP 300K returned to portfolio reserve.
- All POs closed as of 31 March 2026 except PO-2025-1147 (CyberArk dispute, GBP 28K, held pending legal). Accruals: nil.
- Finance Director (N. Farrell) sign-off: 2 April 2026.

Lessons Learned:

Theme	Finding	Recommendation
Vendor agent compatibility	AIX/legacy OS CyberArk/Zscaler agent gaps impacted 3 projects, total delay ~19 weeks	Add agent compatibility gate to program Blueprint; validate support matrix against full asset inventory before baselining
AWS IAM integration complexity	PAM-cloud integration complexity underestimated	Dedicate AWS IAM SME from Day 1 of design; route lesson to Enterprise Architecture
Change fatigue	ZPA rollout user adoption	Embed dedicated change

Theme	Finding	Recommendation
	dipped in weeks 12-16 at branch level	champion per business unit from kickoff rather than reactive comms
Benefits measurement data sources	BEN-02 and BEN-05 lacked agreed baseline data sources at program start	Confirm BAU data ownership in Blueprint

Team Disbandment and Transition:

Resource	Release Date	Transition Action
Sarah Okonkwo (PM)	30 Apr 2026	Knowledge transfer complete; system access revoked 1 May 2026
D. Mercer, J. Adeyemi, T. Bassett (component PMs)	31 Mar 2026	Runbooks handed to Helen Stroud (IT Ops)
12 contractor resources	14 Mar 2026	CyberArk admin rights transferred to BAU PAM team (3 FTE, lead: G. Osei)
Program SharePoint	1 May 2026	Set to read-only

Assurance and Sign-Off:

Independent assurance review conducted by Internal Audit (lead: P. Cunningham) 18-28 March 2026. Condition 1: BAU measurement schedule confirmed in writing by Claire Moss and Helen Stroud - MET 1 April 2026. Condition 2: OI-01 AIX nodes residual risk accepted by SRO in writing - MET 2 April 2026. No further conditions.

Signatory	Role	Date
R. Hale	SRO	4 April 2026
S. Okonkwo	PM	4 April 2026
N. Farrell	Finance Director	2 April 2026
P. Cunningham	Assurance (Internal Audit)	3 April 2026

Archive Index:

Document	Location	Retention
Program Business Case (v1.0, v2.1)	SharePoint /Governance/Business-Case	7 years
Program Blueprint (v3.2 final)	SharePoint /Governance/Blueprint	7 years
Benefits Realization Plan (v4.0)	SharePoint /Benefits	7 years
Risk Register final snapshot	SharePoint /Risk	7 years
Decision & Changes Log	SharePoint /Governance/Decisions	7 years
Component closure reports (all)	SharePoint	7 years

Document	Location	Retention
	/Components/[project]/Closure	
Contracts (Zscaler, CyberArk, SI)	Legal DMS /Atlas	10 years (per contract terms)
This report (signed PDF)	SharePoint /Governance/Closure/ProgramC losureReport_v1.0_signed.pdf	10 years
—— HOW TO READ THIS EXAMPLE ——		

Why this example works: This example demonstrates the distinction between project closeout and program closure: the emphasis is on benefits hand-off with named BAU owners and scheduled measurement dates, financial reconciliation to portfolio level, and a consolidated lessons synthesis that is actionable rather than a log dump. The outstanding items table shows how residual risk is managed rather than buried.

Key judgment calls:

- BEN-02 and BEN-05 being 'In-Progress' at closure is acceptable IF BAU owners have signed measurement schedules; declaring them realized prematurely would misrepresent program value.
- The AIX legacy issue (OI-01) illustrates why a program closure report must distinguish between 'program delivered its scope' and 'all benefits are fully realized' - the SRO's written risk acceptance is the critical control.

Adapting it to your context:

- If your program has no formal BAU benefits owners, escalate to the SRO before closure - this is a governance gap that must be resolved, not a section to skip.
- For programs with 10+ component projects, compress the Component Delivery Summary into a dashboard with exceptions only and link to individual project closeout reports rather than repeating detail.
- In regulated environments (PCI, SOX, FCA) add a regulatory obligations closure checklist as a standalone section and obtain the relevant compliance officer sign-off separately.

60 — Tranche & Release Plan — Bristol Identity & Access Program

Program Tranche Map:

Tranche	Name	Dates	End of Tranche Review (EoTR)
T1	Foundation	Apr 2024 - Dec 2024	15 Jan 2025
T2	Scale	Jan 2025 - Sep 2025	10 Oct 2025
T3	Complete & Decommission	Oct 2025 - Mar 2026	28 Mar 2026 (= Program Closure gate)

Tranche 1 Definition:

Capability state: Bristol Financial staff can access all Tier-1 applications via ZPA without VPN; all Windows privileged accounts (1,847) are vaulted in CyberArk and require MFA for access.

- BEN-01: VPN licence savings GBP 160K (50% of annual target, 6-month run-rate).
- BEN-04: PCI audit readiness assessment GREEN.

- Key assumption: Zscaler connector deployment to all 6 datacentres complete by June 2024.

Release Schedule - Tranche 1:

Release	Description	Target Date	Dependency	Readiness Gate	Deployment Window
REL-T1-01	ZPA Pilot (100 users, Finance dept)	30 Jun 2024	Connector deployment	UAT pass + CISO approval	Weekend 29-30 Jun 2024
REL-T1-02	ZPA Wave 1 (1,500 users)	31 Aug 2024	REL-T1-01 stable 30 days	UAT pass	Rolling weeknights
REL-T1-03	PAM Windows Phase 1 (1,847 accounts)	30 Nov 2024	CyberArk infrastructure provisioned	UAT pass	3 maintenance weekends Oct-Nov

Tranche Dependencies and Constraints:

ID	Dependency	Owner	Impact if Late	Mitigation
DEP-01	Zscaler connector hardware - vendor lead time 10 weeks	D. Mercer	REL-T1-01 slips	PO raised 1 March 2024
DEP-02	CyberArk licence for 2,600 accounts - required before REL-T1-03	J. Adeyemi	REL-T1-03 slips	PO confirmed
DEP-03	BAU Change Freeze 15 Dec - 5 Jan - no production releases in window	Program	T1 releases must complete by 13 Dec or defer to 6 Jan	Plan all releases before 13 Dec

Benefit Realization Checkpoint - Tranche 1:

Benefit	Measure	Owner	Minimum Acceptable Result
BEN-01 VPN licence savings	Zscaler invoice vs. Cisco AnyConnect invoice	Nick Farrell	GBP 120K annualized saving evidenced by Jan 2025 (75% of 6-month target)
BEN-04 PCI audit readiness	Internal audit pre-assessment report	P. Cunningham	No Critical or High findings against network segmentation controls

EoTR T1 Decision Record - 15 Jan 2025:

- REL-T1-01 and REL-T1-02 complete - 4,200 seats on ZPA.
- REL-T1-03 complete - 1,847 Windows accounts vaulted.

- BEN-01 result: GBP 148K annualized saving (exceeds GBP 120K threshold).
- BEN-04 result: internal audit pre-assessment - 0 Critical, 1 High (remediated before EoTR).
- Outstanding risk: R-014 AIX agent compatibility amber.
- Decision: PROCEED to Tranche 2 (full commitment). Condition: R-014 mitigation plan confirmed by 31 Jan 2025.
- Signed: R. Hale 15 Jan 2025.

Tranche 2 Definition:

Capability state: All 4,200 seats on ZPA with VPN fully decommissioned; all Tier-1 Cloud privileged accounts (600 AWS/Azure) vaulted.

- BEN-02: privileged access incidents reduced 35% vs. baseline (interim milestone toward 60% target).
- BEN-03: audit cost reduction GBP 40K evidenced.
- BEN-05: staff productivity baseline established.

Tranche 3 Definition:

Capability state: All privileged accounts in scope (2,847 including Unix) vaulted; legacy VPN infrastructure physically decommissioned; program ready for closure.

- All five benefits at or above minimum acceptable levels.
- BEN-02 at $\geq 47\%$ reduction; BEN-01 full year saving confirmed.
- Key assumption: AIX 6.1 legacy risk resolved or formally accepted by SRO before T3 EoTR.

Next-Tranche Readiness Checklist - T2 to T3 (assessed 30 Sep 2025):

Item	Status	Notes
Funding confirmed for T3	GREEN	Approved in Business Case
CyberArk Unix licences	GREEN	PO raised
Unix agent compatibility (AIX 6.1)	AMBER	14 nodes unresolved; mitigation: proxy vault; owner T. Bassett; target Nov 2025
BAU PAM team capacity	GREEN	G. Osei team confirmed
Blueprint updated	GREEN	v3.2 issued 28 Sep 2025
SRO accepted AMBER item	SIGNED	Signed 10 Oct 2025 EoTR
— HOW TO READ THIS EXAMPLE —		

Why this example works: This example shows the core MSP tranche discipline: each tranche ends at a genuine capability state (not just 'projects done'), the EoTR T1 decision record demonstrates evidence-based governance with a named threshold and a named condition, and the readiness checklist shows how an AMBER item is handled without blocking progress.

Key judgment calls:

- The BEN-01 threshold of GBP 120K (75% of target) rather than the full GBP 160K is a deliberate judgment - requiring 100% of an annualized saving from a 6-month run-rate would be statistically premature; the 75% floor provides confidence without being unrealistic.

- The AIX AMBER on the T2-to-T3 readiness checklist is escalated to SRO written acceptance rather than being RAG-washed to Green - this is the discipline that prevents hidden risk accumulating into program closure.

Adapting it to your context:

- If your program uses agile delivery with quarterly PI planning, align tranche boundaries to PI increments but ensure the EoTR is a distinct governance event layered above the PI review, not merged with it.
- For programs with regulatory tranches (e.g., must achieve PCI scope reduction before expanding), use the regulatory milestone as the mandatory EoTR trigger rather than a calendar date.
- If the Program Board does not have authority to stop or re-plan the program without escalating to an Investment Committee, document this authority chain in the EoTR Protocol section so there is no ambiguity on the day.

61 — Program Risk Management — Bristol Identity & Access Program

Risk Appetite Statement (SRO-approved Jan 2025):

Category	Tolerance	Notes
Regulatory / PCI-DSS compliance	ZERO	Any compliance gap escalates immediately to SRO and General Counsel
Security / data breach	ZERO	Immediate escalation
Benefits realization	LOW	Program must achieve $\geq 80\%$ of each benefit target at closure or re-plan triggered at EoTR
Schedule (within tranche)	MEDIUM	Tranche-level slip up to 6 weeks acceptable without SRO re-approval; beyond 6 weeks requires SRO and CFO sign-off
Cost	LOW-MEDIUM	Contingency draw-down up to 50% (GBP 90K) within PM authority; beyond requires SRO approval

Signed: R. Hale 15 Jan 2025.

Escalation Protocol:

- Score ≥ 15 (Red) -> PM escalates to SRO within 2 business days with response plan.
- Score 10-14 (Amber-High) -> PM flags at next Program Board (within 10 business days).
- Any PCI-DSS/data-breach risk regardless of score -> immediate SRO escalation.
- Any risk causing forecast benefit shortfall below appetite threshold -> Business Change Manager and SRO notified within 3 business days.

Program Risk Register:

ID	Category	Description	Owner	P x I = Score	Trend	Strategy / Key Actions	Residual
R-PRG-001	Systemic/ Vendor	CyberArk agent incompati	S. Okonkwo	4 x 4 = 16 (Red)	Stable (known, bounded)	(1) CyberArk CSM	3x3=9

ID	Category	Description	Owner	P x I = Score	Trend	Strategy / Key Actions	Residual
		bility with AIX 6.1 and RHEL 5.x confirmed across P-ATL-03 and P-ATL-05; systemic vendor constraint				escalation for roadmap by 15 Feb 2025; (2) proxy vault design fallback (T. Bassett, due 28 Feb 2025). SRO notified 16 Jan 2025.	
R-PRG-002	Benefits Realization	BEN-02 incident reduction 60% - change fatigue from concurrent ZPA/PAM rollout may suppress adoption below 47% interim target	Priya Nair (BCM)	3 x 4 = 12 (Amber-High)	Worsening (adoption survey Jan 2025: 62% positive vs. 75% target)	(1) Deploy change champions in 5 BUs by Mar 2025; (2) gamified adoption dashboard live Feb 2025.	2x3=6
R-PRG-003	External/Regulatory	PCI-DSS v4.0 requirement 8.6.1 (interactive accounts managed by PAM) not explicitly addressed for 47 application service accounts	S. Okonkwo / CISO	4 x 5 = 20 (Red - zero tolerance)	New risk identified 20 Jan 2025	(1) Scope change assessment CR-022 raised; (2) QSA consulted; decision at Feb Program Board. SRO and General Counsel notified 20 Jan 2025.	Pending CR-022

ID	Category	Description	Owner	P x I = Score	Trend	Strategy / Key Actions	Residual
R-PRG-004	Systemic/Architecture	Each component making independent security architecture decisions not reconciled at program level - integration debt risk for T3	S. Okonkwo	3 x 5 = 15 (Red)	New (aggregated from P-ATL-02, P-ATL-04, P-ATL-05)	Enterprise Architect M. Singh added to Program Board; ADR process mandated from Feb 2025.	-
R-PRG-005	Systemic/Performance	ZPA connector performance issues at Bristol Glasgow and two further sites showing similar latency pattern	D. Mercer	-	Pattern risk (escalated from P-ATL-02)	Monitor; site-level investigation.	-

Risks to Benefits Realization:

Benefit	Risk	P x I = Score	Owner	EoTR Threshold
BEN-01 VPN savings	ZPA performance issues at 3 sites may force VPN retention, reducing saving by GBP 40K	2x3=6	D. Mercer	>=GBP 240K annualized (75% of target) at T2 EoTR
BEN-02 Incident reduction	R-PRG-002 adoption gap may suppress reduction below 35% interim target	3x4=12	Priya Nair	>=35% reduction at T2 EoTR
BEN-03 Audit cost reduction	PCI-DSS v4.0 scope gap (R-PRG-003) may require additional audit spend in	4x3=12	Nick Farrell	>=30% reduction at T2 EoTR

Benefit	Risk	P x I = Score	Owner	EoTR Threshold
	2025			

Risk Reporting Summary - Feb 2025 Program Board:

Risk	Score	Trend	Board Action Required
R-PRG-001 AIX agent compatibility	16 (Red)	Stable	NOTE - response on track
R-PRG-003 PCI 8.6.1 scope gap	20 (Red)	New	DECIDE on CR-022 today - delay increases regulatory exposure
R-PRG-002 Adoption gap	12 (Amber-High)	Worsening	APPROVE additional change champion budget GBP 15K
R-PRG-004 Architecture drift	15 (Red)	New	NOTE - M. Singh attendance confirmed from March
— HOW TO READ THIS EXAMPLE —			

Why this example works: This example demonstrates genuine program-level risk management: R-PRG-001 is systemic (same vendor limitation appearing across multiple projects), R-PRG-003 illustrates zero-tolerance escalation with SRO and General Counsel notification, and the Benefits Realization section shows how risks are linked to specific benefit thresholds rather than tracked separately.

Key judgment calls:

- R-PRG-003 being scored $4 \times 5 = 20$ AND triggering zero-tolerance escalation regardless of score is deliberate - the appetite statement makes regulatory compliance non-negotiable, so the escalation is automatic; the score only determines urgency of response.
- Distinguishing R-PRG-001 (systemic vendor pattern) from the individual project-level AIX risks in P-ATL-03 and P-ATL-05 is the core value of program risk aggregation - the program manager can negotiate a single vendor escalation rather than having two PMs independently chase the same CSM.

Adapting it to your context:

- If your program operates within an enterprise risk framework (e.g., Three Lines model, GRC tool like Archer or ServiceNow GRC), align risk categories and scoring scales to the enterprise taxonomy so program risks can be reported upward without re-scoring.
- For programs with a large number of component projects (8+), consider a tiered aggregation: component PM escalates to workstream lead, workstream lead escalates to program - the direct component-to-program channel becomes unmanageable above ~5 projects.
- If the program has an external regulator (FCA, PRA for Bristol Financial), add a regulatory liaison review of the top 5 risks quarterly - regulators often surface external risk intelligence not visible inside the program.

Program Management · Workbook (8)

Program Workbook — Program Identification

Program Identification

Program name	Project Atlas
Program ID	PROG-2026-001
Strategic theme	Zero Trust Security & Identity Modernization
Executive sponsor	Sandra Park, CISO
Program manager	Senior Security TPM (you)
Start date	2026-01-15
Target end date	2027-09-30
Total program budget	\$8,400,000
Component count	5 initiatives
Current overall status	At-Risk Two components At-Risk: ZTNA Rollout (dev tool latency for 10% of users — under remediation) and MFA Hardening (FIDO2
Status rationale	hardware lead time delay — hybrid platform-authenticator approach approved per DC-005). Other 3 components On-Track. Program timeline currently holding. See Status Reports tab for weekly detail.
Last status update	2026-04-21
Driver	SOC 2 Type II audit findings + 2025 insider threat incident
Regulatory drivers	SOX, GLBA, state privacy laws

What On-Track / At-Risk / Off-Track mean for this program

Status Definition for Project Atlas

On track on scope, schedule, and budget. Risks are within tolerance. No executive escalations needed. If any single component is

At-Risk and others are On-Track, program may still be On-Track at PM's discretion.

On-Track

One or more components have material issues (cost, schedule, scope, or risk) that the team is actively mitigating, BUT the program

timeline and budget are still expected to hold. Steering awareness needed; intervention typically not. Trigger: 2+ components At-

At-Risk	Risk, OR any single risk rated High/High and unmitigated. Material risk to program completion timing, budget, or scope. Executive intervention required. Trigger: 2+ components Off-Track, OR any single component Off-Track on a critical-path dependency, OR unrecoverable budget overrun, OR sponsor support
Off-Track	materially compromised.

Note: RAG definitions vary by org. The thresholds above are this program's defaults. Adjust to match your org's PMO standards and document the change in the

Decisions & Changes log so historical status reports are interpretable.

Program Workbook — Workbook Map

Workbook Map

#	Tab	Purpose	Update cadence
1	Cover	Program identification + tab map	Static; updated when material change
2	Components	5 component initiatives W with status, % complete, budget, risk	Weekly — by program manager
3	Program RAID	Program-level W risks/issues/dependencies (NOT component-level)	Weekly review
4	Cross-Component Dps	Dependencies between Week component initiatives	Weekly review
5	Program Schedule	Milestone roll-up across all components	Weekly update
6	Program Budget	Total budget with allocation across components	Monthly close
7	Resource Conflicts	Shared resources allocated across components	Bi-weekly review
8	Decisions & Changes	Program-level decisions and approved changes	Append as events occur
9	Action Items	Meeting action items + cross-meeting commitments	Weekly review
10	Vendor Management	Vendor SLAs, escalations, business reviews, renewals	Monthly + ad-hoc
11	Benefits Realization	Program benefits map with realization timing	Quarterly review
12	Status Reports	Program-level weekly status running history	Weekly — append a row

Program vs Project Workbook

This workbook tracks ONE program with 5 component projects. Each component has its own project workbook for component-level detail.

What's HERE: program-level status, cross-component dependencies, shared resources, program-level RAID, program benefits.

What's in the COMPONENT workbooks: component RAID, component schedule, component-level decisions, component team allocation.

Roll-up rule: component status feeds program status. If 2+ components are Off-Track, program status is Off-Track unless explicitly justified otherwise.

RAG dropdowns and conditional formatting auto-apply to status fields throughout. Component status changes turn the cells red/amber/green automatically.

Where to start (new program managers)

1. Fill in the Cover tab — program identification at top, leave the rest as reference.
2. Populate Components tab — list each component initiative with PM, phase, and initial budget. Get sponsor sign-off.
3. Build out Program Schedule — major milestones across components.
4. Identify cross-component dependencies in the Cross-Component Deps tab.
5. Open the Program RAID tab — populate from kickoff risk re

Program Workbook — Component Initiatives

Component Initiatives

The 5 component projects under Project Atlas. Status here rolls up to the program.

Spend to date

#	Component initiative	Component PM	Phase	Status	% complete	Budget (\$)	Variance	Top risk	Notes
1	Identity Provider Migration	M. Ortiz	Execute	On-Track	65.0%	\$1,850,000 \$1,200,000	\$650,000	Legacy app SSO integration O risk t	n track. 60% of apps migrated o enterprise IdP.
2	ZTNA Rollout (VPN replacement)	J. Liu	Execute	At-Risk	45.0%	\$2,100,000 \$1,050,000	\$1,050,000	Engineering org pilot revealed latency on dev tools	Latency issue mitigated for 90% of cases; 10% need architecture review. Pilot at engineering completes wk of 4/28.
3	Privileged Access Management	K. Reddy	Plan	On-Track	20.0%	\$1,600,000 \$280,000	\$1,320,000	Beyond Trust vendor SOW negotiation	SOW expected to sign 5/2. Implem

#	Component initiative	Component PM	Phase	Status	% complete	Budget (\$)	Variance	Top risk	Notes
									entation kickoff target 5/15.
4	MFA Hardening (FIDO2)	S. Chen	Execute	Off-Track	30.0%	\$1,100,000 \$680,000	\$420,000	FIDO2 hardware procurement delay (12-week r lead time) h a	ardwar e delay pushes Phase 2 ollout 8 weeks. Considering ybrid approa ch with platfor m uthentic ators for Phase 1.
5	Access Review Automation P. Ng COMPONENT TOTAL	uyen	Initiate	On-Track	10.0% 38.8%	\$750,000 \$35,000 \$7,400,000 \$3,245,000	\$715,000 \$4,155,000	Vendor selection pending — R RFP closes 5/15 c c	FP issued 4/15. 4 vendors onfirmed bidding. Scoring complete by 6/1.

Status roll-up rule

Program status reflects component health: if 2+ components are Off-Track, program is Off-Track. If multiple At-Risk without Off-Track, program is At-Risk. All On-Track or 1 At-Risk, program is On-Track. PM judgment

overrides this rule when justified — document the reasoning in Status Reports.

% complete methodology

% complete is a TPM-asserted estimate of component progress, not strict milestone completion. It accounts for in-progress work within milestones (e.g., ZTNA at 45% reflects pilot underway and architecture work in

progress, even though no major milestones are formally complete yet). Discuss methodology change with PMO if you want to switch to strict milestone-weighted or earned-value calculation.

Quick metrics

Components On-Track	3
Components At-Risk	1

Components Of

Program Workbook — Program-Level RAID

Program-Level RAID

Risks/Assumptions/Issues/Dependencies that affect the PROGRAM. Component-specific items live in component workbooks.

ID	Type	Description	Likelihood	Impact	Score	Status	Owner	Date raised	Target close	Mitigation / response plan
P-R-001	Risk	FIDO2 hardware lead time (12 weeks) High jeopardizes program completion timeline		High	9	Mitigating	S. Chen	2026-03-15	2026-05-30	Procurement escalation to CFO completed 4/10. Negotiated 50% partial shipment in 6 weeks. Considering platform authenticators for Phase 1 to maintain timeline.
P-R-002	Risk	Identity Provider migration could break legacy	Medium	High	6	Monitoring	M. Ortiz	2026-02-20	2026-08-30	Sequencing constraint added: ZTNA rollout follows IdP

ID	Type	Description	Likelihood	Impact	Score	Status	Owner	Date raised	Target close	Mitigation / response plan
		app SSO integrations during ZTNA cutover								migration by min 4 weeks per app. Integration test environment built.
P-R-003	Risk	Engineering org pushback on ZTNA H rollout — perceived as friction added to dev workflow	High	Medium	6	Mitigating	OCM Lead	2026-03-01	2026-06-30	OCM activated. CISO + CTO joint message to eng org wk of 4/15. Eng champion network established. Pilot feedback loop in place.
P-I-001	Issue	PAM tool (BeyondTrust) SOW negotiation stalled on pricing for produc	—	—		Mitigating	Procurement + K. Reddy	2026-04-10	2026-05-02	Procurement escalation to vendor exec completed 4/22. Counter-proposal

ID	Type	Description	Likelihood	Impact	Score	Status	Owner	Date raised	Target close	Mitigation / response plan
		tion database access								expected by 4/28. CFO approved \$50K above original budget if needed.
P-D-001	Dependency N c b	etwork team must complete VPN oncentrator decommission to free budget for ZTNA expansion	—	—		Open	Network Team (J. Park)	2026-02-15	2026-09-30	Network team committed to Q3 decommission. Tracking in their roadmap. Status check monthly.
P-D-002	Dependency H A	R system access feed required for ccess Review Automation	—	—		Open	HR IT (A. Brooks)	2026-04-01	2026-07-15	HR IT prioritization confirmed.

Program Workbook — Cross-Component Dependencies

Cross-Component Dependencies

Where Component A needs something from Component B. The most common source of program failure — track these closely.

ID	(needs)	What's needed Need-by date Status Risk Owner Notes (provides)
DEP- 001	ZTNA Rollout (#2)	Identity Provider Apps must be migrated to 2026-08-15 On-Track Medium M. Ortiz Sequencing built into program
DEP- 002	Access Review	Identity Provider Centralized identity needed 2026-09-30 On-Track Low M. Ortiz IdP completion 8/30 leaves
DEP- 003	Automation (#5)	Migration (#1) before access review can run buffer for access review go- org- wide live.
DEP- 004	Access Review	Privileged Access PAM must be deployed before 2026-10-30 At-Risk High K. Reddy PAM SOW delay pushes
DEP- 005	Automation (#5)	Management (#3) privileged access reviews can deployment to 9/30. Access include those accounts Review go-live target 11/15. Tight but achievable.
DEP- 006	MFA Hardening (#4)	Identity Provider Enterprise IdP must support 2026-06-30 Complete — M. Ortiz / S. Chen IdP FIDO2 support enabled
DEP- 007	MFA Hardening (#4)	Migration (#1) FIDO2 (confirmed) before MFA 4/15. Dependency satisfied. hardening can roll out
DEP- 008	ZTNA Rollout (#2)	Network Team (external VPN concentrator 2026-09-30 At-Risk Medium Network Team / J. Network team committed but
DEP- 009	ZTNA Rollout (#2)	— not in program) decommission frees network

ID	(needs)	What's needed Need-by date Status Owner Notes Risk (provides)
		Liu their priorities can shift. capex for ZTNA expansion Tracked in Program RAID (P-D-001).
DEP-	PAM (#3)	MFA Hardening (#4) FIDO2 hardware tokens 2026-08-30 At-Risk High S. Chen / K. Reddy FIDO2 hardware delay (P-R-
006		needed for privileged users 001) puts this at risk. Backup: before PAM go-live software token interim, hardware retrofit Phase 2.

Program Schedule — Milestones Across All Components

Roll-up of major milestones from each component. Detailed schedules live in component workbooks.

ID	Milestone	Component	Phase	Planned start Planned end	Actual end	Status	Notes
M-001	Program kickoff	Program	Initiate	2026-01-15 2026-01-20	2026-01-20	Complete	
M-002	Charter approved by all sponsors	Program	Initiate	2026-01-20 2026-02-05	2026-02-03	Complete	
M-003	IdP RFP issued	IdP Migration	Plan	2026-01-25 2026-02-15	2026-02-12	Complete	
M-004	IdP vendor selected	IdP Migration	Plan	2026-02-20 2026-03-15	2026-03-12	Complete	
M-005	IdP — first 50 apps migrated (Phase 1)	dP Migration	Execute	2026-03-20 2026-05-30		In Progress	On track — 30 of 50 done
M-006	IdP — remaining	Migration					

ID	Milestone	Component	Phase	Planned start Planned end	Actual end	Status	Notes
	apps migrated (Phase IdP)						

Program Workbook — Shared Resources Across Components

Shared Resources Across Components

People allocated to multiple components. Watch the Total column — anyone over 100% is over-allocated.

Access

Name	Role	IdP	ZTNA	PAM	MFA Review	Program	Total %	Notes
A. Singh	Sr Security Engineer	30%	30%	20%	10% 0%	0%	90%	
L. Garcia	Identity Architect	60%	20%	0%	20% 0%	0%	100%	
R. Patel	Network Engineer	10%	50%	0%	0% 0%	0%	60%	
T. Wilson	GRC Analyst	10%	10%	20%	20% 30%	10%	100%	
D. Kim	Security Engineer	0%	20%	40%	30% 0%	0%	90%	
B. Foster	Cloud Engineer	20%	30%	40%	20% 0%	0%	110%	
E. Tanaka	QA Engineer	20%	20%	20%	20% 10%	0%	90%	
Program PM	Program Manager (you) 10%		10%	10%	15% 5%	50%	100% 0% 0% 0% 0% 0% 0% 0% 0%	

Allocation rules

Total allocation should be ≤100% per person. Anything above is over-allocation and a portfolio risk. 0.9–1.0 (amber) means 'fully booked, no slack' — also a risk because illness or unexpected work has

nowhere to go. Surface over-allocations at the program steering meeting.

Program Workbook — Program-Level Decisions & Changes Log

Program-Level Decisions & Changes Log

Program-level only. Component-specific decisions live in component workbooks. Append-only — never delete.

Stakeholders

ID	Date	Type	Description	Rationale	Decision-maker consulted	Status
DC-001 2	026-02-03	Decision	Selected Okta as enterprise IdP over Azure AD	Okta scored higher on app catalog S breadth (60% vs 40% pre-built integrations) and was preferred by business unit IT leads. Total cost slightly higher (\$150K over 3 yr) b offset by integration time savings.	andra Park CIO, CTO, Identity (CISO) Architect, Procurement ut	Active
DC-002 2	026-02-15	Change Request — Schedule	Extended ZTNA pilot from 2 weeks En to 4 weeks to us to	gineering org pilot revealed dev- S ol latency issues affecting 10% of ers. Additional 2 weeks needed validate fix before broader rollou	andra Park CTO, ZTNA PM, OCM Lead t.	Approved
DC-003 2	026-03-12	Decision	Adopted BeyondTrust over CyberArk for PAM	BeyondTrust pricing came in \$400K S under CyberArk over 3 years. Both met functional requirement	andra Park CIO, PAM PM, Procurement, Audit	Active

ID	Date	Type	Description	Rationale	Decision-maker consulted	Status
				S. BeyondTrust references stronger on cloud / hybrid environments which fits our roadmap.		
DC-004 2	026-04-05	Change Request — Budget Incre \$50K datab	ased PAM SOW ceiling by to unblock production ase access scope	Vendor pricing for production DB tier came in higher than RFP indicated. Required to maintain Phase 1 timeline. Pulled from program contingency reserve.	Sandra Park CFO, PAM PM, Procurement	Approved
DC-005 2	026-04-10	Decision	Approve hybrid FIDO2 approach: hardware tokens for privileged users, platform authenticators (Touch ID, Windows Hello) for everyone else	Hardware lead time was 12 weeks, Sa threatening program timeline. Hybrid approach maintains hardware FIDO2 for SOX-scope users (privileged + production access) and uses platform authenticators for the broader population. Compliance reviewed	ndra Park GRC Lead, MFA PM, Audit, IT Operations	Active

ID	Date	Type	Description	Rationale	Decision-maker consulted	Status
				and accepted 4/26.		
DC-006 2	026-04-21 Cha	nge Request — Scope Removed from Id	legacy mainframe app Mainfra P migration scope decommi of migr	me app is 18 months from M. Ortiz (ssion per IT roadmap. ROI atin	IdP PM) Sandra Park, App Approved Owner, Audit	

Program Workbook — Program Benefits Realization Map

Program Benefits Realization Map

Benefits the program is delivering, when each materializes, how it's measured, and who owns sustainment.

Benefit owner (post-

Benefit	Source component(s) Realization timing Measurement method Target program)	Notes
Reduce VPN-related security	ZTNA Rollout (#2) 12 months post- Incident count from 70% reduction (baseline Director, Security	Measured at 6 mo and 12 mo.
incidents by 70%	launch SIEM tagged 'remote 2025: 23 incidents) Operations access'	Track quarterly.
Achieve SOC 2 Type II audit	IdP Migration (#1) + On Phase 1 External auditor Zero critical/major Director, GRC	Audit window: Q4 2026. Pre-
findings closure for identity	MFA Hardening (#4) + completion attestation findings on identity	audit dry-run scheduled 8/30.
controls	PAM (#3) (estimated 9/30) controls in next audit	
Reduce mean-time-to-revoke	Access Review On launch + 1 Time delta between <24 hours for 95% of Director, Security	HR system feed dependency
access from 14 days to <24	Automation (#5) quarter (estimated termination event in HR terminations	must be live.

Benefit	Source component(s) Realization timing Measurement method Target program)	Notes
	Operations	
hours	Q1 2027) and access removal across systems	
Eliminate password-based	PAM (#3) + MFA On Phase 2 Audit log review — Zero password-only Director, Infrastructure	Hard cutover requires PAM
access to production systems	Hardening (#4) completion count of password auth access by 2/2027 (estimated events on prod systems 1/31/2027)	Phase 2 + FIDO2 Phase 2 both complete.
Reduce identity-related help desk	IdP Migration (#1) + 6 months post- ServiceNow ticket 40% reduction (baseline Director, IT Service	Counter-effect possible during
tickets by 40%	MFA Hardening (#4) launch volume tagged 'identity' 2025 monthly avg: 340) Management or 'MFA'	migration — expect spike before drop.
Enable foundation for future Zero	All 5 components On program Architecture maturity Achieve 'Defined' or VP, Security	Strategic, not directly
Trust architecture	completion assessment by external higher on 8 of 10 ZT Architecture (estimated advisor pillars 9/30/2027)	measurable. Maturity assessment Q4 2027.
Reduce annual cost of legacy ZT	NA Rollout (#2) On VPN Annual VPN licensing + \$420K annual savings VP, Network Dependent on Network team's	
VPN infrastructure	decommission maintenance contracts Engineering decommission timeline (P-D- (estimated cancelled 001). 12/31/2026)	

Program Status Reports — Running History

Append a new row each week. The history is the artifact — never overwrite.

Overall

Report date	Period	Reported by status	Key accomplishments	Planned next period	Top risks / issues	Asks / blockers
2026-04-07	Wk 14	Program PM At-Risk	IdP migration hit 50% of Phase 1 apps. ZTNA pilot launched eng org.	Continue IdP Phase 1; ZTNA pilot week 1 feedback ses	FIDO2 hardware lead time delay	Need CISO 1:1 with CTO this week

Part III — Shared & Cross-cutting

Shared & Cross-cutting · Framework Artifacts (20)

Artifact #8 — Communications Plan

Purpose: Defines what gets communicated to whom, through which channel, at what cadence, with what message. The artifact most projects under-do.

When you use it: Plan phase; refined as stakeholder needs become clearer.

Owner: TPM or comms lead; coordinated with OCM lead.

Cadence: Monthly review; ad-hoc updates for major announcements or escalations.

Where it lives: Templates Pack 6 has fillable Communications Plan.

Sections / contents:

Section	Contents / fields
Communication objectives	What this plan must achieve
Audience map	Per audience: why we communicate, key messages, channel, frequency
Channel guidance	Which channel for which type of message
Message framework	Per audience: core message, supporting points, proof
Communications calendar	Standing comms scheduled in advance
Crisis & escalation comms	Triggers, comms lead, escalation path, pre-approved holding statements
Effectiveness measurement	How we know the comms are working

AI enablement

- Tailor message variants per audience automatically — exec summary vs detailed team update vs customer-facing.
- Schedule and send recurring updates from workbook tabs without manual work.
- Measure effectiveness — open rates, engagement, sentiment — and surface where comms aren't landing.
- Detect comm gaps: stakeholders not receiving updates aligned to their RACI involvement level.

Note: Most projects over-communicate to too many people, under-communicate to the ones who matter, and never measure whether the comms worked. The plan should fix all three.

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 (Stakeholder performance domain) and ISO 21500:2021 clause 4.3.38. Method: identify audiences -> define information needs and frequency -> select channels -> assign message owners -> schedule -> execute -> measure effectiveness -> adjust.

Guiding principles: Every communication serves a specific audience with a specific purpose; frequency and channel must match the audience's role and preference, not the sender's

convenience; two-way communication (feedback loops) must be built in, not added as an afterthought; the plan covers crisis and escalation communications, not just routine status.

What good looks like:

- Each row specifies audience, message content, owner, channel, frequency, and feedback mechanism.
- Escalation and crisis communication protocols (what triggers them, who sends them, within what SLA) are explicitly documented.
- Communications effectiveness is measured (e.g., open rates, survey scores) and the plan is adjusted based on data.
- The plan is synchronized with the Stakeholder Engagement Plan so high-influence resistors receive targeted messaging.
- Executive-level communications (SteerCo packs, sponsor updates) are scheduled in advance and never ad hoc.

Common pitfalls:

- Communications plan conflated with a distribution list; no frequency, message, or owner specified per audience.
- One-way broadcast approach with no mechanism for stakeholders to ask questions or signal concerns.
- Plan written at initiation and never updated as audiences, channels, or project context change.
- No owner for each communication; 'the PM' is responsible for everything, which means nothing gets tailored.
- Sensitive communications (cost overruns, personnel changes) not addressed, leading to reactive, inconsistent messaging.

Maturity (1-5): L1 Ad hoc - communications sent reactively when problems arise; L2 Defined - a plan exists with a distribution list but no owned schedule or feedback loop; L3 Managed - audience-segmented, owned, scheduled, with two-way feedback mechanisms; L4 Integrated - communications synchronized with stakeholder engagement and change management plans, effectiveness measured; L5 Optimizing - real-time sentiment analytics feed message calibration and channel optimization.

Artifact #9 — Organizational Change Management (OCM) Plan

Purpose: Manages the human side of change — adoption, resistance, sponsorship, training, reinforcement. The Communications Plan is one component of OCM but not the whole thing.

Not to be confused with: Not to be confused with project Change Control (Artifact #61): Organizational Change Management is the people side - helping the organization adopt the new way of working (ADKAR). A project Change Request manages changes to the project's scope, schedule, and cost baseline through the CCB. Different discipline, different owner.

When you use it: Plan phase, for projects with meaningful behavioral, process, role, or tooling change.

Owner: OCM lead (dedicated for major change) or TPM (for lighter change).

Cadence: Living document — updated as adoption metrics come in.

Where it lives: Templates Pack 7 has fillable OCM Plan.

Sections / contents:

Section	Contents / fields
Change vision	What's changing, why, future-state vision

Section	Contents / fields
Change impact assessment	Per affected group: what changes, impact level, resistance risk, adoption complexity
Sponsorship & coalition	Active, visible sponsor activities — not just endorsement
Resistance management	Anticipated sources, concerns, response approach
Training strategy (high level)	Audiences, modalities, timing, success metrics — links to Training & Awareness Plan
Communications	OCM-specific comms — coordinate with Communications Plan
Reinforcement & sustainment	How adoption is sustained 6+ months post-launch
Adoption metrics	Usage, compliance, sentiment, productivity, resistance indicators
Risks to adoption	Cross-reference RAID Log
Approvals	Sponsor, OCM lead, TPM, HR partner if applicable

AI enablement

- Score change impact and resistance risk per stakeholder group based on past adoption patterns.
- Recommend interventions tailored to each group's resistance profile.
- Track adoption metrics in real time and surface where reinforcement is failing.
- Personalize change messaging by role, tenure, and prior change history.

Note: Resistance is information, not opposition. Address the concern to address the resistance. Sponsor 'support' is not an OCM activity — name what the sponsor will actually do, when.

PRACTITIONER REFERENCE

Standards & method: Grounded in Prosci ADKAR model (Awareness, Desire, Knowledge, Ability, Reinforcement) and Kotter 8-Step Change Model. Complements ISO 21500 (Stakeholder management). Method: assess change impact -> diagnose readiness and resistance -> design interventions per ADKAR gap -> execute with reinforcement loops -> sustain post-go-live.

Guiding principles: People change at the speed of trust, not the speed of the project plan; ADKAR gaps must be diagnosed per role group, not assumed uniform; change management starts at project initiation, not 30 days before go-live; sponsorship is an active, visible behavior, not a signature.

What good looks like:

- A change impact assessment quantifies the number of impacted roles, volume of process change, and magnitude of behavior shift per group.
- ADKAR scores are assessed by role group with targeted interventions mapped to each gap.
- Sponsor and change champion network is identified, activated, and coached with specific talking points and behaviors expected.
- Resistance is anticipated by role group with mitigation strategies, not treated as an unexpected event.
- A post-go-live reinforcement plan (coaching, metrics, feedback loops) extends at least 90 days beyond cutover.

Common pitfalls:

- OCM plan written as a communications plan with a new title; no behavioral change analysis.
- Change management engagement starting in the final month before go-live, when resistance is already entrenched.
- Sponsor treated as a figurehead who sends one all-hands email rather than an active, visible change advocate.
- Resistance dismissed as 'people resisting change' with no structured diagnosis of the root cause.
- No reinforcement or sustainment plan; adoption assumed to occur naturally after training.

Maturity (1-5): L1 Ad hoc - change communicated via an all-hands announcement; L2 Defined - a communications plan exists but no impact assessment or ADKAR analysis; L3 Managed - ADKAR scored by role group, sponsor activated, resistance managed, reinforcement planned; L4 Integrated - change management integrated with training, communications, and project schedule with adoption KPIs tracked; L5 Optimizing - real-time adoption data feeds adaptive interventions and organizational change capability is continuously built.

Artifact #10 — Training & Awareness Plan

Purpose: Operationalizes the training strategy from the OCM Plan. Specifies who is trained on what, when, by whom, in what format, with what assessment.

When you use it: Plan phase; refined as launch approaches.

Owner: Training lead or OCM lead.

Cadence: Detailed plan locked 4–8 weeks before launch; refreshed for waves and reinforcement.

Where it lives: Templates Pack 8 has fillable Training & Awareness Plan.

Sections / contents:

Section	Contents / fields
Training objectives	Measurable outcomes — what people can do after training
Audiences & learning needs	Current state, required state, learning gap per audience
Curriculum	Modules with audience, learning objectives, duration, modality, owner
Delivery schedule	Waves: pre-launch, launch waves, post-launch reinforcement
Assessment & completion	How tracked, assessment method, pass criteria
Awareness activities	Broader, lighter activities for non-trained audiences
Effectiveness metrics	Completion, comprehension, application, confidence, help desk volume
Logistics	Environments, materials hosting, train-the-trainer, localization, accessibility

AI enablement

- Generate role-specific training content variants from a single source-of-truth knowledge base.
- Personalize training paths based on existing skills and prior training history.
- Auto-assess comprehension and adapt the path when learners struggle with specific concepts.
- Track completion and competence in real time; surface where reinforcement is needed.

Note: Awareness is not training. Awareness is broader and lighter, designed to ensure people

who aren't being trained still understand what's happening.

PRACTITIONER REFERENCE

Standards & method: Aligned to ADKAR (Knowledge and Ability components) for change enablement and ISO 10015:2019 (Quality management - guidelines for competence development). For regulated environments, references relevant compliance training standards. Method: assess training needs by role -> design curriculum and modality -> develop content -> pilot and refine -> deliver -> assess knowledge transfer -> reinforce.

Guiding principles: Training addresses the ADKAR Knowledge and Ability gaps, not the system's features; modality must match the learner's context and complexity of the behavior change; completion rates are a lagging indicator - proficiency measures are the real metric; just-in-time delivery beats months-before-go-live delivery.

What good looks like:

- Training needs assessment is role-based, linked to the change impact assessment, and distinguishes awareness from skill-building needs.
- Each course or module has a defined learning objective with a measurable proficiency test, not just an attendance record.
- Training schedule is sequenced so delivery occurs close enough to go-live that knowledge is retained and actionable.
- Pilot delivery with a representative user group captures feedback before full rollout, allowing content revision.
- Post-training support model (job aids, help desk, floor-walkers) is documented and resourced for go-live and hypercare.

Common pitfalls:

- Training scheduled 6-8 weeks before go-live, ensuring maximum knowledge decay before day one.
- Completion rate reported as success metric with no assessment of actual proficiency or behavioral change.
- One modality (e.g., e-learning only) applied uniformly across roles with vastly different complexity of change.
- Training content developed before the system is stable, requiring expensive rework at the last minute.
- No plan for employees who miss scheduled training sessions, creating a coverage gap at go-live.

Maturity (1-5): L1 Ad hoc - training is a one-day go-live briefing; L2 Defined - training plan exists with role lists and dates but no needs assessment or proficiency metrics; L3 Managed - needs assessed by role, proficiency tested, just-in-time delivery, hypercare support planned; L4 Integrated - training effectiveness linked to adoption KPIs and performance metrics post go-live; L5 Optimizing - learning analytics drive continuous curriculum improvement and predictive readiness scoring.

Artifact #46 — Delivery Health Check Assessment

Purpose: Give a structured, repeatable read on the true health of a project or program beyond the status RAG - across delivery, governance, risk, stakeholder, and team dimensions - so problems surface before they show up in the schedule. Usable at project and program level.

When you use it: Run at major gates, when a status color is disputed, on takeover of a troubled effort, or on a fixed cadence for assurance.

Owner: TPM/PMO runs the assessment; sponsor receives it; an independent reviewer adds objectivity for high-stakes efforts.

Cadence: Gate-based or quarterly; immediately on takeover or when RAG and reality disagree.

Where it lives: Workbook tab 'Health Check'; findings feed the RAID log and recovery planning.

Sections / contents:

- Dimensions scored (1-5) with defined anchors: scope clarity, schedule confidence, budget health, risk posture, quality, stakeholder/sponsor engagement, team capacity/morale, governance effectiveness
- Evidence per dimension (not opinion): what was reviewed
- Overall health rating and trend vs last assessment
- Red/amber findings with recommended actions and owners
- Confidence in the reported status (does RAG match the assessment?)
- Escalations requiring sponsor/executive action

PRACTITIONER REFERENCE

Standards & method: Aligned to PMI PMBOK 7 performance domains and P3M3 Portfolio, Programme, and Project Management Maturity Model. Method: define health dimensions (schedule, scope, budget, risk, governance, team, benefits) -> define RAG thresholds quantitatively -> assess each dimension with evidence -> calculate aggregate health score -> produce trend and recommended interventions.

Guiding principles: RAG status is evidence-based, not sentiment-based; trends matter more than point-in-time status; health checks are safe-to-speak forums, not audit events; recommendations are actionable and owner-assigned.

What good looks like:

- RAG thresholds are pre-defined numerically (e.g., schedule variance >10% = amber, >20% = red) and agreed with sponsors.
- Each dimension has cited evidence (metric, date, source) not just a color.
- Trend line shown over at least three prior periods, distinguishing improving from deteriorating status.
- Recommended interventions are specific, time-bound, and owner-named, not generic advice.
- Results are shared with the full delivery team, not just executives, to drive engagement and trust.

Common pitfalls:

- RAG inflation: everything green until catastrophic failure, destroying the signal value of the tool.
- Health check is a compliance exercise completed the day before governance, not a management tool.
- No distinction between lagging indicators (variance) and leading indicators (risk exposure, team morale).
- Aggregated score masks a critical red dimension hidden by green scores in non-critical areas.
- Recommendations repeated verbatim across consecutive cycles with no progress tracking, signaling theater.

Maturity (1-5): L1 Ad hoc - health assessed informally if at all; L2 Defined - standard template used, periodic cadence; L3 Managed - thresholds defined, trends tracked, interventions assigned; L4 Quantified - predictive health models, cross-portfolio benchmarking; L5 Optimizing - automated health telemetry, AI-generated intervention recommendations.

Artifact #47 — Team Onboarding & Ramp Plan

Purpose: Ensures every new team member and vendor arrives with the context, access, tools, and role clarity to contribute without delay. Covers program background, ways of working, clearances, tooling setup, who-owns-what, and a structured 30/60/90-day ramp to full productivity.

When you use it: Drafted in Initiate before the first wave of staff joins; updated for each subsequent onboarding cohort or vendor mobilization.

Owner: TPM owns the master plan; workstream leads own cohort-specific tracks; HR/procurement own clearance and contracting preconditions.

Cadence: Reviewed at each major staffing event; completion status tracked weekly in the first 30 days per joinee.

Where it lives: Workbook tab 'Onboarding'; linked to RACI, RAID, and resource plan.

Sections / contents:

Section	Contents / fields
Joiner	Name, role, workstream, start date, cohort
Program Context	One-page brief: scope, objectives, key decisions to date, current phase
Access & Clearances	Systems, environments, VPN, PAM vault, badge access - owner and target date per item
Tooling Setup	Jira, Confluence, Slack, repo, AI toolkit access - status and verification step
Ways of Working	Meeting cadence, communication norms, decision rights, escalation path, code-of-conduct pointer
Role & Deliverable Map	Deliverables owned, key dependencies, first 30-day output target
30/60/90 Milestones	Day 30: context and access complete; Day 60: first deliverable drafted; Day 90: fully productive, peer-reviewed output
Buddy/Mentor	Named buddy, check-in schedule, feedback loop
Completion Sign-off	Joiner and workstream lead confirm each section complete
— PRACTITIONER REFERENCE	—

Standards & method: Aligned to PMI PMBOK 7 (Team Performance Domain: enabling effective team integration) and PRINCE2 Organizing theme (define roles and responsibilities before work starts). Method: identify joiner cohort -> assign buddy -> complete access checklist -> brief on ways of working -> set 30/60/90 targets -> sign off. ISO 30401 (Knowledge Management) supports the structured knowledge-transfer approach.

Guiding principles: No one should block on context they were never given; access readiness is a project risk, not an HR task; ramp pace should be measured, not assumed; buddy accountability closes the gap between plan and reality.

What good looks like:

- All access items have an owner and a target date tracked to completion
- 30/60/90 milestones are specific and measurable, not generic
- Vendors and contractors onboard through the same gate as staff
- Buddy check-ins surface blockers before they affect delivery

- Completion rate is visible on the project dashboard

Common pitfalls:

- Access requests raised after start date, causing idle time in week one
- Program context left to informal hallway conversations
- Vendor onboarding treated as the vendor's problem alone
- 30/60/90 targets not reviewed, making ramp invisible to leadership
- Plan created once and never updated for later cohorts

Maturity (1-5): L1 Ad hoc - no plan, each joinee navigates alone; L2 Defined - checklist exists but not tracked; L3 Managed - plan tracked per joinee, access and milestones logged; L4 Quantified - ramp time measured, completion rates reported, blockers trended; L5 Optimizing - data drives pre-emptive access provisioning and buddy matching before start date.

Artifact #48 — Team AI Enablement & Literacy

Purpose: Builds the delivery team's capability to use the PMO AI toolkit safely and effectively: good prompting, output verification discipline, data classification boundaries, role-based enablement paths, and a measurable uplift baseline. Ensures AI adoption is intentional and auditable, not ad hoc.

When you use it: Designed in Plan before AI-assisted artifacts are produced; refreshed when new toolkit features are released or when AI use audits reveal gaps.

Owner: TPM owns the enablement plan; AI practice lead or equivalent owns content and verification standards; workstream leads own team compliance.

Cadence: Kickoff session in Plan week; monthly pulse check on usage and quality; quarterly uplift assessment.

Where it lives: Workbook tab 'AI Enablement'; linked to Team Onboarding Plan and quality gate checklist.

Sections / contents:

Section	Contents / fields
Role Tier	Role group (e.g., TPM, BA, engineer, PMO analyst) and permitted AI use cases per tier
Permitted Data Classes	What data may be pasted into AI prompts: public, internal, confidential-labeled items explicitly excluded
Prompt Standards	Required prompt structure: role framing, context, task, constraints, output format; example approved prompts per tier
Verification Discipline	Mandatory human review steps: fact-check, source trace, hallucination scan checklist before any AI output is filed
Prohibited Uses	Explicit list: no PII, no regulated data, no final approvals without human sign-off, no unreviewed AI text in client deliverables
Enablement Path	By role: self-paced module, practice exercise, assessed prompt task, sign-off; target completion date
Uplift Baseline & Target	Pre-training benchmark (task time or quality score), target post-training metric, measurement method
Audit & Compliance Log	How AI use is logged, who reviews, escalation if prohibited use detected
Refresh Trigger	Events that trigger plan update: new model, new toolkit feature, audit finding, regulatory change

Section	Contents / fields
— PRACTITIONER REFERENCE —	—

Standards & method: Aligned to NIST AI RMF (Govern 1.1: policies for AI use; Map 1.5: risk tolerance per use case) and ISO/IEC 42001 (AI Management System: competence and awareness clause 7.2/7.3). Method: classify permitted use cases by role -> set data boundaries -> define prompt standards -> train and assess -> measure uplift -> audit. PMI PMBOK 7 Team Performance Domain supports intentional capability building.

Guiding principles: AI amplifies the analyst, it does not replace judgment; every AI output that enters a deliverable must pass a human verification gate; data classification governs what enters the prompt, always; uplift is measured, not assumed.

What good looks like:

- Every team member has a role-matched enablement path with a clear completion gate
- Data classification boundaries are explicit and tested, not implied
- Verification checklists are embedded in the artifact workflow, not a separate afterthought
- Uplift metrics show before/after productivity or quality delta
- Prohibited uses are a named, maintained list visible to all

Common pitfalls:

- AI enablement treated as a one-time lunch-and-learn with no follow-up
- No data classification rules, leading to confidential data in prompts
- Verification discipline absent, so AI hallucinations reach deliverables
- Uplift assumed rather than measured, making ROI invisible
- Enablement one-size-fits-all when BA, engineer, and PMO analyst have very different use cases

Maturity (1-5): L1 Ad hoc - individuals use AI tools without guidance or guardrails; L2 Defined - usage policy exists but training is informal; L3 Managed - role-based paths, data rules, verification checklists all in place and tracked; L4 Quantified - uplift measured, audit logs reviewed, defect rate from AI outputs trended; L5 Optimizing - continuous prompt library improvement driven by audit findings and measured quality gains.

Artifact #49 — Security Awareness Campaign

Purpose: Drives org-wide and role-based security behavior change aligned to the Atlas ZTNA and PAM deployment. Covers campaign design, phishing simulations, behavior-change metrics, role-targeted content, and a measurement framework that distinguishes awareness from behavioral adoption.

When you use it: Campaign design begins in Plan; active execution runs through Execute and into Stabilize; measurement continues post-go-live until behavior targets are met.

Owner: Change lead owns campaign design and delivery; CISO owns security content accuracy; comms lead owns channel and messaging; workstream leads own role-targeted modules.

Cadence: Monthly campaign pulse; phishing simulations quarterly or event-triggered; behavior metric review in every governance cycle.

Where it lives: Workbook tab 'Security Awareness'; linked to Change Impact Assessment, Training Plan, and Risk Register.

Sections / contents:

Section	Contents / fields
Audience Segment	Role group, estimated headcount, risk profile (high/medium/low), and rationale for segmentation
Threat Scenarios	Top 3-5 threats relevant to ZTNA/PAM change per segment: credential phishing, privilege abuse, shadow IT, MFA fatigue, social engineering
Campaign Modules	Module name, format (email, video, workshop, simulation), audience, delivery channel, owner, target date
Phishing Simulation Plan	Scenario design, target group, success metric (click rate, report rate), scheduled dates, feedback loop for those who click
Behavior Metrics	Leading indicators (click-through rate, simulation report rate, helpdesk query type) and lagging indicators (security incidents attributable to human error)
Reinforcement Mechanism	How good behavior is recognized; how repeat failures trigger escalation; manager briefing on team-level results
Channel & Cadence Plan	Intranet, email, digital signage, team meetings, leadership cascade; message frequency per channel
Completion & Compliance Tracking	Mandatory vs. recommended modules; completion rate by segment; escalation for non-completion
Campaign Retrospective	Post-campaign review: metric targets vs. actuals, lessons, plan for sustained reinforcement
— PRACTITIONER REFERENCE —	

Standards & method: Aligned to ISO 27001:2022 Annex A 6.3 (Security Awareness, Education, and Training) requiring role-based, measured awareness programs. Method: segment audience by risk -> design threat scenarios -> build campaign modules -> run phishing simulations -> measure behavior metrics -> reinforce and escalate. Prosci ADKAR supports the awareness-to-behavior-change arc (Awareness -> Desire -> Knowledge -> Ability -> Reinforcement). NIST SP 800-50 (Building an IT Security Awareness Program) informs simulation and metric design.

Guiding principles: Awareness without behavior change is a compliance checkbox, not a risk control; role-based targeting beats org-wide blast; measurement must distinguish knowledge from behavior; leadership visibility of team-level metrics drives manager accountability.

What good looks like:

- Phishing simulation click rates trending down across all segments over the campaign lifecycle
- Role-targeted content addresses the actual threat scenarios that segment faces, not generic tips
- Behavior metrics (simulation report rate, helpdesk query type) tracked alongside completion rates
- Manager briefings on team-level results create accountability below the campaign team
- Reinforcement plan sustains behavior change beyond go-live, not just a pre-launch spike

Common pitfalls:

- Org-wide email blasts treated as sufficient - awareness measured by send, not behavior

- Phishing simulations run without a feedback loop for those who click, missing the learning moment
- Completion rate reported as the headline metric while click rates are ignored
- No role-based segmentation, so executives, engineers, and call-center agents get identical content
- Campaign ends at go-live with no reinforcement, and behavior reverts within 60 days

Maturity (1-5): L1 Ad hoc - annual security email, no measurement; L2 Defined - structured campaign with completion tracking; L3 Managed - role-based segments, phishing simulations, behavior metrics tracked; L4 Quantified - click rate and incident trends correlated, manager accountability integrated; L5 Optimizing - behavioral data drives real-time campaign adjustment, simulation scenarios updated from live threat intelligence.

Artifact #50 — Responsible AI Usage Guardrails

Purpose: Defines what program data may and may not be entered into AI/LLM tools, establishes data-classification rules for AI inputs, mandates human-in-the-loop verification for all AI-assisted outputs, enumerates approved tools, assigns accountability, and requires audit logging - protecting Bristol Financial from data leakage, hallucination-driven decisions, and regulatory exposure across all 40+ AI prompts in the toolkit.

When you use it: Authored and approved in the Plan phase before any AI-assisted work products are generated; reviewed at each phase gate and updated whenever a new AI tool is onboarded or a new data-classification concern is raised.

Owner: TPM owns the document and enforces compliance; CISO or delegate approves data-classification rules; each workstream lead is accountable for their team's adherence.

Cadence: Approved once in Plan; reviewed at every phase gate; ad hoc update within 5 business days of any new AI-tool request or classification incident.

Where it lives: Workbook tab 'AI Guardrails'; linked from the Program Charter and the onboarding checklist; physical copy in the secure document repository.

Sections / contents:

Section	Contents / fields
Scope and Applicability	All team members, contractors, and vendors using AI or LLM tools (ChatGPT, Copilot, Claude, Gemini, or equivalent) in any program-related activity on Project Atlas at Bristol Financial.
Data Classification Matrix	Restricted (e.g., PAM credential vaults, ZTNA policy configs, PII, audit logs) - NEVER entered into external AI. Confidential (e.g., architecture diagrams, risk registers) - approved internal AI only with DLP controls. Internal (e.g., meeting notes, draft schedules) - approved tools with output review. Public (e.g., vendor documentation, published standards) - any approved tool.
Approved Tools Register	Columnar log: Tool Name Approval Date Approver Data Classes Permitted Deployment Model (cloud/on-prem) Expiry Review Date. Unapproved tools are prohibited; using an unapproved tool is a policy violation reportable to the CISO.
Human-in-the-Loop Requirements	All AI-generated work products (risk assessments, status reports, architecture recommendations, test cases) must be reviewed and explicitly accepted by a named human owner before use. AI output may not be forwarded externally or to governance bodies without human certification. Certification is logged with reviewer name, date, and artifact ID.

Section	Contents / fields
Prohibited Uses	Entering restricted or confidential data into non-approved external AI. Autonomous AI-driven configuration changes to identity or network systems. Using AI output as sole basis for go/no-go decisions. Generating synthetic PII or credential data in any AI tool. Sharing AI-generated security-architecture outputs outside the project without CISO clearance.
Prompt Engineering and Output Hygiene	Prompts must be stripped of restricted/confidential tokens before submission. Outputs must be validated against source-of-truth documentation. Hallucinated citations or vendor claims must be flagged and removed. Teams are encouraged to use the toolkit's pre-approved prompt library to reduce ad hoc prompt risk.
Accountability and Breach Response	Each workstream lead signs the AI Guardrails acknowledgment. Suspected data-leakage incidents are reported to the CISO and TPM within 1 hour. Root-cause review is completed within 5 business days. Repeat violations escalate to the Steering Committee.
Audit Logging	Each AI-assisted output is tagged with: artifact ID, tool used, date, author, data class of inputs, and human-reviewer sign-off. Logs retained for the duration of the program plus 12 months. Logs are reviewed quarterly by the CISO delegate.
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to NIST AI RMF (Govern, Map, Measure, Manage functions) and ISO/IEC 42001 (AI management system - policy, risk, human oversight). OWASP LLM Top 10 (LLM01 Prompt Injection, LLM02 Insecure Output Handling, LLM06 Sensitive Information Disclosure) directly informs the prohibited-uses and output-hygiene sections. ISO 27001 Annex A controls (A.8 Technological controls, A.5 Organizational controls) apply to data classification and access. Method: classify data -> approve tools -> define prohibited uses -> mandate human review -> log and audit.

Guiding principles: No restricted or confidential data enters an unapproved AI system; every AI-generated output has a named human accountable for its accuracy; AI accelerates the team but never makes governance decisions autonomously; guardrails are living policy - updated as the tooling landscape evolves.

What good looks like:

- Data classification matrix is specific to Bristol Financial's own classification scheme and maps directly to named systems (PAM vaults, ZTNA configs)
- Approved tools register is a live log with expiry review dates, not a static list
- Human-in-the-loop requirement is enforceable - each AI output carries a named reviewer and date before it can be used
- Prohibited uses are written as concrete actions, not vague principles, so team members can self-check
- Breach response has a 1-hour reporting SLA and a defined root-cause timeline, closing the accountability loop

Common pitfalls:

- Guardrails written at too high a level - team members cannot determine from the policy alone whether a specific action is permitted

- No approved-tools register maintained, so the policy drifts from reality as new tools are adopted informally
- Human-in-the-loop requirement exists on paper but is never logged, making compliance unverifiable
- Data classification not mapped to actual Bristol Financial systems, leaving ambiguity about which assets are restricted
- Policy authored once and never reviewed, so it does not keep pace with new AI capabilities or new toolkit prompts added mid-program

Maturity (1-5): L1 No policy; AI tools used ad hoc with no data-handling rules; L2 Basic list of approved tools exists but data classification and human-review requirements are absent; L3 Written policy covering classification, approved tools, prohibited uses, and human review; signed acknowledgment by all team members; L4 Audit logs are kept, reviewed quarterly, and breach incidents are tracked with root-cause closure; compliance metrics reported to SteerCo; L5 Guardrails continuously updated based on incident learnings, new tool assessments, and evolving NIST AI RMF / ISO 42001 guidance; integrated into vendor onboarding and program change control.

Artifact #52 — Phase-Gate (Tollgate) Reviews

Purpose: Provides formal stage-gate governance for each lifecycle phase transition - defining entry and exit criteria per phase, a structured gate review pack, and a go / no-go / go-with-conditions decision by a named gate authority - so that the program advances only when readiness is objectively demonstrated and any conditions are tracked to closure.

When you use it: Gate review pack prepared in the final 2 weeks of each phase; gate meeting held on the last day of the phase or first day of the next (per the program calendar). Gate criteria are defined in Plan phase for all gates; not negotiated at the gate itself.

Owner: Gate Authority (Steering Committee Chair or delegated executive) makes the go/no-go/go-with-conditions decision. TPM owns the gate review pack preparation and coordinates input from all workstream leads. Each workstream lead signs off their section before submission.

Cadence: One gate review per phase transition: Initiate -> Plan, Plan -> Execute, Execute -> Monitor and Control (milestone gates), Monitor and Control -> Close. Unscheduled gates may be called by the Steering Committee if a major risk or change event warrants reassessment.

Where it lives: Gate review pack published to the program SharePoint site at least 3 business days before the gate meeting. Decision recorded in the Gate Decision Log (workbook tab 'Gate Log'). Conditions tracked in the RAID log.

Sections / contents:

Section	Contents / fields
Gate Definitions and Authorities	Table: Gate ID Phase Transition Gate Name Gate Authority Quorum Decision Options. Decision options: Go (all criteria met), No-Go (gate does not pass; phase does not advance; remediation plan required within 5 business days), Go-with-Conditions (gate passes with named conditions; each condition has an owner, completion date, and is logged in the RAID register).
Entry and Exit Criteria per Gate	For each gate: a numbered list of mandatory criteria (must-pass) and advisory criteria (best-practice; documented if not met). Criteria are specific, binary, and verifiable - not subjective judgments. Example structure: Gate 2 (Plan -> Execute) exit criteria: (1) Approved Project Charter with sponsor signature. (2) Baselined integrated schedule with no open critical-path dependencies. (3) Risk register with at

Section	Contents / fields
	least one response per High-rated risk. (4) AI Guardrails document approved by CISO. (5) All team members onboarded and acknowledging program policies.
Gate Review Pack Structure	Cover page with gate name, date, gate authority, and TPM. Executive summary (1 page): overall recommendation (Go / No-Go / Go-with-Conditions), top 3 risks, top 3 open issues. Schedule status: RAG, milestone completion, float on critical path. Scope status: scope changes since last gate, open change requests. Financial status: spend vs. budget, forecast to complete. Risk and issues summary: top 5 risks with current response, top 5 issues with resolution status. Dependency status: at-risk dependencies and resolution plans. Quality and testing status (where applicable). Criteria scorecard: checklist of all exit criteria with evidence reference and met/not-met status.
Criteria Scorecard	One row per exit criterion: Criterion ID Criterion Text Evidence Document / Reference Met (Y/N/Partial) Notes. Any criterion marked N or Partial automatically triggers a no-go recommendation for that criterion; the gate authority decides whether to accept as a condition or reject the gate.
Go-with-Conditions Log	For each condition accepted at a gate: Condition ID Gate Condition Description Owner Due Date Status (Open / Closed). Reviewed at the next project team meeting after the gate and at weekly governance until closed. Overdue conditions are escalated to the gate authority.
Gate Decision Log	Permanent record: Gate ID Date Gate Authority Decision Conditions Count Conditions Closed By Actual Close Date Notes. Used at program close to evidence governance rigor and for post-program review.
No-Go Protocol	If a gate receives a No-Go decision: TPM publishes a remediation plan within 5 business days identifying actions, owners, and a revised gate date. The gate authority approves the remediation plan. The program does not advance to the next phase. A re-gate is scheduled once all mandatory criteria are met. No-Go decisions are reported to the Steering Committee and noted in the program status report.
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to PRINCE2 Stage Boundaries (end-stage assessment, authorization to proceed) and MSP Tranch Reviews (governance checkpoints between tranches). PMI PMBOK 7 Project Work and Delivery Performance Domains inform the criteria-based gate structure. ISO 9001 clause 8.5 (controlled conditions) and clause 9.3 (management review) support the documented criteria scorecard and formal decision record. ISO 21500 section 4.3.3 (phase reviews) is directly applicable. Method: define gates and authorities in Plan -> set binary exit criteria -> prepare pack 3 days prior -> score criteria -> gate authority decides -> log decision -> track conditions to closure.

Guiding principles: Gate criteria are agreed before the phase begins, not negotiated at the gate; the gate authority has genuine power to stop the program; go-with-conditions is not a free

pass - conditions are tracked with the same rigor as RAID items; gate decisions are recorded permanently and provide program governance evidence.

What good looks like:

- Exit criteria are written as binary, verifiable statements with a named evidence document - the gate authority can check compliance without subjective judgment
- Go-with-conditions log is maintained after the gate and conditions are reviewed weekly until closed - conditions do not quietly expire
- No-Go protocol is defined before it is ever needed, so the team knows exactly what happens and there is no ambiguity about program continuity
- Gate review pack is circulated 3 business days before the meeting so the gate authority can read it, not just listen to a presentation
- Gate Decision Log provides a permanent audit trail that can be used in a post-program review or audit

Common pitfalls:

- Exit criteria written as subjective assessments ('risks are well managed') rather than binary statements ('all High-rated risks have an approved response in the register') - gates become rubber stamps
- Gate authority attends the meeting but has not read the pack - the review becomes a presentation rather than a decision and the authority rubber-stamps the TPM's recommendation
- Go-with-conditions used routinely as a way to avoid No-Go - conditions accumulate, are never closed, and the program carries compounding technical debt through phases
- Gate criteria not set until shortly before the gate - workstream leads design backward from 'what we have' rather than forward from 'what the next phase requires'
- No-Go protocol undefined - when a gate is borderline the team has no agreed process, the decision drags, and the program either advances inappropriately or stalls without a recovery plan

Maturity (1-5): L1 No formal gates; phases begin when work is ready or when budget pressure drives it; L2 Gates exist on the program calendar but criteria are informal or absent; gate meetings are status updates, not decisions; L3 Written entry and exit criteria per gate; criteria scorecard completed; gate authority named and empowered; decisions logged; L4 Criteria scorecard linked to evidence documents; go-with-conditions tracked to closure with metrics reported to SteerCo; gate effectiveness reviewed post-program; L5 Criteria benchmarked against industry standards and prior program data; gate prediction model flags likely No-Go conditions 2-3 weeks in advance; gate process continuously improved through retrospectives.

Artifact #54 — Operating Rhythm & Cadence Map

Purpose: Provides a single authoritative map of every recurring ceremony, governance forum, and report across the programme - capturing cadence, owner, attendees, inputs, outputs, and purpose - so the team's operating rhythm is deliberate, visible, and load-balanced rather than emergent and accidental.

When you use it: Drafted in Plan phase before delivery starts; updated whenever a new governance body is stood up, a forum is retired, or the programme moves into a new phase.

Owner: TPM owns the cadence map; Programme Director approves it; each forum owner is accountable for their row.

Cadence: Reviewed monthly and formally refreshed at each phase gate; spot-checked in weekly TPM ops review against actual calendar.

Where it lives: Workbook tab 'Cadence Map'; published to the programme SharePoint homepage so all stakeholders can find it without asking.

Sections / contents:

Section	Contents / fields
Forum / Ceremony	Name of the meeting, report, or event; type tag (delivery / governance / reporting / stakeholder).
Purpose	One-sentence statement of what decision or outcome this forum produces; if no clear purpose, the forum should not exist.
Cadence & Duration	Frequency (daily, weekly, bi-weekly, monthly, per-phase) and planned duration in minutes.
Owner / Facilitator	Named individual accountable for scheduling, running, and producing outputs from this forum.
Required Attendees	Named roles (and individuals where relevant); distinguish required from optional.
Inputs Required	Documents, data, or decisions that must arrive before the forum can run effectively (with lead time needed).
Outputs / Artefacts	What the forum produces: decisions logged, actions assigned, reports published, risks updated.
Tooling & Location	Where the forum is held (Teams/in-person), where outputs are stored (SharePoint path or Jira board), and the calendar series owner.
Load Indicator	Estimated total meeting hours per week per role; flag roles exceeding 6 h/week of ceremony time as overloaded.
—— PRACTITIONER REFEREN	CE ——

Standards & method: Aligned to PMI PMBOK 7 Stakeholder Performance Domain (cadence of engagement) and PRINCE2 7 Directing and Managing a Stage (defined governance rhythm). Also supports ITIL 4 Service Value Chain (Plan and Engage activities) by making operational review cadence explicit. Method: inventory all proposed forums -> assign owners and purposes -> map inputs/outputs -> calculate per-role load -> remove or consolidate forums with no clear purpose -> publish and link from project homepage.

Guiding principles: Every forum must justify its existence with a named output; no meeting exists without an owner; ceremony load is measured and managed like any other resource; the cadence map is a living document updated when reality changes.

What good looks like:

- Every row has a named owner and at least one concrete output, making accountability clear.
- Per-role meeting load is calculated and no key delivery role exceeds 6 h/week of ceremony time.
- Inputs required are listed with lead times so late-arriving inputs are identified before the meeting, not during.
- The map distinguishes delivery ceremonies from governance forums from stakeholder reporting, preventing conflation.
- The cadence map is published on the programme homepage and referenced in onboarding, not buried in the workbook.

Common pitfalls:

- Forums are added as the programme grows but never retired, resulting in 15+ hours/week of meetings for core team members.
- Cadence is set by calendar invites without documenting purpose or outputs, so forums drift into status-read-outs with no decisions made.
- Inputs are not listed, so forums frequently cannot complete their agenda because a prerequisite report is not ready.
- Governance forums and delivery stand-ups are conflated, pulling senior stakeholders into operational detail and blocking delivery team velocity.
- The cadence map is a static slide deck updated once at programme start and never revised as the programme evolves.

Maturity (1-5): L1 - Meetings are created ad hoc via calendar invite; no inventory exists; load is unknown. L2 - A list of recurring meetings exists but purpose and outputs are not documented; load is unchecked. L3 - Full cadence map with owner, purpose, inputs, outputs, and load indicator; reviewed at phase gates. L4 - Load metrics tracked over time; cadence adjustments driven by data (e.g., attendance rates, decision latency); map auto-syncs with calendar. L5 - Cadence is continuously optimised from stakeholder feedback and delivery velocity data; benchmarked against programme portfolio norms; new forums require TPM approval and cadence map entry before first occurrence.

Artifact #55 — Escalation Framework

Purpose: Defines tiered escalation with numeric triggers and thresholds, named decision owners and rights per tier, response SLAs, routing paths and named backups, and a persistent escalation log - so issues reach the right authority at the right speed without requiring TPM judgment calls under pressure.

When you use it: Designed and agreed in Plan phase before delivery begins; thresholds validated with the sponsor and governance bodies at the first SteerCo; revisited at each phase gate and whenever a new risk category emerges.

Owner: TPM owns the framework and the escalation log; each tier owner is accountable for their response SLA; Programme Director approves tier definitions and thresholds.

Cadence: Escalation log reviewed weekly in the Programme Status Review; framework thresholds reviewed at each phase gate; open escalations tracked to closure.

Where it lives: Workbook tab 'Escalation'; escalation log in the programme SharePoint site with edit access for TPM and read access for all stakeholders.

Sections / contents:

Section	Contents / fields
Escalation Tiers	Table of tiers (T1-T4): tier label, scope of authority, named owner, named backup, and the types of issue each tier handles.
Triggers & Thresholds	Numeric or binary threshold per issue category and per tier: schedule variance (days), budget variance (%), risk score change, blockers unresolved (hours), stakeholder escalation requests, security control gaps (count).
Response SLAs	Maximum elapsed time from trigger event to tier owner acknowledgment, and maximum elapsed time to resolution or escalation to the next tier.
Routing & Backup	Decision tree or table: who is contacted first, what channel is used, who is the backup if the primary is unavailable, and what constitutes unavailability.

Section	Contents / fields
Decision Rights per Tier	What each tier owner is authorized to decide unilaterally vs. what requires consultation or a higher tier: budget authority (\$), scope change authority, vendor escalation authority, regulatory notification authority.
Escalation Log	Persistent log of every escalation raised: ID, date raised, tier, issue description, owner assigned, SLA target, resolution date, outcome, and lessons noted.
De-escalation Criteria	Explicit conditions under which an escalated item is returned to a lower tier or closed: resolution confirmed by raiser, risk score below threshold for two consecutive reviews, or formal closure by tier owner.
Cross-Programme Escalation	Routing path for issues that cross programme boundaries (e.g., Atlas dependency on Bristol Financial network team outside the programme): named liaison, escalation path into the wider portfolio or into BAU governance.
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to PMI PMBOK 7 Uncertainty Performance Domain (risk and issue escalation) and PRINCE2 7 Managing by Exception (tolerance thresholds and escalation to Project Board). ITIL 4 Incident Management informs the SLA and priority classification model for service-impacting issues. Method: define tiers and owners -> set numeric thresholds per issue category -> assign response SLAs -> document routing and backups -> agree decision rights at each tier -> publish log template -> review at each governance cycle.

Guiding principles: Thresholds are numeric and pre-agreed so escalation is triggered by facts not feelings; every escalation is logged and tracked to closure so patterns are visible; escalation is a professional tool not a political act; de-escalation criteria are as explicit as escalation triggers.

What good looks like:

- All thresholds are numeric (e.g., schedule slip > 10 days, budget variance > 8%) so the decision to escalate requires no subjective judgment.
- Each tier has a named backup so the escalation path does not stall when the primary is on leave.
- The escalation log is reviewed weekly and open items have explicit SLA countdown visible to all stakeholders.
- De-escalation criteria are written down, preventing issues from remaining 'open' in the log indefinitely after resolution.
- Decision rights per tier include dollar and scope authority thresholds, removing the most common source of tier ambiguity.

Common pitfalls:

- Thresholds are qualitative ('significant delay', 'material budget issue') leaving the escalation decision to TPM discretion and creating inconsistency.
- No named backups, so when the T2 owner is on annual leave, escalations queue unacknowledged past the SLA.
- Escalation log is not reviewed in any recurring forum, so open escalations persist for weeks without owner action.

- The framework conflates risk escalation (probability-weighted, forward-looking) with issue escalation (event has occurred), causing the wrong tier owner to receive the wrong type of item.
- De-escalation is never formalised, resulting in a log full of 'resolved' items that are never formally closed, degrading trust in the log's accuracy.

Maturity (1-5): L1 - Escalation is ad hoc and relationship-dependent; no tiers or thresholds defined; log absent. L2 - Tiers and owners defined but thresholds are qualitative; log exists but not reviewed consistently. L3 - Numeric thresholds per category; named backups; SLAs defined; log reviewed weekly; de-escalation criteria written. L4 - Escalation metrics tracked (volume by tier, SLA attainment rate, average resolution time); patterns feed risk register updates; threshold calibration driven by historical data. L5 - Thresholds continuously calibrated from programme outcome data; escalation analytics surfaced in SteerCo dashboard; framework benchmarked across programme portfolio; near-zero unacknowledged escalations.

Artifact #56 — Knowledge Management & Document Control

Purpose: Establishes the single source of truth for all project artifacts: defines the repository structure, document naming convention, version control rules, access and permissions model, retention schedule, and the processes by which knowledge assets (decisions, lessons learned, runbooks, and handover packages) are captured, maintained, and transferred at closeout.

When you use it: Established during the Plan phase before first artifacts are baselined; updated at each phase gate and when repository structure or tooling changes; formally reviewed at project closeout to ensure knowledge transfer completeness.

Owner: TPM owns the framework and naming convention; workstream leads own their section libraries; document controller (or designated TPM delegate) enforces version control and access rules.

Cadence: Naming convention and structure set once at Plan; version log reviewed each governance cycle; access and permissions audited quarterly; lessons-learned repository updated after each sprint review or phase gate; full retention audit at closeout.

Where it lives: Central project repository (e.g., SharePoint site 'Project Atlas - Central Repository'); workbook tab 'Doc Control'; linked from the Project Charter and referenced in the RACI.

Sections / contents:

Section	Contents / fields
Repository Structure	Folder hierarchy: /Governance, /Plans, /Status, /Risk-Issues, /Change, /Architecture, /Runbooks, /Lessons-Learned, /Handover; each workstream owns a named subfolder; root README maps folders to phases.
Naming Convention	Format: [ProjectCode]-[WorkstreamCode]-[DocType]-[Version]-[YYYYMMDD]; example: ATL-IAM-RISK-v1.2-20260115; codes defined in a lookup table pinned to the repository root.
Version Control	Major versions (v1.0, v2.0) for baselined or formally approved documents; minor versions (v1.1, v1.2) for drafts and amendments; version history table maintained in each document footer; superseded versions archived in /Archive subfolder, not deleted.
Access and Permissions	Role-based access: Project Core Team (read/write); Steering Committee (read); External Auditors (read, gated folder only); Vendor Partners (read, /Architecture subfolder only, NDA required); access changes require TPM approval and are logged in the Permissions

Section	Contents / fields
	Register.
Retention Schedule	Active documents retained for project duration plus 7 years in line with Bristol Financial records policy; security-classified documents (ZTNA architecture, PAM credential vault design) subject to InfoSec retention and destruction procedures; retention schedule linked to the project closure checklist.
Knowledge Capture Process	Decisions: logged in Decision Register within 24 hours of resolution, referencing the meeting or change request that produced them. Lessons Learned: captured in structured template (what happened, root cause, impact, recommendation, owner) after each sprint review, phase gate, and incident. Runbooks: authored by implementation workstream, reviewed by operations team, baselined before go-live.
Handover Package	Compiled no later than 2 weeks before project closeout; contents: as-built architecture diagrams, final runbooks, configuration baselines, vendor contracts summary, open issues log, lessons-learned digest, and transition-to-BAU checklist; signed off by TPM, Operations Lead, and CISO delegate.
Document Review and Approval Workflow	Draft -> Peer Review (workstream lead, 3 business days) -> Technical Review (Architect or SME, 3 business days) -> Approval (TPM or Sponsor depending on classification); approval recorded in document header and version log; SLA for full cycle: 10 business days.
Quality and Compliance Checks	TPM or delegate audits repository completeness monthly using the Document Control Checklist; critical documents (Risk Register, Architecture Baseline, Change Log) must not be more than 14 days stale; non-compliance flagged to workstream lead and tracked as an issue.
— PRACTITIONER REFERENCE —	

Standards & method: Aligned to ISO 30401:2018 (Knowledge Management Systems) which requires a knowledge management policy, defined processes for knowledge creation, capture, transfer, and retention, and explicit leadership accountability - implement by: define KM policy -> map knowledge assets -> assign custodians -> establish capture workflows -> audit and improve. Aligned to ITIL 4 Knowledge Management practice which prescribes a Service Knowledge Management System (SKMS) with controlled access, version history, and quality assurance of knowledge articles - implement by: identify knowledge assets -> create or update articles -> review and approve -> publish -> retire on schedule. Aligned to PMI PMBOK 7 (Stewardship and delivery performance domains) which recognises document and knowledge management as foundational to project governance and team performance.

Guiding principles: Single source of truth - one authoritative location for every artifact, no parallel copies in personal drives; version discipline - every change increments the version and is traceable to an approver; knowledge is a deliverable - lessons learned, decisions, and runbooks are formal outputs with owners and due dates, not optional activities; access follows role - permissions are set by function and reviewed, not granted ad hoc.

What good looks like:

- Naming convention is documented in a lookup table, applied consistently from day one, and audited monthly so any team member can find any document in under 60 seconds.

- Every key decision is logged in the Decision Register within 24 hours with rationale, alternatives considered, and the decision-maker named.
- Lessons learned are captured continuously after each sprint review and phase gate, not only at project closeout, producing an actionable digest rather than a retrospective list.
- The handover package is treated as a project deliverable with its own milestone, owner, and acceptance criteria, ensuring operations teams receive a complete, reviewed set of runbooks and configuration baselines.
- Access permissions are role-based, documented in a Permissions Register, and reviewed quarterly, preventing both information leakage and knowledge hoarding.

Common pitfalls:

- Naming convention defined but not enforced - files accumulate in personal folders or with ad hoc names, making search unreliable and audit impossible.
- Lessons learned deferred entirely to closeout - by then context is lost, contributors have moved on, and the output is superficial.
- Version control collapse - multiple 'final_v2_REAL_USE_THIS.docx' variants circulate, stakeholders reference different versions, and the approved baseline is unclear.
- Handover treated as an afterthought - runbooks and as-built diagrams are incomplete at go-live, forcing the operations team to reverse-engineer configuration from the system.
- Overly broad permissions granted for convenience - vendors or contractors retain access to sensitive ZTNA architecture documents beyond contract end, creating a security and compliance exposure.

Maturity (1-5): L1 Ad hoc - documents saved in personal drives or email threads, no naming convention, no version control, knowledge lost at staff turnover; L2 Defined - naming convention and folder structure documented and communicated, version control applied to key documents, basic lessons-learned template exists; L3 Managed - repository actively maintained and audited, decision register in use, lessons learned captured at gates, handover package produced at closeout; L4 Quantified - document retrieval time measured, completeness metrics tracked each governance cycle, lessons-learned recommendations demonstrably fed back into project planning; L5 Optimizing - KM system continuously improved based on metrics and retrospectives, knowledge reuse across the portfolio is tracked, runbook quality validated by operations before go-live.

Artifact #64 — Knowledge Transfer Plan

Purpose: Defines what knowledge must be transferred, from whom to whom, by what method, and by when - and specifies how verified competence of the receiving party is demonstrated and signed off before the project team stands down, a vendor exits, or BAU operations assume responsibility.

When you use it: Drafted during Execute (no later than 60 days before planned Close) so that KT activities can be scheduled, resourced, and executed with adequate overlap time. Formally activated at the start of Close. The KT plan is complete only when all sign-offs are obtained - not when sessions are merely delivered.

Owner: Project Manager owns the plan and drives completion. Workstream leads are accountable for their domain knowledge being transferred. Named Subject Matter Experts (SMEs) are designated as knowledge sources. Named BAU/operations leads (or incoming team members) are the knowledge receivers. PMO tracks status and escalates incomplete KT before resource release.

Cadence: Weekly KT progress reviewed in the Close phase project meeting. Each KT item has a scheduled completion date. Verification checkpoint (can the receiver operate unaided?)

completed before each SME or vendor is released. Final KT sign-off obtained at Project Closure meeting.

Where it lives: Workbook tab 'KT Plan'. Links to the runbook/documentation repository (Knowledge Management & Document Control register). Referenced in the Project Closure Report. KT completion certificate or sign-off email archived in the project document repository.

Sections / contents:

Section	Contents / fields
Knowledge Inventory	List of knowledge areas/topics to be transferred: system architecture, operational runbooks, vendor contacts and escalation paths, configuration standards, incident response procedures, licence management, audit evidence procedures
Knowledge Source (From)	Named individual(s) - employee or vendor - who currently hold the knowledge; workstream; departure/release date
Knowledge Receiver (To)	Named individual(s) or team who will hold the knowledge post-transition; role; confirmation of availability for KT schedule
Transfer Method	Method per knowledge item: structured handover session, shadowing (observe/assist/lead model), documented runbook or SOP, recorded walkthrough, pairing/embedded working, Q&A workshop, tabletop exercise
Schedule and Duration	Planned start and end date per knowledge item; hours or days required; dependencies (e.g., system access required before shadowing can begin)
Documentation Artifacts	Link to runbook, SOP, architecture diagram, config guide, or other artifact that codifies the knowledge; document owner; version; location in repository
Verification Method	How the receiver demonstrates competence: independent execution of task, passing a tabletop scenario, sign-off checklist, supervised live incident response, or formal assessment
Sign-off Status	Per knowledge item: Not Started / In Progress / Delivered / Verified / Signed Off. Receiver sign-off and date. Source sign-off confirming receiver is competent to operate unaided
Gaps and Risks	Knowledge items with no identified receiver, undocumented tribal knowledge, short vendor exit windows, or receiver unavailability - with mitigation actions and owner
KT Completion Certificate	Overall sign-off: PMO, Project Manager, BAU/Operations Lead, and (for vendor exits) vendor Account Manager confirming all items are signed off and no known knowledge gaps remain
—— PRACTITIONER REFERENCE ——	

Standards & method: Aligned to ISO 30401:2018 (Knowledge Management Systems) principles: knowledge as an organizational asset, explicit and tacit knowledge distinction, verification of knowledge transfer effectiveness (not just delivery). Aligned to ITIL 4 Service Transition and Knowledge Management practices: transfer to service operation, knowledge base population, use of the Service Knowledge Management System (SKMS). PMI PMBOK 7 Resource and Stakeholder Performance Domains inform receiver identification and engagement. Method: inventory knowledge -> assign source and receiver -> select transfer

method per knowledge type (tacit vs explicit) -> schedule with overlap -> document artifacts -> verify competence -> obtain sign-off -> record in KM register.

Guiding principles: Delivery is not transfer - a session or document delivered does not constitute transfer; the receiver must demonstrate they can operate unaided; tacit and explicit knowledge require different methods - documented runbooks cover explicit knowledge, but shadowing and pairing are required for tacit operational know-how; no resource is released until their KT items are signed off - project close dates should not override KT completion; gaps are identified and mitigated early - a knowledge gap found on the last day of a vendor engagement is a project risk, not a close-phase task.

What good looks like:

- Every knowledge item has a named source, a named receiver, a scheduled date, a verification method, and a sign-off status - the plan is a live tracker, not a one-time document
- Tacit knowledge (e.g., PAM vault operational patterns, ZTNA policy troubleshooting heuristics) is transferred via shadowing or pairing with an observe/assist/lead model - not just a runbook
- Verification is independent execution or tabletop scenario, not a receiver's self-declaration - a third party (workstream lead or PMO) witnesses or reviews the verification evidence
- Vendor knowledge transfer is scheduled with sufficient overlap before the vendor's contractual end date - not crammed into the final week of the engagement
- A KT gap register captures tribal knowledge, undocumented configurations, and receiver availability risks - each with a named mitigation owner and resolution date

Common pitfalls:

- KT plan created as a formality and never updated - status columns left as 'In Progress' indefinitely; enforce weekly review with escalation to PM if items slip
- Runbook delivery treated as KT completion - documentation is a prerequisite, not a substitute for verified competence; always include a verification step
- Receiver not identified or unavailable for KT sessions - KT cannot happen without a named, available receiver; this must be resolved as a risk before Close begins
- Vendor exit window too short to complete KT - contractual end date arrives before all items are signed off; negotiate KT schedule in the SOW or raise a CO to extend the vendor engagement
- Knowledge transfer scope too narrow - only operational runbooks covered, but architectural decision rationale, known defects, and future-roadmap context are not transferred; use the knowledge inventory to ensure breadth

Maturity (1-5): L1 Ad hoc: KT happens informally if at all, no plan, knowledge lost when team members leave; L2 Defined: KT plan template exists, produced at Close but often incomplete, verification not systematic; L3 Managed: KT plan covers all knowledge items with named sources and receivers, verification step present, status tracked weekly, vendor exit KT included in SOW; L4 Quantified: KT completion rate tracked (% items signed off on schedule), knowledge gap incidents post-transition measured, KT lead time optimized based on complexity scoring; L5 Optimizing: knowledge inventory built incrementally throughout the project (not only at Close), tacit knowledge captured in recorded walkthroughs during Execute, KT effectiveness measured via post-transition incident rate attributable to knowledge gaps.

Artifact #65 — Automating Work with AI

Purpose: Equip project teams to identify which recurring PM tasks are worth automating with AI, select the right tool-neutral pattern, and apply guardrails that scale with the level of

autonomy granted - so automation accelerates delivery without introducing uncontrolled risk or replacing judgment where judgment is required.

When you use it: During project planning when recurring task patterns emerge; at sprint or phase transitions when workload spikes; whenever a team member spends more than 30 min/week on a structured, repeatable task; and as part of the continuous improvement review after each delivery milestone.

Owner: Project Manager (accountable); team members who own the recurring task (responsible); AI/Data Governance lead or equivalent (consulted on guardrails); PMO lead (informed).

Cadence: Initial assessment at project kickoff or planning. Re-evaluated at each phase gate. Spot-checked monthly during execution. Retired or upgraded when the underlying process changes materially.

Where it lives: Project management platform (task/backlog), team collaboration space, and the project's AI automation register (a living log of active automations, their owners, guardrails, and review dates). All artefacts that feed or are produced by automations must be stored in the project's designated, access-controlled document repository.

Sections / contents:

Section	Contents / fields
Automation Maturity Ladder	L1 Ad-hoc prompting: team members craft one-off prompts manually, no consistency or reuse. L2 Prompt/template library: reusable prompt templates saved and shared; output quality improves but context is re-entered each time. L3 Assistant loaded with project context: the AI assistant is pre-loaded with project charter, RAID log, standards, and glossary so responses are project-aware without manual re-entry. L4 Retrieval over your own artefacts: the assistant can query and synthesise across the project's own documents (meeting notes, status reports, decision logs) to draft outputs grounded in real project data. L5 Triggered and scheduled runs with human review: recurring tasks (e.g., weekly status draft, RAID hygiene check) are triggered automatically on a schedule or event, producing a draft that a human reviews and approves before it is used or sent. L6 Supervised agentic workflows: multi-step autonomous sequences (e.g., ingest stakeholder emails -> extract actions -> update RAID log -> draft owner notifications) run end-to-end with defined human checkpoints and escalation paths. Note: most project teams operate at L2-L4; L5-L6 require explicit governance approval and are subject to the Responsible AI Usage Guardrails artefact.
Should You Automate This? - Decision Test	Automate when: the task recurs at least weekly OR consumes more than 1 hour per occurrence; inputs and outputs are structured or semi-structured (forms, templates, standard fields); the acceptable output can be defined clearly enough to verify it; errors are detectable and recoverable before downstream harm occurs; the data classification of inputs is compatible with the AI tool's approved data handling tier. Keep human when: the task requires negotiation, political judgment, or relationship management; the output commits the organisation to a course of action without further review; the input data is classified above the tool's approved tier; errors would be difficult to detect or could cause irreversible harm; the task is the exception-handling path for a process (automate the routine, not the exception).

Section	Contents / fields
Tool-Neutral Automation Patterns	Pattern 1 - Assistant-with-context: load a reusable system prompt containing project metadata (name, phase, stakeholders, acronyms, risk appetite) so every interaction is project-aware. Pattern 2 - Retrieval over your own artefacts: index the project's own documents so the assistant drafts outputs grounded in actual project data rather than generic content; requires controlled access to the index. Pattern 3 - Trigger -> Draft -> Review -> Act: an event or schedule triggers the AI to produce a draft (e.g., status report, meeting agenda); a named human reviews and approves; the approved output is then published or acted on. This pattern is the minimum viable guardrail for any scheduled automation. Pattern 4 - Supervised agentic workflow: a sequence of AI steps executes autonomously across tools (read, reason, write, notify) with human checkpoints at defined decision gates; each step is logged; the workflow can be paused or rolled back. Choosing a pattern: start with the simplest pattern that meets the need; escalate to a higher pattern only when the simpler one demonstrably cannot deliver the required quality or efficiency.
Guardrails That Scale with Autonomy	Core principle: the less hands-on the human, the more verification, logging, and containment the automation must have. L1-L2: no guardrails beyond prompt hygiene and not pasting restricted data. L3: define which data classifications may be included in the system context; document the context in the project register. L4: access controls on the document index; audit log of queries and outputs; human spot-check of retrieval quality monthly. L5: named human reviewer and explicit sign-off step before any output is used or distributed; outputs logged with timestamp and reviewer identity; rollback procedure defined. L6 (agentic): full audit trail of every agent action; defined escalation path when confidence is below threshold; data classification enforced at ingestion; scheduled human review of the workflow's behaviour; change-control process for modifying the workflow. All levels: reference the project's Responsible AI Usage Guardrails artefact for data classification rules, prohibited use cases, and incident reporting. Never use an AI tool at a tier that exceeds its approved data classification ceiling.
Automation Candidate Register	A living log maintained by the PM listing: task name; current time cost (hours/week); candidate pattern; data classification of inputs; guardrails in place; human checkpoint owner; go-live date; measured time saving (actual vs. estimate); review date. This register is reviewed at each phase gate and updated when tasks or tooling change. It is the primary evidence artefact for AI governance audits.
Human Checkpoints and Accountability	Every active automation must have a named human owner who is accountable for the quality of outputs. Checkpoints must be explicit (not implied): define who reviews, what they are checking, and what action they take if quality fails. Checkpoint frequency scales with risk: daily for client-facing outputs, weekly for internal operational outputs, monthly for low-risk informational outputs. Automation does not transfer accountability - the human owner remains responsible for any output that is published, acted on, or communicated.
Metrics and Continuous Improvement	Track: time saved per week (actual vs. estimate); error or rework rate on AI-assisted outputs vs. manual baseline; human checkpoint rejection rate (high rejection = pattern or prompt needs tuning); data classification incidents (target zero). Review metrics monthly. If the

Section	Contents / fields
	rejection rate exceeds 20% over two consecutive weeks, pause the automation and re-assess the pattern or the task's suitability. Celebrate time savings but also track quality - speed without accuracy is not a gain.
Integration with Existing PMO Artefacts	Automations that produce or consume RAID log entries, status reports, meeting minutes, decision logs, or stakeholder communications must comply with the data standards and templates defined in those artefacts. The automation does not override the artefact standard - it must conform to it. Where an automation produces a draft, the draft must be reviewed against the artefact's quality criteria before it replaces a human-authored version.
—— PRACTITIONER REFERENCE ——	

Standards & method: NIST AI RMF (GOVERN, MAP, MEASURE, MANAGE functions) - used to classify automation risk, assign accountability, and define measurement cadence. ISO/IEC 42001 (AI Management System) - informs the automation register, change control, and continuous improvement loop. Lean automation principles (automate the stable, repeatable core; leave judgment and exceptions to humans; measure actual vs. expected value) - applied in the should-you-automate test and the metrics section. The method is explicitly tool-neutral: no step references a specific vendor, platform, or model. Organisations substitute their approved tooling into each pattern. The Responsible AI Usage Guardrails artefact (key 18 or equivalent) is the companion reference for data classification, prohibited uses, and incident reporting.

Guiding principles: Automate the routine; protect the judgment - high-frequency structured work is the target, negotiation and accountability stay human; Guardrails scale with autonomy - the less hands-on the human, the more verification, logging, and containment the automation must carry; Start simple and earn complexity - begin at the lowest maturity level that delivers the benefit, escalate only when that level demonstrably cannot; Ownership does not transfer to the machine - a named human is accountable for every automated output that is used or communicated.

What good looks like:

- The automation candidate register is maintained and reviewed at every phase gate, with actual time savings measured against estimates.
- Every active automation has a named human owner, a defined review checkpoint, and a documented rollback or pause procedure.
- Data classification of all inputs is verified before an automation goes live, and no automation operates above the tool's approved data handling tier.
- The team operates at L3 or above for routine recurring tasks, with at least one L4 or L5 automation delivering measurable capacity relief by the midpoint of each phase.
- The rejection rate at human checkpoints is tracked; automations with persistent high rejection rates are paused and re-assessed rather than left running at low quality.

Common pitfalls:

- Automating judgment-heavy or exception-handling tasks and then treating the AI output as final without meaningful human review, creating a false sense of efficiency while quality degrades.
- Skipping data classification checks and inadvertently feeding restricted or confidential data into an AI tool that is not approved for that tier.

- Building automations with no named owner and no checkpoint, so when output quality drifts nobody notices until downstream harm has occurred.
- Leaping to agentic or scheduled automations (L5-L6) without first validating output quality at L2-L3, resulting in high-volume low-quality output that is harder to correct.
- Measuring success only by time saved and ignoring rework rate, error rate, or stakeholder complaints - automation that saves 2 hours but creates 1 hour of rework and damages trust is not a net gain.

Maturity (1-5): L1 Ad-hoc prompting - team crafts one-off prompts manually with no reuse or consistency; L2 Prompt and template library - reusable prompt templates saved and shared across the team, context re-entered each session; L3 Assistant loaded with project context - system prompt pre-loaded with project metadata so every session is project-aware without manual re-entry; L4 Retrieval over project artefacts - assistant queries and synthesises across the project's own indexed documents to produce grounded, data-backed drafts with human review; L5 Triggered and scheduled runs with supervised agentic workflows - recurring tasks run on schedule or event trigger through multi-step autonomous sequences, with explicit human checkpoints, audit logging, escalation paths, and governance approval.

Artifact #66 — Audience & Persona Messaging Matrix

Purpose: A Communications Plan answers who hears what, when, and through which channel. The Audience and Persona Messaging Matrix answers the question the Comms Plan leaves open: how the same change is framed differently for each audience so that each one hears why it matters to them, in their own language, with a clear ask they can act on. It sits between the Stakeholder Register (who matters) and the Communications Plan (the schedule of messages). It is where the message content actually gets differentiated by persona.

When to use it

For any change with more than one distinct audience whose interests, vocabulary, or required actions differ. Most enterprise and security programs qualify. Skip it only for a change with a single homogeneous audience.

Who owns it

The TPM or OCM lead drafts it. The sponsor and comms lead review it. Each persona's row is validated with someone who represents or knows that audience: a manager, a respected peer, a department lead. The program office consistently mis-guesses two things, the real objection and the trusted messenger, and the people inside each audience correct it.

Why audience-as-a-field is not enough

The Communications Plan captures audience as one column. The Stakeholder Register captures influence and preferred channel. Both capture who. Neither captures the differentiated content: the same initiative reframed in each group's terms, the specific behavior asked of them, the objection they are most likely to raise, and the messenger they will believe. Two failure modes follow from skipping this. First, one message written for the average reader lands with no one. Second, the message is tuned for the loudest or highest-influence audience, and the quieter audiences quietly disengage. The quieter audiences are often the ones whose adoption the program actually depends on.

What is in it (the columns), per persona

Persona: the audience segment, named specifically. Not "stakeholders" but "security engineers", "business unit leads", "frontline staff".

WIIFM (what is in it for me): the benefit or relief stated in the persona's own terms, not the program's terms.

The change in their language: the same initiative described using the words and reference points that persona uses day to day.

The ask: the concrete action or behavior change required of this persona. If there is no action, say so. Awareness-only is a valid ask, but name it.

Likely objection or resistance: the concern this persona will raise, stated honestly, including the unspoken version that does the real damage.

Proof points they trust: the evidence that moves this persona. A metric, a peer's experience, a regulator's requirement, a leader's commitment. Different personas trust different proof.

Tone and register: formal or plain, detailed or headline, reassuring or urgent.

Channel and messenger: not just the channel (email, town hall, team meeting, dashboard) but who delivers it.

The messenger principle

People weigh a message partly by who carries it. A security engineer weighs a CISO's framing of control coverage. A business unit lead weighs a peer leader's framing of revenue risk. Frontline staff weigh their own manager over a program office they have never met. Map the right messenger to each persona deliberately, and recruit those messengers early, because borrowing someone's credibility takes a relationship you build before you need it. The messenger often matters more than the wording.

How it travels across contexts

The columns stay fixed. The personas change with the setting. In a corporate security program the rows are typically security engineers, business unit leads, compliance and risk, executives, and end users. In a university the rows shift to faculty, deans and department chairs, IT staff, students, and administration, each with a different WIIFM and a different trusted messenger (a faculty member trusts a department chair or a respected colleague over a central IT announcement). The two worked examples show the same framework populated for each.

Common failure modes

One message for everyone, tuned to no one.

Messaging tuned only to the highest-influence persona, losing the quieter audiences whose adoption you actually need.

A strong WIIFM with no concrete ask, so the audience nods and changes nothing.

The right message from the wrong messenger.

Treating an objection as something to suppress rather than answer. The unspoken objection does the most damage when it is never named.

Related artifacts

- Stakeholder Register (Artifact #3, Example #188): the audience list and influence map this builds on
- Communications Plan (Artifact #8, Example #134): the cadence this content feeds. Build the matrix first, then the schedule
- Organizational Change Management Plan (Artifact #9): persona resistance and asks feed the change-impact and adoption sections
- Training and Awareness Plan (Artifact #10, Example #192): per-persona asks define what each audience needs to learn
- AI Prompts #277, #278, #279: drafting the communications, OCM, and training plans

Keywords: persona message matrix, audience messaging, WIIFM, what's in it for me, message differentiation, stakeholder messaging, persona-based communication, messenger, who delivers the message, change communication, OCM messaging, audience segmentation,

tailored messaging, communications by persona, university change communication, faculty messaging, resistance, objection handling, proof points, tone and register, IT versus business messaging

Appendix A — AI Capability Mapping

The original feature catalog described AI capabilities for an enabled PMO. This appendix maps each capability to the artifact it actually supports. AI-only configuration templates are noted as 'AI Config Reference' — they belong in the AI engineering team's documentation, not the TPM template library.

1	Predictive task assignment & risk alerts	RAID Log (#11), Resource Plan (#13), Schedule (#12)
2	Timezone-aware smart scheduling	Resource Plan (#13); AI Config Reference for fairness rules
3	NLP meeting summaries & update digests	Status Report (#18), Decisions & Changes Log (#19), RAID Log (#11)
4	Automated charter, test, DR, procurement plan builders	Charter (#1); other plans are project-type- specific
5	PMO skill-builder & onboarding	Operating Model (#29); separate Skills Framework deliverable
6	Executive dashboards w/ explainable AI	Portfolio Dashboard (#28), Steering Pack (#20)
AI Capabil	ity (from source catalog) Plugs i	nto PMO artifact
7 Seamless	tool integrations AI Con	fig Reference — engineering setup
8 Action it	em extraction from emails / chats Decisi Log (#	ons & Changes Log (#19), RAID 11)
9 Plain Eng	lish to structured updates Status for ma	Report (#18); AI Config Reference pping rules
10 Status re	ports & briefs from unstructured Status	Report (#18), Steering Pack (#20)

inputs

11	Comms & OCM plans from inputs	Communications Plan (#8), OCM Plan (#9)
12	Suggestions on what's missing in plans/docs/compliance	Charter (#1), all artifacts as quality check
13	Audit project inputs & reach out to TPMs / DRIs	RAID Log (#11), Status Report (#18)
14	Stakeholder inclusion / exclusion suggestions	Stakeholder Register (#3)
15	Initiative consolidation & prioritization	Project Intake Form (#27), Portfolio Dashboard (#28)

11	Comms & OCM plans from inputs	Communications Plan (#8), OCM Plan (#9)
16	Highlight pulls	Status Report (#18), Steering Pack (#20)
17	Risk anticipation	RAID Log (#11)
18	Procurement next-step tracking & comms	Schedule (#12); Vendor tracker (separate)
19	Forecasting from previous inputs	Schedule (#12), Budget (#14)
20	Cost savings identification (vendor consolidation)	Budget (#14), Portfolio Dashboard (#28)
21	Cross-check project plans for dependencies	RAID Log (#11), Schedule (#12)
22	Resource availability tracking & forecasting	Resource Plan (#13), Portfolio Dashboard (#28)
23	Project document library	Workbook (#5) is the project library; org- level doc system separate
24	Team strategy updates from company strategy	Operating Model (#29)
25	Initiative reprioritization from strategy / risk	Portfolio Dashboard (#28), Intake Form (#27)
26	DRI accomplishment tracking AI Capability (from source catalog) Plu	Outside scope — HR / performance system gs into PMO artifact
27	Compensation recommendations Ou	tside scope — HR system
28	Drafting employee evaluations Ou	tside scope — HR system
29	Policies, standards, guidelines Op Li	erating Model (#29); separate Policy brary
30	Project budget creation & tracking Bu	dget (#14)
31	Easy tool integration setup AI	Config Reference
32	Cross-project querying for redundancy Po	rtfolio Dashboard (#28)
33	Comprehensive comms plan Co	mmunications Plan (#8)
34	Independent at-risk recommendations St (#	atus Report (#18), Portfolio Dashboard 28)
35	Project vs security / industry risk R	

Appendix B — Companion Workbook

Quick reference for navigating PMO_Project_Workbook.xlsx.

Section	Contents / fields
Cover	Project identification + tab map; the home page. Fill this in first.
Charter	Artifact #1 — full charter structure with sections and approvals.
Stakeholders	Artifact #3 — register with influence/interest/RACI/engagement classification.
RACI	Artifact #4 — decision-level RACI matrix with auto- validation (one A per row).
Requirements	Artifact #6 + #7 — traceability matrix from BR/FR/NFR through design to test.
RAID Log	Artifact #11 — integrated Risks/Assumptions/Issues/Dependencies log with auto- scoring.
Schedule	Artifact #12 — milestone tracker with status conditional formatting.
Resources	Artifact #13 — team roster with allocation summaries.
Budget	Artifact #14 — planned vs actual with formulas for variance, % used, EAC.
Decisions & Changes	Artifact #19 — combined append-only log of decisions and approved changes (Type column to filter).
Status Reports	Artifact #18 — running history of weekly status with RAG conditional formatting.
UAT Log	Artifact #21 — test cases with auto-calculated pass rate.
Post-Incident Actions	Artifact #32 — cross-incident corrective action tracker with 30/60/90 verification.
Lessons Learned	Artifact #22 — captured throughout, formalized at close.
Closeout	Artifact #23 — final outcomes, benefits realization, handoff, sign-offs.

All formulas are pre-built and tested. Dropdowns, conditional formatting, and auto-validations are pre-configured. Works in Excel, Google Sheets, Numbers, and LibreOffice without modification.

Appendix C — Templates Pack Reference

Quick reference for navigating PMO_Templates_Pack.docx — the fillable standalone documents.

Section	Contents / fields
1 — Kickoff Pack	P re-read + agenda + 13-slide deck outline (artifact #2)
2 — Program Charter M	ulti-initiative program charter (artifact #24)
3 — RACI Template S	tandalone RACI with role definitions and sample matrix (artifact #4)
4 — BRD	B usiness Requirements Document (artifact #6)

Section		Contents / fields
5 — Tech Spec	T	Technical Requirements / Functional Specification (artifact #7)
6 — Communications Plan		Standalone Comms Plan (artifact #8)
7 — OCM Plan	O	Organizational Change Management Plan (artifact #9)
8 — Training & Awareness		Operationalizes OCM training strategy (artifact #10)

Plan

9 — RFP	Request for Proposal (artifact #15)
10 — RFP Scoring	Scoring rubric + reference check template (artifact #16)
11 — SOW	Statement of Work (artifact #17)
12 — UAT Plan & Test Cases	User Acceptance Testing plan (artifact #21)
13 — Operating Model	Function/program operating model (artifact #29)

Each template is a complete, fillable document. Copy the section you need into a new doc, replace italic placeholder text with real content, and you have a working artifact.

Appendix E — Adapting to Other Tooling

The methodology in this framework is tool-agnostic; the included workbooks and docs are an Excel + Word implementation. This appendix outlines how to adapt to other common stacks. Notion / Coda

Sm	arts • • • • •	heet Workbook tabs become Smartsheet sheets — natural mapping. RAID, Schedule, Resources translate directly with native conditional formatting and dropdowns. Cross-sheet references replace cross-tab references; Smartsheet's reporting layer can roll up across sheets. Templates Pack docs go into Smartsheet Documents or a Confluence/SharePoint companion. Trade-offs: best 1:1 fit for tracking artifacts; weaker for narrative/methodology docs.
As	ana • • • • •	/ Jira / Monday These are work management tools, not document tools — best for Schedule, Resources, Action Items, RAID. Each artifact tab becomes a project, board, or list with custom fields matching the workbook columns. Status

Sm	arts • • • • •	heet Workbook tabs become Smartsheet sheets — natural mapping. RAID, Schedule, Resources translate directly with native conditional formatting and dropdowns. Cross-sheet references replace cross-tab references; Smartsheet's reporting layer can roll up across sheets. Templates Pack docs go into Smartsheet Documents or a Confluence/SharePoint companion. Trade-offs: best 1:1 fit for tracking artifacts; weaker for narrative/methodology docs.
		Reports become recurring Asana update posts or Jira dashboards. Charters, BRDs, Comms Plans, OCM Plans need a companion doc tool (Confluence, Notion, Google Docs, SharePoint). Trade-offs: strongest for execution tracking; weakest for governance and narrative artifacts. Plan for a hybrid stack.
Co	nflu • • • • •	ence + Jira Most common enterprise stack. Confluence holds narrative artifacts (Charter, BRD, Tech Spec, Comms Plan, OCM Plan, Operating Model). Jira holds tracking artifacts (RAID, Schedule, Action Items). Confluence templates map directly to Templates Pack s — create one Confluence template per and link them in a PMO space index. Jira → use issue types Risk, Issue, Decision, Change, Action with custom fields. Status reports are typically Confluence pages with embedded Jira queries (live-rendering current state). Trade-offs: well-supported and audit-friendly; requires more upfront configuration than Excel + Word.
Go	ogle • • • • •	Workspace (Docs + Sheets) The closest like-for-like swap. Workbook tabs become Sheets tabs. Word docs become

Sm	arts • • • • •	heet Workbook tabs become Smartsheet sheets — natural mapping. RAID, Schedule, Resources translate directly with native conditional formatting and dropdowns. Cross-sheet references replace cross-tab references; Smartsheet's reporting layer can roll up across sheets. Templates Pack docs go into Smartsheet Documents or a Confluence/SharePoint companion. Trade-offs: best 1:1 fit for tracking artifacts; weaker for narrative/methodology docs.
		Google Docs. Most formulas and dropdowns transfer cleanly. Some EXACT()-based conditional formatting may need re-creation. Cross-doc references are weaker than Excel — use named ranges or IMPORTRANGE. Trade-offs: best collaborative editing; some Office features lost in translation.
Ge	nera • • • • •	I principles when porting Methodology travels — artifact definitions, sections, and lifecycle don't change with tooling. Re-read the framework artifact descriptions, not the templates, when porting. The 'append-only' discipline (Status Reports, Decisions & Changes, Action Items) is enforced by tool features in some stacks (Notion versioning, Jira issue history) — preserve the audit trail in whichever way the tool supports. RACI integrity (one A per activity) needs explicit validation in tools without formulas — add a manual review step or build a custom check. Cross-references between artifacts are usually weaker outside Excel — invest in linking conventions (Confluence labels, Notion mentions, Jira links) at the start, not later.

Framework Overview — What this is

What this is

The methodology document. Describes each PMO artifact, when to use it, who owns it, and how AI makes it dynamic. Use the workbook for live working artifacts; use the templates pack for fillable standalone documents.

Shared & Cross-cutting · Engineering (21)

Engineering Artifact #E1 — Rollout (ROLL) Plan

Rollout (ROLL) Plan

Purpose

The operational plan for how a new feature, service, or system actually reaches users. The ROLL plan answers: in what order, to which users, with what guardrails, and with what abort criteria. It bridges engineering completion and operational reality — code being merged is not the same as users having access, and this plan is what makes the difference safe.

When to use it

Required for any change that materially affects user experience, system behavior, or operational risk: new features going to production, major version upgrades, infrastructure changes that affect routing or authentication, configuration changes that change defaults. Strongly recommended for anything with rollback complexity (e.g., schema migrations, identity changes, billing changes).

Skip for: trivially-reversible changes already covered by a feature flag with binary on/off, internal-only changes that don't affect users.

Who owns it

Component PM or engineering lead drafts. TPM coordinates across components when the rollout has dependencies. Sponsor approves the rollout strategy at the milestone level. SRE/operations lead approves the abort criteria and rollback procedure. Security signs off when the change has security implications (which most identity/auth changes do).

What's in it

Rollout plans vary in detail by risk, but a complete one covers eight sections:

1. Scope and target state. What's being rolled out, what the post-rollout state looks like, what's NOT in scope.
2. Rollout strategy. Phased percentage (e.g., 1% → 10% → 50% → 100%), canary cohort selection criteria, geographic phasing, ring-based deployment (internal users → friendly customers → broad availability), or wave-based for change programs (employee waves by department/risk profile).
3. Pre-rollout gates. What must be true before rollout starts. Test pass criteria, observability ready, runbooks published, support trained, rollback validated, comms sent. Each gate has a named owner who confirms.
4. Per-phase plan. For each phase: cohort definition, success criteria with specific metrics, observation period, decision point (proceed / hold / abort), and named owner.
5. Success metrics. Quantitative thresholds the rollout is measured against. Conversion rates, error rates, latency, support ticket volume, user satisfaction. Each metric has a baseline (pre-rollout state) and a tolerance (acceptable variance).

6. Abort criteria. The thresholds that trigger rollback or hold. Hard aborts (immediate rollback, no human decision needed): error rate spike beyond threshold, security incident, data corruption. Soft aborts (rollback after human review): user complaints above threshold, support ticket volume spike, sponsor escalation. Specify the actual numbers, not "if things look bad."
7. Rollback procedure. The mechanical steps to revert. Who triggers it, what changes, how long it takes, what data is preserved or lost, how users are notified, when post-rollback the team can re-attempt. Rollback procedure should be validated before rollout starts (rehearsed in a non-prod environment).
8. Post-rollout closure. What "done" looks like. Final metrics confirmed, observability transitioned to steady-state monitoring, runbooks updated, lessons captured.

What TPMs check for in review

- Are the abort criteria actually measurable, or are they aspirational? ("If things look bad" is not an abort criterion.)
- Is the rollback procedure validated, or only documented? Validated means rehearsed.
- Who has decision authority at each gate, and is that person available during the rollout window?
- What's the relationship between this rollout's gates and the program's broader steering / change-control process? Does the steering committee need to approve the rollout strategy before it starts?
- For multi-component rollouts: how do component teams coordinate gate decisions? Is there a war room, a daily standup, or just a Slack channel?
- For changes with regulatory implications: has compliance signed off on the rollout strategy, especially abort criteria?

Common gaps in real ROLL plans

- Abort criteria are described in vague terms ("if user complaints spike") rather than specific thresholds ("if support tickets exceed 200/hour or user-reported error rate exceeds 0.5%")
- Rollback procedure is documented but not rehearsed, so the first time it's actually executed is during an incident
- Per-phase observation periods are too short to surface real problems (1 hour at 1% traffic doesn't catch issues that only show up under load)
- Success metrics conflate "no errors" with "rollout succeeded" — but a rollout can have zero errors and still be wrong (users not adopting, workflow broken, business impact)
- Gate ownership is unclear — multiple people thought someone else was watching, no one was

Related artifacts

- Test Plan (Engineering Artifact #E7): defines what test pass criteria the pre-rollout gates check
- Comms Plan (Artifact #8): coordinates user-facing messaging during the rollout
- Decision & Changes Log (Artifact #19): captures gate decisions and abort/proceed calls
- Status Report (Artifact #18): reports rollout state to sponsor and steering during execution

Keywords: ROLL plan, rollout plan, rollout strategy, phased rollout, canary deployment, ring deployment, wave-based rollout, abort criteria, rollback procedure, deployment plan, release plan, go-to-production plan, GA plan, general availability, percentage rollout, gradual rollout, rollout gates, pre-rollout gates, rollout success criteria, rollout metrics, rollout owner

PRACTITIONER REFERENCE

Standards & method: Aligned to ITIL 4 Release Management and Change Enablement practices, and SAFe 6.0 Release on Demand capability. Method: define release scope and ring-

based deployment strategy -> build rollout sequence (canary/blue-green/feature flag) -> define success metrics and automated gates -> execute phased rollout -> monitor and auto-rollback or promote.

Guiding principles: Release risk is proportional to blast radius; progressive rollout stages have binary promotion gates, not judgment calls; observability is deployed before the feature, not after; rollback is automated where possible.

What good looks like:

- Rollout rings are defined (internal -> beta -> 5% -> 25% -> 100%) with explicit dwell time and promotion criteria at each stage.
- Success metrics (error rate, p99 latency, business KPIs) are instrumented and dashboarded before rollout begins.
- Feature flags are used to decouple deployment from release, enabling instant kill-switch without redeployment.
- Rollback procedure is automated and tested in a pre-production environment within the sprint before release.
- On-call runbook is updated and communicated to the NOC/SRE team before any ring promotion.

Common pitfalls:

- Big-bang deployment to 100% of users with no canary or progressive validation, maximizing blast radius.
- Success metrics defined after rollout, making promotion decisions purely subjective.
- Feature flags left permanently enabled after full rollout, accumulating tech debt and runtime branching complexity.
- Rollback never tested, discovered to be non-trivial (e.g., schema migration) only during an incident.
- Communication plan missing, causing support teams to be caught off guard by behavior changes.

Maturity (1-5): L1 Ad hoc - all-at-once deployments, manual rollback; L2 Defined - rollout plan documented, environments staged; L3 Managed - canary/ring strategy, automated gates; L4 Quantified - deployment frequency and change failure rate tracked against DORA targets; L5 Optimizing - fully automated progressive delivery, real-time blast radius control.

Engineering Artifact #E2 — Incident Response (IR) Plan

Incident Response (IR) Plan

Purpose

The runbook for handling production incidents — what counts as an incident, who responds, how they coordinate, when sponsors and customers are told, and what happens after. The IR plan exists so that during an actual incident, no one is improvising the process. People are improvising the diagnosis and the fix; the response process is pre-decided.

When to use it

Required for any service or system with:

- Customer-facing impact when it fails
- Regulatory or audit implications
- Cross-team operational dependencies
- Security implications (which most identity, access, and infrastructure systems have)

Skip for: services so internal and low-stakes that "fix it during business hours" is the actual response posture. But be honest about whether that's true — most teams discover during their first real incident that they needed an IR plan.

Who owns it

The on-call engineering lead drafts. SRE / operations function reviews and approves. Security signs off when there are security implications. The IR plan is owned by whoever owns the production service in steady state — for capabilities built by a program (like Atlas's ZTNA), the IR plan transitions from program ownership to operational function ownership at handoff.

What's in it

A complete IR plan covers nine sections:

1. Scope. What service or system this plan covers, and which other services it depends on or is depended-by. The plan should make clear what's in scope (e.g., "ZTNA service") vs. out of scope (e.g., "the underlying cloud network — see Cloud Networking IR plan").
2. Severity classification. Specific criteria for SEV-0 (critical, customer-impacting), SEV-1 (major), SEV-2 (significant), SEV-3 (minor). Each severity has thresholds (error rate, customer impact, regulatory implication) AND example scenarios so on-call engineers don't argue about classification at 3 AM.
3. On-call structure. Primary, secondary, escalation tiers. Rotation schedule. How on-call is paged (PagerDuty, Opsgenie, etc.). SLA for primary acknowledgment. What happens if primary is unreachable.
4. Roles during an incident. Incident Commander (IC) — runs the response, makes decisions. Communications Lead — handles internal and external comms. Subject Matter Experts (SMEs) — engineers who actually fix things. Scribe — captures the timeline. For SEV-0/SEV-1, these roles must be filled by different people. For SEV-2/SEV-3, one engineer can hold multiple roles.
5. Communication protocols. Internal: which Slack channel, which paging tool, which leadership notifications and at what severity. External: when customers are notified (and through what channel — status page, email, in-app), when regulators are notified (and how, by whom). Specify timing: "Customer notification within 30 min of SEV-0 declaration" not "customers will be notified."
6. Escalation paths. When to call in additional help. SEV-0 within X minutes triggers VP-level notification. SEV-1 unresolved at Y hours triggers SVP. Security incidents trigger CISO regardless of severity. Regulatory implications trigger CRO + General Counsel. Specific names and phone numbers, not just titles.
7. Response runbooks. The detailed playbooks for specific incident types. Authentication outage runbook. Data-loss incident runbook. Suspected breach runbook. Each runbook is a separate document; the IR plan references them. The IR plan itself is the meta-document; runbooks are the detailed procedures.
8. Post-incident review (PIR) trigger. Which incidents trigger a formal PIR (typically all SEV-0 and SEV-1, plus any SEV-2 with regulatory implications). Who attends, who facilitates, what timeline (usually within 5 business days). How findings are tracked to closure.
9. Plan maintenance. Review cadence (typically quarterly), change-trigger conditions (after every SEV-0/SEV-1 incident, after major service changes), named owner, version history.

What TPMs check for in review

- Are severity criteria specific and measurable, or are they wishful? ("If a lot of customers are affected" is not a criterion — give a number.)
- Is the on-call rotation actually staffed for the next 12 months, or is it documented in theory but in practice the same two people get all the pages?
- Are escalation phone numbers actually current? (This is the most commonly stale piece of any IR plan.)

- For security or regulated services: does the comms protocol match the regulatory notification SLA? GDPR has 72 hours; some financial regulators have 24-72 hours; some have immediate. The IR plan must align.
- Is there a separate, accessible-during-an-incident copy of this plan? (If your IR plan is on a wiki that's down because of the incident, it's not useful.)
- Are runbooks rehearsed (game-day exercises) or only documented?

Common gaps in real IR plans

- Severity criteria conflate "lots of errors" with "high severity" — but a small number of errors affecting one regulated customer can be SEV-0 while a large number of errors affecting unauthenticated traffic might be SEV-2
- On-call rotation is documented but not maintained — people leave the team and aren't removed
- External communication (status page, customer notification) is documented but never rehearsed; first time it's used is during an actual incident
- Regulatory notification protocols don't actually match regulatory requirements — IR plan says "notify within 4 hours" but the regulation says 24 with specific format requirements
- IR plan doesn't account for incidents during low-coverage hours (weekends, holidays, regional time zones)
- Post-incident reviews are scheduled but findings are never actually tracked to closure

Related artifacts

- Severity classification informs RAID Log (Artifact #11) risk classification
- Communications protocols coordinate with Comms Plan (Artifact #8) for crisis communications section
- Post-incident review feeds Lessons Learned Register (Artifact #22)
- Runbooks reference Operating Model (Artifact #29) for operational ownership

Keywords: IR plan, incident response plan, incident response procedure, on-call rotation, severity classification, SEV-0 SEV-1 SEV-2, incident commander, IC role, communications lead, SME, post-incident review, PIR, runbook, paging procedure, escalation path, regulatory notification, customer notification during incident, status page protocol

PRACTITIONER REFERENCE

Standards & method: Aligned to NIST SP 800-61 Rev. 2 Computer Security Incident Handling Guide. Method: Preparation -> Detection and Analysis (severity triage, indicator correlation) -> Containment (short-term and long-term) -> Eradication -> Recovery -> Post-Incident Activity (PIR, lessons learned, indicator sharing).

Guiding principles: Severity classification drives response SLA, not individual judgment; containment precedes eradication; communication cadence is pre-scripted to prevent chaos; every incident closes with a blameless PIR.

What good looks like:

- Severity matrix is quantified (user impact x data sensitivity x blast radius) with pre-approved response SLAs per tier.
- Runbooks exist for the top-10 incident archetypes, tested in tabletop exercises at least twice per year.
- Containment options (isolate, throttle, roll back, disable) are pre-authorized so on-call engineers act without approval delays.
- Communication templates for internal escalation, customer notification, and regulator notification are pre-drafted and version-controlled.

- PIR is completed within five business days, with action items tracked to closure in the next sprint.

Common pitfalls:

- Incident response plan exists as a PDF last updated two years ago that no one has read.
- Severity classification done by the on-call engineer at 2am, producing inconsistent and politically influenced triage.
- Containment deferred pending root cause analysis, allowing a breach or outage to expand while investigation occurs.
- Post-incident review skipped when the incident is resolved, eliminating the organizational learning loop.
- Customer and regulator notification timelines not pre-defined, creating legal exposure from delayed disclosure.

Maturity (1-5): L1 Ad hoc - response improvised, no plan; L2 Defined - IR plan documented, roles assigned; L3 Managed - runbooks tested, SLAs enforced, PIR cadence; L4 Quantified - MTTR/MTTD trended, repeat incident rate declining; L5 Optimizing - automated detection and containment playbooks, threat intel integrated into detection.

Engineering Artifact #E3 — Disaster Recovery (DR) Plan

Disaster Recovery (DR) Plan

Purpose

The plan for restoring service after a major failure event — data center outage, cloud region failure, ransomware, catastrophic data loss, prolonged vendor outage. The DR plan answers: how long will we be down, how much data will we lose, what's the procedure to restore, who has authority to execute it, and how do we know it actually works.

DR is different from IR. IR plans handle production incidents (something broke; let's fix it). DR plans handle disasters (the entire environment is gone; let's rebuild it elsewhere). The two plans connect — a SEV-0 incident might escalate to DR if recovery isn't possible in primary infrastructure — but the response posture is fundamentally different.

When to use it

Required for any service or system with:

- Regulatory requirements specifying RTO/RPO (most financial services, healthcare, regulated infrastructure)
- Business continuity criticality (revenue-impacting if down for hours/days)
- Audit findings (SOC 2, ISO 27001, etc., specifically test for documented DR plans)
- Single-point-of-failure topology that makes a major outage plausible

Strongly recommended for any production system with significant business impact, even if not formally required.

Skip for: low-stakes internal services where "we'll rebuild from scratch if it breaks" is the actual posture. But again — be honest about whether that's true. Most teams discover the answer is no.

Who owns it

Senior engineering or infrastructure lead drafts. SRE/operations function reviews. Risk and compliance functions sign off (DR plans are compliance artifacts as much as operational ones — they're inspected during audits). Sponsor approves the strategy and the budget commitment (DR is expensive: replicated infrastructure, regular tests, dedicated tooling).

What's in it

A complete DR plan covers eight sections:

1. Scope and criticality. What systems this DR plan covers, and for each, the criticality tier (Tier 1 = restore within hours; Tier 2 = within 1 day; Tier 3 = within 3 days; Tier 4 = best-effort). The criticality tier drives the RTO/RPO targets and the recovery architecture.
2. RTO and RPO targets. Recovery Time Objective (how quickly service is restored) and Recovery Point Objective (how much data is acceptable to lose). Each system has explicit targets, and the targets must be testable, not aspirational. RTO for an audit-regulated system might be 4 hours; the DR plan must show how 4 hours is achievable.
3. Architecture. The recovery architecture: primary site, secondary site (or region, or zone), replication mechanism, data backup strategy, failover orchestration, DNS strategy. Diagrams matter here; visual architecture is more reliably understood than prose during a real DR.
4. Recovery procedures. The step-by-step playbook for executing recovery. Each step has a named owner, expected duration, validation criteria, and dependencies on other steps. For a complex system, recovery procedures are themselves multi-page runbooks; the DR plan references them.
5. Decision authority. Who declares a disaster (specifically, who has authority to invoke DR procedures, which is significant because it commits resources and may have customer-facing implications). Who approves recovery decisions during execution. The default is the CISO, CIO, or COO depending on org structure — but it must be specific named people, not just titles.
6. Communication plan. During DR execution: internal updates, customer notifications, regulatory notifications, board/audit committee notifications. This section coordinates with the IR plan's communication protocols and the Communications Plan's crisis section, but DR comms have specific patterns (longer time horizon, more deliberate cadence, more formal regulatory communication).
7. Testing program. The schedule and methodology for validating that the DR plan actually works. Tabletop exercises (annual minimum). Partial-failover tests (semi-annual or quarterly). Full DR test (annual minimum, more frequent for the most critical tiers). Each test has documented results, identified gaps, and remediation tracking. A DR plan that hasn't been tested in 18 months is, for all practical purposes, not a DR plan.
8. Maintenance. Review cadence (typically annual; triggered review after major architecture change, after every test, after every DR-relevant incident). Named owner. Version history with substantive change notes.

What TPMs check for in review

- Are the RTO/RPO targets actually achievable, or are they targets that match a regulatory requirement but no one has tested the architecture against them?
- Is the DR site actually maintained, or is it a stale snapshot that wouldn't successfully restore production?
- Has the DR plan been tested in the last 12 months? With actual production-shape data and load? End-to-end?
- Are decision authorities specific named people with current contact information, or are they roles that have been re-orged?
- Does the comms section align with regulatory notification requirements? (DR events that affect customer data may have specific regulatory disclosure obligations.)
- For ransomware specifically: is the DR plan distinguishable from "restore from backup"? (Ransomware-specific DR has additional steps: forensic preservation, scope determination, ensuring restored systems aren't reinfected.)

Common gaps in real DR plans

- RTO/RPO targets are aspirational, not validated by actual testing

- Documented backup architecture exists, but the backups haven't been test-restored within the last 12 months
- Recovery procedures reference systems and tools that have been deprecated or replaced
- DR site is on the same regional infrastructure as primary (not actually independent)
- Decision authority is documented but never rehearsed; first time the named person sees their role is during an actual disaster
- Testing program is "annual" but has been skipped for 2+ years due to "test environment isn't ready" — which means production isn't recoverable
- Communication plan doesn't account for the difference between a localized disaster (DR site is healthy) and a regional disaster (DR site is also affected)

Related artifacts

- IR Plan (Engineering Artifact #E2): the IR plan handles incidents that don't require DR; the DR plan handles those that do
- Operating Model (Artifact #29): the function that owns this DR plan in steady state
- RAID Log (Artifact #11): the risks that this DR plan mitigates feed into the program/operational risk register
- Recovery Plan (Artifact #21): for program-level recovery from off-track state, not service-level disaster recovery; different artifact, related concept

Keywords: DR plan, disaster recovery plan, business continuity plan, BCP, RTO, RPO, recovery time objective, recovery point objective, failover, failover procedure, DR site, secondary region, hot standby, warm standby, cold standby, DR test, tabletop exercise, full DR test, ransomware recovery, regional outage, cloud region failure

PRACTITIONER REFERENCE

Standards & method: Aligned to ISO 22301:2019 Business Continuity Management and NIST SP 800-34 Rev. 1 Contingency Planning Guide. Method: Business Impact Analysis (RTO/RPO per system) -> recovery strategy selection -> DR plan documentation -> test schedule (tabletop -> parallel -> full failover) -> lessons learned -> plan update cycle.

Guiding principles: RTO and RPO are business-driven, not IT-estimated; the plan is only as good as its last test; recovery procedures are owned by operations, not the original developers; DR and incident response are linked but distinct.

What good looks like:

- RTO and RPO are formally signed off by the business process owner, not set by IT default.
- Full failover test (not tabletop) is conducted at least annually with results documented and business stakeholders present.
- Recovery procedures are written at the step level, executable by someone who did not build the system.
- DR environment parity with production is audited quarterly; configuration drift is a tracked risk.
- Lessons learned from each DR test produce dated action items closed before the next test cycle.

Common pitfalls:

- DR plan tested only via tabletop, with actual failover capability unverified for years.
- RPO set to zero by default without a cost-benefit analysis, driving unnecessary infrastructure spend.
- Recovery procedures reference systems, tools, or contacts that no longer exist since the last plan update.

- DR plan stored only on the primary production systems it is supposed to protect, making it inaccessible during a disaster.
- Third-party dependencies and their RTO/RPO commitments not validated against contractual SLAs.

Maturity (1-5): L1 Ad hoc - recovery by heroics, no plan; L2 Defined - DR plan documented, RTO/RPO set; L3 Managed - annual full-failover test, lessons learned tracked; L4 Quantified - actual RTO/RPO measured against targets, drift continuously monitored; L5 Optimizing - automated failover orchestration, continuous DR validation integrated into CI/CD.

Engineering Artifact #E4 — SPADE Decision Document

SPADE Decision Document

Purpose

A structured format for documenting technical decisions: Story, Problem, Approach, Decision, Evidence. SPADE makes engineering decision-making auditable by capturing not just what was decided, but the context that produced the decision and the evidence that supports it. The format originated at Spotify and has become a common pattern at engineering organizations that need decisions to be both fast and reviewable later.

A SPADE doc is not a meeting notes file or a one-off proposal. It's a durable artifact that lives next to the system it describes, gets referenced when later decisions interact with it, and survives team changes. The point is that someone joining the team in 18 months can read the SPADE and understand why the system was built the way it was.

When to use it

Required for: architectural decisions affecting multiple teams, vendor selections above a stated threshold, decisions with security or compliance implications, decisions that lock in a direction that's expensive to reverse, decisions that the team will be asked about during audits or post-incident reviews.

Strongly recommended for: anything where you'd want a trail when a future engineer asks "why did we do it this way?"

Skip for: implementation choices within an already-decided architecture, day-to-day prioritization, decisions that are easily reversible.

Who owns it

The engineer or TPM driving the decision drafts. The technical reviewer (typically a staff/principal engineer or architect) reviews. The decision authority approves — for engineering decisions this is usually the engineering manager, director, or architecture review board depending on scope. Once approved, the SPADE doc is locked; superseding decisions create new SPADE docs that reference the prior one.

What's in it

A complete SPADE doc has five sections:

1. Story. The narrative context. What's been happening that led to this decision needing to be made. Who's been involved. What's been tried, considered, or assumed. The Story is what makes the decision interpretable later — without it, the Decision is just a sentence with no reasoning attached.
2. Problem. The specific problem the decision is solving, stated precisely. Not "we need a faster database" but "our P95 query latency is 1.2s; product target is 200ms; we have evidence the database is the bottleneck." Problem statements that don't include measurable criteria are usually disguising scope or assumptions.

3. Approach. The candidate approaches considered, with tradeoffs. Typically 2-4 approaches, each with what it would entail, what it would cost, what it would risk, and what evidence supports or undermines it. The Approach section makes clear that the decision was a choice, not a default.

4. Decision. The chosen approach, stated clearly. Includes: who decided, when, what authority they had, who else needed to be consulted, and what conditions would cause this decision to be revisited.

5. Evidence. The data, prototypes, benchmarks, expert opinions, or other concrete inputs that support the decision. Evidence isn't "we discussed it" — it's "we ran X benchmark and got Y result; we talked to Z external practitioner who's done this; we built a prototype that demonstrated A."

What TPMs check for in review

- Is the Problem section actually measurable? "Our system is slow" is not a problem statement; "our P95 latency is X, target is Y, evidence the bottleneck is Z" is.
- Are the Approaches genuinely distinct, or are they the same approach with cosmetic variations? Three approaches that all amount to "do what we were going to do anyway" is decision theater, not decision-making.
- Does the Evidence actually support the Decision? It's common to see evidence cited that supports the chosen approach but doesn't address the strongest argument against it.
- Who has authority to make this decision? SPADE docs that list a decision-maker who doesn't actually have the authority for the decision's scope are a real problem; they're audit-ready in form but invalid in substance.
- What conditions would cause this decision to be revisited? A SPADE doc with no revisit criteria is essentially permanent; that's appropriate for some decisions and inappropriate for many.
- Does the Story acknowledge the political and organizational context honestly, or is it sanitized? "We adopted X because the team learned Y" is more useful than "we adopted X because it's a best practice."

Common gaps in real SPADE docs

- Story sections that are minimal or omitted; later readers can't reconstruct context
- Problems stated as solutions in disguise ("we need to migrate to Y") rather than as actual problems ("we cannot achieve Z given our current X")
- Approach sections that present one approach in detail and dismiss others in a sentence each
- Evidence cited as "team consensus" or "best practice" without actual data or external reference
- Decision authority unclear; "we decided" without naming who has the authority
- No revisit criteria; the decision is treated as final without acknowledging what would change if circumstances shift

Related artifacts

- Decisions & Changes Log (Artifact #19): SPADE docs are referenced from the Decisions Log; the log captures the decision; the SPADE captures the reasoning
- Design Doc (Engineering Artifact #E6): when SPADE decisions affect system design, the Design Doc references the SPADE
- ROLL Plan (Engineering Artifact #E1): rollout strategy decisions often have a SPADE behind them
- IR Plan (Engineering Artifact #E2): post-incident decisions about prevention often produce SPADE docs

Keywords: SPADE, SPADE decision, decision document, technical decision, decision record, ADR, architecture decision record, story problem approach decision evidence, decision rationale, engineering decision, audit-ready decision, decision authority, decision evidence, decision tradeoffs

PRACTITIONER REFERENCE

Standards & method: Aligned to the SPADE decision framework (Setting, People, Alternatives, Decide, Explain) as published by Gokul Rajaram, and informed by DACI/RAPID RACI variants for decision accountability. Method: set context and non-negotiable constraints -> name the Decider explicitly -> enumerate alternatives with pros/cons and evaluation criteria -> recommend with evidence -> circulate for input with a deadline -> Decider decides and documents rationale.

Guiding principles: One named Decider; input is invited but does not require consensus; alternatives are genuinely evaluated, not used to justify a pre-selected answer; the decision and its rationale are permanently recorded.

What good looks like:

- The Setting section defines the deadline, non-negotiable constraints, and what is explicitly out of scope.
- A minimum of three substantive alternatives are analyzed; the status quo is always one of them.
- Evaluation criteria are defined before alternatives are scored, preventing post-hoc rationalization.
- Approver list is minimal (the Decider plus directly impacted stakeholders), preventing decision-by-committee drift.
- The final explanation documents not just what was decided but why the other alternatives were rejected.

Common pitfalls:

- Decider is a committee, producing either endless delay or a watered-down compromise.
- Alternative analysis is a facade: one real option plus two strawmen designed to lose.
- SPADE written after the decision to create paper trail, not as a genuine decision aid.
- Input deadline not set, allowing the consultation phase to drift indefinitely.
- Decision not recorded or stored accessibly, causing the same debate to recur six months later.

Maturity (1-5): L1 Ad hoc - decisions made verbally, no record; L2 Defined - decision log exists, some decisions documented; L3 Managed - SPADE or equivalent used for all major decisions, Decider named; L4 Quantified - decision quality reviewed retrospectively, reversal rate tracked; L5 Optimizing - decision intelligence tooling, outcome tracking linked back to original criteria.

Engineering Artifact #E5 — Product Requirements Document (PRD)

Product Requirements Document (PRD)

Purpose

The product manager's specification for what's being built and why. The PRD answers: what problem are we solving, for whom, what does success look like, what's required, what's out of scope, and what depends on what. The PRD is the document that engineering, design, marketing, sales, support, and legal all read to understand the same thing about the same feature or product.

The PRD is not a project plan. It doesn't say when things ship or who owns each task — that's program management work. It also isn't a technical spec — it doesn't say how to build it, only

what to build. The PRD sits at the boundary between problem and solution: precise enough about the problem that engineers can design a solution, agnostic enough about the solution that the design space stays open.

When to use it

Required for: any new product, new feature, or significant change to existing functionality. Especially required when multiple teams need to coordinate (engineering + design + marketing + support all need to know the same things).

Strongly recommended for: any work that goes through formal review (design review, security review, launch review, etc.). The reviewers need a PRD to evaluate.

Skip for: bug fixes, performance improvements, internal tooling that doesn't have a user-facing surface, very small additions that don't justify the overhead.

Who owns it

Product Manager drafts. Design partners contribute the user experience perspective. Engineering reviews for feasibility and surfaces technical implications. TPM partners with PM to coordinate cross-team review and tracking. Stakeholders sign off based on their domain (legal, security, compliance, marketing). Once approved, the PRD is the source of truth; changes go through formal change-control.

What's in it

A complete PRD covers eight sections:

1. Problem and users. The problem the work solves, who has the problem, how big the problem is (with evidence), and why now. This section is the foundation; if it's weak, everything downstream is suspect.
2. Goals and non-goals. What this work aims to achieve, with success metrics. Equally important: what this work is explicitly NOT trying to achieve. Non-goals prevent scope creep and clarify the solution space.
3. User experience. The user-facing experience at a level engineers can build from. Wireframes, flows, key screens, edge cases. Not pixel-perfect designs (those come from design); enough to communicate intent.
4. Functional requirements. The behaviors the product must support, organized by user type or feature area. Each requirement is testable. "Users can manage their MFA methods" is not testable; "users can add a new MFA method, view their existing methods, set a primary method, and remove a method (with confirmation)" is.
5. Non-functional requirements. Performance, scalability, security, availability, accessibility, internationalization. The qualities the product must have, with measurable thresholds. "Fast" is not a requirement; "P95 page load < 1.5s on 4G" is.
6. Dependencies and integrations. What systems this depends on, what systems depend on this, what API contracts exist or need to exist, what data flows in and out.
7. Risks and open questions. Known risks (with mitigation strategies) and questions that need to be resolved before or during development. PRDs that have no open questions are usually hiding them.
8. Success metrics and tracking. The measurable outcomes that determine whether this work succeeded after launch. With baselines (where they exist), targets, measurement methodology, and review cadence post-launch.

What TPMs check for in review

- Is the Problem section evidence-based or hand-wavy? "Users want this" is not evidence; "support tickets show 47% of MFA-related contacts are users trying to manage their methods themselves" is.
- Are non-goals stated, or is the scope wide-open? Wide-open scope produces wide-open delivery, which means slippage.
- Are functional requirements testable? Each one should be reviewable as "did we build this exactly, yes or no."
- Are non-functional requirements measurable? Performance/security/accessibility numbers, not adjectives.
- For regulated work: have legal/compliance reviewed and signed off on the PRD before engineering starts? Easier to fix scope problems before code than after.
- For accessibility: is WCAG conformance level specified, or is accessibility just listed as "the product will be accessible"? The latter means it won't be.
- For internationalization: are locale, timezone, and language requirements specified, or is it implicitly US English?
- Are the dependencies tracked anywhere outside the PRD? If a dependency slips, who knows about it?

Common gaps in real PRDs

- Problem sections that are solutions in disguise ("users need a way to do X" — but X is a solution; what's the underlying problem?)
- Goals stated as outputs (we'll build X) rather than outcomes (X will reduce support contacts by Y%)
- No non-goals section, or non-goals that are toothless ("we won't solve world hunger")
- Functional requirements that aren't testable
- Non-functional requirements that are aspirational ("fast", "secure", "accessible") without measurable thresholds
- Open questions section is empty (because the PRD author doesn't want to look uncertain) or full (because they're using the PRD as a backlog rather than a spec)
- Success metrics that can't be measured with the data the team actually has access to
- Dependencies on external teams without those teams being engaged

Related artifacts

- Design Doc (Engineering Artifact #E6): translates the PRD's "what" into an engineering "how"
- ROLL Plan (Engineering Artifact #E1): governs how the PRD's deliverable reaches users
- SPADE Decision Document (Engineering Artifact #E4): captures decisions made during PRD review or implementation that affect the PRD
- Test Plan (Engineering Artifact #E7): defines how PRD requirements are verified
- Charter (Artifact #1): for major work, the program charter sits above the PRD; for smaller work the PRD is the founding document

Keywords: PRD, product requirements document, product spec, product specification, product brief, MRD, market requirements, functional requirements, non-functional requirements, user stories, feature spec, product manager spec

PRACTITIONER REFERENCE

Standards & method: Aligned to industry-standard Product Management practice (Marty Cagan INSPIRED framework, Shape Up by Basecamp where applicable) and IEEE 830 SRS as a structural reference for requirement specification. Method: problem statement and target user -> goals and success metrics (HEART/AARRR) -> user stories or jobs-to-be-done -> functional requirements -> non-functional requirements -> out of scope -> open questions.

Guiding principles: Requirements describe the problem and outcome, not the solution; every requirement is testable; success metrics are defined before build begins; out-of-scope is as important as in-scope.

What good looks like:

- Each requirement is traceable to a stated user problem or business objective, not an internal assumption.
- Non-functional requirements (performance, security, accessibility, scalability) are quantified, not adjective-based (e.g., 'fast').
- Success metrics include leading and lagging indicators with baseline, target, and measurement method.
- Out-of-scope section prevents scope creep by explicitly naming adjacent features deferred to a future phase.
- Open questions have named owners and resolution-by dates, preventing them from silently blocking engineering.

Common pitfalls:

- PRD describes the UI in detail but omits the problem it solves, locking engineering into a solution before problem validation.
- Non-functional requirements absent or aspirational ('the system shall be highly available'), making them unenforceable.
- Success metrics added as an afterthought after engineering has started, making outcome measurement impossible.
- PRD is a living document with no versioning, making it impossible to understand what was agreed at a given point.
- Single author with no structured review by engineering, data, and security, allowing blind spots to survive to build.

Maturity (1-5): L1 Ad hoc - requirements in email threads; L2 Defined - PRD template used, functional requirements documented; L3 Managed - NFRs quantified, success metrics defined, structured review completed; L4 Quantified - requirement traceability to test and outcome tracked; L5 Optimizing - continuous feedback loop from production metrics back to PRD, outcome-driven roadmap.

Engineering Artifact #E6 — Engineering Design Document

Engineering Design Document

Purpose

The technical specification for how an engineering system or component will be built. The design doc translates the PRD's "what" into an engineering "how" — proposed architecture, alternatives considered, system diagrams, API contracts, data models, security and privacy considerations, observability strategy, rollout approach, and open questions. The design doc is what the engineering team agrees to before code is written, and what reviewers (other engineers, security, SRE, architecture) evaluate the design against.

A design doc is not a project plan, not a PRD, and not documentation. It's a snapshot of an engineering proposal at a specific moment, captured precisely enough that someone reading it later can understand both the design and why this design rather than alternatives.

When to use it

Required for: any new system or service, any significant change to existing systems (new component, new dependency, new data flow), any change with security or privacy implications, any change reviewed by an architecture review board or external stakeholders.

Strongly recommended for: anything that 2 or more engineers will work on; anything that has cross-team dependencies; anything that will outlast the team that builds it.

Skip for: trivial changes within existing patterns, bug fixes, refactoring without behavior change.

Who owns it

The engineer or engineers driving the design draft. A staff or principal engineer or architect typically reviews. Cross-functional reviewers (security, SRE, privacy, accessibility) review based on the change's surface area. The TPM coordinates review and tracks open questions to closure. The decision authority approves — for engineering decisions this is usually the engineering manager, director, or architecture review board.

What's in it

A complete design doc covers nine sections:

1. Context and goals. The problem being solved (referenced from PRD or stated directly), the goals of this design, and the constraints that any design must satisfy. Context provides what later readers need to understand why the design exists at all.
2. Proposed design. The proposed architecture and approach, at a level engineers can build from. System diagrams. Component responsibilities. Major data flows. Key interfaces.
3. Alternatives considered. Other approaches that were considered, with reasons each was not chosen. Honest alternatives with honest tradeoffs. A design doc with no alternatives is suspicious — either the author didn't consider any, or they're hiding something.
4. Detailed design. The specifics: API contracts (request/response shapes), data models (schemas), state machines, sequencing, concurrency considerations, error handling. This is the part that engineers will reference when implementing.
5. Security and privacy. Threat model, authentication and authorization approach, data classification and handling, encryption (in transit, at rest), audit logging, regulatory compliance considerations. For systems handling user data, this section is mandatory and substantial.
6. Observability. What metrics, logs, and traces this system produces. What alerts will be configured. What dashboards. How the team knows the system is healthy in production.
7. Rollout and migration. How the design ships safely. Feature flags. Phased rollout strategy (links to or anticipates a ROLL plan). Backward compatibility considerations. Migration plan if existing data or behavior changes.
8. Open questions. Things still being decided or investigated, with named owners and target resolution dates. Empty open-questions sections are a warning sign — design docs almost always have unresolved questions; pretending otherwise sets the project up for surprises.
9. Appendices. Reference material that's important but not essential to understanding the proposal: detailed benchmarks, vendor evaluation matrices, prior-art links, related design docs.

What TPMs check for in review

- Is the design doc evidence-based, or is it asserting things without backing? "We chose X because it's faster" should be "we chose X because benchmark Y showed it's faster by Z%."
- Are alternatives honest? Three alternatives that all amount to "do what we were going to do anyway, with cosmetic variations" is design theater.
- Is the security section thorough? Does it identify a threat model, or just say "we'll use HTTPS"?
- Is observability designed in, or bolted on? Designs that mention observability as an afterthought ("we'll add dashboards later") usually don't get observability later.
- Is the rollout strategy realistic? Is there a feature flag? Is there a rollback path? Will the team know quickly if something goes wrong?

- Are open questions tracked outside the doc, or do they live only here? If only here, who's chasing them?
- Does the design address what happens when its dependencies fail, or does it implicitly assume dependencies are always available?
- For systems handling regulated data: have legal/compliance reviewed the design before implementation, or are they reviewing the implementation?

Common gaps in real design docs

- Context section that assumes the reader already knows everything the author knows
- "Alternatives considered" sections that aren't real alternatives
- Detailed design sections that punt on hard parts ("error handling: TBD")
- Security sections that conflate "uses authentication" with "is secure"
- Privacy sections that don't actually consider privacy ("no PII is handled" — but isn't user behavior data also a privacy concern depending on how it's used?)
- Observability sections that list metrics without explaining what they'd alert on or what action they'd drive
- Rollout sections that say "we'll roll out gradually" without defining gradually
- Open questions that have been open for so long they've effectively become decisions by inaction

Related artifacts

- PRD (Engineering Artifact #E5): the design doc translates a PRD into an engineering proposal
- SPADE Decision Document (Engineering Artifact #E4): significant decisions made during design get their own SPADE
- ROLL Plan (Engineering Artifact #E1): the rollout section of the design doc anticipates the ROLL plan
- Test Plan (Engineering Artifact #E7): the design doc's detailed design + non-functional requirements drive the test plan
- IR Plan (Engineering Artifact #E2): when the design ships, it gets covered by an IR plan; the design doc's observability section feeds the IR plan's response runbooks
- DR Plan (Engineering Artifact #E3): for Tier 1 systems, the design doc must address DR architecture from the start

Keywords: design doc, engineering design document, technical spec, technical specification, architecture document, design review, RFC, request for comments, design proposal, system design, software design document

PRACTITIONER REFERENCE

Standards & method: Aligned to TOGAF 10 Architecture Development Method (ADM) for enterprise-level design and arc42 template for system/solution-level design documentation. Method: architectural drivers (requirements, constraints, quality attributes) -> system context and container diagrams (C4 model) -> component decisions and ADRs -> cross-cutting concerns (security, observability, scalability) -> deployment view -> architecture decision log.

Guiding principles: Design documents record the reasoning, not just the decision; quality attributes are the primary architectural driver; Architecture Decision Records capture context and trade-offs, not just outcomes; the design is owned by the team, not an ivory-tower architect.

What good looks like:

- C4 or equivalent context, container, and component diagrams are current, versioned, and generated from code where possible.

- Every significant design choice has a linked Architecture Decision Record with context, options considered, and consequences.
- Non-functional quality attributes (availability, security, latency, maintainability) are explicitly addressed with design responses.
- Cross-cutting concerns (auth, logging, error handling, data residency) are resolved at the design level, not deferred to individual engineers.
- Design document reviewed by security, SRE/ops, and data engineering before implementation begins.

Common pitfalls:

- Design document written after implementation to satisfy a governance gate, reflecting what was built rather than driving what should be built.
- Diagrams exist only in a single engineer's head or in a one-off Miro board that is never updated.
- ADRs absent: decisions made verbally, leaving future maintainers unable to understand why the system is designed as it is.
- Security architecture treated as an afterthought, with auth and data protection bolted on post-design.
- Design scope conflated with implementation detail, producing a 100-page document that engineers ignore.

Maturity (1-5): L1 Ad hoc - design in tribal knowledge; L2 Defined - design document template used, diagrams exist; L3 Managed - C4 model maintained, ADRs logged, quality attributes addressed; L4 Quantified - architecture fitness functions automated, design compliance tracked in CI; L5 Optimizing - self-documenting architecture, continuous fitness function monitoring, design debt quantified.

Engineering Artifact #E7 — Test Plan

Test Plan

Purpose

The plan for how a system or change will be tested before it ships. The test plan answers: what's being tested, what types of testing apply, what test data and environments are needed, what passes and what fails (entry/exit criteria), how defects are handled, and who has sign-off authority. The test plan is the artifact that quality engineering, development, product, and stakeholders all reference to know whether something is ready to ship.

A test plan is not a test case list and not a QA strategy document. It's the agreement on the scope and structure of testing for a specific change. Test cases live within the plan or are referenced from it; QA strategy is the broader document about how the team approaches testing across all work.

When to use it

Required for: any change that goes through formal testing gates (UAT, security testing, performance testing, accessibility testing); any change with regulatory testing requirements; any change where multiple teams contribute to testing.

Strongly recommended for: any change reaching production, especially customer-facing changes; any change with rollback complexity.

Skip for: trivial changes already covered by automated test suites; changes that don't reach production until after a separate test plan is in place.

Who owns it

QA lead drafts. Engineering lead provides scope and feasibility input. Product manager provides functional acceptance criteria. Security reviews if there are security testing requirements. TPM

coordinates cross-team review. The decision authority approves — typically the QA lead and engineering manager jointly.

What's in it

A complete test plan covers eight sections:

1. Scope. What's being tested, what's not being tested, and what depends on this scope. Boundaries matter; test plans that try to test everything end up testing nothing well.
2. Test types and coverage. What types of testing apply: unit, integration, end-to-end, performance, security, accessibility, regression, compatibility, usability. Each type has its own coverage target and methodology.
3. Test environment and data. What environments are needed for which tests. What test data is required. Whether production-like data can be used (with what privacy controls), or whether synthetic data is required.
4. Entry and exit criteria. What must be true before testing starts (entry criteria) and what must be true before testing is considered complete (exit criteria). Each criterion is specific and verifiable.
5. Schedule and resource plan. Who's testing what, when, with what tools. The plan accounts for parallelism (e.g., unit tests during development, performance tests after feature complete) and dependencies (e.g., security tests can't start until functional tests pass).
6. Defect process. How defects are reported, triaged, prioritized, fixed, and verified. Severity definitions. Decision authority for "ship despite this defect" calls.
7. Risk and contingency. Testing risks (test environment unavailable, test data deficient, key tester out, timeline pressure compressing test cycles). What happens when contingencies trigger.
8. Sign-off authority. Who signs off on each test type. What constitutes "tests passed." How disagreements about test results are resolved.

What TPMs check for in review

- Are entry criteria realistic? "All previous gates passed" is fine; "no known defects" is unrealistic and means testing won't actually start.
- Are exit criteria specific enough that you can determine "passed" objectively? "Most tests pass" is not exit criteria; "all P0 and P1 tests pass and all P2/P3 defects have triage decisions" is.
- Is the test environment realistic enough? Performance testing in an environment 1/10 the scale of production is meaningful only for relative comparisons, not for absolute thresholds.
- Is test data adequate? Particularly for edge cases and regulatory scenarios — production-like volumes, demographic diversity, regulatory-protected attribute coverage.
- Is the defect process specific about who decides "ship despite defects"? This is the most contentious moment in any test cycle; the plan must name decision authority.
- For regulated work: are regulatory testing scenarios explicitly covered (e.g., accessibility, internationalization, data-handling)?
- Does the plan account for retesting after fixes? Defects discovered late don't get retested without explicit time and ownership.

Common gaps in real test plans

- Scope sections that are too broad or too narrow; the plan ends up testing the wrong things
- Coverage targets that are aspirational (e.g., "100% test coverage") rather than risk-based
- Test environment details glossed over; problems surface late when environments don't actually exist or aren't representative

- Test data plans that ignore privacy: production-like data used in test environments without appropriate controls
- Entry criteria too loose, exit criteria too strict (or vice versa); both lead to test cycles that don't end on schedule
- Defect severity definitions vague; team argues about whether something is P1 or P2 instead of fixing it
- No retesting plan after fixes; defects fixed at the end of the cycle ship without verification
- Sign-off authority unclear; the moment of "is this ready to ship" devolves into a meeting

Related artifacts

- PRD (Engineering Artifact #E5): the test plan verifies the PRD's functional and non-functional requirements
- Design Doc (Engineering Artifact #E6): the test plan exercises the design's components and interfaces
- ROLL Plan (Engineering Artifact #E1): the ROLL plan's pre-rollout gates reference test plan exit criteria
- SPADE Decision Document (Engineering Artifact #E4): decisions about test scope or coverage often produce a SPADE
- IR Plan (Engineering Artifact #E2): post-incident reviews often surface test-plan gaps that drive next-cycle test plan changes
- UAT Plan & Test Cases (Artifact #21): the PMO methodology's view of UAT specifically, framed as the business-owner's tool. If you're running UAT, see #21. If you're authoring the broader test plan that includes UAT, this artifact (#E7) is where you start.

Keywords: test plan, testing plan, QA plan, test strategy, test scope, test coverage, test environment, test data, entry criteria, exit criteria, defect process, severity definitions, UAT plan, user acceptance testing plan, testing approach

PRACTITIONER REFERENCE

Standards & method: Aligned to IEEE 829-2008 (Software Test Documentation) and ISO-IEC-IEEE 29119 Software Testing standard. Method: test scope and objectives -> test strategy (unit, integration, system, UAT, performance, security) -> entry and exit criteria -> test environment and data requirements -> test case design (equivalence partitioning, boundary value, risk-based) -> defect management -> test summary report.

Guiding principles: Testing strategy is risk-driven, not coverage-driven; exit criteria are defined before testing begins; test environments are production-equivalent for system and performance testing; testing is a quality gate, not a phase-end activity.

What good looks like:

- Test scope explicitly maps to requirements, ensuring traceability from requirement to test case to result.
- Entry and exit criteria are binary and pre-agreed with the project sponsor (e.g., zero P1 open defects, >=95% test case pass rate).
- Performance test targets (throughput, p95 latency, concurrency) are derived from business SLAs, not engineering guesses.
- Security testing (SAST, DAST, dependency scan) is integrated into CI/CD and included as an exit criterion.
- Test summary report quantifies coverage, defect density by component, and residual risk accepted at sign-off.

Common pitfalls:

- Test plan written at project start and never updated as scope changes, making it a misleading artifact.
- Exit criteria absent or qualitative ('stakeholder comfortable'), enabling premature sign-off under schedule pressure.
- Test environment not representative of production (different infra, synthetic data, missing integrations), producing false confidence.
- Performance and security testing treated as optional or deferred post-launch, discovering critical issues in production.
- Defect triage informal: severity assigned inconsistently, P1s closed as 'by design' without documented business acceptance.

Maturity (1-5): L1 Ad hoc - testing improvised; L2 Defined - test plan documented, manual test cases written; L3 Managed - risk-based strategy, exit criteria enforced, regression automated; L4 Quantified - defect escape rate trended, test coverage analytically managed; L5 Optimizing - shift-left quality engineering, mutation testing, AI-assisted test generation, continuous production quality feedback.

Engineering Example — DR Plan — Identity Platform (Cloud Security Operations)

Disaster Recovery (DR) Plan — Identity Platform

Document Control

- System: Bristol Identity Platform (Okta Identity Cloud + Bristol-managed integration layer)
- DR plan version: v3.1, last revised 2027-09-15 (post-Atlas operational handoff), next review 2027-12-15
- Owner: D. Reyes (Director, Cloud Security Operations)
- Approvers: Mike Tanaka (SRE Lead), Sandra Park (CISO), Robert Stein (CRO), Audit Committee acknowledged 2027-10-15
- Last DR test: 2027-09-22 (partial failover, US-East to US-West); 4-hour completion vs. 4-hour RTO target
- Last triggered review: 2027-09-15 (Atlas operational handoff)

1. Scope and criticality

Systems in scope of this DR plan

- Bristol Identity Platform (Okta tenant + integration layer) | Tier 1 | RTO: 4 hours | RPO: 15 minutes
- Identity audit log pipeline | Tier 1 | RTO: 4 hours | RPO: 5 minutes (regulatory: log gap > 5 min triggers regulatory notification)
- ZTNA control plane integration | Tier 1 | RTO: 4 hours | RPO: 15 minutes
- PAM (Privileged Access Management) | Tier 2 | RTO: 24 hours | RPO: 1 hour
- Access Review tooling | Tier 3 | RTO: 72 hours | RPO: 24 hours

Criticality tier definitions

- Tier 1: revenue-bearing or regulated infrastructure where outage > 4 hours triggers regulatory notification or material business impact
- Tier 2: significant business impact within 24 hours; SOX-relevant access controls fall here
- Tier 3: operational impact within 72 hours; recoverable from less-frequent backups
- Tier 4: best-effort recovery; not needed for compliance or operations

Out of scope

- Customer-facing application authentication flows — covered by per-application DR plans, but those depend on this plan's identity platform recovery
- The underlying Cloudflare ZTNA control plane (vendor-managed; vendor DR applies)
- Endpoint device management (covered by Endpoint Operations DR plan)

2. RTO and RPO targets

System	Tier	RTO	RPO	Driver
Bristol Identity Platform	1	4 hours	15 min	SOC 2 Type II requirement; audit committee mandate (2026)
Identity audit log pipeline	1	4 hours	5 min	State banking regulator: log gap > 5 min triggers notification within 24 hours
ZTNA control plane integration	1	4 hours	15 min	Internal application access dependency
PAM	2	24 hours	1 hour	SOX requirement; privileged access auditability
Access Review tooling	3	72 hours	24 hours	Annual access review process; not real-time-critical

Validation status

- Tier 1 RTO: validated 2027-09-22 partial failover (4-hour actual vs. 4-hour target); next full validation 2027-12-15
- Tier 1 RPO: validated 2027-09-22 (12-min data loss vs. 15-min target — within tolerance)
- Tier 2 RTO: validated 2027-08-30 tabletop (procedural validation only; full failover next scheduled 2027-12-15)
- Tier 3 RTO: not validated in last 12 months (gap noted; remediation: tabletop scheduled 2027-11-15)

3. Architecture

Primary site / region

- Primary: Okta Identity Cloud, US-East data center cluster (Virginia)
- Bristol integration layer: AWS US-East-1 (Virginia)
- Audit log pipeline: AWS US-East-1 → SIEM (Bristol-managed) → S3 (US-East-1, with cross-region replication to US-West-2)

Secondary (DR) site / region

- Secondary: Okta Identity Cloud failover cluster, US-West data center (Oregon) — operated by Okta with active-active replication
- Bristol integration layer: AWS US-West-2 (Oregon) — warm standby with hourly sync from primary
- Audit log pipeline: replicated to AWS US-West-2 with 5-minute target replication lag

Independence verification

- US-East and US-West are different AWS regions with independent power, network, and control planes
- Okta confirms US-East and US-West tenants are operated on independent control planes (verified 2027-09-10 via vendor architecture review)

- Cross-region replication does not introduce single-point-of-failure (verified via 2027-09-22 partial failover test)

Replication mechanism

- Identity data: Okta-managed active-active replication (vendor-controlled, 5-minute lag commitment per Okta SLA)
- Bristol integration layer: hourly snapshot replication to US-West-2 (Bristol-managed via AWS Backup)
- Audit logs: 5-minute target replication lag via cross-region S3 replication

Failover orchestration

- DNS-based failover for Bristol-controlled endpoints (Route 53 health check; 60-second TTL)
- Okta-side failover: vendor-managed; Okta automatically routes Bristol traffic to US-West if US-East fails (per vendor SLA)
- Authentication endpoint cutover: scripted; Mike Tanaka (SRE) authorizes execution
- Audit log endpoint cutover: scripted; runs simultaneously with authentication endpoint cutover

DNS / traffic routing

- Bristol-managed DNS (auth.bristol-financial.com) with Route 53 health check
- TTL: 60 seconds (allows fast cutover)
- Client-side cache: applications use server-side identity validation; no problematic client-side caching

Architecture diagram

- Current diagram: confluence link "Identity Platform DR Architecture v3.1"
- Last review: 2027-09-15 by Mike Tanaka and D. Reyes

4. Recovery procedures

Procedure	Runbook	Owner	Last validated	Expected duration
Tier 1 identity failover (US-E to US-W)	confluence link to ID-DR-001	Mike Tanaka	2027-09-22	4 hours
Tier 1 identity failback (US-W to US-E)	confluence link to ID-DR-002	Mike Tanaka	2027-09-23	6 hours
Audit log pipeline recovery	confluence link to ID-DR-003	SIEM Lead	2027-09-22	2 hours
Bristol integration layer recovery	confluence link to ID-DR-004	Integration Lead	2027-09-22	3 hours
PAM recovery	confluence link to ID-DR-005	PAM Lead	2027-08-30 (TT)	24 hours estimated (not full-tested)
Access Review tooling recovery	confluence link to ID-DR-006	IAM Operations	not validated	72 hours estimated
Ransomware-specific recovery	confluence link to ID-DR-007	Mike Tanaka + ISIRT	2027-08-15 (TT)	72 hours estimated for full recovery
Cross-vendor	confluence link to	SRE Lead	2027-08-15 (TT)	Variable; vendor-

Procedure	Runbook	Owner	Last validated	Expected duration
(Okta) outage recovery	ID-DR-008			dependent

5. Decision authority

Disaster declaration authority

- Primary: D. Reyes (Director, Cloud Security Operations)
- Secondary (if primary unavailable): Mike Tanaka (SRE Lead)
- Tertiary: Sandra Park (CISO)

Recovery decisions during execution

- Architecture-level: Mike Tanaka (SRE Lead)
- Communications-level: D. Reyes (Cloud Sec Ops Director); Sandra Park co-signs for SEV-0
- Regulatory engagement: Robert Stein (CRO); General Counsel co-signs

DR-related budget authority

- Within annual DR budget (\$2.4M for FY2028): D. Reyes
- Above annual DR budget (extended outage > 5 days): Sandra Park (CISO) with CFO consultation

6. Communication plan

Internal communications during DR

- Channel: #disaster-recovery-identity Slack (created on disaster declaration); war room conference bridge
- Cadence:
- Hours 0-4: status updates every 30 minutes
- Hours 4-12: every hour
- Hours 12-48: every 2 hours
- Beyond 48: every 4 hours
- Leadership notifications:
- Disaster declaration: Sandra Park (CISO), Linda Walsh (CIO), Robert Stein (CRO) within 15 minutes via call
- At 4 hours: Steering committee (CISO + CIO + CTO + CRO + PMO Director) via email
- At 12 hours: Audit committee chair via call (if applicable)

Customer communications during DR

- Trigger: any DR event with customer-facing impact (4 dependent customer applications)
- Channel: status.bristol-financial.com + per-app email from product manager
- Authority: D. Reyes signs off on technical content; Bristol External Comms approves customer language
- Pre-drafted templates: confluence link to "Customer DR Communication Library"
- Coordination with marketing/PR: standard Bristol crisis communication protocol applies

Regulatory communications during DR

- Regulators: State banking examiner; GLBA examiner
- Notification SLA per regulator
- State banking: within 24 hours of any DR event affecting Tier 1 systems with audit-log gap or customer impact
- GLBA: within 72 hours of any DR event with customer-PII exposure risk

- Authority: Robert Stein (CRO) signs; General Counsel co-signs; Sandra Park provides technical content
- Format: formal letter via certified mail; e-filed via examiner portal; phone-call follow-up for time-sensitive notifications

Board / audit committee communication

- Trigger: any Tier 1 DR event lasting > 4 hours
- Channel: board portal email + audit committee chair phone call
- Authority: Sandra Park (CISO)

7. Testing program

Annual DR plan

- Tabletop exercises: quarterly (next: 2027-11-15 for Tier 3 systems; 2028-02-15 for full plan tabletop)
- Partial-failover tests: semi-annual for Tier 1 (last: 2027-09-22; next: 2028-03-15)
- Full DR tests: annual for Tier 1 (last: 2027-04-15 — pre-Atlas; next: 2027-12-15)

Test results tracking

- Test report repository: confluence "Identity Platform DR Test History"
- Gap remediation tracking: Cloud Security Operations function backlog; status reviewed monthly in operations standup; SOC 2 audit prep includes DR test review

Per-tier testing requirements

- Tier 1: quarterly partial failover; annual full failover; annual tabletop covering ransomware and vendor-outage scenarios
- Tier 2: semi-annual tabletop; annual partial failover
- Tier 3: annual tabletop; partial failover when feasible (currently 2027 has not had Tier 3 partial failover — gap noted; remediation: 2027-11-15 tabletop, 2028-Q1 partial failover scheduled)
- Tier 4: tabletop only, every 18 months

8. Maintenance

Review cadence: Annual; next 2027-12-15 (combined with full DR test debrief)

Triggered review

- After every full or partial DR test (last: 2027-09-22, completed)
- After every Tier 1 system architecture change (last: 2027-09-15, completed for Atlas operational handoff)
- After every disaster (real or simulated) (none real in last 12 months; simulated 2027-09-22)
- After regulatory framework change (none in last 12 months)

Owner: D. Reyes (Cloud Security Operations Director)

Version history

v3.1 2027-09-15 — Operational handoff from Atlas program; updated decision authorities; expanded vendor-coordination protocols; added ransomware-specific runbook reference

v3.0 2027-08-15 — Pre-handoff comprehensive update; tabletop-validated all runbooks; added cross-vendor (Okta) outage scenarios

v2.4 2027-04-10 — RTO target updated from 6 hours to 4 hours per audit committee mandate; architecture updated to support tighter target

Related artifacts

- IR Plan (Engineering Example #E2): the IR plan for incidents that don't require DR; the DR plan covers escalations beyond IR scope

- Operating Model #153 (Cloud Security Operations): the operational ownership context for this plan
- ROLL Plan (Engineering Example #E1): the Wave 4 cutover plan that consumed identity platform DR architecture changes
- Operating Model section 11 (External Dependencies): vendor relationship management with Okta for vendor-side DR
- RAID Log (Artifact #11): identity platform DR risks tracked here; SOC 2 audit-finding remediation feeds in
- Recovery Plan (Examples #217): different artifact (program recovery, not service DR), but shares the discipline of explicit RTO and validated procedures

Keywords: DR plan example, disaster recovery plan example, identity platform DR, BCP example, RTO RPO example, failover example, regional failover, US-East to US-West, cross-region replication, DR test results, tabletop exercise example, populated DR plan, Cloud Security Operations DR

Engineering Example — Design Doc — ZTNA Policy Engine

Engineering Design Document — ZTNA Policy Engine

Document Control

- System: ZTNA Policy Engine (Project Atlas component #2 — engineering subsystem)
- Design doc version: v3.0, last revised 2026-06-15, last reviewed 2027-09-15 (post-Atlas operational handoff)
- Author: J. Liu (ZTNA Component Lead)
- Technical reviewer: Mike Tanaka (SRE Lead)
- Cross-functional reviewers: Sandra Park (CISO — security review), R. Patel (OCM Lead — change-management review for user-facing implications), Bristol Privacy Office (privacy review)
- Approvers: Linda Walsh (CIO — engineering owner during Atlas), D. Reyes (Cloud Security Operations Director — operational owner post-Atlas)
- Related PRD: not applicable (this is internal infrastructure; the PRD-equivalent is the Atlas Charter, Artifact #1, and Project Atlas Steering Committee approvals)
- Status: Implemented and operational

1. Context and goals

Background

Bristol's pre-Atlas authentication and access-control approach used a perimeter VPN model: employees connected to one of two VPN concentrators (LON-VPN-01, LON-VPN-02), and once connected, they had broad access to internal applications based on group membership. This model has three limitations the Atlas program was chartered to address: (1) compromised credentials grant broad access (no per-application policy enforcement), (2) device posture is not continuously evaluated (only at VPN connection time), (3) audit logging is coarse (per-VPN-session, not per-application-access).

The Zero Trust mandate adopted by Bristol's board in January 2026, along with the SOC 2 Type II findings on identity governance, drove the decision to replace the perimeter model with a Zero Trust Network Access (ZTNA) approach. Cloudflare ZTNA was selected as the vendor (separate SPADE: ATLAS-SPADE-007). This design doc addresses the policy engine — the component that evaluates access decisions for every internal application request, on every device, for every user.

Problem statement

Build a policy engine that evaluates access decisions in real time for all employee access to internal applications, with support for user identity, device posture, conditional access policies, and continuous evaluation. The engine must satisfy Bristol's audit-log requirements (per-access logging with attribution), performance targets (P95 evaluation < 50ms at scale), and operational requirements (failover, rollback, observability).

Goals

- Real-time policy evaluation for all internal application access (47 applications, ~3,500 employees)
- P95 evaluation latency < 50ms at general-availability scale
- Audit-ready per-access logging conforming to SOC 2 and GLBA evidence requirements
- Continuous evaluation: policy decisions updated on device-posture changes, user-risk-score changes, and policy changes without requiring re-authentication
- Vendor-supplied control plane (Cloudflare) with Bristol-managed integration and overrides

Non-goals

- This design does NOT replace the identity platform; identity authentication is upstream (Okta) and provides the authenticated principal that the policy engine evaluates against
- This design does NOT cover customer-facing applications; ZTNA is for internal-only access in this design
- This design does NOT cover service-to-service authentication; that's the service-mesh program's scope
- This design does NOT extend to vendor or contractor access; that's the post-Atlas Q4 2027 program

Constraints

- Bristol's existing identity platform (Okta) must be the authentication source of truth
- Audit log must conform to SOC 2 Type II evidence requirements (per-access attribution, immutable, 90-day retention minimum, archival to cold storage with 7-year retention)
- Policy engine must support rollback to legacy VPN within 60 minutes (validated rollback procedure)
- All evaluation must occur within Bristol-controlled infrastructure or vendor-controlled infrastructure with Bristol audit access; no third-party intermediaries

2. Proposed design

Architecture overview

The ZTNA policy engine is implemented as a hybrid: Cloudflare ZTNA control plane (vendor-managed) handles policy distribution and edge evaluation, with a Bristol-managed integration layer that bridges Cloudflare to the Bristol identity platform, the Bristol risk-scoring system, and the Bristol audit log infrastructure. Bristol-controlled policy authorship is via a Bristol-built policy-as-code system that compiles to the Cloudflare policy format and pushes to Cloudflare via API.

System diagram

Reference: confluence link "ZTNA Policy Engine v3.0 Architecture Diagram" (J. Liu, 2026-06-15; last refreshed 2027-09-15 post-Atlas)

Component responsibilities

- Bristol Policy Authoring System: where security/InfoSec authors and tests policies; compiles to Cloudflare format; pushes to Cloudflare control plane
- Cloudflare ZTNA Control Plane: vendor-managed; receives compiled policies; distributes to edge for evaluation
- Cloudflare ZTNA Edge: vendor-managed; evaluates access requests in real time; calls back to Bristol identity platform and risk-scoring as needed

- Bristol Identity Platform Integration Layer: Bristol-managed; provides identity attributes and risk signals to Cloudflare edge on demand
- Bristol Audit Log Pipeline: receives all access decisions from Cloudflare edge; writes to Bristol-managed audit log infrastructure
- Bristol Override Service: allows Bristol-side override of Cloudflare decisions in defined scenarios (incident response, manual customer escalation)

Major data flows

1. Policy authoring → Bristol Policy System → Cloudflare API → policy distributed to Cloudflare edge
2. Employee access request → Cloudflare edge → Bristol identity attributes/risk → policy evaluation → access decision → audit log
3. Policy update → Bristol Policy System → Cloudflare API → policy redistributed to Cloudflare edge (without service restart)
4. Audit log: Cloudflare edge → Bristol Audit Log Pipeline → SIEM → cold storage

Key interfaces

- Bristol Policy → Cloudflare API: REST, OAuth-authenticated, schema versioned
- Cloudflare edge → Bristol identity attributes: webhook callback, < 30ms target, with 5-minute cache for non-sensitive attributes
- Cloudflare edge → Bristol audit log: streaming, < 5-minute target write latency
- Bristol override → Cloudflare API: REST, authenticated via Bristol service account with Cloudflare admin scope

3. Alternatives considered

Alternative 1: Pure Bristol-built policy engine (no vendor)

- Description: Build the entire policy engine in-house, with edge instances at Bristol's primary data centers
- Pros: Full Bristol control; no vendor dependency; Bristol can innovate at any pace
- Cons: 18-24 month build estimate; ongoing infrastructure costs estimated at \$4-5M/year; would require building 24/7 ops capability for a system Bristol doesn't have differentiating expertise in; would not satisfy Atlas timeline
- Why not chosen: Atlas timeline is 21 months total; a 24-month policy engine build alone would slip the program. Bristol does not have a strategic reason to build vs. buy here.

Alternative 2: Cloudflare ZTNA with no Bristol integration layer

- Description: Use Cloudflare's stock ZTNA offering directly, integrating Cloudflare directly with Okta and pushing audit logs from Cloudflare to Bristol's SIEM via Cloudflare's standard log export
- Pros: Faster build (estimated 6 months); lower infrastructure complexity; less Bristol code to maintain
- Cons: Bristol-specific risk-scoring signals not available; no Bristol-side override capability; audit-log latency higher (Cloudflare's log export SLA is 15 minutes, our requirement is 5 minutes)
- Why not chosen: The 5-minute audit-log latency is a regulatory requirement (state banking examiner correspondence 2026-02-15); Cloudflare's stock log export does not meet it. The lack of Bristol-side override is also a real operational gap.

Alternative 3: Cloudflare ZTNA with thin Bristol integration (chosen)

- Description: Cloudflare ZTNA control plane and edge, with Bristol-managed integration layer for identity attributes, risk signals, audit logging, and override

- Pros: Atlas timeline achievable; Bristol-controlled audit log meets regulatory latency; Bristol risk-scoring integrated; override capability available
- Cons: Bristol must build and maintain integration layer; vendor-Bristol responsibility split adds operational complexity
- Why chosen: Best balance of timeline, regulatory compliance, and operational control. The integration-layer maintenance burden is acceptable given the strategic importance.

4. Detailed design

API contracts

POST /policy-engine/v3/policies

- Authentication: OAuth client_credentials, scope policy:write
- Request body: PolicySet (schema versioned)
- Response: 200 with policy version metadata; 4xx with structured error
- Rate limit: 10 req/min per client (policies are not high-frequency writes)

POST /policy-engine/v3/evaluate (called by Cloudflare edge via webhook)

- Authentication: mutual TLS with Cloudflare-issued cert
- Request body: AccessRequest (user_id, app_id, device_id, request_metadata)
- Response: 200 with AccessDecision (allow/deny, reasons, ttl) within 30ms target
- Rate limit: not applied (this is the hot path; rate limits are upstream at Cloudflare edge)

POST /policy-engine/v3/override

- Authentication: OAuth client_credentials, scope policy:override; restricted to incident-response and approved operational service accounts
- Request body: Override (target_principal, target_app, decision, ttl, justification)
- Response: 200 with override metadata; 4xx with structured error
- Rate limit: 5 req/min per client; alerting on override frequency above threshold

Data models

PolicySet (schema v3.2)

- policy_set_id: UUID
- version: monotonic integer
- author: principal_id
- compiled_at: timestamp
- rules: array of Rule
- audit_metadata: { reviewer, approval_chain, change_summary }

Rule

- rule_id: UUID
- precedence: integer (lower number = higher priority)
- condition: structured boolean (user attributes $\wedge$ device posture $\wedge$ app context $\wedge$ time-of-day $\wedge$ risk score)
- decision: allow | deny | challenge
- reason_code: string (enum)

AccessDecision

- decision: allow | deny | challenge
- reason_code: string (enum, audit-friendly)
- evaluated_rule_id: UUID
- ttl_seconds: integer (typically 300; lower for elevated-risk users)
- audit_event_id: UUID (for cross-reference with audit log)

State machines

The policy engine itself is largely stateless. The override service is stateful: each override has a TTL after which it expires automatically.

Concurrency model

Policy evaluation is read-heavy; policies are read-only at evaluation time. Policy updates use compare-and-swap semantics: if two updates race, the second update either succeeds (because it was compiled against the first's output) or fails with a structured retry-after error. Cloudflare edge handles eventual consistency: an update may take up to 90 seconds to fully propagate; during this window, edge instances may return decisions based on either the old or new policy. Audit log captures which policy version was used.

Error handling

- Identity attribute fetch fails: deny with reason_code AUTH_DEPENDENCY_DOWN; logged; alerting at 0.1% error rate
- Risk-score fetch fails: fall back to last-known risk score with a TTL; if no last-known score, deny with reason_code RISK_DEPENDENCY_DOWN
- Policy evaluation timeout (>30ms): deny with reason_code EVAL_TIMEOUT; logged; alerting on patterns
- Override service unreachable: continue with regular policy evaluation; override is non-blocking by design

5. Security and privacy

Threat model

Primary threats: (1) compromised employee credential gaining broad access (the original perimeter model's failure mode), (2) compromised device gaining access despite credential being valid, (3) policy engine compromise allowing attacker to author bypass policies, (4) audit log tampering hiding malicious access, (5) integration layer compromise providing fake identity or risk signals.

Authentication

- Employee → Cloudflare: OAuth via Bristol identity platform (Okta). The policy engine receives the authenticated principal; it does not authenticate.
- Bristol Policy System → Cloudflare API: OAuth client_credentials with rotating credentials.
- Cloudflare edge → Bristol Integration Layer: mutual TLS with Cloudflare-issued certificates rotated quarterly.
- Bristol Override Service callers: OAuth with override-specific scope; restricted client list maintained in Bristol identity platform.

Authorization

- Policy authoring: requires Bristol InfoSec policy-author role
- Policy approval: requires Bristol InfoSec policy-approver role (separate from author for separation-of-duties)
- Override capability: requires Bristol incident-response role or specific operational override roles
- Audit log read: requires Bristol audit-read role; segregated from operational roles

Data classification and handling

- Policy data: confidential; Bristol-controlled; encrypted at rest and in transit
- User identity attributes: confidential; cached briefly at Cloudflare edge with strict TTLs; never logged in plaintext
- Risk scores: confidential; cached briefly at edge; written to audit log alongside decisions
- Audit log: confidential; immutable once written; 90-day hot retention, 7-year cold retention

Encryption

- In transit: TLS 1.2+ for all interfaces; mutual TLS for Bristol-Cloudflare edge integration
- At rest: AWS KMS with Bristol-controlled keys for all Bristol-side data; Cloudflare-managed encryption for vendor-side data with Bristol audit access

Audit logging

- Every access decision generates an audit event with: timestamp, principal_id, app_id, device_id, decision, reason_code, evaluated_rule_id, source_IP, geolocation
- Events flow from Cloudflare edge → Bristol Audit Log Pipeline → Bristol SIEM → cold storage
- 5-minute end-to-end latency target; 5-minute SLA per regulator commitment
- Tamper-evident: hashed event chain with periodic root publication to Bristol's audit-evidence store

Compliance

- SOC 2 Type II: per-access logging satisfies CC6.1, CC6.6
- GLBA: customer-data access via this engine satisfies GLBA Privacy Rule §314.4(a)(3)
- State banking examiner: 5-minute audit-log latency satisfies 2026-02-15 examiner commitment

6. Observability

Metrics

- policy_evaluation_count (counter): rate of evaluation requests
- policy_evaluation_latency_p50, p95, p99: evaluation timing
- policy_decision_outcomes (counter, labeled by decision): allow vs. deny vs. challenge breakdown
- audit_log_write_latency_p95: audit log pipeline timing
- override_invocations (counter, labeled by reason): override usage tracking

Logs

- Access decision events: per-evaluation, in audit log infrastructure
- Policy update events: per-update, in policy authoring system audit log
- Override events: per-invocation, in override service audit log
- Error events: at Bristol Integration Layer; structured logs to SIEM

Traces

- End-to-end traces for a sample of access requests (1% sampling rate, 100% on errors)
- Spans capture: Cloudflare edge → Bristol identity → Bristol risk score → policy evaluation → audit log write

Alerts

- Policy evaluation P95 latency > 60ms for 5 minutes: SEV-2 to ZTNA on-call
- Policy evaluation P95 latency > 100ms for 5 minutes: SEV-1
- Audit log write latency P95 > 10 minutes: SEV-1 (5-min target with 2x cushion)
- Audit log write failure rate > 0.1%: SEV-0 (regulatory implication)
- Override invocations > 50/hour (anomaly threshold): SEV-2
- Identity dependency error rate > 0.5%: SEV-1

Dashboards

- ZTNA Policy Engine Operational: confluence link, audience: ZTNA Operations team
- ZTNA Audit Compliance: confluence link, audience: Bristol Risk and Compliance functions
- ZTNA Capacity: confluence link, audience: SRE

7. Rollout and migration

Feature flag strategy

Wave-based rollout aligned with Atlas program waves. Per-employee feature flag controls whether ZTNA is the active access path or VPN remains active. Both paths run simultaneously during transition to enable per-employee rollback.

Phased rollout plan

References ROLL Plan (Engineering Example #246) for the operational version.

- Wave 1 (45 users, IT pilot): policy engine in active use for Wave 1; VPN remains active for everyone else
- Wave 2 (1,200 users, engineering org): expanded usage; observability data informs Wave 3+
- Wave 3 (1,200 users, operations org)
- Wave 4 (1,100 users, remaining): final wave; legacy VPN decommissioned 30 days post-Wave 4

Backward compatibility

Legacy VPN remains active throughout the program for in-flight users; decommissioned only after 30-day post-Wave-4 stabilization.

Migration plan

- Per-employee migration via wave assignment
- Each employee's first ZTNA-mediated access requires re-authentication (one-time)
- Rollback capability: 60-minute rollback per employee or wave validated in pre-cutover rehearsal

8. Open questions

These were the open questions at v1.0 (2026-04-01). All are now resolved; they're preserved here for the design audit trail.

- Q-001 (RESOLVED 2026-05-01): How should Bristol risk-scoring integrate? Resolved: callback from Cloudflare edge to Bristol Integration Layer with 5-minute cache.
- Q-002 (RESOLVED 2026-05-15): What's the override authority model? Resolved: incident-response role + named operational service accounts; alerting on override frequency above threshold.
- Q-003 (RESOLVED 2026-06-10): How does audit-log archival to cold storage handle deletion-required events? Resolved: tombstone records preserved in audit log with original event referenced; cold storage handles GDPR-style deletion via key destruction.
- Q-004 (RESOLVED 2026-08-22): Is policy engine performance at 80ms P95 acceptable for Wave 1 entry? Resolved via SPADE ATLAS-SPADE-014 (yes, accepted as Wave 1 baseline; 50ms target maintained for general availability).

9. Appendices

Vendor evaluation

- ATLAS-SPADE-007: Cloudflare ZTNA selection (separate SPADE doc)

Performance benchmarks

- 2026-Q1 prototype benchmark: [confluence link to ZTNA-PERF-001](#)
- 2026-Q2 production benchmark: [confluence link to ZTNA-PERF-002](#)
- 2027 post-Atlas operational baseline: [confluence link to ZTNA-PERF-OPS-001](#)

Related design docs

- Identity Platform Integration Layer: [confluence link](#)
- Bristol Audit Log Pipeline: [confluence link](#)
- Bristol Policy Authoring System: [confluence link](#)

Sign-offs

Role	Name	Date	Status
Author	J. Liu	2026-06-15	✓ signed
Technical reviewer	Mike Tanaka	2026-06-22	✓ signed
Security reviewer	Sandra Park	2026-06-25	✓ signed
SRE reviewer	Mike Tanaka	2026-06-22	✓ signed (same person as TR)
Privacy reviewer	Bristol Privacy Of	fice 2026-06-	28 ✓ signed
Engineering manager / director	Linda Walsh	2026-07-02	✓ signed
Architecture review board	2026-07-08		✓ approved

Related artifacts

- Engineering Example #246 (ROLL Plan — ZTNA Component): the rollout plan that operationalized this design
- Engineering Example #249 (IR Plan — ZTNA Service): the IR plan covering this system in production
- Engineering Example #252 (DR Plan — Identity Platform): the DR plan covering the identity-platform foundation this system depends on
- Engineering Example #255 (SPADE — Approve UAT Entry for ZTNA Wave 1): the UAT-entry decision for this design
- Engineering Example #264 (Test Plan — ZTNA UAT): the test plan that verified this design pre-rollout

Keywords: design doc example, engineering design example, ZTNA policy engine, technical specification example, architecture document example, RFC example, populated design doc, Project Atlas design doc, security infrastructure design

Engineering Example — IR Plan — ZTNA Service (Cloud Security Operations)

Incident Response (IR) Plan — ZTNA Service

Document Control

- Service: ZTNA (Zero Trust Network Access) — Cloudflare-based, integrated with Bristol identity platform
- IR plan version: v2.1, last revised 2027-09-15 (post-Atlas operational handoff), next review 2027-12-15
- Owner: Director, Cloud Security Operations (the function that took over from Project Atlas)
- Approvers: Mike Tanaka (SRE Lead), Sandra Park (CISO), Robert Stein (CRO for compliance review)

1. Scope

This IR plan covers

- ZTNA policy engine and policy evaluation pipeline
- ZTNA client (employee endpoint software)
- ZTNA-to-identity-platform integration (authentication and conditional access)
- ZTNA audit log pipeline (writes to SIEM)
- Cloudflare ZTNA control plane (vendor-managed; this plan covers Bristol's interfaces and observability)

This IR plan does NOT cover

- The underlying identity platform itself (see Identity Platform IR plan, owned by IAM team)
- Cloudflare's underlying infrastructure (vendor-managed; vendor IR plan applies; Bristol monitors via vendor status page)
- Customer-facing application authentication (per-application IR plans)

Dependencies (services this depends on)

- Identity Platform (Okta Identity Cloud) | IR plan: link to Identity IR
- DNS (Bristol internal DNS) | IR plan: link to Network IR
- Cloudflare ZTNA control plane | Vendor IR: Cloudflare status + escalation path

Dependents (services that depend on this)

- All 47 internal applications behind ZTNA
- All 3,500 employee endpoints
- 5 customer-facing applications that use ZTNA-mediated employee access for support

2. Severity classification

Severity	Definition	Threshold	Time-to-ack
SEV-0	Critical: ZTNA service unavailable; employees cannot access internal applications; or audit log gap (regulatory impact)	- ≥ 25% of users unable to authenticate - Audit log write failure > 5 min duration - Active security incident in ZTNA	< 5 min
SEV-1	Major: significant ZTNA degradation	- 5-25% authentication failure rate - P95 latency > 1.5 sec (vs. 30ms baseline) - Single application or department fully blocked	< 15 min
SEV-2	Significant: localized issues	- < 5% authentication failure rate - Single user/team affected (5-50 people) - Performance degradation to 3-5x baseline	< 30 min
SEV-3	Minor: low impact, manual handling acceptable	- Single user issues, < 5 people - Cosmetic/UX issues - Documentation drift	< 4 hrs (business hours)

Example scenarios from actual incidents

SEV-0: 2027-08-17 03:42 — During Wave 4 cutover, ZTNA policy engine returned errors for 8 minutes affecting ~200 newly-cutover users. Resolved by failover; PIR done; lessons logged. (See PIR #ATLAS-PIR-W4-03)

SEV-1: 2027-09-22 11:14 — Conditional access policy update misconfigured; blocked 35 marketing-team users for 23 minutes.

SEV-2: 2027-10-03 14:30 — Three users in Singapore office unable to authenticate due to local DNS caching; resolved by client cache flush.

3. On-call structure

Primary on-call: ZTNA Operations team rotation (5 engineers, 1 week per rotation, currently J. Liu's former team after Atlas handoff)

Secondary on-call: ZTNA Operations team next-in-rotation

Tertiary / escalation: Director, Cloud Security Operations (current: D. Reyes)

Paging tool: PagerDuty (link to ZTNA service in PD)

Primary acknowledgment SLA: 5 minutes for SEV-0/SEV-1; 15 minutes for SEV-2; 4 hours business hours for SEV-3

Auto-escalation if primary doesn't ack within 5 min: page secondary; if secondary doesn't ack within 5 min: page tertiary

Coverage gaps

- Weekends: full coverage (SLA applies 24/7 for SEV-0/SEV-1)
- Holidays: full coverage; rotation-holder paid extra
- Time zones: primary follows London business hours; SEV-0/SEV-1 globally cause paging regardless of time

4. Roles during an incident

For SEV-0 and SEV-1, these roles are filled by different people:

Incident Commander (IC)

- Default: most-senior ZTNA Operations engineer on-call
- Authority: coordinates response, makes decisions about declaring rollback or extended response
- Hand-off: if incident extends beyond 8 hours, IC transitions per IC handoff protocol

Communications Lead

- Default: ZTNA Operations team lead during business hours; on-call SRE lead off-hours
- Authority: signs off on all customer/regulator/internal communications
- Pre-drafted message library: confluence link

SMEs

- Engaged based on incident type:
- Authentication issues → ZTNA engineering + Identity engineering
- Policy issues → ZTNA engineering + InfoSec policy team
- Vendor-side issues → SRE + Cloudflare TAM
- Audit log issues → ZTNA engineering + SIEM team

Scribe

- Default: junior on-call engineer or designated note-taker
- Output: incident timeline in Confluence, action item list

For SEV-2/SEV-3: single engineer can hold IC + SME; Comms Lead role compressed.

5. Communication protocols

Internal communications

Channel: #incident-ztna Slack (created on incident declaration)

Status updates cadence:

- SEV-0: every 30 min until SEV downgraded
- SEV-1: every 60 min
- SEV-2/3: as needed, minimum every 4 hours

Leadership notification:

- SEV-0: Sandra Park (CISO) + Linda Walsh (CIO) within 15 min via page + call
- SEV-1: D. Reyes (Cloud Sec Ops Director) within 30 min via page; CISO at 4-hour mark if unresolved
- SEV-2: D. Reyes within 4 hours via Slack
- SEV-3: weekly aggregate report

External communications (customer-facing)

Status page: status.bristol-financial.com (Atlas section + general)

Trigger thresholds:

- SEV-0: status page entry within 15 min of declaration; customer-facing email if any of the 5 dependent customer apps are affected (within 30 min)
- SEV-1: status page within 30 min if customer-facing app affected
- SEV-2/3: status page only if customer-facing app affected and resolution > 1 hour

Pre-drafted message templates

- SEV-0 ZTNA outage: confluence link
- SEV-0 ZTNA breach: confluence link (additional General Counsel review required)
- SEV-1 partial degradation: confluence link
- Customer notification (per-app variants): confluence link

Regulatory communications

Regulators: State banking examiner; GLBA examiner

Notification SLA per regulator

- State banking: within 24 hours of any incident with customer-data exposure or audit-log gap > 1 hour
- GLBA: within 72 hours of any incident with customer-PII exposure

Notification authority: Robert Stein (CRO); General Counsel co-signs

Format: formal letter via certified mail; e-filed via examiner portal

6. Escalation paths

Trigger	Notify	Within	Channel
SEV-0 declared	Sandra Park (CISO) + Linda Walsh (CIO)	15 min	Page + call
SEV-1 declared	D. Reyes (Cloud Sec Ops Director)	30 min	Page
SEV-1 unresolved at 4 hours	Sandra Park (CISO)	immediate	Call
Security implications (any severity)	Sandra Park (CISO)	immediate	Page
Data loss or breach (any severity)	Sandra Park + General Counsel + Robert S	tein (CRO) 15 m	in Call
Regulatory implication (any severity)	Robert Stein (CRO) + General Counsel	30 min	Call
Customer-impacting (any severity)	VP Customer Success	30 min	Slack
Audit log gap > 5 min (regulatory implication automatic)	Robert Stein (CRO) + General Counsel	immediate	Page

Trigger	Notify	Within	Channel
Media or public exposure	Communications team + General Counsel	immediate	Call

7. Response runbooks

Incident type	Runbook	Last reviewed	Last drilled
ZTNA full outage	confluence link to ZTNA-RUN-001	2027-09-15	2027-09-22 (game day)
ZTNA partial outage	confluence link to ZTNA-RUN-002	2027-09-15	2027-09-22 (game day)
Conditional access policy misconfig	confluence link to ZTNA-RUN-003	2027-08-30	2027-09-22 (game day)
Audit log pipeline failure	confluence link to ZTNA-RUN-004	2027-09-01	2027-09-22 (game day)
Suspected ZTNA-mediated breach	confluence link to ZTNA-RUN-005	2027-08-15	Quarterly tabletop 2027-09-30
Cloudflare control plane outage	confluence link to ZTNA-RUN-006	2027-09-01	Vendor-led drill 2027-08-15
Identity platform dependency failure	confluence link to ZTNA-RUN-007	2027-09-15	2027-09-22 (cross-team game day)

8. Post-incident review (PIR) trigger

PIR required for

- All SEV-0 incidents
- All SEV-1 incidents
- Any SEV-2 with regulatory or customer-impact implications
- Optional for SEV-2/SEV-3 by IC discretion

PIR timeline: within 5 business days of incident closure

Facilitator: Cloud Security Operations Director (or designate)

Attendees: IC, Comms Lead, SMEs, Service Owner, Sandra Park for SEV-0, Robert Stein for any with regulatory implication

Output: Post-Incident Review document (see Examples #211 for the 11/18 Authentication Outage PIR — same format)

Findings tracking: PIR action items logged to Cloud Security Operations function backlog with named owner, target date, status; tracked weekly in operations standup until closed

9. Plan maintenance

Review cadence: Quarterly (next: 2027-12-15)

Triggered review: After every SEV-0 or SEV-1 incident; after major service change; after significant infrastructure change

Owner: D. Reyes (Cloud Security Operations Director)

Version history

v2.1 2027-09-15 — Operational handoff from Atlas program; added vendor coordination protocols

v2.0 2027-09-01 — Pre-handoff draft; updated severity criteria post-Wave 4 incident learnings

v1.0 2027-01-15 — Initial draft during Atlas program build phase

Related artifacts

- Operating Model #153 (Cloud Security Operations): the operational ownership context for this plan
- Comms Plan #134: crisis & escalation section coordinates with this IR plan
- ROLL Plan (Engineering Example #E1): the Wave 4 cutover ROLL plan that referenced this IR plan
- Post-Incident Review (Examples #211): real PIR using this plan's structure (11/18 Authentication Outage)
- RAID Log (Artifact #11): risks identified through PIRs feed back into the program/operational risk register

Keywords: IR plan example, incident response plan example, ZTNA incident response, on-call rotation example, severity classification example, escalation path example, post-incident review trigger, populated IR plan, Project Atlas IR plan, Cloud Security Operations IR plan

Engineering Example — PRD — Bristol Customer-Facing MFA Self-Service Portal

Product Requirements Document (PRD) — Bristol Customer-Facing MFA Self-Service Portal Document Control

- Product / feature: Customer MFA Self-Service Portal (added to bristol-financial.com customer experience)
- PRD version: v2.1, last revised 2027-11-15, next review 2027-12-15
- Author: A. Park (Product Manager, Bristol Customer Experience)
- Contributing reviewers: J. Hsu (Design Lead, Bristol Digital), J. Liu (Engineering Lead, post-Atlas — owns ZTNA platform), Casey Morrison (TPM, Bristol Customer Experience)
- Approvers: Customer Experience VP — A. Sundararajan; Engineering Director — D. Reyes (Cloud Security Operations); Robert Stein (CRO — for compliance review); Sandra Park (CISO — for security review); Bristol Legal — General Counsel office
- Target launch: 2028-Q1, soft launch (5% traffic) February 2028, full availability March 2028

1. Problem and users

Problem statement

Bristol customers cannot manage their own multi-factor authentication methods. Today, customers wanting to add a new MFA method (e.g., enrolling a security key when they get a new phone), swap their authenticator app (when changing phones), or remove a stale MFA method must call Bristol customer support. Customer support data from the 2027 post-Atlas year shows that MFA-related contacts represent 47% of authentication-related support volume — approximately 8,400 contacts per month. Average handle time is 11 minutes per contact, primarily because the customer cannot complete the change themselves and the support agent must guide them through Bristol's identity platform admin tools.

Beyond the support cost, customer feedback consistently flags the experience as poor: customers expect modern self-service for their own security settings, and Bristol's current process feels dated relative to peer financial-services experiences. Net Promoter Score data segmented by recent-MFA-contact shows a 22-point NPS depression for customers who needed MFA support in the prior 90 days.

Affected users

- Primary: Bristol Treasury Portal customers (8,200 active users) and Bristol Wealth Portal customers (3,800 active users) — total 12,000 — currently subject to support-call-only MFA management
- Secondary: Bristol customer support agents (80 agents) — currently spending ~370 hours per month on MFA-related contacts
- Tertiary: Bristol IT operations team — receives Tier 2 escalations from customer support for non-routine MFA cases

Why now

Three drivers converge: (1) post-Atlas, the underlying identity platform now supports the API surface needed for self-service (this was not true pre-Atlas; it's a direct enabler from program completion); (2) the 2027 SOC 2 audit recommended self-service capability for customer-managed authentication as part of customer agency-of-self controls; (3) two of Bristol's three peer institutions launched comparable capabilities in 2027, putting Bristol behind market on a customer-visible feature.

2. Goals and non-goals

Goals

1. Reduce MFA-related customer support contacts by at least 60% within 90 days of full availability (baseline: 8,400/month → target: 3,360/month or fewer)
2. Achieve customer-segment NPS lift of at least 15 points among customers who use the self-service portal vs. those who continue to use support
3. Maintain or improve security posture: zero increase in fraudulent MFA changes attributable to self-service vs. support-mediated changes

Non-goals

- This work does NOT change Bristol's MFA methods or policies (FIDO2 keys, authenticator apps, SMS as backup remain the same; what's changing is who can manage them, not what they are)
- This work does NOT extend to employee MFA management (employees use the internal Bristol identity tools — covered by Operating Model #153)
- This work does NOT redesign the Bristol Treasury Portal or Wealth Portal sign-in experience overall — only the MFA management surface within those portals
- This work does NOT support managed-account scenarios where customers have a Bristol-assigned account manager — those customers continue to engage their account manager for MFA changes (high-touch by design)
- This work does NOT extend to Bristol's commercial-banking customer base — that customer segment has different security and identity requirements; a separate PRD will scope that work in 2028-Q3

Success will be measured by

- Lead indicator: portal usage rate among MFA-related actions (target: ≥80% of MFA changes go through self-service after full launch)
- Lag indicator: 90-day MFA-related support contact volume (target: ≤3,360/month, down from 8,400/month baseline)

3. User experience

User flows

Reference: design files at design.bristol-financial.com/projects/mfa-self-service (J. Hsu, design lead)

Key user flows:

1. Add a new MFA method (security key, authenticator app, SMS backup): 4 screens

2. Set a primary MFA method: 2 screens
3. Remove an existing MFA method: 3 screens (with explicit confirmation)
4. View MFA method history: 1 screen
5. Recover access when primary method is lost: 5 screens (this flow has additional security checks)

Key screens

- Customer dashboard MFA section (entry point; shows current methods at a glance with management actions)
- Add-method flow (per-method-type variants)
- Remove-method confirmation (with friction: explicit confirmation including reason for removal, used for fraud detection)
- Recovery flow (combines knowledge factors + Bristol identity verification with stricter rate limiting)

Edge cases

- Customer attempts to remove their last/only MFA method: blocked; cannot leave account without MFA
- Customer attempts to add an MFA method while signed in via a different MFA method that's flagged as compromised: blocked; routed to support
- Customer attempts to make changes from a device flagged as suspicious by Bristol's risk scoring: routed to support with explanation
- Customer experiences a change-flow timeout: progress is saved; can resume within 24 hours; after 24 hours, restart required

4. Functional requirements

User-facing requirements

- F-001: Customers can view all their currently-enrolled MFA methods including method type, enrollment date, last-used date, and primary status
- F-002: Customers can add a new MFA method of any supported type (FIDO2 security key, authenticator app, SMS backup), provided they have at least one existing valid MFA method to authenticate the change
- F-003: Customers can designate which of their MFA methods is primary
- F-004: Customers can remove an MFA method, provided removal does not leave them with zero valid methods, and provided they pass an explicit confirmation flow
- F-005: Customers can view their MFA method history (additions, removals, primary changes) for the last 365 days
- F-006: Customers can initiate access recovery when they have lost their primary MFA method, with the recovery flow including knowledge factors and Bristol identity verification
- F-007: All MFA management actions require successful authentication via an existing valid MFA method (not just the customer's password)
- F-008: All MFA management actions are confirmed via an out-of-band notification (email + SMS to the registered backup) so that any change a customer didn't initiate is immediately visible to them

Internal/admin requirements

- F-101: All MFA management actions write to the Bristol identity audit log with full attribution (customer ID, action type, source IP, device fingerprint, geolocation if available, timestamp)

- F-102: Bristol customer support has read-only visibility into a customer's MFA history when supporting that customer (with explicit customer consent recorded in the support session)
- F-103: Bristol fraud operations has alerting on MFA-management patterns indicative of account takeover (e.g., MFA method change from a new device + new geolocation + within 30 days of password change)
- F-104: Bristol risk scoring system can flag a customer's account in a state that requires support-mediated MFA changes (overrides self-service)

5. Non-functional requirements

Performance

- P95 page load < 1.5s on 4G mobile for all MFA management screens
- P95 action completion (e.g., add method, remove method) < 4s including out-of-band notification dispatch

Scalability

- Must support 12,000 active customers with concurrent peak usage of up to 800 simultaneous MFA management sessions (modeled on observed customer-portal usage peaks)
- Underlying identity platform calls must not exceed Bristol's existing rate-limit envelope with the platform

Security

- All MFA management changes authenticated via existing valid MFA (not password alone)
- Out-of-band notification to email + SMS for every change
- Audit log retention 7 years (matches Bristol's customer-data retention policy)
- Conforms to NIST SP 800-63B for authentication assurance level (AAL2 minimum)
- Conforms to Bristol's GLBA and SOC 2 Type II controls
- Risk-scoring integration: customers flagged as elevated risk are routed to support, not self-service
- Recovery flow conforms to FFIEC guidance on customer authentication recovery

Availability

- 99.9% availability target (matches Bristol customer-portal SLA)
- Maintenance windows align with existing Bristol customer-portal maintenance windows
- Identity-platform dependency: this feature is unavailable when the identity platform is unavailable (a Tier 1 system per the DR plan); customer messaging must communicate this clearly

Accessibility

- WCAG 2.1 Level AA conformance for all customer-facing screens
- Screen-reader compatibility for all flows including the recovery flow
- Support for keyboard-only navigation
- Support for Bristol's customer-accessibility-options panel (large text, high contrast)

Internationalization

- Launch: English (US) only
- Phase 2 (post-launch, 2028-Q3): Spanish (US) — already on Bristol's customer-portal roadmap
- Locale-aware date/time formatting in MFA history view
- Timezone handling: Bristol customer accounts are stored with customer-stated timezone; MFA action timestamps are displayed in customer's stated timezone with optional UTC equivalent

6. Dependencies and integrations

Internal dependencies

- Bristol identity platform (Cloud Security Operations function — D. Reyes) — provides the API surface for MFA management. API contract finalized 2027-10-30. Identity platform has confirmed capacity allocation for projected portal load.
- Bristol customer-portal platform (Bristol Customer Experience engineering) — provides the embedding surface where the MFA self-service screens live. UX-shell integration agreement finalized 2027-11-01.
- Bristol fraud operations system — provides the risk-scoring signal that determines whether a customer is eligible for self-service or routed to support. Integration test environment available 2027-12-15.
- Bristol audit log infrastructure — receives MFA management events. Schema finalized 2027-11-10.

External dependencies

- FIDO2 security key vendor (Yubico) — already integrated for Bristol employees via Atlas; same API surface usable for customer-facing flow with minimal changes
- SMS provider (Twilio) — already integrated for Bristol customer notifications
- Authenticator app: standard TOTP (RFC 6238); no vendor-specific dependency

Integrations

- Bristol identity platform API: documented at api-docs.bristol-financial.com/identity (v3.2)
- Bristol risk-scoring API: documented at api-docs.bristol-financial.com/risk (v2.0)
- Bristol customer-portal embed contract: documented at design.bristol-financial.com/projects/portal-embed

What depends on this

- Bristol customer support tooling will be updated to reduce MFA-related volume; staffing model will be re-baselined 90 days post-launch (Customer Experience VP)
- Bristol's customer marketing team plans to feature the self-service capability in 2028-Q2 marketing
- The 2028-Q3 commercial-banking PRD will reference this customer-facing pattern for design consistency

7. Risks and open questions

Risks

- R-001: Increase in fraudulent MFA changes if attacker compromises an existing MFA method | Likelihood M | Impact H | Mitigation: out-of-band notification + risk-scoring flag for support-routing + 24-hour change-history visibility for customers
- R-002: Customer confusion in recovery flow leads to abandonment and contact-volume increase rather than decrease | Likelihood M | Impact M | Mitigation: usability testing in Phase 1 with 30 customers; iterative refinement; recovery flow KPI in 90-day review
- R-003: Identity platform capacity headroom insufficient for projected load | Likelihood L | Impact H | Mitigation: capacity validated 2027-11-15 with Cloud Security Operations; load test scheduled 2028-01-15
- R-004: Accessibility regression vs. existing support-mediated flow | Likelihood L | Impact M | Mitigation: WCAG audit by Bristol accessibility team in Phase 1; remediation tracked to launch readiness
- R-005: Regulatory interpretation issue on customer authentication recovery | Likelihood L | Impact H | Mitigation: General Counsel + CRO review of recovery flow; FFIEC guidance interpretation documented in dedicated SPADE

Open questions

- Q-001: Should we offer "passkey" as a Phase 1 method type, or defer to Phase 2 as a separate addition? | Owner: A. Park (PM) + J. Hsu (Design) | Target resolution: 2027-12-01
- Q-002: What's the right friction level for the "remove an MFA method" flow? Aggressive friction (multi-step confirmation + 24-hour cooldown) protects against account takeover but may push customers back to support. | Owner: A. Park + Bristol fraud operations | Target resolution: 2027-12-15 after usability testing
- Q-003: Should support agents have the ability to initiate self-service flow on behalf of the customer (assisted self-service) or is this an anti-pattern that re-creates the volume issue we're trying to solve? | Owner: A. Park + Customer Experience VP | Target resolution: 2027-12-08

8. Success metrics and tracking

Lead indicators (measured during launch and stabilization)

- Self-service portal adoption rate (% of MFA actions via self-service vs. support) | Baseline 0% | Target 80%+ at full availability
- Self-service flow completion rate (% of started flows that complete successfully) | Baseline n/a | Target 92%+
- Self-service flow time-to-complete (median across flow types) | Baseline n/a | Target <3 minutes for routine actions, <8 minutes for recovery

Lag indicators (measured 30/60/90 days post-launch)

- MFA-related support contact volume | Baseline 8,400/month | Target ≤3,360/month at 90 days post-full-launch (60% reduction)
- NPS lift for self-service users vs. support-mediated users | Baseline NPS-22 for support-mediated | Target +15 NPS for self-service users
- Fraud rate on MFA changes via self-service vs. support-mediated | Baseline n/a | Target ≤support-mediated rate
- Customer agent productivity (contacts/hour for non-MFA volume) | Baseline x | Target +12% as MFA volume reduces

Review cadence

- 30-day post-launch review: 2028-04-15 (assumes March 2028 full availability) | Attendees: A. Park, A. Sundararajan, J. Liu, Casey Morrison, customer support ops lead, fraud ops lead
- 60-day post-launch review: 2028-05-15
- 90-day post-launch review: 2028-06-15 — primary milestone for measuring contact-volume reduction

Tracking instrumentation

- Bristol customer-portal analytics dashboard: dashboard.bristol-financial.com/customer-experience/mfa-portal
- Bristol identity-platform metrics: integrated into Cloud Security Operations function dashboards
- Bristol fraud-operations dashboard: continuous monitoring with monthly review of MFA-fraud signals

Sign-offs

Role	Name	Date	Status
PM owner	A. Park	2027-11-15	✓ signed
Engineering owner	D. Reyes	2027-11-18	✓ signed

Role	Name	Date	Status
Design owner	J. Hsu	2027-11-16	✓ signed
Legal	Bristol Legal	2027-11-22	✓ signed
Security	Sandra Park (CISO)	2027-11-20	✓ signed
Compliance / Risk	Robert Stein (CRO)	2027-11-22	✓ signed
Stakeholder: Customer Exp VP	A. Sundararajan	2027-11-23	✓ signed
Stakeholder: Customer Support	[Support Ops Lead]	2027-11-19	✓ acknowledged
Stakeholder: Fraud Ops	[Fraud Ops Lead]	2027-11-21	✓ acknowledged

Related artifacts

- Engineering Example #261 (Design Doc — Customer MFA Self-Service): the engineering technical design for this PRD
- Engineering Example #264 (Test Plan — Customer MFA Self-Service): the test plan for this PRD's requirements
- Operating Model #153 (Cloud Security Operations): provides the identity platform foundation this PRD builds on
- IR Plan (Engineering Example #249): customer-impacting incidents involving this feature route through this IR plan
- DR Plan (Engineering Example #252): identity platform DR plan applies to this customer-facing capability

Keywords: PRD example, product requirements document example, customer MFA self-service, customer authentication management, populated PRD, Bristol customer experience, post-Atlas product feature, financial services PRD example

Engineering Example — ROLL Plan — ZTNA Component (Project Atlas)

ROLL Plan — ZTNA Component (Project Atlas)

Document Control

- Component: ZTNA Rollout (Project Atlas component #2)
- ROLL plan version: v3.2, last revised 2027-04-10, next review 2027-05-15
- Owner: J. Liu (ZTNA Component Lead)
- Approvers: Sandra Park (CISO, sponsor); Mike Tanaka (SRE Lead); Sandra Park (Security — same person, same role here); Robert Stein (CRO, for compliance sign-off)
- Target rollout window: Wave 4 final cutover August 17, 2027 (overnight 1:00 AM - 6:00 AM ET)
- Anchor event: Wave 4 IDP final cutover (program-completing event)

1. Scope and target state

What's being rolled out

Final wave (Wave 4) of ZTNA migration: 1,100 remaining employees move from legacy VPN to Cloudflare ZTNA + new identity platform. Decommissions the legacy VPN concentrator pair (LON-VPN-01, LON-VPN-02). Completes program-wide ZTNA coverage across all 3,500 employees and 47 internal applications.

Post-rollout target state

- All employee access to internal applications is via ZTNA (no VPN client required)
- Legacy VPN concentrators decommissioned and identity records archived
- Continuous device verification active for all access
- Conditional access policies applied based on device posture and user risk score
- Audit-ready access logs flowing to SIEM (90-day retention, examiner-accessible)

Out of scope

- Customer-facing applications (handled separately by per-app product teams)
- Vendor and contractor access (separate program scheduled Q4 2027)
- Mobile device-only access (already migrated in Wave 2)
- API-to-API service access (handled by service-mesh program, not Atlas)

2. Rollout strategy

Strategy type: Wave-based (program convention from Waves 1-3); within Wave 4, ring-based deployment by employee risk profile.

Phasing within Wave 4

- Phase 1 (Wave 4-A, T-0 1:00 AM): IT team and Atlas core team — 45 users. Self-validation cohort.
- Phase 2 (Wave 4-B, T-0 1:30 AM): Engineering org (excluding identity/security teams) — 380 users. Most technically-fluent population for early issue surfacing.
- Phase 3 (Wave 4-C, T-0 2:30 AM): Operations, support, customer-facing teams — 425 users. Higher business-impact cohort.
- Phase 4 (Wave 4-D, T-0 4:00 AM): Executive office, legal, finance, HR, and remaining functions — 250 users. Lowest tolerance for disruption, latest in window.

Cohort selection criteria

- Phase 1: voluntary opt-in from Atlas team plus IT operations
- Phase 2: department code in (ENG, INFRA, DATA, AI) excluding (SEC, IDM)
- Phase 3: department code in (OPS, SUP, CS, FIELD)
- Phase 4: all remaining Wave 4 employees

Geographic phasing

Cutover happens globally during the same overnight window (1:00 AM - 6:00 AM ET = 6 AM - 11 AM London = 2 PM - 7 PM Singapore). London office (180 of 1,100 Wave 4 users) and Singapore office (35 users) are observed throughout for time-zone-specific issues.

3. Pre-rollout gates

Gate	Criteria	Owner	Status
Test pass	All P0/P1 ZTNA-Wave4 test cases passing in stage	J. Liu	✓ confirmed 2027-04-08
Observability ready	ZTNA cutover dashboard live; 12 alerts active	Mike Tanaka	✓ confirmed 2027-04-12
Runbooks published	Cutover-day runbook + IR runbook on intranet	Casey Morrison	✓ confirmed 2027-04-15
Support trained	Support staff trained, FAQ live, 80 staff at 95%	R. Patel	✓ confirmed 2027-04-30
Rollback validated	Rehearsed in non-prod 2027-03-22; 47 min	Mike Tanaka	✓ confirmed 2027-03-25

Gate	Criteria	Owner	Status
	duration		
Comms sent	T-90, T-60, T-30 employee comms sent on schedule	R. Patel	✓ confirmed via Comms Plan
Compliance sign-off	Robert Stein (CRO) approved 2027-04-12	Robert Stein	✓ confirmed 2027-04- 12
Pre-cutover rehearsal	Full T-3 rehearsal (Aug 14)	J. Liu	[] scheduled
Final go/no-go	T-1 review (Aug 16, 4:00 PM ET)	Sandra Park	[] scheduled

4. Per-phase plan

Phase 1: Wave 4-A (IT + Atlas core)

- Cohort: 45 users, voluntary opt-in
- Start: 2027-08-17 1:00 AM ET
- Observation period: 30 minutes
- Success criteria:

* Sign-in success rate $\geq 98\%$ (vs. baseline 99.4%)

* No P0 incidents

* No more than 2 user-reported issues

- Decision point: 2027-08-17 1:30 AM ET
- Decision authority: J. Liu (with Casey Morrison and Sandra Park notified)
- Decision options: Proceed to Phase 2 / Hold for 30 more min / Abort per Section 7

Phase 2: Wave 4-B (Engineering, 380 users)

- Cohort: ENG, INFRA, DATA, AI departments excluding SEC, IDM
- Start: 2027-08-17 1:30 AM ET
- Observation period: 60 minutes
- Success criteria:

* Sign-in success rate $\geq 98\%$ (rolling)

* Support ticket volume < 30 in window

* No P0 incidents; ≤ 1 P1 incident with mitigation in flight

- Decision point: 2027-08-17 2:30 AM ET
- Decision authority: J. Liu (with sponsor escalation if soft-abort triggered)

Phase 3: Wave 4-C (Operations + Customer-facing, 425 users)

- Cohort: OPS, SUP, CS, FIELD departments
- Start: 2027-08-17 2:30 AM ET
- Observation period: 90 minutes
- Success criteria:

* Sign-in success rate $\geq 98\%$

* Support ticket volume < 60 in window

* No P0 incidents; ≤ 2 P1 incidents

- Decision point: 2027-08-17 4:00 AM ET

- Decision authority: J. Liu (sponsor approval required to proceed if any P1 issues unmitigated)

Phase 4: Wave 4-D (Executive + remaining functions, 250 users)

- Cohort: All remaining Wave 4 employees
- Start: 2027-08-17 4:00 AM ET
- Observation period: continues through end of cutover window (2 hours)
- Success criteria:

* Sign-in success rate $\geq 98\%$

* Support ticket volume tracking against forecast (< 200 cumulative for cutover window)

- Decision point: 2027-08-17 6:00 AM ET (cutover window close)
- Decision authority: J. Liu confirms; Casey Morrison and Sandra Park co-sign cutover-complete declaration

5. Success metrics

Metric	Baseline	Acceptable range	Post-rollout target
Sign-in success rate	99.4%	$\geq 98\%$ during cutover	$\geq 99.5\%$
Sign-in P95 latency	420ms	$< 700\text{ms}$ during cutover	$r < 350\text{ms}$
Support tickets/hour (cutover window)	18 (normal)	$< 200/\text{hour}$	$< 25/\text{hour}$ by T+7
ZTNA policy evaluation P95	(new metric)	$< 50\text{ms}$	$< 30\text{ms}$ by T+7
Cumulative cutover-window issues	n/a	< 50 P2/P3 total	< 10 P2/P3 backlog at T+7
Wave 4 satisfaction (T+30 survey)	(new metric)	$\geq 70\%$ positive	$\geq 75\%$ positive

6. Abort criteria

Hard aborts (automatic rollback, no human decision required)

- Sign-in success rate drops below 90% in any 5-minute window
- ZTNA policy engine becomes unresponsive (P0 incident on policy evaluation)
- Identity audit log pipeline fails (loss of audit-trail continuity = regulatory issue)
- Customer-facing application authentication impacted (cross-program impact)

Soft aborts (rollback after human review by J. Liu, with Sandra Park escalation)

- Support ticket volume exceeds 300/hour for two consecutive hours
- More than 5 user-reported P1 issues with no mitigation in flight
- Phase 3 success criteria not met (signal that broader population sees something Phase 1-2 didn't)
- Rollback rehearsal-validated procedure starts encountering unexpected steps (signal of drift between rehearsal and actual)

Sponsor escalation triggers (Sandra Park notified within 15 minutes; rollback decision held pending her approval)

- Any unplanned customer-facing impact
- Any apparent regulatory implication (e.g., audit log gap > 5 minutes)
- Media or external attention to the cutover

7. Rollback procedure

Trigger authority: J. Liu (component lead) for soft aborts; Mike Tanaka (SRE Lead) automatic for hard aborts; Sandra Park (sponsor) override available

Rollback execution time: 47 minutes (validated in 2027-03-22 rehearsal)

Mechanical steps

1. Pause new ZTNA policy evaluations (DNS-level cutoff)
2. Revert identity provider to pre-cutover state (restore from snapshot taken at T-1 hour)
3. Re-enable legacy VPN concentrator pair (LON-VPN-01, LON-VPN-02 standby state)
4. Force re-authentication for all in-flight sessions
5. Status page updated: "Authentication maintenance experiencing issues; legacy access restored. Investigating."
6. Validation: ten test users sign in via legacy path; if all succeed, rollback declared complete; if any fail, escalate to crisis comms (Tier 3)

Data handling during rollback

- Audit logs from cutover window preserved separately for incident review (regulatory requirement)
- User-level access changes from cutover window are reverted to pre-cutover state; no data loss expected
- New identity records (FIDO2 key associations, etc.) are preserved for re-cutover

User notification during rollback

- All Wave 4 employees: email within 30 minutes of rollback decision
- Customers (only if their authentication was impacted): per-app email + status page update
- Regulators: telephone notification to CRO Robert Stein within 30 min if rollback triggers audit-log gap or customer impact; formal letter follow-up within 24 hours

Validation

Rollback procedure rehearsed 2027-03-22 in non-prod environment that mirrors prod scale. Result: 47-minute completion (within 60-minute target). Three minor procedural updates made post-rehearsal and incorporated into v3.2 of this plan.

Re-attempt criteria

- Root cause of triggering issue identified and remediated
- Mike Tanaka and J. Liu jointly confirm SRE and engineering readiness
- Sandra Park approves re-attempt window
- Earliest re-attempt: 14 days after rollback (allows for proper RCA and re-rehearsal)

8. Post-rollout closure

Final metrics review at: 2027-09-16 (T+30) — see T+30 entry in Comms Plan

Steady-state monitoring transition: 2027-09-01 — Cloud Security Operations function takes ZTNA monitoring ownership (per Operating Model #153)

Runbook update: 2027-09-01 — runbook lessons from cutover incorporated

Lessons captured to: Lessons Learned Register Atlas-LL-W4-* entries

Sign-offs

Role	Name	Date	Status
Component owner	J. Liu	2027-04-10	✓ signed
Program PM	Casey Morrison	2027-04-12	✓ signed
Sponsor	Sandra Park	2027-04-12	✓ signed

Role	Name	Date	Status
SRE/Ops Lead	Mike Tanaka	2027-04-15	✓ signed
CRO (compliance)	Robert Stein	2027-04-12	✓ signed
Steering committee acknowledgm	ent 2027-04-15		✓ recorded in Decisions Log Atlas- DC-098

Related artifacts

- Comms Plan (#134): user-facing communications coordinating with each rollout phase
- Test Plan (Engineering Example #E7): UAT test results that closed Phase-1 readiness gates
- Decision & Changes Log (Artifact #19): Atlas-DC-098 (Wave 4 rollout strategy approval)
- Recovery Plan (Examples #217): the plan that established the Wave 4 cutover discipline
- IR Plan (Engineering Example #E2): the IR plan that handles any incident triggered during cutover

Keywords: ROLL plan example, rollout plan example, ZTNA rollout, Wave 4 rollout, phased rollout example, ring deployment example, abort criteria example, rollback procedure example, Project Atlas ZTNA cutover, populated rollout plan

Engineering Example — SPADE — Approve UAT Entry for ZTNA Wave 1

SPADE Decision Document — Approve UAT Entry for ZTNA Wave 1

Document Control

- Decision title: Approve UAT entry for ZTNA Wave 1 (Project Atlas component #2)
- SPADE ID: ATLAS-SPADE-014
- Status: Approved
- Author: J. Liu (ZTNA Component Lead)
- Reviewer: Mike Tanaka (SRE Lead)
- Decision authority: Sandra Park (CISO, Project Atlas sponsor)
- Date drafted: 2026-08-15
- Date approved: 2026-08-22
- Supersedes: none

Cross-reference: This decision is also captured in the Project Atlas RACI walkthrough (Examples #152 — RACI — One Decision In Practice) showing the role-and-responsibility view; this SPADE captures the rationale-and-evidence view of the same decision.

1. Story

What's been happening

ZTNA Wave 1 (Bristol IT pilot, 45 users) has been in stage testing for 5 weeks. The original plan was 3 weeks of stage testing, then UAT with 200 users from the friendly-customer cohort, then production cutover. Stage testing surfaced two material issues: (1) policy engine evaluation latency at P95 of 180ms vs. our 50ms target — too slow for the user experience the program promised, (2) a conditional access edge case where users on managed iPads got blocked from internal apps when corporate VPN was simultaneously connected. Both issues have been mitigated in the latest stage build (week 5 testing): policy engine is at P95 80ms (still above target but acceptable for Wave 1), and the iPad/VPN edge case is resolved with a network-routing fix.

The question is whether to enter UAT now or extend stage testing further. The pressure to enter UAT comes from program timeline (Wave 1 is on critical path; a 2-week delay slips the program), from the friendly-customer cohort (we've coordinated their availability for August 25; if we miss it, next window is October), and from sponsor expectations (board update October 15 will flag program slippage if Wave 1 isn't in UAT by then). The pressure to extend stage testing comes from the residual policy engine performance (still above target), from one tester reporting an unrelated authentication anomaly (low frequency, root cause unclear), and from operational caution (this is the foundation component; getting it wrong cascades).

Who's been involved

- J. Liu (ZTNA Component Lead) — driving the decision
- Mike Tanaka (SRE Lead) — operational risk perspective
- Sandra Park (CISO) — sponsor authority
- M. Ortiz (IDP Migration Component Lead) — dependency owner; ZTNA depends on IDP migration being stable
- Casey Morrison (Program PM) — program-level coordination, RAID owner
- 3 friendly-customer security leads — UAT cohort availability

What's been tried, considered, or assumed

- We've extended stage testing twice already (originally 3 weeks → 4 → 5)
- We've considered scoping down Wave 1 (reducing from 45 users to 25 to lower blast radius)
- We've considered a parallel approach where stage testing continues for 2 more weeks while UAT enters with a smaller cohort
- We're assuming the policy engine performance issue is a known-cost rather than a known-risk; the team has high confidence the 80ms is acceptable for Wave 1 but suboptimal for general availability

2. Problem

Problem statement

We must decide whether ZTNA Wave 1 enters UAT on August 25 or extends stage testing for an additional 2 weeks. The decision affects whether the Atlas program meets its October 15 board-update commitment, whether we use the August 25 friendly-customer window or wait until October, and whether we accept the residual policy engine performance gap (80ms P95 vs. 50ms target) at this gate or defer the gate decision.

Constraints

- Sandra Park (CISO) has authority to approve UAT entry; Mike Tanaka (SRE) has authority to veto on operational risk grounds
- Friendly-customer cohort availability: August 25 or October 13; no windows in between
- Program timeline commitment: Wave 1 in UAT by mid-October per October 15 board update
- Policy engine target P95 50ms is the program-level target for general availability, not necessarily for Wave 1

Success criteria

- UAT completes within 4 weeks of entry
- Zero P0 incidents during UAT
- Friendly customers complete the test scenarios with sign-in success rate ≥ 99%
- Policy engine performance does not regress further (P95 stays at or below 80ms)

3. Approach

Approach 1: Enter UAT August 25 (recommended)

- What it entails: Proceed with planned UAT entry. Accept current 80ms P95 as Wave 1 baseline. Continue policy engine optimization work in parallel; target 50ms P95 by Wave 2 entry.
- Cost: \$0 incremental (already-planned UAT entry)
- Risk: residual performance gap creates Wave 1 user-experience tension; if a P0 surfaces in UAT, recovery requires rollback to stage and re-entry (estimated 3-week impact)
- Evidence supporting: stage testing 5 weeks complete; both blocking issues mitigated; policy engine performance acceptable for Wave 1 cohort (45 users, IT-fluent); friendly-customer cohort window aligned
- Evidence against: 80ms is above stated target; one residual unexplained authentication anomaly (low frequency); policy engine improvements may be harder once UAT is underway

Approach 2: Extend stage testing 2 weeks; enter UAT September 8

- What it entails: Continue stage testing through September 8. Use the time to drive policy engine to ≤ 50 ms P95 and root-cause the residual authentication anomaly.
- Cost: 2-week program slip; loss of August 25 friendly-customer window; pushes UAT completion past October 15 board update
- Risk: program perceived as slipping; sponsor confidence eroded; friendly-customer relationships strained
- Evidence supporting: meets policy engine target before UAT; resolves residual anomaly before customer exposure
- Evidence against: 2 weeks may not be enough to drive 80ms to 50ms (the gap is in policy engine architecture, not configuration); residual anomaly may not be root-causable in stage; the friendly-customer cohort window loss is a real cost

Approach 3: Enter UAT August 25 with reduced cohort (25 users, IT only)

- What it entails: Enter UAT on schedule but reduce blast radius from 45 to 25 users. Continue policy engine work in parallel.
- Cost: friendly-customer cohort partially deferred (the 20 customers not in the reduced cohort move to Wave 2)
- Risk: friendly-customer relationships strained; Wave 2 cohort grows beyond planned size; loss of testing breadth in UAT
- Evidence supporting: lower operational risk in UAT
- Evidence against: doesn't actually address the policy engine performance question (just defers the test); creates Wave 2 capacity issue

Tradeoff summary

Approach 1 trades performance-target compliance for timeline preservation. Approach 2 trades timeline for performance-target compliance. Approach 3 trades cohort size for risk reduction without addressing the underlying performance question.

4. Decision

Chosen approach: Approach 1 — Enter UAT August 25, accept current 80ms P95 as Wave 1 baseline, continue policy engine optimization in parallel.

Rationale

The policy engine performance gap (80ms vs. 50ms target) is a known cost, not a known risk. Stage testing has demonstrated that 80ms is acceptable for the Wave 1 user experience; the 50ms target was set for general availability across 3,500 users with diverse use patterns, not for a 45-user IT pilot. Driving to 50ms requires policy engine architectural work that is in flight but won't complete in 2 weeks. Extending stage by 2 weeks would slip the program without producing the change that makes the gap acceptable.

The strongest argument against Approach 1 is the residual unexplained authentication anomaly. Mike Tanaka and J. Liu jointly assessed the anomaly: low frequency (3 occurrences in 5 weeks), no pattern matching known vulnerability classes, no security implications observed. The decision treats this as acceptable for UAT entry with the agreement that any recurrence in UAT immediately escalates to abort criteria.

Decision authority

- Decided by: Sandra Park, Chief Information Security Officer
- On date: 2026-08-22
- Authority cited: Project Atlas charter delegates Wave-entry decisions to the program sponsor (Atlas Charter, section 4)
- Consulted: Mike Tanaka (SRE Lead — confirmed operational acceptability), M. Ortiz (IDP Migration — confirmed dependency stability), Casey Morrison (Program PM — confirmed timeline implications)
- Informed: Steering committee (notified August 23 via email); friendly-customer security leads (notified August 24 by Casey Morrison); CRO Robert Stein (notified August 23, no compliance objections raised)

Revisit criteria

- Any recurrence of the unexplained authentication anomaly during UAT triggers immediate abort and revisit
- If UAT does not complete within 4 weeks, revisit the Wave 1 → Wave 2 transition decision
- Policy engine performance baseline (P95 80ms) is locked for Wave 1; revisit the 50ms target for Wave 2 entry decision (separate SPADE will be drafted)

5. Evidence

Internal evidence

- Stage testing report week 5 (J. Liu, 2026-08-14): policy engine P95 at 80ms, P99 at 110ms, error rate 0.04% on 11,200 test sign-ins
- Anomaly investigation report (Mike Tanaka + J. Liu, 2026-08-19): 3 authentication anomalies over 5 weeks, no shared root cause, all resolved by client retry; no security implications
- iPad/VPN edge case fix verification (J. Liu, 2026-08-12): 47 test sign-ins from managed iPads with VPN connected; all successful; root cause identified and patched in network-routing layer

External evidence

- Cloudflare ZTNA performance benchmarks (Cloudflare engineering, 2026-Q2 reference): P95 50ms achievable at scale once policy cache is warm; cold-start performance varies by deployment topology
- Two reference customers (financial services, similar identity scope) operating Cloudflare ZTNA in production: report P95 50-70ms after 3-month bake-in; both noted UAT-period performance was higher than steady state

Expert input

- Mike Tanaka (SRE Lead, 12 years infrastructure operations): "80ms is acceptable for Wave 1. The performance work to hit 50ms is real but doesn't have to gate UAT entry. The unexplained anomaly is the only thing I'd weight strongly, and we've evaluated it."
- M. Ortiz (IDP Migration Component Lead, dependency owner): "IDP migration foundation is stable through Wave 1 cohort. We can support UAT August 25 entry."

Sign-offs

Role	Name	Date	Status
Author	J. Liu	2026-08-15	✓ signed
Technical reviewer	Mike Tanaka	2026-08-20	✓ signed
Decision authority	Sandra Park	2026-08-22	✓ signed
Stakeholder consultation	M. Ortiz	2026-08-19	✓ acknowledged
Stakeholder consultation	Casey Morrison	2026-08-19	✓ acknowledged

Related artifacts

- Examples #152 (RACI — One Decision In Practice): the role-and-responsibility view of this same decision
- Decisions & Changes Log (#19) entry: ATLAS-DC-072 references this SPADE
- Engineering Example #246 (ROLL Plan — ZTNA): the rollout plan whose Wave 1 entry was authorized by this decision
- Engineering Example #264 (Test Plan — ZTNA UAT): the test plan that defines what "passing UAT" means

Keywords: SPADE example, SPADE decision example, ZTNA UAT entry, ZTNA Wave 1, decision rationale, decision evidence, decision authority, populated SPADE document, Project Atlas decision, technical decision example

Engineering Example — Test Plan — ZTNA UAT (Project Atlas)

Test Plan — ZTNA UAT (Project Atlas Wave 1)

Document Control

- System: ZTNA Service (Project Atlas component #2) — UAT phase before Wave 1 production cutover
- Test plan version: v2.4, approved 2026-08-20, used through Wave 1 UAT entry on 2026-08-25
- Author: T. Sato (QA Lead, Project Atlas)
- Contributing: J. Liu (ZTNA Component Lead), Casey Morrison (Program PM), Mike Tanaka (SRE Lead — performance test review), Sandra Park (CISO — security test review)
- Approvers: T. Sato (QA Lead), J. Liu (ZTNA Component Lead — engineering manager during Atlas), Sandra Park (CISO — security sign-off), Bristol Compliance (compliance sign-off via Robert Stein)
- Related PRD: not applicable (infrastructure program; reference Atlas Charter, Artifact #1)
- Related Design Doc: Engineering Example #261 (Design Doc — ZTNA Policy Engine)

1. Scope

In scope

- ZTNA policy engine functional behavior across all 47 internal applications in Wave 1 cohort
- Policy engine performance under Wave 1 cohort load (45 users, IT-fluent population)
- ZTNA-Identity Platform integration (Okta authentication chain)
- ZTNA audit log pipeline including 5-minute write-latency target
- Bristol-side policy authoring and override capabilities
- ZTNA client (employee endpoint) installation, sign-in, and access flows

- Conditional access policy evaluation: device posture, user risk score, time-of-day, application context
- Wave 1 user-experience scenarios across 12 representative roles

Out of scope

- Performance testing at general-availability scale (covered separately by GA-readiness test plan, scheduled for Wave 3 entry)
- Customer-facing application authentication (covered by per-application test plans for Bristol customer-facing applications)
- Vendor and contractor access (post-Atlas program; separate test plan)
- Mobile-only access patterns (already covered in Wave 2 dress rehearsal test plan)
- Service-to-service authentication (service-mesh program scope, not Atlas)

Dependencies

- Identity Platform UAT must pass before this test plan starts (passed 2026-07-30; sign-off by M. Ortiz)
- Cloudflare ZTNA control plane must be configured for Bristol production tenant (confirmed 2026-08-05 by J. Liu)
- Bristol Audit Log Pipeline must accept events from Cloudflare edge (verified 2026-08-10)

2. Test types and coverage

Unit testing

- Coverage target: 85% line coverage on Bristol-built code (Bristol Policy System, Integration Layer, Override Service)
- Status at UAT entry: 89% line coverage achieved
- Owner: ZTNA engineering team
- Tooling: Bristol-standard test framework (Jest for TypeScript, pytest for Python)

Integration testing

- Coverage target: all API contracts in design doc (Bristol Policy → Cloudflare API; Cloudflare edge → Bristol Integration Layer; Bristol Override → Cloudflare API; Bristol Audit Log Pipeline)
- Status at UAT entry: 100% API contracts covered; 47/47 integration tests passing
- Owner: ZTNA engineering + QA
- Tooling: Bristol integration test harness

End-to-end / functional testing

- Coverage target: all user-facing flows for Wave 1 cohort across 12 representative roles
- Test scenarios:
 - Standard sign-in and access for each role × each of 47 internal applications ($47 \times 12 = 564$ scenarios; sampled to 180 representative cases)
 - Conditional access edge cases: managed iPad + simultaneous VPN, untrusted device + sensitive app, elevated-risk user + high-sensitivity app
 - Sign-in retry behavior after Cloudflare edge transient errors
 - Sign-in behavior during identity-platform partial degradation
 - Override invocation and revocation
 - Audit log presence verification for every test sign-in
- Status at UAT entry: 178/180 passing; 2 documented as known issues for UAT verification (the residual unexplained anomaly behaviors from stage)
- Owner: QA team

Performance testing

- Coverage target: P95 evaluation latency < 80ms (Wave 1 baseline per ATLAS-SPADE-014); P95 audit log write < 5 minutes; sustained load equivalent to Wave 1 peak (~120 simultaneous sign-in events) for 4 hours
- Status at UAT entry: P95 evaluation 78ms (within Wave 1 baseline); P95 audit log write 3.2 minutes (within target); 4-hour sustained test passed 2026-08-18
- Owner: SRE + QA
- Tooling: Bristol load-test harness against pre-production Cloudflare tenant

Security testing

- Coverage target: OWASP Top 10 for the Bristol-built components; threat model coverage from Design Doc #261 Section 5
- Test scenarios: credential compromise simulation, device-posture bypass attempts, policy-injection attempts via override service, audit-log tamper attempts
- Status at UAT entry: external security audit (Bristol-contracted firm) completed 2026-08-12; 0 critical findings, 2 medium findings (both remediated by 2026-08-19)
- Owner: Bristol Security team + external auditor

Accessibility testing

- Coverage target: WCAG 2.1 AA for the ZTNA client UI surfaces and the Bristol Policy authoring system UI
- Status at UAT entry: WCAG audit completed 2026-08-15; 1 minor issue (color-contrast on a status indicator) remediated 2026-08-18
- Owner: Bristol Accessibility team

Regression testing

- Coverage target: full Bristol regression suite + new tests added by this change
- Status at UAT entry: regression suite 100% pass

UAT (User Acceptance Testing)

- Coverage target: 45 Wave 1 users running specific scenarios over 4-week window
- Cohort: 45 IT and Atlas-team users; opt-in volunteers; covers all 12 representative roles
- Scenarios per user: 8 mandatory scenarios + 5 optional exploratory scenarios
- Sign-off criterion: ≥99% scenario pass rate; 0 unresolved P0/P1 findings

3. Test environment and data

Test environments

- Stage 1 (pre-prod, low scale): used for unit, integration, early functional. Scale: 5 users equivalent. Owner: ZTNA engineering.
- Stage 2 (pre-prod, production-like): used for functional, performance, security. Scale: 50 users equivalent (matched to Wave 1 cohort + headroom). Owner: SRE.
- UAT environment: production Cloudflare tenant, production identity platform, production audit log infrastructure; the 45 UAT users are migrated for real but with rapid rollback capability. Owner: ZTNA Operations.

Test data

- Functional test data: synthetic users created in test identity tenant; 12 representative role profiles; covers all conditional access edge cases
- Performance test data: synthetic events generated by load-test harness; calibrated to mirror real Wave 1 access pattern profile
- Edge-case test data: includes managed iPads (5), untrusted devices (10), users with elevated risk score (8), users in different time zones (5)

- PII handling: synthetic identities only in stage environments; UAT uses real Wave 1 user identities (this is genuine production access for UAT cohort, not test); standard production data controls apply

4. Entry and exit criteria

Entry criteria (must be true before UAT starts)

- ✓ Identity Platform UAT passed (sign-off M. Ortiz, 2026-07-30)
- ✓ All P0 functional tests passing (verified 2026-08-15)
- ✓ Performance test pass at Wave 1 baseline (verified 2026-08-18 — 78ms P95)
- ✓ Security audit complete with 0 critical findings (verified 2026-08-12)
- ✓ Accessibility audit complete with all critical findings remediated (verified 2026-08-18)
- ✓ Rollback procedure validated (rehearsed 2026-08-19; 47-min completion vs. 60-min target)
- ✓ Cloudflare control plane configured for Bristol production tenant (verified 2026-08-05)
- ✓ Audit log pipeline accepting events from Cloudflare edge (verified 2026-08-10)
- ✓ ATLAS-SPADE-014 approved (Sandra Park, 2026-08-22) authorizing UAT entry with Wave 1 baseline performance
- ✓ Wave 1 cohort confirmed; UAT scenarios distributed (Casey Morrison, 2026-08-23)

Exit criteria (must be true to declare UAT complete and authorize Wave 1 production cutover)

- All P0 UAT scenarios pass: 100% rate
- All P1 UAT scenarios pass: ≥ 98% rate
- All P2 UAT scenarios have defect triage decisions
- 0 unresolved P0/P1 defects
- ≤ 5 unresolved P2 defects with documented decisions
- Performance during UAT: P95 evaluation < 90ms sustained (10ms headroom over 80ms baseline)
- Audit log: P95 write latency < 5 minutes; 0 audit-log gaps > 5 min duration
- Security: 0 unresolved critical findings; ≤ 2 unresolved medium findings with documented decisions
- All findings from external security audit closed (verified by Bristol Security)

5. Schedule and resource plan

Phase	Start date	End date	Owner	Tests covered
Unit/integration testing	2026-06-15	2026-07-31	ZTNA eng	Unit + integration suites
Functional (stage 1)	2026-07-15	2026-08-10	QA team	Standard flows
Functional (stage 2)	2026-08-01	2026-08-15	QA team	Conditional access edge cases
Performance testing	2026-08-12	2026-08-18	SRE + QA	Wave 1 baseline + 4-hr sustain
Security testing	2026-08-05	2026-08-19	Bristol Security	OWASP + threat model
Accessibility testing	2026-08-08	2026-08-18	Accessibility team	WCAG 2.1 AA
Regression testing	2026-08-18	2026-08-22	QA team	Full Bristol regression suite

Phase	Start date	End date	Owner	Tests covered
UAT	2026-08-25	2026-09-22	Wave 1 cohort	8 mandatory scenarios per user
Final regression	2026-09-19	2026-09-22	QA team	Pre-cutover regression
Wave 1 production cutover 2	026-09-22 2	026-09-22 J	. Liu N	/A (production cutover)

6. Defect process

Severity definitions

- P0 (Critical): blocks UAT for any user; or blocks > 25% of test scenarios; or has security implications; or has audit-log integrity implications. Examples: policy engine returns errors for any sign-in; audit log gap > 5 min; override service compromise.
- P1 (Major): blocks specific roles or scenarios but not the whole UAT; or affects performance materially (P95 > 100ms); or has accessibility implications affecting screen-reader use; or affects > 5% of test scenarios. Examples: managed iPad workflow blocks 1 role; sustained P95 latency at 95ms.
- P2 (Significant): UX issue affecting 1-2 scenarios but workaround exists; or performance regression noticeable but within tolerance; or affects < 5% of test scenarios. Examples: error message text confusing but workaround works; specific application's policy evaluation 50ms slower than baseline.
- P3 (Minor): cosmetic issues, documentation gaps, edge cases that don't affect actual user experience.

Defect lifecycle

1. Reported in Bristol-standard defect tracker with reproducer
2. Triageed within 4 business hours; severity assigned
3. Assigned to developer; estimated and prioritized
4. Fixed (PR merged); marked Ready-for-Verification
5. Verified by QA; marked Closed
6. Re-verified during regression testing if fix landed > 24 hours before target ship date

Defect triage cadence

Daily during UAT (10 AM ET stand-up); attendees J. Liu, T. Sato, Casey Morrison; +CISO if any P0 with security implications

Decision authority for "ship despite defect"

- P0/P1: Sandra Park (CISO, sponsor) decides; T. Sato and J. Liu provide recommendations
- P2: T. Sato (QA Lead) decides; can batch-decide for routine cases
- P3: documented in test report; not blocking

7. Risk and contingency

Testing risks

- R-001: UAT environment instability during 4-week window | Likelihood M | Impact H | Mitigation: dedicated SRE coverage during UAT; 24-hour SLA on stability fixes

- R-002: UAT cohort availability gaps (vacations, sickness) | Likelihood H | Impact M | Mitigation: 45 user cohort gives ~5 user buffer for typical attendance; Casey Morrison tracks daily
- R-003: Performance regression during UAT scale-up | Likelihood L | Impact H | Mitigation: continuous performance monitoring during UAT with 10ms regression alerting; rollback to stage if confirmed
- R-004: Defect surge requires more triage capacity than scheduled | Likelihood M | Impact M | Mitigation: T. Sato has 25% backup QA capacity available on standby
- R-005: Cross-team dependency slip (identity platform regression that affects ZTNA UAT) | Likelihood L | Impact H | Mitigation: daily cross-team sync; identity platform regression suite runs daily during ZTNA UAT

Contingencies

- If UAT P95 evaluation latency exceeds 100ms: T. Sato + J. Liu jointly assess; Sandra Park notified; possible UAT pause and stage re-test
- If P0 defect surfaces: cutover paused; daily triage continues until resolved
- If UAT cohort participation drops below 80%: Casey Morrison engages with managers to ensure scenarios are run; UAT timeline may extend if coverage insufficient

8. Sign-off authority

Test type	Sign-off authority	Sign-off criterion
Unit testing	ZTNA Engineering Lead	85% coverage achieved
Integration testing	T. Sato (QA Lead)	All API contracts; 100% pass
Functional testing	T. Sato	All P0/P1 pass; 178+ of 180 scenarios pass
Performance testing	Mike Tanaka (SRE Lead)	Wave 1 baseline + 4-hr sustained met
Security testing	Sandra Park (CISO)	0 critical findings unresolved
Accessibility testing	Bristol Accessibility Lead	WCAG 2.1 AA achieved
UAT	T. Sato + Casey Morrison	Exit criteria from Section 4 met
Regression testing	T. Sato	No regressions vs. baseline
Final cutover authorization	Sandra Park (CISO)	All test types signed off; ATLAS-DC-094 logged in Decisions & Changes Log

Sign-offs (final state at UAT completion 2026-09-22)

Role	Name	Date	Status
QA Lead	T. Sato	2026-09-22	✓ signed
ZTNA Engineering Lead	J. Liu	2026-09-22	✓ signed
SRE Lead	Mike Tanaka	2026-09-22	✓ signed
CISO (security)	Sandra Park	2026-09-22	✓ signed
CRO (compliance)	Robert Stein	2026-09-22	✓ signed
Program PM	Casey Morrison	2026-09-22	✓ acknowledged
Wave 1 cutover			2026-09-22 — Sandra

Role	Name	Date	Status
authorization			Park decision logged ATLAS-DC-094

Related artifacts

- Engineering Example #261 (Design Doc — ZTNA Policy Engine): the design this test plan verifies
- Engineering Example #255 (SPADE — Approve UAT Entry for ZTNA Wave 1): the decision authorizing UAT entry per this plan
- Engineering Example #246 (ROLL Plan — ZTNA Component): the rollout plan whose Wave 1 entry was gated by this test plan's exit criteria
- Decisions & Changes Log (Artifact #19): ATLAS-DC-094 (UAT completion + Wave 1 cutover authorization)

Keywords: test plan example, UAT test plan example, ZTNA test plan, populated test plan, performance testing example, security testing example, accessibility testing example, defect process example, Project Atlas test plan, Wave 1 UAT

Engineering Template — Disaster Recovery (DR) Plan

Disaster Recovery (DR) Plan — Template

Document Control

- System / service: [name]
- DR plan version: v[N], last revised [date], next review [date]
- Owner: [name, role]
- Approvers: [SRE Lead — name], [CISO/CIO — name], [CRO — name], [Audit Committee — date of acknowledgment]
- Last DR test: [date and type]
- Last triggered review: [date and trigger event]

1. Scope and criticality

Systems in scope of this DR plan

- [System 1] | Criticality: Tier [N] | RTO: [target] | RPO: [target]
- [System 2] | Criticality: Tier [N] | RTO: [target] | RPO: [target]
- [System 3] | Criticality: Tier [N] | RTO: [target] | RPO: [target]

Criticality tier definitions used here

- Tier 1: [definition; e.g., revenue-bearing, regulated, customer-facing critical]
- Tier 2: [definition]
- Tier 3: [definition]
- Tier 4: [definition]

Out of scope of this DR plan

- [Adjacent system with separate DR plan]
- [Adjacent system with separate DR plan]

2. RTO and RPO targets

System	Tier	RTO target	RPO target	Driver
[System 1]	[N]	[duration]	[duration]	[regulatory cite / SLA / business case]

System	Tier	RTO target	RPO target	Driver
[System 2]	[N]	[duration]	[duration]	[regulatory cite / SLA / business case]

Validation status

[For each target: was this validated by actual testing? When? With what success rate?]

3. Architecture

Primary site / region: [location]

Secondary (DR) site / region: [location, with verification that it's truly independent — different cloud region, different data center, different power/network/control-plane]

Replication mechanism

[Synchronous / asynchronous; data layer; orchestration layer; metadata layer]

Data backup strategy

[Backup frequency; retention; storage location; encryption-at-rest and in-transit; restore validation cadence]

Failover orchestration

[Manual / scripted / automated; what triggers it; who initiates it; what's reversible vs. one-way]

DNS / traffic routing

[How traffic is routed during DR; TTL implications; client-side cache implications]

Architecture diagram

[Insert or link to current architecture diagram, with version date]

4. Recovery procedures

Procedures are detailed in separate runbooks. This section lists the runbooks and their relationships.

Procedure	Runbook	Owner	Last validated	Expected duration
[Tier 1 system failover]	[link]	[name]	[date]	[time]
[Tier 1 system failback]	[link]	[name]	[date]	[time]
[Backup restoration]	[link]	[name]	[date]	[time]
[Cross-region replication failure]	[link]	[name]	[date]	[time]
[Ransomware recovery]	[link]	[name]	[date]	[time]
[Vendor outage extended recovery]	[link]	[name]	[date]	[time]

5. Decision authority

Disaster declaration authority

- Primary: [named person, role]
- Secondary (if primary unavailable): [named person, role]
- Tertiary: [named person, role]

Recovery decisions during execution

- Architecture-level: [name, role]
- Communications-level: [name, role]
- Regulatory engagement: [name, role]

DR-related budget authority

- Within annual DR budget: [name, role]
- Above annual DR budget (extended outage scenarios): [name, role]

6. Communication plan

Internal communications during DR

- Channel: [Slack / phone tree / war room]
- Cadence: [during early hours] [during stabilization] [during recovery]
- Leadership notifications: [list with timing and channel]

Customer communications during DR

- Trigger: [conditions that require customer-facing comms during DR]
- Channel: [status page, email, in-app]
- Authority: [named person]
- Pre-drafted templates: [link to library]
- Coordination with marketing/PR: [process]

Regulatory communications during DR

- Regulators: [list]
- Notification SLA per regulator: [list]
- Authority: [named person, typically CRO + General Counsel]
- Format: [letter, portal submission, telephone with letter follow-up]

Board / audit committee communication

- Trigger: [conditions, typically Tier 1 system DR]
- Channel: [board portal, email]
- Authority: [CISO or CIO]

7. Testing program

Annual DR plan

- Tabletop exercises: [frequency, last performed, next scheduled]
- Partial-failover tests: [frequency, scope, last performed]
- Full DR tests: [frequency, scope, last performed]

Test results tracking

- Test report repository: [link]
- Gap remediation tracking: [where tracked, status review cadence]

Per-tier testing requirements

- Tier 1: [specific testing requirements, e.g., quarterly partial failover, annual full failover]
- Tier 2: [specific testing requirements]
- Tier 3: [specific testing requirements]
- Tier 4: [specific testing requirements]

8. Maintenance

Review cadence: [typically annual]

Triggered review conditions

- After every full or partial DR test
- After every Tier 1 system architecture change
- After every disaster (real or rehearsed)
- After regulatory framework change

Owner: [named role]

Version history

v[N] [date] [substantive change summary]

v[N-1] [date] [substantive change summary]

Keywords: DR plan template, disaster recovery template, business continuity template, BCP template, RTO RPO template, failover template, DR architecture template, DR test program template, blank DR plan

Engineering Template — Engineering Design Document

Engineering Design Document — Template

Document Control

- System / component: [name]
- Design doc version: v[N], last revised [date], next review [date]
- Author(s): [name(s), role(s)]
- Technical reviewer: [staff/principal engineer or architect — name]
- Cross-functional reviewers: [Security — name], [SRE — name], [Privacy — name if applicable], [Accessibility — name if applicable]
- Approvers: [Engineering manager / director — name], [Architecture review board if applicable — date of review]
- Related PRD: [link / reference]
- Status: [Draft / Under review / Approved / Implemented / Superseded]

1. Context and goals

Background

[2-4 paragraphs of context. What's the prior state? What changed? What does this design fit into?]

Problem statement

[Specific problem this design solves; reference the PRD if applicable]

Goals

- [Engineering goal 1]
- [Engineering goal 2]
- [Engineering goal 3]

Non-goals

- [Explicit thing this design is NOT trying to do]

Constraints

- [Hard constraint: regulatory, technical, organizational, vendor]

2. Proposed design

Architecture overview

[1-2 paragraphs describing the high-level approach]

System diagram

[Insert or link to architecture diagram]

Component responsibilities

- [Component A: what it does, what it owns]
- [Component B: what it does, what it owns]
- [Component C: what it does, what it owns]

Major data flows

[Describe the key paths data takes through the system]

Key interfaces

- [Interface A: between which components, what's exchanged]
- [Interface B: between which components, what's exchanged]

3. Alternatives considered

Alternative 1: [name]

- Description
- Pros
- Cons
- Why not chosen

Alternative 2: [name]

- (same structure)

Alternative 3: [name]

- (same structure)

4. Detailed design

API contracts

[For each endpoint: method, path, request shape, response shape, error responses, rate limits]

Data models

[For each entity: schema, key fields, relationships, indexes, retention]

State machines

[For any stateful flows: state diagram, transitions, terminal states]

Concurrency model

[Threading, locking, transactions, race conditions and how they're handled]

Error handling

[Error categories, response strategies, retry policies, fallback behavior]

5. Security and privacy

Threat model

[Key threats this system must defend against]

Authentication

[How identity is established for all flows]

Authorization

[How permission checks work]

Data classification and handling

[Each data category: sensitivity level, where stored, how protected]

Encryption

[In transit: protocol, version. At rest: encryption strategy, key management.]

Audit logging

[What events are logged, retention period, where logs go]

Compliance

[Specific frameworks the design must conform to: SOC 2, GDPR, HIPAA, etc.]

6. Observability

Metrics

- [Metric: what it measures, how it's collected]

Logs

- [Log type: what's logged, retention, sensitivity]

Traces

- [Trace type: spans captured, sampling strategy]

Alerts

- [Alert: trigger condition, severity, who's paged]

Dashboards

- [Dashboard: link, audience, what it surfaces]

7. Rollout and migration

Feature flag strategy

[How the feature is gated; what flag controls what]

Phased rollout plan

[High-level plan; references the ROLL Plan artifact for the operational version]

Backward compatibility

[What old clients/data this design must continue to support]

Migration plan

[If existing data or behavior changes: migration steps, validation, rollback]

8. Open questions

- Q-001: [Question] | Owner [name] | Target resolution [date]
- Q-002: [Question] | Owner [name] | Target resolution [date]

9. Appendices

[Optional: benchmarks, vendor evaluations, prior-art references, related design docs]

Sign-offs

Role	Name	Date	Status
Author(s)	[name]	[date]	[signed/pending]
Technical reviewer	[name]	[date]	[signed/pending]
Security reviewer	[name]	[date]	[signed/pending]
SRE reviewer	[name]	[date]	[signed/pending]
Privacy reviewer (if applicable)	[name]	[date]	[signed/pending]
Engineering manager / director	[name]	[date]	[signed/pending]
Architecture review board	[date of review]		[approved/pending]

Keywords: design doc template, engineering design template, technical specification template, RFC template, architecture document template, blank design doc

Engineering Template — Incident Response (IR) Plan

Incident Response (IR) Plan — Template

Document Control

- Service / system: [name]
- IR plan version: v[N], last revised [date], next review [date]
- Owner: [name, role]
- Approvers: [SRE Lead — name], [Security — name if applicable], [Operational function lead — name]

1. Scope

This IR plan covers

[Specific service or system, with key components listed]

This IR plan does NOT cover

- [Adjacent service with its own IR plan]
- [Adjacent service with its own IR plan]

Dependencies (services this depends on)

- [Service: name | their IR plan: link]
- [Service: name | their IR plan: link]

Dependents (services that depend on this)

- [Service: name | their IR plan: link]

2. Severity classification

Severity	Definition	Threshold examples	Time-to-respond
SEV-0	Critical: customer-impacting outage	[Specific error rate / customer]	count / revenue] [primary on-call ack < 5 min]
SEV-1	Major: significant impact	[Specific thresholds]	[< 15 min]
SEV-2	Significant: limited impact	[Specific thresholds]	[< 30 min]
SEV-3	Minor: low impact	[Specific thresholds]	[< 4 hrs (business hours)]

Example scenarios (real or representative)

SEV-0: [Example]

SEV-1: [Example]

SEV-2: [Example]

SEV-3: [Example]

3. On-call structure

Primary on-call: [rotation; who is current primary]

Secondary on-call: [rotation; who is current secondary]

Tertiary / escalation: [rotation; who is current tertiary]

Paging tool: [PagerDuty / Opsgenie / etc., with link]

Primary acknowledgment SLA: [time]

Auto-escalation if primary doesn't ack: [time and who]

Coverage gaps

- Weekends: [coverage state]
- Holidays: [coverage state]
- Time zones: [follow-the-sun? gap coverage?]

4. Roles during an incident

For SEV-0 and SEV-1, these roles must be different people:

Incident Commander (IC)

- Owns: response coordination, decision-making, ensuring closure
- Authority: can override individual engineering judgment in service of incident resolution
- Default: highest-tier on-call for the service

Communications Lead

- Owns: internal updates, customer notifications, status page, regulator notification (if applicable)
- Authority: signs off on all external comms

Subject Matter Experts (SMEs)

- Owns: actual diagnosis and fix
- Engaged based on incident type

Scribe

- Owns: timeline capture, decision log, action items
- Default: rotates among non-engaged team members

For SEV-2 and SEV-3: one engineer can hold IC + SME; Comms Lead is optional.

5. Communication protocols

Internal communications

Channel: [Slack channel name]

Status updates cadence: SEV-0: every 30 min; SEV-1: every 60 min; SEV-2/3: as needed

Leadership notification:

- SEV-0: [VP role] within [time]; [SVP role] within [time]
- SEV-1: [VP role] within [time]
- SEV-2/3: as needed

External communications (customer-facing)

Channel: status page at [URL]; email via [system]

Trigger thresholds:

- SEV-0: status page within [time] of declaration; customer email within [time]
- SEV-1: status page within [time]
- SEV-2/3: case-by-case

Pre-drafted message templates: [link to library]

Regulatory communications (if applicable)

Regulators: [list]

Notification SLA per regulator: [list with specific timing]

Notification authority: [role with named person]

Format: [letter, portal submission, telephone with letter follow-up]

6. Escalation paths

Trigger	Notify	Within	Channel
SEV-0 declared	CISO + CIO	15 min	Page + call
SEV-1 declared	Engineering VP + Service Owner	30 min	Page
SEV-1 unresolved at 4 hours	SVP Engineering	immediate	Call
Security implications (any severity)	CISO	immediate	Page
Data loss or breach (any severity)	CISO + General Counsel + CRO	15 min	Call
Regulatory implication (any severity)	CRO + General Counsel	30 min	Call
Customer-impacting (any severity)	Customer Success VP	30 min	Slack
Media attention or public exposure	Communications team + General Counsel	1 immediate	Call

7. Response runbooks

For each incident type, link to the dedicated runbook:

Incident type	Runbook	Last reviewed	Last drilled
[Authentication outage]	[link]	[date]	[date]
[Data corruption]	[link]	[date]	[date]
[Suspected breach]	[link]	[date]	[date]
[Performance degradation]	[link]	[date]	[date]
[Third-party dependency failure]	[link]	[date]	[date]

8. Post-incident review (PIR) trigger

PIR required for

- All SEV-0 incidents
- All SEV-1 incidents
- Any SEV-2 with regulatory implications, customer impact, or security implications
- Optional for SEV-2/3 by IC discretion

PIR timeline: within 5 business days of incident closure

Facilitator: [role]

Attendees: IC, Comms Lead, SMEs from incident, Service Owner, [other stakeholders by incident type]

Output: Post-Incident Review document (see Examples #211 for template)

Findings tracking: [system / log where action items are tracked to closure]

9. Plan maintenance

Review cadence: Quarterly

Triggered review: After every SEV-0 or SEV-1 incident; after major service change

Owner: [role]

Last review: [date]

Next review: [date]

Version history

v[N] [date] [change summary]

v[N-1] [date] [change summary]

Keywords: IR plan template, incident response template, on-call template, severity classification template, escalation path template, runbook template, PIR trigger template, blank incident response plan

Engineering Template — Product Requirements Document (PRD)

Product Requirements Document (PRD) — Template

Document Control

- Product / feature: [name]
- PRD version: v[N], last revised [date], next review [date]
- Author: [Product Manager — name]
- Contributing reviewers: [Design — name], [Engineering — name], [TPM — name]
- Approvers: [Product owner — name], [Engineering owner — name], [Stakeholder approvers based on scope: Legal, Security, Compliance, Marketing as applicable]
- Target launch: [date or quarter]

1. Problem and users

Problem statement

[1-2 paragraphs describing the problem this work solves. Cite evidence — usage data, support data, user research, market analysis.]

Affected users

- [Primary user type]: [size of population, key characteristics]
- [Secondary user type]: [size of population, key characteristics]

Why now

[Why this work is being done at this time rather than earlier or later. Sources of urgency: competitive, regulatory, technical-debt, opportunity-cost.]

2. Goals and non-goals

Goals

1. [Outcome-based goal 1; e.g., "Reduce MFA-related support contacts by 40%"]
2. [Outcome-based goal 2]
3. [Outcome-based goal 3]

Non-goals

- [Explicit thing this work is NOT trying to do]
- [Explicit thing this work is NOT trying to do]
- [Explicit thing this work is NOT trying to do]

Success will be measured by

[See Section 8 for full metrics; here state 1-2 lead indicators]

3. User experience

User flows

[Reference design files or include flow diagrams; describe the key paths a user takes through the product]

Key screens

[Reference design files; include enough description that engineers can build it]

Edge cases

- [Edge case: what happens when X]
- [Edge case: what happens when Y]

4. Functional requirements

Each requirement is testable. Format: "Users can [specific action]."

User-facing requirements

- F-001: [Specific, testable requirement]
- F-002: [Specific, testable requirement]
- F-003: [Specific, testable requirement]

Internal/admin requirements

- F-101: [Specific, testable requirement]
- F-102: [Specific, testable requirement]

5. Non-functional requirements

Performance

- [Metric, target, measurement context — e.g., "P95 page load < 1.5s on 4G mobile"]

Scalability

- [Concurrent users, throughput, data volumes the system must support]

Security

- [Authentication, authorization, data handling, encryption, audit logging requirements]
- [Specific compliance frameworks: SOC 2, GDPR, GLBA, HIPAA — as applicable]

Availability

- [SLA/SLO targets, downtime expectations]

Accessibility

- [WCAG conformance level — A, AA, or AAA — and any specific accommodations]

Internationalization

- [Languages supported, locale requirements, timezone handling]

6. Dependencies and integrations

Internal dependencies

- [Service or team this work depends on — what's needed and when]
- [Service or team this work depends on — what's needed and when]

External dependencies

- [Vendor, partner, third-party — what's needed]

Integrations

- [Existing system this connects to — API contract reference]
- [Existing system this connects to — API contract reference]

What depends on this

- [Downstream consumers]

7. Risks and open questions

Risks

- R-001: [Risk] | Likelihood [H/M/L] | Impact [H/M/L] | Mitigation [strategy]

- R-002: [Risk] | Likelihood [H/M/L] | Impact [H/M/L] | Mitigation [strategy]

Open questions

- Q-001: [Question] | Owner [name] | Target resolution date [date]
- Q-002: [Question] | Owner [name] | Target resolution date [date]

8. Success metrics and tracking

Lead indicators (measured during launch and stabilization)

- [Metric] | Baseline [value] | Target [value] | Measurement methodology

Lag indicators (measured 30/60/90 days post-launch)

- [Metric] | Baseline [value] | Target [value] | Measurement methodology

Review cadence

- 30-day post-launch review: [scheduled date, attendees]
- 90-day post-launch review: [scheduled date, attendees]

Tracking instrumentation

- [Where metrics are tracked — dashboard reference, analytics tool]

Sign-offs

Role	Name	Date	Status
PM owner	[name]	[date]	[signed/pending]
Engineering owner	[name]	[date]	[signed/pending]
Design owner	[name]	[date]	[signed/pending]
Legal (if applicable)	[name]	[date]	[signed/pending]
Security (if applicable)	[name]	[date]	[signed/pending]
Compliance (if applicable)	[name]	[date]	[signed/pending]
Stakeholder approvers	[name]	[date]	[signed/pending]

Keywords: PRD template, product requirements document template, product spec template, product brief template, functional requirements template, non-functional requirements template, blank PRD

Engineering Template — Rollout (ROLL) Plan

Rollout (ROLL) Plan — Template

Document Control

- Component / feature: [name]
- ROLL plan version: v[N], last revised [date], next review [date]
- Owner: [name, role]
- Approvers: [Sponsor — name], [SRE/Operations Lead — name], [Security — name if applicable]
- Target rollout window: [start date — end date]
- Anchor event (if applicable): [e.g., "GA launch", "Wave 4 cutover", "Region migration"]

1. Scope and target state

What's being rolled out

[1-2 sentences describing the change]

Post-rollout target state

[Describe the system/service/user-experience state after rollout completes]

Out of scope

- [Item not included]
- [Item not included]

2. Rollout strategy

Strategy type: [Phased percentage / Canary / Ring deployment / Wave-based / Big bang (justify if so)]

Phasing

- Phase 1: [cohort, percentage or criteria]
- Phase 2: [cohort, percentage or criteria]
- Phase 3: [cohort, percentage or criteria]
- Phase 4: [cohort, percentage or criteria]

Cohort selection criteria

[How users/systems are assigned to phases]

Geographic phasing (if applicable)

[Regions or data centers in order of rollout]

3. Pre-rollout gates

Gate	Criteria	Owner	Status
Test pass	All [P0/P1] tests passing in stage	[name]	[]
Observability ready	Dashboards live, alerts configured	[name]	[]
Runbooks published	Operational + IR runbooks available	[name]	[]
Support trained	Support staff briefed, FAQ live	[name]	[]
Rollback validated	Rehearsed in non-prod, timing confirmed	[name]	[]
Comms sent	User-facing communications complete	[name]	[]
Compliance sign-off	[if applicable]	[name]	[]

4. Per-phase plan

For each phase, fill in:

Phase [N]: [Phase name]

- Cohort: [specific users/percentage/region]
- Start: [datetime]
- Observation period: [duration]
- Success criteria:

* [Metric 1]: [threshold]

* [Metric 2]: [threshold]

- Decision point: [datetime]
- Decision authority: [name]

- Decision options:
- * Proceed → next phase
- * Hold → continue observing for [extended period], reassess at [datetime]
- * Abort → trigger rollback per Section 7

5. Success metrics

Each metric: name | baseline (pre-rollout) | acceptable range during rollout | post-rollout target

Metric	Baseline	Acceptable range	Post-rollout target
[e.g., Sign-in error rate]	[0.05%]	[< 0.1%]	[< 0.05%]
[e.g., Support tickets/hour]	[50]	[< 200]	[< 60]
[e.g., P95 latency]	[350ms]	[< 500ms]	[< 350ms]

6. Abort criteria

Hard aborts (automatic rollback, no human decision required)

- [Criterion with specific threshold]
- [Criterion with specific threshold]

Soft aborts (rollback after human review by [named role])

- [Criterion with specific threshold]
- [Criterion with specific threshold]

Sponsor escalation triggers

- [Criterion that triggers sponsor notification before rollback decision]

7. Rollback procedure

Trigger authority: [who can call rollback]

Rollback execution time: [estimated duration]

Mechanical steps:

1. [Step]
2. [Step]
3. [Step]

Data handling during rollback

[What data is preserved, what is lost, what migrations are reversible]

User notification during rollback

[Who is notified, on what channel, with what message — refer to Comms Plan]

Validation

[Date the rollback procedure was rehearsed in non-prod, with results]

Re-attempt criteria

[Conditions that must be met before re-rolling-out]

8. Post-rollout closure

Final metrics review at: [datetime, typically T+30 or T+60]

Steady-state monitoring transition: [date and named owner]

Runbook update: [date and named owner]

Lessons captured to: [Lessons Learned Register reference]

Sign-offs

Role	Name	Date	Status
Component owner	[name]	[date]	[signed/pending]
Sponsor	[name]	[date]	[signed/pending]
SRE/Ops Lead	[name]	[date]	[signed/pending]
Security (if applicable)	[name]	[date]	[signed/pending]
Compliance (if applicable)	[name]	[date]	[signed/pending]

Keywords: ROLL plan template, rollout plan template, rollout strategy template, phased rollout template, deployment plan template, abort criteria template, rollback procedure template, blank rollout plan

Engineering Template — SPADE Decision Document

SPADE Decision Document — Template

Document Control

- Decision title: [short noun phrase, e.g., "Adopt Cloudflare ZTNA over Cisco Duo for Bristol identity modernization"]
- SPADE ID: [your team's naming convention, e.g., ATLAS-SPADE-014]
- Status: [Draft / Under review / Approved / Superseded]
- Author: [name, role]
- Reviewer: [name, role — typically staff/principal engineer or architect]
- Decision authority: [name, role — must have actual authority for this scope]
- Date drafted: [date]
- Date approved: [date]
- Supersedes: [prior SPADE ID, if any]

1. Story

[2-4 paragraphs of narrative context. Cover:]

What's been happening

[The history that led to this decision. What was the prior state? What changed? What prompted this work?]

Who's been involved

[The teams, individuals, vendors, or external practitioners whose input shaped the decision]

What's been tried, considered, or assumed

[Prior approaches, abandoned ideas, current assumptions that this decision either confirms or rejects]

2. Problem

Problem statement

[1-2 sentences stating the specific problem, with measurable criteria]

Constraints

[Hard constraints that any approach must satisfy: regulatory, technical, budgetary, timeline]

Success criteria

[How we'll know the decision was correct, with specific metrics]

3. Approach

Approach 1: [name]

- What it entails: [brief description]
- Cost: [dollar/time/effort estimate]
- Risk: [what could go wrong]
- Evidence supporting: [data points, references]
- Evidence against: [data points, references]

Approach 2: [name]

- (same structure)

Approach 3: [name]

- (same structure)

[Add more approaches as needed; typically 2-4 total]

Tradeoff summary

[Brief comparison of the approaches against the success criteria from Section 2]

4. Decision

Chosen approach: [name from Approach section]

Rationale

[2-3 paragraphs explaining why this approach won, addressing the strongest argument against it]

Decision authority

- Decided by: [name, role]
- On date: [date]
- Authority cited: [the specific delegation or scope that gives this person authority for this decision]
- Consulted: [list of people consulted, with their roles]
- Informed: [list of people informed of the decision]

Revisit criteria

[Conditions under which this decision should be revisited. "Never" is a valid answer for some decisions; "if X changes" is valid; "annually" is valid. Vague is not valid.]

5. Evidence

[Concrete inputs that support the Decision. Each item should be specific and verifiable.]

Internal evidence

- [Benchmark / prototype / production data / etc., with reference]
- [Benchmark / prototype / production data / etc., with reference]

External evidence

- [Industry reference / vendor data / external practitioner input, with reference]
- [Industry reference / vendor data / external practitioner input, with reference]

Expert input

- [Named individual + their relevant experience + summary of their input]

Sign-offs

Role	Name	Date	Status
Author	[name]	[date]	[signed/pending]
Technical reviewer	[name]	[date]	[signed/pending]
Decision authority	[name]	[date]	[signed/pending]

Role	Name	Date	Status
Stakeholder (if relevant)	[name]	[date]	[signed/pending]

Keywords: SPADE template, SPADE decision template, decision document template, technical decision template, ADR template, architecture decision record template, blank SPADE document

Engineering Template — Test Plan

Test Plan — Template

Document Control

- System / change being tested: [name]
- Test plan version: v[N], last revised [date], next review [date]
- Author: [QA lead — name]
- Contributing: [Engineering lead — name], [Product Manager — name], [TPM — name]
- Approvers: [QA lead — name], [Engineering manager — name], [PM — name], [Security — name if applicable], [Compliance — name if applicable]
- Related PRD: [link / reference]
- Related Design Doc: [link / reference]

1. Scope

In scope

[Specifically what this test plan covers]

Out of scope

[Specifically what this test plan does NOT cover]

Dependencies

[Other test plans, systems, or capabilities this plan depends on]

2. Test types and coverage

Unit testing

- Coverage target: [e.g., 80% line coverage; 100% branch coverage on payment paths]
- Owner: [development team]
- Tooling: [framework]

Integration testing

- Coverage target: [e.g., all API contracts; all cross-component data flows]
- Owner: [QA + development]
- Tooling: [framework]

End-to-end / functional testing

- Coverage target: [e.g., all user-facing flows from PRD]
- Owner: [QA]
- Tooling: [framework]

Performance testing

- Coverage target: [e.g., load up to 2x projected peak; sustained for 4 hours]
- Owner: [SRE / QA]
- Tooling: [framework]

Security testing

- Coverage target: [e.g., OWASP Top 10; specific threat-model coverage]

- Owner: [security team]
- Tooling: [framework]

Accessibility testing

- Coverage target: [e.g., WCAG 2.1 AA across all customer-facing screens]
- Owner: [accessibility team or QA]
- Tooling: [framework]

Regression testing

- Coverage target: [e.g., all existing tests in regression suite + new tests added by this change]
- Owner: [QA]
- Tooling: [framework]

UAT (User Acceptance Testing)

- Coverage target: [e.g., representative cohort of 50 users running specific scenarios]
- Owner: [PM + QA]
- Cohort: [who participates]

3. Test environment and data

Test environments

- Environment 1: [name, scale, what's tested here, owner]
- Environment 2: [name, scale, what's tested here, owner]
- Production-like environment: [scale, scope, who has access]

Test data

- Functional test data: [source, refresh cadence]
- Performance test data: [source, scale, generation methodology]
- Edge-case test data: [source — must cover boundary conditions, regulatory scenarios, demographic diversity]
- PII handling: [whether production-like data is used, with what controls]

4. Entry and exit criteria

Entry criteria (must be true before testing starts)

- [Criterion 1, with evidence]
- [Criterion 2, with evidence]
- [Criterion 3, with evidence]

Exit criteria (must be true to declare test complete)

- All P0 tests pass; rate: 100%
- All P1 tests pass; rate: $\geq$ [target %]
- All P2 tests have defect triage decisions; pass rate $\geq$ [target %]
- All P3 tests documented; pass rate not blocking
- All performance criteria met (see Section 2)
- All security criteria met (see Section 2)
- All accessibility criteria met (see Section 2)
- All open defects assigned, prioritized, and have decision (fix-now / fix-later / accept)

5. Schedule and resource plan

Phase	Start date	End date	Owner	Tests covered
[Unit/integration]	[date]	[date]	[name]	[tests]
[Functional]	[date]	[date]	[name]	[tests]

Phase	Start date	End date	Owner	Tests covered
[Performance]	[date]	[date]	[name]	[tests]
[Security]	[date]	[date]	[name]	[tests]
[Accessibility]	[date]	[date]	[name]	[tests]
[UAT]	[date]	[date]	[name]	[tests]
[Regression]	[date]	[date]	[name]	[tests]

6. Defect process

Severity definitions

- P0 (Critical): [definition with examples]
- P1 (Major): [definition with examples]
- P2 (Significant): [definition with examples]
- P3 (Minor): [definition with examples]

Defect lifecycle

- Reported (with reproducer)
- Triaged (severity assigned)
- Assigned to developer
- Fixed (PR merged)
- Verified by tester
- Closed

Tooling

- Defect tracker: [system]
- Defect triage cadence: [frequency, attendees]

Decision authority for "ship despite defect"

- P0/P1 defects: [name, role] decides
- P2 defects: [name, role] decides; can be batch-decided
- P3 defects: documented; not blocking

7. Risk and contingency

Testing risks

- R-001: [Risk] | Likelihood [H/M/L] | Impact [H/M/L] | Mitigation [strategy]
- R-002: [Risk] | Likelihood [H/M/L] | Impact [H/M/L] | Mitigation [strategy]

Contingencies

- If [trigger]: [contingency action; named owner]

8. Sign-off authority

Test type	Sign-off authority	Sign-off criterion
Functional testing	[QA lead]	All P0/P1 pass
Performance testing	[SRE lead]	Performance targets met
Security testing	[Security lead]	All security criteria met
Accessibility testing	[Accessibility lead]	WCAG conformance achieved
UAT	[PM]	Acceptance criteria met
Regression testing	[QA lead]	No regressions vs. baseline

Test type	Sign-off authority	Sign-off criterion
Final ship decision	[Engineering manager + QA lead jointly]	d jointly]

Keywords: test plan template, testing plan template, QA plan template, UAT plan template, test strategy template, test environment template, defect process template, blank test plan

Shared & Cross-cutting · Templates (36)

Template — Automating Work with AI

Fillable Automating Work with AI. Use this canvas to assess whether a specific recurring task is a good candidate for AI automation, select the appropriate pattern, and define the guardrails and checkpoints required before the automation goes live. Complete one canvas per candidate task. Do not combine multiple tasks on a single canvas.

Sections:

- {'field': 'Task Name and Description', 'contents': 'Name the task precisely. Describe what is done, what inputs are consumed, and what output is produced. Example: 'Weekly project status report - compile updates from team, RAID log, and milestone tracker into a 1-page summary for the steering committee.'}
- {'field': 'Frequency and Time Cost', 'contents': 'How often does this task recur? (daily / weekly / per sprint / per phase). How long does it take a human today (hours per occurrence)? Multiply to get hours per month. This is your maximum savings ceiling.'}
- {'field': 'Automate-Worthiness Score', 'contents': 'Rate each dimension 1 (low) to 3 (high): Frequency (3=daily, 2=weekly, 1=less); Structured I/O (3=fully templated, 2=semi-structured, 1=narrative/judgment); Value of time saved (3=high, 2=medium, 1=low); Risk if output is wrong (3=high - reverse this: lower score = more automatable on this dimension). Sum the first three, subtract the risk score. Score >= 5: strong candidate. Score 3-4: automate with strong guardrails. Score < 3: keep human or automate only the data-gathering step.'}
- {'field': 'Judgment and Sensitivity Assessment', 'contents': 'Does this task require negotiation, political judgment, or relationship management? (Y/N). Does the output commit the organisation to a course of action without further review? (Y/N). Is the input data classified above the approved tool tier? (Y/N). If any answer is Y, the task is not suitable for full automation; identify which sub-step can be automated (e.g., data gathering) and which must remain human.'}
- {'field': 'Recommended Pattern', 'contents': 'Select one: Assistant-with-context / Retrieval over project artefacts / Trigger -> Draft -> Review -> Act / Supervised agentic workflow. Justify the selection in one sentence. If selecting L5+ (triggered or agentic), confirm governance approval has been obtained and note the approval reference.'}
- {'field': 'Guardrails and Data Classification', 'contents': 'State the data classification of all inputs. Confirm the selected tool is approved for that classification. List the specific guardrails: access controls, output logging, prompt constraints, prohibited data types. Reference the Responsible AI Usage Guardrails artefact for the project-level rules.'}
- {'field': 'Human Checkpoint Definition', 'contents': 'Name the human reviewer (role, not just name). Define exactly what they review (completeness, accuracy, tone, compliance with template). Define the pass/fail criteria. Define what happens if the output fails (rework, escalate, revert to manual). State the checkpoint frequency.'}
- {'field': 'Owner and Accountability', 'contents': 'Name the owner who is accountable for the quality of every output this automation produces. This person cannot be the AI system.'}

Confirm they have been briefed on the automation, the guardrails, and the checkpoint requirements.}

- {'field': 'Success Metric', 'contents': 'Define the primary metric (e.g., hours saved per week) and the quality metric (e.g., checkpoint rejection rate < 10%). Set a 4-week baseline measurement period before declaring the automation successful. Define the threshold at which the automation will be paused and re-assessed.'}
- {'field': 'Go-Live Readiness Checklist', 'contents': 'Confirm all of: data classification verified; tool tier approved; guardrails documented and in place; human checkpoint owner briefed; rollback/pause procedure defined; entry added to the Automation Candidate Register; initial output quality validated by human review before first live use.'}

HOW TO USE THIS TEMPLATE

Completion guidance: A canvas is complete when all ten sections are filled, the go-live checklist is confirmed, and the automation has been registered in the project's Automation Candidate Register. The canvas is a living document: revisit it when the task, the tooling, or the data classification changes, and at each phase gate as part of the standard review. Completion is the PM's sign-off that the automation is operating within the project's governance framework.

A strong completed version:

- The automate-worthiness score is calculated honestly, including the risk dimension, not just the frequency and time-saving dimensions.
- The judgment and sensitivity assessment identifies specific sub-steps that must remain human, rather than applying an all-or-nothing decision.
- The human checkpoint is defined with a named owner, explicit pass/fail criteria, and a documented failure path - not just 'someone will review it.'
- The success metric includes both an efficiency measure and a quality measure, with a defined threshold for pausing the automation.

Common pitfalls when filling it in:

- Scoring the risk dimension as low to make the overall score more favourable, rather than applying honest assessment of what happens if the output is wrong.
- Leaving the human checkpoint owner field as a role without briefing the actual person, resulting in checkpoints that exist on paper but not in practice.
- Completing the canvas once and never revisiting it, so the guardrails become stale as the task, data, or tooling evolves.
- Treating the canvas as a bureaucratic hurdle rather than a design tool, completing it after the automation is already live rather than before.

Template — Communications Plan

Defines what gets communicated to whom, through which channel, at what cadence, with what message. The artifact most projects under-do.

See example: PMO_Examples.docx 1 (Project Atlas program-level Comms

Plan with audience map, channel guidance, and T-90 → T+30 wave-based comms calendar).

AI enablement

- Tailor message variants per audience — exec summary vs detailed team update vs customer-facing.
- Schedule and send recurring updates from workbook tabs without manual work.
- Measure effectiveness — open rates, engagement, sentiment — and surface where comms aren't

landing.

- Detect comm gaps: stakeholders not receiving updates aligned to their RACI involvement level.

Document Control

Project / program name	[Name]
Plan version	[v1.0]
Owner	[TPM or comms lead]
Last updated	[Date]
—— HOW TO USE THIS TEMPLATE ——	

Completion guidance: Start by completing the stakeholder audience table - segment, information need, channel preference, frequency - before writing a single message, because every other column derives from audience insight; this requires 30-45 minutes with the project sponsor and OCM lead to agree on segmentation. Inputs are the stakeholder register, the project timeline, and any executive communication standards or brand guidelines in effect. The first full draft should be reviewed by the sponsor before any communications are sent, since tone and channel choices reflect sponsor authority.

A strong completed version:

- Every row specifies a named sender, not just a role, because stakeholders read the email, not the org chart.
- Frequency and channel are matched to message type: status updates may be weekly email, but go-live alerts require synchronous channels with confirmed read receipts.
- The plan covers two-way communication checkpoints (feedback surveys, town hall Q&A) not just broadcast messages, so the team can detect resistance early.
- The plan is version-controlled and the PM reviews it monthly, retiring completed items and adding new ones as the project phase changes.

Common pitfalls when filling it in:

- Listing 'all stakeholders' as the audience for every message, which guarantees over-communication to some and under-communication to others.
- Treating the communications plan as a calendar of emails rather than a strategy for building understanding and managing resistance.
- Failing to identify who approves each communication before it is sent, creating last-minute scrambles or unauthorized messages.
- Building the plan for the project team's convenience (weekly status emails) rather than for the audience's information needs.

Template — Communications Plan → Audience Map

Audience	Why we communicate	Key messages	Owner	Frequency
Executive	[Decisions needed,	[Top-line themes]	[Owner]	Weekly /
sponsor	escalations, headline outcomes]			Monthly
Steering	[Governance	[Themes]	[Owner]	Monthly

Audience	Why we communicate	Key messages	Owner	Frequency
	decisions,			
committee	risk visibility]			
Working team	[Operational coordination]	[Themes]	[Owner]	Daily / Weekly
Affected end users	[What's changing, when, what to do]	[Themes]	[OCM / comms]	Per change milestone
Adjacent teams	[Awareness of	[Themes]	[Owner]	Bi-weekly
Audience	Why we communicate dependencies]	Key messages	Owner	Frequency
Vendors / partners	[Coordination, expectations]	[Themes]	[Owner]	Per vendor SLA
Customers (if external)	[Status, value, support]	t] [Themes]	[Market CS]	ing / Per release

[...]

Template — Communications Plan → Channel Guidance

Channel	Best for	Avoid for
Email	Decisions, formal updates, anything searchable later	Real-time coordination, anything urgent
Slack / Teams	Working coordination, transparent	Confidential decisions, wide-
(channel)	team comms	distribution content
Slack / Teams (DM)	Quick clarifications, sensitive topics	Anything others need to see
Status report	Recurring health snapshot	First time anyone is hearing about a problem
Steering committee	Decisions needing executive input	Status-only — push status async
meeting		first
Townhall	Major announcements, change story	Routine updates
1:1 meeting	Sensitive comms, individual coaching, escalation	Anything broadcastable
Written FAQ / wiki	Reusable answers to common questions	Time-sensitive updates
Newsletter / digest	Curated highlights to broad audience	Decisions or asks needing response

Template — Communications Plan → Communications Calendar

When	Audience	Channel	Type	Owner
[Day / cadence]	[Audience]	[Channel]	[Status / decision / change / FYI]	[Name]

[...]

Template — Communications Plan → Crisis & Escalation Communications

Trigger events

[Events that activate the crisis comms protocol — major incident, project red status, regulatory issue, customer impact.]

Crisis comms lead

[Named person + backup. They run the comms response.]

Escalation path

[Who is notified at what severity, and how fast.]

Pre-approved holding statements

[Short statements pre-approved by Legal / Comms so they can be used quickly.]

Template — Communications Plan → Message Framework

Audience	Core message	Supporting points	Proof / evidence
[Audience 1]	[Message]	[2–3 bullets]	[Data, examples, references]
[Audience 2]	[Message]	[...]	[...]
Audience	Co re message Supp	orting points / Proof	evidence

[...]

Template — Delivery Health Check Assessment

Fillable health check assessment.

Sections:

- Scope and reviewer (self / peer / independent)
- Dimension scorecard: dimension | score 1-5 | anchor evidence | trend
- Overall rating and confidence-in-status statement
- Findings table: dimension | finding | severity | recommended action | owner | due
- Top escalations for sponsor/executive
- Comparison to previous assessment

HOW TO USE THIS TEMPLATE

Completion guidance: Complete the scoring criteria and RAG thresholds before assessing any projects, so the assessment is calibrated, not impressionistic. The PMO lead should conduct the initial assessment for each project using inputs from the current schedule, cost report, risk register, and a brief interview with the TPM; expect 30-45 minutes per project. Assessments

must be reviewed by the portfolio sponsor before being shared, to avoid the assessment being the first time a troubled project is surfaced.

A strong completed version:

- Every dimension score (schedule, cost, risk, quality, stakeholder, governance) is supported by one or two specific evidence points, not a gut-feel RAG color.
- Red-rated dimensions have a named intervention, owner, and target resolution date in the 'recommended action' column - not just a red cell.
- Trend arrows (improving, stable, deteriorating) are included alongside point-in-time RAG so the portfolio owner can distinguish a stable red from a rapidly declining amber.
- The aggregate portfolio view shows concentration of risk (e.g., three projects red on the same dimension) that no single project report would reveal.

Common pitfalls when filling it in:

- Letting project teams self-assess without independent PMO validation, producing a portfolio of amber projects that are all 'manageable with close monitoring'.
- Conflating schedule variance (days behind) with schedule risk (probability of missing the milestone), so a project that is 10 days behind on a non-critical path is rated the same as one that is 10 days behind on a hard contractual deadline.
- Omitting governance and decision-quality dimensions, so a project that is on time and budget but making undocumented decisions scores green while silently accumulating risk.
- Publishing the health check without a corresponding action register, making it a reporting artifact rather than a management intervention tool.

Template — Escalation Framework

Fillable Escalation Framework. Use this template to design the Project Atlas escalation framework before the first sprint. Complete the tier table and threshold table first, then validate thresholds with the Programme Director and sponsor before publishing. Every field is mandatory - do not leave thresholds blank.

Sections:

- Tier table (T1-T4: tier, scope, owner, backup, issue types handled)
- Threshold table (issue category, T1 threshold, T2 threshold, T3 threshold, T4 threshold)
- Response SLA table (tier, acknowledgment SLA, resolution SLA, escalation-to-next-tier SLA)
- Routing and backup decision table (trigger event, primary contact, channel, backup, unavailability definition)
- Decision rights table (tier, budget authority \$, scope change authority, vendor escalation authority, regulatory notification authority)
- Escalation log (ID, date raised, tier, issue summary, owner, SLA target, resolution date, outcome, lessons)

HOW TO USE THIS TEMPLATE

Completion guidance: Validate the threshold table with both the Programme Director and the sponsor before the framework goes live - misaligned thresholds discovered after the first real escalation erode trust in the framework. Allow 60-90 minutes for the threshold alignment session.

A strong completed version:

- Every threshold in the threshold table is a number, a date, or a binary condition - no qualitative terms like 'significant' or 'material'.

- The tier table has a named backup for every tier owner, verified against the actual team calendar.
- The escalation log template is linked in the workbook and the SharePoint site before the first sprint starts.

Common pitfalls when filling it in:

- Setting the T3/T4 threshold so low that SteerCo is flooded with operational issues that the TPM should resolve, desensitising governance to real programme threats.
- Copying thresholds from a prior project without validating them against Atlas risk appetite - a ZTNA/PAM programme has different risk tolerance than a standard infrastructure refresh.
- Designing the framework without the sponsor in the room, resulting in thresholds the sponsor later overrides informally, bypassing the framework.

Template — Knowledge Management & Document Control

Fillable Knowledge Management & Document Control. This template establishes the Knowledge Management and Document Control framework for [Project Name]. Complete each section before the first artifacts are baselined. Estimated completion time: 90 minutes for initial setup; 15-minute review each governance cycle.

Sections:

- Repository Structure - define top-level folders, workstream subfolders, and root README
- Naming Convention - complete the lookup table of project code, workstream codes, and document type codes
- Version Control Rules - confirm major/minor version thresholds and archive procedure
- Access and Permissions - list roles, access level, and approval authority; identify gated folders
- Retention Schedule - map document classes to retention periods and destruction procedures
- Knowledge Capture Process - confirm Decision Register owner and SLA; confirm lessons-learned cadence
- Handover Package Contents - list required artifacts, owner, and due date relative to closeout milestone
- Document Review and Approval Workflow - confirm reviewer roles and SLA per document class
- Quality and Compliance Checks - confirm audit owner, frequency, and escalation path for non-compliance

HOW TO USE THIS TEMPLATE

Completion guidance: Before finalising, confirm the repository has been provisioned in the agreed tool (SharePoint, Confluence, etc.) and that role-based permissions have been applied. Walk the core team through the naming convention and version control rules in a 30-minute kickoff - teams that skip this step reliably drift within two sprints. File this document in /Governance/Doc-Control and link it from the Project Charter.

A strong completed version:

- Lookup table for naming codes is complete, pinned to the repository root, and referenced in the team onboarding checklist.
- Handover package has a named owner, a milestone date, and acceptance criteria signed by the Operations Lead before the project enters closeout.
- Lessons-learned cadence is scheduled in the project calendar, not left to discretion.

- Permissions register lists every role, what they can access, who approved it, and when it was last reviewed.

Common pitfalls when filling it in:

- Leaving the naming convention lookup table blank or 'TBD' - without it the convention is not enforceable.
- Assigning document control to 'the team' rather than a named individual - shared ownership produces zero ownership.
- Setting a retention schedule that conflicts with Bristol Financial records policy - align with Legal and InfoSec before finalising.
- Treating the handover package section as optional for 'small' projects - incomplete runbooks at go-live are a top source of post-launch incidents.

Template — Knowledge Transfer Plan

Fillable Knowledge Transfer Plan. Use this plan to document and track all knowledge transfer activities for Project Atlas. Start no later than 60 days before planned close. The plan is not complete until all sign-off columns are populated - do not release resources or close the project until KT is verified.

Sections:

- Knowledge Inventory (all topics requiring transfer)
- Source and Receiver assignment (named individuals)
- Transfer Method per item
- Schedule and Duration (start, end, hours)
- Documentation Artifacts (runbooks, SOPs, diagrams - links and versions)
- Verification Method and Evidence
- Sign-off Status Tracker (per item)
- Gaps and Risks Register
- KT Completion Certificate (final overall sign-off)

HOW TO USE THIS TEMPLATE

Completion guidance: Allow a minimum of 4-6 weeks of active KT for complex technical workstreams (ZTNA policy management, PAM vault operations); simpler administrative or governance topics may complete in 1-2 weeks. The completion certificate should be signed at the same meeting as the Project Closure Report acceptance.

A strong completed version:

- Every row in the knowledge inventory has a named receiver who has confirmed availability
- Verification method is specific (e.g., 'receiver independently resolves a simulated PAM vault lockout scenario') not generic (e.g., 'receiver understands the topic')
- Tacit knowledge items are flagged and assigned a shadowing or pairing method, not a runbook
- Gap register is populated - even if gaps are minor - demonstrating that a deliberate inventory was completed

Common pitfalls when filling it in:

- Listing only documented artifacts in the knowledge inventory and omitting tribal knowledge or architectural rationale
- Setting the verification method as 'receiver confirms understanding' - this is self-declaration, not verification
- Scheduling all KT in the final two weeks of the project, leaving no time to address gaps found during verification

- Omitting vendor-held knowledge from the inventory because it is assumed to be in the documentation - vendor engineers hold tacit knowledge that must be explicitly elicited

Template — Operating Rhythm & Cadence Map

Fillable Operating Rhythm & Cadence Map. Use this template to map every recurring programme event before delivery begins. One row per forum. Complete all columns - write 'TBD by [date]' only if the forum is not yet designed. Calculate the load summary at the bottom before publishing.

Sections:

- Forum inventory table (one row per forum, all columns populated)
- Per-role load summary table (role, total ceremony hours/week, flag if > 6 h)
- Phase transition notes (which forums are added, modified, or retired at each phase gate)
- Calendar series ownership log (who owns each series, when it was last updated)

HOW TO USE THIS TEMPLATE

Completion guidance: The cadence map is ready to publish when every row has a named owner, a stated purpose, and at least one concrete output. Present the per-role load summary to the Programme Director for sign-off before distributing to stakeholders.

A strong completed version:

- The load summary identifies overloaded roles before the programme starts, allowing consolidation rather than discovery through burnout.
- Each forum row links to the folder or board where its outputs are stored, making the map navigable.
- Phase transition notes mean the map proactively evolves rather than becoming stale at phase boundaries.

Common pitfalls when filling it in:

- Treating the cadence map as a one-time planning deliverable rather than a living operations document with an assigned update owner.
- Omitting the load summary, which allows ceremony creep to go undetected until delivery team capacity is consumed.
- Listing attendees by name rather than role, causing the map to go stale every time team membership changes.

Template — Organizational Change Management (OCM) Plan

Manages the human side of change — adoption, resistance, sponsorship, training, reinforcement. The Communications Plan is one component of OCM but not the whole thing.

See example: PMO_Examples.docx 2 (ZTNA Rollout component OCM Plan with populated impact assessment, sponsor coalition with named activities, and resistance management table).

AI enablement

- Score change impact and resistance risk per stakeholder group based on past adoption patterns.
- Recommend interventions tailored to each group's resistance profile.
- Track adoption metrics in real time and surface where reinforcement is failing.
- Personalize change messaging by role, tenure, and prior change history.

Document Control

Project / program name	[Name]
OCM plan version	[v1.0]
OCM lead	[Name, title]
Sponsor	[Name, title]
Date	[Date]
— HOW TO USE THIS TEMPLATE —	

Completion guidance: Open with the change impact assessment before any intervention is planned, because the depth and breadth of impact determines what level of OCM investment is warranted; this assessment requires at least one structured workshop per affected business unit and should not be completed by the project team alone. The OCM lead, HR business partner, and the change sponsor must be aligned on the readiness baseline before the plan is drafted. Inputs are the BRD scope, current-state process maps, workforce data, and any prior change management assessments from related initiatives. Expect 2-3 weeks to produce a credible first draft for a large-scale change.

A strong completed version:

- The stakeholder impact table rates each group on both the depth of change they face and their current readiness, not just their position in the org chart.
- Resistance risks are named and owned, with specific early-warning indicators (e.g., 'drop in voluntary UAT participation below 60%') so the team can detect problems before they compound.
- Interventions are sequenced on a timeline that respects change saturation - no stakeholder group is hit with more than two major interventions in the same two-week window.
- Adoption metrics are defined upfront ('process compliance rate $\geq$ 90% at 30 days post go-live') so success is measurable, not subjective.

Common pitfalls when filling it in:

- Treating OCM as a communications and training plan only, omitting leadership alignment, resistance management, and reinforcement mechanisms.
- Conducting the change impact assessment at the system level ('this replaces the old platform') rather than at the job-task level ('this changes how a loan officer processes approvals every day').
- Assigning OCM activities to the project manager when a dedicated change lead is warranted, then watching both roles be executed poorly.
- Closing out the OCM plan at go-live rather than running a 30-60-90 day reinforcement phase, which is when adoption actually sticks or fails.

Template — Organizational Change Management (OCM) Plan → Adoption Metrics

Metric	Target	Source	Cadence	Owner
[Usage / participation	[%]	[System logs]	[Daily / Weekly]	[Owner]

rate]

[Process compliance]	[%]	[Audit / sample]	[Monthly]	[Owner]
[Sentiment /	[Score]	[Pulse survey]	[Monthly]	[Owner]

satisfaction]

[Productivity / outcome [Target] [Business KPI] [Quarterly] [Owner]
metric]

[Resistance indicators] [Threshold] [Tickets, escalations] [Weekly] [Owner]

Template — Organizational Change Management (OCM) Plan → Approvals

Sponsor	[Name, date]
OCM lead	[Name, date]
TPM	[Name, date]
HR / People partner (if	[Name, date]

applicable)

Template — Organizational Change Management (OCM) Plan → Change Impact Assessment

Affected group	What changes for them	Impact level	Resistance risk	Adoption complexity
[Group 1]	[Specific changes]	High / Med / Low	High / Med / Low	High / Med / Low
[Group 2]	[...]	[...]	[...]	[...]

[...]

Impact factors

- Process change — how much day-to-day workflow changes
- Technology change — new tools, systems, interfaces
- Role change — responsibilities added, removed, or restructured
- Skill change — new capabilities required
- Identity change — perception of the role or function shifts
- Volume change — more or less of the same work
- Cultural change — norms or ways of working that have to shift

Template — Organizational Change Management (OCM) Plan → Change Vision

What is changing

[The change in plain language. Distinguish process, technology, role, structure changes.]

Why we're changing

[Case for change in language that resonates with affected groups, not just the executive sponsor.]

Vision of the future state

[Vivid description of what life looks like once the change is adopted.]

Template — Organizational Change Management (OCM) Plan → Reinforcement & Sustainment

Adoption fades without reinforcement. The 6 months after launch are usually when adoption is won or lost.

- [How we'll measure ongoing adoption]
- [Recognition and celebration]
- [Performance management alignment]
- [Manager reinforcement]
- [Course corrections if adoption stalls]

Template — Organizational Change Management (OCM) Plan → Resistance Management

Source	Likely concern	Response approach	Owner
[Group / role]	[The actual concern in their words]	[How we address it]	[Owner]

[...]

Template — Organizational Change Management (OCM) Plan → Sponsorship & Coalition

Change requires active, visible sponsorship — not just executive endorsement.

Role	Name	Org / function	Active sponsor activities
Primary sponsor	[Name]	[Org]	[Visible activities — not just 'support']
Sponsor coalition	[Name]	[Org]	[Specific activities]

member

Sponsor coalition [Name] [Org] [Specific activities]

member

Change champions	[Names]	[Org / role]	[Activities — peer influence, feedback]
(front line)			

Sponsor activities should be specific and time-bound. 'Be supportive' is not an activity. 'Send a message to the eng org by Friday' is.

Template — Organizational Change Management (OCM) Plan → Training Strategy (high level)

Detailed training plan lives in the Training & Awareness Plan (next template). This section captures the strategy.

- [Audiences requiring training and approximate sizes]
- [Training modalities]
- [Pre-launch vs at-launch vs post-launch training]

- [Knowledge reinforcement strategy]
- [Training success metrics]

Template — Persona Message Matrix

Persona Message Matrix - Template

Document Control

- Program / change: [name]
- Matrix version: v[N], last revised [date]
- Owner: [TPM or OCM lead]
- Reviewers: [sponsor, comms lead]
- Linked Communications Plan: [reference]

How to use this template

List your audiences as rows. For each, complete every column. Validate each row with someone who represents or knows that audience before you publish, because the program office tends to mis-guess the objection and the messenger. The matrix is the source of message content. The Communications Plan schedules it.

Column definitions

- Persona: the specific audience segment
- WIIFM: the benefit or relief in their terms
- Change in their language: the initiative described in their words
- The ask: the concrete action required (awareness-only is valid, but say so)
- Likely objection: the concern they will raise, including the unspoken version
- Proof points they trust: the evidence that moves this persona
- Tone and register: formal or plain, detailed or headline, reassuring or urgent
- Channel and messenger: where it goes and who delivers it

Matrix (repeat the block once per persona)

Persona: [name the segment]

- WIIFM: [...]
- Change in their language: [...]
- The ask: [...]
- Likely objection: [...]
- Proof points they trust: [...]
- Tone and register: [...]
- Channel and messenger: [channel] / [who delivers it]

Persona: [...]

Persona: [...]

Cross-checks before you publish

- Does every persona have a distinct WIIFM, or did some rows collapse into the same generic benefit?
- Does every persona have a concrete ask, or an explicit awareness-only note?
- Is the messenger named for each row, and have you secured them?
- Have you written the objection you would rather not say out loud?
- Did someone who knows each audience review its row?

Related artifacts

- Audience and Persona Messaging Matrix (Artifact #66): the framework behind this template

- Communications Plan (Artifact #8): where this content is scheduled
- Persona Message Matrix examples: Project Atlas, and University variant

Keywords: persona message matrix template, audience messaging template, WIIFM template, message differentiation template, stakeholder messaging template, blank persona matrix, communications template, change messaging template, messenger template

Template — Phase-Gate (Tollgate) Reviews

Fillable Phase-Gate (Tollgate) Reviews. This template provides the Phase-Gate Review structure for [Program Name] at [Organization]. Gate definitions, authorities, and exit criteria must be completed and approved in the Plan phase - before any gate is reached. The gate review pack template (sections 3-4) is completed by the TPM for each gate and distributed to the gate authority at least 3 business days before the gate meeting.

Sections:

- Gate Definitions and Authorities table - Gate ID, Phase Transition, Gate Name, Gate Authority, Quorum, Decision Options
- Entry and Exit Criteria per Gate - one block per gate; each criterion numbered and binary; evidence source named
- Gate Review Pack cover page and executive summary template
- Schedule, Scope, Financial, Risk/Issues, Dependency, Quality status sections - one RAG summary block each
- Criteria Scorecard table - Criterion ID, Text, Evidence Reference, Met Y/N/Partial, Notes
- Go-with-Conditions Log table - Condition ID, Gate, Description, Owner, Due Date, Status
- Gate Decision Log table - permanent record of all gate decisions
- No-Go Protocol - blank remediation plan template

HOW TO USE THIS TEMPLATE

Completion guidance: The gate definitions and criteria table (sections 1-2) should be completed and signed off by the gate authority in the Plan phase, not at the gate itself; if the gate authority will not engage with criteria until the gate meeting, that is a governance risk to escalate to the sponsor. Allow 2-3 hours with the TPM and workstream leads to draft criteria; plan for one revision cycle with the gate authority before baseline.

A strong completed version:

- Every exit criterion has an evidence document reference named - not 'TBD' - before the gate is reached
- Go-with-conditions log is empty at program start and entries are added only at actual gates, not pre-populated with anticipated conditions
- The gate authority has confirmed their availability for the gate meeting and agreed to read the pack 3 days in advance
- At least one No-Go criterion is genuinely gate-stopping for this program - if every criterion could theoretically be waived, the gate has no teeth

Common pitfalls when filling it in:

- Writing criteria in the pack the week before the gate rather than in Plan phase - criteria will be written to match what already exists
- Gate authority listed as 'Steering Committee' without a named chair or quorum rule - responsibility is diffuse and the decision can be avoided
- Go-with-conditions accepted for mandatory criteria without a hard close date - the condition becomes permanent background noise

- Criteria scorecard not completed before the gate meeting - the meeting becomes a discussion of whether criteria are met rather than a governance decision

Template — Responsible AI Usage Guardrails

Fillable Responsible AI Usage Guardrails. This template captures the Responsible AI Usage Guardrails for [Program Name] at [Organization]. Complete all sections before AI-assisted work begins. Fields in [brackets] require program-specific input. Data-classification entries must be validated by the CISO delegate before the document is approved.

Sections:

- Scope and Applicability - list all roles and tool categories in scope
- Data Classification Matrix - four-row table (Restricted / Confidential / Internal / Public) with examples from this program and permitted AI tool classes per row
- Approved Tools Register - columnar log with Tool Name, Approval Date, Approver, Permitted Data Classes, Deployment Model, Expiry Review Date
- Human-in-the-Loop Requirements - describe the review-and-certification step and where it is logged
- Prohibited Uses - bulleted list of concrete forbidden actions
- Prompt Engineering and Output Hygiene - rules for stripping sensitive tokens and validating outputs
- Accountability and Breach Response - named roles, 1-hour reporting SLA, root-cause timeline
- Audit Logging - log fields, retention period, review cadence

HOW TO USE THIS TEMPLATE

Completion guidance: Allow 90-120 minutes with the TPM, CISO delegate, and one workstream lead to populate the data classification matrix and approved tools register; those two sections drive the practical utility of the entire document. Obtain CISO sign-off before distributing to the team, and circulate an acknowledgment form to all members before any AI tool is used on program work.

A strong completed version:

- Data classification matrix cites real system names from this program, not generic categories
- Approved tools register has at least one entry per tool currently in use, with a named approver and an expiry review date within 6 months
- Human-in-the-loop log format is agreed and a sample entry is shown so the team knows exactly what to record
- Prohibited uses list has been reviewed by the CISO and includes at least one item specific to the security/identity context of this program

Common pitfalls when filling it in:

- Leaving the data classification matrix at generic label names (Restricted/Confidential) without mapping to actual program systems - teams will default to permissive interpretations
- Omitting the approved tools register or treating it as a one-time snapshot - new tools will be adopted informally and the policy will be circumvented
- No named reviewer in the human-in-the-loop section - 'someone reviews it' is not enforceable
- Skipping CISO sign-off to save time in Plan phase - this removes the security authority's endorsement and weakens enforceability

Template — Security Awareness Campaign

Fillable Security Awareness Campaign. Fillable security awareness campaign plan for a technology change program.

Sections:

- Audience segment table with risk profile
- Threat scenario register per segment
- Campaign module schedule with owner and channel
- Phishing simulation plan with scenario and metrics
- Behavior metric dashboard (leading and lagging)
- Reinforcement and escalation mechanism
- Channel and cadence plan
- Completion and compliance tracker
- Campaign retrospective template

HOW TO USE THIS TEMPLATE

Completion guidance: Start with audience segmentation and threat scenario mapping, which requires input from the CISO and change impact assessment before content is designed. Convene change lead, CISO representative, comms lead, and one workstream lead per high-risk segment for a 90-minute design session; inputs are the Change Impact Assessment, Risk Register, and any existing security incident data by role. Phishing simulation scenarios must be reviewed and approved by the CISO before scheduling.

A strong completed version:

- Threat scenarios are specific to the change (ZTNA/PAM) and the segment, not recycled from last year
- Phishing simulation feedback loop is designed before the simulation runs
- Behavior metrics baseline captured before campaign launches so delta is measurable

Common pitfalls when filling it in:

- Using completion rate as the only success metric
- Designing simulations without CISO approval, creating legal and trust risk
- No reinforcement plan beyond go-live

Template — Team AI Enablement & Literacy

Fillable Team AI Enablement & Literacy. Fillable AI enablement and literacy plan for the delivery team.

Sections:

- Role tier table with permitted use cases
- Permitted and prohibited data classification table
- Prompt standards with example prompts per role tier
- Verification discipline checklist
- Enablement path by role with completion gate and due date
- Uplift baseline and target metrics table
- Audit and compliance log pointer
- Refresh trigger register

HOW TO USE THIS TEMPLATE

Completion guidance: Begin with the data classification and prohibited uses table, which requires sign-off from the CISO or data governance lead before any team AI use begins.

Convene TPM, AI practice lead, workstream leads, and a CISO representative for a 60-minute scoping session; inputs are the program data classification policy, toolkit capability list, and RAID log. Complete role-tier enablement paths within 10 business days of plan sign-off.

A strong completed version:

- Data classification boundaries confirmed by CISO before training starts
- Verification checklist embedded in artifact sign-off, not standalone
- Uplift baseline captured before training so delta is measurable

Common pitfalls when filling it in:

- Skipping data classification sign-off and assuming 'internal only' is safe
- No completion gate so enablement paths are started but not finished
- Treating verification as optional rather than a quality gate

Template — Team Onboarding & Ramp Plan

Fillable Team Onboarding & Ramp Plan. Fillable onboarding and ramp plan for one joiner or a cohort.

Sections:

- Joiner roster with role and start date
- Program context brief
- Access and clearance tracker with owner and due date
- Tooling setup checklist with verification step
- Ways of working summary
- Role and deliverable map
- 30/60/90 milestone table
- Buddy assignment and check-in log
- Completion sign-off block

HOW TO USE THIS TEMPLATE

Completion guidance: Start with the access and clearance tracker at least 10 business days before the start date to avoid week-one idle time. Convene the workstream lead, buddy, and TPM for a 30-minute briefing session on day one; inputs are the approved RACI, resource plan, and latest program status report. Target all checklist items green before end of week one.

A strong completed version:

- Every access item has a named owner and a date
- 30/60/90 milestones are output-specific, not activity-based
- Buddy check-ins are calendared, not ad hoc

Common pitfalls when filling it in:

- Leaving access requests until start date
- Generic 30/60/90 targets that cannot be assessed
- Skipping vendor rows because procurement 'handles it'

Template — Training & Awareness Plan

Operationalizes the training strategy from the OCM Plan. Specifies who is trained on what, when, by whom, in what format, with what assessment.

AI enablement

- Generate role-specific training content variants from a single source-of-truth knowledge base.
- Personalize training paths based on existing skills and prior training history.

- Auto-assess comprehension and adapt the path when learners struggle with specific concepts.
- Track completion and competence in real time; surface where reinforcement is needed.

Document Control

Project / program name	[Name]
Training plan version	[v1.0]
Training lead	[Name, title]
Date	[Date]
Linked OCM Plan	[Reference]
—— HOW TO USE THIS TEMPLATE ——	

Completion guidance: Derive the training audience matrix directly from the change impact assessment in the OCM plan so that training effort is proportional to impact, not to org seniority; this mapping session takes 60-90 minutes with the OCM lead and the functional leads for each impacted group. Training modality decisions (ILT, eLearning, job aids) should be finalized before content development begins, because modality drives timeline and budget. Inputs are role-based process maps, the system functional spec, and any existing training infrastructure (LMS, preferred vendors) constraints.

A strong completed version:

- The training matrix maps each audience segment to specific learning objectives, not just course titles, so curriculum can be evaluated against the objective, not the clock hours.
- Completion metrics and target dates are set per audience segment, with a named training coordinator accountable for each segment's completion rate.
- The plan includes a proficiency validation mechanism (assessment score threshold, observed task completion, or supervisor sign-off) not just attendance records.
- Super-user and train-the-trainer populations are identified and scheduled ahead of general rollout, with their own readiness criteria before they deliver to end users.

Common pitfalls when filling it in:

- Designing one generic training course for all user roles, resulting in both under-training power users and overwhelming casual users.
- Scheduling training too early in the project lifecycle so content changes with the system, requiring expensive re-delivery.
- Measuring training success by enrollment or seat time rather than demonstrated competency or post-go-live performance.
- Treating the training plan as complete at go-live and failing to account for new-hire onboarding, refresher training, or retraining after system updates.

Template — Training & Awareness Plan → Assessment & Completion

•	[How completion is tracked — LMS, sign-in, manager attestation]
•	[Assessment method — quiz, scenario test, observed performance]
•	[Pass criteria — score threshold, retake policy]
•	[Recordkeeping — what's retained for compliance]

Template — Training & Awareness Plan → Audiences & Learning Needs

Audience	Size	Current state	Required state	Learning gap
[Audience 1]	[Count]	[What they know today]	[What they need to know]	[Specific gaps]
[Audience 2]	[...]	[...]	[...]	[...]

[...]

Template — Training & Awareness Plan → Awareness Activities

Awareness ≠ training. Awareness is broader, lighter, designed to ensure people who aren't being trained still understand what's happening.

Activity	Audience	Channel	Cadence	Owner
Project intranet page	Everyone	Intranet	Always-on, refreshed weekly	[Owner]
Townhall briefing	Affected org	Live / recorded	[Cadence]	[Owner]
Manager talking points	All managers	Email / wiki	Per milestone	[Owner]
FAQ / help desk content	Affected users	Self-service portal	Updated weekly	[Owner]

[Other]

Template — Training & Awareness Plan → Delivery Schedule

Wave	Audience	Modules	Start	End	Delivery owner
Pre-launch	[Champions / leads]	[Modules]	[Date]	[Date]	[Owner]
Launch wave 1	[Audience]	[Modules]	[Date]	[Date]	[Owner]
Launch wave 2	[Audience]	[Modules]	[Date]	[Date]	[Owner]
Post-launch	[All]	[Refresh]	[Date]	[Date]	[Owner]

reinforcement

Template — Training & Awareness Plan → Logistics

•	[Training environments / sandbox access]
•	[Materials hosting and version control]
•	[Train-the-trainer plan if scaling]
•	[Translation / localization needs]
•	[Accessibility — closed captions, screen reader, alternate formats]

PROCURE

Template — Training & Awareness Plan → Training Curriculum

Module	Audience	Learning objectives	Duration	Modality	Owner
[Module 1]	[Audiences]	[What they'll do after]	[Hours]	[ILT / e-	[Owner]
Module	Audience	Learning objectives	Duration	Modality	Owner

[...]

Modality guidance

- Instructor-led training (ILT) — best for complex topics, interactive practice, sensitive change
- E-learning — best for procedural knowledge, scalable delivery, self-paced
- Job aids / cheat sheets — best for in-the-moment reference
- Peer / champion-led — best for adoption support, especially cultural or behavioral change
- Manager-led — best for context-setting, team-specific application, accountability

Template — Training & Awareness Plan → Training Effectiveness Metrics

•	Training completion rate — % of target audience completed by deadline
•	Comprehension — % passing assessment first attempt
•	Application — % demonstrating competence on the job (sampled, observed)
•	Confidence — self-reported readiness pre / post
•	Help desk volume — trending down post-training (good) or up (training gap)
•	Reinforcement uptake — % engaging with refresh content

Template — Training & Awareness Plan → Training Objectives

[3–5 measurable outcomes the training must deliver. Not 'people are trained' but 'people can perform [specific task] correctly without supervision within X days'.]

Shared & Cross-cutting · Worked Examples (17)

1 — Communications Plan — Project Atlas

Communications Plan — Project Atlas, Wave 4 IDP Final Cutover

Document Control

Program: Project Atlas (Zero Trust & Identity Modernization)

Plan version: v4.1, last revised 2027-04-15, next review 2027-05-15

Owner: Casey Morrison (Program PM), with input from R. Patel (OCM Lead) and Internal Comms

Anchor event: Wave 4 IDP final cutover, August 17, 2027 (program week 84)

Scope: All Wave 4 communications plus standing program comms through program closeout
Context

Wave 4 is the final IDP cutover for Project Atlas. The previous three waves (Q4 2026 - Q2 2027) migrated approximately 2,400 employees off the legacy identity provider; Wave 4 migrates the remaining 1,100 employees, decommissions the legacy IDP, and triggers the program's final stabilization period. The cutover is the highest-stakes communication event in Atlas because every remaining employee, several customer-facing applications, and regulatory reporting all depend on it landing cleanly.

Communication objectives

Four outcomes the plan is designed to produce:

1. All 1,100 Wave 4 employees know the cutover date by T-30, know what they need to do by T-14, and know exactly what's happening on cutover day by T-1. Measured by training enrollment rate (target 95% by T-14) and pre-cutover survey results (target 85% confidence by T-7).
2. Customer-facing applications using the legacy IDP (4 applications, ~12,000 external users) are notified by T-30 with explicit migration windows and contingency information. No customer is surprised on cutover day.
3. Regulators (state banking examiner, GLBA examiner) and the audit committee receive structured updates at T-60, T-14, and T+7. The cutover is positioned within the broader Atlas program's risk posture, not as a standalone event.
4. The internal organization knows the program is reaching final cutover. Builds confidence in the Atlas team for future programs and creates the conditions for clean program closeout. Steering knows by T-90; engineering org-wide knows by T-30; full company by T-14.

Audience map

Eight stakeholder audiences, with what each needs, when they need it, and the appropriate tone:

Steering committee (5 people: Sandra Park CISO, Linda Walsh CIO, Mark Williams CTO, Robert Stein CRO, Martin Chen PMO)

- Needs: Risk posture, contingency plans, decision points before cutover. Confidence level. Resourcing for stabilization.
- Cadence: Standing biweekly; pre-cutover briefing T-14; cutover day status; post-cutover retrospective T+14
- Tone: Sober, data-anchored, decision-oriented. No surprises.
- Channel: Steering pack, in-person briefing for T-14 and T+14

Engineering leadership (~30 people: directors and senior managers across CIO and CTO orgs)

- Needs: Technical readiness, dependency status, support coverage during cutover, escalation paths
- Cadence: Weekly Atlas all-hands; pre-cutover technical briefing T-30; cutover day Slack channel active
- Tone: Direct, technical, problem-solving oriented. Concerns surfaced early.
- Channel: All-hands meeting, dedicated #atlas-cutover Slack channel, technical readiness review docs

Wave 4 employees (1,100 people: remaining migrations)

- Needs: What's changing, what they need to do, when, what to expect on cutover day, where to get help

- Cadence: Heads-up at T-60; formal announcement at T-30 with training; reminder at T-14; daily comms T-7 through T-1; cutover day live updates
- Tone: Clear, calm, confident. Avoids both alarm and minimization. Anticipates anxiety about access loss.
- Channel: Email primary; manager cascade for context; Slack for questions; intranet hub for self-serve

All employees (~3,500 across the company, including the ~2,400 already migrated)

- Needs: General awareness that final cutover is happening, modest celebration of program completion
- Cadence: Brief mention in monthly all-hands at T-30; company email at T-7; closeout email at T+30
- Tone: Confident, brief. Not the headline of their week, but they should know.
- Channel: All-hands meeting, company-wide email

Customers (12,000 external users on 4 customer-facing applications)

- Needs: Notification of authentication change, migration window, contingency contacts, support hours during cutover
- Cadence: Initial notification at T-60 with calendar invites; reminder at T-14; cutover-day status page; post-cutover confirmation at T+1
- Tone: Professional, clear, customer-service-oriented. Acknowledges potential disruption.
- Channel: Email from product manager (not from Atlas); status page updates; in-app banners T-7 onward

Regulators (state banking examiner, GLBA examiner)

- Needs: Structured update on Atlas progress, risk posture for cutover, post-cutover confirmation
- Cadence: Quarterly examiner brief includes Atlas; pre-cutover formal letter at T-14; post-cutover confirmation letter at T+7
- Tone: Formal, factual, evidence-anchored. No marketing language.
- Channel: Formal letters via CRO and General Counsel; in-person briefing if requested

Vendors (Okta, Cloudflare, BeyondTrust, Yubico, SailPoint)

- Needs: Cutover schedule, support expectations during the window, escalation contacts
- Cadence: Vendor sync biweekly through program; dedicated cutover-readiness call at T-30 and T-7
- Tone: Operational, partnership-oriented. Specific commitments documented.
- Channel: Vendor sync calls; dedicated readiness checklist owned by procurement

Support function (Help Desk, IT Support, Customer Support — ~80 people)

- Needs: What to expect, escalation paths, FAQ scripts, staffing for cutover day
- Cadence: Briefing at T-30; FAQ scripts at T-14; staffing plan confirmed T-7; cutover-day Slack channel active
- Tone: Practical, scenario-anchored. Anticipates the volume and shape of incoming questions.
- Channel: Function-specific briefings; shared FAQ doc; #atlas-cutover-support Slack channel

Channel guidance

Slack

- Best for: real-time technical coordination, question-and-answer with engineering, sponsor escalation when meetings aren't possible

- Worst for: official announcements, regulatory communication, customer communication, communications that need a paper trail
- Cutover-specific channels: #atlas-cutover (all-hands), #atlas-cutover-support (support function), #atlas-cutover-eng (engineering)

Email

- Best for: official announcements, customer communication, regulatory communication, anything that needs a paper trail or reaches people not on Slack
- Worst for: time-sensitive coordination, back-and-forth conversation, situations where read-receipt matters
- Distribution lists: wave4-employees, atlas-leadership, atlas-customers (per-app), atlas-regulators

Meetings

- Best for: high-stakes decisions, sensitive topics, situations where reading the room matters, briefings that need Q&A, recovery-period sponsor alignment
- Worst for: status updates that could be email, large groups (>15 people without structured agenda)
- Standing meetings: weekly Atlas all-hands (Tuesdays); biweekly steering (alternating Wednesdays); cutover-readiness review T-30, T-14, T-7

Other (intranet hub, status page, formal letters)

- Intranet hub: persistent self-serve content for Wave 4 employees (FAQ, training links, what-to-expect)
- Status page: real-time cutover-day updates for customers, automated where possible
- Formal letters: regulatory communication, going through CRO and General Counsel

Wave 4 cutover cadence — T-90 through T+30

The full pre/post-launch communication cadence around the August 17, 2027 cutover. Each entry shows when, audience, channel, the actual message content, and owner.

T-90 (May 19, 2027) — Steering committee pre-brief

- Audience: Steering committee (5)
- Channel: Steering pack supplement, in-person briefing
- Message:

Wave 4 cutover is scheduled for August 17, 2027. This is the final IDP cutover for Project Atlas — 1,100 remaining employees migrate, the legacy IDP is decommissioned, and the program enters its stabilization period.

Current readiness signals (as of T-90):

- Wave 3 stabilization complete; production-load lessons applied to Wave 4 plan.
- Engineering technical readiness checklist published; tracking 14 open dependencies.
- Support function staffing model published; surge capacity confirmed for Aug 17-24.
- Regulator pre-notification scheduled for T-60 (quarterly examiner brief) and T-14 (formal pre-cutover letter).

Decision needed at this meeting:

- Confirm Wave 4 timing (no reason to defer based on current state).
- Confirm stabilization resourcing (4 component PMs through Aug 31; 2 PMs through Sep 16).
- Acknowledge handoff to Cloud Security Operations function at T+30.

Recommendation: proceed. Next decision point: T-14 final go/no-go.

- Owner: Casey Morrison (Program PM), with Sandra Park (sponsor)

T-90 (May 19, 2027) — Engineering leadership pre-brief

- Audience: Engineering leadership (30)
- Channel: Atlas all-hands meeting agenda item
- Message:

Wave 4 timeline confirmed for August 17. Director-level engagement needed on the following before June 30:

- Dependency confirmations from each system owner (14 systems integrating with the IDP — list in shared readout doc).
- Cutover-day on-call coverage rosters.
- Rollback decision authority — confirm who in your org has the call to invoke rollback if criteria are met.

No surprises before cutover is the operating principle. If something looks off in the next 90 days, raise it immediately — don't save it for the readiness review.

- Owner: Casey Morrison

T-60 (June 18, 2027) — Wave 4 employee heads-up

- Audience: Wave 4 employees (1,100)
- Channel: Manager cascade (managers brief their teams using talking points), followed by intranet hub publication
- Message (manager talking points + intranet content):

What's happening: Your team is in Wave 4 of Project Atlas, Bristol's identity modernization program. On August 17, 2027, you'll be migrated from the legacy identity provider to the new platform.

Why this matters to you: How you sign in to Bristol systems is changing. Today, you connect to the VPN first, then access internal tools. After August 17, you'll access tools directly through the new identity platform — no separate VPN step. You'll also use a new MFA method (FIDO2 security key or authenticator app, depending on role).

Why we're doing this: The legacy identity provider doesn't support the security controls Bristol needs (continuous device verification, conditional access policies, audit-ready access logs). The change closes audit findings from the 2025 SOC 2 examination and aligns Bristol with the Zero Trust mandate the board adopted in January 2026. The first three waves (~2,400 employees) have already migrated; Wave 4 completes the program.

What you need to do now: Nothing yet. Today's heads-up is so you can plan around it — don't schedule major work or critical client deliverables for August 17-18.

What's coming: Formal communications and training enrollment open July 18. Final reminders go out August 3 and August 10. Cutover happens overnight August 17 (1 AM - 6 AM ET); you'll find your access migrated when you sign in that morning.

Where to ask questions: #atlas-cutover Slack channel (active now), or email atlas-help@bristol-financial.com. Your manager can also direct questions to the OCM team.

- Owner: R. Patel (OCM Lead) coordinates manager cascade content; managers deliver

T-60 (June 18, 2027) — Customer notification

- Audience: 12,000 external users on 4 customer-facing applications
- Channel: Email from each product manager (not from Atlas team); calendar invites attached for the maintenance window
- Message (per-app email; example below from Bristol Treasury Portal):

Subject: Scheduled authentication maintenance — August 17, 2027

What's happening: On August 17, 2027, between 1:00 AM and 6:00 AM ET, we will be performing scheduled maintenance on the authentication system for Bristol Treasury Portal. During the maintenance window, Bristol Treasury Portal will be temporarily unavailable.

Why this matters to you: When you sign in after the maintenance window, you will be required to re-authenticate. Your saved credentials and active sessions will not carry over. Your data, account information, transaction history, and saved preferences are not affected — only the sign-in process changes.

Why we're doing this: This change strengthens authentication security across Bristol Financial's customer-facing applications. It is part of a broader modernization of Bristol's identity infrastructure that completes August 17.

What you need to do, by when: No action is required before August 17. On August 17, plan to re-authenticate when you next sign in. If you use Bristol Treasury Portal during overnight hours (1 AM - 6 AM ET), schedule alternative access for that window.

What's coming: A reminder email will be sent on August 3 (T-14) and August 10 (T-7). On August 17, an in-app banner will display real-time maintenance status. A confirmation email will be sent on August 18 once the maintenance is complete.

Where to ask questions or raise concerns: Reply to this email and your Bristol Treasury Portal account team will respond within one business day. For urgent issues during the maintenance window, call the Bristol Treasury Portal support line at [number] (extended hours: 12 AM - 8 AM ET on August 17). Live status available at status.bristol-financial.com.

- Owner: Per-app product manager signs and sends; content drafted by Atlas comms with product-team review; Bristol External Comms approves before send

T-60 (June 18, 2027) — Regulator structured update

- Audience: State banking examiner; GLBA examiner
- Channel: Quarterly examiner brief — Atlas occupies one structured section (5-7 pages)
- Message (formal regulator brief; structured factual content, no marketing language):

Section: Project Atlas — Identity & Zero Trust Modernization

Status: Final phase scheduled. Wave 4 cutover August 17, 2027 completes the program scope.

Background: Project Atlas is Bristol Financial's program to modernize identity infrastructure (identity provider, ZTNA, PAM, MFA, access review) across all employees and customer-facing applications. The program was approved January 2026 in response to (1) findings from the 2025 SOC 2 Type II examination regarding identity governance and access review controls, and (2) the board-adopted Zero Trust mandate of January 2026.

Why this matters for examination: The cutover affects authentication for approximately 1,100 remaining employees and four customer-facing applications serving 12,000 external users. Post-cutover, Bristol's identity controls will satisfy the previously-noted SOC 2 control gaps. Operational ownership transitions from the program team to the Cloud Security Operations function on September 16, 2027 (T+30).

Risk posture: Three risk categories tracked weekly through cutover. (1) Customer access continuity: mitigated through 5-hour overnight maintenance window, in-app banners 7 days prior, and rollback capability validated through Wave 1 dress rehearsal. (2) Employee access continuity: mitigated through staged migration over previous three waves (~2,400 employees migrated successfully), comprehensive training, and 80-person support function staffing during stabilization. (3) Audit-trail continuity: all access events logged in both legacy and new systems for 90 days post-cutover to ensure audit-period completeness.

What is required of regulators, by when: No action is required from regulators in advance. Bristol will provide a formal pre-cutover letter at T-14 (August 3, 2027) confirming readiness state, and a formal post-cutover confirmation letter at T+7 (August 24, 2027) reporting outcome and any material findings.

What's coming: Pre-cutover formal letter August 3, 2027. Post-cutover confirmation letter August 24, 2027. Atlas closeout report (covering full program retrospective and operational handoff) included in Q4 2027 examiner brief.

Where to direct questions or concerns: Robert Stein, Chief Risk Officer (rstein@bristol-financial.com or via Bristol's Office of General Counsel) is the named point of contact. Sandra Park, Chief Information Security Officer, is available for technical questions on request.

- Owner: Robert Stein (CRO) signs; content prepared by Casey Morrison and reviewed by General Counsel

T-30 (July 18, 2027) — Wave 4 formal announcement

- Audience: Wave 4 employees (1,100), with copy to managers
- Channel: Email primary; intranet hub published with same content; manager talking points distributed for follow-up conversations
- Message (employee email + intranet content):

Subject: Action required — your Wave 4 cutover is August 17

What's happening: On August 17, 2027 (overnight, 1 AM - 6 AM ET), your access to Bristol systems will be migrated from the legacy identity provider to the new identity platform. This is the final phase of Project Atlas, Bristol's identity modernization program. You are in Wave 4 — the last group to migrate.

Why this matters to you: Three things change for you on August 17. (1) Sign-in: you will sign in directly through the new identity platform — no separate VPN connection step. (2) Multi-factor authentication: you will use a FIDO2 security key (issued separately for higher-privilege roles) or the Bristol Authenticator app (most roles); your current MFA method will not work after cutover. (3) Single sign-on: most internal tools will be available through one sign-in instead of repeated credential prompts.

Why we're doing this: The legacy identity provider doesn't support continuous device verification, conditional access policies, or audit-ready access logs — controls Bristol now needs for both regulatory compliance (SOX, GLBA, SOC 2) and the Zero Trust mandate the board adopted in January 2026. The first three waves (~2,400 employees) have already migrated. Wave 4 closes the program.

What you need to do, by when:

1. By August 3 (T-14): complete the 30-minute Wave 4 training module. Enrollment link below. The training covers what changes for your sign-in flow, how to use the new MFA, and what to do on cutover day.
2. By August 10 (T-7): if your role requires a FIDO2 security key, pick yours up from your local IT support office. (Eligibility list maintained at intranet.bristol-financial.com/atlas/wave4-roles.)
3. On August 17: when you sign in to your computer that morning, follow the on-screen prompts to complete the one-time re-enrollment (estimated 15-20 minutes). Block 30 minutes on your calendar for August 17 morning.

What's coming: Reminder email on August 3 (with training-completion status). Daily reminders begin August 10 and continue through August 16. Cutover overnight August 17. Post-cutover confirmation email morning of August 17.

Where to ask questions or raise concerns:

- Self-serve: intranet hub at intranet.bristol-financial.com/atlas (FAQ, training links, video walkthroughs)
- Slack: #atlas-cutover (active now; OCM and engineering response within 4 business hours)
- Email: atlas-help@bristol-financial.com (response within 24 hours)

- Your manager: for context-specific questions about your team's workflow or schedule
- Cutover-day support: extended help desk hours August 17 (5 AM - 10 PM ET); call x4357 or use #atlas-cutover-support Slack
- Owner: R. Patel (OCM Lead) drafts and sends; copy review by Casey Morrison and Sandra Park; manager talking points distributed to ~85 Wave 4 managers two days before send

T-30 (July 18, 2027) — All-employee mention

- Audience: All employees (3,500) — the broader org, including the ~2,400 already migrated
- Channel: Monthly all-hands meeting (90-second segment within larger meeting)
- Message (verbal talking points for Linda Walsh, CIO):

"Quick Atlas update. On August 17, we hit final cutover — Wave 4. About a third of you are still on the legacy system; you'll be hearing more from your managers and from the OCM team in the coming weeks. The other two-thirds — thank you for your patience through your earlier waves. We're closing this out. The Atlas team has been at this for nearly two years; this last cutover gets us to a Zero Trust posture and clears the SOC 2 findings we've been carrying. If you have questions, the #atlas-cutover Slack channel is open and the OCM team is responsive. More from your managers if you're in Wave 4."

Why brief: All-employees who aren't in Wave 4 don't need detail at T-30. The point is awareness that the program is reaching closeout, not orientation to a change that doesn't affect them. Wave 4 employees are getting the formal announcement on the same day through email — this all-hands mention is supplementary, not primary.

Where to ask questions: #atlas-cutover Slack channel (linked from the all-hands deck); Wave 4 employees should reference their email for primary instructions.

- Owner: Linda Walsh (CIO) delivers; talking points drafted by Casey Morrison; deck slide approved by Sandra Park

T-30 (July 18, 2027) — Engineering technical readiness review

- Audience: Engineering leadership (30) plus key engineers (~50)
- Channel: 90-minute readiness review meeting; dedicated readout doc
- Message (meeting agenda + outputs):

Structured review of Wave 4 cutover readiness. Each system owner walks through:

- Current readiness state (green / yellow / red) with evidence.
- Open dependencies and remediation plan.
- Rollback criteria and decision authority.
- On-call coverage for cutover window (1 AM - 12 PM ET August 17) and stabilization week (August 18-24).

Output: readout doc with each system's status, open issues logged to RAID for resolution before T-7 final review, escalations to Casey Morrison for any red items.

Operating principle: red is OK at T-30; red at T-7 is not. Surface concerns now.

- Owner: J. Liu (ZTNA component lead) chairs; Casey Morrison documents

T-30 (July 18, 2027) — Vendor cutover-readiness call

- Audience: Vendor partners (Okta, Cloudflare, BeyondTrust, Yubico, SailPoint)
- Channel: Joint vendor call; written checklist signed off by each vendor
- Message (checklist items):
- Confirm dedicated vendor support coverage during cutover window (1 AM - 12 PM ET August 17).
- Confirm escalation contacts (primary + backup) with response time commitments (P0: 15 min, P1: 1 hour).

- Confirm post-cutover monitoring through August 24.
- Confirm vendor TAMs aware of stabilization period support expectations.
- Confirm any planned vendor-side maintenance for August 14-21 (none expected; flag if changes).
- Owner: Procurement, with technical owners from Atlas team

T-14 (August 3, 2027) — Wave 4 reminder + final preparation

- Audience: Wave 4 employees (1,100); separate version for managers with team-level training-completion data
- Channel: Email; intranet hub refreshed with countdown banner; manager dashboard updated
- Message (employee email):

Subject: Two weeks to your Wave 4 cutover — final preparation steps

What's happening: Your Wave 4 cutover is in 14 days. On August 17, your Bristol sign-in moves to the new identity platform. This email is your final preparation reminder.

Why this matters to you: Two weeks from today, the way you sign in changes. If your training isn't complete, your FIDO2 key isn't picked up (where required), or you don't know what to expect on cutover day, your morning of August 17 will be slower than it needs to be. The team that's already migrated through Waves 1-3 told us the difference between a smooth cutover morning and a frustrating one comes down to two things: training done in advance, and having the support contacts handy before you need them.

Why we're doing this: (Same as the T-30 announcement — final phase of Bristol's identity modernization, completes Project Atlas, closes audit findings, completes the Zero Trust posture.)

What you need to do, by when:

1. If your training is not yet complete, complete it by August 10 (one week from today). Enrollment link below. Current training-completion rate for Wave 4: [actual percentage at send time]. Your manager has visibility into your team's status.
2. If you require a FIDO2 security key, pick it up from your local IT support office by August 10. Eligible-roles list at intranet hub.
3. Save the cutover-day support contacts in your phone now (see "Where to ask questions" below).
4. On August 17, plan for 30 minutes in your morning for re-enrollment. Don't schedule client calls or critical work for the first hour of your day.

What's coming: Daily reminder emails begin August 10 (T-7) and continue through August 16 (T-1). Cutover overnight August 17. Confirmation email morning of August 17.

Where to ask questions or raise concerns:

- Slack: #atlas-cutover (response within 4 business hours)
- Email: atlas-help@bristol-financial.com (response within 24 hours)
- Your manager: for context-specific questions
- Cutover-day support: x4357 (extended hours August 17 5 AM - 10 PM ET) or #atlas-cutover-support Slack
- Self-serve: intranet hub for FAQ, training links, video walkthroughs

If you have a concern that hasn't been addressed (a workflow that won't work post-cutover, a dependency the migration plan doesn't seem to cover, an access need that's not on the eligibility lists): email atlas-help@bristol-financial.com with subject line "T-14 concern" — these go to a triage queue with response within 8 business hours.

- Owner: R. Patel drafts and sends; manager-version drafted from same source with team-level training-completion data appended

T-14 (August 3, 2027) — Steering pre-cutover briefing

- Audience: Steering committee (5)
- Channel: 60-minute in-person briefing; slide pack
- Message (briefing outline):

Final go/no-go review for Wave 4 cutover.

Sections:

1. Risk posture — current state of all material risks; mitigations confirmed.
2. Readiness state — system-by-system green/yellow/red with evidence.
3. Contingencies — rollback plan, decision criteria, decision authority. Walk through 3 scenarios (mild issue, significant issue, crisis) and what each triggers.
4. Resourcing — cutover-day on-call, stabilization-week staffing, support function surge capacity.
5. Communications readiness — pre-cutover comms tracking; post-cutover comms drafted and queued.
6. Decision: confirm cutover proceeds August 17.

Decision authority: Sandra Park as sponsor. Recommendation: Casey Morrison.

If go: T-7 daily countdown begins; T-1 final pre-flight; T-0 cutover.

If defer: trigger contingency comms plan (drafts in runbook).

- Owner: Casey Morrison presents; Sandra Park decides

T-14 (August 3, 2027) — Regulator formal pre-cutover letter

- Audience: State banking examiner; GLBA examiner
- Channel: Formal letter from CRO via General Counsel; signed hardcopy mailed and e-filed through examiner portal
- Message (formal letter content; structured for audit-record purposes):

Subject: Pre-cutover notification — Project Atlas Wave 4

What is happening: On August 17, 2027, between 1:00 AM and 6:00 AM ET, Bristol Financial will perform the final phase of Project Atlas, the identity infrastructure modernization program previously communicated in Bristol's quarterly examiner briefs. The maintenance window will affect authentication for the four customer-facing applications listed in Appendix A and approximately 1,100 employees in the final Wave 4 migration cohort.

Background: Project Atlas was initiated January 2026 in response to (1) findings from the 2025 SOC 2 Type II examination regarding identity governance, and (2) the board-adopted Zero Trust mandate of January 2026. The program scope, governance, and progress have been reported in quarterly examiner briefs since Q2 2026.

Why this matters for regulatory oversight: The cutover does not introduce new business risk and does not change the substance of any regulatory control, account, transaction, or customer relationship. The cutover does change the technical mechanism of authentication and access logging. Post-cutover, Bristol's identity controls satisfy the previously-noted SOC 2 control gaps; documentation of the new control state will be available for next-cycle examination.

Risk posture and contingencies: All known risks tracked through the program risk register (RAID Log Atlas-001 through Atlas-247, available on examiner request) are at acceptable levels at T-14. A go/no-go review is scheduled for August 16 at 4:00 PM ET; if the review surfaces material risk, the cutover will be deferred and Bristol will notify regulators within 24 hours of the

deferral decision. Rollback capability has been validated through Wave 1 dress rehearsal and confirmed functional through pre-cutover rehearsal scheduled for August 14 (T-3).

What is required of regulators, by when: No advance action is required. Examiners may request access to any program artifacts (charter, RAID, status reports, decisions log, rehearsal results) on request. A formal post-cutover confirmation letter will follow within 7 days of cutover (target send date: August 24, 2027) reporting: (a) cutover outcome, (b) any unplanned customer or employee access disruptions, (c) operational handoff to the Cloud Security Operations function.

Where to direct questions or concerns: Robert Stein, Chief Risk Officer (rstein@bristol-financial.com; phone via Bristol Office of General Counsel) is the named point of contact for this notification. Sandra Park, Chief Information Security Officer (spark@bristol-financial.com), is available for technical or program-level questions. Casey Morrison, Project Atlas Program Manager, is available for cutover-execution questions.

Appendices: A — list of customer-facing applications affected; B — Wave 4 migration scope and contingency summary; C — pre-cutover rehearsal results (will be provided August 15 if requested).

- Owner: Robert Stein (CRO) signs; content drafted by Casey Morrison; reviewed by General Counsel and approved by Sandra Park before send

T-14 (August 3, 2027) — Customer reminder

- Audience: 12,000 external users on 4 customer-facing applications
- Channel: Email reminder + in-app banner activated (banner goes live in all 4 applications T-14 morning)
- Message (per-app email; example from Bristol Treasury Portal):

Subject: Reminder — Bristol Treasury Portal scheduled maintenance August 17

What's happening: This is a reminder that on August 17, 2027, between 1:00 AM and 6:00 AM ET, we will perform scheduled maintenance on the authentication system for Bristol Treasury Portal. The application will be temporarily unavailable during this window.

Why this matters to you: When you sign in after the maintenance window, you will be required to re-authenticate. Your saved credentials and active sessions will not carry over. If you use Bristol Treasury Portal during overnight hours, plan alternative access for the maintenance window.

Why we're doing this: This is the final phase of a security infrastructure modernization initiative across Bristol Financial. After August 17, your sign-in is supported by the same modernized authentication infrastructure used for all Bristol customer-facing applications.

What you need to do, by when: No advance action is required. On August 17 between 1 AM and 6 AM ET, expect the application to be unavailable. After the maintenance window, plan a few extra minutes for re-authentication on your next sign-in.

What's coming: A final reminder will be sent on August 10 (T-7), with a daily countdown banner in-app from August 10 onward. On August 17, real-time status will be available on the in-app banner and at status.bristol-financial.com. Confirmation will be sent on August 18 once the maintenance is complete.

Where to ask questions or raise concerns: Reply to this email — your Bristol account team will respond within one business day. For urgent questions, call the Bristol Treasury Portal support line at [number]. Subscribe to status.bristol-financial.com for real-time updates. For specific questions about your account configuration, contact your account manager directly.

- Owner: Per-app product manager; in-app banner activated by product engineering on T-14 morning

T-7 (August 10, 2027) — Daily countdown begins

- Audience: Wave 4 employees (1,100) primary; engineering and support function receive related but role-specific versions
- Channel: Daily 8:00 AM email to Wave 4 employees + Slack pinned message in #atlas-cutover; engineering/support get parallel daily Slack stand-up posts
- Message (Wave 4 employee daily email, day 7 example — content adjusts daily T-7 through T-1):

Subject: 7 days to cutover — readiness check

What's happening: One week until Wave 4 cutover. On August 17 (overnight 1 AM - 6 AM ET), your access migrates to the new identity platform. Daily reminders run from today (T-7) through August 16 (T-1).

Why this matters to you: Today is the last day to complete remaining preparation if you've fallen behind. Tomorrow's email will include final-week logistics; the days after that focus on cutover-day expectations. After today, the time for catch-up shrinks fast.

Why we're doing this: Final phase of Project Atlas — Bristol's identity modernization. Completes the Zero Trust posture and closes outstanding audit findings.

What you need to do today, by end of day:

1. Confirm your training is complete. Current Wave 4 training-completion rate: [percentage]. If yours is not, the link is below; the module takes 30 minutes.
2. If your role requires a FIDO2 security key (eligibility list at intranet hub) and you have not picked yours up, today is the deadline.
3. Save these support contacts in your phone: x4357 (cutover-day help desk, extended hours August 17), atlas-help@bristol-financial.com.
4. Block 30 minutes on your calendar for August 17 morning (re-enrollment time).

What's coming: Daily emails will continue through August 16. Each day will cover one specific cutover-day topic: T-6 sign-in changes, T-5 MFA changes, T-4 SSO changes, T-3 known issues from Waves 1-3, T-2 cutover-day timing, T-1 final pre-flight. All emails preserved in the intranet hub if you miss any.

Where to ask questions or raise concerns:

- Slack: #atlas-cutover (response within 2 business hours during T-7 to T-1)
- Email: atlas-help@bristol-financial.com (response within 12 hours during T-7 to T-1)
- Cutover-day specific: x4357 (extended hours August 17), #atlas-cutover-support Slack
- Issue-specific: if you have a concern not yet addressed, email atlas-help@bristol-financial.com with subject "T-7 concern" — triage queue with 4-hour response
- Engineering daily Slack post (parallel cadence, terse): Day 7 readiness state. Open issues count. Today's focus: [daily topic]. Owner: J. Liu.
- Support function daily Slack post (parallel cadence, terse): Day 7 staffing confirmation. FAQ-script status. Today's drill: [scenario]. Owner: Help Desk Lead.
- Owner: R. Patel drafts daily employee email; J. Liu posts engineering Slack; Help Desk Lead posts support Slack; all three threads coordinated in #atlas-cutover-leads

T-7 (August 10, 2027) — Final vendor readiness confirmation

- Audience: Vendor partners
- Channel: Email + brief sync call (15 min)
- Message:

Final vendor readiness confirmation for August 17 cutover.

Confirmed via this call:

- Vendor support coverage 1 AM - 12 PM ET August 17 (escalation contacts in vendor sheet — confirm names + numbers).
- On-call schedules synced with Bristol on-call schedules.
- Vendor-side maintenance freeze August 14-21 (no planned changes).
- Post-cutover monitoring through August 24 confirmed.
- Stabilization-week support expectations acknowledged.

Action: Each vendor confirms by email by EOD August 11. Any issue escalates to Procurement immediately.

- Owner: Procurement

T-3 (August 14, 2027) — Pre-cutover rehearsal communication

- Audience: Engineering leadership, support function, steering committee
- Channel: Email + #atlas-cutover Slack
- Message:

Pre-cutover rehearsal complete (executed August 13).

Findings:

- All cutover steps executed in non-production successfully end-to-end.
- One issue identified: legacy IDP session cleanup script ran 12 minutes longer than budgeted. Mitigation: budget revised to 6:15 AM ET completion (adds 15 minutes); customer comms unchanged (still showing 1-6 AM window with "may extend slightly" note added).
- Rollback path tested in non-production successfully.

Open issues: None at red. Two yellow items in RAID (RAID-W4-027, RAID-W4-031) tracking to closure by EOD August 15.

Go/no-go review: Tomorrow (August 15) at 4:00 PM ET. Sandra Park, Casey Morrison, J. Liu, R. Patel attending. Recommendation: proceed.

- Owner: Casey Morrison

T-1 (August 16, 2027) — Final pre-flight readiness

- Audience: Steering, engineering leadership, support function, all Atlas team
- Channel: Final 30-minute go/no-go meeting; email confirmation post-meeting
- Message (post-meeting email):

Subject: Atlas Wave 4 — GO for cutover

Final go decision confirmed by Sandra Park (CISO). Cutover proceeds at 1:00 AM ET tomorrow, August 17.

Final state:

- All systems green. Zero red items in RAID.
- On-call schedules active (engineering, support function, vendor partners).
- Customer comms queued for 1:00 AM ET (status page) and 6:30 AM ET (post-cutover email).
- Employee comms queued for 6:15 AM ET.
- Steering update queued for 4:00 PM ET end-of-day.

Tonight: Casey Morrison and J. Liu on standby. R. Patel activates comms war room at 12:30 AM ET tomorrow.

See you on the other side.

- Owner: Casey Morrison

T-0 (August 17, 2027) — Cutover day live communications

- Audience: Engineering, support, steering, customers, employees — varies by time of day

- Channel: Multiple — see hourly schedule below
- Cutover day operates on a tight, pre-rehearsed comms schedule. Each communication has a named owner, a pre-drafted template, and a delivery time. Casey Morrison runs the war room and authorizes each send.

Hourly comms schedule:

1:00 AM ET — Cutover begins

- Status page transitions to "Maintenance in progress." Pre-drafted text: "Bristol Treasury Portal and related applications are undergoing scheduled authentication maintenance. Expected completion: 6:00 AM ET. Real-time updates posted here every 30 minutes."
- Owner: Status page automated, with manual override available to product team

2:00 AM, 4:00 AM, 5:00 AM ET — Engineering check-in posts

- Channel: #atlas-cutover Slack
- Content: state of cutover, percentage complete, any active issues, on-call status. Format pre-drafted as fill-in-the-blank template.
- Owner: J. Liu (ZTNA component lead) drafts; Casey Morrison reviews and posts

6:00 AM ET — Cutover complete

- Status page transitions to "Operational." Pre-drafted text: "Authentication maintenance complete. All services operational. If you experience issues, see [support contact details]."
- Owner: Status page; manual confirmation by Casey Morrison

6:15 AM ET — Wave 4 employee post-cutover email

- Channel: Email to all 1,100 Wave 4 employees + intranet hub status update
- Message:

Subject: Cutover complete — your access is migrated

What's happening: Cutover is complete. Your Bristol access has been migrated to the new identity platform.

Why this matters to you: When you sign in this morning, the on-screen prompts will guide you through one-time re-enrollment (~15-20 minutes). Today's sign-in flow is different from yesterday's; this email tells you exactly what to expect.

What you need to do, by when: Allow 30 minutes for re-enrollment when you sign in this morning. Don't schedule client calls or critical work for the first hour of your day. Follow on-screen prompts; if you get stuck, the support contacts below have extended hours today.

What's coming: Stabilization period through August 24 (T+7). Support function staffing is elevated through that window. Day-after status email tomorrow morning. Week-1 retrospective communication August 24.

Where to ask questions or raise concerns:

- Cutover-day help desk: x4357 (extended hours today: 5 AM - 10 PM ET)
- Slack: #atlas-cutover (live monitoring all day)
- Slack: #atlas-cutover-support (help desk and support specialists)
- Email: atlas-help@bristol-financial.com (response within 4 hours today)
- Walk-up support stations: [list of locations] open 7 AM - 7 PM ET
- Owner: R. Patel (drafted day before, sent at 6:15 AM by automated scheduler with Casey Morrison's pre-authorization)

6:30 AM ET — Customer post-cutover email + status page final update

- Channel: Per-app email + status page

- Message (per-app, abbreviated): "Maintenance complete. All services operational. If you experience issues with sign-in, [per-app support contact]. Subscribe to status.bristol-financial.com for ongoing notifications."
- Owner: Per-app product manager

8:00 AM ET — Slack post to #atlas-cutover

- Audience: Engineering, support, steering, all Atlas team
- Content: "Cutover complete. Stabilization period begins. Support function staffed for elevated volume through August 24. Daily war-room standups continue 9 AM through August 21. Open issues at this time: [list]. Casey Morrison."
- Owner: Casey Morrison

Throughout the day — ad-hoc updates as needed

- #atlas-cutover Slack channel monitored by Casey Morrison and OCM team
- If Tier 2 escalation triggered (significant issue), Sandra Park notified within 30 minutes; steering committee notified within 2 hours via email; status page updated
- If Tier 3 crisis triggered (clear customer impact, rollback considered, regulatory implications), formal crisis comms protocol activated (see Crisis & Escalation section below)

4:00 PM ET — End-of-day steering committee update

- Channel: Email to steering committee + Sandra Park briefs CIO/CTO/CRO/General Counsel verbally
- Content: state of cutover (closed/ongoing), ticket volume vs. forecast, any open issues, projected stabilization timeline
- Format: structured dashboard email; pre-drafted template
- Owner: Casey Morrison drafts; Sandra Park co-signs

8:00 PM ET — End-of-day employee/customer summary

- Channel: #atlas-cutover Slack pinned post + status page final entry for the day
- Content: total day-1 sign-in events, support ticket volume, top issues seen, what stabilization period focuses on tomorrow
- Owner: Casey Morrison

Where to ask questions or raise concerns (cutover day specifically):

- Cutover-day help desk: x4357 (extended hours 5 AM - 10 PM ET)
- Slack: #atlas-cutover (live monitoring; Casey Morrison or designate responding within 30 min during business hours)
- Walk-up support stations at HQ and three regional offices (locations listed in employee email)
- Critical-path issues only: page Casey Morrison directly via PagerDuty (extension provided to operations leads)
- Owner: Casey Morrison runs the war room and orchestrates all comms; R. Patel drafts employee/customer comms (pre-staged); J. Liu handles engineering comms; Help Desk Lead handles support comms

T+1 (August 18, 2027) — Day-after status

- Audience: Steering, engineering leadership, support function, Wave 4 employees, manager network
- Channel: Email + Slack updates in #atlas-cutover; manager talking points distributed
- Message (Wave 4 employee email, primary version):

Subject: Day-after status — Wave 4 cutover

What's happening: Wave 4 cutover completed yesterday. Stabilization period continues through August 24. This email summarizes overnight activity and what to expect this week.

Why this matters to you: If you experienced issues yesterday and they're still unresolved, this email tells you where to escalate. If everything went smoothly, you can move ahead with confidence — the stabilization period is for catching residual issues that don't show up until people use the new flow in real work scenarios.

Day-1 summary:

- Total successful migrations: [number]
- Total support tickets opened: [number] vs. forecast [number]
- Top 3 issues seen: [list, e.g., "FIDO2 key registration delays for ~15 users (resolved by 9 AM); SSO integration intermittent for one third-party tool (workaround posted to intranet hub); stale browser sessions requiring full sign-out/sign-in (FAQ posted)"]
- Any rollback considerations: [none / description]

What you need to do, by when:

- If your access is working as expected, no action is required.
- If you're experiencing issues that are not on the resolved list above, contact the cutover-day help desk today (extended hours through end of day): x4357 or #atlas-cutover-support Slack.
- If you noticed something that doesn't seem right but isn't urgent (workflow oddity, slowness, prompt you don't expect), report it via atlas-help@bristol-financial.com — these go to the stabilization triage queue.

What's coming this week: Daily war-room standups continue 9 AM ET through August 21.

Day-3 status communication August 20. Week-1 retrospective communication August 24 (T+7).

Help desk extended hours continue through August 21; normal hours resume August 24.

Where to ask questions or raise concerns: same channels as cutover day — x4357, atlas-help@bristol-financial.com, #atlas-cutover, your manager. Stabilization triage queue email: atlas-stabilization@bristol-financial.com (response within 8 business hours).

- Engineering leadership / steering version: structured dashboard with same data + system-level metrics (latency, error rate, log completeness), tracked against pre-cutover baseline
- Owner: Casey Morrison drafts steering version; R. Patel drafts employee version; both reviewed by Sandra Park

T+7 (August 24, 2027) — Week-1 retrospective communication

- Audience: Steering, engineering leadership, all employees, regulators (separate per-audience versions)
- Channel: Multi-channel cascade through the day
- Each version below covers the same factual ground tailored to audience needs.

Steering committee version (in regular biweekly steering meeting + email summary):

- Format: Full week-1 retrospective in steering meeting; structured summary email
- Content: cutover outcome (success/issues), full ticket volume by category, top 5 lessons learned, stabilization status, projected closeout timeline, any handoff-blocking issues for Cloud Security Operations
- Decision points: any extended stabilization needed; readiness to declare cutover successful and begin closeout activities
- Owner: Casey Morrison presents; Sandra Park decides

Engineering leadership version (Atlas all-hands + retrospective session):

- Format: 60-min retrospective session, structured around what worked / what didn't / what we'll change next time

- Content: technical lessons (rollback strategy validation, dress rehearsal value, on-call coverage), process lessons (which comms worked, which didn't), people lessons (where we burned out, where coverage was thin)
- Outputs: lessons logged to Lessons Learned Register; specific items escalated to closeout report
- Owner: J. Liu chairs; Casey Morrison facilitates

All-employee version (mention in next monthly all-hands, supplementary email):

- Subject: Project Atlas final cutover — complete
- What's happening: Last week's Wave 4 cutover marks the end of the active migration phase of Project Atlas. The program now enters closeout (stabilization through end of August, operational handoff to Cloud Security Operations on September 16, formal closeout report October 1).
- Why this matters to you: If you migrated last week, your sign-in is now on the new platform; the support contacts you've been using continue through August 24, then transition to standard help desk channels. If you're not in Wave 4, you've already been on the new platform — this just means the program officially closes.
- Why we did this: As covered in earlier comms — closes SOC 2 audit findings, completes board-mandated Zero Trust posture, retires legacy infrastructure, sets up Cloud Security Operations function for steady-state.
- What you need to do, by when: Nothing. If you experience any access or sign-in issues, contact your local IT support; the program-specific channels phase down on August 24.
- What's coming: Standard help desk hours resume August 25. Cloud Security Operations function takes operational ownership September 16. Atlas closeout report published October 1.
- Where to ask questions: Through August 24, the program-specific channels are still live (x4357, #atlas-cutover, atlas-help@). After August 24, contact your local IT support or the standard Bristol help desk.

Regulator version (formal post-cutover confirmation letter):

- What is happening: On August 17, 2027, Bristol Financial completed the final phase of Project Atlas (Wave 4 IDP cutover) within the planned maintenance window (1:00 AM - 6:00 AM ET). All four customer-facing applications (Appendix A) and the final 1,100-employee migration cohort are now on the modernized identity platform.
- Outcome: [structured factual summary — total successful migrations, total support tickets, any unplanned customer disruptions, rollback considerations and disposition].
- Material findings: [structured list, or "none material" if applicable]. Any material findings include: nature, scope, current status, remediation plan, target resolution date, regulatory implications.
- Why this matters for regulatory oversight: The new identity controls now in place satisfy the previously-noted SOC 2 control gaps; documentation of the new control state will be available for next-cycle examination. Operational ownership transitions from the Atlas program team to the Cloud Security Operations function on September 16, 2027 (T+30).
- What is required of regulators, by when: No action is required. Examiners may request access to any program artifacts on request. The program closeout report (covering full retrospective, lessons learned, and operational handoff) will be included in the Q4 2027 examiner brief and is available on examiner request prior to that.
- Where to direct questions or concerns: Robert Stein, CRO (named contact). Sandra Park, CISO (technical questions). Casey Morrison, Program Manager (program-specific questions).

- Owner: Casey Morrison coordinates all four versions; per-channel owners draft (Casey: steering; J. Liu: engineering; R. Patel: employee; Robert Stein: regulator); Sandra Park reviews all before send

T+30 (September 16, 2027) — Adoption metrics and closeout pre-comms

- Audience: Steering, all employees, customers (status page only); operational handoff happens this date
- Channel: Email to steering and employees + status page final entry + intranet hub closeout summary
- Message (employee version):

Subject: Project Atlas — closing the program

What's happening: 30 days post-cutover. Project Atlas closes today. Operational ownership of the identity platform, ZTNA, PAM, MFA, and access review controls transitions to the Cloud Security Operations function as of today.

Why this matters to you: If you've been using the program-specific channels (x4357, #atlas-cutover, atlas-help@bristol-financial.com) for support, those channels phase down today. From tomorrow forward, identity-related issues go to standard help desk channels. The Cloud Security Operations function (led by [Director name], reporting to Sandra Park) is the new owner; their team has been part of the Atlas program since January and is fully briefed on the operational state.

30-day adoption summary:

- Wave 4 successful migration rate: [percentage]
- 30-day Wave 4 satisfaction (post-cutover survey): [percentage positive]
- Total support tickets across stabilization period: [number]
- Top resolved issue categories: [list]
- Issues remaining in active resolution: [list, or "none material"]
- Audit-period control state: confirmed satisfied (SOC 2 control gaps closed; documentation handed to Risk function)

Why we did this: Project Atlas began January 2026 in response to the 2025 SOC 2 findings on identity governance and the board's January 2026 Zero Trust mandate. The program has now delivered: a modernized identity platform across all 3,500 employees and four customer-facing applications; ZTNA replacing the legacy VPN; PAM for privileged access; MFA modernization (FIDO2 + Bristol Authenticator); a formal access review process. The audit findings that initiated the program are closed. The Zero Trust mandate is delivered.

What you need to do, by when: Nothing. If you have any outstanding issues, contact the standard help desk; they have the context and the runbooks.

What's coming: Atlas closeout report published October 1, 2027 (board-level summary, lessons learned, operational handoff documentation). Standard examiner brief Q4 2027 includes Atlas closeout content. Cloud Security Operations function continues operating these capabilities indefinitely.

Where to ask questions or raise concerns: Standard help desk for any access/identity issues. Cloud Security Operations function for capability-level questions (contact in intranet hub directory). Casey Morrison and the Atlas team are still available for retrospective questions through October 1.

- Steering version: structured 30-day metrics dashboard + handoff confirmation; Sandra Park co-signs the operational handoff to Cloud Security Operations
- Customer status page entry: "30-day post-cutover update: all services operational. Standard support channels active. Future updates from this status page will reflect Cloud Security Operations function steady-state operations."

- Owner: Casey Morrison coordinates final program comms; Cloud Security Operations function director takes over from this point forward

Standing communications (program-level, not wave-based)

Communications that run continuously alongside the wave-based work, all the way through program closeout:

Weekly Atlas all-hands (Tuesdays, 30 min, ~30 attendees): engineering leadership and Atlas team. Status, blockers, decisions needed. Owner: Casey Morrison.

Biweekly Steering (Wednesdays, 60 min, ~5 attendees): steering committee. RAG status, risks requiring sponsor attention, decisions requiring sponsor authority. Owner: Casey Morrison; Sandra Park chairs.

Monthly engineering org all-hands mention (~5 minutes within larger meeting): broader engineering org awareness. Atlas progress in 60 seconds. Owner: Linda Walsh or Mark Williams alternating.

Quarterly board update (~10 minutes within larger CISO board update): board awareness. Atlas in context of broader security program. Owner: Sandra Park, with input from Casey Morrison.

Quarterly examiner brief: regulatory communication, structured Atlas section. Owner: Robert Stein, with content from Casey Morrison.

Crisis & escalation communications

The protocol when something goes wrong before, during, or after cutover. Three escalation tiers:

Tier 1 — Issue (no customer impact, no executive involvement)

- Engineering team handles directly. Logged in #atlas-cutover Slack. Status page unchanged unless extending into customer-impact.
- Communication: internal only, no broader audience.

Tier 2 — Significant issue (potential customer impact OR escalating ticket volume OR exceeding stabilization plan)

- Casey Morrison notifies Sandra Park within 30 minutes. Steering committee notified within 2 hours via email. Status page updated.
- Communication: customers notified via status page; affected employees notified via email; regulator notification considered if material.

Tier 3 — Crisis (clear customer impact OR rollback being considered OR regulatory implications)

- Sandra Park briefs CIO, CTO, CRO, and General Counsel within 30 minutes. Casey Morrison runs the war room. Public-facing comms drafted by Comms team in coordination with General Counsel.
- Communication: customers notified via direct email + status page; regulators notified via formal letter; employees notified via company-wide email if access broadly impacted; board notified if material.

Standing crisis comms protocol: drafts of customer notification, regulator notification, and rollback announcement are pre-written and stored in the runbook. Reduces time-to-comm during actual crisis.

Effectiveness measurement

How the plan knows whether it's working:

Pre-cutover signals (T-30 through T-1):

- Training enrollment rate (target 95% by T-14, actual tracked weekly)
- Pre-cutover survey results (target 85% confidence among Wave 4 employees by T-7)

- Slack channel question volume (sudden spike indicates communication gap)
- Manager-reported confidence (informal poll at T-14 standup)

Cutover-day signals:

- Status page subscriber count (proxy for customer engagement)
- Ticket volume vs. forecast (target 30% above baseline; over 100% triggers Tier 2 escalation)
- Support function staffing utilization (target 80%; over 95% indicates undercommunication)

Post-cutover signals (T+1 through T+30):

- Help desk volume by category (drops below baseline by T+14)
- Wave 4 satisfaction survey (target 75% positive by T+30)
- Regulator inquiry volume (zero is the target; any inquiry triggers review)

Feedback loops:

- Daily during cutover week: 5 PM debrief among Casey Morrison, R. Patel, J. Liu
- Weekly during stabilization: lessons captured in #atlas-cutover Slack, escalated to Lessons Learned Register
- T+30 retrospective: full plan effectiveness review, findings inform program closeout report and future wave plans

Related artifacts

- Artifact #8 (Communications Plan): the structural artifact this example populates
- Artifact #11 (Stakeholder Register): the audience analysis that feeds the audience map
- 33 — Recovery Plan — Project Atlas: the recovery context from week 13 that established the discipline this Wave 4 plan inherits

Keywords: Communications Plan example, comms plan example, Project Atlas example, Wave 4 cutover, T-90 cadence, T-30 cadence, launch communications, pre-launch comms, cutover communications, communications cadence, audience map, channel guidance, communications calendar, stakeholder communications, comms cadence, T-minus cadence, cutover day comms, post-cutover communications, regulator communication, customer notification, engineering all-hands, IDP migration communications, identity migration comms, full communications plan, complete comms plan, populated comms plan

HOW TO READ THIS EXAMPLE

Why this example works: This plan earns its keep because every message is engineered backward from a stakeholder reaction, not forward from a project milestone. Notice how channel, frequency, and owner are specified per audience segment, and how the plan distinguishes between informing, engaging, and mobilizing - those are not the same verb and the plan treats them differently.

Key judgment calls:

- Choosing asynchronous email for the board tier and synchronous town halls for the frontline, recognizing that compression of information up the hierarchy and participation down the hierarchy require opposite formats.
- Setting the communications freeze window around the holiday code-freeze rather than maintaining artificial cadence, which would have trained stakeholders to ignore comms.
- Assigning message ownership to the CISO for security rationale and to HR for the behavioral change ask, splitting the messenger by audience psychology rather than org chart.

Adapting it to your context:

- The Atlas audience map (board, CISO, IT ops, end users) is a reusable tier model; replace the named individuals and adjust the count of tiers to match your org's actual decision hierarchy.
- The milestone-triggered communications beats (kickoff, pilot go-live, org-wide cutover, hypercare close) are reusable; substitute your program's critical path dates.
- The two-way feedback loop mechanism (pulse survey after each major beat) is Atlas-specific in its tooling but the pattern - send, measure reaction, adjust next message - should be preserved regardless of platform.

2 — OCM Plan — ZTNA Rollout

OCM Plan — ZTNA Rollout (Project Atlas component #2)

Document Control

Component: ZTNA Rollout (Project Atlas component #2)

OCM plan version: v2.4 (2026-04-15), next review 2026-05-15

Owner: R. Patel — embedded OCM resource (50% on Project Atlas, 40% on Cloud Migration program, 10% on org-level OCM capacity development)

Component PM: J. Liu (ZTNA Component Lead)

Primary sponsor: Sandra Park (CISO)

Engineering co-sponsor: Mark Williams (CTO)

Coalition: Linda Walsh (CIO), Robert Stein (CRO)

Anchor scope: ZTNA rollout to all 3,500 Bristol Financial employees + ~250 contractors + 50 vendor user populations, executed over four waves between Q4 2026 and Q3 2027

Context

ZTNA is the largest user-facing change in Project Atlas. The other Atlas components — IDP migration, PAM, MFA, access review — touch employee experience but mostly through their interaction with ZTNA. This is the component that changes how every Bristol employee actually accesses internal applications, every working day, for the rest of their time at Bristol.

That makes ZTNA the OCM-heaviest component of the program. Employees are not migrating between equivalent systems; they are moving from a network-perimeter mental model (connect to VPN, you're in) to an application-layer access model (every application access verifies identity, device posture, and policy, regardless of where the user is). The technology change is real, but the behavior change is bigger: employees have to stop expecting "I'm on the VPN, I have access" and start expecting "I have access to the specific applications my role needs, on this device, in this context, right now."

This plan is organized in eight sections covering the full change-management lifecycle: vision, impact assessment, sponsorship, resistance management, training, reinforcement, adoption metrics, and approvals. Each section is populated with the actual decisions made for the ZTNA rollout — real audiences with real population sizes, real sponsors with real commitments, real resistance patterns the team has already observed in the engineering pilot. Adapt the structure to your context; the specifics here belong to ZTNA at Bristol.

1 — Change Vision

What is changing

Bristol Financial is replacing legacy VPN with Zero Trust Network Access (ZTNA). The change affects how every employee, contractor, and vendor user accesses internal applications.

Concrete differences for the average employee:

- Login flow changes from "connect to VPN, then access apps" to "access apps directly through ZTNA gateway with continuous identity verification"

- Always-on connectivity — no more "remember to connect to VPN" before sensitive work
- Apps load faster from home, coffee shops, hotels (no VPN concentrator bottleneck)
- Some apps now require periodic re-authentication; we explain which apps and why in pre-wave training
- Network access is no longer a "you're either on the corporate network or you're not" binary; access is granted per-application, per-session, based on identity + device posture + policy

Why we're changing

Legacy VPN exposes the entire internal network once a user connects. A compromised laptop with a valid VPN session is an attacker on the network with broad lateral-movement capability. ZTNA grants access application-by-application, evaluated continuously against identity, device posture, and policy — even when the user is sitting in a Bristol office. This is what "Zero Trust" means for our network: never trust based on location alone, always verify against current state.

In employee terms, three reasons to expect this change to land well:

- Better security: a compromised laptop cannot roam the network; an attacker has to compromise each application's access independently, and continuous evaluation surfaces anomalies fast
- Better experience: faster access from anywhere; no VPN to remember to connect; no "is the VPN slow today?" Slack messages
- Required by external mandates: SOC 2 Type II findings (2025 examination) explicitly identified perimeter-VPN dependency as a control gap; cyber insurance carrier requires Zero Trust posture for renewal terms; State banking examiner has indicated alignment expectation for next examination cycle

Vision of future state

Six months after the final wave, nobody at Bristol thinks about VPN. They open their laptop, sign in to the new identity platform, and the applications they need are there — same flow at the office, at home, in a hotel in Singapore. The "I forgot to connect to VPN" help desk tickets are gone. Engineering teams have stopped sending "is the VPN slow today?" Slack messages. Audit findings on remote access are closed. The Cloud Security Operations function detects and responds to access anomalies in minutes instead of hours, because it has continuous per-application visibility instead of session-level VPN logs. Employees who joined Bristol after the rollout have never used the legacy VPN and don't know what it was. That is what we are building toward.

2 — Change Impact Assessment

The seven population segments below are the working impact map. Sizes are current as of 2026-04-15; populations will be re-validated before each wave. Resistance risk and adoption complexity reflect what the engineering pilot (Wave 0, summer 2026) surfaced.

Affected group	Size	What changes for them	Impact level	Resistance risk	Adoption complexity
Engineering org	~600	ZTNA login per app; some dev tools require periodic re-auth;	High	High	High — strong opinions,
(devs, SREs, infra)		cert-based auth for SSH;			technical scrutiny,

Affected group	Size	What changes for them	Impact level	Resistance risk	Adoption complexity
		perceived friction in dev workflow			identifies edge cases first
Corporate office	~2,200	Different login experience; one-time enrollment per device; faster M	edium L	ow L	ow — most won't notice
workers		access experience overall			after week 1
Field / branch	~400	Different login experience from branch workstations and laptops; M	edium L	ow-Medium M	edium — geographically
employees		in-branch IT support coverage during cutover			dispersed, harder to support during cutover
Executives + admins	~30	Different login on phones, tablets, laptops; travel scenarios; M personalized white-glove migration	edium L	ow M	edium — high-visibility users, must-not-break
Contractors	~250	ZTNA enrollment process slightly different; access scoped more tightly than VPN-era; renewal cycle aligned with contract dates	Medium	Medium	Medium — onboarding/off boarding workflows change for IT
Help desk / IT support	~25	New troubleshooting flows; new ticket categories; new escalation	igh L	ow H	igh — must be expert by week 1; surge support required

Affected group	Size	What changes for them	Impact level	Resistance risk	Adoption complexity
		H path; their ticket volume surges during each cutover wave			
Vendor / 3rd party	~50	Vendor portal access changes; ZTNA replaces VPN-for-vendors; M	edium M	ed-High H	igh — coordination
access	vendors	12-month notice + per-vendor migration playbook			across many vendor IT teams

Notes on resistance risk patterns

The engineering pilot surfaced three resistance patterns worth highlighting in the rollout: (1) the engineering org's resistance is technical-detail-driven, not change-resistant — they need data, not reassurance, and they catch issues before broader populations do; (2) field/branch resistance correlates with local IT support availability, not with technical complexity, so geographic surge planning is the lever; (3) vendor resistance is contractual-leverage-dependent, which means Vendor Management must engage 12 months pre-wave for each vendor to use contract renewal cycles as the migration anchor.

3 — Sponsorship & Coalition

Sponsorship is active, named work — not a sentiment. The activities below are commitments, with dates, that the sponsors have agreed to. "Be supportive" is not a sponsor activity; the activities below are.

Role	Name	Org	Specific sponsor activities (with dates)
Primary sponsor	Sandra Park, CISO	Security	(1) Send all-hands email kicking off Project Atlas — sent 2026-01-25 (2) Personally present at engineering townhall T-21 days each wave (3) Monthly office hours with eng leadership, 3rd Wednesday (4) Quarterly Audit Committee update covering Atlas progress
Engineering co-sponsor	Mark Williams, CTO	Engineering	(1) Co-write engineering org email

Role	Name	Org	Specific sponsor activities (with dates)
			with CISO 2026-04-15 (2) Visible support at engineering townhall — co-presents with CISO (3) Attend monthly office hours (4) Personally use ZTNA in engineering pilot — visible activity in eng Slack
Coalition member	Linda Walsh, CIO	IT	(1) Approve help desk staffing surge for cutover weeks (2) Mention Project Atlas in CIO monthly newsletter for awareness (3) Attend quarterly all-hands updates and acknowledge program
Coalition member	Robert Stein, CRO	Risk	(1) Brief Audit Committee on regulatory rationale (2) Sign formal risk acceptance for hybrid FIDO2 approach (Decisions Log entry DC-005) (3) Quarterly review of program risk register
Engineering champions	12 named eng leads,	Engineering	(1) Pilot participants — feedback in week 1 of pilot
network	1 per major eng team		(2) Run team-level sessions before each wave (3) Identify edge cases for OCM team and surface in weekly working team (4) Standing rep at weekly working team meeting (5) First adopters every wave — visibly use ZTNA before broader rollout
Help desk champion	T. Brooks, IT Service Manager	IT Operations	(1) Owner of help desk runbook for ZTNA-related tickets (2) Train help desk team 2 weeks pre-wave (3) Surge planning per

Role	Name	Org	Specific sponsor activities (with dates)
			wave — temp staffing approved (4) Daily ticket review during cutover weeks (5) Bi-weekly readout to OCM Lead

Sponsor activation cadence

The OCM Lead tracks sponsor activity completion against this commitment list. If a sponsor activity is missed (e.g., Sandra Park misses the engineering townhall T-21 days), it is flagged at the next weekly working team meeting and either rescheduled or escalated. Sponsor commitment is the lever the OCM team has the least direct control over and the most concentrated risk on; the discipline is to track it explicitly and surface gaps fast.

4 — Resistance Management

Resistance is information, not opposition. The OCM team's job is to surface concerns early enough to address them in time for them to land. The four patterns below are the ones the engineering pilot surfaced or that prior Bristol change programs have produced. Each has a planned response approach with named owners.

Source	Likely concern	Response approach	Owner
Engineering team leads	"ZTNA will add latency to dev tool access. We'll lose productivity."	Pilot data: 90% of dev tool flows under target latency in pilot; 10% under remediation. CTO commits to delaying broader rollout if pilot shows >5% productivity impact. Engineering champions network as the feedback loop. Pilot data published weekly to engineering org for transparency.	OCM Lead + CTO Chief of Staff
SRE / on-call	"During an incident I need fast access. ZTNA	Engineering-specific policy: extended session times for	ZTNA PM (J. Liu)
engineers	re-auth cycles will slow me down."	designated SRE/IR roles. Documented exception process. Network engineering team consulted before policy lock. SRE leads briefed at T-30 each wave.	
Field / branch	"My team isn't tech-savvy. They'll struggle."	Wave-based rollout starts with corporate office workers (lower	OCM Lead +

Source	Likely concern	Response approach	Owner
managers	Tickets will surge."	technical complexity), then field/branch waves include in-person help from regional IT during cutover days. Manager talking points + branch-specific FAQ. Help desk surge staffing approved 30 days pre-wave.	IT Service Manager
Vendor IT teams	"You're forcing us to change our integration. We have other priorities."	12-month notice issued at program kickoff. Vendor-specific migration playbook drafted per vendor. Account managers pre-briefed by Vendor Management 90 days before each vendor's wave. Hard date enforced via contract amendments aligned with renewal cycles.	Vendor Management
Frequent-traveling	"Last thing I want is to mess with login from a	Executive admin pre-briefing 2 weeks before exec's wave.	OCM Lead +
executives	hotel in Singapore. This better not break travel access."	Personalized hand-holding for first travel after rollout (executive admin coordinates). Direct escalation path to CIO Chief of Staff for any travel-blocking issue. Tested in international travel scenarios pre-rollout (Singapore, London, São Paulo).	CIO Chief of Staff

Surfacing concerns we haven't anticipated

The four patterns above are the ones the team can predict. The ones we cannot predict are surfaced through three channels: the engineering champions network (weekly readout), the help desk's wave-period ticket data (daily review), and the post-wave pulse survey (T+7 each wave). When something new surfaces, the OCM Lead categorizes it (rational concern, emotional reaction, structural barrier, or outright refusal), names an owner, and tracks the response. This pattern survives the program — Cloud Security Operations inherits the ongoing resistance-management cadence as part of operational handoff.

5 — Training Strategy

The training strategy is built around the principle that different audiences need different modalities at different times. The full Training & Awareness Plan (Artifact #10 in the toolkit) covers the detailed module-level content; this section covers the delivery model and timing.

Audience	Modality	Duration	Timing
Help desk + IT support	Live instructor-led + hands-on lab with realistic scenarios	4 hours	T-14 days each wave
Engineering champions	Live + sandbox access	2 hours + self-paced sandbox practice	T-30 days first wave only; champions retain access throughout
Engineering org broad	Self-paced e-learning + optional live Q&A	30 min e-learning + optional 30 min live Q&A	T-21 to T-7 each wave
Corporate / field	Self-paced job aid + 5-minute video	10 minutes total	T-30 to T-7 each wave

employees

Executives + admins	1:1 white-glove session with executive admin	30 minutes	T-14 days each wave; admin owns scheduling around exec calendar
Vendor IT teams	Documentation + 1:1 calls per vendor	Variable per vendor (avg 90 minutes)	T-90 days each wave (longest lead time given vendor priorities)

Training-completion tracking

Completion is tracked daily during the T-21 to T-1 window for each wave. Target: 95% of wave-eligible population completes required training by T-7. Below 90% triggers manager escalation; below 80% triggers OCM Lead intervention with the affected manager network. Training-completion data is published weekly to managers so they can see their own team's status without having to ask. Refresher training for users who report difficulty post-cutover is available on-demand and integrated with the help desk runbook.

Where employees go with training questions

The intranet hub (intranet.bristol-financial.com/atlas/training) is the single source of truth for training content, schedules, and FAQ. The #atlas-cutover Slack channel handles in-the-moment questions during cutover weeks. Email atlas-help@bristol-financial.com handles non-urgent questions with 24-hour response SLA. Managers are briefed to be the first-line responders for context-specific questions about their team's workflow.

6 — Reinforcement & Sustainment

The hardest part of any change program is what happens after the cutover lands. Adoption that looks healthy at T+7 can erode by T+90 if reinforcement isn't deliberate. The pattern below applies to each wave and continues into the post-program steady state under Cloud Security Operations.

Reinforcement cadence

- Adoption metrics tracked daily for 30 days post-wave, then weekly to 90 days, then monthly through the end of the program (and indefinitely under Cloud Security Operations afterward)
- Pulse surveys at T+7 and T+30 per wave — results feed into next-wave planning, with patterns and themes shared back to the population that responded
- Recognition: each wave's engineering champions named in CISO+CTO joint Slack post within 7 days of wave completion; champion commitment letter on file for promotion-evidence purposes
- Manager reinforcement: managers attest to their team's adoption at T+30; tracked as a metric; non-attestation triggers OCM follow-up with that manager
- "Lessons from previous wave" built into the next wave's pre-wave email so adoption improves across waves rather than each wave starting from zero
- Help desk closure rate as leading indicator: if rate drops below baseline post-cutover, OCM intervention is triggered (additional drop-in sessions, refreshed FAQ, manager check-ins)
- Quarterly retrospective at six months post-launch and again at 12 months reviewing whether adoption stuck or eroded; corrective actions logged to the Lessons Learned Register

Operational handoff

Post-program (after T+30 of Wave 4), the reinforcement cadence transitions from program ownership to Cloud Security Operations function ownership. The function inherits: the metrics, the pulse-survey rhythm, the manager-attestation loop, and the relationship with the help desk champion network. R. Patel transitions to Cloud Migration program full-time at the same handoff date. Continuity of OCM context across the handoff is documented in the Atlas closeout report.

7 — Adoption Metrics

Seven metrics, tracked across the rollout. Targets are calibrated against pilot performance and prior-program benchmarks; the program is not the first OCM-heavy effort at Bristol, and the targets reflect what comparable programs have achieved with similar discipline.

Metric	Target	Source	Cadence	Owner
Enrollment rate by T-1 day per wave	≥ 98%	ZTNA admin console	Daily during T-30 to T-1	OCM Lead
Active ZTNA usage at T+7 days	≥ 99% of enrolled users	ZTNA logs	Daily T-0 to T+7, then weekly	Component PM
Help desk ticket volume per 100 users	Peak day < 5 per 100 users; decay to baseline by T+14	ServiceNow	Daily during cutover weeks	IT Service Manager
Pulse survey NPS	≥ +20 by Wave 3	Survey tool	T+7 each wave	OCM Lead
Pulse survey ease-of-use	≥ 4.0 / 5 by Wave 3	Survey tool	T+7 each wave	OCM Lead
VPN concurrent sessions	Trending to zero by 2026-12-31	Network monitoring	Weekly	Network Team
(decommission KPI)				
"Nobody told me" issues per wave	< 3 per wave by Wave 3	Retrospective outputs	T+14 each wave	OCM Lead

How the metrics drive decisions

Each metric has explicit thresholds for OCM intervention. Enrollment below 95% by T-7 triggers manager outreach. Ticket volume above 10/100 users triggers help desk surge expansion. NPS below +10 at any wave triggers a working session with the affected segment to understand pattern. The metrics are not status reports; they are decision triggers, and the program treats them that way.

8 — Approvals

Sponsor (CISO)	Sandra Park — approved 2026-02-08
Engineering co-sponsor	Mark Williams (CTO) — approved 2026-02-12
OCM Lead	R. Patel — owner
Component PM	J. Liu — acknowledged
HR partner	K. Davis — acknowledged 2026-02-15
Coalition: CIO	Linda Walsh — acknowledged 2026-02-10
Coalition: CRO	Robert Stein — acknowledged 2026-02-12
Audit Committee	2026-Q1 acknowledgment recorded in committee minutes

Plan review and revision cadence

Material revisions to this plan trigger re-approval by the primary sponsor (Sandra Park). Non-material revisions (table updates, metric refreshes, minor wording) are tracked in version history and reviewed by the OCM Lead. Next scheduled review: 2026-05-15 (between Wave 0 pilot completion and Wave 1 entry decision).

Related artifacts

- Artifact #9 (OCM Plan): the structural artifact this example populates
- Artifact #10 (Training & Awareness Plan): the detailed training plan referenced in section 5
- 1 — Communications Plan — Project Atlas: the communications plan that integrates with this OCM plan; the comms cadence in that plan delivers the messages this plan defines
- Engineering Example #246 (ROLL Plan — ZTNA Component): the rollout plan whose user-facing change is what this OCM plan prepares the org for
- Engineering Example #255 (SPADE — Approve UAT Entry for ZTNA Wave 1): the decision documenting Wave 1 readiness, including OCM-side readiness gates

Keywords: OCM Plan example, organizational change management example, change management plan example, ZTNA rollout OCM, change vision, change impact assessment, sponsorship coalition, resistance management, training strategy, reinforcement sustainment, adoption metrics, OCM approvals, change management example, populated OCM plan, comprehensive OCM example, Project Atlas OCM

HOW TO READ THIS EXAMPLE

Why this example works: What makes this OCM plan exemplary is that it treats resistance as a design input, not a surprise. The plan segments users by change impact level, pre-identifies the personas most likely to resist (network engineers losing manual access, branch managers fearing productivity loss), and assigns distinct interventions to each - this is OCM done as engineering, not cheerleading.

Key judgment calls:

- Running a change-impact assessment before committing to the communications schedule, so the plan could sequence the heaviest-impact groups last and use early adopters as internal advocates.
- Separating training readiness milestones from technical readiness milestones on the integrated plan, recognizing that users being trained-and-ready is a critical path dependency in its own right.
- Choosing manager-led cascade over central broadcast for the branch network, because local credibility matters more than consistency of message in geographically dispersed rollouts.

Adapting it to your context:

- The resistance persona model (skeptic engineer, worried manager, passive end user) is reusable structure; re-identify your personas by interviewing frontline supervisors before drafting the plan.
- ZTNA is a high-disruption change because it visibly changes daily authentication behavior; calibrate your OCM investment (light, medium, heavy) to the disruption level of your own change, which may be lower.
- The manager enablement kit (talking points, FAQ, escalation path) is a portable deliverable format; recreate it with your program's content and your organization's manager communication norms.

12 — Training & Awareness Plan — Project Atlas

12 — Training & Awareness Plan — Project Atlas (workforce-wide)

The full training plan covers all 5 components. Shown here is the workforce-wide training rollout for the ZTNA + MFA changes (the parts users actually feel).

Document control

Title	Project Atlas — Training & Awareness Plan
Version	v2.0 (approved)
Date	2026-04-08
Author	OCM Lead (R. Patel) with TPM + Component Leads
Approver	Sandra Park (sponsor), Linda Walsh (CIO)

Audiences & training paths

Audience	Size	Path	Format	Time	Required by
General employees	3,000	Path A: Light	eLearning (15 min)	15 min	Wave 2 cutover
Field Engineering	220	Path B: Heavy	Live + lab	90 min	Wave 1 cutover
Privileged users	150	Path C: Privilege	d Live + FIDO2 set	up 60 mi	n MFA Wave 1
Helpdesk (Tier 1)	25	Path D: Support	Live + lab + cert	4 hours	Wave 1 cutover
Helpdesk (Tier 2)	10	Path E: Deep	Live + shadow	8 hours	Wave 1 cutover
Application owners	58	Path F: Owners	eLearning + 1:1	30 min	Wave 1 cutover

Audience	Size	Path	Format	Time	Required by
Contractors	200	Path G: External	Vendor- managed	20 min	Wave 3 cutover

Training content per path

Path A (general employees): What's changing, why, what to expect on cutover day, what to do if something doesn't work, where to get help. Pre-recorded eLearning with knowledge-check quiz at end.

Path B (Field Engineering): Path A content + deep-dive on offline / split-tunnel scenarios + new troubleshooting workflows + how to register engineering tools / scripts. Live session with hands-on lab. Field Engineering specifically is high-resistance (see OCM 4) — training content acknowledges existing pain points.

Path C (privileged users): FIDO2 token registration, step-up flows, what changes day-to-day, what changes at the application boundary. Hands-on token registration during the session.

Path D (Helpdesk Tier 1): Common user issues, decision tree for triage, when to escalate, how to use the access-event audit log for first-line troubleshooting. Includes certification — must pass quiz before being on-call.

Path E (Helpdesk Tier 2): Path D content + deep architecture knowledge + integration debugging + post-incident root cause work. 1-day shadow with the engineering team.

Path F (Application owners): What ZTNA does to their app, how to read their app's access decisions log, when to escalate to engineering. eLearning + 30-min 1:1 with engineering for app-specific edge cases.

Path G (Contractors): Vendor-distributed (delivered through their own channels). Identical content to Path A plus contractor-specific workflows.

Delivery schedule

T-90 days from each cutover: training content finalized

T-60 days: train-the-trainers complete (15 trainers across paths B, C, D)

T-45 days: cohort enrollment opens

T-30 days: training waves begin

T-7 days: completion reporting + non-completer escalation

T-0: cutover

Reinforcement (post-cutover)

T+1 to T+7: Daily 'office hours' (open Zoom for issues)

T+1 to T+30: Helpdesk maintains heightened-staffing baseline (+5 people)

T+30: Effectiveness review — completion data, helpdesk ticket trends, sentiment survey

T+60: First refresher comms (no full re-training)

T+90: Post-launch retrospective contributes to next-component training

Effectiveness measures (Adoption Metrics in OCM Plan 7)

- Training completion rate: target 95% by T-7 days
- Knowledge-check pass rate: target 85% first-attempt
- Helpdesk first-call resolution rate: target 70% (vs 60% pre-launch)
- User sentiment (post-cutover survey): target NPS +20
- Repeat-issue rate (same user, same problem >2x): target under 5%

Approvals

OCM Lead: R. Patel / 2026-04-08 / signed
Sponsor: Sandra Park / 2026-04-09 / signed
CIO: Linda Walsh / 2026-04-09 / signed
Component leads (J. Liu, S. Chen): 2026-04-08 / signed

HOW TO READ THIS EXAMPLE

Why this example works: This training plan is exemplary because it maps learning objectives to role-based impact, not to the technology feature set - the end user does not need to understand how ZTNA works, they need to know what changes in their daily workflow, and the plan is organized around that distinction. Notice also that the plan includes a measurement mechanism for each delivery channel, so training effectiveness is treated as a program metric, not an assumption.

Key judgment calls:

- Building three distinct learning paths (end user, IT administrator, security analyst) rather than one universal curriculum, accepting higher development cost in exchange for relevance - the single biggest driver of training completion rates is perceived applicability.
- Sequencing awareness before training before simulation, which follows the established adult learning model: establish why before how before practice; collapsing these into a single event produces knowledge without behavior change.
- Setting a 90% completion threshold as a go/no-go criterion for the org-wide cutover rather than treating training as a best-effort activity, which creates organizational accountability for learning rather than leaving it to individual motivation.

Adapting it to your context:

- The Atlas training plan was built for approximately 2,400 end users across six regional offices; adjust the delivery channel mix (live facilitated vs. self-paced eLearning vs. manager cascade) based on your organization's headcount, geography, and existing learning infrastructure.
- The phishing simulation component is specific to Bristol Financial's security culture program; include or exclude it based on your organization's existing security awareness maturity and HR appetite for simulated social engineering.
- The completion tracking mechanism assumes an LMS integration with Active Directory; if your organization does not have an LMS, design a manual completion tracking workflow before the plan is finalized, because completion data is required for the go/no-go gate.

47 — Delivery Health Check Assessment — Project Atlas (week 12 takeover review)

Assessment Context:

Delivery health check on Project Atlas at week 12, run on takeover.

Dimension Scores (1-5):

Dimension	Score
Scope clarity	4
Schedule confidence	2
Budget health	2
Risk posture	3
Quality	4
Sponsor engagement	4

Dimension	Score
Team capacity	2
Governance	3

Evidence:

- Schedule reviewed against WBS: 15% behind
- EVM CPI 0.88 / SPI 0.86
- RAID top risks active
- Team at 115% identity-skill allocation

Overall Status:

AMBER-RED, trend down. Prior status reported GREEN; assessment disagreed. Reported RAG corrected to AMBER.

Top Findings:

Finding	Action	Owner	Timing
Schedule slip unacknowledged	Trigger recovery plan	TPM	This week
Identity-skill bottleneck	Capacity plan + contractor	PgM	-
\$0.33M forecast overrun	SteerCo decision	Sponsor	-

Outcome:

This assessment justified opening the 45-day recovery plan and resetting expectations with the sponsor.

HOW TO READ THIS EXAMPLE

Why this example works: The health check assessment is exemplary because it is structured as a diagnostic with evidence citations, not an opinion survey - each amber or red rating is backed by a specific finding (document reference, interview source, or metric) so a new program director can validate the assessment independently. The week 12 takeover timing means the reviewer is assessing an inherited situation, and the report correctly separates findings about historical decisions from recommendations about forward actions, avoiding the trap of attributing current problems purely to predecessors or to circumstances. The prioritized action list at the end maps each finding to a remediation owner and a deadline, converting the assessment from an observation into a recovery plan.

Key judgment calls:

- Rating schedule health amber rather than red despite a two-week slip, because the critical path had float that absorbed the slip without affecting the delivery commitment date.
- Separating governance health from delivery health as distinct assessment dimensions, recognizing that a well-governed program can be delivery-challenged and vice versa.
- Recommending a scope freeze for 30 days as the first recovery action rather than a re-plan, on the grounds that scope instability was the primary driver of schedule variance.

Adapting it to your context:

- Reuse the structure of evidence-cited ratings plus a prioritized remediation table for any mid-program health review.

- Calibrate the assessment dimensions (schedule, cost, scope, governance, risk, stakeholder) to your organization's delivery framework.
- If you are taking over a troubled program, follow the same discipline of separating diagnostic findings from forward recommendations to maintain credibility with the inherited team.

48 — Team Onboarding & Ramp Plan — Project Atlas (vendor engineer)

Joiner Details:

Field	Value
Name	Riya Patel
Role	Network Security Engineer
Workstream	ZTNA
Start date	2024-02-05
Cohort	2

Program Context:

Atlas is a 14-month ZTNA + PAM modernization at Bristol Financial. ZTNA Phase 1 (pilot, 200 users) complete; Phase 2 (enterprise rollout) begins February.

Access and Clearances:

Item	Owner	Due	Status
Privileged-access PAM vault provisioning	Marcus Chen (IAM lead)	2024-01-30	Complete
Production network read access	IT Ops	2024-02-02	Delayed -> escalated to TPM 2024-01-31

Tooling:

- Jira Atlas project added
- Confluence space granted
- Zscaler tenant read access
- AI toolkit license allocated
- All green by day 3

Ways of Working:

- Daily 9am ZTNA standup
- Decisions recorded in Confluence ADRs
- Escalate blockers via Jira with 'BLOCKER' label
- Code review SLA: 1 business day

Role and Deliverable Map:

Owns ZTNA segment policy design for 12 business units. First deliverable: segment matrix draft by Day 30 (2024-03-05).

Milestone Plan:

Milestone	Target
30-day: context briefed, all access green, segment matrix	Day 30

Milestone	Target
draft reviewed by lead architect	
60-day: segment matrix approved by CISO, pilot rollout plan drafted for BU1-3	Day 60
90-day: BU1-3 rollout complete, lessons learned filed, peer review score $\geq 4/5$	Day 90

Buddy and Check-ins:

Buddy: Sofia Reyes (senior ZTNA engineer). Check-ins on Day 5, Day 15, Day 30. Day-5 check-in noted production network delay; unblocked same day.

Sign-off:

Riya Patel and workstream lead James Okafor confirmed plan complete 2024-02-07.

HOW TO READ THIS EXAMPLE

Why this example works: The access delay on production network access was surfaced on Day 5 via the buddy check-in and resolved before it affected the segment matrix deliverable. Without the structured plan, that blocker would likely have sat unresolved for two weeks.

Key judgment calls:

- Pre-provisioning PAM vault before start date removed a common week-one blocker for privileged-access programs
- Output-specific 30/60/90 milestones (segment matrix draft, not 'learning the system') gave the workstream lead a real ramp signal

Adapting it to your context:

- For internal hires with existing access, collapse the clearance section and extend the program-context and ways-of-working sections
- For large cohorts (>10), run a single group context briefing and manage individual access rows in the tracker tab

49 — Team AI Enablement & Literacy — Project Atlas (delivery team)

Role Tiers:

Role	Count
TPM	1
Workstream leads	4
BAs	5
Security engineers	6
PMO analysts	2

Data Permissions:

Category	Detail
Permitted	Project-internal documents (non-PII, non-customer-data); Bristol Financial data classification 'Internal' and below only
Prohibited	Customer identity records, PAM vault credentials, audit logs with

Category	Detail
	individual names, any data marked 'Confidential' or above

Prompt Standard:

- Open with role framing (e.g., 'You are a PMO analyst working on a ZTNA program...')
- Include a constraint clause ('Do not fabricate names or metrics')
- Specify output format

Verification Checklist (mandatory before filing):

- Fact-check all metrics against source
- Flag any proper noun not in the source document
- TPM or workstream lead initials on the artifact

Enablement Paths:

Audience	Path	Completion Target
BAs	45-min self-paced module (prompt structure) + 1 practice artifact + assessed prompt task reviewed by AI practice lead	2024-03-15
Security Engineers	30-min module (data classification focus) + 1 assessed task	2024-03-15

Uplift Baseline and Results:

Metric	Pre-training	Target	Day 60 Result
BA status-report drafting time	90 min avg	<=55 min	58 min avg (35% reduction)
Quality score (TPM review)	-	>=4/5	4.2/5
Hallucinations in filed artifacts	-	0	0

Week 6 Pulse Check:

15/18 team members completed enablement path. 2 engineers pending. 1 BA flagged for pasting an internal network diagram into a public AI endpoint; corrective briefing issued same day.

Audit and Compliance:

All AI-assisted artifacts tagged 'AI-ASSISTED' in Confluence metadata. TPM reviews tag compliance weekly.

Plan Refresh:

New Zscaler AI feature released in April -> prompt library updated and engineers re-assessed within 10 days.

HOW TO READ THIS EXAMPLE

Why this example works: The data classification incident in week 6 (internal diagram in a public endpoint) was caught by the audit log and corrected before any data left the firm. The

measured uplift (35% drafting time reduction) gave the sponsor concrete ROI evidence for continued AI toolkit investment.

Key judgment calls:

- Role-differentiated enablement paths prevented one-size-fits-all training that would have under-served engineers and over-burdened BAs
- Embedding the verification checklist in artifact sign-off made human review structural rather than optional

Adapting it to your context:

- For smaller teams, collapse role tiers to two (PM/analyst vs. technical) to reduce overhead
- If the firm has an existing AI acceptable-use policy, import its data classification table directly rather than authoring from scratch

50 — Security Awareness Campaign — Project Atlas (Execute phase)

Audience Segments:

Segment	Count	Risk Profile
Executive	45	High-value target
IT/Security Staff	120	Privileged access
Finance & HR	200	Data-handling, high phishing risk
General Staff	1,800	Baseline

Finance & HR Threat Scenarios:

- Credential phishing targeting MFA bypass
- Pretexting calls requesting PAM password reset
- QR-code phishing on printed materials

Training Modules:

Module	Audience	Format	Owner	Target Date	Completion
Module 1: 'Why ZTNA Changes Your Login' (3-min video + 5-question quiz)	All staff	Intranet + email	Comms lead	2024-05-01	90% target
Module 2: 'Privileged Access: Your New Responsibilities' (20-min interactive)	IT/Security staff	LMS	CISO team	2024-05-15	Mandatory
Module 3: Executive Briefing (30-min facilitated session)	CFO and direct reports	Face-to-face	Change lead + CISO	2024-05-10	Mandatory

Phishing Simulations:

Simulation	Date	Lure	Target	Key Metric
Sim 1	2024-06-03	Fake IT helpdesk password reset (credential harvest)	All staff	Baseline click rate; report rate target >=25%
Sim 2	2024-08-12	MFA fatigue push notification	IT/Security staff and Finance & HR	Click rate target <=8% (down from Sim1 baseline of 18%)

Behavior Metrics at Month 7:

Metric	Sim 1 (Baseline)	Sim 2 Result
Click rate	18%	11% (39% reduction)
Report rate	12%	29%
Helpdesk 'I think I was phished' calls	-	4x increase (positive signal)

Manager Briefing:

Team-level Sim2 results shared with 12 managers whose teams exceeded 15% click rate. Two teams scheduled for targeted reinforcement workshop.

Reinforcement Activities:

- Monthly security tip in team all-hands template
- CISO 'Security Minute' in leadership town hall
- Quarterly simulation continuing post-go-live through month 14

Month 9 Retrospective:

- All-staff completion 87% (target 90%; gap in contractor population - addressed in wave 2)
- No security incidents attributable to phishing in months 7-9 post-campaign vs. 3 in equivalent prior period

Campaign Lessons:

QR-code scenario underperformed (low click rate, low learning signal). Replaced with voice phishing scenario for Sim3.

HOW TO READ THIS EXAMPLE

Why this example works: The 39% reduction in phishing click rate between simulations, combined with a 4x increase in self-reported phishing attempts, demonstrates genuine behavior change rather than just awareness. The manager accountability loop for high-click-rate teams converted a campaign metric into a management conversation.

Key judgment calls:

- Separating 'report rate' from 'click rate' as a distinct metric captured the positive behavior (reporting) that completion-only tracking would have missed
- Contractor gap identified at retrospective before go-live prevented a compliance and risk exposure in the highest-turnover population

Adapting it to your context:

- For smaller organizations, collapse Executive and IT segments into one high-privilege group and run a single targeted session rather than separate modules
- If a phishing simulation platform is not available, proxy the click-rate metric with quiz scores on scenario-based questions and manual report-rate tracking via helpdesk ticket tagging

51 — Responsible AI Usage Guardrails — Project Atlas (Bristol Financial)

Scope:

All Bristol Financial employees, SI contractor staff, and independent consultants performing work on Project Atlas, using any AI or LLM tool for any program-related task.

Restricted Data Examples:

- PAM credential vault exports
- ZTNA policy JSON configs
- MFA enrollment lists
- Active Directory OU structures
- Penetration test findings
- Any file tagged RESTRICTED in Bristol Financial's DLP system

Approved Tools:

Tool	Permitted Data Classes	Approver	Expiry Review
Claude (Anthropic, cloud)	Internal and Public only	CISO	2026-12-01
Microsoft Copilot (Microsoft 365, tenant-isolated)	Internal and Confidential with DLP policy active	CISO	2026-12-01
GitHub Copilot (JetBrains/VS Code plugin)	Internal only; no credential or config files in context	Engineering Lead + CISO	2026-12-01

Prohibited Actions:

- Pasting any PAM vault export or ZTNA config file into Claude or any other cloud AI
- Asking Copilot to generate synthetic Active Directory credentials for testing
- Using AI risk-scoring output as the sole basis for a go/no-go gate decision without TPM and workstream-lead sign-off

Human-in-the-Loop Requirement:

All AI-drafted risk register entries must be reviewed by the relevant workstream lead and TPM before being added to the live register. Reviewer logs entry in the AI Output Log (SharePoint list).

Log Column	Values
Fields	Artifact ID, Tool, Date, Author, Data Class, Reviewer, Accepted Y/N

Prompt Hygiene Rule:

When using Claude to draft the Weekly Status Report, the author must replace actual system names in incident descriptions with tokens (e.g., [SYSTEM-A]) if the description references a specific vulnerability. TPM reviews the final draft before it is emailed to SteerCo.

Breach Example:

- Date: 2026-03-14 - contractor pasted a ZTNA config snippet into Claude to debug a policy rule
- Incident reported to CISO within 40 minutes
- Root-cause review completed 2026-03-19: contractor had not completed AI guardrails acknowledgment
- Corrective action: mandatory acknowledgment before any system access; added to onboarding checklist

Audit Log Entry Example:

Artifact ID	Tool	Date	Author	Data Class	Reviewer	Accepted
RISK-047	Claude	2026-04-02	J. Okonkwo (Integration Lead)	Internal	S. Patel (TPM)	Y
— HOW TO REA	D THIS EX	AMPLE —				

Why this example works: This example shows the guardrails doing real protective work - specific system names are classified, approved tools have named approvers and expiry dates, the breach scenario demonstrates the 1-hour SLA and root-cause process, and the audit log entry is concrete enough to be reproduced. The contractor incident illustrates why the acknowledgment step matters and how the corrective-action loop closes.

Key judgment calls:

- Restricting PAM vault exports and ZTNA configs by name (not just by label) removes ambiguity and prevents the most likely data-leakage vector on a security modernization program
- Logging every AI-assisted output with a named human reviewer makes the human-in-the-loop requirement auditable and defensible to the CISO and any future regulator

Adapting it to your context:

- If your organization has a formal AI governance committee, route approved-tools register changes through that body rather than directly to the CISO
- For programs with lower data sensitivity, the Confidential row of the classification matrix may be permitted in tenant-isolated enterprise AI tools - adjust the matrix with explicit CISO approval
- Add a vendor-specific column to the approved tools register if SI partners operate under a separate data-handling agreement with different permitted classes

53 — Phase-Gate (Tollgate) Reviews — Project Atlas (Gate 2)

Gate Overview:

Field	Value
Gate	Gate 2: Plan to Execute
Authority	CISO (Bristol Financial)
Date	2026-04-18
Quorum	CISO + CFO or Deputy
Decision Options	Go / No-Go / Go-with-Conditions

Exit Criteria Assessment:

ID	Criterion	Evidence	Met
2.1	Approved Project Charter with CFO and CISO signatures	Charter v2.0, SharePoint /Atlas/Governance/Charter	Y
2.2	Baselined integrated schedule in MS Project; no open critical-path dependencies (float > 0 or documented mitigation)	Atlas_Schedule_Baseline_v1.mpp + Dependency Log DEP-002 resolved 2026-04-10 per IT Ops Director email	Y
2.3	Risk register with approved response for every risk rated High or Critical (likelihood >= 3 and impact >= 4 on 5x5 matrix)	RAID Register tab 'Risks', filter High/Critical = 7 items, all with approved responses	Y
2.4	AI Guardrails document approved by CISO; acknowledgment forms signed by all team members	AI Guardrails v1.1, CISO sign-off email 2026-04-02; acknowledgment tracker 18/18 complete	Y
2.5	Budget approved and POs raised for all Phase 1 and Phase 2 procurement items	Finance confirmation email 2026-04-15; PO numbers PO-2026-0441, PO-2026-0442, PO-2026-0443	Y
2.6	All workstream leads and key external contacts onboarded, security-cleared, and program-policy acknowledgments signed	Onboarding tracker 2026-04-17; one contractor (SI partner) background check pending	Partial

Go-with-Conditions Detail:

Condition ID	Description	Owner	Due	Status
GWC-001	SI contractor (A. Nwosu) background check completed and program-policy acknowledgment signed before access to any Restricted-class systems or data. AI Guardrails restrict contractor to Internal-class	TPM (S. Patel)	2026-04-25	Closed 2026-04-23 (background check cleared; acknowledgment signed)

Condition ID	Description	Owner	Due	Status
	work only until closed.			

Gate Decision:

Decision: Go-with-Conditions. CISO approved 2026-04-18. 1 condition. GWC-001 closed 2026-04-23. Gate Decision Log updated 2026-04-23.

Executive Summary:

Program Atlas is ready to execute. The single condition (contractor clearance) carries no critical-path risk as the contractor's Phase 1 tasks begin 2026-05-05. All seven other criteria are met with evidence. Recommend Go-with-Conditions.

HOW TO READ THIS EXAMPLE

Why this example works: This example shows the gate process working as designed: criteria are binary and evidenced, the partial criterion triggers a go-with-conditions rather than a rubber-stamp go, the condition is specific and time-bounded, and it is tracked to actual closure (not left open). The CISO as gate authority for a security program is appropriate and defensible.

Key judgment calls:

- Using 'Met: Partial' on criterion 2.6 rather than rounding it up to Y is the critical honest judgment - it triggers a condition that protects the program from a security risk (uncleared contractor accessing Restricted systems) without blocking the gate unnecessarily
- Documenting the DEP-002 resolution as evidence for criterion 2.2 closes the loop between the dependency log and the gate criteria - the two artifacts are mutually reinforcing

Adapting it to your context:

- For agile delivery within phases, replace the single Execute gate with rolling sprint-level Definition of Done reviews and reserve the formal gate for phase-level transitions only
- If the gate authority cannot attend in person, establish a written approval process (gate pack reviewed asynchronously, decision emailed within 24 hours of pack distribution) - document this in the Gate Definitions table
- For externally regulated programs (e.g., PCI DSS, FCA authorization), map gate exit criteria directly to regulatory control checkpoints so that passing the gate also evidences regulatory readiness

55 — Operating Rhythm & Cadence Map — Project Atlas (hybrid delivery)

Delivery Ceremonies:

Ceremony	Frequency / Duration	Owner	Key Inputs	Key Outputs	Load
Daily Stand-up	Daily, 15 min	TPM	Jira board current state	Blocker log updated, impediment owner assigned	1.25 h/week per delivery team member
Sprint Planning	Bi-weekly Mon, 2 h	TPM + BA	Refined backlog (DoR passed), velocity from prior sprint	Sprint goal, committed sprint backlog	1 h/week per delivery team member

Ceremony	Frequency / Duration	Owner	Key Inputs	Key Outputs	Load
Sprint Review & Demo	Bi-weekly Fri, 1 h	TPM	Completed stories (DoD passed)	Accepted increment, product owner sign-off logged in Jira	0.5 h/week
Sprint Retrospective	Bi-weekly Fri post-review, 45 min	Rotating team member	Sprint metrics (velocity, DoD pass rate, blocker count)	<= 3 action items in Jira with owner and due date	0.375 h/week
Architecture & Security Sync	Weekly Wed, 45 min	Security Lead	Open architecture decisions log, security scan results	ADR drafted or closed, scan exceptions reviewed	0.75 h/week for technical roles

Governance Ceremonies:

Ceremony	Frequency / Duration	Owner	Key Inputs	Key Outputs	Load
Programme Status Review	Weekly Mon, 1 h	Programme Director	Weekly status report (due Fri COB prior), RAID log, schedule variance	Decisions logged, escalations raised, status report approved	1 h/week for TPM and leads
SteerCo	Monthly, 90 min	Programme Director	SteerCo pack due 3 business days prior: dashboard, milestone status, RAID summary, financial snapshot	Formal decisions minuted, change requests approved or deferred, strategic direction confirmed	1.5 h/month for SteerCo members
Change Advisory Board (CAB)	Weekly Thu, 1 h	Change Manager (ITIL)	RFC submissions (due 48 h prior), change calendar	RFCs approved/deferred/rejected, change calendar updated	1 h/week for technical leads

Stakeholder and Reporting Activities:

Activity	Frequency / Duration	Owner	Key Inputs	Key Outputs	Load
Stakeholder Engagement Check-in	Bi-weekly, 30 min per key stakeholder	Change Lead	Stakeholder engagement tracker,	Engagement status updated,	1 h/week for change lead

Activity	Frequency / Duration	Owner	Key Inputs	Key Outputs	Load
			ADKAR assessment	actions logged	
Weekly Status Report	Weekly Fri by 17:00 ET	PMO Analyst	Jira sprint metrics, RAID log, financial actuals	Status report distributed to Programme Director and SteerCo list	2 h/week for PMO analyst

Per-Role Meeting Load Summary:

Role	Load	Flag
TPM	5.6 h/week ceremonies	Within 6 h threshold
Security Lead	6.25 h/week	FLAG - review Architecture Sync duration or attendance
PMO Analyst	4.5 h/week meetings + 2 h report production = 6.5 h/week total	FLAG - consider delegating stand-up notes

Phase Transition Note:

At Execute->Close transition, Sprint Planning and Retrospective are retired. A Lessons Learned Workshop (single occurrence, 3 h) and Benefits Realisation Review (monthly, 1 h) are added.

HOW TO READ THIS EXAMPLE

Why this example works: This example demonstrates the cadence map doing real analytical work: the load summary flags two roles approaching or exceeding the 6 h/week threshold before the programme starts, enabling adjustments at planning rather than retrospective discovery. Every forum has a concrete output (not just 'discussion') and required inputs with lead times.

Key judgment calls:

- The CAB is listed as a governance forum distinct from delivery ceremonies because ITIL change management operates on its own cadence and must not be conflated with sprint ceremonies - conflation caused change approval bottlenecks in the programme's predecessor project.
- SteerCo requires the pack three business days in advance, not the night before - this is a deliberate standard that prevents the TPM from producing slides under pressure and allows sponsors to review substantively.

Adapting it to your context:

- For a fully waterfall programme, replace sprint ceremonies with phase-gate prep meetings and a rolling weekly workstream sync; the governance and reporting rows remain unchanged.
- If the programme is in a sensitive phase (e.g., cutover preparation), add a daily war-room call temporarily and mark it with a sunset date in the cadence map so it is not accidentally retained after cutover.
- In a multi-vendor environment, add a vendor management sync row (bi-weekly, TPM + vendor PMs) to ensure commercial and delivery coordination is explicit on the cadence map.

56 — Escalation Framework — Project Atlas (Bristol Financial)

Tier Definitions and Backups:

Tier	Owner	Scope	Backup
T1	TPM	Daily operational issues, blocking impediments, intra-team conflicts	BA (if TPM unavailable)
T2	Programme Director	Cross-workstream issues, minor scope adjustments up to 5 story points, vendor performance issues	PMO Lead
T3	SteerCo Chair / CISO	Schedule or budget exceptions beyond T2 authority, regulatory risk triggers, major vendor contract issues	CTO delegate
T4	Bristol Financial Executive Committee	Programme stop/go, budget increase > \$500K, material regulatory breach notification	CFO

Unavailability defined as: out-of-office auto-reply active OR unresponsive to Teams message for > 2 h during core hours.

Escalation Thresholds:

Category	T1 Trigger	T2 Trigger	T3 Trigger	T4 Trigger
Schedule Variance	<= 5 days cumulative slip on sprint goal	> 5 days and <= 10 days	> 10 days and <= 20 days	> 20 days or critical path milestone missed
Budget Variance	<= 3% over approved sprint budget	> 3% and <= 8%	> 8% and <= 15%	> 15% or forecast-to-complete exceeds approved budget by any amount
Security Control Gap	Single non-critical control gap; remediation plan in place within 48 h	Critical control gap or remediation overdue > 48 h	Control gap affects regulatory compliance posture or PAM privileged account exposure	Confirmed data exposure or regulatory breach notification required
Blockers Unresolved	Blocker unresolved > 4 h during core hours	Blocker unresolved > 1 business day and impacting sprint goal	Blocker unresolved > 3 business days and impacting programme milestone	n/a

Response SLAs:

Tier	Acknowledgment	Resolution or Escalate
T1	2 h	8 h
T2	4 h	24 h
T3	8 h	48 h
T4	24 h	Per ExCo governance cycle

Decision Rights by Tier:

Tier	Owner	Authority
T1	TPM	Approve unplanned work up to 3 story points; reassign team members within sprint
T2	Programme Director	Approve scope changes up to \$50K incremental cost; issue formal vendor performance notice
T3	SteerCo	Approve budget increases up to \$500K; approve major scope change; authorise regulatory pre-notification
T4	ExCo	Approve budget increase > \$500K; programme pause or termination; regulatory authority notification

Escalation Routing Process:

- Trigger identified -> TPM logs in escalation log within 1 h of identification.
- If T1 resolvable: TPM resolves and logs outcome.
- If T2+ required: TPM sends Teams message to tier owner with log ID and summary.
- Tier owner acknowledges per SLA.
- If primary unreachable after 2 h: TPM contacts named backup.
- All routing steps timestamped in escalation log.

De-escalation Criteria:

- Issue raiser confirms resolution in writing in the log; or
- Risk/issue score below T1 threshold for two consecutive weekly reviews; or
- Tier owner formally closes with documented outcome.
- Closed items are marked 'CLOSED' in the log and moved to the archive tab; they are not deleted.

Sample Escalation Log Entry:

Field	Value
ID	ATL-ESC-007
Date	2026-03-04
Tier	T2

Field	Value
Issue	PAM vendor delayed Tier-1 account migration by 7 days, impacting Q2 milestone
Owner	Programme Director
SLA Target	Resolve or escalate by 2026-03-05 17:00 ET
Resolved	2026-03-05 14:30 ET
Outcome	Vendor committed to revised schedule with \$25K SLA credit applied; recovery plan reviewed by TPM
Lesson	Vendor contract SLA clause needs tighter milestone definition at next renewal

Cross-Programme Escalation:

- Issues involving Bristol Financial network operations team (outside Atlas scope): routed via Programme Director to Bristol Financial CTO office.
- Issues involving regulatory counsel: routed via T3 (CISO) to Bristol Financial Legal and Compliance.
- External vendor executive escalation: handled by Programme Director with TPM in support.

HOW TO READ THIS EXAMPLE

Why this example works: This example shows numeric thresholds doing the analytical work the TPM would otherwise do under pressure. The security control gap row is Atlas-specific: a ZTNA/PAM programme has a regulatory dimension that standard IT projects do not, so T3 and T4 thresholds reference compliance posture and breach notification - categories absent from a generic escalation framework. The sample log entry demonstrates the closed-loop log discipline that prevents escalation logs from becoming graveyards of unresolved items.

Key judgment calls:

- The T1 blocker threshold is set at 4 h rather than the common 24 h because Atlas has a daily stand-up and a 4 h unresolved blocker represents half a working morning lost before the team can surface it - the tighter threshold matches the delivery tempo.
- T4 is intentionally hard to reach (> 20 days schedule slip or > \$500K budget increase) to preserve ExCo attention for genuine programme-threatening events and prevent SteerCo from bypassing T3.

Adapting it to your context:

- Calibrate all numeric thresholds against your organisation's actual risk appetite before using - a \$50K T2 budget authority is appropriate for Atlas but may be too high or too low for programmes of different scale.
- In a multi-programme portfolio, add a T0 tier below T1 for intra-team self-resolution (e.g., blockers resolvable within 1 h by team member without TPM involvement) to reduce TPM log burden.
- If operating under a formal ITIL incident management process, map T1-T4 to ITIL P1-P4 priority levels and align SLAs to the existing incident SLA table to avoid dual-tracking.

57 — Knowledge Management & Document Control — Project Atlas (Plan phase)

Repository Structure:

Repository root: <https://bristolfinancial.sharepoint.com/sites/ProjectAtlas>

Top-Level Folder	Contents
/Governance	Governance documents, permissions register, decision log, retention schedule
/Plans	Project plans
/Status	Status reports
/Risk-Issues	RAID register
/Change	Change requests
/Architecture	Architecture documents and ADRs
/Runbooks	Operational runbooks
/Lessons-Learned	Lessons learned records
/Handover	Handover package

README.docx at root maps each folder to its phase and document types.

Naming Convention:

- Project code: ATL
- Workstream codes: IAM, ZTNA, PAM, PMO
- Document type codes: ARCH (architecture), PLAN (plan), RISK (risk register), CHG (change request), RUN (runbook), LL (lessons learned), RPT (status report)
- Example: ATL-PAM-RUN-v1.0-20260301

Version Control Policy:

- Minor increment (v0.1 -> v0.2) for drafts in review.
- Major increment (v0.x -> v1.0) upon TPM approval.
- Superseded versions moved to /Archive subfolder within 24 hours of new baseline.
- No document deleted during project lifetime.

Access Permissions:

Group / Role	Access	Scope / Expiry
Bristol Financial Core Team (IAM, ZTNA, PAM leads, TPM, PMO Analyst)	Read/write	All folders
SteerCo and CISO	Read	All folders
External ZTNA Vendor (ClearPath Networks)	Read	/Architecture/ZTNA subfolder only; access expires 2027-06-30; NDA on file
Internal Audit	Read	/Governance and /Risk-Issues

Access changes logged in ATL-PMO-PERM-v1.0 Permissions Register.

Retention Policy:

- All project documents retained through project end plus 7 years per Bristol Financial Records Retention Policy RF-2024-03.
- PAM credential vault design documents (ATL-PAM-ARCH-*) classified RESTRICTED; subject to InfoSec destruction procedure IS-DES-01 at end of retention period.
- Retention schedule filed at /Governance/Retention-Schedule.

Decision Register:

ID	Date	Decision	Rationale
DEC-001	2026-02-14	Chosen ZTNA vendor: ClearPath Networks	Lowest TCO and native integration with existing IdP
DEC-002	2026-03-01	PAM vault to remain on-premises for Year 1	Data residency requirement

Decision register maintained as ATL-PMO-DECLOG-v1.0 in /Governance. TPM updates within 24 hours of any governance decision.

Lessons Learned Cadence:

- Captured using ATL-PMO-LL template after each two-week sprint review (IAM and PAM workstreams) and at each phase gate.
- LL-003 (Sprint 4, IAM): AD group enumeration took 3 days vs 1 day estimated due to undocumented legacy OUs. Recommendation: add OU discovery step to PAM workstream plan. Assigned to PAM Lead, due 2026-04-15.

Runbook Status:

Runbook ID	Description	Status
ATL-IAM-RUN-v0.3	Okta provisioning runbook	In technical review with IAM Architect
ATL-PAM-RUN-v0.1	CyberArk vault onboarding	In draft

All runbooks must reach v1.0 (Operations Lead approved) no later than 2 weeks before respective go-live milestone.

Handover Package:

ATL-HANDOVER-PKG due 2027-03-15 (2 weeks before project closeout milestone 2027-03-31). Owner: TPM. Required contents: as-built ZTNA and PAM architecture diagrams, all v1.0 runbooks, CyberArk and Okta configuration baselines, open issues log, vendor contract summary, lessons-learned digest. Acceptance sign-off: TPM, Operations Lead, CISO delegate.

Monthly Repository Audit:

- Next audit: 2026-07-01. TPM reviews repository using ATL-PMO-DOCAUDIT checklist.
- Critical documents (Risk Register, Architecture Baseline, Change Log) must not be more than 14 days stale.
- 2 non-compliances found in May audit (PAM architecture diagram not updated after DEC-002); corrective action assigned to PAM Lead, resolved within 5 business days.

HOW TO READ THIS EXAMPLE

Why this example works: This example demonstrates the full framework in operation: naming convention applied consistently across workstreams, the decision register capturing rationale for two high-stakes vendor and architecture decisions that will be essential for future audits and operational teams, and the lessons-learned entry from Sprint 4 already feeding a concrete change to the PAM workstream plan rather than sitting as an unread appendix. The handover package is treated as a milestone deliverable with a named owner, due date, and acceptance criteria, which is the single most common gap in project knowledge transfer.

Key judgment calls:

- The 24-hour SLA for decision logging is intentionally tight - ZTNA and PAM decisions often have security and compliance implications that need to be traceable; relaxing this to 'end of week' risks context loss and untraceable rationale.
- Restricting ClearPath Networks to the /Architecture/ZTNA subfolder with a hard expiry date is a deliberate application of least-privilege; security projects that grant broad vendor access to SharePoint sites routinely create post-engagement data exposure issues.
- Treating the runbook v1.0 Operations Lead sign-off as a gate condition for go-live prevents the most common cause of post-launch P1 incidents on identity and network security projects: incomplete operational documentation.

Adapting it to your context:

- If the project uses Confluence instead of SharePoint, replace folder paths with Confluence space/page hierarchy and use Confluence page labels as the equivalent of the naming convention lookup table; version history is native to Confluence pages.
- For a smaller project without a dedicated document controller, collapse the review SLA to 5 business days and assign audit responsibility to the PMO Analyst; the naming convention and decision register remain non-negotiable regardless of project size.
- If Bristol Financial's records policy retention period differs from the 7-year default used here, update the retention schedule before the framework is baselined and get Legal sign-off - security architecture documents in particular may have longer regulatory retention requirements under financial services regulation.

65 — Knowledge Transfer Plan — PAM vendor exit (Project Atlas)

Knowledge Inventory:

Item	Domain	Topic
1	PAM	CyberArk vault architecture and segmentation design
2	PAM	Privileged account onboarding procedure
3	PAM	Session recording and audit log retrieval
4	PAM	Emergency break-glass access procedure
5	PAM	Connector and CPM (Central Policy Manager) troubleshooting
6	PAM	Licence usage monitoring and renewal triggers
7	ZTNA	SecureEdge policy authoring and deployment workflow
8	ZTNA	ZTNA-PAM integration configuration
9	ZTNA	Certificate lifecycle management
10	ZTNA	SecureEdge escalation and support portal usage

Source and Receiver Assignments:

Items	Source	Departure	Primary Receiver	Secondary Receiver
1-6	Anton Kress (CyberArk PS)	2026-07-31	Oluwaseun Adeyemi (BF PAM Engineer, start 2026-06-16)	Priya Nair (BF, internal, already competent)
7-9	James Whitfield (SecureEdge)	2026-08-15	Raj Patel	2 BAU network security engineers
10	SecureEdge account team (BAU relationship)	Ongoing	Raj Patel	Documented in vendor contact register

Transfer Methods:

Items	Method
1 (vault architecture)	4-hour structured handover session + architecture diagram review
2-3 (onboarding, audit logs)	Shadowing: Oluwaseun observes Anton 3 runs, assists 3 runs, leads independently 2 runs with Anton present
4 (break-glass)	Tabletop exercise with incident scenario
5-6 (troubleshooting, licence)	CPM Troubleshooting Guide v2.1 + 2-hour Q&A workshop
7-8 (ZTNA policy, integration)	3-day embedded working session (Oluwaseun and Raj Patel paired with James Whitfield)
9 (certificate lifecycle)	SOP + 1-hour walkthrough

Schedule:

- KT start date: 2026-07-01
- CyberArk KT window: 2026-07-01 to 2026-07-25 (4 weeks before Anton's departure on 2026-07-31)
- SecureEdge KT window: 2026-07-14 to 2026-08-08 (4 weeks before James's departure on 2026-08-15)
- 1-week buffer before each vendor exit built into schedule

Documentation Artifacts:

Document	Version	Repository / Access
CyberArk Vault Architecture Diagram	v3.0	/Atlas/PAM/Architecture/
PAM Onboarding SOP	v2.2	/Atlas/PAM/Runbooks/
CPM Troubleshooting Guide	v2.1	/Atlas/PAM/Runbooks/
Break-Glass Access Procedure	v1.0	Restricted access - security team only
ZTNA Policy Authoring Guide	v1.4	/Atlas/ZTNA/
ZTNA-PAM Integration Config Reference	v1.1	/Atlas/ZTNA/
Certificate Lifecycle SOP	v1.0	/Atlas/ZTNA/

All documents reviewed and approved by Priya Nair and Raj Patel as technically accurate before KT sessions.

Verification Criteria:

Item	Verification Activity	Witness / Sign-off
2 (onboarding procedure)	Oluwaseun independently onboards 5 test accounts in non-production without assistance	Priya Nair witnesses and signs off
4 (break-glass)	Oluwaseun resolves simulated vault lockout scenario in tabletop without reference to runbook	PM witnesses
5 (CPM troubleshooting)	Oluwaseun diagnoses and resolves 3 injected fault scenarios	Anton Kress confirms correct resolution
7-8 (ZTNA)	Raj Patel and one BAU engineer deploy a new ZTNA policy for a test user group without SecureEdge assistance	James Whitfield reviews output and signs off

Sign-off Status (as at 2026-07-20):

Items	Status	Receiver	Source	Date
1-3	Signed Off	Oluwaseun Adeyemi	Anton Kress	2026-07-18
4	In Progress	Oluwaseun Adeyemi	Anton Kress	Tabletop scheduled 2026-07-22
5-6	Verified - awaiting final sign-off signature	Oluwaseun Adeyemi	Anton Kress	-
7-9	In Progress	Raj Patel	James Whitfield	SecureEdge KT window active
10	Not Started	Raj Patel	SecureEdge account team	Scheduled 2026-08-04

Gaps and Risks:

Ref	Description	Owner	Due	Risk Level
Gap 1	CyberArk connector configuration for 3 legacy LDAP directories is undocumented; Anton Kress to produce configuration reference	PM	2026-07-23	High if unresolved before exit

Ref	Description	Owner	Due	Risk Level
Gap 2	Oluwaseun had no prior CyberArk experience; 2 additional shadowing sessions added to onboarding procedure KT	PM	Resolved - schedule updated	Closed
Risk 1	SecureEdge embedding session (Items 7-8) depends on ZTNA production environment access granted by 2026-07-14; access request submitted	Raj Patel	2026-07-10	Active

KT Completion Certificate:

Draft certificate to be signed at Project Closure meeting on 2026-08-12. Signatories: Priya Nair (BF PAM Lead), Raj Patel (BF ZTNA Lead), Oluwaseun Adeyemi (receiver), Marcus Chen (CISO Sponsor), Anton Kress (CyberArk, vendor), James Whitfield (SecureEdge, vendor), and PM.

Certificate states: 'All knowledge transfer items have been delivered, verified, and signed off. The Bristol Financial BAU team is assessed as competent to operate ZTNA and PAM systems without vendor support. No known unmitigated knowledge gaps remain.'

HOW TO READ THIS EXAMPLE

Why this example works: This example demonstrates that KT is a managed, verified process - not a set of sessions. The observe/assist/lead model for tacit PAM knowledge, the tabletop verification for break-glass, the gap register identifying undocumented LDAP configuration, and the 4-week buffer before vendor exit are all evidence of a plan designed to ensure operational capability, not just tick a close-phase checkbox.

Key judgment calls:

- The undocumented LDAP connector configuration (Gap 1) is exactly the type of tribal knowledge that would cause a BAU incident within 30 days of go-live if not captured - flagging it two weeks before Anton's exit while there is still time to resolve it is the value the gap register provides
- Scheduling Oluwaseun's KT over a 25-day window (not 5 days) acknowledges that a person with no prior CyberArk experience cannot absorb vault operations in a compressed handover - the observe/assist/lead model operationalizes this
- Requiring Anton Kress (the source) to co-sign the sign-off alongside the receiver creates accountability on both sides - the vendor cannot claim KT is complete unless the receiver has independently demonstrated competence

Adapting it to your context:

- For an internal team reorganization (not vendor exit), the KT plan structure is identical but the contractual urgency is lower; however, impose the same verification requirement - a

departing internal SME should not be released to their new role until receivers are signed off

- If the project produced a complex data pipeline or analytics capability rather than security infrastructure, replace the observe/assist/lead rows with a different tacit-knowledge method such as paired development sprints or recorded debugging sessions - the structure of the plan does not change, only the methods
- For a multi-vendor exit (e.g., both SecureEdge and CyberArk leaving within 2 weeks of each other), run a dependency check on the KT schedule - items like ZTNA-PAM integration knowledge span both vendors and may require a joint session before either exits

66 — Automating Work with AI — Project Atlas (Phase 2)

Automation Candidate Assessment:

Criterion	Score	Rationale
Frequency	3	Weekly occurrence
Structured I/O	3	All inputs templated: sprint board, RAID log, milestone tracker, standard status template
Value	3	10 hours/month saving is significant for a team of 12
Risk if wrong	-2	Steering committee receives incorrect data - serious but detectable before distribution
Total Score	7	Strong candidate

Task Profile:

- Task: Weekly project status report compilation
- Owner: PM (Sarah Chen, Delivery Lead)
- Current effort: 2.5 hours every Friday aggregating sprint updates, RAID changes, milestone progress, and decisions into the standard 1-page steering committee template
- Frequency: Weekly; 10 hours per month
- Maximum savings ceiling: 10 hours/month

Judgment and Sensitivity:

- No negotiation or political judgment required in compilation step
- Output does not commit the organisation (summary, not a decision)
- Input data is Project Confidential - within the approved tool tier for Bristol Financial's AI platform
- Narrative commentary on programme health DOES require PM judgment and stays human

Recommended Automation Pattern:

Pattern 2 (Retrieval over project artefacts) feeding into Pattern 3 (Trigger -> Draft -> Review -> Act). Governance approval reference: Atlas-AI-GOV-003.

- Every Friday at 08:00: automation queries sprint board, RAID log, and milestone tracker
- By 08:15: draft delivered to PM with factual fields populated from standard status template
- By 09:30: PM adds narrative commentary and reviews accuracy

- By 10:00: approved report distributed to steering committee

Guardrails:

- All inputs classified Project Confidential; AI tool approved for Project Confidential tier per Bristol Financial AI Tool Registry
- Output logging enabled: every draft timestamped and archived in Atlas SharePoint AI Outputs folder
- Prompt constraint: automation populates factual fields only; narrative fields locked for human input
- No personally identifiable data or client financial data included in the index

Human Checkpoint:

- Sarah Chen (Delivery Lead) reviews every draft before distribution
- Review criteria: all milestone statuses accurate vs. sprint board; RAID count matches log; no hallucinated content in factual fields
- Failure path: if any factual field is incorrect, PM corrects and logs error type in Automation Candidate Register for prompt tuning
- Checkpoint frequency: every occurrence (weekly)

Success Metrics and Thresholds:

Metric	Target	Pause Threshold
Time to compile draft	Reduced from 2.5 hours to 0.25 hours (PM review only) - saving 2.25 hours/week (9 hours/month)	-
Checkpoint rejection rate (factual errors)	Below 10% after 4-week baseline	Pause and re-assess if >25% in any two consecutive weeks

Measured Outcomes - Week 12 Retrospective:

- Actual time saving: 2.1 hours/week (84% of estimate)
- Rejection rate weeks 9-12: averaged 6% (within target)
- Week 10 incident: RAID item closed same-day not reflected in draft; root cause was index refresh latency; resolved by moving index refresh to 07:45
- Net capacity released to PM: approximately 8.4 hours/month redirected to stakeholder engagement and risk deep-dives

Second Automation Candidate - RAID Log Hygiene:

Criterion	Score	Notes
Frequency	3	Weekly
Structured I/O	3	RAID log is structured
Value	2	45 minutes/week saving
Risk if wrong	-1	Chase notifications - low risk
Total Score	7	Approved candidate

- Pattern: Trigger -> Draft -> Review -> Act
- Activity: weekly scan of RAID log for items with no update in 10+ days; auto-draft chase notification to item owners
- PM reviews draft chase list before sending
- Estimated saving: 45 minutes/week

- Status: approved and live as of week 10

What Stayed Human:

- Programme health narrative in the status report
- All stakeholder escalation decisions
- Risk scoring changes
- Decisions about which RAID items to close vs. monitor
- Steering committee Q&A

HOW TO READ THIS EXAMPLE

Why this example works: These two automations were selected because they represent the highest-frequency, most structured tasks in the PM's weekly workload, and both had clearly defined inputs (machine-readable logs and trackers) and clearly defined output templates. The Trigger -> Draft -> Review -> Act pattern was chosen over a fully automated publish because the outputs are steering-committee-facing and carry reputational risk if wrong. The human checkpoint is fast (15-20 minutes) precisely because the automation handles the mechanical compilation, freeing the PM to focus on quality and narrative.

Key judgment calls:

- The narrative commentary on programme health - assessing whether the project is genuinely on track vs. showing green metrics but accumulating hidden risk - requires PM judgment about context, politics, and stakeholder dynamics that no retrieval system can replicate.
- The decision to escalate a RAID item from 'monitor' to 'escalate' involves weighing probability, impact, relationships, and organisational risk appetite in ways that depend on tacit knowledge the PM holds about Bristol Financial's culture and the steering committee's priorities.
- Stakeholder communications that carry bad news or require negotiation are kept entirely human - the automation produces factual data summaries that the PM may reference, but the message itself is authored and sent by a human.

Adapting it to your context:

- For a smaller project with no structured sprint board or RAID log tool, Pattern 1 (assistant-with-context) may be the right starting point - load the PM's weekly notes into the session context and use a saved prompt to structure the status report, moving to retrieval only when structured data sources exist.
- For a programme with higher data classification (e.g., a financial services regulatory programme handling restricted client data), the same patterns apply but the approved tool tier constraint may limit which AI platform can be used; the canvas forces this check before go-live, not after.
- For a team new to AI automation, start with the RAID hygiene chase notification (lower stakes, fully reviewable) before automating the steering committee status report - build confidence and measure quality at lower risk before escalating to higher-visibility outputs.

67 — Persona Message Matrix — Project Atlas

Persona Message Matrix - Project Atlas

Document Control

- Program / change: Project Atlas, migration from legacy VPN to Zero Trust Network Access (ZTNA) and a new identity platform, rolled out in four waves across 3,500 employees and 47 internal applications
- Matrix version: v2.0

- Owner: R. Patel (OCM Lead), with Casey Morrison (Program PM)
- Reviewers: Sandra Park (CISO, sponsor), comms lead
- Linked Communications Plan: Example #134

How this matrix was produced

R. Patel drafted the rows from the Stakeholder Register (Example #188). Each row was then validated with someone who represents that audience: an engineering manager for the security-engineer row, a business unit lead for the BU row, Robert Stein's team for compliance, and a sample of frontline managers for the end-user row. The validation step exists because the program office reliably mis-guesses the real objection and the trusted messenger, and the people inside each audience correct it.

Persona: Security engineers (the people operating and integrating ZTNA)

- WIIFM: per-application policy and continuous device checks replace the blunt VPN perimeter, so a compromised credential no longer means broad access; less firefighting of access tickets once the waves stabilize
- Change in their language: "We are moving from VPN-and-trust to per-request policy evaluation with device posture and risk signals, audit-logged per access"
- The ask: integrate your applications behind ZTNA on the wave schedule, help triage Wave 1 issues, adopt the policy-as-code workflow
- Likely objection: "This adds latency and another component I will get paged for." Unspoken: "Was Cloudflare the right call, or did procurement pick it?"
- Proof points they trust: the P95 latency numbers, the rollback rehearsal result, the SPADE decision record showing alternatives were weighed
- Tone and register: plain and technical, specifics over reassurance
- Channel and messenger: engineering all-hands plus the design doc, delivered by J. Liu (ZTNA lead) and Mike Tanaka (SRE), not the program office

Persona: Business unit leads

- WIIFM: stronger protection of their unit's data and customers with no change to how their teams get work done once cutover settles, and fewer audit findings landing on their plate
- Change in their language: "Your teams sign in the same way day to day. Behind the scenes, access is verified continuously, which lowers the risk of a breach that would hit your customers and your numbers"
- The ask: nominate a wave date that avoids your peak periods, and tell your teams it is coming and that leadership backs it
- Likely objection: "This will disrupt my team during a critical period and cost us productivity." Unspoken: "I did not ask for this and I will be blamed if my numbers dip"
- Proof points they trust: a peer BU lead who went in an earlier wave with no disruption, the cutover support plan, the named rollback
- Tone and register: brief and outcome-focused, low on technical detail
- Channel and messenger: a short briefing from their own leadership chain or a peer who already migrated, not a central IT email

Persona: Compliance and risk

- WIIFM: per-access audit logging and continuous verification produce the evidence they need for SOC 2 and the banking examiner, replacing coarse VPN-session logs
- Change in their language: "Every access decision is logged with attribution inside the regulator's latency commitment, and remote-access controls move toward zero open findings"
- The ask: confirm the control mapping and audit-log retention meet the regime, and co-sign the rollout's compliance gate

- Likely objection: "A new system is new risk and a new thing for examiners to question." Unspoken: "If this logging has a gap, it is my name on the regulator letter"
- Proof points they trust: the control-to-requirement mapping, the audit-log latency SLA, the examiner correspondence, the DR plan
- Tone and register: precise and evidence-led, regulatory references explicit
- Channel and messenger: a working session with Robert Stein (CRO) and the security team, plus documentation they can cite

Persona: Executives (sponsor and steering)

- WIIFM: the program meets the board's Zero Trust mandate and the external commitments, and removes the identity single point of failure behind the prior outages
- Change in their language: "We are closing the board's Zero Trust commitment on schedule and reducing the breach and outage exposure the audit flagged"
- The ask: hold the line on funding and wave dates, and back the program publicly when a BU pushes for a delay
- Likely objection: "Is this on time, on budget, and is it going to cause an incident on my watch?"
- Proof points they trust: the RAG status tied to KPIs, the wave-by-wave results, the named rollback and crisis plan
- Tone and register: headline first, one page, framing over detail
- Channel and messenger: steering review and a one-page update, delivered by Sandra Park (CISO) as sponsor

Persona: End users (all employees)

- WIIFM: a faster, simpler sign-in once migrated, with fewer VPN drops, and access that keeps working from anywhere
- Change in their language: "On your wave date you will sign in a new way one time, and then access just works without the old VPN client"
- The ask: complete the one-time setup on your wave date, install the client, and know where to get help
- Likely objection: "This will break my access and I will lose a morning to it." Unspoken: "Another IT change I did not ask for"
- Proof points they trust: their own manager saying it went fine for the last wave, a clear two-step guide, a staffed help channel on cutover day
- Tone and register: warm, plain, short, zero jargon
- Channel and messenger: their manager in a team meeting plus a simple guide, reinforced by the help desk, not a wall of text from security

Reading the matrix

The same change carries five different reasons to care, five different asks, and five different messengers. The highest-influence persona (executives) needs the least content, and the lowest-influence persona (end users) needs the most care, because adoption actually lives there. For three of the five rows the trusted messenger is not the program office or central IT. Borrowing a peer's or a manager's credibility is the move that makes the message land.

Related artifacts

- Audience and Persona Messaging Matrix (Artifact #66): the framework
- Persona Message Matrix template: the blank version
- Communications Plan, Project Atlas (Example #134): the cadence this feeds
- Stakeholder Register, Project Atlas (Example #188): the audience list this builds on
- Training and Awareness Plan, Project Atlas (Example #192): the per-persona learning
- Persona Message Matrix, University variant: the same framework in a different setting

Keywords: persona message matrix example, Project Atlas communications, ZTNA change messaging, WIIFM example, audience messaging example, security engineer messaging, business unit lead messaging, compliance messaging, executive messaging, end user messaging, messenger, populated persona matrix, change communication example, IT versus business messaging

68 — Persona Message Matrix — University variant

Persona Message Matrix - University variant

Document Control

- Program / change: a university-wide rollout of multi-factor authentication and modern identity, a higher-education parallel to the Project Atlas Zero Trust change
- Matrix version: v1.0
- Owner: program lead, with the change-management lead
- Note: this example deliberately leaves the Project Atlas world to show the framework is context-portable. The columns are identical to the Project Atlas example. Only the personas change.

Why the personas change but the columns do not

A university has a different power structure than a corporation. Authority is more distributed, faculty have real autonomy, and the trusted messenger is rarely central IT. The matrix handles this by keeping its columns and swapping its rows.

Persona: Faculty (professors)

- WIIFM: their research data, grades, and unpublished work are better protected, and there are fewer account-compromise incidents that disrupt a course or a grant
- Change in their language: "Signing in to university systems will take one extra step that protects your courses, your research, and your students' records"
- The ask: enroll a second factor before the deadline and use it for university sign-ins
- Likely objection: "This is an administrative burden that eats into teaching and research time, imposed by IT." Unspoken: "My autonomy is being eroded by a central mandate"
- Proof points they trust: a respected faculty colleague who enrolled and found it painless, an account-takeover story from a peer institution, endorsement from their department chair rather than an IT memo
- Tone and register: respectful of their time and autonomy, brief, framed around protecting their work
- Channel and messenger: a note from the department chair or faculty senate, reinforced by a colleague, not a campus-wide IT email

Persona: Deans and department chairs

- WIIFM: fewer compromised accounts in their unit, fewer disrupted classes, and a defensible answer if a data incident hits their school
- Change in their language: "This reduces the chance of a breach in your school and gives you one simple thing to ask your faculty to do"
- The ask: carry the message to their faculty, and set the expectation that enrollment is required and supported
- Likely objection: "My faculty will push back and I will absorb the complaints"
- Proof points they trust: a peer chair whose department enrolled smoothly, a short script they can use, assurance of support during enrollment
- Tone and register: collegial and brief, gives them something concrete to say
- Channel and messenger: a dean's-council briefing, delivered by a respected peer or the provost's office

Persona: IT staff (the people running the rollout and the help desk)

- WIIFM: fewer compromised-account tickets and password resets once enrollment completes, and a clearer support model
- Change in their language: "We move from password-only to MFA, with enrollment waves by school and a staffed help line during each wave"
- The ask: support enrollment, staff the help line, and escalate edge cases on the defined path
- Likely objection: "We will be buried in help tickets and blamed for faculty frustration"
- Proof points they trust: the enrollment numbers from earlier waves, the staffing plan, the escalation path
- Tone and register: plain and operational, specific
- Channel and messenger: their own IT leadership and the rollout runbook

Persona: Students

- WIIFM: their accounts, financial aid, and records are protected, and sign-in still works from their phone
- Change in their language: "Add a quick second step on your phone to keep your account and your records safe"
- The ask: enroll a second factor and know where to get help
- Likely objection: "One more hassle to log in." Resistance is usually low if it is fast
- Proof points they trust: it is the same thing their bank and their apps already do, a 30-second setup, peers and RAs
- Tone and register: very short, mobile-first, friendly
- Channel and messenger: student channels (the app, RAs, student email), not formal memos

Persona: Administration (registrar, finance, HR, leadership)

- WIIFM: protection of the most sensitive institutional data and a stronger compliance posture for FERPA, audit, and cyber-insurance requirements
- Change in their language: "This protects student and employee records and helps meet our compliance and insurance obligations"
- The ask: enroll, and for leadership, back the mandate and the deadline publicly
- Likely objection: "Will this disrupt registration or payroll periods?"
- Proof points they trust: a rollout calendar that avoids peak periods, the compliance and insurance drivers, leadership endorsement
- Tone and register: formal and compliance-aware, brief
- Channel and messenger: leadership and compliance channels

Reading the variant

Same columns, different rows, and very different messengers. In the corporate example the CISO and the SRE carry weight. Here the department chair and a respected faculty peer carry the faculty, the provost carries the chairs, and RAs and the campus app carry the students. The lesson the matrix encodes is constant: match the messenger to the audience, and the audience hears the message.

Related artifacts

- Audience and Persona Messaging Matrix (Artifact #66): the framework
- Persona Message Matrix template: the blank version
- Persona Message Matrix, Project Atlas: the corporate example this parallels
- Training and Awareness Plan (Artifact #10): per-persona learning needs

Keywords: persona message matrix university, higher education change communication, faculty messaging, professor WIIFM, dean department chair messaging, student messaging, MFA rollout communication, university Zero Trust, messenger, context-portable persona matrix, FERPA, campus IT communication

Examples — Overview

PMO Examples

What 'Good' Looks Like — Fully Populated Artifacts

Companion to PMO_Framework, Templates Pack, and Project / Program Workbooks

Connected scenario

All examples in this doc are populated against a single scenario:

"Project Atlas"

an enterprise Zero Trust Network Access (ZTNA) and Identity Modernization program at a 3,500-employee mid-market financial services company.

How to use this doc

Templates teach structure. Examples teach quality.

Read these to see what realistic content looks like —

specific message timing, real meeting cadences, populated audience maps, actual sponsor activities. Use them as benchmarks for your own artifacts.

Contents

Each example pairs with a template in PMO_Templates_Pack.docx. Templates are blank; these are filled in.

Scenario summary — Project Atlas + Cloud Security Operations function

EXAMPLES (selected highlights — full set spans 34 populated examples)

- 1. Communications Plan — Project Atlas (program-level)
- 2. OCM Plan — ZTNA Rollout component
- 3. Status Reports — Same week, three R/A/G versions
- 4. RACI — One decision in practice
- 5. Operating Model — Cloud Security Operations function
- ... examples 6-33 cover Charter, Kickoff, Stakeholder Register, BRD, RAID, Schedule, Budget, SOW, Steering Pack, UAT, Closeout, and more
- 34. Program Success Metrics, OKRs & KPIs — Project Atlas

COMPANION

PMO_Program_Workbook.xlsx — Project Atlas program tracker (fully populated)

Scenario Summary

All examples reference the same fictional company and program. Read this once; it grounds everything that follows.

The company

Company	Bristol Financial — mid-market commercial lender
Size	~3,500 employees, 12 office locations, primarily US
Industry	Financial services (commercial lending, treasury services)
Regulatory profile	SOX, GLBA, state privacy laws, SOC 2 Type II

Company	Bristol Financial — mid-market commercial lender
Trigger event	2025 SOC 2 audit findings on identity controls + an internal insider-threat incident

The program — Project Atlas

Strategic goal	Modernize identity and network access to a Zero Trust posture
Duration	Jan 2026 – Sep 2027 (~21 months)
Total budget	\$8.4M
Component count	5 component initiatives
Executive sponsor	Sandra Park, Chief Information Security Officer (CISO)
Program manager	Senior Security TPM (the reader of this doc)
Steering committee	CISO, CIO, CTO, Chief Risk Officer, VP Engineering

The 5 component initiatives

#	Initiative	Component PM	Brief description
1	Identity Provider Migration	M. Ortiz	Consolidate to enterprise Okta IdP across all apps; retire legacy SAML implementations.
2	ZTNA Rollout	J. Liu	Replace legacy VPN with ZTNA

Shared & Cross-cutting · AI Prompts (50)

AI Prompts — Overview

50 prompts a TPM or program manager can paste into Claude or another LLM to accelerate the real work. They cover four intents: Drafting (turn raw inputs into a structured first draft), Synthesis & Aggregation (compile and summarize across artifacts), Analysis (model scenarios, score, and stress-test), and Hard Situations (think through judgment calls privately).

What they are: scaffolding that gets you to a strong first draft or a sharper analysis faster. Every prompt tells the model what structure to produce, what inputs you must supply, and to flag its assumptions.

What they are not: a substitute for your judgment or for real inputs. The model cannot manufacture context it was not given - always verify figures, names, and commitments before anything leaves your hands.

Coverage: Drafting (30), Synthesis & Aggregation (5), Analysis (11), Hard Situations (3). The expanded set adds prompts for the newer artifacts - risk register scoring, quality plans, requirements traceability, WBS and estimation, earned value, business cases, agile story-splitting, go-live readiness, transition and hypercare, delivery health checks, vendor scorecards, and capacity-vs-demand analysis.

AI Prompt — Drafting a Project Charter

What it does: Generates a first draft of a Project Charter from sponsor interviews, intake forms, and strategic context, structured into 10 standard sections. The output is ready for sponsor review and targeted editing.

When to use it: Use when you have substantive inputs from a sponsor kickoff or intake process. When not: Do not use when inputs are vague or missing — the prompt will surface gaps rather than fill them, and a charter built on thin inputs won't hold up to sponsor review.

Inputs to provide:

- Project name, sponsor, TPM/PM, target dates, and total budget
- Sponsor interview notes, intake form answers, strategic context, and any prior charters for similar work

The prompt

You are drafting a first version of a Project Charter for a new project. I will provide raw inputs (sponsor notes, intake form, strategic context). Your job is to structure these into the Charter format below. Project name: [PROJECT NAME] Sponsor: [SPONSOR NAME AND ROLE] TPM/PM: [PM NAME] Target start: [DATE] Target end: [DATE] Total budget: [AMOUNT or RANGE] Inputs: [PASTE: sponsor interview notes, intake form, strategic context, any prior charters for similar work] Generate a Project Charter with these sections: 1. Project Overview (2-3 sentences capturing what the project is for) 2. Business Case & Strategic Alignment (why this project matters, what business outcome it serves) 3. Scope (in-scope items as a clear list) 4. Out-of-Scope (explicit out-of-scope items — important for boundary-setting) 5. Success Criteria (qualitative — leave OKRs/KPIs to be developed via Artifact #33) 6. High-Level Timeline (key phases and milestones) 7. Budget Summary (top-line by major category) 8. Key Stakeholders (with roles) 9. Top Risks at Kickoff (3-5 highest risks identifiable now) 10. Approvals required (sponsor, PMO, Finance, Legal/Security/Compliance as relevant) Constraints: - Use neutral, professional language. No marketing tone. - Do not invent facts. If a section can't be filled from the inputs, write "[NEEDS INPUT FROM SPONSOR]" or "[NEEDS DISCOVERY]". - Keep each section concise. Charter readability matters. - Flag any inconsistencies or gaps in the inputs explicitly at the end. - Flag any assumptions made in producing this draft.

Working with the output: Edit aggressively for your voice and the sponsor's — strategic statements (Business Case, Success Criteria) need your judgment; replace AI framing with what the sponsor actually said. The model cannot manufacture missing context, so any section marked "[NEEDS INPUT FROM SPONSOR]" requires a follow-up conversation before the charter circulates.

AI Prompt — Drafting a Program Charter (Multi-Initiative)

What it does: Generates a first draft of a Program Charter for multi-initiative programs, structured into 9 sections covering strategic context, component initiatives, governance, integration management, and benefits realization. The output distinguishes program-level concerns from component-level concerns.

When to use it: Use when you have a portfolio of related initiatives that need to be framed as a single program with shared governance and integration management. When not: Do not use for a single-project charter or when component scopes are not yet defined — the integration management section will be too thin to be useful.

Inputs to provide:

- Program name, sponsor, TPM, component count, program dates, and total budget
- Component summaries (name, scope, lead, budget, key dates for each) and strategic context (business outcome, executive commitments, regulatory drivers, dependencies)

The prompt

You are drafting a first version of a Program Charter for a multi-initiative program. I will provide raw inputs (component charters or intake forms, strategic context, sponsor commitments). Your job is to structure these into the Program Charter format. Program name: [PROGRAM NAME] Program sponsor: [SPONSOR NAME AND ROLE] Program TPM: [TPM NAME] Component count: [N] Target program duration: [START

DATE] to [END DATE] Total program budget: [AMOUNT] Component summaries: [PASTE: For each component, provide name, scope, lead, budget, key dates] Strategic context: [PASTE: business outcome the program serves, executive commitments, regulatory drivers, dependencies on/from other programs] Generate a Program Charter with these sections: 1. Strategic Context (2-3 paragraphs — why the program exists, what changes if it succeeds) 2. Program Scope (the strategic shape, not just a list of components) 3. Component Initiatives (table format: name, lead, brief description, budget allocation) 4. Program Governance (steering structure, decision rights, escalation paths) 5. Integration Management (how components coordinate — dependencies, shared resources, sequencing) 6. Program Benefits Realization (how success is measured, leave detail to Artifact #33) 7. Program Budget (rolled up from components, plus contingency, plus program-level overhead) 8. Program Risk Profile (program-level risks — different from sum of component risks) 9. Approvals (sponsor, PMO, Finance, component sponsors) Constraints: - Use neutral, professional language. The strategic context should sound deliberate, not aspirational marketing. - Do not invent facts. If a section can't be filled from the inputs, write "[NEEDS INPUT FROM SPONSOR]" or "[NEEDS DISCOVERY WITH COMPONENT LEADS]". - Distinguish program-level concerns from component-level concerns. Don't just sum the components. - Flag any cross-component dependency conflicts or integration gaps at the end. - Flag any assumptions made in producing this draft.

Working with the output: The cross-component integration management section is where the model typically thins out — add the specific dependencies, sequencing, and shared resourcing decisions yourself based on actual conversations with component leads. Verify all figures (budget roll-ups, dates) against source documents before steering review.

AI Prompt — Drafting a Business Requirements Document (BRD)

What it does: Generates a first draft of a BRD from stakeholder interviews, business context, and regulatory drivers, structured into 6 sections with a requirements table that includes source, priority, and acceptance criteria. The output is ready for stakeholder review and refinement.

When to use it: Use after stakeholder discovery when you have substantive interview notes and business context to structure into a formal requirements document. When not: Do not use as a substitute for stakeholder discovery — the model will generate plausible-sounding requirements that may not match what the business actually needs.

Inputs to provide:

- Project name, sponsor, BRD owner, and target audience (Engineering/Architecture/Vendor)
- Stakeholder interview notes (with name and role), business context, and any regulatory or compliance drivers

The prompt

You are drafting a first version of a Business Requirements Document (BRD). I will provide raw inputs (stakeholder interview notes, business context, regulatory drivers, prior BRDs for similar work). Your job is to structure these into the BRD format. Project name: [PROJECT NAME] Project sponsor: [SPONSOR NAME] BRD owner: [OWNER NAME — usually a senior business analyst or TPM] Target audience: [Engineering/Architecture/Vendor — affects detail level] Inputs: Stakeholder interviews: [PASTE: notes from each stakeholder conversation, ideally with stakeholder name and role] Business context: [PASTE: strategic plan, market drivers, organizational changes that motivated the project] Regulatory or compliance drivers: [PASTE: any regulatory text, audit findings, compliance requirements that motivated the project] Generate a BRD with these sections: 1. Background & Business Context (1-2 paragraphs) 2. Business Objectives (what business outcomes the project produces) 3. Scope (in-scope and out-of-scope, with rationale) 4. Stakeholders & User Groups (who is affected, with relationship to the work) 5. Business Requirements (the substantive list — functional, non-functional, regulatory) 6. Approvals (business sponsor, technology sponsor, compliance sponsor) For Section 5 (Business Requirements): - Use a table: ID, Requirement, Source/Stakeholder, Priority (Must/Should/Could), Acceptance Criteria - Distinguish functional ("the system shall...") from non-functional (performance, availability, security) - Distinguish requirements driven by business need from those driven by regulatory or compliance - For each, name the source stakeholder Constraints: - Do not invent requirements. If the inputs don't justify a specific requirement, omit it or flag with "[NEEDS STAKEHOLDER CONFIRMATION]". - Use clear, testable language. Avoid "the system should be user-friendly" — instead, "task X completes in N seconds at the 95th percentile under expected load." - Flag conflicts between stakeholders explicitly at the end (where two stakeholders' inputs imply different requirements). - Flag regulatory items that need legal/compliance review at the end. - Flag any assumptions made in producing this draft.

Working with the output: Requirements often need follow-up clarification with stakeholders — verify each requirement with its stated owner before treating as final. The model cannot manufacture requirements from thin inputs; any item marked "[NEEDS STAKEHOLDER CONFIRMATION]" is a genuine gap that requires another conversation.

AI Prompt — Drafting a Stakeholder Register

What it does: Generates a first draft of a Stakeholder Register from org charts, intake forms, and prior program records, structured into a 9-column table with an overall engagement summary. The output captures roles, stakes, influence levels, engagement strategies, and cadence.

When to use it: Use when you have raw stakeholder context that needs to be structured into a formal register at project or program kickoff. When not: Do not use when stakeholder context is minimal — the model will flag thin rows rather than invent stake or influence, but the register will not be useful until those gaps are filled.

Inputs to provide:

- Project name and TPM name
- For each stakeholder: name, role/title, organization, brief relationship to the project, and any known engagement context

The prompt

You are drafting a first version of a Stakeholder Register. I will provide stakeholder names, roles, and any context I have on their relationship to the project. Your job is to structure these into the Stakeholder Register format. Project name: [PROJECT NAME] TPM: [TPM NAME] Stakeholder list: [PASTE: For each stakeholder, provide: name, role/title, organization, brief relationship to the project, any known engagement context] Generate a Stakeholder Register table with these columns: 1. Name 2. Role / Title 3. Organization / Function 4. Stake (what they care about, what they have to gain or lose) 5. Influence (High / Medium / Low — based on decision authority) 6. Engagement strategy (Inform / Consult / Involve / Collaborate / Empower) 7. Cadence (how often you'll engage them — weekly 1:1, monthly review, quarterly steering, ad hoc) 8. Owner (which member of the project team owns this relationship) 9. Notes (any specific context to remember) After the table, generate a 2-3 sentence engagement summary describing the overall stakeholder picture: where most stakes lie, which relationships need the most TPM attention, where the political risk concentrates. Constraints: - Do not infer high influence from senior title alone. Influence depends on whether the role has decision authority over the project, not on org rank in general. - For Stake, be specific. "Cares about budget" is generic; "owns the IT cost center this project draws from" is specific. - For engagement strategy, default to "Consult" or "Inform" unless the inputs suggest more involvement is warranted. - Flag stakeholders where the inputs are too thin to populate the row — do not invent stake or influence. - Flag any assumptions made in producing this draft.

Working with the output: The influence and engagement-strategy fields require your judgment to correct — the model will guess at influence based on titles, which often does not reflect actual organizational dynamics. Communication preferences should come from the stakeholders themselves, not be assumed from role or seniority.

AI Prompt — Drafting RAID Log entries

What it does: Converts raw meeting notes or workshop output into structured RAID Log entries across four tables (Risks, Assumptions, Issues, Dependencies), each with the standard fields your log requires. The output is ready to paste into an existing RAID Log.

When to use it: Use immediately after a meeting, workshop, or retrospective where risks, assumptions, issues, or dependencies were surfaced and need to be logged. When not: Do not use as a substitute for the conversation itself — the model classifies what is in the notes, and items discussed but not captured will not appear.

Inputs to provide:

- Project name and source meeting/workshop description (name + date)
- Raw meeting notes, transcript, retrospective output, or workshop capture

The prompt

You are converting raw meeting notes or workshop output into structured RAID Log entries. RAID stands for Risks, Assumptions, Issues, Dependencies. I will provide raw notes; your job is to extract entries and structure them. Project name: [PROJECT NAME] Source meeting/workshop: [DESCRIPTION — e.g., "Wave 2 readiness review on 2026-04-15"] Raw notes: [PASTE: meeting notes, transcript, retrospective output, or workshop capture] Extract and structure entries in four tables: Risks, Assumptions, Issues, Dependencies. For each Risk entry: - ID (use format R-NNN starting from where my register currently ends, ask if needed) - Description (what could go wrong) - Likelihood (High/Medium/Low) - Impact (High/Medium/Low) - Mitigation (action being taken or proposed) - Owner (named person) - Status (Open/Mitigated/Closed) For each Assumption entry: - ID (A-NNN) - Description (what we're assuming to be true) - Validation status (Validated/Pending/Invalidated) - Validation owner (who confirms) - Trigger if invalidated (what happens if the assumption proves false) For each Issue entry: - ID (I-NNN) - Description (something that has happened or is happening) - Severity (High/Medium/Low) - Resolution path - Owner - Target resolution date - Status For each Dependency entry: - ID (D-NNN) - Description (what this work depends on) - Direction (Inbound — we depend on them; Outbound — they depend on us; Bidirectional) - External party (named team or person) - Required by date - Status Constraints: - Distinguish Risks (could happen) from Issues (has happened). Many people conflate these. - Be specific. "Vendor risk" is too vague; "FIDO2 vendor lead time may slip from 4 to 8 weeks" is specific. - For Likelihood and Impact, default to Medium unless the inputs justify High or Low. - If an item could be either a Risk or an Assumption (e.g., "we assume X will happen, but if it doesn't..."), file as a Risk. Assumptions are things we're treating as known. - Flag at the end any items in the raw notes that you couldn't categorize cleanly. - Flag any assumptions made in producing this draft.

Working with the output: Verify the RAID classification for every entry — the Risks vs. Issues distinction matters for how the log drives action. Severity ratings often default to Medium when the model is uncertain; correct based on actual program impact, and verify all owner assignments match how your program distributes responsibility.

AI Prompt — Drafting a Communications Plan

What it does: Generates a first draft of a Communications Plan from the Stakeholder Register and program context, structured into 6 sections including a communication matrix and cadence calendar. The output maps each audience to a channel, owner, and cadence appropriate to their engagement tier.

When to use it: Use after the Stakeholder Register is in place and you need to translate engagement tiers into a structured communications schedule. When not: Do not use before stakeholder discovery is complete — a Comms Plan built on an incomplete register will miss key audiences or default to generic cadences.

Inputs to provide:

- Program name, Comms Plan owner, program duration, and key phases
- Stakeholder Register rows (name, role, engagement tier, cadence preference) and any specific communication needs (rollouts, governance reviews, audit briefings, vendor management)

The prompt

You are drafting a first version of a Communications Plan. I will provide the Stakeholder Register and program context; you will structure the Comms Plan. Program name: [PROGRAM NAME] Comms Plan owner: [OWNER] Program duration: [START to END] Key program phases: [PHASES — e.g., chartering, build, pilot, waves, close] Stakeholder Register: [PASTE: stakeholder rows including name, role, engagement tier, cadence preference] Program communication needs: [PASTE: anything specific — rollouts that need OCM comms, governance reviews, audit briefings, vendor management] Generate a Comms Plan with these sections: 1. Communication Objectives (2-3 sentences — what the comms plan is for) 2. Audiences (the audience segments, derived from the Stakeholder Register) 3. Communication Matrix (table — Audience, Message Type, Channel, Cadence, Owner, Notes) 4. Cadence Calendar (visual or text representation of the recurring communications across program phases) 5. Escalation Communication Path (how time-sensitive communications flow) 6. Message Templates Reference (where reusable message templates live, if applicable) For the Communication Matrix: - Audiences should match the Stakeholder Register's tiers (Inform/Consult/Involve/Collaborate/Empower) - Channels: written status, 1:1, group meeting, email, Slack, Steering pack, town hall, video, FAQ doc - Cadences: weekly, biweekly, monthly, quarterly, ad-hoc, milestone-driven - Match channel and cadence to the audience tier — Inform tier gets

less frequent, lower-touch channels; Collaborate tier gets higher-touch Constraints: - Do not over-communicate. Most Comms Plans default to too much, which produces stakeholder fatigue. Default toward less for Inform-tier audiences. - Distinguish routine communications (status, governance) from event-driven (rollouts, escalations, milestones). - For each audience, name a specific Owner — the person who actually delivers the message, not just a role. - Flag at the end any audiences from the Stakeholder Register where the engagement strategy doesn't translate cleanly to a comms cadence (these usually need a 1:1 conversation, not a Comms Plan entry). - Flag any assumptions made in producing this draft.

Working with the output: Validate that the cadence matches your sponsor's actual schedule and your team's capacity; the model generates reasonable defaults but the real constraints come from your program context. Audience-specific messaging requires your judgment about what each population actually needs to hear — do not treat the draft matrix as final without review.

AI Prompt — Drafting an OCM Plan

What it does: Generates a first draft of an OCM Plan from change scope, affected populations, and program timeline, structured into 8 sections covering impact analysis, audience segmentation, interventions, adoption metrics, resistance planning, and reinforcement. Intervention intensity is matched to population impact severity.

When to use it: Use when the program has user-facing change and you need a structured adoption plan covering awareness, training, and reinforcement prior to a cutover or rollout. When not: Do not use when affected population data and stakeholder engagement findings are not yet available — the model will flag gaps rather than invent resistance points or psychological framings.

Inputs to provide:

- Program name, specific change event description, OCM lead name, and change date(s) or wave window
- For each affected population: count, role/function, current state, future state, anticipated impact severity; plus change rationale, business case, any prior survey or engagement data, and known concerns from stakeholder conversations

The prompt

You are drafting a first version of an OCM Plan for a specific change event. I will provide the change description, affected populations, and any prior OCM context; you will structure the plan. Program name: [PROGRAM NAME] Change event: [SPECIFIC CHANGE — e.g., "ZTNA Wave 2 cutover replacing legacy VPN for Engineering, IT, and Security functions"] OCM Lead: [LEAD NAME] Change date(s): [SPECIFIC DATE(S) OR WAVE WINDOW] Affected populations: [PASTE: For each population, provide: count, role/function, current state, future state, anticipated impact severity] Inputs: [PASTE: change rationale, business case for change, any prior survey or engagement data, known concerns from stakeholder conversations] Generate an OCM Plan with these sections: 1. Change Overview (what's changing, when, why) 2. Impact Analysis (table by population: count, severity, current/future state, key concerns) 3. Audience Segmentation (how populations are grouped for tailored intervention) 4. Interventions (table by audience segment: comms, training, support, sponsor visibility, with cadence and owner) 5. Adoption Metrics (leading and lagging indicators of successful change) 6. Resistance Plan (anticipated resistance points and response strategies) 7. Reinforcement (post-cutover support and feedback channels) 8. Success Criteria (specific measurable outcomes that mean the change landed) For the Impact Analysis: - Severity scale: Minimal (workflow doesn't change), Moderate (workflow changes, training required), Significant (process changes, potential productivity hit), Major (role or org change implications) - Be specific about what's changing for each population — not "users will adopt new system" but "engineers move from VPN client connection to ZTNA gateway, requiring new daily authentication flow with FIDO2 token" For Interventions: - Match intensity to severity — Major impact needs sponsor visibility, hands-on support, manager involvement; Minimal impact needs awareness only - Specify owner for each intervention (OCM Lead, change champion, manager, helpdesk) - Specify cadence (T-30 days, T-7 days, cutover day, T+7 days, T+30 days) Constraints: - Do not invent resistance points or psychological framings. If the inputs don't include actual concerns from stakeholder conversations, write "[NEEDS DISCOVERY WITH AFFECTED POPULATIONS]" rather than guessing. - Do not over-engineer interventions for low-severity populations. - Adoption metrics should include both leading indicators (engagement at T-7) and lagging (active usage at T+30). - Flag any assumptions made in producing this draft.

Working with the output: The model will generate generic change-management activities — replace them with specifics tied to your actual populations and channels. Adoption metrics must be measurable in your tools; verify each metric has a named data source before committing to it, and do not treat any figures in the impact analysis as validated until confirmed with population owners.

AI Prompt — Drafting a Training & Awareness Plan

What it does: Generates a first draft of a Training & Awareness Plan from change scope, affected roles, and training infrastructure constraints, structured into 9 sections covering learning audiences, objectives, modality map, materials inventory, delivery schedule, and measurement. Learning objectives use Bloom's-style verbs with specified assessment methods.

When to use it: Use when the program requires user training and you need a structured plan covering content, delivery, and effectiveness measurement prior to a cutover or rollout. When not: Do not use before the affected populations and their specific learning needs are defined — the model will flag gaps rather than invent learning objectives.

Inputs to provide:

- Program name, specific change event description, and training lead name
- For each affected population: count, role, current state, future state, what they specifically need to learn; plus training budget, time-to-cutover, available delivery modalities, and language requirements

The prompt

You are drafting a first version of a Training & Awareness Plan. I will provide the OCM Plan or change description and the affected populations; you will structure the training plan. Program name: [PROGRAM NAME] Change event: [SPECIFIC CHANGE] Training Lead: [LEAD NAME or "TPM" if no dedicated lead] Affected populations and learning needs: [PASTE: For each population, provide: count, role, current state, future state, what they specifically need to learn] Constraints from the program: [PASTE: training budget, time-to-cutover, available delivery modalities (instructor-led, e-learning, video, written guides), language requirements] Generate a Training & Awareness Plan with these sections: 1. Plan Overview (purpose, scope, success criteria for training) 2. Learning Audiences (segmented by role and learning need) 3. Learning Objectives (per audience: what they should know, do, and feel after training) 4. Modality Map (per audience: format, duration, frequency, delivery channel) 5. Materials Inventory (what content needs to be developed, who develops it, when) 6. Delivery Schedule (timeline aligned to OCM cadence — T-30, T-14, T-7, cutover, T+7, T+30) 7. Reinforcement & Refresh (post-cutover knowledge sustainability) 8. Measurement (completion rates, pass rates, post-training competency, post-cutover help desk ticket volume) 9. Owners and Approvals For Learning Objectives: - Use Bloom's-style verbs (understand, demonstrate, complete, troubleshoot) - Distinguish "must know" from "good to know" - For each objective, specify the assessment method (quiz, demonstration, work product, no-assessment for awareness-only) For Modality Map: - Match modality to learning objective intensity — high-stakes operational change usually requires hands-on practice; awareness-only can use email + e-learning - Estimate time investment per learner — most plans underestimate - Distinguish synchronous (live training) from asynchronous (self-paced) Constraints: - Do not invent learning objectives. If the affected population's learning need isn't clear from the inputs, write "[NEEDS DISCOVERY WITH POPULATION OR MANAGER]". - Do not over-train. Most Training Plans default to too much content; edit toward minimum effective dose. - Specify owner for each material item — generic "Training Lead develops" doesn't execute. - Flag any assumptions made in producing this draft.

Working with the output: Training capacity (instructors, LMS slots, room availability) is a real constraint the model cannot know — verify the schedule against actual capacity before committing. Effectiveness metrics should be measurable in your LMS or HRIS; do not include a metric the model suggested if you cannot produce the data to report against it.

AI Prompt — Compiling a Status Report from program artifacts

What it does: Aggregates a weekly Status Report from schedule, RAID, budget, decisions, and activity inputs, structured into 9 sections including an overall RAG status, executive summary, and a specific asks/blockers section. The RAG is calibrated from the inputs rather than auto-defaulted.

When to use it: Use for routine reporting cycles when you have the underlying inputs (milestone tracker, RAID log, budget actuals, DC log) and need them consolidated into a sponsor-readable report. When not: Do not use as a substitute for the underlying data — if the inputs are stale or incomplete, the report will reflect that, and a Green status generated from incomplete inputs is worse than no report.

Inputs to provide:

- Program name, reporting period (week ending date), reporting tier (Executive Summary or Working Team), and author name
- Schedule status (milestones due, completion status, any slip from baseline), RAID status (top 5 risks, new/closed entries), budget status (actuals vs plan, forecast EAC, variances), decisions made this period (DC log entries), and key activities for current and next period

The prompt

You are compiling a Weekly Status Report by aggregating from program artifacts. I will provide current state data from the workbook (schedule, RAID, budget, decisions); you will generate the structured report. Program name: [PROGRAM NAME] Reporting period: [WEEK ENDING DATE] Reporting tier: [Executive Summary / Working Team — affects detail level] Author: [TPM NAME] Current state inputs: Schedule status (from Schedule & Milestone Tracker): [PASTE: milestones due in this period, completion status, slip from baseline if any, upcoming milestones] RAID status (from RAID Log): [PASTE: top 5 risks with current status, any new entries since last report, any closed entries] Budget status (from Project Budget): [PASTE: actuals vs plan, forecast EAC, any material variance] Decisions made this period (from Decisions & Changes Log): [PASTE: DC entries from this reporting period] Key activities this period: [PASTE: brief description of what the team accomplished] Key activities next period: [PASTE: what's coming in the next reporting period] Generate a Status Report with these sections: 1. Header (program name, period, author, date) 2. Overall RAG status (Green / Amber / Red, with one-sentence rationale) 3. Executive Summary (3-4 sentences — what the sponsor needs to know) 4. Schedule Summary (milestones completed, milestones at risk, milestones missed) 5. Top Risks/Issues (top 3-5 from RAID, with status) 6. Budget Snapshot (actuals vs plan vs forecast EAC, with variance commentary) 7. Decisions This Period (key DC entries with one-line summary) 8. Asks/Blockers Needing Escalation (if any — be specific about who needs to act and by when) 9. Metrics Snapshot (KPI readings if applicable — see Artifact #33) Constraints: - The RAG status should be informed by the inputs, not invented. If schedule/budget/risk all look on track, that's Green. If any are showing material concern, that's Amber. Red requires sponsor-level intervention (per Field Note #227). - Do NOT auto-default to Green. Calibrate based on the actual inputs. - The Executive Summary should be readable in 30 seconds. No filler. The sponsor cares about progress against commitments, material risks, and asks. - Do not invent risks or issues that aren't in the inputs. - For asks/blockers, be specific about the action requested. "We need help" is not an ask; "We need [decision] from [name] by [date] or [consequence]" is. - Flag at the end any inconsistencies in the inputs (e.g., RAID says high risk, Schedule says on track) so the TPM can address them before publishing. - Flag any assumptions made in producing this draft.

Working with the output: Verify the RAG matches the underlying data before publishing — if you mark Green but data shows slipping milestones, the rationale must explain why. The model cannot verify figures against your source system; spot-check actuals, milestone dates, and EAC against the workbook before the report goes to the sponsor.

AI Prompt — Compiling a Steering Committee Pack

What it does: Aggregates a Steering Committee Pack from recent status reports, RAID state, decision log, schedule and budget snapshots, and upcoming decision items, structured into 7 sections including an executive summary, progress review, current state snapshot, decisions requested, and watch items. The output is sized for an executive audience (8-15 pages or slides).

When to use it: Use to convert routine program status into a governance-relevant briefing when you have a steering meeting in the next 1-2 weeks and need to structure what steering needs to know vs. decide. When not: Do not use when the underlying program state is unclear or when decision items have not been identified — a steering pack without clear decisions is a status update, not governance.

Inputs to provide:

- Program name, steering meeting date, attendee list (sponsor and governance members), and pack author name
- Recent status reports (last 4-8 cycles), DC log entries since last steering, top 5-8 RAID items, current schedule and budget snapshot, specific decision items for this meeting, and upcoming material events in the next 60 days

The prompt

You are compiling a Steering Committee Pack from recent program artifacts. I will provide the inputs (recent status reports, key decisions, current RAID state, upcoming decision items); you will structure the pack. Program name: [PROGRAM NAME] Steering meeting date: [DATE] Steering attendees: [LIST — sponsor, key executives, governance members] Pack author: [TPM NAME] Inputs: Recent status reports (last 4-8 cycles): [PASTE or attach: prior status reports for context] Decisions made since last steering: [PASTE: DC log entries since last steering] Top RAID items currently: [PASTE: top 5-8 risks/issues] Current schedule + budget snapshot: [PASTE: milestones, schedule variance, budget actuals vs plan, forecast EAC] Decision items for this meeting: [PASTE: specific decisions you're seeking from steering] Upcoming material events (next 60 days): [PASTE: cutover dates, audit windows, vendor commitments] Generate a Steering Committee Pack with these sections: 1. Executive Summary (1 slide / page — 3-4 bullets capturing program state) 2. Progress Since Last Steering (what was committed last time, what was delivered) 3. Current State Snapshot (RAG, schedule, budget, top risks — at executive tier) 4. Decisions Requested This Meeting (specific decisions with context, options, recommendation) 5. Watch Items (situations the TPM is monitoring that may convert to decisions next time) 6. Upcoming Material Events (next 60 days) 7. Backup Detail (additional context for any decision item — accessible if needed but not in the main flow) Constraints: - This is an executive audience. Length matters: total pack should be 8-15 slides or pages, not 30. If a section needs to be longer, it goes in Backup. - Decisions Requested is the most important section. Each decision needs: clear question, 2-3 options, recommendation with rationale, decision deadline if applicable. "Update on X" is not a decision item — it's a status item, which goes in Progress. - Watch Items are NOT decisions. They are situations being monitored. Naming them in the pack lets steering pre-align without committing. - Do not pad. If a section has nothing material to report, write "Nothing material this period" and move on. - Flag any conflicts between inputs (e.g., status report says Green but RAID has multiple new High risks) at the end for TPM resolution. - Flag any assumptions made in producing this draft.

Working with the output: Lead with decisions needed, not status — if the pack does not have a crisp Decisions Requested section, it is not ready for steering. Verify all figures (budget, milestone dates, RAG) against source artifacts before the pack goes out; the model cannot manufacture missing context or reconcile conflicting inputs on your behalf.

AI Prompt — Generating Decision Log entries from a meeting transcript

What it does: Extracts every decision, change, and approval from a meeting transcript or notes and structures them as numbered Decisions & Changes Log entries, capturing type, rationale, owners, affected artifacts, and status. It also flags items that were discussed but not decided, so nothing falls through.

When to use it: Use immediately after a decision-making meeting to convert the raw transcript into a durable, cross-referenced log. When not: Do not use as a substitute for capturing rationale in real time - if the transcript itself is thin, the entries will be thin.

Inputs to provide:

- Program name, meeting date, meeting type, and attendee list
- Full meeting transcript or detailed notes (pasted or attached)
- Latest DC entry IDs or current log (for continued numbering)

The prompt

You are extracting decisions and changes from a meeting transcript and structuring them as Decisions & Changes Log entries. I will provide the transcript and program context; you will produce structured DC entries. Program name: [PROGRAM NAME] Meeting date: [DATE] Meeting type: [STEERING / WORKING TEAM / ARCHITECTURE REVIEW / SPONSOR 1:1 / etc.] Attendees: [LIST] Transcript: [PASTE OR ATTACH: meeting transcript or detailed notes] Existing DC log (so you can continue numbering): [PASTE: latest DC entry IDs or attach the current log] Extract every decision and change. For each, generate a structured entry: DC ID: [Continue from existing -- DC-NNN] Date: [Meeting date] Decision/Change Title: [Concise title -- 5-10 words] Type: [Decision / Change / Approval] Description: [What was decided, in 2-3

sentences. Capture enough context that a reader 6 months from now will understand without the original meeting context.] Rationale: [Why this was decided this way, including any trade-offs surfaced] Owners: [Who is accountable for execution] Affected artifacts: [Which other artifacts need to be updated as a result -- Charter, RAID, Schedule, etc.] Status: [Approved / Pending Approval / Awaiting Confirmation] Constraints: - Distinguish Decisions (deliberate choices among options) from Changes (modifications to prior commitments) from Approvals (ratifications of work already done). - Capture the rationale, not just the outcome. The rationale is what makes the entry useful 6 months later. - If the transcript has discussion that didn't reach a decision, do not generate an entry for it. Instead, list at the end: "Items discussed but not decided -- recommend continuing in [next forum]: [list]". - If a decision was made but the rationale wasn't captured in the transcript, write "[RATIONALE NEEDS CAPTURE FROM ATTENDEES]" rather than inventing it. - Flag at the end any decisions where the affected artifacts list is significant -- those need TPM follow-up to ensure cross-document consistency. - Flag any place where you are making an assumption about type, rationale, or affected artifacts, and note what additional information would resolve it.

Working with the output: Verify that the alternatives listed reflect what was actually discussed - the model cannot know what wasn't in the transcript. Be specific about schedule impact where noted; "may affect schedule" is not actionable but "adds 14 days to M-008 critical path" is. Verify all figures against source data before using the entries as the record of truth.

AI Prompt — Synthesizing Lessons Learned from retrospectives and post-incident reviews

What it does: Converts raw retrospective notes, post-incident review outputs, and sponsor or audit feedback into structured Lessons Learned entries expressed as durable principles - not observations of specific events - with category, context, recommendation, and audience for each. It also groups overlapping lessons and distinguishes lessons from action items.

When to use it: Use after a retrospective or PIR when you have enough raw input that synthesis requires pattern recognition across many items. When not: Do not use when the source material is thin (fewer than a handful of observations) - synthesis adds no value and may manufacture patterns.

Inputs to provide:

- Program name (or "Cross-Program" if synthesizing across programs) and synthesis owner
- Retrospective output notes, PIR notes (if applicable), and any other reflection material (1:1 notes, sponsor feedback, audit observations)

The prompt

You are synthesizing Lessons Learned from retrospective and post-incident review output. I will provide the source material; you will extract structured lessons. Program name: [PROGRAM NAME or "Cross-Program" if synthesizing across multiple] Synthesis owner: [TPM NAME or PMO ROLE] Source material: Retrospective output: [PASTE: retrospective notes, including what worked / what didn't / what to change] Post-incident review output (if applicable): [PASTE: PIR notes, root causes, action items] Other reflection material: [PASTE: any 1:1 retrospective notes, sponsor feedback, audit observations] Generate Lessons Learned entries with this structure: Lesson ID: [L-NNN] Lesson Title: [Concise title -- 5-10 words] Category: [Process / Tooling / Communication / Stakeholder / Technical / Governance / Vendor] Context: [The situation that produced the lesson, in 2-3 sentences] Lesson: [What was learned, expressed as a durable principle, not a specific observation] Recommendation: [What to do differently going forward] Audience: [Who should know this -- TPMs, engineering leads, sponsors, PMO, whole organization] Source: [Which retrospective/incident/feedback this came from] Constraints: - A lesson is durable. "Vendor X is slow" is not a lesson; "Single-sourcing critical-path components produces hidden risk" is a lesson. - Lessons should be expressed as principles, not as observations of specific events. - If a source observation doesn't generalize, do not force it into a lesson. Either reframe it as a durable principle or omit. - Distinguish lessons (durable principles) from action items (specific tasks to complete). Action items belong in the Post-Incident Action Tracker (#32), not the Lessons Learned Register. - Do not include observations that are essentially blame ("X person didn't do Y"). Reframe systemically ("the process didn't include a checkpoint for Y") or omit. - Group related lessons at the end and flag any that overlap so the TPM can consolidate. - Flag any assumption you are making when reframing an observation into a principle.

Working with the output: Surface patterns, not just aggregations - a list of 47 items is not a synthesis. Verify that each principle actually generalizes from the source material; the model

cannot manufacture context that wasn't provided. "Communication broke down" is a symptom; "comms plan didn't include functional team cadence" is a diagnosis - push for the latter.

AI Prompt — Drafting an Executive Briefing

What it does: Generates a structured first-draft executive briefing - for board, audit committee, regulator, or senior leadership - calibrated to the specific audience's concerns, using their language and the altitude they need. Covers executive summary, strategic context, current state, key risks, decision items, and forward look in the target length.

When to use it: Use when you need to translate a program status into language calibrated for a senior external or executive audience and need a structural starting point. When not: Do not use when the audience relationship or political framing requires judgment calls the AI cannot make - this is collaborator-mode only; the framing has to be yours.

Inputs to provide:

- Briefing audience, purpose, and target length (slides or pages)
- Program scope, current state (RAG, milestones), top 3-5 risks with mitigations, any decision items, and audience-specific context (what this audience cares about)

The prompt

You are drafting a first version of an executive briefing on a program. I will provide program context, the audience, and the briefing's purpose; you will structure the briefing. Program name: [PROGRAM NAME] Briefing audience: [BOARD / AUDIT COMMITTEE / EXECUTIVE LEADERSHIP / REGULATOR / OTHER] Briefing purpose: [WHY THIS BRIEFING -- periodic update, decision request, response to inquiry, etc.] Briefing length target: [SLIDES OR PAGES -- usually 5-10 for executive audiences] Program context: Program scope and timeline: [PASTE: high-level scope, dates, budget] Current state: [PASTE: where the program is -- RAG, key milestones completed, key milestones upcoming] Key risks or concerns: [PASTE: top 3-5 risks at executive tier, with mitigations] Decision items (if any): [PASTE: specific decisions or asks for the audience] Audience-specific context: [PASTE: what this audience cares about specifically -- board cares about strategic outcomes and risk; audit committee cares about controls and compliance; regulator cares about specific regulatory commitments; etc.] Generate an Executive Briefing with these sections: 1. Title and Audience (top of doc) 2. Executive Summary (3-4 bullets -- what the audience needs to take away) 3. Strategic Context (why the program matters -- at the audience's altitude) 4. Current State (where the program is, in audience-relevant framing) 5. Key Risks (top 3-5, framed for audience concerns) 6. Decision Items / Asks (if applicable) 7. Looking Ahead (what's coming, what to expect at the next briefing) Constraints: - Audience altitude matters. Board doesn't want operational detail; auditors don't want strategic vision; regulators want specific commitments and evidence. Tailor the framing. - Length target is firm. If a section needs to be longer, it goes in an Appendix that's available if asked but not in the main flow. - Use the audience's language. Boards use business outcome language; audit committees use controls language; regulators use regulatory text. Do not generic-corporate-speak. - Risks should be framed in terms the audience cares about. Schedule risks for the board are about strategic delivery; for the audit committee, schedule risks are about audit window timing. - Do not invent. If a section's input is thin, write "[NEEDS INPUT FROM TPM]" rather than padding. - Flag any concerns where the briefing's framing might land differently for this audience than other audiences would expect -- those are places the TPM needs to think carefully about wording. - Flag any assumption you are making about audience priorities or framing choices.

Working with the output: This briefing is judgment-bearing for the senior audience receiving it - treat the AI draft as a structural starting point only; the framing has to be yours. Verify every number against source data before use; the model will confabulate figures when inputs are uncertain.

AI Prompt — Running a "+2 weeks" scenario model

What it does: Models the downstream cascade if a slipping milestone slips another 2 weeks (or a specified increment), walking forward through dependencies to surface hidden float, identify hard-date exposure, and produce a structured watch-item or decision-item recommendation. Covers cascade walk-forward, hidden float opportunities, budget tail, and sponsor-surfacing criteria.

When to use it: Use when something on or near the critical path is showing risk and you need to decide whether to surface it to the sponsor as a watch item or fix it quietly before it becomes a decision. When not: Do not use when the schedule data is too sparse to model - the analysis will manufacture false confidence.

Inputs to provide:

- Milestone at risk (name and current best-case forecast), slip being modeled, and trigger conditions present
- Schedule context for the affected milestone and downstream milestones, dependency information, budget context, and any hard downstream dates

The prompt

You are running a "+2 weeks" scenario model for a slipping or at-risk milestone. I will provide the milestone, the schedule context, and dependency information; you will structure the cascade analysis. Milestone at risk: [MILESTONE NAME -- e.g., M-008 FIDO2 privileged enrollment] Current best-case forecast: [DATE] Slip being modeled: [+2 weeks / +1 week / +4 weeks -- typically +2] Trigger conditions present: [Which of: critical-path proximity, hard-date downstream commitment, external coordination dependency, compounding factor] Schedule context: [PASTE: the affected milestone and downstream milestones, with current dates and dependencies between them] Dependency information: [PASTE: known dependencies -- both technical and stakeholder/process -- that could absorb or amplify the slip] Budget context: [PASTE: any budget implications -- premium pricing, team carrying cost, vendor change orders] Hard dates downstream: [PASTE: any non-negotiable downstream dates -- regulatory, audit, customer commitments] Generate a structured scenario analysis with these sections: 1. The cascade walk-forward For each downstream item: - Item ID and name - Whether it depends on the slipping milestone - Float available - Net slip after applied float Walk forward 4-6 cycles or until reaching a hard date. 2. Hidden float opportunities Three places to look: - Parallel work that doesn't actually depend (sequencing artifacts vs. real dependencies) - Buffer between completion and downstream consumption (real testing time vs. calendar space) - Work already partially done (front-loaded prep that shrinks the cascade) For each, identify whether it applies to this scenario and estimate the float recovery if so. 3. Budget tail - Team carrying cost per week of slip (estimate or range if precise data not available) - Vendor change-order exposure - Premium or overtime cost if compression is attempted - Total budget tail range 4. Sponsor-surfacing criteria Apply the four criteria: - Critical-path proximity (yes/no, with specifics) - Hard-date downstream commitment (yes/no, with specifics) - External coordination dependency (yes/no, with specifics) - Compounding factor (yes/no, with specifics) Tally: how many criteria are met? - How long until inevitable? - What's the cost of late notice? Make a recommendation -- surface as watch item, surface as decision item, or fix quietly. 5. If recommended as watch item, draft the watch item structure - Specific scenario named - Threshold that converts watch to real problem - Clear conversion path (what action gets taken if threshold trips) Constraints: - Be honest about float. Don't manufacture float that doesn't exist. - Budget tail estimates can be ranges; do not invent precision. - The recommendation should be calibrated to the actual analysis. Don't default to surface-now or fix-quietly without working through the criteria. - Flag any inputs that are too thin to model and where TPM judgment will need to fill gaps.

Working with the output: Verify float estimates against your direct knowledge of the team - the model may miss program-specific reasons items can run in parallel that you would know. The watch-item vs decision-item recommendation is a starting point; you make the call. Never present budget figures from this analysis without verifying against your actuals.

AI Prompt — Running a prioritization scoring exercise

What it does: Runs a structured prioritization analysis (RICE, weighted scoring, value-vs-effort, MoSCoW, or your team's standard) on a candidate list of programs, features, or initiatives, producing a ranked list with composite scores, confidence flags, sensitivity analysis, and a recommendation with explicit assumptions. Surfaces false precision and close calls.

When to use it: Use when ranking a candidate set for a quarterly portfolio review, feature backlog, or resource allocation decision and the rationale needs to be defensible to stakeholders. When not: Do not use when inputs are too speculative to score meaningfully - garbage in, garbage out, and false precision is worse than no analysis.

Inputs to provide:

- Prioritization context, scoring framework, and decision audience

- For each candidate: name, brief description, impact estimate with assumptions, effort estimate with caveats, strategic alignment, and any other relevant inputs; scoring weights if using weighted scoring or RICE

The prompt

You are running a structured prioritization exercise for a candidate set. I will provide the candidates and the scoring inputs; you will produce a ranked list with explicit assumptions and uncertainty. Prioritization context: [WHY this prioritization is happening -- quarterly portfolio review, feature backlog, etc.] Scoring framework: [RICE / Weighted Scoring / Value-vs-Effort / MoSCoW / OTHER] Decision audience: [Who will use this output -- sponsor, steering, product council] Candidate set: [For each candidate, paste: name, brief description, impact estimate (with assumptions), effort estimate (with caveats), strategic alignment, any other relevant inputs] Scoring weights (if weighted scoring or RICE): [PASTE: weights for each dimension if not using framework defaults] Generate a structured prioritization output with these sections: 1. Inputs summary For each candidate, restate the inputs in normalized form. Flag inputs that are point estimates vs. ranges, and note confidence levels where they vary. 2. Scoring table For each candidate: - Score components (impact, effort, confidence, etc. per the framework) - Composite score - Confidence in the score (High / Medium / Low -- based on input quality) 3. Ranked list Sorted by composite score, with confidence flags. Items with overlapping confidence intervals should be flagged as ties for prioritization purposes. 4. Sensitivity analysis For at least the top 8-10 items, show how rankings would shift if: - The top scoring weight is changed by +/-20% - The top assumption (highest-impact input) is changed This surfaces which rankings are robust vs. which depend heavily on specific inputs. 5. Recommendation Distinguish: - Clear top tier (robust across sensitivity analysis) - Contested middle (where ranking flips under reasonable input variation) - Below-the-line items (clearly not in the top tier) For close calls, name what additional information or assumption would resolve them. Constraints: - Do not present scores with false precision. If inputs are best-guess, the score is best-guess. - Distinguish point estimates from ranges. Force the answer to acknowledge uncertainty where it exists. - The framework calculation is a starting point for the conversation, not the conversation's conclusion. - Flag any candidate where inputs seem to be advocacy ("score this high because X is important") rather than analysis. Those need TPM judgment. - Do not pad the list with "everything matters." If items genuinely cluster at the bottom, say so. - Flag any assumption you are making when normalizing or interpreting candidate inputs.

Working with the output: Treat the framework score as the start of the conversation, not its conclusion. Use ranges for uncertain inputs (\$2M-\$8M, not "\$5M"). When items are within 0.5 on a 5-point scale they are tied - do not present the model's ranking as definitive. Verify all input figures against source data; the model cannot manufacture missing context.

AI Prompt — Running a Vendor SOW gap analysis

What it does: Diagnoses why a vendor engagement is failing by distinguishing vendor performance issues from structural causes (scope wrong, handoff bad, dependencies blocked), then generates a recommended negotiation approach matched to the actual cause. Covers inflection point, internal dependencies owed, deliverable quality, and a structured action plan.

When to use it: Use before negotiating with a failing vendor, because the right negotiation move depends on the cause - a SOW amendment doesn't fix performance issues, and pressure on the vendor when the cause is structural makes things worse. When not: Do not use as a substitute for the direct diagnostic conversation with the vendor's PM (not the AE) that Field Note #226 describes.

Inputs to provide:

- Vendor name, engagement description, original SOW date, engagement period, current point in engagement, and TPM name
- Original SOW content (deliverables, milestones, pricing, dependencies, success criteria), deliverables completed and outstanding, communication trail summary, and internal team context (what you owe the vendor and its status)

The prompt

You are running a diagnostic analysis on a failing vendor SOW. I will provide the SOW, current state, and evidence; you will structure the diagnostic and recommend a negotiation approach. Vendor: [VENDOR NAME] Engagement: [BRIEF DESCRIPTION] Original SOW signed: [DATE] Engagement period: [START to PLANNED END] Current point in engagement: [WEEK N or PERCENT COMPLETE] TPM: [TPM NAME]

Original SOW content: [PASTE OR ATTACH: the SOW -- deliverables, milestones, pricing, dependencies, success criteria] Current state evidence: Deliverables completed: [PASTE: what has been delivered, with dates] Deliverables outstanding: [PASTE: what was due and hasn't been delivered, with original target dates] Communication trail: [PASTE: vendor communication summary -- escalations, status updates, account executive interactions] Internal team context: [PASTE: anything the internal team owes the vendor -- credentials, decisions, environments, data access -- with status] Generate a structured diagnostic with these sections: 1. Diagnostic question 1: When did the slip start, and what changed at that point? - Identify the inflection point in the engagement timeline - Surface what changed (scope addition, vendor personnel change, internal dependency lapse, external event) - Categorize: scope-driven, handoff-driven, dependency-driven, or genuine vendor performance 2. Diagnostic question 2: Is the vendor blocked on anything we owe them? - Walk the dependency list (what the internal team committed to provide) - Identify items the internal team owes that haven't been provided - Quantify how long each item has been outstanding 3. Diagnostic question 3: Is the work being delivered actually wrong, or just late? - Distinguish quality failures (deliverables don't meet acceptance criteria) from pacing failures (deliverables meet criteria but are late) - This determines whether the conversation is about process or capability 4. Root cause assessment Categorize the failure: - Structural (scope, handoff, or dependency-driven) -> SOW amendment - Performance (genuine vendor capability or accountability issue) -> escalation - Mixed -> address each cause separately; do not bundle Generate the recommended approach with specific actions, named owners, and timeline. Constraints: - Do not default to "vendor is failing." Most vendor SOW failures are structural; the diagnostic discipline is what surfaces this. - Do not invent dependencies the internal team owes. If unclear, write "[NEEDS CONFIRMATION FROM INTERNAL TEAM]". - The negotiation approach should match the cause. A SOW amendment doesn't fix performance issues; an account executive escalation doesn't fix structural issues. - Flag at the end any escalation that warrants sponsor involvement (typically only Mixed and severe Performance cases). - Flag any assumption you are making about cause categorization where evidence is ambiguous.

Working with the output: Verify the dependency check carefully - TPMs often underestimate what they owe vendors. The model cannot confirm what the internal team has or hasn't delivered; that requires direct verification. Most SOW failures are structural; do not present the output to the vendor before confirming the root cause with your own investigation.

AI Prompt — Surfacing patterns across the risk register

What it does: Analyzes a full RAID Log for clusters, recurring themes, and escalating dynamics - grouping entries by structural cause, surfacing recurrent themes that cross categories, identifying entries whose trajectory suggests escalation, and naming structural concerns that may not yet have their own log entries. Distinguishes program-addressable patterns from org-level ones.

When to use it: Use when the register has accumulated enough entries (roughly 20+) that pattern recognition requires synthesis across many items rather than per-item review. When not: Do not use on a sparse register where 2-3 entries don't constitute a real pattern - premature synthesis manufactures signal.

Inputs to provide:

- Program name, register snapshot date, and total entry count
- Full RAID register with all entries and their fields (pasted or attached)

The prompt

You are surfacing patterns across a program's RAID Log. I will provide the current register; you will identify clusters, themes, and structural concerns. Program name: [PROGRAM NAME] Register snapshot date: [DATE] Register size: [N entries -- Risks, Assumptions, Issues, Dependencies] Current register: [PASTE OR ATTACH: full RAID register -- all entries with their fields] Generate a pattern analysis with these sections: 1. Cluster analysis Group entries that share a structural cause: - By function (vendor, team capacity, sponsor decision, technical, regulatory, etc.) - By component (which component sub-projects accumulate the most entries) - By severity (where High/Medium concentrate) - By age (which entries have been open the longest, with what status) For each cluster of 3+ related entries, name the cluster and list the entries. 2. Recurrent themes Identify themes that show up across multiple entries even when they're filed under different categories: - "Vendor X appears in 6 entries across Risks, Issues, and Dependencies -- vendor relationship may need structural attention" - "Sponsor decision velocity appears in 4 entries -- pacing constraint worth surfacing" 3. Escalating dynamics Surface entries where the pattern over time suggests escalation: - Risks that started Low/Low and have moved to Medium/Medium then High/High - Issues that have been re-scoped or had target resolution dates pushed multiple times - Dependencies that

have remained Open past their original required-by dates 4. Structural concerns not yet logged as their own entries Based on the patterns, identify structural concerns that might be the underlying cause of multiple existing entries but haven't been named as a standalone risk or issue yet. For each, suggest a draft entry. 5. Prioritized action list Based on the above: - Which clusters need immediate TPM attention - Which entries are actually the same underlying issue and should be consolidated - Which entries should be escalated based on the escalating dynamics Constraints: - Patterns require evidence. If the pattern is suggested by 2 entries, name it as "potential pattern" not "confirmed pattern." - Do not generate pattern claims that aren't supported by the entries. Speculation is worse than no observation. - Distinguish patterns about the program (which the program team can address) from patterns about the org (which the sponsor needs to address). - For escalating dynamics, show the trajectory specifically -- "Risk R-016 escalated from Low/Medium to High/Medium between Q1 and Q2" not "this risk has gotten worse." - Flag patterns that may be coincidence rather than structural -- "These three entries all involve compliance" may be a coincidence, not a pattern. - Flag any assumption you are making when naming a structural concern that isn't explicitly stated in the register.

Working with the output: Pattern recognition surfaces what to investigate, not what to conclude. Verify each suggested pattern against your direct knowledge of the program - some clusters are real and actionable (single-vendor concentration), others are coincidental. The model cannot know context that isn't in the register entries.

AI Prompt — Drafting a Recovery Plan (private TPM use)

What it does: Generates a structural first draft of a Recovery Plan - covering current state, what changed, recovery levers, the new commitment, what the plan doesn't solve, specific asks, and risks of the plan - along with three meta-reactions: whether the proposal fits the diagnosis, where the sponsor will push back, and whether the situation needs rebaselining rather than recovery.

When to use it: Use as a private thinking tool when the program has gone sideways and you need to pressure-test your diagnosis, recovery levers, and asks before you write the actual document. When not: Do not present the AI's draft to the sponsor unedited - recovery plans signal your reading of the situation; that signal has to be your judgment.

Inputs to provide:

- Program name, sponsor, and TPM name
- Diagnosis: what changed (one sentence), when you knew, what's hard to say (structural discomforts), recovery levers you are considering with brief rationale, and specific asks you think you need from the sponsor

The prompt

You are helping me draft a structural first version of a Recovery Plan. I'll review the output to sharpen my thinking, then write the actual document myself with my judgment driving the framing. Treat this as a thinking exercise, not as production output. Program name: [PROGRAM NAME] Sponsor: [SPONSOR NAME AND ROLE] TPM: [TPM NAME -- me] Diagnosis: What changed: [PASTE: in one sentence, what changed that produced the slip] When I knew: [PASTE: when this became visible, including any earlier signals I should have surfaced] What's hard to say: [PASTE: anything structurally uncomfortable -- a vendor I single-sourced, a decision that turned out wrong, a relationship that's been deteriorating] Recovery levers I'm considering: [PASTE: which of Descope / Extend / Increase Budget / Add Resource / Accept apply, with brief rationale] Specific asks I think I need: [PASTE: specific decisions, with thresholds, that I think the sponsor needs to make] Generate a Recovery Plan structure with these sections: 1. Where we are (one paragraph -- honest current state) 2. What changed since the plan was approved (3-5 factual bullets) 3. What we're proposing (which levers, specifically what's being adjusted) 4. What this gets us (the new commitment -- date, scope, budget specifics) 5. What we're not solving (honest acknowledgment of what this plan doesn't address) 6. What we need from you (specific decisions with names and dates) 7. Risks of this plan (2-3 risks with mitigations) Constraints: - The framing should be neutral about cause. Use "discovery revealed" not "we got it wrong." - Lead with what the team controls. If a vendor caused the problem, lead with what the team will do. - Name the structural cause once if it exists, then move on. Don't build a case across the document. - Be specific about asks. "We need help" is not an ask. - The total document should fit on one page. If it doesn't, the proposal isn't yet clear enough. - Flag any assumption you are making about framing or recovery lever selection, and flag where my diagnosis seems internally inconsistent. After generating the structure, give me three additional reactions: - Does the proposal make sense given the diagnosis I provided? - Where might the sponsor push back, and on what specifically? - Is

there anything in the diagnosis that suggests the situation needs re-baselining (per Field Note #215) rather than recovery?

Working with the output: Do not present the AI's draft to the sponsor unedited - use the structure to sharpen your diagnosis, recovery levers, and asks, then write the actual document yourself. The model cannot verify numbers or assess the sponsor relationship; both are your responsibility. Field Note #213 covers the conversation discipline.

AI Prompt — Running a reprioritization cost analysis

What it does: Models the full disruption cost of a mid-program reprioritization - context-switch tax on the team, sunk cost on in-flight work, communication cost across stakeholders, and trust cost - then weighs it against the benefit of the trigger, identifies bundling opportunities with other pending triggers, and recommends whether to reprioritize now, hold, or bundle into a rebaseline event.

When to use it: Use before recommending reprioritization to a sponsor or steering committee, because the disruption cost is almost always larger than it looks without explicit modeling. When not: Do not use when the trigger is a genuine emergency that has already made the decision - model the cost afterward to inform the communication, not to relitigate the call.

Inputs to provide:

- Program name, reprioritization trigger and its category (external hard constraint / material new info / pressure without clear cause)
- Every piece of in-flight work not at a clean stopping point (description, owner, percent complete); downstream dependencies that assumed the current sequencing; what the reprioritization would do and what you get in return; any other pending triggers that haven't yet driven action

The prompt

You are running a cost analysis for a potential reprioritization. I will provide the trigger and program context; you will structure the cost-benefit analysis. Program name: [PROGRAM NAME] Reprioritization trigger: [WHAT'S CAUSING CONSIDERATION OF REPRIORITIZATION] Trigger category: [External hard constraint / Material new info on scope / Material new info on effort / Pressure without clear cause] Currently in flight: [PASTE: every piece of work that's not at a clean stopping point -- for each, brief description, owner, percent complete] Dependencies that depend on current sequencing: [PASTE: every downstream commitment that assumed the current priorities -- stakeholder commitments, vendor SOWs, etc.] What the reprioritization would do: [PASTE: which work moves forward, which work defers, what the new sequence looks like] What we get in return: [PASTE: the benefit -- alignment with new constraint, risk reduction, etc., quantified where possible] Other reprioritization triggers in the air: [PASTE: any other potential triggers that haven't yet driven action -- these are bundling candidates] Generate a cost-benefit analysis with these sections: 1. Disruption cost on the team For each in-flight item: - Cost to pause (sunk cost on partial work, in person-weeks) - Context-switch cost to resume (typically 20-40% of original effort) - Total cost in person-weeks Sum the costs. 2. Communication cost - Stakeholders who need re-explanation - Estimated TPM time for the communication (typically 0.5-1 person-week per major reprioritization on a program with 30+ stakeholders) 3. Trust cost Qualitative assessment: - Has this team been reprioritized before, and recently? - What is the pattern of changes signaling to the team and stakeholders? - What is the cost to the TPM's credibility as a stable planner? 4. Total cost summary Quantitative (person-weeks) + qualitative (trust and communication) in a single summary. 5. Benefit assessment State the benefit of the trigger clearly: - Is it quantified or estimated? - Is the trigger category genuine (external constraint, material new info) or pressure-driven? - Does the benefit clearly outweigh the total cost? 6. Bundling analysis - Which other pending triggers should bundle with this one - What rebaseline event makes sense (next steering, formal rebaseline) - What the unified communication should cover Constraints: - Don't default to either "reprioritize" or "hold." Calibrate based on actual cost-benefit. - Disruption cost estimates can be ranges; don't fake precision. - Trust cost is qualitative; surface considerations rather than quantifying. - The bundling recommendation often produces better outcomes than reprioritizing item-by-item -- surface bundling opportunities deliberately. - Flag any cost or benefit that the TPM seems to be underweighting in the inputs. - Flag any assumption you are making about context-switch rates or stakeholder count where inputs are not provided.

Working with the output: The cost analysis is the input to the decision, not the recommendation itself - the decision is whether the gain justifies the cost. Use the bundling pattern: if multiple reprioritization triggers are accumulating, hold for one consolidated rebaseline rather than three trickled changes. Verify all person-week estimates against your knowledge of the team; the model uses typical-case rates that may not match your situation.

AI Prompt — Thinking through a saying-no conversation (private TPM use only)

What it does: Helps you think through framing options for pushing back on a sponsor or senior stakeholder - running a diagnostic on whether push-back is actually warranted, surfacing steel-man arguments for the stakeholder's position, listing available framing strategies, and walking through delivery, opening, and trade-off considerations. Explicitly private: output is for your thinking only, never for the conversation itself.

When to use it: Use privately before a high-stakes push-back conversation with a sponsor or senior stakeholder to pressure-test your diagnosis and prepare your framing options. When not: Do not use as a substitute for the actual judgment call on whether to push back - that is yours alone - and do not present any AI output to the stakeholder.

Inputs to provide:

- The specific ask, who is making it, and context
- Your initial reaction, your best diagnosis of what's actually wrong with the ask, the relationship context with this stakeholder, and the cost of saying yes vs. the cost of saying no

The prompt

I am thinking through a difficult conversation where I may need to push back on a sponsor or senior stakeholder. I want help thinking through it. Treat this as private exercise -- your output is for my thinking, not for the conversation itself. The ask: [PASTE: what's been asked of me -- the specific request, who's making it, the context] My initial reaction: [PASTE: my honest first read of why I want to push back] What I think is actually wrong with the ask: [PASTE: my best diagnosis -- is it scope, is it timing, is it relationship dynamics, is it that I'm wrong] The relationship context: [PASTE: my history with this stakeholder, recent dynamics, anything relevant about how push-back will land] The cost of saying yes: [PASTE: what happens to the program, the team, or me if I accept the ask] The cost of saying no: [PASTE: what happens to the relationship, my standing, the stakeholder's position if I push back] Help me think through this with these prompts: 1. Diagnostic -- am I sure this needs push-back? - Is the ask actually unreasonable, or is my reaction the issue? - Have I steel-manned the stakeholder's position? - Is there a version of the ask that I could accept? - Could this be a normal disagreement that I should let the stakeholder win? 2. Framing options -- if push-back is warranted, what frames are available? - Costs and trade-offs (showing the real cost of yes -- Field Note #229's "yes, here's the cost" pattern) - Surfacing the real concern (sometimes the ask is a symptom, not the cause) - Offering a different version (counterproposal that addresses the underlying need) - Direct disagreement with rationale (when the ask is genuinely wrong and the relationship can absorb it) 3. Delivery considerations - Setting (1:1 vs. in front of others?) - Opening sentence -- what should the first 30 seconds establish? - What I'm prepared to compromise on, and what I'm not - What happens if the stakeholder doesn't accept the push-back Constraints: - Do not draft the actual words I'll say. Help me think; the words are mine. - Be honest about ways my own framing might be wrong. If my diagnostic is shaky, surface that. - Surface considerations I might be missing -- relationship history, organizational dynamics, what the stakeholder might be optimizing for that I haven't considered. - This is private. The output never reaches the stakeholder. - Flag any assumption you are making about stakeholder motivations or relationship dynamics that I should verify.

Working with the output: Do not use the AI's framing verbatim with the sponsor - use the framing options to think through trade-offs, then choose the framing that fits the relationship and stakes, then write what you will say yourself. The model cannot know the relationship dynamics you have not described; verify every assumption it surfaces against your actual read of the situation. Field Note #229 covers the discipline.

AI Prompt — Drafting and scoring a Risk Register with response strategies

What it does: Generates a fully scored Risk Register with inherent and residual risk ratings, response strategies, trigger conditions, and named owners aligned to the Risk Register & Response Plan artifact.

When to use it: Use at project initiation or whenever a formal risk identification workshop has just concluded and you need to turn raw notes into a structured register. When not: Do not use as a substitute for a live facilitated risk workshop; the model cannot surface risks that have not been described to it.

Inputs to provide:

- Project or program name, phase, and a brief description of scope and objectives
- Raw list of identified risks (free-text notes, workshop outputs, or prior risk logs)
- Probability and impact scales in use (e.g., 1-5 x 1-5, or Low/Medium/High)

The prompt

You are a senior risk management specialist helping to build a formal Risk Register & Response Plan for [PROJECT/PROGRAM NAME] in the [PHASE] phase. Project context: [2-3 SENTENCE DESCRIPTION OF SCOPE AND OBJECTIVES] Probability scale: [E.G., 1=Rare, 2=Unlikely, 3=Possible, 4=Likely, 5=Almost Certain] Impact scale: [E.G., 1=Negligible, 2=Minor, 3=Moderate, 4=Major, 5=Critical] Raw risk inputs: [PASTE RAW RISK NOTES, WORKSHOP OUTPUTS, OR PRIOR RISK LIST] Instructions: 1. Parse each distinct risk from the raw inputs. Do not invent risks not implied by the inputs. 2. For each risk produce a single row with these columns: - Risk ID (RISK-001, RISK-002, ...) - Risk Category (e.g., Technical, Schedule, Resource, Vendor, Regulatory, Security) - Risk Statement ("If [cause], then [event], resulting in [impact]") - Inherent Probability (P) score and label - Inherent Impact (I) score and label - Inherent Risk Score (P x I) and RAG rating (Green <=4, Amber 5-12, Red >=15 unless you are told otherwise - flag if scale differs) - Response Strategy (Avoid / Transfer / Mitigate / Accept) - Specific Response Actions (2-4 bullet actions) - Residual P, Residual I, Residual Score after actions - Trigger / Early Warning Indicator - Risk Owner (use [OWNER NAME/ROLE] placeholder if not known) - Target Resolution Date ([DATE]) - Status (Open / In Progress / Closed) 3. After the table, write a short Risk Summary section (max 150 words) highlighting the top three risks by inherent score and any concentration of risk in one category. 4. Flag all assumptions you have made. Flag any inputs that were ambiguous or where you had insufficient information to score confidently - mark those rows with a note "[REVIEW REQUIRED]". 5. Do not invent probability or impact scores without a stated basis; if the raw input provides no severity signal, state the score is assumed and needs stakeholder confirmation. Output format: Markdown table followed by the Risk Summary section and an Assumptions & Gaps list.

Working with the output: Review every "[REVIEW REQUIRED]" flag with a risk owner before baseline; the model cannot know organizational risk appetite, political risk, or undisclosed dependencies, so treat all scores as first-draft estimates requiring expert validation.

AI Prompt — Drafting a Quality Management Plan with Definition of Done and acceptance criteria

What it does: Produces a structured Quality Management Plan (QMP) including quality objectives, quality standards, control activities, a Definition of Done (DoD), and artifact-level acceptance criteria aligned to the Quality Management Plan artifact.

When to use it: Use at the start of planning when the team needs to agree on what "good" looks like before delivery begins. When not: Do not use this prompt to replace a formal peer-review or audit process; the output is a draft plan, not a certified quality assessment.

Inputs to provide:

- Project name, delivery methodology (waterfall, agile, hybrid), and a brief description of what is being delivered
- Applicable standards, regulations, or frameworks (e.g., ISO 27001, NIST, SOC 2, internal SDLC policy)
- Known quality pain points or lessons learned from previous similar projects

The prompt

You are a quality assurance lead drafting a Quality Management Plan for [PROJECT/PROGRAM NAME]. Delivery methodology: [WATERFALL / AGILE / HYBRID] Deliverable type: [E.G., enterprise software platform, data migration, infrastructure rollout] Applicable standards/frameworks: [LIST STANDARDS - e.g., ISO 27001, NIST SP 800-53, internal SDLC policy] Known quality risks or past lessons: [PASTE LESSONS LEARNED OR LEAVE AS "NONE PROVIDED"] Draft a Quality Management Plan covering all of the sections below. Do not invent compliance requirements not listed above; flag any section where you have assumed a standard applies. Section 1 - Quality Objectives: 3-5 measurable quality goals (use SMART format). Section 2 - Quality Standards and References: table mapping each standard/framework to the project activities it governs. Section 3 - Quality Roles and Responsibilities: table with role, responsibilities, and accountabilities (RACI style). Section 4 - Quality Control Activities: for each major deliverable or phase gate, list: - Activity name - Type (inspection / testing / review / audit) - Frequency - Entry criteria - Exit criteria - Owner - Tool or template used Section 5 - Definition of Done (DoD): a checklist (minimum 10 items) that must be true before any work item or deliverable can be called complete. Tailor to [WATERFALL / AGILE / HYBRID]. Section 6 - Acceptance Criteria Template: a reusable template with fields: Deliverable Name, Functional Criteria, Non-Functional Criteria (performance, security, accessibility), Review Authority, Sign-off Required, and Defect Threshold. Section 7 - Non-Conformance Process: steps for logging, triaging, resolving, and escalating quality failures, including severity levels. Section 8 - Quality Metrics and Reporting: at least 4 metrics (e.g., defect density, test pass rate, review cycle time, customer satisfaction score) with targets and reporting frequency. End with an Assumptions & Gaps list. Flag every place where project-specific detail was not provided and a placeholder was used.

Working with the output: Validate Section 5 (DoD) and Section 6 (acceptance criteria) with the delivery team and product owner before sprint 1 or phase gate 1; the model cannot know undocumented organizational standards or client-specific sign-off requirements.

AI Prompt — Building a Requirements Traceability Matrix and finding coverage gaps

What it does: Constructs a Requirements Traceability Matrix (RTM) that maps each requirement forward through design, build, and test artifacts to results, and flags orphaned requirements, untested items, and coverage gaps aligned to the RTM artifact.

When to use it: Use at the end of each phase or at release time to verify that every stated requirement has been designed, built, and tested. When not: Do not use when requirements, design, or test artifacts have not yet been documented; the model needs real input data to trace, not assumptions.

Inputs to provide:

- List of requirements (ID, description, source/stakeholder)
- List of design components or user stories (IDs and brief descriptions)
- List of test cases or test scripts (IDs and brief descriptions) with pass/fail status if available

The prompt

You are a business analyst and QA lead building a Requirements Traceability Matrix (RTM) for [PROJECT/PROGRAM NAME]. Requirements list: [PASTE REQUIREMENTS - include Req ID, description, and source/priority] Design / user story list: [PASTE DESIGN COMPONENTS OR USER STORY IDs WITH BRIEF DESCRIPTIONS] Test case / test script list: [PASTE TEST CASE IDs, DESCRIPTIONS, AND PASS/FAIL STATUS IF KNOWN] Result / defect data (optional): [PASTE DEFECT IDs OR TEST EXECUTION RESULTS, OR WRITE "NONE PROVIDED"] Instructions: 1. Build the RTM as a table with these columns: - Requirement ID - Requirement Description - Priority (as given; mark [UNKNOWN] if not provided) - Source / Stakeholder - Linked Design Component(s) / Story ID(s) - Linked Test Case ID(s) - Test Execution Status (Pass / Fail / Not Executed / Blocked) - Linked Defect ID(s) (if any) - Traceability Status (Fully Traced / Partially Traced / Not Traced) 2. After the table, produce a Coverage Gap Analysis with four sub-sections: a. Orphaned Requirements - requirements with no linked design artifact b. Untested Requirements - requirements with no linked test case c. Untraceable Test Cases - test cases that do not link to any requirement (potential scope creep) d. Failed or Blocked Requirements - requirements where linked tests are failing or blocked 3. Produce a Coverage Summary table: - Total requirements - % Fully Traced - % Partially Traced - % Not Traced - % with passing tests 4. Provide a Recommended Actions list (prioritized) for closing each gap type. 5. Flag all assumptions. If a mapping was inferred rather than explicitly stated in the input, mark it "[INFERRED - VERIFY]". Output format: Markdown RTM table, then Coverage Gap Analysis sections, then Coverage Summary table, then Recommended Actions, then Assumptions & Gaps.

Working with the output: All "[INFERRED - VERIFY]" links must be confirmed with the BA or dev lead before the RTM is used as a release gate; the model cannot read source code or test management tools and can only trace what was explicitly described in the inputs.

AI Prompt — Decomposing scope into a WBS with three-point estimates

What it does: Decomposes a project scope statement into a hierarchical Work Breakdown Structure (WBS) that satisfies the 100% rule, then applies PERT three-point estimation (Optimistic/Most Likely/Pessimistic) and produces a Basis of Estimate aligned to the WBS & Estimation Approach artifact.

When to use it: Use during planning when the project scope is defined and the team needs an initial schedule and effort baseline. When not: Do not use for projects where scope is intentionally emergent (e.g., pure discovery sprints); use the Agile backlog prompt instead.

Inputs to provide:

- Project scope statement or Statement of Work (SOW)
- List of known deliverables, milestones, or exclusions
- Team composition and any known constraints (resources, calendar, tools)

The prompt

You are a senior project manager decomposing scope into a Work Breakdown Structure (WBS) with three-point estimates for [PROJECT/PROGRAM NAME]. Scope statement / SOW: [PASTE SCOPE STATEMENT OR SOW EXCERPT] Known deliverables: [LIST DELIVERABLES] Known exclusions: [LIST EXCLUSIONS OR WRITE "NONE STATED"] Team composition: [E.G., 2 developers, 1 BA, 1 QA, 1 PM - or "NOT PROVIDED"] Constraints: [CALENDAR, TOOL, BUDGET, OR OTHER CONSTRAINTS - or "NONE STATED"] Instructions: 1. WBS Structure: decompose the scope to at least three levels (Level 1 = project, Level 2 = major phases or deliverables, Level 3 = work packages). Use numeric WBS codes (1.0, 1.1, 1.1.1, etc.). 2. 100% Rule Check: after decomposing, confirm that every child node rolls up to its parent and that the union of all Level 3 work packages covers 100% of the project scope with no gaps and no overlaps. Note any areas where you are uncertain. 3. Three-Point Estimates table for each Level 3 work package: - WBS Code - Work Package Name - Optimistic (O) hours - Most Likely (M) hours - Pessimistic (P) hours - PERT Expected = $(O + 4M + P) / 6$ - PERT Standard Deviation = $(P - O) / 6$ - Assigned Role(s) 4. WBS Dictionary (brief): for each Level 2 element, one sentence describing what is included and what is explicitly excluded. 5. Basis of Estimate (BoE) narrative (max 300 words): explain the estimation approach, analogous or parametric data used (state clearly if none was provided and estimates are judgment-based), confidence level (High / Medium / Low), and key assumptions. 6. Roll-up Summary: total PERT expected hours by Level 2 element and overall project total. 7. Flags: list any scope areas where you lacked enough detail to decompose confidently, and mark those work packages "[DETAIL REQUIRED]". Do not invent scope items not grounded in the inputs. Mark all inferred items "[ASSUMED]". Output format: WBS outline, then estimates table, then WBS Dictionary, then BoE narrative, then Roll-up Summary, then Flags.

Working with the output: All "[DETAIL REQUIRED]" and "[ASSUMED]" items must be reviewed with the project sponsor and technical lead before the WBS is baselined; PERT estimates are directional only and should be replaced with expert estimates from the delivery team before commitment.

AI Prompt — Computing Earned Value metrics and drafting the variance and EAC narrative

What it does: Calculates the full set of Earned Value Management (EVM) metrics (CV, SV, CPI, SPI, EAC, ETC, VAC) from raw inputs and produces a plain-English variance narrative plus corrective options, aligned to the Cost Management & EVM Tracker artifact.

When to use it: Use at any reporting cycle (weekly, monthly, or at a phase gate) when actual cost and schedule data are available. When not: Do not use when PV, EV, or AC figures are unavailable or estimated; garbage-in garbage-out applies directly to EVM.

Inputs to provide:

- Budget at Completion (BAC) and current data date
- Planned Value (PV), Earned Value (EV), and Actual Cost (AC) as of the data date

- Estimate at Completion (EAC) if the team has an independent bottom-up EAC to compare

The prompt

You are a cost control analyst preparing an Earned Value Management report for [PROJECT/PROGRAM NAME] for the period ending [DATA DATE]. Provided figures (all in [CURRENCY, e.g., USD thousands]): - Budget at Completion (BAC): [VALUE] - Planned Value (PV) to date: [VALUE] - Earned Value (EV) to date: [VALUE] - Actual Cost (AC) to date: [VALUE] - Independent bottom-up EAC (if available): [VALUE or "NOT PROVIDED"] - % Complete per schedule (schedule % complete): [VALUE or "NOT PROVIDED"]

Instructions: 1. Compute and display all of the following metrics in a clean table. Show the formula and the calculated result for each: - Cost Variance ($CV = EV - AC$) - Schedule Variance ($SV = EV - PV$) - Cost Performance Index ($CPI = EV / AC$) - Schedule Performance Index ($SPI = EV / PV$) - Estimate at Completion - CPI method ($EAC_{cpi} = BAC / CPI$) - Estimate at Completion - CPI x SPI method ($EAC_{cpispi} = AC + ((BAC - EV) / (CPI \times SPI))$) - Estimate to Complete ($ETC = EAC_{cpi} - AC$) - Variance at Completion ($VAC = BAC - EAC_{cpi}$) - To-Complete Performance Index against BAC ($TCPI_{bac} = (BAC - EV) / (BAC - AC)$) - To-Complete Performance Index against EAC ($TCPI_{eac} = (BAC - EV) / (EAC_{cpi} - AC)$)

2. If an independent bottom-up EAC was provided, show it alongside the formula-based EACs and note the variance between them. 3. RAG Status: assign a Red / Amber / Green rating to cost performance and schedule performance using standard thresholds (CPI or $SPI < 0.85$ = Red, $0.85-0.95$ = Amber, ≥ 0.95 = Green) - note if the project uses different thresholds and adjust accordingly. 4. Plain-English Narrative (max 250 words): explain what the numbers mean in non-technical language suitable for an executive audience. Cover: current cost health, schedule health, projected final cost, and what is driving the variances. 5. Corrective Options: list 3-5 realistic corrective actions with an assessment of likely impact on CPI and SPI for each. 6. Assumptions & Caveats: flag any metric that could not be computed due to missing input, and note that EVM results are only as reliable as the underlying PV, EV, and AC data. Do not fabricate input values. If any input is missing, state which metric cannot be computed and why. Output format: Metrics table, then RAG status, then Narrative, then Corrective Options, then Assumptions & Caveats.

Working with the output: Validate PV, EV, and AC inputs against the source schedule and financial system before distributing the report; even small errors in EV percentage-complete calculations materially distort all downstream metrics.

AI Prompt — Drafting a Business Case with cost-benefit and options analysis

What it does: Produces a structured Business Case including problem statement, options analysis (including a do-nothing baseline), NPV/IRR/payback calculations, sensitivity analysis, and a recommended option, aligned to the Business Case & Cost-Benefit Analysis artifact.

When to use it: Use in pre-initiation or gate reviews when leadership needs a formal justification document to authorize investment. When not: Do not use when financial inputs (costs, benefits, discount rate) are entirely unknown; the model will flag gaps but cannot manufacture credible figures.

Inputs to provide:

- Problem or opportunity statement and strategic alignment rationale
- Estimated costs and benefits for each option (include timing/year if known)
- Discount rate, analysis horizon (years), and any sensitivity variables to test

The prompt

You are a senior management consultant drafting a Business Case & Cost-Benefit Analysis for [PROJECT/PROGRAM NAME] to be presented to [APPROVING BODY / SPONSOR]. Problem / opportunity statement: [DESCRIBE THE BUSINESS PROBLEM OR OPPORTUNITY IN 2-4 SENTENCES] Strategic alignment: [STATE WHICH ORGANIZATIONAL STRATEGIES OR OBJECTIVES THIS ADDRESSES] Options to evaluate (include Option 0 = do nothing as a baseline): [LIST OPTIONS - e.g., Option 0: Do nothing; Option 1: Buy COTS solution; Option 2: Build in-house; Option 3: Outsource] Cost and benefit inputs per option: [PASTE A TABLE OR BULLET LIST WITH YEAR-BY-YEAR COSTS AND BENEFITS PER OPTION - OR STATE "ESTIMATES REQUIRED" FOR ANY UNKNOWN ITEMS] Financial parameters: - Discount rate: [E.G., 8%] - Analysis horizon: [E.G., 5 years] - Currency: [E.G., USD thousands] Sensitivity variables to test: [E.G., benefits 20% lower; costs 20% higher; delayed benefits by 1 year - or "USE STANDARD +/-20% ON BENEFITS AND COSTS"] Instructions: 1. Executive Summary (max 200 words): problem, recommended option, headline financials, and decision requested. 2. Problem Statement and Strategic Context: expand the inputs into a professional 2-3 paragraph narrative. 3. Options Analysis table: for each option: - Option name and description - Key assumptions - Total cost over horizon - Total benefit over horizon - Net

Benefit - NPV (show discount factors and year-by-year NPV calc) - IRR (state if cannot be computed from the inputs and why) - Payback period (in months or years) - Qualitative pros and cons (bullets) - Risk level (High / Medium / Low) with rationale 4. Recommended Option: state the recommendation with a justification referencing the financial and qualitative analysis. 5. Sensitivity Analysis: show a simple table varying the specified sensitivity variables and their impact on NPV for the recommended option. 6. Implementation Considerations: 4-6 bullets on key dependencies, risks, or conditions for the recommendation to hold. 7. Assumptions & Gaps: flag every input that was not provided and mark corresponding figures "[ASSUMED - REQUIRES VALIDATION]". Do not present assumed figures as facts. Do not invent financial data not grounded in the inputs. If inputs are insufficient to compute NPV or IRR, state this explicitly. Output format: Executive Summary, then each numbered section, then Assumptions & Gaps.

Working with the output: All "[ASSUMED - REQUIRES VALIDATION]" figures must be signed off by the finance lead or sponsor before the Business Case is submitted to the approving body; NPV and IRR are highly sensitive to discount rate and benefit timing assumptions that only domain experts can confirm.

AI Prompt — Splitting epics into user stories with acceptance criteria and sprint goals

What it does: Decomposes one or more epics into well-formed, INVEST-compliant user stories with Given/When/Then acceptance criteria, story point hints, WSJF inputs, and proposed sprint goals, aligned to the Agile & Hybrid Delivery Plan artifact.

When to use it: Use during backlog refinement or PI planning when the team needs to break high-level epics into sprint-ready stories. When not: Do not use as a substitute for a real refinement session with the development team; the model cannot estimate complexity without team input.

Inputs to provide:

- Epic title(s) and a description of the business objective each epic serves
- Persona or user role(s) who will interact with the feature
- Any known constraints, non-functional requirements, or dependencies

The prompt

You are an agile coach and product owner proxy decomposing epics into sprint-ready user stories for [PROJECT/PROGRAM NAME] on the [PRODUCT / PLATFORM NAME] product. Sprint length: [E.G., 2 weeks] Team velocity (story points per sprint): [VALUE or "UNKNOWN"] Story point scale: [E.G., Fibonacci 1-2-3-5-8-13] Epic(s) to decompose: [FOR EACH EPIC PROVIDE: Epic ID, Epic Title, Business Objective, Persona(s), Known Constraints or NFRs, Dependencies] Instructions: 1. For each epic, decompose into user stories following the INVEST criteria (Independent, Negotiable, Valuable, Estimable, Small, Testable). Aim for stories completable within one sprint. 2. For each user story produce: a. Story ID (linked to epic, e.g., EPIC-01-S01) b. Story Title c. User Story statement: "As a [persona], I want [capability] so that [benefit]" d. Acceptance Criteria: minimum 3 Given/When/Then scenarios covering happy path, edge case, and error/failure path e. Story Point estimate hint (acknowledge this is a model suggestion, not a team estimate) f. WSJF inputs (if estimable from the inputs): Business Value (1-10), Time Criticality (1-10), Risk Reduction / Opportunity Enablement (1-10), Job Size (1-10), and WSJF score = (BV + TC + RR) / Job Size g. Dependencies (on other stories, teams, or systems) h. Definition of Ready checklist (5 items minimum that must be true before the story enters a sprint) 3. After all stories, propose Sprint Goals: group the stories into logical sprint-sized batches and write a one-sentence sprint goal for each batch. Base batching on value delivery sequencing and dependencies, not arbitrary ordering. 4. Identify any stories that are still too large (suggest splitting further) or any acceptance criteria that are ambiguous and need product owner clarification. 5. Flag all assumptions. Mark any story where business rules, data flows, or technical approach were not specified as "[REFINEMENT REQUIRED]". Do not invent business rules or technical designs not grounded in the inputs. Use [PLACEHOLDER] for any field where the input was insufficient. Output format: For each epic - Epic summary, then story cards in the format above, then Sprint Goal proposals, then Flags & Assumptions.

Working with the output: Story point estimates from this prompt are illustrative only and must be replaced with real team estimates during a planning session; acceptance criteria marked "[REFINEMENT REQUIRED]" must be resolved with the product owner before the story is accepted into a sprint.

AI Prompt — Generating a Go-Live Readiness checklist and cutover runbook with rollback

What it does: Produces a domain-by-domain Go-Live Readiness checklist, a sequenced cutover runbook with time-boxed steps and owners, explicit go/no-go criteria, and documented rollback triggers and procedures, aligned to the Go-Live Readiness & Cutover Plan artifact.

When to use it: Use 2-4 weeks before a planned go-live date when the delivery team needs to structure the final readiness assessment and cutover execution plan. When not: Do not use this prompt as the live execution record during cutover; it produces a plan template, not a real-time tracking tool.

Inputs to provide:

- System or release name, go-live date/window, and deployment environment details
- List of activities completed to date and any known open items or risks
- Rollback capability (yes/no) and high-level rollback approach if known

The prompt

You are a release manager and cutover lead preparing the Go-Live Readiness & Cutover Plan for [SYSTEM/RELEASE NAME] targeting go-live on [TARGET DATE] during [CUTOVER WINDOW, e.g., Friday 22:00 - Saturday 06:00]. Environment: [E.G., AWS production, on-premise data center, SaaS tenant] Deployment approach: [E.G., big-bang cutover, phased rollout by region, blue-green deployment] Rollback capability: [YES / NO / PARTIAL] Rollback approach: [DESCRIBE OR WRITE "TO BE DEFINED"] Activities completed to date: [LIST COMPLETED MILESTONES, UAT STATUS, TRAINING STATUS, DATA MIGRATION STATUS, ETC.] Known open items or risks at time of this draft: [LIST OPEN ITEMS WITH OWNER AND TARGET CLOSE DATE - or "NONE STATED"] Instructions: 1. Go-Live Readiness Checklist: organise into these domains. For each item include Status (Complete / In Progress / Not Started / N/A), Owner, and Evidence Required: - Technical Readiness (infrastructure, deployment scripts, data migration, integrations, performance test results) - Functional Readiness (UAT sign-off, regression, known defect disposition) - Security and Compliance Readiness (pen test, vulnerability scan, access provisioning, audit log) - Operational Readiness (runbooks, monitoring, alerting, support procedures, SLAs) - Business and Change Readiness (training completion, communications, process cutover, stakeholder sign-off) - Rollback Readiness (rollback plan tested, backups confirmed, decision authority named) 2. Go / No-Go Criteria: list the minimum conditions that must all be true for go-live to proceed. Flag any criterion that is currently not met based on the inputs. 3. Cutover Runbook: a sequenced table with columns: - Step number - Start time (relative, e.g., T-2h, T-0, T+1h) - Step description - Owner / Role - Duration (estimated) - Dependencies (prior step numbers) - Verification check (how to confirm the step succeeded) - Escalation path if step fails 4. Rollback Decision Gate: define the rollback trigger conditions (e.g., critical defect found, data integrity failure, cutover exceeds time box) and the decision authority. Include a Rollback Runbook in the same table format as step 3. 5. Post-Go-Live Hypercare Summary: list first 48-hour monitoring priorities and who owns them. 6. Assumptions & Gaps: flag every domain where readiness status was not confirmed in the inputs and mark as "[STATUS UNKNOWN - VERIFY BEFORE GO-LIVE]". Do not mark any item as Complete unless the inputs explicitly confirm it. Do not invent technical steps not grounded in the provided deployment approach. Output format: Readiness Checklist by domain, then Go/No-Go Criteria, then Cutover Runbook table, then Rollback Decision Gate and Rollback Runbook, then Hypercare Summary, then Assumptions & Gaps.

Working with the output: Every "[STATUS UNKNOWN - VERIFY BEFORE GO-LIVE]" item must be resolved and signed off by the relevant domain lead before the go/no-go decision meeting; the model cannot verify actual system or environment state.

AI Prompt — Drafting a Transition-to-Operations and Hypercare plan

What it does: Produces a Transition-to-Operations plan covering the handover register, knowledge transfer (KT) activities, support tier definitions, escalation paths, and hypercare exit criteria, aligned to the Transition to Operations & Hypercare Plan artifact.

When to use it: Use 4-6 weeks before go-live when the project team needs to formally hand the solution to the operations or support team. When not: Do not use as a substitute for live KT sessions; the plan identifies what KT is needed but cannot replace the actual transfer of tacit knowledge.

Inputs to provide:

- System or product name and a brief description of what is being transitioned
- Names/roles of the project (sending) team and the operations (receiving) team
- Any existing support model, SLA commitments, or support tooling in use

The prompt

You are a transition manager drafting the Transition to Operations & Hypercare Plan for [SYSTEM/PRODUCT NAME]. Brief description of what is being transitioned: [2-3 SENTENCES] Planned go-live date: [DATE] Project team (sending): [LIST KEY ROLES AND NAMES OR WRITE "TO BE CONFIRMED"] Operations / support team (receiving): [LIST KEY ROLES AND NAMES OR WRITE "TO BE CONFIRMED"] Existing support model: [E.G., internal IT helpdesk, managed service provider, DevOps team - or "NOT DEFINED"] SLA commitments: [LIST KEY SLAs OR WRITE "NOT DEFINED"] Support tooling: [E.G., ServiceNow, Jira Service Management, PagerDuty - or "NOT DEFINED"] Hypercare duration requested: [E.G., 4 weeks post go-live] Instructions: 1. Transition Readiness Criteria: list the conditions that must be true before the handover can begin (minimum 8 items spanning technical, documentation, and people readiness). 2. Handover Register: a table of every item being handed over with columns: - Item ID - Item Name / Description - Type (documentation / access / process / tool / knowledge) - Sender (project team role) - Receiver (ops team role) - Due Date - Status (Not Started / In Progress / Complete) - Acceptance Criteria (how receiver confirms they have what they need) 3. Knowledge Transfer Plan: a table of KT sessions with columns: - Session ID - Topic - Format (walkthrough / workshop / shadowing / recorded demo) - Presenter - Audience - Planned Date - Validation method (quiz / sign-off / practice run) 4. Support Model and Tier Definitions: - Tier 0 (self-service), Tier 1 (helpdesk), Tier 2 (application support), Tier 3 (engineering / vendor escalation) - For each tier: scope, team/contact, response target, resolution target, escalation trigger 5. Escalation Path and RACI: a contact matrix for common incident and problem scenarios. 6. Hypercare Plan: - Hypercare period: start and end dates - Hypercare activities and cadence (e.g., daily stand-up, issue triage, weekly review) - Project team availability commitments during hypercare - Hypercare exit criteria (minimum 5 measurable criteria, e.g., no P1/P2 open > 48h, ops team handling 90% of tickets independently) - Escalation path if exit criteria are not met by the planned end date 7. Transition Risk Register: top 5 transition-specific risks with mitigation actions. 8. Assumptions & Gaps: flag every section where information was not provided and mark as "[CONFIRM WITH TRANSITION SPONSOR]". Do not assume support model details not stated in the inputs. Use [PLACEHOLDER] for names and dates not provided. Output format: Each numbered section in order, then Assumptions & Gaps.

Working with the output: The Handover Register and KT Plan must be reviewed jointly by the project and operations team leads before sign-off; the model cannot assess the actual readiness or capability of the receiving team.

AI Prompt — Running a Delivery or Program Health Check from your artifacts

What it does: Scores the program or project across standard health dimensions on a 1-5 scale with evidence-based ratings, an overall confidence-in-status indicator, and a prioritized findings and actions list, aligned to the Delivery Health Check Assessment artifact.

When to use it: Use at monthly reviews, quarterly program assurance gates, or when a sponsor requests an independent health perspective. When not: Do not use when artifact inputs are superficial or heavily sanitized; the health score is only as credible as the evidence provided.

Inputs to provide:

- A collection of current project artifacts or status summaries (schedule, risk log, issue log, budget, stakeholder feedback, quality metrics)
- Assessment scope (full program or a specific workstream) and the reporting period
- Any known concerns or areas of focus raised by the sponsor or steering committee

The prompt

You are an independent program assurance advisor conducting a Delivery Health Check Assessment for [PROJECT/PROGRAM NAME] covering the period [START DATE] to [END DATE]. Assessment scope: [FULL PROGRAM / SPECIFIC WORKSTREAM: NAME] Stakeholder concerns or focus areas: [LIST ANY SPECIFIC CONCERNS RAISED - or "NONE STATED"] Artifact inputs (paste or summarize each): - Schedule status: [PASTE OR SUMMARIZE] - Budget / EVM status: [PASTE OR SUMMARIZE] - Risk register summary: [PASTE OR SUMMARIZE] - Issue log summary: [PASTE OR SUMMARIZE] - Quality / defect

metrics: [PASTE OR SUMMARIZE] - Stakeholder engagement notes: [PASTE OR SUMMARIZE] - Change log / scope change summary: [PASTE OR SUMMARIZE] - Team capacity and resource status: [PASTE OR SUMMARIZE] - Other artifacts: [PASTE OR SUMMARIZE - or "NONE PROVIDED"] Instructions: 1. Score each of the following dimensions on a 1-5 scale (1 = Critical concern, 2 = Significant concern, 3 = Moderate/watch, 4 = On track with minor issues, 5 = Strong/no concerns). For each dimension provide: - Score (1-5) - RAG (Red <=2, Amber 3, Green >=4) - Evidence basis (cite the artifact(s) you drew from) - Key observations (2-3 bullet points) Dimensions to score: a. Schedule Performance b. Budget / Cost Performance c. Scope Management d. Risk Management e. Issue Management f. Quality and Testing g. Stakeholder Engagement and Communications h. Team Capacity and Resourcing i. Change Management and Organizational Readiness j. Governance and Decision-Making 2. Overall Program Health Score: weighted average (equal weights unless stated) and overall RAG. 3. Confidence in Reported Status: rate your confidence that the reported status reflects reality on a scale of Low / Medium / High, and explain the basis. Flag any dimensions where artifact evidence was thin, absent, or inconsistent. 4. Key Findings: top 5 findings (prioritized by severity), each with: - Finding ID - Dimension - Finding description - Severity (Critical / High / Medium / Low) - Recommended action - Suggested owner - Target resolution date ([DATE]) 5. Positive Highlights: 2-3 things the program is doing well, with evidence. 6. Assumptions & Limitations: list every dimension where evidence was missing and note that scores in those areas are based on limited information. Do not assign a score higher than 3 for any dimension where no supporting evidence was provided. Flag all inferences clearly. Output format: Dimension Scorecard table, then Overall Health Score, then Confidence in Status, then Key Findings, then Positive Highlights, then Assumptions & Limitations.

Working with the output: Health scores derived from incomplete or self-reported artifacts should be treated as indicative only; an independent assurance reviewer should validate findings against source documents before sharing with the steering committee.

AI Prompt — Building a vendor performance scorecard from SLA data

What it does: Constructs a vendor performance scorecard from SLA attainment data, assigns RAG ratings and trend indicators, flags remedy triggers, and drafts an executive narrative, aligned to the Vendor & Contract Management Plan artifact.

When to use it: Use at monthly or quarterly vendor review meetings when SLA performance data is available from the vendor or monitoring tooling. When not: Do not use when SLA definitions or targets have not been formally agreed in the contract; scoring against undefined baselines is misleading.

Inputs to provide:

- Vendor name, contract reference, and review period
- SLA definitions with contractual targets and actual attainment figures for the period
- Any service credits, penalty clauses, or remedy triggers defined in the contract

The prompt

You are a vendor manager preparing a performance scorecard for [VENDOR NAME] under contract [CONTRACT REFERENCE / NAME] for the review period [START DATE] to [END DATE]. Contract value and term: [E.G., USD 2M / 3-year term ending DD-MMM-YYYY - or "NOT PROVIDED"] Primary contact (vendor): [NAME / ROLE - or "NOT PROVIDED"] Primary contact (client): [NAME / ROLE - or "NOT PROVIDED"] SLA data (paste a table or list for each SLA metric): [FORMAT: SLA Name | Contractual Target | Actual Attainment This Period | Actual Attainment Last Period | Notes] [PASTE DATA HERE] Remedy / service credit triggers defined in contract: [DESCRIBE REMEDY TRIGGERS - e.g., "If availability < 99.5% in any month, vendor owes 5% service credit" - or "NOT PROVIDED"] Qualitative performance inputs (optional): [PASTE ANY CSAT SCORES, ESCALATION COUNTS, DELIVERY MILESTONE STATUS, OR STAKEHOLDER FEEDBACK - or "NONE PROVIDED"] Instructions: 1. SLA Performance Scorecard table with these columns for each SLA metric: - SLA ID - SLA Name / Description - Category (e.g., Availability, Response Time, Resolution Time, Quality, Security) - Contractual Target - Actual Attainment This Period - Actual Attainment Last Period - Trend (Improving / Stable / Deteriorating - based on period-over-period change) - RAG Rating (Green = at or above target; Amber = within 2% below target; Red = more than 2% below target - adjust thresholds if contract specifies different bands) - Remedy Trigger Breached? (Yes / No / Borderline) - Notes 2. Remedy / Service Credit Summary: list any SLAs where a remedy trigger was breached this period, the applicable credit or remedy, and the action required. 3. Qualitative Performance Assessment (if inputs provided): score on a 1-5 scale across: Responsiveness, Communication Quality, Issue Resolution, and Strategic Partnership Value. If no inputs were provided, state this section cannot be completed and leave as "[DATA REQUIRED]". 4. Overall

Vendor RAG: aggregate RAG based on SLA performance and qualitative score. State your weighting logic. 5. Executive Narrative (max 200 words): summarize performance this period, key concerns, positive highlights, and recommended actions for the next review cycle. Write for a non-technical executive audience. 6. Recommended Actions table: columns - Action, Owner (client or vendor), Due Date, Priority (High / Medium / Low). 7. Assumptions & Gaps: flag any SLA where the target or attainment was not provided, and note that the scorecard is only as reliable as the data supplied. Mark missing data cells "[DATA NOT PROVIDED]". Do not calculate service credits without the contractual formula. Do not invent attainment figures. Flag all inferences. Output format: Scorecard table, then Remedy Summary, then Qualitative Assessment, then Overall RAG, then Executive Narrative, then Recommended Actions, then Assumptions & Gaps.

Working with the output: Verify all attainment figures against the vendor's own reporting and the monitoring tooling before presenting the scorecard in a formal review; discrepancies between vendor-reported and client-measured attainment are a common dispute point and must be reconciled before triggering any remedy clause.

AI Prompt — Running a capacity vs demand gap analysis with scenarios

What it does: Produces a supply-vs-demand heatmap by role and time period, identifies bottlenecks, and models add/defer scenarios to close capacity gaps, aligned to the Program Capacity & Demand Management Plan artifact.

When to use it: Use during planning cycles, PI planning, or when new demand is proposed and the program manager needs to assess feasibility before committing. When not: Do not use when resource data is entirely fictional or when the team size is too small to warrant structured capacity modeling (e.g., 1-2 people).

Inputs to provide:

- List of roles and their available capacity (FTE or hours) by time period (week, sprint, or month)
- List of demand items (projects, epics, or work packages) with estimated effort by role and time period
- Any known constraints (leave, holidays, shared resources, skill constraints)

The prompt

You are a resource manager and PMO analyst running a capacity vs demand gap analysis for [PROGRAM / TEAM NAME] covering the period [START DATE] to [END DATE] in [WEEKLY / SPRINT / MONTHLY] buckets. Capacity inputs (supply): [PASTE A TABLE OR LIST: Role | Resource Name (or "pooled") | Available Hours or FTE per period | Notes on constraints] Demand inputs: [PASTE A TABLE OR LIST: Demand Item Name | Priority | Role Required | Estimated Hours per period | Period(s) | Dependency or Constraint] Constraints: [LIST HOLIDAYS, PLANNED LEAVE, PART-TIME ARRANGEMENTS, SHARED RESOURCES, SKILL GAPS - or "NONE STATED"] Scenarios to model: [LIST SCENARIOS - e.g., "Scenario A: hire 1 additional developer in period 3", "Scenario B: defer Demand Item X by 2 periods", "Scenario C: reduce scope of Item Y by 30%" - or "USE STANDARD ADD/DEFER/REDUCE SCENARIOS"] Instructions: 1. Capacity vs Demand Heatmap: produce a table with rows = Roles and columns = Time Periods. Each cell shows: - Supply (available hours) - Demand (required hours) - Gap (Supply minus Demand; negative = overloaded) - Color indicator in text: [OVER] for gap < 0, [AT] for gap 0 to -10%, [UNDER] for gap > 10% surplus 2. Bottleneck Analysis: identify the top 3 roles and/or time periods with the most severe capacity constraints. For each bottleneck provide: - Role / period - Severity (hours overloaded and as % of capacity) - Demand items driving the overload - Risk if not resolved 3. Scenario Analysis: for each scenario provided (or for Add Resource / Defer Demand / Reduce Scope if "USE STANDARD" was specified), produce: - Scenario name and description - Change to supply or demand - Revised heatmap summary (delta from baseline; full heatmap only if < 10 cells change, otherwise summarize) - Residual gaps after the scenario - Estimated cost or schedule impact (state "[COST DATA REQUIRED]" if not provided) - Recommendation: preferred scenario with rationale 4. Utilization Summary table: for each role, show average utilization % across the full period and flag roles above 90% as [AT RISK] and above 100% as [OVERLOADED]. 5. Recommended Actions: prioritized list of actions to close critical gaps, with owner, due date, and expected impact. 6. Assumptions & Gaps: flag any role or period where capacity or demand data was not provided, and note that the analysis is only as reliable as the input data. Mark missing inputs "[DATA NOT PROVIDED]". Do not invent capacity or demand figures. If data is missing for a role or period, show "[DATA NOT PROVIDED]" in the heatmap cell and exclude it from totals. Flag all

inferences. Output format: Heatmap table, then Bottleneck Analysis, then Scenario Analysis sections, then Utilization Summary, then Recommended Actions, then Assumptions & Gaps.

Working with the output: Validate supply figures with resource managers and time-tracking data before using this analysis for hiring or deferral decisions; demand estimates are only as accurate as the underlying work package definitions and should be re-run whenever scope changes.

AI Prompt — Drafting a team onboarding and 30/60/90 ramp plan

What it does: Generates a structured 30/60/90-day onboarding and ramp plan for a new team member, covering orientation activities, learning milestones, relationship-building goals, and performance expectations at each phase. Produces output aligned with the Team Onboarding & Ramp Plan artifact.

When to use it: Use when onboarding a new hire, contractor, or internal transfer onto a program team. When not: Do not use as a substitute for formal HR onboarding documentation or legal employment agreements.

Inputs to provide:

- Role title and level (e.g., Senior Business Analyst, mid-level)
- Program or project name and brief description
- Key stakeholders and team members the new hire will interact with
- Core tools, systems, and access requirements
- Any known priorities or deliverables for the first 90 days
- Manager name and any buddy/mentor assignments

The prompt

You are an expert program manager helping onboard a new team member. Draft a 30/60/90-day ramp plan for the following role and context. Role: [ROLE TITLE AND LEVEL] Program/Project: [PROGRAM OR PROJECT NAME AND BRIEF DESCRIPTION] Manager: [MANAGER NAME] Buddy/Mentor (if assigned): [BUDDY OR MENTOR NAME, OR "TBD"] Key stakeholders and collaborators: [LIST KEY PEOPLE AND THEIR ROLES] Core tools and systems: [LIST TOOLS, PLATFORMS, ACCESS REQUIRED] Known first-90-day priorities: [LIST ANY KNOWN DELIVERABLES OR GOALS] Produce the ramp plan as a structured table with the following columns: Phase (30 / 60 / 90 days), Focus Area, Specific Activity or Milestone, Owner (new hire / manager / team), and Success Indicator. Cover these focus areas across all three phases: Program Context & Orientation, Stakeholder Relationships, Role-Specific Deliverables, Tool & Process Proficiency, and Team Integration. After the table, add a short "Key Risks & Gaps" section listing any assumptions you made and any information that was missing from the inputs that a manager should confirm before finalizing this plan. Do not invent names, dates, or system details that were not provided.

Working with the output: Review each milestone against actual program timelines and confirm success indicators with the hiring manager before sharing with the new team member. The model cannot manufacture access provisioning timelines or HR policy details - validate those against your organization's real onboarding process.

AI Prompt — Designing a role-based security awareness campaign

What it does: Produces a structured, role-tailored security awareness campaign plan covering phishing simulation design, behavior-change interventions, training content themes, and measurable success metrics. Produces output aligned with the Security Awareness Campaign artifact.

When to use it: Use when standing up or refreshing a security awareness program for a project team, business unit, or enterprise audience. When not: Do not use in place of a certified security architect's technical controls assessment or legal/compliance review.

Inputs to provide:

- Target audience roles (e.g., developers, executives, call-center staff)
- Current threat landscape or recent incidents to address

- Duration of campaign (e.g., one quarter, six months)
- Available delivery channels (LMS, email, live training, intranet)
- Baseline metrics available (e.g., prior phishing click rates, policy acknowledgment rates)
- Regulatory or compliance framework in scope (e.g., NIST, ISO 27001, SOC 2)

The prompt

You are a cybersecurity program manager designing a role-based security awareness campaign. Use the inputs below to produce a detailed campaign plan. Target audience roles: [LIST ROLES AND APPROXIMATE HEADCOUNT PER ROLE] Key threats or incidents to address: [DESCRIBE THREAT TYPES OR RECENT INCIDENTS] Campaign duration: [DURATION, e.g., "Q3 2025 - 12 weeks"] Delivery channels available: [LIST CHANNELS] Baseline metrics: [PROVIDE ANY KNOWN BASELINE DATA OR WRITE "NONE AVAILABLE"] Compliance framework: [FRAMEWORK NAME OR "NONE"] Produce the campaign plan with these sections: 1. Campaign Objectives - three to five SMART objectives. 2. Role-Based Threat Profiles - for each role, one paragraph on the top threats and why they are targeted. 3. Phishing Simulation Schedule - a table with columns: Wave, Target Role(s), Simulation Theme, Difficulty Level (Low/Medium/High), Timing, and Pass/Fail Criteria. 4. Behavior-Change Interventions - for each role, recommended training modules, nudges, or job aids mapped to the identified threats. 5. Metrics & Measurement Plan - a table with columns: Metric, Baseline, Target, Measurement Method, and Review Frequency. 6. Campaign Timeline - a week-by-week or month-by-month activity plan. 7. Assumptions & Gaps - list every assumption made and any input that was absent; do not invent compliance requirements or incident data not provided.

Working with the output: Have your information security team validate the phishing simulation themes and metric targets against your organization's actual tooling (e.g., KnowBe4, Proofpoint) before launching. The model cannot access your existing click-rate data or compliance audit findings - supply those as inputs for a more precise plan.

AI Prompt — Drafting a Responsible-AI usage policy for a program

What it does: Generates a program-level Responsible AI usage policy covering data classification, allowed and forbidden data inputs, human-in-the-loop requirements, approved AI tools, logging obligations, and incident response. Produces output aligned with the Responsible AI Usage Guardrails artifact.

When to use it: Use when a program team is adopting AI-assisted tools and needs a written governance policy before go-live. When not: Do not use as a final legal instrument; route the output through your legal and compliance teams before publication.

Inputs to provide:

- Program name and brief description
- AI tools currently approved or under evaluation (e.g., ChatGPT Enterprise, GitHub Copilot, Gemini)
- Data classification levels in use at the organization (e.g., Public, Internal, Confidential, Restricted)
- Regulatory or contractual constraints (e.g., GDPR, HIPAA, client NDA, FedRAMP)
- Key use cases AI will support (e.g., code generation, document summarization, data analysis)
- Stakeholders who must approve exceptions or escalations

The prompt

You are a senior technology governance advisor. Draft a Responsible AI Usage Policy for the program described below. The policy must be practical, enforceable, and understandable by non-lawyers. Program name: [PROGRAM NAME] Program description: [1-3 SENTENCE DESCRIPTION] Approved or evaluated AI tools: [LIST TOOLS] Data classification levels: [LIST LEVELS, e.g., Public / Internal / Confidential / Restricted] Regulatory or contractual constraints: [LIST CONSTRAINTS OR "NONE IDENTIFIED"] AI-supported use cases: [LIST USE CASES] Exception/escalation approvers: [LIST ROLES OR NAMES] Structure the policy with the following sections: 1. Purpose & Scope 2. Definitions (AI Tool, Prompt, Output, Human-in-the-Loop) 3. Data Classification Rules - a table mapping each classification level to: Allowed in AI prompts (Yes/No/Conditional), Required safeguards, and Examples. 4. Allowed Use Cases - brief description of each approved use case and any conditions. 5. Forbidden Uses - explicit list of

prohibited inputs and outputs. 6. Human-in-the-Loop Requirements - specify which output types require human review before use, and who is responsible. 7. Approved Tools & Procurement Gate - how new tools get evaluated and approved. 8. Logging & Audit Requirements - what must be logged, retention period, and who reviews. 9. Incident Response - steps to follow if a policy violation or AI-generated error is discovered. 10. Policy Governance - owner, review cadence, version history placeholder. After the policy, add an "Assumptions & Open Items" section listing anything assumed and any input that was missing. Do not invent regulatory citations, specific tool capabilities, or contractual terms not provided.

Working with the output: Treat the draft as a starting point - have your legal, compliance, and security leads review before distribution, and confirm tool-specific data handling guarantees directly with vendors. The model cannot access your organization's existing policies or vendor contracts.

AI Prompt — Building a cross-team dependency map from plans

What it does: Parses raw project or program plan inputs and produces a structured cross-team dependency register with provider, receiver, deliverable, needed-by date, float, and risk flags. Produces output aligned with the Cross-Team Dependency Management artifact.

When to use it: Use when consolidating plans from multiple workstreams or teams to surface sequencing conflicts and hand-off risks before they become schedule delays. When not: Do not use as a replacement for integrated scheduling in a tool such as MS Project or Smartsheet - use this to draft and validate, then load into your scheduling tool.

Inputs to provide:

- List of workstreams or teams and their current plan summaries (milestones, deliverables, owners, dates)
- Any known dependencies already identified
- Overall program end date or key milestone dates
- Definition of float tolerance (e.g., "<5 business days is high risk")

The prompt

You are a program integration manager. Analyze the workstream plans and inputs below and produce a cross-team dependency map. Program name: [PROGRAM NAME] Program end date or key milestone: [DATE OR MILESTONE] Float risk threshold: [e.g., "Dependencies with fewer than [N] business days of float are HIGH risk"] Workstream plans (paste each team's plan summary below; include team name, owner, key deliverables, and dates): [PASTE WORKSTREAM 1 PLAN] [PASTE WORKSTREAM 2 PLAN] [ADD MORE AS NEEDED] Known dependencies already identified: [LIST OR "NONE"] Produce the following outputs: 1. Dependency Register - a table with columns: Dependency ID, Provider Team, Receiver Team, Deliverable/Hand-off, Needed-By Date, Provider Committed Date, Float (business days), Risk Level (High/Medium/Low based on float threshold), and Notes. 2. Dependency Network Summary - a short narrative describing the critical dependency chain (the sequence of hand-offs with the least float). 3. Top 5 Dependency Risks - ranked list with risk description, impact if missed, and suggested mitigation. 4. Gaps & Assumptions - list every date or deliverable you assumed because it was not explicitly stated in the inputs. Do not invent commitments or owners not mentioned in the plans.

Working with the output: Walk the dependency register with each team lead to confirm committed dates and owners before treating it as a program baseline. The model cannot infer unstated hand-offs or access your scheduling tool's resource calendars.

AI Prompt — Generating a phase-gate review pack with entry and exit criteria

What it does: Generates a complete phase-gate (tollgate) review pack for a specified program phase, including entry criteria, exit criteria, go/no-go decision checklist, conditions for conditional approval, and a reviewer scorecard. Produces output aligned with the Phase-Gate (Tollgate) Reviews artifact.

When to use it: Use before scheduling a formal stage-gate or tollgate review meeting to ensure all criteria are defined and documented. When not: Do not use as a substitute for governance body sign-off - this tool drafts the pack; the governance body must still approve it.

Inputs to provide:

- Program name and phase being reviewed (e.g., Phase 2 - Build)
- Phase objectives and key deliverables
- Governance body or approvers attending the review
- Any mandatory regulatory or compliance checkpoints for this phase
- Known risks or issues open at the time of the review
- Next phase start date and dependencies

The prompt

You are a PMO governance specialist. Create a phase-gate review pack for the program phase described below. Program name: [PROGRAM NAME] Phase name and number: [e.g., "Phase 2 - Build"] Phase objectives: [LIST 3-5 OBJECTIVES] Key deliverables expected by gate: [LIST DELIVERABLES WITH OWNERS] Governance body / approvers: [LIST NAMES AND ROLES] Mandatory compliance or regulatory checkpoints: [LIST OR "NONE"] Open risks and issues: [SUMMARIZE KEY RISKS/ISSUES OR "NONE DOCUMENTED"] Next phase start date: [DATE] Next phase key dependencies: [LIST DEPENDENCIES] Produce the phase-gate review pack with these sections: 1. Gate Overview - purpose, phase summary, decision date, and attendees. 2. Entry Criteria Checklist - table with columns: Criterion, Evidence Required, Status (Met/Not Met/Partial), and Owner. Include criteria for: deliverable completion, quality assurance sign-off, risk register currency, budget and schedule health, and stakeholder approvals. 3. Exit Criteria Checklist - same table structure; criteria must be specific and measurable. 4. Go / No-Go Decision Matrix - table mapping each criterion to a weight and a score (1-5), with a total weighted score and recommended decision threshold (e.g., $\geq 80\%$ = Go). 5. Conditions for Conditional Approval - template for recording any conditions that must be met within [N] days post-gate. 6. Open Issues & Risk Summary - brief table: Issue/Risk, Owner, Resolution Plan, Target Date. 7. Reviewer Scorecard - template for each approver to record their vote (Go / No-Go / Conditional Go) and rationale. 8. Assumptions & Gaps - list any criterion or data you assumed because it was not in the inputs; do not invent compliance requirements or deliverable owners.

Working with the output: Pre-populate the Evidence Required and Status columns with actual artifact links and status before distributing to reviewers. The model cannot access your project management system to verify deliverable completion - that must be done manually.

AI Prompt — Drafting a team charter and working agreements

What it does: Produces a complete team charter and working agreements document covering mission, scope, roles and decision rights, Definition of Ready (DoR), Definition of Done (DoD), team norms, and escalation paths. Produces output aligned with the Team Charter & Working Agreements artifact.

When to use it: Use at program kickoff or when restructuring a team to establish shared expectations and governance from day one. When not: Do not use as a replacement for formal organizational charts, HR job descriptions, or contractual statements of work.

Inputs to provide:

- Team name and program context
- Team members with roles/titles
- Team mission and scope (what is in/out of scope)
- Key stakeholders and sponsors
- Primary delivery methodology (e.g., Agile/Scrum, waterfall, hybrid)
- Any known working constraints (time zones, part-time members, tool preferences)

The prompt

You are an experienced agile coach and program manager. Draft a complete Team Charter and Working Agreements document for the team described below. Team name: [TEAM NAME] Program context: [1-3 SENTENCE DESCRIPTION OF THE PROGRAM] Team members: [LIST NAME, ROLE, AND FTE% OR TIME ZONE FOR EACH MEMBER] Team mission (draft or bullet points): [DESCRIBE MISSION OR WRITE "TO BE DEFINED"] In-scope responsibilities: [LIST] Out-of-scope responsibilities: [LIST OR "TO BE CONFIRMED"] Key stakeholders and sponsors: [LIST WITH NAMES AND ROLES] Delivery methodology: [e.g., SCRUM, KANBAN, HYBRID, WATERFALL] Working constraints: [TIME ZONES, PART-TIME MEMBERS, TOOL RESTRICTIONS, ETC.] Produce the charter with the following sections: 1. Team Identity - name, mission statement, and charter effective date. 2. Scope - in-scope and out-of-scope

responsibilities as two bullet lists. 3. Team Roster & Roles - table with columns: Name, Role, Responsibilities, Decision Authority (RACI: Responsible/Accountable/Consulted/Informed), and FTE%. 4. Decision Rights - table mapping decision type to who decides (using RACI), input required, and turnaround expectation. 5. Definition of Ready (DoR) - checklist of criteria a work item must meet before the team commits to it. 6. Definition of Done (DoD) - checklist of criteria that must be true before any deliverable is considered complete. 7. Working Norms - at least 8 explicit agreements covering: meeting attendance, communication channels and response SLAs, documentation standards, code/artifact review process, conflict resolution, and availability windows. 8. Escalation Path - table: Issue Type, First Escalation Contact, Second Escalation Contact, and Expected Resolution Time. 9. Charter Amendments Process - how the team agrees to change the charter. 10. Assumptions & Open Items - list every assumption made and flag any section that requires team discussion before finalizing. Do not invent names, decisions, or norms not supported by the inputs.

Working with the output: Run the draft charter through a team kickoff session to get explicit buy-in on norms, DoR/DoD, and decision rights - written agreement without discussion rarely sticks. The model cannot infer unspoken team preferences or access your organization's HR or RACI standards.

AI Prompt — Designing a program operating rhythm and cadence map

What it does: Produces a structured program operating rhythm and cadence map showing all recurring meetings, ceremonies, and reporting cycles, their purpose, frequency, owners, attendees, inputs, and outputs. Produces output aligned with the Operating Rhythm & Cadence Map artifact.

When to use it: Use at program inception or when reorganizing a program's governance structure to eliminate meeting bloat and ensure the right information flows to the right audiences. When not: Do not use as a substitute for actually scheduling and sending calendar invites - this is a design artifact, not a live calendar.

Inputs to provide:

- Program name and governance tiers (e.g., team, program, steering committee, executive)
- Delivery methodology (e.g., Scrum, waterfall, hybrid)
- Team size and key roles that must be covered in the cadence
- Any non-negotiable reporting deadlines (e.g., monthly board report, weekly client status)
- Known time zone constraints
- Current pain points with existing cadence (if refreshing an existing rhythm)

The prompt

You are a senior program manager designing the operating rhythm for a program. Use the inputs below to produce a complete cadence map. Program name: [PROGRAM NAME] Governance tiers: [LIST TIERS, e.g., "Team / Program / Steering Committee / Executive"] Delivery methodology: [METHODOLOGY] Key roles that must have representation in the cadence: [LIST ROLES] Non-negotiable reporting deadlines: [LIST WITH FREQUENCY AND AUDIENCE, OR "NONE"] Time zone constraints: [LIST TEAM LOCATIONS AND TIME ZONES, OR "ALL SAME TIMEZONE"] Current cadence pain points: [DESCRIBE OR "N/A - NEW PROGRAM"] Produce the cadence map with these sections: 1. Cadence Design Principles - 4-6 guiding principles used to design this rhythm (e.g., decisions at the lowest competent level, no meeting without a clear output). 2. Master Cadence Table - one row per recurring event with columns: Event Name, Governance Tier, Purpose (1 sentence), Frequency, Duration, Day/Time Window, Owner/Facilitator, Required Attendees, Key Inputs, Key Outputs, and Format (synchronous/async). 3. Information Flow Diagram (text-based) - show how outputs from lower-tier meetings feed inputs to higher-tier meetings, using a simple ASCII or indented list format. 4. Weekly Rhythm Summary - a plain-language description of what a typical week looks like for a team member. 5. Reporting Calendar - a table mapping each report or artifact (e.g., status report, risk register update) to: Frequency, Due Date Logic (e.g., "every Friday by 5pm"), Owner, and Recipient(s). 6. Cadence Health Metrics - 3-5 metrics to track whether the operating rhythm is working (e.g., meeting attendance rate, decision backlog age). 7. Assumptions & Gaps - list every assumption made, especially around time zones and governance tier membership. Do not invent meeting owners or attendees not identified in the inputs.

Working with the output: Validate the proposed day/time windows against actual team availability before sending calendar invites, and review the cadence map quarterly to prune

meetings that have outlived their purpose. The model cannot access team calendars or infer organizational hierarchy beyond what you provide.

AI Prompt — Drafting an escalation framework with tiers, thresholds and SLAs

What it does: Generates a tiered escalation framework defining issue categories, severity thresholds, escalation paths, responsible parties at each tier, and SLAs for acknowledgment and resolution. Produces output aligned with the Escalation Framework artifact.

When to use it: Use when a program lacks a documented escalation process or when recurring issues are being resolved too slowly or at the wrong level. When not: Do not use as a substitute for executive alignment on authority levels - the escalation paths must be confirmed with actual decision-makers before publication.

Inputs to provide:

- Program name and delivery context
- Escalation tiers and key roles at each tier (e.g., Team Lead, Program Manager, Steering Committee, Executive Sponsor)
- Issue categories relevant to this program (e.g., scope, schedule, budget, resource, risk, vendor, technical)
- Any existing SLA expectations or service agreements
- Communication channels available (e.g., email, Slack, Teams, phone)
- On-call or after-hours coverage requirements (if any)

The prompt

You are a PMO governance lead. Draft a comprehensive escalation framework for the program described below. Program name: [PROGRAM NAME] Program delivery context: [1-2 SENTENCE DESCRIPTION] Escalation tiers and key roles: Tier 1: [ROLE NAME, e.g., "Team Lead"] Tier 2: [ROLE NAME, e.g., "Program Manager"] Tier 3: [ROLE NAME, e.g., "Steering Committee or PMO Director"] Tier 4 (if applicable): [ROLE NAME, e.g., "Executive Sponsor"] Issue categories in scope: [LIST CATEGORIES] Existing SLA expectations: [DESCRIBE OR "NONE DEFINED"] Communication channels: [LIST CHANNELS] After-hours coverage requirement: [YES/NO AND DESCRIPTION, OR "NO"] Produce the escalation framework with the following sections: 1. Framework Purpose & Scope - one paragraph. 2. Escalation Principles - 4-6 guiding principles (e.g., escalate early, de-escalate promptly, one owner per issue). 3. Severity Classification Matrix - a table with columns: Severity Level (1-Critical, 2-High, 3-Medium, 4-Low), Definition, Business Impact, and Examples per Issue Category. 4. Escalation Path by Tier - a table with columns: Severity Level, Initial Owner (Tier 1), Escalation to Tier 2 If (condition and time threshold), Escalation to Tier 3 If, Escalation to Tier 4 If, and Communication Channel at Each Tier. 5. SLA Table - a table with columns: Severity Level, Acknowledgment SLA, Initial Response SLA, Resolution Target SLA, and Escalation Trigger (time without resolution -> next tier). 6. Issue Lifecycle - step-by-step process from issue identification through escalation, resolution, and closure, with owner at each step. 7. Escalation Communication Templates - one short template each for: initial issue notification, escalation notification, and resolution/closure notification. Use [BRACKETED PLACEHOLDERS] for variable fields. 8. Roles and Responsibilities Summary - RACI table: Identify, Log, Escalate, Resolve, Communicate, Close. 9. Assumptions & Gaps - list every assumption made about tier membership, SLA values, or authority levels. Do not invent SLAs or authority structures not confirmed in the inputs.

Working with the output: Walk the escalation paths with each named tier owner and get explicit sign-off on SLAs before publishing - undisclosed SLAs create conflict rather than resolve it. The model cannot verify organizational authority levels or existing contractual SLA commitments.

AI Prompt — Drafting a program roadmap from initiatives and milestones

What it does: Transforms raw initiative lists, milestone inputs, and strategic objectives into a structured program roadmap with phased timelines, initiative sequencing rationale, dependencies, and an executive summary narrative. Produces output aligned with the Program Roadmap artifact.

When to use it: Use when a program needs a consolidated roadmap view for executive communication, planning, or funding approval. When not: Do not use as a replacement for a detailed project schedule with resource loading - this produces a roadmap-level view, not a work breakdown structure.

Inputs to provide:

- Program name and strategic objectives (2-5 bullets)
- List of initiatives or workstreams with rough scope descriptions
- Key milestones with target dates (or relative timing if dates are unknown)
- Known dependencies between initiatives
- Planning horizon (e.g., 12 months, 18 months, through Q4 2026)
- Key constraints (budget tranches, regulatory deadlines, technology sequencing requirements)

The prompt

You are a senior program manager preparing a program roadmap for executive review. Use the inputs below to produce a structured roadmap and narrative. Program name: [PROGRAM NAME] Strategic objectives: [LIST 2-5 STRATEGIC OBJECTIVES] Planning horizon: [e.g., "Jan 2026 - Dec 2026" OR "18 months from [START DATE]"] Initiatives and workstreams (list each with a brief scope description): [INITIATIVE 1 NAME]: [SCOPE DESCRIPTION] [INITIATIVE 2 NAME]: [SCOPE DESCRIPTION] [ADD MORE AS NEEDED] Key milestones (include owner and target date or relative timing): [MILESTONE 1 NAME] - Owner: [OWNER] - Target: [DATE OR RELATIVE TIMING] [ADD MORE AS NEEDED] Known dependencies between initiatives: [LIST DEPENDENCY PAIRS, e.g., "Initiative B cannot start until Initiative A Phase 1 is complete", OR "NONE IDENTIFIED"] Key constraints: [LIST BUDGET TRANCHES, REGULATORY DEADLINES, TECHNOLOGY SEQUENCING REQUIREMENTS, OR "NONE"] Primary audience for this roadmap: [e.g., "Executive Steering Committee", "Client Leadership", "Board"] Produce the program roadmap with the following sections: 1. Executive Summary - a 3-5 sentence narrative summarizing the program purpose, planning horizon, number of initiatives, and the 2-3 most important milestones. 2. Strategic Objective-to-Initiative Mapping - a table showing which initiatives directly support each strategic objective. 3. Phased Roadmap Table - a table with columns: Initiative/Workstream, Phase 1 Scope & Timing, Phase 2 Scope & Timing (if applicable), Phase 3 Scope & Timing (if applicable), Key Milestones, and Owner. 4. Milestone Schedule - a chronological table with columns: Milestone, Initiative, Owner, Target Date, Dependencies, and Status (Planned/At Risk/TBD). 5. Dependency Summary - a table with columns: Dependency, Provider Initiative, Receiver Initiative, Hand-off Deliverable, Needed-By Date, and Risk if Missed. 6. Key Constraints & Sequencing Rationale - a brief narrative or bullet list explaining why initiatives are sequenced as shown, referencing any constraints. 7. Roadmap Risks - top 3-5 risks to the roadmap timeline with likelihood, impact, and suggested mitigation. 8. Assumptions & Gaps - list every date, scope boundary, or dependency you assumed because it was not explicitly stated in the inputs. Do not invent milestones, owners, or strategic linkages not supported by the inputs provided.

Working with the output: Validate all dates and owners with workstream leads before presenting to executives, and confirm that the strategic objective-to-initiative mapping reflects current organizational priorities. The model cannot access your project management system, budget data, or approved scope documents.

AI Prompt — Drafting a Program Closure Report

What it does: Generates a structured Program Closure Report that captures component closure status, benefits handover to BAU, lessons learned, financial closure, and required sign-offs. It surfaces gaps and outstanding items so the program director can remediate before formal closure.

When to use it: Use at the end of the program lifecycle when all components are at or approaching closure and you are preparing the final governance submission. When not: Do not use mid-program or when components are still in active delivery - use a Program Status Report instead.

Inputs to provide:

- Program name, program ID, and planned vs. actual end date
- List of components with individual closure status (closed / in close-out / open)

- Benefits realization summary: planned benefits, benefits confirmed delivered, benefits handed to BAU owner (name and date)
- Financial summary: approved budget, actual spend, variance, and status of any open purchase orders or invoices
- Outstanding risks, issues, or dependencies that must be resolved or formally accepted before closure
- Lessons learned inputs (can be bullet points or a raw notes dump)
- Names and roles of required sign-off authorities

The prompt

You are a senior program management consultant drafting a formal Program Closure Report for [PROGRAM NAME] (ID: [PROGRAM ID]). Use the information provided below and structure the report with the following numbered sections: 1. Executive Summary - State the program's objectives, planned vs. actual end date ([PLANNED END DATE] vs. [ACTUAL END DATE]), overall delivery verdict (delivered / partially delivered / not delivered), and a one-paragraph closure rationale. 2. Component Closure Status - Produce a table with columns: Component Name | Delivery Lead | Planned Close Date | Actual Close Date | Closure Status (Closed / In Close-Out / Open) | Outstanding Actions. Populate from the input data. Flag any component not yet formally closed and list the blocking action required. 3. Benefits Realization and BAU Handover - For each benefit: state the benefit description, planned value, confirmed delivered value, variance, BAU owner name, handover date, and whether a Benefits Realization Plan has been signed. If handover is incomplete, mark it RED and state what is outstanding. 4. Financial Closure - Present a table: Budget Line | Approved Budget | Actual Spend | Variance | Status (Closed / Open PO / Disputed). Summarize total approved budget, total actual spend, and overall variance. List any open purchase orders or invoices and the action needed to close them. 5. Lessons Learned - Organize lessons under these headings: Governance, Planning and Scheduling, Risk and Issue Management, Stakeholder Engagement, Benefits Delivery. For each lesson state: what happened, root cause, and recommended improvement for future programs. 6. Outstanding Items and Conditions for Closure - Produce a numbered list of any items that must be resolved or formally accepted (with owner and target date) before the program can be signed off as closed. 7. Sign-Off Schedule - Produce a table: Authority Name | Role | Signature Required | Date Signed. Leave date fields blank for the program director to complete. Inputs: [PASTE COMPONENT CLOSURE STATUS HERE] [PASTE BENEFITS REALIZATION SUMMARY HERE] [PASTE FINANCIAL SUMMARY HERE] [PASTE OUTSTANDING RISKS/ISSUES/DEPENDENCIES HERE] [PASTE LESSONS LEARNED NOTES HERE] [PASTE SIGN-OFF AUTHORITIES HERE] Instructions: - Flag every assumption you make with the prefix ASSUMPTION: so the program director can verify. - Do not invent financial figures, benefit values, names, or dates - if data is missing, insert [DATA REQUIRED] and explain what is needed. - If any section cannot be completed from the inputs provided, state GAP: and describe the gap. - Use plain language suitable for a senior executive audience. No jargon unless defined. - Output the report in clean, structured plain text ready to paste into the Program Closure Report artifact.

Working with the output: Paste the output directly into the Program Closure Report artifact and resolve every ASSUMPTION:, GAP:, and [DATA REQUIRED] marker before submitting for sign-off. Verify all financial figures against the program's finance system of record before circulation.

AI Prompt — Planning program tranches with an end-of-tranche review

What it does: Produces a structured Tranche and Release Plan that defines tranche outcomes, constituent releases, dependencies, and the end-of-tranche go/no-go review criteria so the program board can make evidence-based continuation decisions. It also flags planning gaps and risks that could undermine tranche boundaries.

When to use it: Use during program planning or re-planning when you need to organize delivery into discrete tranches with formal review gates. When not: Do not use for single-project delivery without a program board or where tranche-based governance has not been mandated.

Inputs to provide:

- Program vision statement and strategic objectives (1-3 sentences)
- Proposed number of tranches and high-level description of the outcome each tranche should deliver
- List of components or workstreams in the program and which tranche each belongs to

- Known releases or milestones within each tranche (name, target date, deliverables)
- Key dependencies between tranches and between components within a tranche
- Constraints: budget envelope per tranche (if known), hard regulatory or contractual dates, resource availability windows
- Risk and assumption inputs relevant to tranche boundaries

The prompt

You are a senior program management consultant developing a Tranche and Release Plan for [PROGRAM NAME]. Using the inputs below, produce the plan in the following structure: 1. Program Context - Restate the program vision and strategic objectives in 2-3 sentences. Confirm the number of tranches being planned and the overall planning horizon ([START DATE] to [END DATE]). 2. Tranche Summary Table - Produce a table with columns: Tranche Number | Tranche Name | Outcome Statement (what capability or benefit is delivered by end of tranche) | Planned Start | Planned End | Budget Envelope | Status (Planned / Active / Closed). Populate one row per tranche. 3. Tranche Detail - For each tranche, produce a sub-section containing: a. Outcome and success criteria - What must be true for this tranche to be considered successful? State 3-5 measurable criteria. b. Releases within this tranche - Table: Release Name | Components Involved | Planned Delivery Date | Key Deliverables | Dependencies. c. Intra-tranche dependencies - List critical dependencies between components within this tranche. For each: Dependency description | From (component/release) | To (component/release) | Risk if not met. d. Cross-tranche dependencies - List any outputs from this tranche that are inputs to a later tranche. e. Constraints and risks - List constraints affecting this tranche's boundary dates or budget. Flag any risk that could require the tranche boundary to be moved. 4. End-of-Tranche Review Framework - For each tranche, define the go/no-go review with: Review date | Chair | Attendees | Evidence pack required (list of documents and data) | Go criteria (all of these must be true to proceed) | No-go triggers (any of these present means halt or re-plan) | Escalation path if no-go. 5. Cross-Tranche Dependency Map - Produce a structured list (not a diagram) of all cross-tranche dependencies. Format: [Tranche N deliverable] -> required by [Tranche M release] by [date]. Flag any dependency where the delivery date is within 2 weeks of the consuming release date as HIGH RISK. 6. Planning Gaps and Recommendations - List any gaps in the inputs provided that prevent a complete plan from being produced. For each gap: what is missing, why it matters, and who should provide it. Inputs: [PASTE PROGRAM VISION AND OBJECTIVES HERE] [PASTE TRANCHE DESCRIPTIONS HERE] [PASTE COMPONENT/WORKSTREAM LIST AND TRANCHE ASSIGNMENTS HERE] [PASTE RELEASES AND MILESTONES HERE] [PASTE DEPENDENCIES HERE] [PASTE CONSTRAINTS HERE] [PASTE RISKS AND ASSUMPTIONS HERE] Instructions: - Flag every assumption you make with the prefix ASSUMPTION: so the program manager can verify. - Do not invent dates, budget figures, or component names - insert [DATA REQUIRED] where inputs are missing. - Where tranche boundaries appear inconsistent with the stated outcomes or dependencies, flag this as PLANNING RISK: and explain the concern. - Output in structured plain text ready to paste into the Tranche and Release Plan artifact.

Working with the output: Paste into the Tranche and Release Plan artifact and walk each ASSUMPTION: and PLANNING RISK: with the program management team before baselining. Verify all dates against the master schedule and confirm budget envelopes with the finance lead.

AI Prompt — Aggregating and analyzing program-level risk

What it does: Rolls up component-level risks into a program-level risk register, identifies systemic and cross-component risks that are invisible at the component level, calculates program exposure, and produces a prioritized set of program director actions. It flags data quality issues and gaps that would undermine the analysis.

When to use it: Use when preparing for a program board, portfolio review, or program-level risk workshop where you need a consolidated view across all components. When not: Do not use as a substitute for component-level risk management - this tool works on aggregated inputs, not individual component registers.

Inputs to provide:

- Program name and current tranche/phase
- Risk registers from each component (paste as tables or bullet lists): risk ID, description, probability (H/M/L or 1-5), impact (H/M/L or 1-5), current rating, owner, current response/mitigations

- Any program-level constraints or strategic risks already identified by the program director
- List of components and their interdependencies (so cross-component risks can be identified)
- Risk appetite statement or tolerance thresholds if defined (e.g., no red risks unmitigated at program level)

The prompt

You are a senior risk management consultant performing a program-level risk aggregation and analysis for [PROGRAM NAME], currently in [TRANCHE/PHASE]. Using the component risk register inputs below, perform the following analysis and produce the output in the sections specified: 1. Data Quality Assessment - Before analysis, review each component's risk input and flag: missing fields, inconsistent scoring scales, risks with no owner, risks rated red with no documented mitigation. Summarize data quality as: Acceptable / Needs Remediation / Unreliable. If Unreliable, state that the analysis cannot proceed until gaps are fixed. 2. Program-Level Risk Register - Produce a consolidated table with columns: Program Risk ID | Source Component(s) | Risk Description | Category (Strategic / Delivery / Financial / People / External / Technology) | Probability (H/M/L) | Impact (H/M/L) | Current Rating (H/M/L) | Program Owner | Current Response | Residual Rating | Escalation Required (Y/N). Include all component risks. Where the same risk appears in multiple components, merge into one row and note all source components. 3. Systemic and Cross-Component Risk Analysis - Identify risks that: (a) appear in ≥ 2 components (systemic risks), (b) arise from dependencies between components (cross-component risks), or (c) would only become visible at program level (emergent risks). For each, write: Risk description | Why it is systemic/cross-component/emergent | Affected components | Recommended program-level response. 4. Program Risk Exposure Summary - Produce: (a) a count of risks by rating (High/Medium/Low) and by category; (b) top 5 risks ranked by combined probability x impact; (c) a narrative paragraph of no more than 150 words summarizing overall program risk posture for the program board. 5. Risks Requiring Escalation - List all risks that exceed the program's risk appetite or tolerance thresholds (using thresholds provided, or flag ASSUMPTION: using standard threshold of any red risk with no approved mitigation). For each: Risk ID | Description | Why it requires escalation | Recommended escalation action | Proposed owner. 6. Program Director Action List - Produce a numbered list of priority actions for the program director, ordered by urgency. Format: [Priority 1-5] | Action | Owner | Target Date | Success Criteria. 7. Gaps and Assumptions - List all assumptions made and all data gaps that limit the reliability of this analysis. Inputs: [PASTE COMPONENT RISK REGISTERS HERE - ONE SECTION PER COMPONENT, LABELED WITH COMPONENT NAME] [PASTE PROGRAM-LEVEL CONSTRAINTS AND STRATEGIC RISKS HERE] [PASTE COMPONENT INTERDEPENDENCY LIST HERE] [PASTE RISK APPETITE STATEMENT OR THRESHOLDS HERE - OR STATE 'NOT PROVIDED'] Instructions: - Flag every assumption with ASSUMPTION: and every data gap with GAP:. - Do not invent risk ratings, owners, or mitigations. If a field is missing, insert [DATA REQUIRED]. - Do not conflate probability with impact. Treat them as separate dimensions. - Where you identify a cross-component or systemic risk not present in any component register, label it NEW-PROGRAM-RISK: so the program manager can formally log it. - Output in structured plain text ready to paste into the Program Risk Management artifact.

Working with the output: Paste into the Program Risk Management artifact and validate every NEW-PROGRAM-RISK: entry with the relevant component leads before the program board. Have the program manager confirm all risk owners before the output is treated as the authoritative program risk register.

AI Prompt — Drafting a change request with impact analysis for the CCB

What it does: Produces a complete Change Request document including full impact analysis across scope, schedule, cost, quality, and risk, presents options with a clear recommendation, and formats the output for submission to the Change Control Board (CCB). It flags assumptions, data gaps, and any impacts that require specialist verification before the CCB meeting.

When to use it: Use when a proposed change to program scope, schedule, budget, or baseline requires formal CCB approval and you need a rigorous, decision-ready document. When not: Do not use for minor operational decisions that fall within delegated authority and do not require CCB review.

Inputs to provide:

- Change requestor name, role, date, and component or program area affected

- Change description: what is changing and why (the business driver or problem being solved)
- Current approved baseline for scope, schedule, cost, and quality (can be brief summaries)
- Proposed new baseline or the specific change being requested
- Any options already considered and rejected (optional but helpful)
- Known constraints: hard dates, budget ceilings, contractual obligations, dependencies
- Risk inputs: any risks introduced or retired by the change

The prompt

You are a senior program management consultant drafting a Change Request and impact analysis for submission to the Change Control Board (CCB) for [PROGRAM NAME]. Using the inputs below, produce the Change Request document in the following structure:

1. Change Request Header - Produce a header table with: CR Reference Number [CR-XXXX - leave blank for program manager to assign] | Program Name | Component/Area Affected | Requestor Name | Requestor Role | Date Raised | Priority (Critical / High / Medium / Low - based on inputs) | CCB Meeting Target Date [DATA REQUIRED if not provided].
2. Change Description - Write a clear, concise description (maximum 200 words) of: what is being changed, the business driver or problem that makes this change necessary, and what will happen if the change is not approved (the 'do nothing' consequence).
3. Current Baseline Summary - Summarize the approved baseline being changed across four dimensions: Scope (what is currently committed), Schedule (key milestones and end date), Cost (approved budget and spend to date), Quality (acceptance criteria or quality targets affected).
4. Impact Analysis - Produce a detailed impact assessment for each of the five dimensions below. For each dimension state: current position, position if change is approved, quantified variance (use numbers; if unknown insert [DATA REQUIRED]), confidence level (High/Medium/Low), and any assumptions made.
 - a. Scope Impact - What is added, removed, or modified? What is explicitly out of scope for this change?
 - b. Schedule Impact - Which milestones or end dates are affected? By how many days/weeks? Are there downstream program or cross-component impacts?
 - c. Cost Impact - What are the estimated additional costs (capital and operating, broken down if possible)? What are the cost implications of not approving the change?
 - d. Quality Impact - Are acceptance criteria, non-functional requirements, or quality gates affected? What is the risk to product/service quality?
 - e. Risk Impact - List new risks introduced by approving the change. List risks retired or reduced by approving the change. Net risk direction: increased / neutral / decreased.
5. Options Analysis - Present at minimum 3 options (including 'do nothing' as Option 1). For each option produce: Option number | Description | Scope delta | Schedule delta | Cost delta | Quality delta | Risk delta | Feasibility (High/Medium/Low) | Recommended? (Y/N).
6. Recommendation - State clearly which option the requestor recommends and why (maximum 150 words). Address: why this option best balances cost, schedule, risk, and strategic fit; what the key conditions or dependencies are for this recommendation to hold.
7. Items Requiring CCB Decision - Produce a numbered list of the specific decisions the CCB must make (do not leave the CCB to infer what they are being asked to approve). Each item: Decision required | Options | Implication of each option.
8. Assumptions, Constraints, and Gaps - List all assumptions underpinning the impact analysis. List all constraints. List all gaps where additional specialist input is required before the CCB can make a fully informed decision - state who should provide the input and by when.
9. Sign-Off and Approval Table - Produce a table: Role | Name | Recommendation (Approve/Reject/Defer/Approve with Conditions) | Conditions (if any) | Date. Rows: Change Requestor | Program Manager | [COMPONENT LEADS AS REQUIRED] | CCB Chair. Leave all fields except Role blank for completion at the CCB.

Inputs: [PASTE CHANGE REQUESTOR DETAILS HERE] [PASTE CHANGE DESCRIPTION AND BUSINESS DRIVER HERE] [PASTE CURRENT APPROVED BASELINE HERE] [PASTE PROPOSED CHANGE OR NEW BASELINE HERE] [PASTE OPTIONS ALREADY CONSIDERED HERE - OR STATE 'NONE'] [PASTE CONSTRAINTS HERE] [PASTE RISK INPUTS HERE]

Instructions: - Flag every assumption with ASSUMPTION: so the program manager can verify before the CCB. - Do not invent cost estimates, schedule variances, or risk ratings. Insert [DATA REQUIRED] and name the specialist who should provide the figure (e.g., finance lead, scheduler, architect). - Where the inputs are insufficient to complete a section, state GAP: and describe exactly what is needed. - Do not recommend approval or rejection on behalf of the CCB - the recommendation in Section 6 is the requestor's recommendation only. - Output in structured plain text ready to paste into the Change Request and Change Control artifact.

Working with the output: Paste into the Change Request and Change Control artifact and resolve all ASSUMPTION:, GAP:, and [DATA REQUIRED] markers with the relevant specialists before distributing the pack to CCB members. Do not present cost or schedule variances to the CCB without independent verification from the finance lead and program scheduler.

AI Prompt — Drafting a contract change order

What it does: Produces a complete, structured Contract Change Order document covering scope delta, price and schedule impact, revised acceptance criteria, and authorization blocks. It surfaces every assumption and flags missing inputs before drafting.

When to use it: Use when a vendor SOW requires a formal amendment due to scope, cost, or timeline changes. When not: Do not use for informal scope discussions, internal-only work-order adjustments, or situations where a full contract re-execution is required.

Inputs to provide:

- Original SOW or contract excerpt (scope, price, schedule, acceptance criteria)
- Description of the change (what is added, removed, or modified)
- Agreed or proposed price delta (fixed fee, T&M rate, or not-yet-negotiated)
- Revised milestone or delivery dates
- Names and titles of signatories (client and vendor)
- Change order number and contract reference number

The prompt

You are a senior contracts and procurement specialist. Draft a formal Contract Change Order (CO) using the inputs below. Structure the output exactly as specified. Do not invent facts; if any required input is missing or ambiguous, flag it in a clearly labeled "ASSUMPTIONS AND GAPS" section at the top before the CO body, and insert a [TBD - reason] placeholder in the relevant field. INPUTS: - Original contract/SOW reference: [CONTRACT_REFERENCE_NUMBER] - Change order number: [CO_NUMBER] - Effective date: [EFFECTIVE_DATE] - Client entity: [CLIENT_ENTITY_NAME] - Vendor entity: [VENDOR_ENTITY_NAME] - Original scope summary: [ORIGINAL_SCOPE_SUMMARY] - Change description (added/removed/modified): [CHANGE_DESCRIPTION] - Reason for change: [REASON_FOR_CHANGE] - Original contract value: [ORIGINAL_CONTRACT_VALUE] - Price delta (+ or -): [PRICE_DELTA] - New total contract value: [NEW_TOTAL_CONTRACT_VALUE] - Original completion date: [ORIGINAL_COMPLETION_DATE] - Revised completion date: [REVISED_COMPLETION_DATE] - Affected milestones and revised dates: [MILESTONE_TABLE] - Revised acceptance criteria (if changed): [REVISED_ACCEPTANCE_CRITERIA] - Client signatory name and title: [CLIENT_SIGNATORY] - Vendor signatory name and title: [VENDOR_SIGNATORY] OUTPUT STRUCTURE (use these exact headings): 1. ASSUMPTIONS AND GAPS (list any; write "None" if clean) 2. CHANGE ORDER HEADER (CO number, contract ref, effective date, parties) 3. BACKGROUND AND REASON FOR CHANGE (2-4 sentences) 4. SCOPE DELTA (table: Item | Original | Revised | In/Out-of-Scope Flag) 5. FINANCIAL IMPACT (table: Line Item | Original Value | Delta | Revised Value; subtotals and new total) 6. SCHEDULE IMPACT (table: Milestone | Original Date | Revised Date | Days Delta) 7. REVISED ACCEPTANCE CRITERIA (list only criteria that changed; note "Unchanged" for all others) 8. TERMS AND CONDITIONS (state which original contract terms carry forward unchanged; note any superseded terms) 9. AUTHORIZATION BLOCK (signature lines: Client Signatory, Vendor Signatory, Date each) Formatting rules: use plain text tables (pipe-delimited). No markdown headers. Label each section with its number and title in ALL CAPS. Keep language formal and unambiguous. Do not use em dashes; use plain hyphens.

Working with the output: Review the ASSUMPTIONS AND GAPS section first and resolve every [TBD] before sending to legal or procurement. Verify all financial figures against the original contract and approved change request before circulating for signature - the model cannot access live contract data and figures must be independently confirmed. This prompt generates the artifact: Contract Change Order.

AI Prompt — Building a resource tracker with contractor hours and burn

What it does: Produces a fully structured Resource Tracking and Time/Cost register covering all staff and contractors, with hours by period, bill rates, actual cost, burn vs. budget variance, and PO/invoice reconciliation rows. It flags data gaps before building the register.

When to use it: Use when standing up or refreshing a project resource tracker that must reconcile contractor invoices against PO balances and show real-time burn against budget. When not: Do not use as a substitute for an approved financial system of record or when your organization requires tracker data to flow from a time-entry system (pull the export instead).

Inputs to provide:

- List of resources (name, role, type: FTE or contractor, vendor name if contractor)
- Budget hours and dollar budget per resource or role
- Bill rates or fully-loaded rates per resource
- Reporting period start and end dates (and cadence: weekly/biweekly/monthly)
- PO numbers, PO ceiling values, and invoices received to date (contractor resources)
- Actual hours logged to date per resource (if available)

The prompt

You are a senior PMO analyst. Build a detailed Resource Tracking register using the inputs below. Do not invent rates, hours, or financial figures. If any input is missing, flag it in a clearly labeled "ASSUMPTIONS AND GAPS" section before the register, and insert a [TBD - reason] placeholder in the affected cell or column. INPUTS: - Project name: [PROJECT_NAME] - Project ID / WBS code: [PROJECT_ID] - Reporting period cadence: [WEEKLY | BIWEEKLY | MONTHLY] - Reporting period covered: [PERIOD_START] to [PERIOD_END] - Resources (repeat block for each): Name: [RESOURCE_NAME] Role: [ROLE] Type: [FTE | CONTRACTOR] Vendor (if contractor): [VENDOR_NAME] PO number (if contractor): [PO_NUMBER] PO ceiling (\$): [PO_CEILING] Bill rate (\$/hr): [BILL_RATE] Budget hours (total engagement): [BUDGET_HOURS] Budget cost (total engagement): [BUDGET_COST] Actual hours this period: [ACTUAL_HOURS_THIS_PERIOD] Cumulative actual hours to date: [CUMULATIVE_ACTUAL_HOURS] Invoices received to date (\$): [INVOICES_RECEIVED] Invoices paid to date (\$): [INVOICES_PAID] OUTPUT STRUCTURE (produce each section in order): 1. ASSUMPTIONS AND GAPS (list any; write "None" if clean) 2. RESOURCE REGISTER TABLE Columns: Resource Name | Role | Type | Vendor | PO Number | PO Ceiling (\$) | Bill Rate (\$/hr) | Budget Hours | Budget Cost (\$) | Actual Hours This Period | Cumulative Actual Hours | Actual Cost to Date (\$) | Budget Remaining (\$) | % Budget Burned | PO Remaining (\$) | Invoices Received (\$) | Invoices Paid (\$) | Invoice Reconciliation Status | RAG Status - Actual Cost to Date = Cumulative Actual Hours x Bill Rate (show formula note if rate is [TBD]) - Budget Remaining = Budget Cost - Actual Cost to Date - % Budget Burned = (Actual Cost to Date / Budget Cost) x 100 - PO Remaining = PO Ceiling - Invoices Received - Invoice Reconciliation Status: flag if Invoices Received > PO Remaining or if Invoices Received > Actual Cost to Date by more than 10% - RAG Status: Green (<= 80% burned with >= 20% work remaining); Yellow (81-95% or invoice discrepancy); Red (>95% or PO ceiling breach) 3. SUMMARY ROW: totals for Budget Hours, Budget Cost, Actual Cost to Date, Budget Remaining, Invoices Received, Invoices Paid 4. BURN NARRATIVE: 3-5 bullet points calling out resources at Yellow or Red status, PO ceiling risks, and invoice reconciliation issues 5. RECOMMENDED ACTIONS: numbered list of actions to resolve gaps, ordered by urgency Formatting rules: pipe-delimited tables, plain text, no markdown bold or headers. Label each section in ALL CAPS. Use "x" for multiplication in formula notes. Use ">=" and "<=" for comparisons.

Working with the output: Cross-check every calculated field against your source timesheets and PO documentation before sharing with finance or the client - the model performs arithmetic on the inputs you provide, so any input error propagates to all derived columns. Resolve all [TBD] placeholders and Invoice Reconciliation Status flags before treating the register as authoritative. This prompt generates the artifact: Resource Tracking & Time/Cost.

AI Prompt — Drafting a knowledge transfer plan

What it does: Produces a complete, structured Knowledge Transfer Plan covering all knowledge domains, from/to assignments, transfer methods, a session schedule, and verification/sign-off criteria - with a dedicated vendor-exit KT section when applicable. It flags every gap before drafting.

When to use it: Use when onboarding a new team member, transitioning a workstream to a new owner, or preparing for vendor contract end/offboarding to ensure no critical knowledge is lost. When not: Do not use as a substitute for formal system-access provisioning, security offboarding checklists, or HR separation workflows - those require parallel processes.

Inputs to provide:

- Project or program name and brief description
- Knowledge domains to transfer (e.g., system architecture, process runbooks, stakeholder relationships, data sources, vendor contacts)

- Knowledge sources (names, roles, organizations - who currently holds the knowledge)
- Knowledge recipients (names, roles, organizations - who must receive it)
- Transfer deadline or end date (e.g., vendor contract end date)
- Available transfer methods (e.g., shadowing sessions, recorded walkthroughs, document handoff, Q&A workshops)
- Verification approach (e.g., quiz, sign-off checklist, demonstrated task completion)
- Any known constraints (availability windows, NDAs, system-access limitations)

The prompt

You are a senior PMO knowledge management specialist. Draft a formal Knowledge Transfer Plan (KTP) using the inputs below. Do not invent knowledge domains, owners, dates, or verification criteria. If any required input is missing or ambiguous, list it in a clearly labeled "ASSUMPTIONS AND GAPS" section at the top before the KTP body, and insert a [TBD - reason] placeholder in the affected field. INPUTS: - Project/program name: [PROJECT_PROGRAM_NAME] - Project description (1-2 sentences): [PROJECT_DESCRIPTION] - KTP effective date: [KTP_EFFECTIVE_DATE] - Transfer deadline: [TRANSFER_DEADLINE] - Is this a vendor exit KT? [YES | NO] - If yes, vendor name and contract end date: [VENDOR_NAME] / [CONTRACT_END_DATE] - Knowledge sources (repeat for each): Name: [SOURCE_NAME] Role: [SOURCE_ROLE] Organization: [SOURCE_ORG] Availability constraints: [AVAILABILITY_CONSTRAINTS] - Knowledge recipients (repeat for each): Name: [RECIPIENT_NAME] Role: [RECIPIENT_ROLE] Organization: [RECIPIENT_ORG] - Knowledge domains (repeat for each): Domain name: [DOMAIN_NAME] Description: [DOMAIN_DESCRIPTION] Criticality: [HIGH | MEDIUM | LOW] Current owner (source): [SOURCE_NAME] Recipient(s): [RECIPIENT_NAMES] Existing documentation (location/status): [DOCUMENTATION_STATUS] Known gaps or risks: [GAPS_RISKS] - Preferred transfer methods: [METHOD_LIST] - Verification approach: [VERIFICATION_APPROACH] - Sign-off authority (name and title): [SIGNOFF_AUTHORITY] OUTPUT STRUCTURE (produce each section in order): 1. ASSUMPTIONS AND GAPS (list any; write "None" if clean) 2. KTP HEADER (project name, effective date, transfer deadline, parties) 3. EXECUTIVE SUMMARY (3-5 sentences: purpose, scope, key risks if KT is incomplete) 4. KNOWLEDGE DOMAIN REGISTER (table: Domain Name | Criticality | Description | Source | Recipient(s) | Existing Docs Status | Transfer Method | Scheduled Session Date(s) | Verification Method | Sign-off Date | Status) - For each [TBD] session date, flag as "TO BE SCHEDULED" - Status values: Not Started | In Progress | Completed | Verified 5. SESSION SCHEDULE (table: Session # | Domain(s) Covered | Format | Source | Recipient(s) | Proposed Date | Duration | Location/Link | Pre-work Required) 6. DOCUMENTATION REQUIREMENTS (table: Document Name | Domain | Owner | Due Date | Storage Location | Review/Approval Required) 7. VERIFICATION AND SIGN-OFF CRITERIA (for each domain: what the recipient must demonstrate or attest; method; pass threshold; who signs off) 8. VENDOR EXIT KT SECTION (include only if "Is this a vendor exit KT?" = YES): - Vendor-held IP and proprietary tools inventory - System and data access revocation checklist (flag items requiring IT involvement) - Contractual KT obligations (cite clause numbers if provided; otherwise flag as [TBD - confirm with legal]) - Transition risk register (table: Risk | Likelihood | Impact | Mitigation | Owner) 9. ESCALATION AND CONTINGENCY PLAN (what happens if a source is unavailable or a session is missed; escalation path and fallback method) 10. APPROVAL BLOCK (sign-off lines: KTP Author, Project Sponsor, Knowledge Source Lead, Knowledge Recipient Lead, Date) Formatting rules: pipe-delimited tables, plain text, no markdown. Label each section in ALL CAPS with its number. Use plain hyphens, not em dashes. Keep language direct and unambiguous. Surface every assumption - do not fill gaps silently.

Working with the output: Review the ASSUMPTIONS AND GAPS section first and resolve every [TBD] with confirmed inputs from the project team before distributing the plan. Verify all session dates against participant calendars and confirm vendor contractual KT obligations with legal before treating the Vendor Exit KT section as binding - the model cannot access contracts or calendars and all scheduling/legal references must be independently confirmed. This prompt generates the artifact: Knowledge Transfer Plan.

AI Prompt — Designing an AI automation for a recurring PM task

What it does: Given a description of a recurring project management task, this prompt assesses whether the task is worth automating, recommends a tool-neutral automation pattern, defines the guardrails and human checkpoints required, and outlines a phased rollout. It explicitly flags which elements of the task must remain human and makes no assumptions about the user's tooling or platform.

When to use it: When a PM or team member has identified a task they perform repeatedly and wants a structured assessment of whether and how to automate it. Best used before any automation work begins, as an input to the Automation Candidate Assessment and Design Canvas.

When not: Do not use when the task involves active negotiation, client relationship management, or real-time judgment about organisational dynamics. Do not use as a replacement for data classification review - that must be done by the responsible human against the organisation's approved AI tool registry.

Inputs to provide:

- A precise description of the task (what is done, how often, what inputs are consumed, what output is produced)
- The current time cost per occurrence and per week/month
- The audience or downstream use of the output (internal team, steering committee, client, etc.)
- The data classification of the inputs if known (e.g., internal, confidential, restricted)
- Any known constraints on tooling (e.g., "we can only use tools approved by our IT security team" or "we have no existing AI platform")

The prompt

You are a senior project management and AI delivery advisor. I will describe a recurring task I perform as part of managing a project. Your job is to: 1. Assess whether this task is a good candidate for AI automation using these criteria: - Frequency: how often it recurs - Structured I/O: how well-defined the inputs and outputs are - Judgment required: whether completing it well requires negotiation, political judgment, or tacit contextual knowledge - Risk if output is wrong: how detectable and recoverable an error would be before downstream harm - Data sensitivity: whether the inputs may contain information that restricts which tools can handle them Score each dimension and give an overall recommendation: automate, automate with strong guardrails, automate only a sub-step, or keep human. Show your reasoning. 2. Recommend the most appropriate tool-neutral automation pattern from this list. Describe the pattern in terms of what happens, not which tool implements it: - Assistant-with-context: a reusable system prompt loaded with project metadata makes every session project-aware - Retrieval over project artefacts: the AI queries and synthesises across the project's own indexed documents to ground its output in real data - Trigger -> Draft -> Review -> Act: an event or schedule triggers a draft; a named human reviews and approves before the output is used - Supervised agentic workflow: a multi-step autonomous sequence executes with defined human checkpoints and escalation paths Justify your choice in one or two sentences. If you recommend a more complex pattern, explain what quality evidence you would want to see before escalating to it. 3. Define the guardrails required for your recommended pattern. Include: data classification check (what class of data is involved and what that means for tool selection), output logging requirements, access controls, prompt constraints, and any prohibited data types. State the principle that guardrails must scale with the level of autonomy: the less hands-on the human, the more verification and containment the automation must carry. 4. Define the human checkpoints. Name the role (not tool) responsible for review. State what they are checking, the pass/fail criteria, what happens if the output fails, and how often the checkpoint occurs. 5. Flag explicitly what must remain human in this task, even if other parts are automated. Be specific about which sub-steps, which decisions, or which communications cannot be delegated to an automated process and why. 6. Outline a phased rollout in three steps: (a) validate output quality manually before any live use; (b) run the automation in parallel with the manual process for at least two weeks, comparing outputs; (c) go live with the automation as the primary method, with the manual process as the documented fallback. For each step, name the exit criterion that must be met before moving to the next step. Do not assume anything about the tools, platforms, or AI systems available to me. Describe every recommendation in terms of what the automation does and what properties it must have, not how to configure a specific product. If my description suggests a data classification or risk level that would make automation inadvisable without further information, say so clearly and ask the clarifying question before proceeding. Here is the task I want to assess: [PASTE TASK DESCRIPTION HERE - include: what is done, how often, what inputs are used, what the output is, who receives or acts on the output, current time cost, and any known data sensitivity]

Working with the output: Use the assessment directly as input to the Automation Candidate Assessment and Design Canvas (Artefact 19), mapping each section of the prompt output to the corresponding canvas field. Verify the data classification recommendation against your organisation's actual AI tool approval registry before acting on it - the prompt reasons from the

information you provide, so if your data classification is more restrictive than described, the pattern recommendation may need to change. The phased rollout outline is a starting point; adjust timeline and exit criteria to match your project's risk appetite and governance requirements. Do not treat the prompt output as governance approval - that requires human sign-off per your organisation's AI governance process.

Shared & Cross-cutting · Field Notes (22)

Field Note — Writing a recovery plan when the project is sideways

Field Note - Writing a recovery plan when the project is sideways

In short: A recovery plan is not a confession or a status report -- it is a one-page, versioned document that acknowledges new reality, diagnoses what changed, proposes a credible new path with explicit trade-offs, and asks for the specific decisions needed to move.

A recovery plan resets the program to a new credible plan. It has four jobs: acknowledge new reality honestly, diagnose what changed, propose a new path with explicit trade-offs, and ask for the specific decisions needed. It is not a status report saying things are bad. It is not a request for more time and money. It is not a confession.

Vignette: Naomi Vargas, Staff TPM, infrastructure modernization at Bristol Financial

Naomi was 10 months into a 16-month infrastructure program. Her FIDO2 hardware vendor's lead time moved from 4 weeks to 8 weeks. The program's critical path ran through privileged-user FIDO2 enrollment, which gated the SOC 2 audit window in August. Without intervention, the audit slipped -- which meant a finding for the regulator and a difficult conversation with the CRO.

Before writing anything, Naomi worked through the assessment. She named what changed in one sentence: vendor lead time, specifically. Not "the program is behind." That clarity mattered. She identified when she knew -- three weeks earlier, when the vendor sent a capacity update that buried the news in section three. She had been hoping for a recovery without surfacing. And she identified what was hard to say: the program had been single-sourced on this vendor for cost reasons, and that decision was now causing the slip. She named the structural cause once in the document and then moved on. Repeating it would have read as building a case rather than proposing a path.

Then she wrote the document -- one page, versioned, structured as follows:

- Where we are: 2 sentences with the gap and the consequence date
- What changed: 4 bullet items, each factual not editorial
- What we're proposing: Descope + Increase Budget. Defer non-privileged enrollment to Phase 2, draw \$80K from contingency for buffer-token premium pricing
- What this gets us: privileged FIDO2 by original M-008 date, workforce-wide by Q1 2027, within original \$8.4M budget after \$80K contingency draw
- What we're not solving: single-source vendor dependency. Recommendation: dual-source as a requirement for next contract renewal
- What we need from you: sponsor approval on \$80K by Friday, CRO acknowledgment of revised audit posture, steering ratification at next monthly meeting
- Risks of this plan: 2 items with mitigations

She brought it to her sponsor in a 1:1 forty-eight hours before steering -- not a cold email. The sponsor flagged that the language about the structural cause was too heavy and one of the proposed mitigations was unrealistic. Naomi revised. By the time it hit steering, the sponsor was an ally. She led the meeting with the ask: "I'm here to walk through a recovery plan for the FIDO2 supply chain situation. The recommendation is Descope + Increase Budget. Five

minutes, then I need three decisions." All three decisions were approved. The \$80K contingency draw was logged as DC-028. The deferral was logged as a Charter amendment. The SOC 2 audit window held. The dual-source requirement went into the Lessons Learned register as L-009 and shaped the next year's procurement strategy.

The five recovery levers

Every recovery plan pulls one or more of these. Most real recoveries combine two or three.

Descope. Cut the work. The hardest to propose because it sounds like failure; it usually isn't. Often the most credible option because it doesn't require additional time, money, or people.

Extend. Move the date. Easier to propose, often the wrong call. Extending without descope just ratifies that the same team will work harder for longer to deliver the same scope.

Increase budget. Ask for more money. Legitimate, frequent, necessary. The framing that works: "Conditions have changed. To meet the original commitment under the new conditions, we need [specific amount] for [specific purpose]." Vendors increase pricing, hardware costs change, scope discovery surfaces work -- all valid reasons sponsors expect to see on programs of any meaningful size.

Add resource. Bring on more people. Often proposed first because it feels active. Bringing on more engineers in month 6 of a 9-month project rarely buys the velocity people imagine. Useful only when the bottleneck is genuinely a single skill or capacity gap that can be filled cleanly.

Accept. Take the hit. Sometimes the recovery is acknowledging that the program will deliver less than promised, on the original date, with the original budget. Less common than people think.

How to ask for budget without losing credibility

Be specific about what the increase buys. "\$80K for 200 buffer FIDO2 tokens at premium pricing, which closes the supply chain risk and protects the August audit window." Not "approximately \$100K for vendor remediation."

Tie the increase to a specific risk you are closing. "Without this, the FIDO2 supply chain risk remains open and SOC 2 readiness is compromised."

Show what you considered and didn't propose. "I considered software tokens as an interim; Compliance ruled them inadequate. I considered descope the audit-relevant population entirely; that left an open SOX finding."

Don't bundle multiple unrelated asks. Don't come back for incremental additions every two weeks. If you will need more money, model out what the program needs through close and ask once.

Moves that work:

- Name what changed in one sentence -- "vendor lead time moved from 4 weeks to 8 weeks" -- before writing anything else; it forces clarity and shapes every section that follows
- Pre-align with the sponsor 48 hours before steering so the sponsor becomes an ally who can correct tone and flag unrealistic mitigations before the document is final
- Lead the steering meeting with the ask, not the context -- "I need three decisions" -- and state the specific dollar and scope trade-offs (Descope + Increase Budget, \$80K contingency draw logged as DC-028) up front
- Name the structural cause once and move on; repeating it reads as building a case rather than proposing a path
- Close every recovery plan with "what we're not solving" -- naming the dual-source vendor dependency as out-of-scope in this cycle, and recommending it for the next procurement cycle, is what makes the document credible rather than a sales pitch

Watch out for:

- The "we're going to push through" recovery -- no actual change to plan, just more conviction; if the team could push through, they would have already
- The over-engineered recovery -- five pages, multiple scenarios, decision trees; steering can't absorb it; pick one path, own it, present alternatives only if asked
- The recovery that arrives after the sponsor has lost confidence -- signals include shorter 1:1s and the sponsor scheduling time with your manager instead of you; by the time you are writing the recovery plan, the political horse has left the barn; surface trouble before you have a recovery plan to propose
- Adding resource before diagnosing the lever -- two new engineers don't fix a vendor problem; make sure the lever matches the cause
- Asking for budget in incremental additions every two weeks instead of modeling the program through close and asking once

Bottom line: A credible recovery plan is one page, names one path, asks for specific decisions, and arrives 48 hours before steering -- after the sponsor has already seen it.

Field Note — The "what would we do if it slipped 2 more weeks" scenario

Field Note - The "what would we do if it slipped 2 more weeks" scenario

In short: The discipline is asking yourself every week what happens if the currently-slipping item slipped two more weeks -- walking the cascade forward, hunting for hidden float in three specific places, modeling the budget tail, and surfacing as a watch item before it becomes a decision item.

Done well, this discipline is invisible. The program runs smoothly because someone modeled the cascade before it was needed. Done poorly -- or skipped -- the same cascade produces a surprise escalation and a contingency draw that catches the sponsor off guard.

When to run the scenario

Run the scenario when any one of these trigger conditions is present:

- Critical-path proximity: the slipping item sits on or near the critical path
- Hard-date downstream commitment: SOC 2 audit windows, regulatory deadlines, customer commitments, contract terms
- External-coordination dependency: another team or program is depending on your delivery
- Compounding factor: the cause of this slip is also affecting other items

If none are true, the slip is just a slip -- absorb it and move on. If one is true, run the scenario. If two or more are true, you should already be running it.

Vignette: Devon Park, Senior TPM, data platform program at Bristol Financial

Devon was 9 months into a 14-month data platform program. The schema migration milestone (M-014) was tracking 1 week behind -- a routine slip the team thought they could absorb. Devon noticed three of his trigger conditions: M-014 was on the critical path, the downstream M-021 (SOX compliance audit) had a hard date, and the same engineering capacity gap causing M-014 was also affecting M-018.

He walked the cascade forward. M-014 +14 days. M-018 (data quality framework) could not start without M-014 -- float was 5 days, net slip 9 days. M-019 (parallel work) had no dependency and kept its date. M-020 (UAT entry) cascaded the 9 days. M-021 (SOX audit) was a hard date -- the slip landed there.

Then he hunted for hidden float. He found it in three specific places:

- In parallel work that doesn't actually depend. He asked his engineering lead: "is M-018 actually a hard prerequisite for M-020, or did we just sequence them this way?" M-020 needed only 60% of M-018 to start. Hidden float: 4 days.
- In the buffer between completion and downstream consumption. He checked the calendar gaps. Some buffers were real testing windows; one was just calendar space. Hidden float: 3 days.
- In work already partially done. The UAT lead had started test case authoring weeks earlier, before M-018 was finished. Hidden float: 2 days.

Total hidden float surfaced: 9 days. The cascade landed neutral on the SOX audit.

Then he modeled the budget tail. Two weeks of additional team carrying cost on the data platform program: approximately \$70K. Premium pricing on a vendor task that would now need to compress: \$30K. Total potential cost if the cascade played out fully: \$100K.

Devon decided to surface to the sponsor as a watch item, not a decision item. His phrasing: "I want to walk through a scenario I've been modeling." Not "I have bad news." Different signals. The sponsor pre-aligned on the watch item. When the slip materialized two weeks later, the conversation about contingency funding had already happened in concept. Devon submitted a \$100K contingency draw request that was approved in three days because the sponsor wasn't surprised.

The watch item pattern

A watch item has three properties:

It names the scenario specifically. Not "data platform could slip." Specifically: "If the schema migration slips another 2 weeks, M-021 SOX audit is consumed of all float by July 30."

It names the threshold that converts the watch into a decision. "If we don't get vendor confirmation of the buffer fix by Friday, this becomes an active issue requiring sponsor decision next week."

It has a clear conversion path. "If we hit the threshold, I'll come back to steering with a contingency draw of \$50-100K and a Desclope + Reinforce recovery plan."

A program running 3-4 watch items at any given time is a program where the TPM is staying ahead. A program with no watch items either has nothing complex going on, or has a TPM who isn't doing the modeling.

Surface now or fix quietly

Three considerations:

How material is the cascade? If your worst-case lands within float, fix quietly. If it reaches a hard date or affects another stakeholder's commitment, surface.

How long until inevitable? If worst-case is six weeks out with credible mitigations, keep working. If it's two weeks out, the time to mitigate has passed -- surface.

What's the cost of late notice? Even a manageable slip becomes a relationship problem if the sponsor learns late. The general rule: surface anything material at least one decision-cycle ahead of when you'll need a decision.

Moves that work:

- Walk the cascade forward from the slipping item step by step -- M-014 +14 days forces M-018 net slip 9 days, which consumes all float on M-021 (SOX audit hard date) -- before drawing any conclusions about severity
- Hunt for hidden float in three specific places: parallel work that doesn't actually depend (4 days in Devon's case), buffer that is really just calendar space (3 days), and work already partially started (2 days from the UAT lead's early test-case authoring) -- 9 days of hidden float neutralized a SOX cascade entirely

- Model the budget tail explicitly -- two weeks of carrying cost (\$70K) plus vendor compression premium (\$30K) = \$100K potential exposure -- so you can put a number on the watch item, not just a schedule concern
- Frame the sponsor conversation as a watch item with a named threshold and a clear conversion path, not as bad news; Devon's phrasing "I want to walk through a scenario I've been modeling" pre-aligned the sponsor so the \$100K contingency draw was approved in three days rather than triggering a surprise escalation

Watch out for:

- Treating the absence of active trigger conditions as permission to skip the modeling -- the discipline is the willingness to look at the bad scenario before you have to; most TPMs avoid it because it surfaces risks they'll then have to do something about, and that avoidance is what causes late surprises
- Waiting until the slip is confirmed before surfacing -- if worst-case is two weeks out, the time to mitigate has passed; a manageable slip becomes a relationship problem when the sponsor learns late
- Running the cascade without checking whether dependencies are actually hard -- Devon's question "is M-018 actually a hard prerequisite for M-020, or did we just sequence them this way?" unlocked 4 of the 9 days of hidden float; sequencing assumptions are often wrong

Bottom line: Walk the cascade, find the float, model the \$100K tail, and tell the sponsor before they have to ask -- the discipline is looking at the bad scenario before you have to, not after.

Field Note — Re-baselining without losing trust

Field Note - Re-baselining without losing trust

In short: Re-baselining -- formally adopting a new date, scope, or budget commitment -- is the right move when recovery to the original baseline isn't credible, and it preserves trust only when framed as adaptation to changed conditions rather than failure of the original plan.

A re-baseline is not a status report saying you're behind. It is not a recovery plan that recovers to the original commitment. It is the formal act of saying: the original baseline (date, scope, budget) is no longer the goal -- we are adopting a new one. This is a stronger statement than a recovery plan. A recovery plan keeps the original commitment and changes the path. A re-baseline changes the commitment itself. Most programs that need re-baselining try recovery plans first. That is the right order. Re-baseline is what you do when recovery isn't credible.

When re-baselining is the right call

Any of three conditions justifies it:

The scope you signed up for is no longer the right scope. Strategy shifts. Markets move. The thing scoped 14 months ago isn't the right thing anymore.

The conditions that informed the original plan have materially changed. Vendor went out of business. Regulatory landscape shifted. Key dependency program was canceled.

You have executed at least one recovery plan and the program is still off. Two recovery plans means the underlying baseline was wrong, not just the execution.

Not on this list: "the team is tired," "we're behind schedule," "morale is low." Those are recovery problems, not baseline problems.

Vignette: Inez Marchetti, Senior TPM, regulatory reporting modernization at Bristol Financial Inez was 11 months into a 14-month regulatory reporting modernization. The program had been chartered before Bristol's Cloud Migration program, but Cloud Migration was then accelerated 18 months -- Q4 2027 pulled to Q4 2026. That acceleration created a downstream dependency on Inez's program that didn't exist when her Charter was approved. Components 1-3 (data

ingestion, transformation, validation) were now needed by the new Cloud Migration date. Components 4-5 (reporting interfaces, audit dashboards) were no longer time-bound by the same constraint.

Inez wrote the re-baseline document in three sections.

First: what she was proposing, in one paragraph at the top. "I'm proposing we re-baseline this program to deliver Components 1-3 by the original Q3 2027 date, defer Components 4-5 to a Phase 2 program targeted Q1 2028, and reduce program budget from \$4.2M to \$3.4M to reflect the reduced scope."

Second: what changed -- and this is where most re-baselines fail. The framing had to be that the original plan was the right plan for the conditions known at the time; conditions have since changed. She wrote: "When the Charter was approved in October 2025, the Cloud Migration program was scheduled for 2027. In April 2026, Cloud Migration was accelerated to Q4 2026. This created a downstream dependency on Components 1-3 that didn't exist in the original plan. To meet the new dependency, those components must deliver on the original date. Components 4-5 are no longer time-bound by the same constraint, and deferring them does not put any commitment at risk." That framing said: we're not failing to deliver what we promised; we're adapting to deliver what's needed.

Third: the new commitment with the same specificity as the original. Date: Q3 2027 for Components 1-3, Q1 2028 for Components 4-5. Budget: \$3.4M, releasing \$800K back to the portfolio. Specific named milestones, specific owners, specific sign-offs.

She brought it to her sponsor in a 1:1 with a different ask than a recovery plan: "I want to walk through a re-baseline I'm proposing. I want to understand if you can support it before we take it to steering." The sponsor wasn't sure at first. He had committed publicly to the original budget number and worried that releasing \$800K would look like the program had been over-funded. They worked through it together. He concluded that returning unused money would build credibility -- a TPM who gave money back was a TPM the portfolio committee would trust the next time she asked for more. By the end of the 1:1 he had agreed to back the re-baseline at steering and had drafted his own opening line for the meeting.

In steering, the sponsor opened: "We're going to walk through a re-baseline of the regulatory reporting program that I support. The acceleration of Cloud Migration changed the right shape of this program, and Inez has come back with a plan that fits the current state." Steering ratified.

The re-baseline held. The new Q3 2027 date for Components 1-3 was met within a week. The released \$800K funded an unrelated program's contingency the next quarter. Inez's portfolio standing went up, not down -- she was the TPM who returned money when the scope didn't need it. Her next budget request was a \$1.2M increase for a different program; it was approved without much pushback because of the credibility she had built.

The budget question

Three patterns:

Same budget, different scope. The cleanest re-baseline. No incremental ask required.

Lower budget, lower scope. Less common but real. Releasing money builds credibility for next time -- as Inez demonstrated with the \$800K return.

Higher budget, same or expanded scope. The hardest. Tie the increase to specific changed conditions, not to "more work than expected." Lead with the number; don't bury it.

The version trap: a TPM proposes a re-baseline that increases budget by 10%. Sponsor pushes back. TPM revises to hold the original budget by descope more. Six months later, the descope scope turns out to be needed, and the TPM is back asking for the original number plus another 5%. Both parties end up worse off. The fix: be honest about budget the first time. If

the analysis shows you need \$9.2M to deliver a credible program, propose \$9.2M and let the sponsor decide whether to fund it or descope further.

The role of the team

Build the new baseline with the component leads. Walk through constraints together; let them propose what's achievable. The new dates have to come partly from them or they won't defend them.

Acknowledge the cost to the team. The work done in Phase 1 is the foundation, not waste. Say so explicitly.

Give the team time to absorb. A week between announcement and execution. The new baseline is a real change to what they have been working toward.

Moves that work:

- Frame the re-baseline explicitly as adaptation to changed conditions, not failure of the original plan -- Inez's framing ("we're not failing to deliver what we promised; we're adapting to deliver what's needed") was accurate, not spin, because Cloud Migration's 18-month acceleration genuinely changed the right shape of the program
- Bring the sponsor a 1:1 ask ("can you support this?") rather than a review ask ("here's what I'm doing") -- Inez's sponsor found his own reason to support the \$800K release (credibility with the portfolio committee) once he had space to work through it
- Give the new commitment the same specificity as the original -- Q3 2027 for Components 1-3, Q1 2028 for Components 4-5, \$3.4M budget, specific named milestones and owners -- so there's no ambiguity about what the new baseline actually is
- Have the sponsor open the steering meeting; a sponsor who opens with "I support this re-baseline" changes the political temperature of the room before you say a word

Watch out for:

- The version trap -- proposing a 10% budget increase, getting pushed back, descopeing to hold the number, then discovering six months later that the descopeed work was needed and returning to ask for the original number plus 5%; both parties end up worse off; be honest about budget the first time
- Overpromising the new baseline -- the new commitment has to hold; if you re-baseline and miss the new commitment too, you don't get a third chance
- Proposing a re-baseline the team hasn't seen -- component leads need to have helped shape it, or at minimum reviewed it before the steering meeting; dates that come from the TPM alone will not be defended
- Trying to re-baseline twice -- a second re-baseline signals a different problem: either the program isn't viable, or there's a leadership-level question that needs to be resolved before a third baseline would be credible
- Apologizing -- re-baselining is normal program management discipline, not a confession

Bottom line: A re-baseline holds trust when it frames changed conditions honestly, returns specificity equal to the original commitment, and arrives with sponsor backing already secured.

Field Note — Bringing a sponsor bad news

Field Note - Bringing a sponsor bad news

In short: Bringing bad news is a relationship event before it is an information transfer -- lead with what's wrong, state what you've already done, name what you need, and stop talking; the sponsor will do the rest.

Sooner or later you have to tell a senior leader something on their program is broken. The vendor missed a hard date. A key person left. A regulatory inquiry surfaced. The number you

committed to last quarter is no longer reachable. The technical job and the trust job are different jobs, and the second one is harder.

The framing problem

Most TPMs treat bad news as a status report -- comprehensive, calm, professional -- and the sponsor reads it as: you didn't think this was important enough to call me, or you're hiding the part you don't want to say, or you're more interested in having handled it than in solving it with me. Get the relationship part right and the rest is easier.

Vignette: Tariq Mensah, Senior TPM, infrastructure modernization at Bristol Financial

Tariq was 7 months into a 12-month infrastructure modernization. On a Tuesday morning his FIDO2 hardware vendor confirmed they could not ship buffer tokens in the window required to protect the August SOC 2 audit. M-008 (privileged FIDO2 enrollment) was going to slip 14 days. The vendor's explanation was structural -- supply chain consolidation across the FIDO2 industry. Not a one-off. His sponsor, Camille Beaumont (CISO), didn't know yet.

Tariq did three things before opening his laptop.

He drafted, in writing for himself, the three things he owed Camille:

- A direct statement of what was wrong (FIDO2 vendor cannot ship; M-008 slips 14 days)
- What he had already done (called the vendor's account exec, escalated to their VP of operations, identified two alternative paths)
- What he needed from her, specifically (decision on \$80K of contingency by end of week, or guidance to take a different path)

He chose the channel. Not email, not the regular 1:1. He scheduled a 25-minute meeting on her calendar that afternoon, titled "FIDO2 vendor - need 25 min." The act of requesting a special meeting was itself a signal that something needed attention.

He scripted the opening sentence and read it out loud. The first version was "So, I have an update on the FIDO2 situation" -- too evasive. The second version was "I want to walk you through some challenges" -- corporate-speak. The version he used: "I have bad news on FIDO2 and I need 25 minutes to walk you through it." Direct. Sets a time frame. Signals preparation.

In the meeting he led with that line, then walked through the three things in order: what's wrong, what he had done, what he needed from her. Then he stopped talking and let her process.

Camille's first reaction was harder than he expected. She asked sharply why he hadn't surfaced the vendor's earlier capacity update three weeks before. He had. She had missed it in the status report. He didn't argue the point; he said "I should have flagged it more directly. I

underestimated the trajectory and I won't do that again." He didn't apologize beyond that. He waited. After about 90 seconds of her processing, she shifted into problem-solving mode. They worked through the two paths he'd identified. She picked one. They agreed he'd come back with a recovery plan in 48 hours.

Camille approved the \$80K contingency draw the following week. The August SOC 2 audit window held. Tariq sent a written summary within four hours of the meeting -- five sentences covering what they discussed, what they agreed, what's next, who's doing what, and when. The conversation closed for him when he hit send.

The three things you owe a sponsor

A direct statement of what's wrong. Not buried, not preceded by context. The first sentence names the problem.

What you've already done about it. Sponsors don't want to be the first call. They want to be the call that gets made when the team has already taken reasonable action.

What you need from them, specifically. The most-skipped element. Not "I wanted to make you aware." A specific ask. If you don't know what you need yet, name that: "I'm not yet sure what I'll need from you. I wanted you in the loop now so we can react fast."

Channel selection

In person when you can. Bad news in a video call beats bad news in email. Bad news in a phone call beats bad news in Slack DM. Tone, pacing, ability to course-correct in the moment.

Same day. The interval between when you know and when the sponsor knows should be measured in hours, not days.

Direct, not through a chain. The sponsor needs to hear it from you, not your manager or their chief of staff.

Not in the regular 1:1. The regular 1:1 is for normal cadence; bad news interrupts the cadence. Schedule a separate meeting, even if it's 15 minutes. Tariq's "need 25 min" calendar request was itself a signal before the meeting started.

When the bad news is a budget number

Lead with the number, not the cause. "We're going to need an additional \$400K to deliver Component 4 as scoped." Then the cause.

Tie it to a decision the sponsor has authority over. "\$400K is above your single-drawdown threshold, so we need steering. Would you rather a one-time \$400K ask, or me modeling out the program through close and asking for the consolidated number?"

Be honest about what the number doesn't include. If \$400K covers Component 4 but Component 5 has a similar pattern coming, say so now. Don't drip-feed.

Show what you considered cutting. "I considered descoping the regulatory population; Compliance ruled that out. I considered delay-and-batch; the Cloud Migration dependency ruled that out."

Don't ask for budget you'll quietly underrun. Asking for \$400K when you need \$300K reads as gaming. The TPMs who get reputations for clean budget asks ask for what they need, no padding.

After the conversation

Send a written summary within four hours. Five sentences. What you discussed, what you agreed to, what's next, who's doing what, when. Confirms understanding, creates a record, gives you closure.

Don't litigate it with the team. Tell them the headline (sponsor is engaged, supports next steps, key dates are X and Y), not the texture. The texture is between you and the sponsor.

Moves that work:

- Script the opening sentence and read it out loud before the meeting -- Tariq rejected "I have an update on the FIDO2 situation" (evasive) and "I want to walk you through some challenges" (corporate-speak) before landing on "I have bad news on FIDO2 and I need 25 minutes to walk you through it," which set tone, time frame, and preparation signal simultaneously
- Schedule a special meeting -- not the regular 1:1 -- and title it specifically ("FIDO2 vendor - need 25 min"); the calendar request is itself a signal before the meeting starts
- Lead with what's wrong, then what you've already done (account exec called, VP of operations escalated, two alternative paths identified), then the specific ask (\$80K contingency decision by end of week); stop talking after the ask
- When the sponsor's first reaction is hard -- Camille asked sharply why the earlier capacity update hadn't been surfaced -- don't argue the point; say what you'll do differently, wait 90 seconds, and let them shift into problem-solving mode on their own

- Send a written five-sentence summary within four hours covering what was discussed, agreed, and who does what by when; the conversation closes when you hit send

Watch out for:

- Bringing the bad news and the recovery plan in the same meeting -- if you present both together, the sponsor has to react to the recovery plan instead of the news; two conversations (bad news now, recovery in 24-48 hours) is the right sequence except when an immediate decision is required
- Apologizing beyond a single brief acknowledgment -- "I feel terrible, I should have seen it sooner" puts you in defensive posture and forces the sponsor to manage your feelings on top of the problem
- Burying bad news after status updates -- bad news goes first if you have multiple things to discuss; leading with updates and saving the problem for last is a tell
- Drip-feeding on budget -- if \$400K covers Component 4 but Component 5 has a similar pattern coming, say so now; the TPMs who get reputations for clean budget asks ask for what they need, no padding, no sandbagging
- Promising more than you can deliver -- "I'll have it sorted by Friday" is not useful if you're not certain; better: "I'll have a recommendation by Friday, an executable plan by Tuesday"

Bottom line: Bad news delivered same day, by you, in a dedicated meeting, with a scripted opening and a specific ask is a trust-building act -- bad news delivered late, buried in email, or without an ask is a trust-destroying one.

Field Note — Taking over a strained program (the first 45 days)

Field Note - Taking over a strained program (the first 45 days)

In short: When you inherit a strained program, the Listen-Assess-Build pattern -- 10 days of structured listening, 10 days of rigorous assessment, 10 days of building the recovery with the team -- is what converts a 45-day window into a credible reset; skipping the listen phase is the most expensive mistake you can make.

This is a specific kind of role you will get called into a few times in your career: a TPM seat that opened up because the program needs a reset. The program itself is in trouble, the sponsor is uncertain, the team is exhausted, and there is a window -- usually 30 to 60 days -- to deliver something credible before patience runs out. The pattern is Listen-Assess-Build, structured across three phases over 45 days. The order of the phases matters more than any individual move within them. Most TPMs who fail in this situation fail because they skip the listen phase.

What "strained" actually means

A strained program isn't the same as a behind-schedule program. A behind-schedule program can still be in good operating health: the team is honest, the sponsor is engaged, cadence is intact, risks are visible, the schedule slip is a known thing being managed.

A strained program has a different quality. The cadence has broken down. Status reports have either stopped coming or stopped being honest. The sponsor has stopped asking detailed questions -- which usually means they have stopped trusting the answers. Component leads have stopped escalating because they don't believe escalations land. The RAID Log has stale entries. The Decisions Log has decisions that were made but never recorded. Steering hasn't met in weeks. The schedule may or may not be the actual problem. Sometimes the schedule is fine and the trust is gone. Sometimes the trust is fine and the schedule is unrecoverable. Most of the time, both are degraded. The first job is figuring out which is which.

Vignette: Renata Volkov, Senior TPM, security platform reset at Bristol Financial

Renata was 14 years into being a TPM when she was brought in to reset Bristol Financial's identity governance program at month 9 of an 18-month run. The previous PM had been moved

laterally; the team was exhausted; the sponsor (Sandra Park, CISO) was no longer asking detailed questions in the weekly status; the Steering Committee hadn't formally convened in 6 weeks. Renata had a window: roughly 45 days to deliver a credible reset before Sandra would have to escalate to the CIO.

She structured the work in three phases of 10 days each, with a Day 30 recovery plan delivery and a Day 45 cadence-running checkpoint.

Phase 1 -- Listen (Days 1-10). She read everything: charter, all amendments, the 5 component sub-charters, the templates pack, the workbook tabs (especially the stale ones), the SOWs, the audit briefings, every Steering pack, the Lessons Learned register. She talked to every component PM, the OCM Lead, the helpdesk champion, and the previous PM as a peer. Same opening every conversation: tell me about your component, what's working, what's slowing you down, what would help most. She was listening for what people didn't say. The component PM who couldn't articulate what was slowing them down was telling her something. The PM with a list of fifteen items had been carrying weight that should have been escalated.

She did not meet with Sandra in week 1. The instinct is to establish a relationship and signal action immediately. Renata had learned that sponsors don't need TPMs to perform engagement; they need TPMs to come with assessment. She sent Sandra a brief written update at end of Day 10 covering what she had found so far and confirming she'd come with a full picture on Day 19.

Phase 2 -- Assess (Days 11-20). Three full days of analysis with no external meetings. Output: a technical and operational gap analysis (SOW vs. reality, component by component, in matrix form), a reset risk register (top 8 risks needing sponsor attention), and the Day 19 sponsor meeting.

The Day 19 meeting structure: where the program actually was (matrix), top 8 risks with mitigation paths, what she had observed (system-focused, not people-focused), the recovery plan framework she was proposing (high-level, no committed dates yet), Sandra's pushback, what she'd deliver by Day 30. Renata set conservative expectations. She did not promise specific dates for major milestones in this meeting. The ask was: give me 10 more days to build the plan, and I'll bring you a credible commitment.

Phase 3 -- Build (Days 21-30). The recovery plan, built with the team. Workshops where component PMs proposed achievable dates with explicit buffer. Renata's job was to ask "what would it take to hold this date with confidence" and listen to the answer. The dates came from them; they would defend them.

She kept the operating model lean: daily standup (15 min), weekly delivery review (60 min), biweekly written status to sponsor, monthly Steering, quarterly audit briefing. No new tooling. The infrastructure the program already had was sufficient.

By Day 25, two visible quick wins were in place that weren't the recovery plan itself: the first daily standup had run, the first written biweekly status had landed, the first Decisions Log entry of the recovery period was filed. Proof the cadence was real, before the recovery plan presentation.

The Day 30 recovery plan was ratified by Sandra and Steering. Cadence held through Day 45 and beyond. The program landed in March 2027, three weeks after the re-baselined date. Renata stayed on as the TPM through close.

The judgment calls embedded in the timeline

Why no sponsor meeting in week 1. The exploratory conversation costs more than the engagement signal it provides. A sponsor in week 1 leaves the meeting feeling like they've added one more uncertain person to a program with too much uncertainty. A sponsor in week 3 with a full assessment leaves feeling like the program has stabilized.

Why quick wins land before the recovery plan. The recovery plan is a document. The cadence is a behavior. Sponsors trust behaviors faster than documents. Running the daily standup for a week before presenting establishes that the program is being managed differently. The plan ratifies what's already happening.

Why component PMs author the dates. If the TPM writes dates and asks PMs to confirm, PMs will confirm dates they don't believe in because confirming is socially easier than pushing back on a new TPM in week 5. If the TPM holds workshops where PMs propose dates with buffer, PMs own those dates.

Why no new tooling. Learning curves consume calendar time. In a 45-day window, calendar is the most expensive resource. Use what's there.

Why 8 risks, not 30. Sponsors absorb 5-8 priorities at a time. Bringing 30 risks communicates that you don't know which ones matter most.

Why framing matters. "The team has been struggling to keep up" lands differently from "the program structure didn't include a cadence to surface cross-component dependencies." Both might be technically true. The second invites problem-solving; the first invites defensiveness.

Moves that work:

- Delay the sponsor meeting until Day 19 -- a sponsor in week 1 leaves with one more source of uncertainty; a sponsor in week 3 with a gap matrix and top 8 risks leaves feeling like the program has stabilized; write a brief end-of-Day-10 update to hold the relationship in the meantime
- Hunt for what people don't say in the listen phase -- the component PM who can't articulate what's slowing them down is telling you something; the PM with fifteen items has been carrying weight that should have been escalated weeks ago
- Establish cadence behaviors before delivering the recovery plan document -- the daily standup, biweekly written status, and first Decisions Log entry all ran by Day 25; the Day 30 plan ratified what was already happening, which is faster trust than a document alone
- Have component PMs author their own dates with explicit buffer in workshops rather than confirming dates the TPM wrote -- PMs defend dates they proposed; they quietly disbelieve dates they were handed
- Present the top 8 risks to the sponsor, not 30 -- a list of 30 communicates that you don't yet know which risks matter most

Watch out for:

- Skipping the listen phase -- visible problems are not the actual problems; the actual problems live in the gap between what the team says and what the documents show, and you only see that gap by spending time in both; this is the most expensive shortcut
- Inheriting committed dates without re-validating them -- the previous PM may have committed to dates the team can't actually hit; keeping them to avoid looking like you slipped in your first 30 days guarantees a miss in your second 30 days
- Bringing the recovery plan before establishing the cadence -- the plan is a document; the cadence is the behavior; reverse the order
- Bringing component PMs into the Day 19 sponsor meeting -- the sponsor's response has to be honest, and an honest response in front of component PMs creates downstream political problems; that meeting is between the TPM and the sponsor (PMO Director optionally)
- Letting the cadence slip after Day 30 -- recovery plan approved, team tired, daily standup feels redundant; the cadence is what made the recovery work; the intensity scales down on Day 31, the discipline does not

Bottom line: The 45-day window is won in the listen phase -- get the assessment right before committing to anything, establish the cadence before presenting the plan, and the recovery document ratifies what's already happening.

Field Note — Building credibility in your first 30 days on a new project

Field Note - Building credibility in your first 30 days on a new project

In short: Credibility in the first 30 days is built by running the existing program at quality, delivering one small useful thing fast, and giving the sponsor a written summary - not a presentation.

The most common new-TPM situation is inheriting a healthy program: previous TPM moved laterally, team is healthy, sponsor is engaged, your job is to keep it that way. The first 30 days are about building enough credibility that the team's confidence in the program survives the change in TPM.

Credibility, in this context, is not the same as trust. Trust is built over months. Credibility is built - or lost - in the first few interactions. Credibility is the working assumption your team makes about you before they have data: that you're competent enough to do the job, honest enough to surface problems, and disciplined enough to run the cadence the previous TPM ran.

Maya Reyes, three years a TPM, was assigned to Bristol Financial's regulatory operations compliance modernization project at week 18 of an 18-month run. The previous TPM had moved laterally. The team was healthy. The sponsor was engaged. Maya's job was to keep it that way - and to build credibility with a team that hadn't chosen her, without overplaying her hand by trying to differentiate from her predecessor.

She did three things in the first 30 days that set the trajectory.

She didn't restructure anything. The team's existing rituals - standups, weekly reviews, the steering pack format - were working. Maya's job was to run them at the same level of quality, not to improve them. She watched two weekly reviews silently before chairing one. She read three months of steering packs before producing one. The format she eventually used was identical to the previous TPM's format. The team noticed she hadn't changed it. That was the point.

She produced a "first useful thing" in the first 10 days. Not a big move - a small one that made the team's life slightly easier. Maya noticed in 1:1s that three component leads were each individually escalating to the same VP about delays from a shared dependency team. The VP was getting three uncoordinated escalations; the dependency team was getting three competing priority requests. Maya didn't propose a new escalation framework or meeting cadence. She sent one email, jointly to the VP and the dependency team's lead, summarizing the three asks as a single consolidated request with one priority recommendation. The VP responded within an hour. The dependency team's lead thanked her for clarifying. The component leads didn't have to fight about whose escalation came first. Twenty minutes. It signaled more about how she'd run the program than any introductory speech could have.

She delivered the 30-day sponsor 1:1 as a brief written summary, not a presentation. The summary covered what she'd learned, what was working, what she was going to keep doing, what risks she'd surfaced, and what - if anything - she was considering changing in the next 30 days. The 30-minute conversation was the sponsor reacting to the summary. The sponsor spent most of it telling her she was glad the program was in good hands.

Six months later, Maya was running a second program for the same sponsor. The first program landed on schedule. Her standing with the regulatory operations group was solid. The credibility built in the first 30 days carried the rest of her tenure on the program.

The "first useful thing" has a specific character. It is not the first big thing. It is the first thing that makes the team's life slightly easier in a way that wouldn't have happened without you. Useful first things share three properties: small (completes in a day or two), visible (the team notices it happened), and compound (sets a pattern that will repeat). Consolidating three uncoordinated escalations into one - Maya's pattern - qualifies. So does writing a short FAQ for a recurring stakeholder confusion, surfacing a risk that nobody had explicitly named, or cleaning up the Decisions Log so the last 30 days are accurately captured. Restructuring the standup, replacing a template, proposing a new escalation framework, or anything that takes more than two days - those don't qualify.

The healthy-program sponsor needs reassurance that you won't destabilize. They need to see three things in 30 days: that you've understood what's working before changing anything (the most common failure mode is restructuring proposals in week three - even if technically better, the sponsor reads it as "she didn't take time to understand"); that you've identified the real risks by producing an updated risk register that surfaces things the previous TPM didn't have visibility into; and that you can run the cadence without it degrading.

Moves that work:

- Run the existing cadence at quality for at least two cycles before considering any changes - earn the right to improve before you improve
- Deliver the first useful thing in 10 days: small, visible, and compound (Maya's consolidated escalation email is the model)
- Deliver the 30-day sponsor 1:1 as a written summary covering what you learned, what you're keeping, risks surfaced, and any planned changes - let the sponsor react to the document, not to a presentation
- Read three months of steering packs and prior status reports before producing your own; match the format exactly

Watch out for:

- Trying to differentiate yourself from the previous TPM in week one - differentiation reads as insecurity, not strength; earn differentiation over months by doing the work well
- Over-scheduling 1:1s in the first two weeks with every adjacent stakeholder, vendor, and executive sponsor - prioritize the team first, the sponsor at week 4, adjacent stakeholders as situations require
- Confusing the credibility window with relationship-building - credibility in 30 days opens the door; trust in six months is built by doing the work well consistently

Bottom line: In a healthy-program transition, the new TPM's job is to run the existing program at quality, deliver one small useful thing inside 10 days, and give the sponsor a written brief at 30 days - differentiation comes from months of good work, not from conversations.

Field Note — Working with combative or uncooperative stakeholders

Field Note - Working with combative or uncooperative stakeholders

In short: Diagnose whether resistance is a real concern, performative pushback, or genuine non-cooperation before responding - the right move is different in each case, and getting the diagnosis wrong makes things worse.

Combative stakeholders are part of the work. The political dimension of program management is not separate from execution - it is execution, in cases where execution depends on people who don't want to do the thing.

Three patterns look similar from a distance and require different responses. Getting the diagnosis wrong means the response makes things worse.

Resistance with a real concern is someone who doesn't want to do the thing because doing it is genuinely problematic for them - their workload, their roadmap, their compliance posture, their relationships with their own users. They're not opposed to the program; they're opposed to the cost of compliance with the program. The right response is to surface the concern and address it.

Performative resistance is someone signaling resistance to maintain a position or relationship, but not actually opposed to the underlying work. They need to be on record as having pushed back; they don't need to win. The right response is to give them the space to push back without making the program flex on the substance.

Genuine non-cooperation is someone who doesn't want the work to happen and is willing to obstruct it. Less common than the other two but real. The right response is escalation through the appropriate channel - but only after diagnosis.

Casey Morrison was six weeks into the ZTNA rollout on Atlas when three application owners refused to install required ZTNA connectors on their workloads. Two were missing meetings. One had escalated a complaint to his VP about the program's "lack of consultation" - which was specious: the consultation had happened, his designate had attended, and the requirements had been signed off. None of this was on the schedule. All of it was real.

Casey did three 1:1 conversations, one per owner, and listened for the diagnostic signal.

The first owner had a real concern. Her application had a regulatory data residency requirement that the standard ZTNA configuration didn't address. She wasn't refusing the program; she was refusing a configuration she couldn't legally accept. Casey worked with the architecture team to add a regional gateway configuration to her component. Two weeks of additional engineering work, but it unblocked the resistance and her team installed the connector. Casey didn't argue the program's rationale. She heard the concern, addressed it, and the resistance dissolved.

The second owner was performative. He wanted to be on record as having pushed back because his director had recently questioned why his team had agreed to "yet another security tool" without more analysis. He needed the visible pushback; he didn't actually oppose the work. Casey listened, acknowledged the bandwidth concern, and asked: "If we structured this as a phased rollout - two weeks of testing in stage before production - would that work?" He said yes. Casey wrote a follow-up email confirming the phased approach, copied his director, and the work proceeded on the original timeline (the "two weeks of testing in stage" was already in the plan). The director saw evidence of considered pushback; the owner saw evidence of program flexibility; the program lost no time.

The third owner was genuine non-cooperation. He didn't want the program to happen and was using "lack of consultation" as cover. Casey didn't try to win the conversation. She named the level mismatch directly: "I want to make sure this gets addressed at the right level. Should we set up time with your VP and Sandra Park together?" He declined and instead committed to the connector installation by end of next sprint. He held to that commitment because he didn't want the level mismatch surfaced.

All three components installed connectors within the next four weeks. The program held to the Wave 2 schedule. Casey did not need to escalate the third owner; the offer to escalate was the move that produced the cooperation.

When a senior stakeholder is resistant, the instinct to bring your manager into the conversation often makes things worse - now there are two people the VP is irritated with, and the relationship has been moved up a level without the underlying issue being addressed. Name the level mismatch directly instead. If a senior stakeholder is refusing engagement, document the request, the response (or lack of response), and the program impact in writing - not as ammunition, but as record-keeping. When program commitments slip because of this stakeholder's non-cooperation, you need the record to be clean.

Moves that work:

- Open with their stake, not yours: "I want to understand what installing this connector means for your team. What changes for you?" - this is not manipulation; it surfaces information you genuinely need
- Get the diagnosis right before responding: one 1:1 conversation per resistant stakeholder, listening for whether it is a real concern, performative resistance, or genuine non-cooperation
- Be willing to lose small to win the relationship - if the connector installation can wait two sprints, or the scope can be phased, flex when flex is the right answer; this builds the relationship capital to be firm when firm is required
- Name the level mismatch directly with genuinely uncooperative senior stakeholders: "Should we set up time with your VP and [sponsor name] together?" - the offer itself often produces cooperation without requiring follow-through

Watch out for:

- Treating resistance as an attack - most resistance is a stakeholder doing their job from their angle; treating it as combative escalates a normal disagreement into a real conflict
- Trying to overpower with rationale - the program's rationale is fine; the stakeholder isn't refusing because the rationale is bad, and more rationale doesn't address the actual concern
- Escalating before diagnosing - escalation without diagnostic damages relationships and rarely produces durable resolution

Bottom line: Three different resistance patterns require three different responses, and the diagnostic 1:1 - listening before responding - is the move that makes the difference.

Field Note — When your sponsor goes quiet

Field Note - When your sponsor goes quiet

In short: Sponsor disengagement is usually about something larger than the program - observe before reacting, run the diagnosis, make the program easier to support, and do quiet succession planning regardless of cause.

Sponsor going quiet is one of the most common and most consequential leading indicators in program management. Also one of the least discussed, because it's hard to write about. There's no decisive moment. There's no clear action to take. The signals are subtle, the causes are usually not about you, and the wrong response makes things worse.

"Going quiet" takes specific forms. The 1:1 that used to run an hour runs forty-five minutes, then thirty. The sponsor's questions get less specific. They stop pushing back on details; they start summarizing what you said before you've finished saying it. The targeted questions about specific risks, specific decisions, and specific stakeholder dynamics give way to "how are things going overall?" The Slack message that used to get a response in an hour takes a day; the email sits for two days, three days, a week. Decisions that the sponsor used to make quickly now require additional consultation and additional input.

Diane Okafor's program had been running well. Twelve years into being a TPM at Bristol Financial, she'd seen most of what programs do. This one - a \$2.1M security audit modernization, nine months in, three months from close - was textbook. Status reports green. Steering committee engaged. No material risks. Then her sponsor's 1:1s started getting shorter. Not skipped, not canceled - just shorter. Forty-five minutes became thirty. Thirty became twenty. The detailed questions stopped. The "let me know if you need anything" sign-off appeared. Diane could feel something shifting before she could name it.

She did four things over the next three weeks.

First, she observed before reacting. Two more 1:1s passed. The pattern held - shorter, less detailed, more general. She didn't email her sponsor asking if everything was okay. She didn't try to win back engagement by surfacing more issues. She watched.

Second, she ran the diagnosis. The disengagement could be about her, about the program, or about something larger than either. She gathered three data points: her sponsor had been pulled into a major regulatory inquiry from another business unit (visible in calendar conflicts); the CISO's overall portfolio had grown by 30% with the addition of a new acquisition (mentioned in a town hall); and her sponsor's manager had recently asked the CISO to take on a board-level cybersecurity disclosure committee. Three things competing for sponsor attention. None of them were about Diane or the audit modernization program.

Third, she made the program easier to support. She started sending a 5-sentence Monday morning summary to her sponsor: where the program is, top risk this week, decision needed by Friday (if any), nothing else. Async. No need for sponsor to schedule a meeting. The sponsor could process in two minutes whether to engage further. The Monday summary became a load-bearing piece of communication for the rest of the program.

Fourth, she did quiet succession planning. She built a relationship with the Director of Risk Operations - a peer of her sponsor who knew the program at high level and would be a credible alternative sponsor if needed. Not a backup; just a relationship. Built through small interactions: copying the Director on a relevant decision, asking their opinion on a topic in their domain, including them in a steering observation. She also documented the program's strategic context - why it existed, what business outcome it served, who depended on it landing - in a one-page brief separate from the execution status. If a sponsor transition happened, the new sponsor could absorb the strategic context fast.

Diane's sponsor remained engaged at the lighter cadence for the rest of the program. The program landed on time, on budget, on scope. The Monday summary practice continued past close - the sponsor mentioned in the closeout retrospective that it had been one of the most useful pieces of communication on the program. The Director of Risk Operations Diane had built a relationship with subsequently sponsored a follow-on Phase 2 program with Diane as TPM.

The diagnosis has three branches. The most common is about something larger than the program - a competing program, an organizational change, a personal situation, an executive-level pressure. Make the program easier to support, expect the engagement to return when the larger thing resolves, and don't try to compete for attention. Less common but real is disengagement about the program itself - the sponsor has lost confidence in a specific decision, an ongoing risk, or a stakeholder dynamic. Surface it directly: "I noticed the conversation has shifted recently. Is there a concern about the program I should be addressing?" Rare but possible is disengagement about you - the sponsor's questions are still detailed but the tone has shifted, you've been excluded from conversations you used to be in, or your manager mentions feedback from above that doesn't match your self-assessment. This is a different conversation, probably with your manager rather than with the sponsor directly.

Quiet succession planning is the underappreciated discipline. Senior TPMs running programs with quiet sponsors should be doing this even when there's no clear evidence the sponsor is leaving - not as a paranoid hedge, but as normal program management. Build a relationship with one peer of your sponsor. Document strategic context, not just execution status: why the program exists, what business outcome it serves, who depends on it. Know your program as a story, not just a metric set - if a new sponsor asks "what's this program really about and how's it going," you should be able to answer in five sentences.

Moves that work:

- Observe at least two more cycles before reacting to early quieting signals - most disengagement resolves without intervention once the competing pressure passes

- Make the program easier to support when sponsor bandwidth is constrained: Diane's 5-sentence Monday morning summary (where we are, top risk, decision needed by Friday if any) is the model - async, processable in two minutes
- Run the three-branch diagnosis explicitly: is it about something larger than the program, about the program itself, or about you? The response is different in each case
- Do quiet succession planning proactively: one relationship with a sponsor peer, a one-page strategic context brief separate from the execution status

Watch out for:

- Escalating to your own manager during the early phase unless the program is materially at risk - surfacing "my sponsor has been disengaged" usually creates problems rather than resolving them, as the sponsor may feel exposed and pull back further
- Competing for attention by surfacing more issues, scheduling more meetings, or sending more updates to "re-engage" - the sponsor's bandwidth is constrained by something external, and more demands on it don't help

Bottom line: When a sponsor goes quiet, the first move is observation, not action - diagnose the cause, make the program easier to support, and build the succession relationships you should have been building anyway.

Field Note — Working across cultures and seniority lines

Field Note - Working across cultures and seniority lines

In short: Cross-cultural and cross-seniority work requires reading two dimensions simultaneously - create separate low-stakes channels for what won't be said in the room, and use direct invitation to surface what deference suppresses.

Working across cultures and seniority lines suffers from being written about in generalities. The platitudes are well-known: communication styles vary, "yes" doesn't always mean agreement, decision-making norms differ. True, but not useful. What helps is specifics - the situations you'll actually encounter, the moves that work, and the moves that look right but make things worse.

Two dimensions interact in every cross-cultural, cross-seniority interaction and should be treated separately. Cross-cultural work is about communication norms, decision-making patterns, conflict styles, and what gets said directly versus indirectly. The variance is real and it's not about better-or-worse - it's about different default assumptions about how people coordinate work. Cross-seniority work is about authority, deference, voice, and who gets to push back on whom. The two dimensions interact: a direct disagreement in a US team might be a normal Tuesday; the same exchange between a London VP and a Bangalore manager might land as career-affecting. The discipline is reading both dimensions in every interaction.

Twelve years ago, in his first global program, Raj Mehta was running a compliance modernization with workstreams in New York, London, and Bangalore. In a steering meeting, a Bangalore-based engineering manager said "yes, we can deliver by the end of the quarter" in response to a US-based VP's ask. Raj logged it as a commitment. Three weeks later, the same engineering manager privately told Raj that the team had concerns about the timeline that hadn't been voiced in the meeting. Raj's mistake hadn't been trusting the "yes." His mistake had been not creating a separate, lower-stakes channel where the engineering manager could surface the concerns later.

What Raj built into his subsequent global programs:

Get verbal commitments, then get written commitments separately. The written confirmation gives the person a chance to revise without the social cost of public disagreement. In the meeting: "thanks - I'll send you a quick written summary of what we agreed and I'll need your sign-off on the dates by Friday." Not a trust issue - a process that respects the gap between meeting-room language and operational reality.

Schedule 1:1 follow-ups specifically to surface what wasn't said. After group meetings with cross-cultural groups, the most useful conversation is often the 1:1 the next day with someone who didn't say much in the meeting. Open with: "I wanted to check on the timeline we discussed. What's your honest read on whether the team can hit it?" The phrase "your honest read" signals you're inviting candor.

Watch for the "yes, but" that doesn't get said. Sometimes you'll see body language or tone that suggests there's a "but" coming, and the person stops at "yes." Don't push in the meeting. Make a note. Find them privately afterward.

Over the next twelve years across three global programs, Raj used these patterns and never again confused public assent with operational commitment. The Bangalore-based engineering manager from his first program eventually became a peer he works with regularly - the relationship was strengthened, not damaged, by Raj treating the original "yes" as the start of a conversation rather than the end of one.

Cross-seniority dynamics layer onto cross-cultural ones. The senior person in the room sets the conversation's tone; junior people calibrate to what the senior person seems to want. This is true across cultures but more pronounced in cultures with stronger hierarchical defaults. Two situations worth naming: when a senior person says something incorrect in a meeting, the right move depends on the stakes - if the inaccuracy will affect a decision, surface it carefully ("I want to make sure I understood - when you said X, did you mean..."); if it's incidental, let it stand and follow up offline. When a junior person has critical information the senior person needs but may not volunteer in the meeting, ask directly: "We haven't heard from [name] yet - what's your read on this?" Direct invitation overrides default deference; the junior person can speak because they were asked, which is socially safer than volunteering.

The TPM is often the person in the room with the most cross-cultural visibility - they've talked to everyone individually and they see the gap between what's being said publicly and what's been said privately. The job is making the private context visible without violating the trust of the people who shared it.

A junior US-based TPM working with a senior India-based engineering lead is navigating both dimensions at once. Acknowledge the seniority directly, once: "I appreciate you taking the time to work with me on this - your experience with [domain] is exactly what we need." Done sincerely, this acknowledges the asymmetry without performing deference. Don't repeat it. Bring substantive value to the relationship - senior engineers respect TPMs who add to their work, not TPMs who manage around them. The TPM's value to a senior engineer is the surrounding work the engineer doesn't want to do: stakeholder management, dependency mapping, communication. Don't perform expertise you don't have; senior engineers detect this immediately and lose respect quickly.

Cross-cultural programs often span time zones. Use async writing as the substantive channel - synchronous meetings work for connection and decision; asynchronous writing works for sharing context that everyone can absorb on their own time. Programs that try to do all coordination synchronously across many time zones burn out the people on the worst-time-zone end. Be explicit about which decisions need synchronous discussion versus which can happen async - most decisions can be made async if the framing is clean; reserve synchronous time for escalations, contentious calls, and relationship-building.

Moves that work:

- After group meetings with cross-cultural teams, schedule a 1:1 follow-up with someone who said little - open with "what's your honest read" to signal you're inviting candor that the meeting format suppressed
- Get verbal commitments, then get written sign-off separately - the written step gives people a chance to revise without the social cost of public disagreement

- Use direct invitation to surface critical information from junior participants: "We haven't heard from [name] yet - what's your read on this?" overrides default deference more reliably than open questions to the group
- Acknowledge seniority directly once at the start of a seniority-mismatched relationship, then shift immediately to substantive value

Watch out for:

- Treating "we communicate the same way" as the norm - the norm at headquarters isn't the norm everywhere, and the TPM whose default is "everyone should communicate the way I do" produces silence from people who communicate differently
- Mistaking politeness for agreement - many cultures default to politeness in disagreement, and the polite response is not the same as the consenting response; surface what you think you heard and ask for written confirmation
- Assuming the senior person on the other side speaks for everyone - they may speak for a position the team hasn't really agreed on, and the gap shows up in execution

Bottom line: "Yes" in some cultures means "I have heard you" or "I will not openly disagree in this setting" - none of these are deceptive, and the discipline is building channels where the actual concerns can surface without social cost.

Field Note — Recommending prioritization with data

Field Note - Recommending prioritization with data

In short: The framework produces a structured conversation, not the answer - lead with outputs, show inputs with confidence levels, make close calls explicit, and when stakeholders push back, ask which assumption they think is wrong.

Data-driven prioritization works when you let the data inform judgment, not replace it. Frameworks like RICE, MoSCoW, ICE, weighted scoring, and value-vs-effort matrices share a structure: take inputs that vary in quality, run them through a calculation, produce a ranked output. The output looks objective. It isn't. The objectivity is borrowed from the math, but the math is operating on inputs that are often best-guesses dressed up as measurements. The skill is knowing when the score is credible and when it's giving you false precision.

Marcus Chen runs the quarterly portfolio review for Bristol Financial's security PMO. Twenty active programs across five domains, \$24M aggregate budget, the eternal question of what gets funded next quarter and what waits. Eight years into the work. The Q3 review had to recommend funding for 8 of 14 candidate programs that together exceeded the budget envelope by 60%.

Marcus structured the inputs carefully, because most prioritization failures happen at the input stage, not the calculation stage.

For Impact, he separated the variable into measurable components: revenue impact (with explicit assumptions about volume), cost impact (operational savings traced to specific budget lines), risk reduction (modeled in financial terms, not qualitative), and strategic alignment (smaller weight, since most subjective). When a component couldn't be measured, he said so explicitly. The score was more credible when it admitted its uncertainty.

For Effort, he asked engineering teams not "how long will this take" but "how long will this take given everything else you're doing." The answers were different. He included context-switching cost, dependencies on other teams, and the cost of starting - which for security work often dominates the total cost of doing.

For Confidence - the most underused input - he asked for each input "how sure are we" and weighted accordingly. Programs with low-confidence high-impact estimates were derisked through phased delivery before committing the full investment. He used ranges instead of point

estimates for the uncertain inputs. A program whose impact was "between \$2M and \$8M depending on adoption rate" was different from one whose impact was "\$5M."

When he presented to the steering committee, he led with the framework output but did not stop there. He showed the inputs side-by-side with their confidence levels. He named which programs had high-confidence rankings (top 4) and which were genuinely close calls (programs 5-8 had overlapping confidence intervals on impact). He made the recommendation specific: fund the top 4 confidently, fund 5 and 6 with phased commitments that derisked the impact uncertainty, defer 7-14.

When a stakeholder pushed back on program 6's ranking - wanting program 9 funded instead - Marcus didn't argue the framework score. He asked what assumption about program 9 would need to be true for it to outrank program 6. The conversation surfaced that program 9's sponsor had a more aggressive adoption assumption than the framework had captured. They updated the input, re-ran the score, and program 9 moved to position 6.

The committee approved the recommendation with one substitution (9 in, 6 out). The substitution was data-driven, not political. The framework didn't produce the right answer; the framework produced a structured conversation that produced the right answer. Marcus's standing with the committee went up because the framework hadn't been treated as a black box.

Frameworks are good at surfacing assumptions, structuring debate, producing defensible rankings, exposing disagreements about weighting, and creating a record. They make it harder for the loudest voice in the room to determine priority by default. They do badly at one thing: precision. When a program scores 4.2 on impact and another scores 3.7, the difference is meaningful only if the underlying measurements are accurate to one decimal place, which they almost never are. Treat the score as the starting point for the conversation, not the conversation's conclusion. When two programs score within 0.5 of each other on a 5-point scale, they're tied for prioritization purposes - treat them as such.

Three common pushback patterns arise. "The score doesn't capture [factor]" - sometimes true; the right response is to ask whether the factor can be added as an input with weighting, or whether it's qualitative judgment that should override the score; either is acceptable, pretending the score covers it isn't. "The weights are wrong" - the weights are always somewhat arbitrary; show the score with alternate weights and see if the ranking changes; if the ranking is robust across reasonable weight choices the recommendation holds, but if the ranking flips, that deserves explicit conversation. "The score is too low because we know this is important" - this is the riskiest pushback because it's often political rather than substantive; the right response is to ask which input the stakeholder thinks is wrong; if they can point to a specific input, that's a legitimate update; if they can only say "this matters more than the score shows," that's a request to override the framework, which is acceptable but should be made explicit.

Moves that work:

- Separate Impact into measurable components (revenue impact with explicit volume assumptions, operational cost savings traced to specific budget lines, risk reduction modeled financially) and explicitly flag components that can't be measured - transparency about uncertainty makes the score more credible, not less
- Ask effort questions in context, not isolation: "how long will this take given everything else your team is doing" produces different and more accurate answers than "how long will this take"
- Use confidence as a first-class input: assign ranges (e.g., "\$2M-\$8M depending on adoption rate") rather than point estimates for uncertain inputs, and derisk low-confidence high-impact programs with phased commitments rather than full investment

- When a stakeholder pushes back on a ranking, ask what assumption would need to be true for their preferred program to outrank the current leader - this moves the conversation from political to data-driven

Watch out for:

- Presenting the framework output as the recommendation - the output is data; the recommendation is your judgment informed by the data; sponsors who hear "the framework says we should fund X" lose confidence faster than those who hear "based on the framework and these specific factors I'm weighting separately, I recommend X"
- Hiding inputs - if the inputs are presented at all, present them transparently with sources, confidence levels, and ranges where applicable; hidden inputs damage trust when they surface later
- Letting one decimal place pretend to be a meaningful difference - two programs within 0.5 of each other on a 5-point scale are tied, and should be treated as close calls requiring explicit conversation about the deciding factors

Bottom line: The framework reveals disagreements and structures the conversation - it doesn't settle disagreements, and the recommendation is always your judgment informed by the data, not the data speaking for itself.

Field Note — Reprioritizing mid-program

In short: Reprioritization mid-program is always expensive — the cost just hides in context-switch tax, sunk work, and communication overhead — so the discipline is to model the cost explicitly, bundle changes, and move only when the benefit clearly exceeds what you can quantify.

The cost of reprioritization is real but invisible. Most reprioritization mid-program looks costless on paper: you move work A in front of work B, the schedule rearranges, the team adjusts. In practice it is expensive. The cost just does not show up where you expect it.

There are four places it shows up. First, context-switch tax: an engineer halfway through complex work who has to set it aside does not just lose the time they would have spent finishing; they lose context, and resuming costs extra time on top. For complex security and infrastructure work, the context-switch cost can be 20-40% of the original effort. A two-week piece of work paused and resumed three months later is not a two-week piece of work anymore. Second, sunk cost on in-flight work: work that is 60% done is not 60% valuable when paused. Some of it is partial implementations that will not run, partial test coverage that will not validate, partial documentation that is incomplete. Pausing usually means treating that work as either abandoned or as a future cost to resume. Third, communication cost: every reprioritization involves re-explaining the program to dozens of people — steering committee, component PMs, stakeholders whose roadmaps depended on the original priorities, vendors with SOWs, compliance teams whose audit prep depended on specific delivery sequencing. The cumulative cost across a program with 30+ stakeholders can easily be a person-month of TPM time, none of which produces program output. Fourth, trust cost with the team: a team that gets reprioritized often starts to discount future commitments because they have learned priority is volatile — less urgency on near-term work, more padding in estimates, less enthusiasm for extra effort. Hard to measure, but real, and it compounds.

In April 2026, eight months into Project Atlas, Casey Morrison got a calendar invite from Linda Walsh's office. Bristol Financial's Cloud Migration program had been pulled forward eighteen months — from Q4 2027 to Q4 2026 — to align with a board-level commitment to data-center exit. The acceleration created a downstream dependency on Atlas: Components 1-3 (IDP, ZTNA, MFA) would now need to be production-ready by the new Cloud Migration date. Components 4-5 (PAM, Access Review) were no longer time-bound by the same constraint.

The question was not whether to reprioritize. The dependency was real and the date was non-negotiable. The question was how to do it without the cost of the reprioritization eating the benefit.

Casey ran a disruption-cost model before committing — the same analytical discipline she applied to "+2 weeks" cascade analysis. Three parts. What was currently in flight: K. Reddy's PAM design work was 60% complete; pausing it would mean partial implementations that would not run, partial test coverage that would not validate, and a context-switch cost to resume in Q4. Casey estimated 3 weeks to resume the PAM work plus the sunk cost on partial implementation. What dependencies were affected: twelve downstream stakeholders had plans depending on the original sequencing, three vendors had SOWs tied to specific deliverables in specific order, and the communication cost across all of them was real — Casey estimated 1 person-week of TPM time across the rebaselining communications. What the program got in return: meeting a hard external date worth multi-millions in business value, plus alignment with a board-level commitment.

Casey's analysis: 4-5 weeks of cumulative team velocity cost (context-switch tax + sunk cost on PAM design + communication cost) in exchange for the dependency satisfaction. Decision was clear. But the analysis surfaced something useful: pausing PAM design mid-stream would cost 3 weeks to resume. That cost got logged explicitly in the rebaseline so it would not surprise anyone later.

Casey also held the changes for one bundle. Linda Walsh had mentioned two other potential reprioritization triggers in passing — a regulatory inquiry and a vendor renegotiation. Rather than reprioritize three times, Casey absorbed those as watch items and bundled them into a single rebaseline with the Cloud Migration trigger. One disruption instead of three.

The communication landed clean. Casey led with the external cause: "Cloud Migration was accelerated to Q4 2026. This creates a downstream dependency on Atlas Components 1-3 that did not exist when we approved the original plan." She was specific about what was changing: Components 1-3 forward, Components 4-5 deferred, original Q3 2027 program close unchanged. She was specific about the cost: 4-5 weeks of cumulative velocity, justified by the new dependency. She acknowledged the cost to K. Reddy's team explicitly: "Pausing the PAM design work mid-stream represents real cost. The disruption is being driven by external conditions, not by anything internal."

The reprioritization landed as discipline, not panic. K. Reddy's PAM design baseline survived the pause and resumed cleanly in Q4. The accelerated Components 1-3 hit the new Cloud Migration dependency date. The bundling kept the disruption to one event instead of three across the year.

Reprioritization is justified in three categories: external hard constraints (regulatory deadline change, customer commitment shift, cross-program dependency change with a hard date); material new information about scope (discovery that a deprioritized item is more important than originally scoped, new risk that affects sequencing); and material new information about effort (original estimate for a high-priority item turns out wrong by a meaningful multiple). The bar in every case is that the benefit must clearly exceed the cost once the cost is modeled honestly.

Reprioritization is not justified when it is anxiety-driven (a senior stakeholder is uncomfortable, the TPM reorganizes priorities to signal action without changed conditions), when it chases the new shiny thing (a newer initiative gets attention without being a genuinely higher priority), or when it responds to stakeholder lobbying without substantive cause (capitulating to pressure rather than new information produces precedent that compounds).

Most reprioritization happens in trickles. Senior stakeholder asks for an adjustment in week 12. Different stakeholder asks for another in week 15. Conditions change in week 18. Each adjustment is small, so each cost looks small. The cumulative cost of three small

reprioritizations is much higher than one larger reprioritization that combines them. The discipline is bundling: absorb changes as watch items until the next steering cycle, then do a single rebaseline that addresses them together. One disruption instead of three. The bundling has limits — if a trigger is genuinely urgent (a hard regulatory deadline change), it may need to move ahead of the bundling cycle. Most triggers are not that urgent.

Moves that work:

- Run a three-part disruption-cost model (in-flight work, downstream dependencies, return value) before committing to any reprioritization, as Casey did with K. Reddy's PAM design pause and the 4-5 week velocity cost
- Bundle multiple triggers into a single rebaseline cycle rather than reprioritizing incrementally; Casey absorbed a regulatory inquiry and a vendor renegotiation alongside the Cloud Migration trigger into one event
- Lead the communication with the external cause ("Cloud Migration was accelerated to Q4 2026"), be specific about what is changing and what is not, and acknowledge the cost to the team explicitly

Watch out for:

- Reprioritizing in the same conversation as the trigger — cost analysis has not happened, team was not consulted, downstream stakeholders were not considered; allow at least 24 hours of analysis before committing
- Treating each request as independent when three reprioritization requests in a quarter are a pattern, not three separate events
- Reprioritizing without rebaselining — schedule and order change but overall commitments stay silently unchanged, which surfaces as "scope did not fit" slippage later
- Underselling cost to the team; the team always knows the cost is real even when officially minimized, and calling a meaningful disruption a "minor adjustment" damages credibility

Bottom line: Model the cost in full before you move, bundle when triggers accumulate, lead with external cause, and acknowledge what it costs the team — reprioritization done this way lands as discipline rather than panic.

Field Note — Negotiating scope with engineering when timeline is fixed

In short: The question "what can we cut?" puts engineering on the defensive and produces resistance; the reframe "what does success look like at minus 30%?" opens a generative conversation where engineering designs the right answer rather than defending against subtraction.

The instinct most TPMs have in this situation makes it harder. Asking "what can we cut?" implies cutting is the goal, that engineering should produce a list of things they are willing to give up, that the conversation is about subtraction. Engineering teams hear that question and become defensive — partly because they do not want to cut, and partly because they know the things that look easy to cut are often load-bearing in ways that are not obvious from the outside. The question produces the wrong posture.

The reframe that works: "What does success look like at minus 30%?" The shift is from subtraction to redefinition. Instead of asking engineering to give up specific items, you are asking them to imagine a smaller version of success and tell you what that version looks like. Engineering teams know better than anyone what is load-bearing in their work — which features depend on which, which abstractions can be simplified, which polish items are nice-to-have, where complexity hides. The "what can we cut" question puts them in a posture where they can only lose. The "smaller version of success" question puts them in a posture where they are designing the right answer.

Sarah Kim's project at Bristol Financial had a date that was not moving. The OCC's revised data privacy rule had a compliance deadline, and Bristol's response had to be production-ready by then. Six months out, the engineering team had completed their detailed scope assessment. The original scope was not going to fit. Something had to come out, and the engineering lead had said in a working session that he did not see what could be cut.

Sarah ran the conversation with her engineering lead a second time, two days later, with different framing. Same constraint, different question: "If we had to deliver something for this deadline that addressed the regulatory requirement at minus 30% capability, what would that look like?" The conversation that followed produced a list of compromises the engineering lead would never have offered in response to "what can we cut":

- Some integrations could be deferred to Phase 2
- The administrative UI could ship at minimum-viable instead of polished
- Two of the four reporting capabilities could be sequenced into a follow-up release
- Architectural complexity could be simplified by deferring multi-tenancy support

The engineering lead was not being cooperative the second time and uncooperative the first time. The frame was different.

Then Sarah and the engineering lead ran a must-vs-want exercise together. They started with the regulatory text — not the high-level summary that had been circulating, but the actual OCC rule. The text constrained less than the summary had suggested. Some features the team had been building toward were not actually required. They mapped each candidate feature to a specific aspect of the requirement; items that did not map to a specific requirement were usually scope expansion that had crept in during planning, and they came out without affecting compliance. They distinguished "this is required" from "this is the way we would build it if we had time." The regulator required a privacy disclosure mechanism. The team had been planning a polished, integrated, multi-channel disclosure system. The minimum compliant version was a single-channel disclosure with manual workflow integration; the integrated multi-channel version went to a follow-up release.

The reduced scope hit the regulatory deadline with two weeks of buffer. Phase 2 — the deferred capabilities — shipped four months later. Sarah's relationship with the engineering lead strengthened; he had been a partner in the scope reduction, not its target.

Three reasons "what can we cut" backfires with engineering: it implies cutting is the goal and reframes their work as a problem to be reduced; it puts the cost on them (smart engineers learn not to volunteer things they will get blamed for cutting later); and it treats their work as fungible units when some items are load-bearing in ways the TPM cannot see from outside. The reframe addresses all three.

When the engineering team genuinely believes minus-30% is not possible, check three things before accepting that. Is the team optimizing for the right deliverable? Their mental model of success may not match the regulatory or business requirement. Is the estimate honest? Engineering estimates often include buffer for things that will not materialize; ask "if we discovered we had only 50% of the time we estimated, what would we actually do?" Is there a structural constraint the team has not surfaced? Sometimes resistance traces to a dependency, a vendor commitment, or an architectural choice the team feels stuck with — surface those, because they may be negotiable.

Moves that work:

- Reframe from "what can we cut" to "what does success look like at minus 30%?" to shift engineering from a defensive posture to a generative one, as Sarah did with her engineering lead at Bristol Financial

- Read the actual regulatory or requirement text together with engineering — not the summary — because the text often constrains less than summaries suggest, surfacing features the team had been building that were not actually required
- Run the must-vs-want exercise with engineering as a joint exercise, mapping each feature to the specific requirement it addresses, distinguishing requirement from implementation choice

Watch out for:

- Doing the must-vs-want exercise to engineering rather than with them; it works only when engineering is generating the answer, not defending against the TPM's proposed cuts
- Promising "we will do the deferred items later" without committing to a Phase 2; if the deferred items genuinely matter, name a Phase 2 program with explicit funding, or the team correctly hears "deferred" as "cut without admitting it"
- Conflating scope reduction (removing features) with quality reduction (shipping the same features at lower polish); they are different choices with different consequences, and being explicit about which one you are doing matters

Bottom line: The reframe from subtraction to redefinition is not a trick — it puts engineering in the posture where their knowledge of what is load-bearing actually gets used, and scope reductions made this way are more durable because engineering was the author.

Field Note — Negotiating with vendors when the SOW is failing

In short: Most SOW failures are structural — wrong original scope, bad internal handoff, or dependency blocks the internal team created — so the first move is always diagnosis, the negotiation has to match the actual cause, and pressure on the vendor's project team fixes almost nothing.

SOW failure is common, structural, and rarely solvable through pressure on the vendor's project team. When deliverables start slipping, the natural framing is "the vendor is failing to perform." Sometimes that is right. Often it is not. Three structural causes look exactly like vendor performance: the original scope was wrong (the SOW described the work in terms that turned out to be ambiguous or incomplete, discovery surfaced complexity nobody priced in, and the vendor is doing reasonable work — just more of it than the SOW assumed); the handoff was bad (the internal team did not fully convey context, critical decisions were made before the vendor was engaged and never communicated, and the vendor is operating from a different mental model than the internal team); and the dependencies the vendor needed were not provided (credentials, data, environments, or decisions the internal team was supposed to provide, still outstanding). These structural causes are probably more common than actual vendor performance issues.

Tomás Aguilar's vendor situation did not start as a problem. Six months into a security architecture engagement, kickoff had been clean — clear SOW, named team on the vendor side, defined deliverables, agreed milestones. Two months in, things were on track. By month four, the slip was visible: deliverables late by a week, then two, then three. By month six, the vendor's project manager had been reassigned and the new one was still ramping. The SOW was failing.

Tomás asked three diagnostic questions before talking to the vendor's account executive. When did the slip start, and what changed at that point? The slip had started immediately after a scope expansion in week 8 — the internal team had asked the vendor to extend the engagement to cover an additional architectural domain; the SOW had not been formally amended; the work had been added on a handshake. The cause was traceable: scope had grown without budget or timeline growing with it. Was the vendor blocked on anything Tomás's team owed them? He pulled the dependency list and walked it with the vendor's project manager: production

credentials not provisioned for the vendor's senior architect (waiting 4 weeks), a decision on cloud platform that the internal architecture team had been deferring (waiting 6 weeks), and a data sample for the threat-modeling work (waiting 2 weeks). Was the work being delivered actually what was asked for? Yes — the deliverables that had been completed were exactly what the SOW described. The ones that had slipped were the ones affected by the dependency gaps and the unmaterialized scope expansion.

Tomás had a diagnostic conversation with the vendor's project manager — not the account executive who would optimize for the contract relationship, but the PM who knew what was happening on the work. The PM was relieved to be asked. He confirmed: the vendor's team was ready to deliver but could not proceed without the dependencies, and the scope expansion needed to be either formally absorbed (with timeline adjustment) or withdrawn.

Tomás then negotiated, but not for the vendor to "perform better." He negotiated three things: a formal SOW amendment for the scope expansion with adjusted timeline and a modest budget addition; Tomás's team committing to provide the three blocked dependencies within 10 business days; and a weekly dependency check-in for the rest of the engagement to surface blocks earlier.

The engagement landed within the amended timeline. The relationship with the vendor strengthened because Tomás had named the structural issues honestly rather than treating the slip as vendor performance. The account executive at the vendor later referred Tomás to a peer at another bank with a similar engagement.

When the diagnosis does point to actual vendor performance — the team is not qualified for the work, the project management is poor, resourcing has been pulled to other accounts — three patterns apply. Escalate to the vendor's account executive with specifics: not "your team is failing," but specific items (which deliverables, which qualifications, which decisions). Ask for team replacement before contract termination; most vendor relationships are recoverable with a different project team. And document precisely; if the engagement is heading toward termination, the record of asks, responses, and program impact matters for both contract enforcement and the relationship's reputation.

When the cause is mixed, address each cause separately. Do not bundle structural fixes and performance fixes; the vendor responds differently to each.

Moves that work:

- Diagnose before negotiating: ask when the slip started and what changed, pull and walk the dependency list with the vendor's PM, and confirm whether the delivered work matches what the SOW actually specified
- Talk to the vendor's project manager first, not the account executive; the PM knows what is happening on the work and is often relieved to be asked directly
- When the cause is structural, negotiate a formal SOW amendment with adjusted timeline and budget (as Tomás did after the week-8 handshake scope expansion), plus an internal commitment to clear dependency blocks (the three items Tomás's team owed within 10 business days), plus a process improvement (weekly dependency check-in)

Watch out for:

- Treating slip as vendor performance when it is structural; pressure on the vendor's team does not fix internal scope problems or dependency blocks, the work does not accelerate, and the relationship deteriorates
- Negotiating with the account executive without diagnosing first; the account executive will offer concessions that do not match the actual cause — a discount that does not fix the work, or additional resources that do not help with dependency blocks

- Threatening termination as a negotiation tool; termination threats damage the relationship even when withdrawn, they are a one-shot move, and the vendor's response is rarely what the TPM hoped for
- Skipping the SOW amendment for verbal scope changes; without the amendment the change is not real, and this is how engagements fail

Bottom line: The negotiation that matches the wrong diagnosis will not fix anything — diagnosis comes first, and most "vendor failures" are structural problems the internal team contributed to.

Field Note — What "executive intervention required" actually means

In short: Off-Track is a contract between the TPM and the sponsor with real costs on both sides, so using it correctly requires a specific ask that only the sponsor can fulfill, sound prior diagnosis, and a 1:1 conversation before the status report goes out.

The Off-Track designation, in the toolkit's status definitions, requires "executive intervention required." Most TPMs treat that phrase loosely. They escalate Off-Track when they need help, when something is going badly, when they want senior visibility on a problem. The phrase ends up meaning whatever the TPM wants it to mean, which means it ends up meaning nothing. Sponsors who receive multiple vague Off-Track escalations stop reading them carefully, and the next time the designation is used on a situation where it is genuinely warranted, it does not land with the weight it should. The discipline of using it correctly is one of the highest-leverage practices in senior TPM work.

Off-Track is a contract between the TPM and the sponsor. The TPM is saying: this program has reached a state where I cannot return it to On-Track using the authority and resources I currently have; I am asking you, the sponsor, to take a specific action -- one that only you can take -- to change the program's trajectory. The sponsor responds by prioritizing the program over their other work, taking the requested action, and trusting that the diagnosis is correct. This costs the sponsor real time, attention, and sometimes political capital with their own peers. The contract works when both sides hold up their ends. It breaks when TPMs flip to Off-Track without a specific ask, or with a vague ask, or with an ask that does not actually require sponsor authority. After enough broken contracts, sponsors learn to discount the designation -- and the next TPM who genuinely needs executive intervention finds the channel less effective than it should be.

Eleven months into Bristol Financial's enterprise data platform program, Priya Iyer hit a wall on data classification. The platform required production data to be classified for sensitivity (PII, PCI, internal-only, public) before its access controls could function correctly. The classification work had been chartered to the data governance team six months earlier. As of week 44, less than 30% was complete, and the data governance team had reduced their working hours on the program from 1.5 FTE to 0.4 FTE due to other priorities. The program could not go live without classification complete. Without going live, downstream programs that depended on the platform -- including a regulatory compliance initiative with a hard deadline -- would slip. The program was 8 weeks from committed go-live; without intervention the slip would be 12-16 weeks with cascading impact on three downstream programs and one regulatory commitment.

Priya spent six weeks trying to resolve this at her level before considering the Off-Track flip. She met with the data governance team's manager, who acknowledged the staffing reduction but said his hands were tied by his own director's priorities. She worked with peer program managers who had similar dependencies on data governance, attempting a coordinated escalation to the data governance director; the director acknowledged the issue but did not change resourcing. She proposed alternative paths -- third-party classification vendor, automated classification with manual review, descoping certain data sources -- each deemed too risky or too expensive by her own program team after analysis.

By week 50 she had exhausted moves at her level. She constructed the ask carefully: "I need a CTO-to-CTO conversation between you and the data governance executive sponsor about reallocating resources to complete classification by week 56. The data governance team's current allocation cannot complete the work; their leadership has acknowledged this and indicated that resourcing requires executive-level alignment. The ask of you is one conversation, with a specific outcome -- confirmed reallocation by week 52 -- that I cannot get at my level." Sponsor-level authority required: yes (CTO-to-CTO peer conversation). Concrete and time-bounded: yes (one conversation, by week 52, for reallocation by week 56). Sound diagnosis: yes (six weeks of remediation attempts at her level, documented).

She flipped the program-level RAG to Off-Track in the Wednesday status report and surfaced the ask to her sponsor in their 1:1 the same morning, before the report went out. The sponsor noticed within an hour. The 1:1 that had been on Wednesday's calendar got rescheduled to that afternoon. The conversation was thirty minutes long and resolved a situation that had been deteriorating for six weeks.

The CTO-to-CTO conversation happened the following week. Reallocation was confirmed by week 52. Classification completed by week 56. The platform shipped on the original committed go-live. The regulatory compliance program downstream held its hard deadline. Six months later, when Priya raised an At-Risk on a different concern, the sponsor read it carefully and engaged substantively. The credibility of her status reporting had been earned by the careful use of the harder designations.

A credible Off-Track ask has three properties. The ask requires sponsor-level authority -- the action cannot be taken at the TPM's level or manager's level (common examples: a budget decision above the sponsor's single-drawdown threshold; a contract negotiation that requires the sponsor's relationship with a peer in another organization; a regulatory escalation that requires the sponsor's standing with the regulator; a personnel intervention that requires authority the TPM does not have). If the ask could be addressed by the TPM or their manager, the situation may be serious but it is not Off-Track. The ask is concrete and time-bounded -- not "we need help with the vendor," but specifically: "We need your direct outreach to the vendor's CEO to address an escalation that has stalled at their VP level; this needs to happen within 5 business days or the SOW remediation timeline slips into next quarter." The diagnosis behind the ask is sound -- if the diagnosis is wrong, the sponsor's intervention will not help and may cause damage that requires repair; diagnostic discipline has to happen before the Off-Track designation, not after.

When the situation is genuinely Off-Track but the specific ask is hard to identify, surface the designation and acknowledge the uncertainty: "I'm flipping the program to Off-Track. I don't yet have a specific ask, but I am certain the path back to On-Track requires action at your level. I'd like 30 minutes to walk through the situation and propose a specific ask coming out of that conversation." Use the conversation to develop the ask jointly; sponsors sometimes see the right intervention faster because they have visibility into options the TPM does not. Commit to coming back within 48 hours with a specific ask if one does not surface in the conversation. This pattern is the exception -- most Off-Track situations have clear asks once the diagnostic work is done.

When the sponsor declines the intervention, do not re-argue the no in the same conversation. Surface the implications clearly and specifically: "Without this intervention, my best estimate is [specific consequence] within [timeframe]. I can adjust the program to absorb this, but we would need to update commitments to steering." Document the conversation; six months later, when stakeholders ask why the program did not deliver to the original commitment, the record shows the adjustment was made consciously.

On frequency: a healthy multi-year program invokes Off-Track once or twice over its life. Programs that are routinely Off-Track are rolling crises. If a program has been Off-Track three times in a year, something larger is wrong -- the program should not have been chartered in the form it was, or resourcing is structurally inadequate, or the sponsor relationship is not working. Off-Track is not the right tool for managing structural program problems.

Moves that work:

- Exhaust moves at your level first -- as Priya did across six weeks (data governance manager, peer program manager coordinated escalation, data governance director, three alternative paths) -- so the sponsor's question "what have you tried?" has a complete answer
- Construct the ask against the three properties before flipping the RAG: sponsor-level authority required, concrete and time-bounded, sound diagnosis (Priya's ask: CTO-to-CTO conversation, confirmed reallocation by week 52, six weeks of documented remediation)
- Surface the ask in a 1:1 with the sponsor before the status report goes out; the report should ratify the conversation, not be the first the sponsor hears of it

Watch out for:

- Using Off-Track to express frustration rather than as a contract; the designation is not a feeling, and frustrated TPMs who use it as venting damage the channel for the next genuine escalation
- Weak asks ("we need more support") that leave the sponsor asking "support for what?" and unable to act, having spent real attention on the escalation
- Confusing Off-Track with At-Risk; At-Risk says there is a material risk being actively managed and commitments may yet hold; Off-Track says the path to holding commitments requires sponsor-level intervention; conflating them weakens both

Bottom line: Off-Track is one of the highest-leverage tools in senior TPM work precisely because it is rare -- use it only when the three properties are met, prepare your sponsor before the report goes out, and the channel remains effective when you genuinely need it.

Field Note — When to break ranks with your team

In short: Breaking ranks is the rarest move in TPM craft -- warranted only when the cost of being wrong about a consequential risk is worse than the certain cost to the team relationship -- and it is done without unnecessary damage by going to a peer specialist first, framing as "asking for input," and being direct with the team afterward.

Breaking ranks is going outside the program team -- to the sponsor, to a senior leader, to a peer organization (compliance, security architecture, GC) -- about a decision the team has made or is about to make, in a way that overrides or threatens to override the team's position. It is distinct from several adjacent things. It is not normal escalation, which surfaces a problem the team has acknowledged and asks for help. Breaking ranks surfaces a disagreement with a position the team has taken, sometimes against the team's wishes. It is not voicing a different opinion in the team's discussion -- that is normal contribution and happens before the team decides. Breaking ranks happens after the team has made a decision; it is a move outside the team to challenge something the team considers settled. And it is not whistleblowing, which involves reporting misconduct or legal violations; breaking ranks here is about disagreement on judgment calls where reasonable people could disagree but the TPM believes the team has gotten it wrong in a way that matters.

Daniel Park's team had reached alignment. The engineering leads on his security platform program had spent three weeks evaluating whether to ship a mid-cycle release with a known authentication weakness -- small population affected, mitigated through monitoring, fix planned for the following quarter -- or to delay the release another six weeks until the fix was in. They

decided to ship. The technical analysis was sound. The mitigation plan was credible. The business case for shipping on schedule was real.

Daniel disagreed. Not because the analysis was wrong. The analysis was correct as far as it went. He disagreed because he believed the team was underweighting a specific risk: the monitoring mitigation depended on a detection capability that had been unreliable in two recent post-incident reviews. The team's decision was reasonable on the assumption that monitoring would catch any exploitation. Daniel did not believe that assumption was sound. The engineering leads, deep in the technical work, had moved past the monitoring concern in their analysis and did not see it the way Daniel did.

Daniel ran a private checklist before deciding whether to break ranks. Was this consequential enough? An authentication weakness that the monitoring might miss, in a system that handled financial customer data -- yes, the cost of being wrong was meaningful (potential incident, regulatory exposure, customer trust impact). Had he made his case fully inside the team? He had raised the monitoring concern in two team meetings. The team had heard it and made their assessment. He had not been silenced; he had been outvoted on a judgment call. He decided he had not made the case as forcefully as he should have given how seriously he weighted the risk. Could he live with the team's decision if he was wrong about the risk? If the monitoring did catch any exploitation, he would feel relieved and slightly embarrassed. He could live with that; the relationship would recover over time. Could he live with the team's decision if he was right about the risk? An incident that the monitoring missed, affecting customer authentication, on his program -- he could not live with that without having tried harder. That was the deciding factor.

Daniel went to security architecture first, not the sponsor. The architecture team had cross-program visibility into the monitoring capability's reliability that the program team did not. He asked them to weigh in on the specific question -- would the monitoring approach catch an exploitation of this weakness? -- and framed it as "I want to make sure I am not over- or under-weighting this; can you give me an architectural read?" The architecture team confirmed Daniel's read. The monitoring approach had a known gap that was not yet documented. They escalated to the program sponsor and the engineering leads together. The decision was reversed; the release was delayed six weeks; the fix went in.

The team relationship took a hit for two weeks. Daniel was direct with the engineering leads in a follow-up: "I went to architecture because I could not make the case strongly enough inside the team. I respect the call you made on the analysis. The architectural input changed it. I would have rather we had surfaced this together inside the team." The engineering leads were initially cool but eventually appreciated the directness. The relationship recovered. No incident occurred during the six-week delay. The fix shipped clean. The monitoring gap was addressed in the architecture team's roadmap. Three months later, the engineering lead Daniel had been most worried about damaging things with told him in a 1:1: "I would rather work with someone who breaks ranks when they are right than someone who goes along when they are wrong."

The four-question test for whether breaking ranks is warranted. Is this consequential enough? Most disagreements are not -- reserve breaking ranks for matters where the cost of being wrong is meaningful (incident risk, regulatory exposure, material business impact, ethical lines). Have you made your case fully inside the team? If not, breaking ranks is bad faith; the team should have heard the concern, considered it, and made their decision knowing the view. Can you live with the team's decision if you are wrong about the risk? If you can, the team's decision can stand; breaking ranks is not for situations where you would be slightly embarrassed if wrong. Can you live with the team's decision if you are right about the risk? If the answer is no, breaking ranks is warranted, even with the cost.

Three real costs to name honestly. Team relationship damage: the engineering leads will know they were overridden; the relationship is recoverable but not free. Credibility on judgment: if you

break ranks and you are wrong, your judgment is in question for future programs, and the team and sponsor will weight your future readings more skeptically. Future-team trust: your reputation as someone who breaks ranks has consequences across subsequent engagements -- some teams will be wary, some will respect it, but the calibration changes in either case.

Breaking ranks is always the wrong move when the disagreement is about judgment within reasonable bounds (the team's call is one of several reasonable answers), when you are acting from frustration rather than analysis (wait, sleep on it, most frustration-driven moves are mistakes), when you have not done the inside work (the team has not actually heard the concern), or when you are protecting yourself rather than the program (career protection and program protection get conflated; they are different).

Recovery after breaking ranks has three components. Acknowledge the cost to the team explicitly -- not apologetically, directly: "I know the move I made cost something; I think it was the right call; I would like to talk about how we work together going forward." Do not re-litigate; once the case has been made and the decision has shifted, leave it. Show consistency in the work; the team will calibrate based on whether this happens routinely or rarely, and most of the work in the following months should look like normal collaboration.

Moves that work:

- Run the four-question private checklist before deciding (consequential enough? case made fully inside? livable if wrong about risk? livable if right about risk?) -- Daniel worked through all four before going to architecture, with the fourth question being the deciding factor
- Go to the right peer specialist first, not the sponsor; architecture, compliance, security, or legal depending on the issue -- they have specialist knowledge that can confirm or correct the read, and going to a peer first preserves the option for the team to correct course collaboratively
- Frame the outreach as asking for input rather than declaring conflict; "I want to make sure I am not over- or under-weighting this" is different from "the team is making a mistake"
- Be direct with the team afterward; acknowledge what you did and why, do not pretend it did not happen, and accept the relationship repair phase as a normal cost of the move

Watch out for:

- Acting from frustration rather than analysis; most breaking-ranks moves made from frustration are mistakes -- sleep on it before deciding
- Breaking ranks when the disagreement is within reasonable bounds of judgment; if the team's call is one of several reasonable answers, the move is overreach, not protection
- Going to the sponsor first rather than a peer specialist; this puts the team in an immediate defensive position and forecloses the option for collaborative correction
- Confusing career protection with program protection; "I do not want this on my record if it goes wrong" is not a sufficient reason to break ranks

Bottom line: The move is rarely right and always costly -- run the four-question test rigorously, go to a peer specialist before the sponsor, and be direct with the team afterward, because the relationship repairs through honest acknowledgment and consistent work, not extra warmth.

Field Note — Saying no to a sponsor

In short: Saying no to a sponsor is not disobedience - it is a specific contribution that protects them from a decision they would regret by surfacing information they did not have when they made the ask.

Three patterns apply here, each suited to a different situation. Getting the move right depends on reading which situation you are actually in.

Situation 1 - Sponsor commits without your input

Anita Roselli, General Counsel and program sponsor, told the Audit Committee that the customer data inventory would be done by October 15. Jordan Asare (Senior TPM, 9 years experience) was not in the room. His plan had the work landing November 30.

Jordan led with analysis, not refusal. He brought a one-page breakdown showing what October 15 actually required, then offered three options: Option A - hit October 15 by descopeing two domains and reassigning a key engineer; Option B - hit October 15 with full scope but reduced documentation depth; Option C - hold November 30 and return to the Audit Committee with a more accurate read. Then he stopped talking. The instinct to keep advocating is strong; the silence is where the sponsor does her work.

Anita chose Option B. The October 15 commitment held. The audit-trail gap was disclosed at the next quarterly update with a written rationale. Jordan said no to the original ask without ever using the word.

Pattern: Lead with analysis. Surface trade-offs as the sponsor's decision. Let silence do the work.

Situation 2 - Sponsor's ask is technically possible but expensive in a different currency

Three months later, Anita asked Jordan to compress the consent management workstream by six weeks to demonstrate live in production during a regulator visit. Technically possible - but the cost was two engineers' canceled vacations (the second time in 18 months), a compressed validation cycle, and skipping the engineering org's annual planning offsite.

Jordan was explicit about the cost rather than burying it in analysis. He laid out specifically what would break: a privacy engineer (probably Lin) leaving by April, six months to hire backfill, Phase 2 slipping a quarter. Then he framed it as her decision: "I want to make sure that cost is part of how you're thinking about it." He did not say "this is too expensive" or "the team won't accept this."

Anita asked the regulator's office whether the production-vs-stage distinction actually mattered. It did not. The program held to late March.

Pattern: Be explicit about the cost. Frame it as the sponsor's decision to weigh, not yours to override. Accept whatever call they make.

Situation 3 - Sponsor would change course if they saw what you see

Five months later, Anita planned to commit at the Board to expanding the program into commercial banking by year-end. Jordan knew the commercial banking org was not ready - the architecture was different, the consent provenance was more complex, and the commercial banking president had privately told Jordan his org was still stabilizing from a prior-year migration. None of that was visible from where Anita sat.

Jordan asked for 20 minutes the morning of the Board meeting. He walked through the architectural and organizational realities as his own technical assessment, without invoking his private conversation with the commercial banking president. He stopped before predicting her reaction. He said "I wanted to make sure you had this before the Board today" and let the information do its work.

When Anita asked "Have you talked to Felix?" Jordan chose honesty: yes, in passing, on a different topic. He had Felix's bandwidth concern but not as a formal position.

Anita called Felix that morning. Felix was honest with her - which he had not been before because no one had asked him directly. The Board commitment shifted to a phased approach: retail by end of year, commercial banking discovery starting Q2 next year.

Pattern: Slow the decision. Present information neutrally. Do not predict the sponsor's reaction. Be willing to be wrong about what they would want.

Moves that work:

- Lead with a structured options analysis (three choices, explicit trade-offs per option) rather than a flat refusal - forces the sponsor into a decision frame, not a confrontation frame
- Name the human cost explicitly ("Lin leaves by April, six months to backfill") rather than burying it in project schedule language - sponsors can weigh what they can see
- Request a short meeting the morning of a high-stakes commitment to surface information gaps, then stop at presenting the facts rather than recommending a decision

Watch out for:

- The dramatic refusal ("I can't do this") - forces a confrontation the sponsor was not in; the passive version (saying yes verbally then not moving) is worse, because the relationship takes longer to repair
- The "team won't accept this" framing - reads as the TPM hiding behind the team; own your concern directly or let the team raise theirs through their own channels
- The retroactive reveal ("I had concerns from the beginning") - unhelpful at best, damaging at worst; the lengthy email that locks both parties into positions and eliminates the back-and-forth that produces better outcomes

When the sponsor decides anyway, three things in order: document the conversation in the Decisions and Changes Log (decision made, trade-offs surfaced, path agreed); implement cleanly with no foot-dragging and no sharing dissent with the team; watch for the second moment - if consequences surface later, return to the original analysis and update for current conditions without saying "I told you so."

Frequency check: healthy programs produce one or two of these conversations per year. If push-back is happening more often, something larger is wrong - sponsor consistently making decisions without enough information, TPM pushing back too readily, or program in structural mismatch with sponsor expectations. Each calls for a different conversation than the individual situation does.

Bottom line: Protecting your sponsor from a bad decision is part of the job - but the move is to surface information and trade-offs as their decision, not to substitute your judgment for theirs.

Field Note — What automation actually changes for TPM work

In short: The TPM role is not disappearing - it is being reshaped, with some activities getting cheaper fast and others staying expensive, and where you invest your time over the next few years will determine whether you are becoming more valuable or treading water.

Aileen Bhatt and Renaud Cole are both 11-year senior TPMs at Bristol Financial. Same level, same compensation, same nominal scope. Their weeks look very different as of late 2026.

Aileen's week: 12 hours on stakeholder 1:1s and political reads, 8 hours on judgment calls about what to surface and how to frame it, 6 hours on strategic input to programs (architecture choices, vendor selections, sequencing), 5 hours developing two junior TPMs on her team, 4 hours on review-and-edit of automated artifacts. Her programs are on track. Her sponsor includes her in conversations she was not included in two years ago. Her standing in the org is rising.

Renaud's week: 18 hours producing artifacts (status reports, documentation, RAID updates, charter sections), 8 hours in meetings, 6 hours on action item tracking and follow-through, 3 hours on stakeholder 1:1s. His programs are on track too. His sponsor's engagement with him is the same as it was two years ago. His standing is not falling, but it is not rising either.

The difference is not effort - both are working hard. The difference is what they are spending their time on. Aileen is investing in the activities that stay expensive; Renaud is investing in the activities that are getting cheaper. Both will still have careers. One of them is becoming more valuable; the other is treading water.

The activities getting cheaper, durably enough to plan around even if specific tools change: status compilation (drafting weekly status from workbook data, RAID entries, milestone status used to take 60-90 minutes; now TPM time goes to review-and-edit rather than blank-page composition); action item tracking (capture, owner attribution, aging surfacing, reminders - previously a meaningful chunk of administrative time, increasingly automated); first-draft artifacts (charters, comms plans, training plans, kickoff agendas - population can be largely automated from program metadata; the TPM's work shifts from "produce the artifact" to "decide what should go in the artifact"); cross-document consistency (catching charter-vs-RAID-vs-status contradictions used to require careful manual review; now automation flags it); meeting summary and decision capture (real-time transcription, post-meeting summaries, decision extraction - used to be a noticeable cost, less so now).

The pattern across these: structure is well-defined, content is mechanical. The TPM was doing them because someone had to, not because the work required senior judgment.

The activities that stay expensive: judgment about what to surface, when, and to whom - status reports are easy to generate, but what to lead with, what to escalate, what to absorb, what to flag does not reduce to mechanical rules; pattern recognition across programs ("this looks like a sponsor-going-quiet pattern," "this resistance is structural not personal," "this vendor situation needs a CTO-to-CTO conversation") built up over decades and not currently transferable to automation with the same calibration; stakeholder relationships built through repeated interactions, showing up, reading the room, and small acts of attention; political reads about which decision actually has authority behind it, which stakeholder's objection is substantive vs. positioning, which sponsor is becoming disengaged; framing hard things well so that the recovery plan lands as discipline rather than panic and bad news comes across as honest rather than alarming; decisive action under uncertainty on reprioritization calls before all data is in, break-ranks decisions when the team's call is wrong, escalation decisions when escalation will damage relationships.

A junior TPM five years ago might have spent 50-60% of their week on activities that are now compressing. Move that down to 20-25% over the next few years. The remaining time has to go somewhere, and where it goes determines whether the role's value is increasing or decreasing for that particular TPM.

Moves that work:

- Treat your judgment time as the scarce resource, not your output time - the senior TPM whose week is full of conversations, reads, decisions, and quiet thinking time is doing the right work even if artifact volume is lower
- Push mechanical work toward the cheaper path - if you are still doing 90-minute status compilations you are paying a cost the work does not require anymore; find the path (automation, tooling, delegation, tighter standards) and reinvest the savings
- Make your judgment work visible to junior TPMs - talk through the call before you make it, explain framing decisions in real time, walk through patterns you are recognizing, because the apprenticeship pathway compresses when mechanical work compresses

Watch out for:

- TPMs whose time savings go to producing more artifacts faster, more status updates, more meetings, more documentation - they are optimizing for the wrong axis and becoming less valuable even if their output looks impressive
- The compression of junior TPM development pathways - the first three years used to build senior judgment through mechanical work exposure; if that compresses, the "see one, do one, teach one" model still works but the seeing has to be more deliberate

Bottom line: The ratio of cheap work to expensive work is shifting fast, and TPMs who actively reinvest time savings into stakeholder relationships, political reads, framing decisions, and

pattern recognition are compounding their value while those optimizing artifact throughput are not.

Field Note — When AI is your collaborator vs. when it's your output

In short: The distinction between AI as collaborator (helping you think) and AI as output (producing what stakeholders read) matters because stakeholders form their model of your judgment from the work that reaches them - and if the work was AI's judgment, their model of you is wrong.

Collaborator mode means using AI to think - to pressure-test a position, to draft something you will then rewrite, to see a situation from an angle you had not considered. What stakeholders see is what you produced based on that thinking. Output mode means using AI to produce a thing the stakeholder will read or use, where the artifact reaches the stakeholder substantially as the AI generated it, with light editing. Most use sits on a spectrum between these poles, but the spectrum has a moral structure: the closer your use sits to "AI produced this and I lightly edited," the more the trust question matters.

Vignette - Mira Halloran, Senior TPM, catching the drift

Mira had been at Bristol Financial for six years and had integrated AI assistance into her workflow over 18 months. The integration was gradual: first for status report drafts, then for routine emails, then for first drafts of difficult emails she would rewrite. The pattern had been working. Then, over a few months, she noticed she was barely rewriting anymore. The emails to her sponsor were going out substantially as the AI drafted them. So were her recommendations. So was her recent stakeholder analysis.

Mira noticed it on a Friday afternoon when her sponsor referenced a phrase from her previous week's email and Mira could not quite remember why she had written it that way. The feeling was distance from her own writing - not a confrontation, just a small disconnect.

She did three things over the next two weeks.

First, she audited. She went back through 30 days of stakeholder-facing communication and categorized: which had been substantially her writing, which had been substantially AI's. The split was 40-60. The 60% that was AI's included three emails to her sponsor, two recommendations she had presented in steering, and a stakeholder analysis the team had referenced multiple times.

Second, she reset her default mode for stakeholder-facing communication. AI as collaborator, not output, for emails to senior stakeholders, recommendations, and framing-bearing artifacts. The pattern: use AI to think through the situation, draft the structure, pressure-test her position - then write the actual stakeholder-facing version herself, with the AI's contribution showing up as sharper thinking rather than text. The time savings shrank from 15 minutes per email to 35, but the trust integrity rebuilt.

Third, she did not backfill disclosure. Her instinct was to mention to her sponsor that she had been using AI heavily for several months. She decided against it. Disclosure in retrospect creates a problem the stakeholder cannot easily evaluate, the relationship gets weird, and the conversation usually does not go anywhere productive. The cleaner move was to reset forward and let her communication shift back toward her own voice.

Six months later, Mira's stakeholder-facing communication read as recognizably hers. Two of her closer peers noticed the shift - one said her recent emails "sounded more like you again." She did not correct them. The judgment-bearing work she shipped was hers; the trust calibration with her sponsor was accurate again. AI continued to be a heavy part of her workflow, but in a different mode.

When AI as your output is fine: templated structural work (charter sections from program metadata, kickoff agenda from a template, vendor RFP from requirements - stakeholders do not expect you to have written boilerplate); aggregation and summary (six weeks of status reports for a steering committee, action items across last quarter, dependency map from the workbook - mechanical aggregation); first drafts you will rewrite substantially before they reach a stakeholder; mechanical translation (technical decision to executive-friendly version, conversation transcript to structured decision log entry - judgment happened upstream, AI is doing the translation).

When AI as your output is a problem: communication that signals your judgment - email to a difficult stakeholder, recommendation to your sponsor, framing of bad news, push-back on a decision - because stakeholders read these as signals about how you think; strategic recommendations on vendor selection, program phasing, stakeholder situations - decisions where stakeholders are paying for your judgment specifically; anything where your reading of the situation is the value (retrospectives, lessons learned, stakeholder profiles, honesty assessments - AI has access to text, not to your read, and AI versions can sound right while being subtly wrong about things only your perception would catch); anything you will be asked to defend - if the artifact came from significant AI generation, you may not be able to defend it as if you had thought it through.

Moves that work:

- Use AI heavily in private to think ("help me think through this situation," "pressure-test this argument," "draft this in three different framings") - the output is your sharpened thinking, not text that reaches stakeholders, and this is unambiguously fine
- When you notice the "distance from your own writing" feeling - the moment Mira caught herself not remembering why she had written a phrase - treat it as a signal to audit and reset, not to rationalize
- For borderline cases in professional settings without explicit policy, partial disclosure ("I drafted this with AI assistance and reviewed it carefully") is a cleaner move than full retroactive disclosure, which tends to land awkwardly even when truthful

Watch out for:

- Gradual drift from "AI as starting point I rewrite substantially" to "AI as output I lightly edit" - the pattern is nearly invisible while it is happening because each step feels like a small efficiency gain
- Relying on AI for artifacts you will be asked to defend in a meeting or walk a sponsor through - questions go to places the AI did not anticipate, and the gap between what you can defend and what the document says becomes visible

Norms on disclosure are still settling. In professional settings without explicit policy, the default is no disclosure for templated and aggregation work; partial disclosure for borderline cases. When in doubt, err toward more disclosure especially with sponsors and senior stakeholders who will eventually have firm views about this and whose trust matters most. In settings with explicit policy, follow the policy - the cost of being out of compliance is much higher than the cost of more disclosure than necessary.

Bottom line: The trust your stakeholders have in your judgment is built on the work that reaches them - keep that work substantially yours for anything that signals how you think.

Field Note — Where automation accelerates the wrong thing

In short: Automation makes an activity cheaper, people do it more often, volume rises - but the underlying decisions and outcomes do not improve correspondingly, and the increased volume often crowds out higher-leverage work.

Bristol Financial deployed an AI status-report assistant in early 2026. Two senior TPMs, Marcus Levin and Tessa Rao, both started using it in the first month. By year-end their patterns had diverged sharply.

Marcus's pattern, year-end 2026: weekly status reports for two of his three programs (was biweekly), each report averaging 8 pages (was 3), three new dashboards added because data was easier to surface, and a daily auto-generated update going to his sponsor's inbox. His sponsor read about 30% of what Marcus produced. The other 70% lived in the inbox unread. Marcus felt productive - he was producing more communication than ever - and his programs were on track. But his sponsor's engagement with him had not increased, and three peer TPMs had quietly started referring to him as someone who "loves to over-communicate."

Tessa's pattern, year-end 2026: status cadence held at biweekly. Reports shorter at 2 pages (was 3), because she was using the time savings from AI-assisted compilation to think harder about which 3-4 things to surface to her sponsor each cycle, then writing those concisely. The dashboards she had considered building she skipped - she asked her sponsor what the sponsor would actually use, and the answer was "what you're already sending me, kept tight." Tessa's time savings went to two new weekly 1:1s with stakeholders she had not been spending enough time with, and to deliberate reflection on a difficult sponsor relationship that needed work. Her programs were on track and her sponsor's engagement had deepened.

Same automation. Same starting point. Different outcomes. Marcus took the time savings and made the activity bigger. Tessa took the time savings and reinvested them in higher-leverage work.

The mechanism: an activity used to be expensive, so people did it sparingly. Automation makes it cheap, so people do it more. The increased volume is mistaken for increased value when often it is just more of an activity that did not need volume increase - and sometimes the volume actively crowds out higher-leverage work the role is supposed to do.

Three places this shows up repeatedly:

Faster status reports. Status used to be expensive to compile, so it happened weekly or biweekly with the TPM forced to think hard about what to surface in limited space. Now status can be generated more often and at greater length. The pattern in many organizations: more frequent reports, longer reports, more dashboards, more scheduled status meetings. The sponsor is not better-informed; they are more saturated. The actual question - what does the sponsor need to know, when, in what framing - has not changed. It was the hard part before; it is still the hard part. Automation made the easy part easier without helping with the hard part.

Faster action item tracking. Action items used to require manual capture, ownership assignment, and follow-up; friction limited how many got formally tracked. Now they are captured automatically from any meeting, attributed, surfaced as overdue. More items tracked, more aging items, more reminders. Owners get more notifications about more items. Completion rate per item tends to drop because attention spreads thinner. The actual question - which items matter, which can be absorbed - has not changed. It was always the harder question.

Faster artifact generation. Charters, comms plans, training plans. The pattern: more artifacts, longer artifacts, more sections, more cross-references. The artifact set grows. The amount of writing increases. The strategic decisions inside the artifacts - the ones the artifacts are supposed to capture - do not improve correspondingly.

Three reasons the pattern holds even when people are aware of it: volume is visible and quality of thinking is not (a TPM who produces more artifacts looks productive; a TPM who produces fewer but spends more time on harder thinking looks less productive, even if program outcomes are better); process integrity feels like progress (tracking more action items feels like better project management even when completion rates drop; disrupting these processes feels like

risk even when disruption would improve outcomes); the harder work is harder (making a sponsor genuinely informed requires understanding what they are worried about and addressing it specifically, which does not compress).

Moves that work:

- Before adopting any automation that makes an activity faster, ask three questions honestly: what is the underlying outcome the activity is supposed to produce (not the activity itself); is the speedup making that outcome more likely or just making the activity easier to do more often; what is the second-order cost of doing more (more status means more sponsor reading time, more artifacts means more team review time)
- Do what Tessa did - ask the sponsor what they would actually use before building dashboards or increasing cadence; "what you're already sending me, kept tight" is a legitimate answer that saves time and improves the relationship
- Track where your automation savings are actually going - if savings are going to more output (more artifacts, more meetings, more status, more documentation) the automation is producing volume increase without value increase

Watch out for:

- The "I can finally do all the things I should have been doing" trap - daily standups, weekly written status, biweekly stakeholder updates, monthly steering, quarterly retrospectives, formal documentation of every decision; each is reasonable in isolation, the aggregate becomes a process tax that crowds out strategic work
- The "more visibility is better" trap - a dashboard goes from manually updated to automatic, the team adds three more, a portfolio dashboard rolls them up, leadership gets daily auto-generated updates; if a dashboard is not producing a decision someone would not have made otherwise, it is process volume, not value
- The "we should track everything we used to track better" trap - informally tracked things like stakeholder sentiment, vendor relationship health, and team morale get formalized once automation makes it possible; formal tracking often misses what informal tracking caught, and the program loses signal that was not easily quantified

When the speedup is real value: when the activity was a genuine bottleneck on a higher-leverage outcome and the freed time is genuinely reinvested; when the speedup enables a cadence that genuinely produces better outcomes (real-time risk surfacing across many components, daily standups in distributed teams); when automation removes errors that were happening because manual work was tedious (cross-document consistency checks, numerical aggregation, date and dependency validation).

The right question is not whether an automation makes an activity faster but whether that speed is going to outcomes that matter or to volume increase that looks like progress.

Bottom line: If you cannot account for where your automation savings went and confirm it was higher-leverage work, the automation probably accelerated the wrong thing.

Field Note — Programs that deliver AI capability

Field Note - Programs that deliver AI capability

In short: AI programs don't break the standard TPM toolkit - they strain it in five specific places, and the right move is targeted extension, not replacement.

Most of the toolkit was developed for programs that deliver software, infrastructure, or process changes. The artifacts assume scope you can specify, requirements you can verify, behavior you can test deterministically, post-launch metrics you can measure cleanly. Programs that deliver AI capability - a model integrated into a workflow, an LLM-powered feature, an automated decision system - don't fit that shape cleanly. The traditional artifacts work, but they have gaps, and the gaps matter for how the program runs.

Joaquin Estrada, Senior TPM at Bristol Financial, had run infrastructure programs for eight years before taking on a fraud detection model rollout. The team was strong on the data science side; the program structure used the standard Bristol artifact set. Three months in, Joaquin noticed the artifacts were straining. UAT had passed but customers were reporting transactions being incorrectly flagged. The RAID Log had no entries about model behavior. The Decisions Log had a thin entry about "model version 3.2 selected" with no explanation of the trade-offs. The team was confident in the deliverable, but the surrounding documentation didn't reflect what they'd actually decided.

Joaquin's task: identify which artifacts were straining for AI-program-specific reasons, extend them where needed, and avoid two failure modes - overcorrecting into "AI programs need a completely new methodology," or undercorrecting into "the existing toolkit handles everything fine."

Over the next month, he made four targeted moves. He added a model evaluation gate separate from UAT - UAT validated the inference pipeline (input goes in, output comes out, no errors), while model evaluation validated the model's behavior on a representative test set with metrics: accuracy, precision, recall, false-positive rate by transaction segment, calibration of confidence scores, and edge-case behavior. The team had been doing this work informally; Joaquin made it a formal gate with explicit acceptance criteria signed off by the data science lead and the fraud operations lead.

He extended the RAID Log with a model-risk subcategory - not a new artifact, but the same RAID Log with additional risk categories surfaced: training data quality, distribution shift (production inputs differing from training inputs), bias risks across customer segments, drift risks (model performance degrading over time), and dependency risks on the model provider. He framed each risk in language the program team could understand and stakeholders could act on.

He revised Decisions and Changes Log entries for model decisions to include explicit trade-off framing. The thin "model version 3.2 selected" entry became: "Selected model version 3.2 over 3.5. Trade-off: 3.5 had higher precision (0.91 vs 0.89) but 3% lower recall on the fraud-positive class. The cost of missed fraud at our scale exceeds the cost of additional manual review on false positives, so we optimized for recall." The longer-format entry took ten minutes to write and made the decision auditable later.

He also added a training data lineage artifact - not in the standard toolkit. It captured where the training data came from, what cleaning was applied, what licensing terms applied, what privacy implications were addressed, and what known limitations existed. It became a one-page reference the privacy office reviewed, and that the fraud operations team referenced when model behavior surprised them.

Six months later, the model was performing as expected and the audit committee asked Joaquin to brief on the program's discipline. All four artifact extensions held up under the briefing. The training data lineage artifact in particular caught the audit committee's attention as a practice they wanted to see across other AI programs at Bristol. Joaquin wasn't trying to invent new methodology - he was extending the existing toolkit where it strained.

The five places artifacts strain on AI programs are consistent across programs. First, UAT doesn't validate model behavior - it covers the system layer but not model accuracy, fairness, calibration, or edge-case behavior; that requires a separate model evaluation gate with richer acceptance criteria. Second, the risk register doesn't capture model-specific risks - standard RAID columns don't surface training data quality, distribution shift, bias across slices, drift, or model-provider dependency; extend RAID with a model-risk subcategory. Third, decisions about model behavior require richer log entries - trade-offs between accuracy and inference cost, recall and precision, explainability and performance, training data sources, and fairness

definitions are multidimensional; the standard log format doesn't capture them. Fourth, post-launch monitoring needs model-specific signals - production accuracy, drift indicators, distribution coverage, output quality signals for generative systems, and human override rates, with thresholds for when retraining is required. Fifth, training data lineage is not a standard program artifact but becomes essential during regulatory inquiries, internal reviews, and post-launch debugging.

The rest of the toolkit translates directly. Charter still works (with model evaluation criteria added to scope). Stakeholder Register still works (with data science and ML engineering teams added). Schedule, Comms Plan, and OCM all still work - OCM is often more important, since users adapting to AI workflows frequently need more change management than users adapting to deterministic systems.

The judgment work is the same shape. The technical context is different - understanding what an evaluation result means, why a model at 92% in evaluation might perform at 78% in production, the difference between model risk and traditional integration risk. But the judgment work - what to surface to the sponsor, when to escalate, how to frame trade-offs, how to handle stakeholder dynamics - is the same shape on an AI program as on any other program. The role doesn't require complete reskilling. It requires extension.

From a career trajectory standpoint, the TPM bench for AI programs is shallow. Most TPMs running them today came up through traditional software delivery and learned AI context on the job. Demand is growing faster than the bench. Senior TPMs whose programs to date have been infrastructure, security, or traditional software delivery will find AI programs a natural extension over the next 2-3 years - the skills transfer, and the upside is high.

Moves that work:

- Add a model evaluation gate separate from UAT, with explicit acceptance criteria signed off by data science and operational leads - covering accuracy, precision, recall, fairness across slices, and calibration
- Extend the RAID Log with a model-risk subcategory covering training data quality, distribution shift, bias, drift, and model-provider dependency risks - framed in language stakeholders can act on
- Rewrite model decisions in the Decisions and Changes Log with explicit trade-off framing (as Joaquin did: 3.2 vs 3.5, precision 0.89 vs 0.91, recall trade-off rationale)
- Build a training data lineage artifact from scratch: source, cleaning applied, licensing terms, privacy implications, and known limitations - one page, reviewed by privacy office
- Add model-specific post-launch monitoring as a first-class deliverable, with thresholds for retraining

Watch out for:

- Overcorrecting into "AI programs need a completely new methodology" - this loses the value of the existing toolkit and creates unnecessary overhead
- Undercorrecting into "the existing toolkit handles everything fine" - this produces the five artifact gaps named above and leaves programs vulnerable to exactly the audit Joaquin nearly failed
- Thin model decision entries that don't capture multidimensional trade-offs - they become unauditable and untraceable when model behavior surprises stakeholders post-launch

Bottom line: AI programs strain the standard toolkit in five specific places - extend it there, leave the rest intact, and you're running the same discipline with the right additions.

Field Note — The pace question

Field Note - The pace question

In short: When AI tooling compresses engineering time, the pacing constraint moves out of engineering and into the decision processes surrounding it - and the TPM's job shifts accordingly.

As engineering productivity gets a meaningful boost from AI tooling - features built faster, code reviewed faster, integrations completed faster - the time profile of programs shifts. Work that used to take months can take weeks. The surrounding decision processes - sponsor approvals, stakeholder reviews, procurement cycles, compliance review, security architecture sign-off - don't speed up on the same curve. The pacing constraint moves.

Cassie Linwood, Senior TPM at a payments company, ran directly into this pattern. Her team had completed a 12-week engineering phase in 7 weeks. The team had integrated AI assistance into their development workflow over the prior six months and the velocity gain was real. Cassie expected the program to move 5 weeks ahead of schedule. Instead, the program's actual end-to-end progress had moved by 2 weeks. The 5-week engineering gain had been mostly absorbed by surrounding processes that hadn't compressed.

Cassie audited where the lost weeks had gone. The procurement cycle for a new payments vendor was 11 weeks (queue plus review). She had kicked it off in week 3 of the program assuming engineering would be the long pole and procurement would catch up. With engineering done in week 7, procurement was now the critical path through week 14. The security architecture review board met monthly - her review had been queued for the next available slot, 5 weeks out. The team's design was ready in week 6 but couldn't move forward until week 11. Her sponsor's decision cadence on this program was 2-3 weeks per major decision. With the program moving faster, she was hitting decision points more frequently than her sponsor's calendar could accommodate. Three recent decisions had been pending sponsor review for 2-plus weeks each.

Three new pacing constraints had become visible because engineering wasn't hiding them anymore.

Cassie made three adjustments. She started kicking off procurement and stakeholder reviews earlier - week 1 instead of week 3 - even when the engineering work hadn't started yet. She started building shorter, decision-ready briefs for her sponsor so the sponsor could process more decisions in less time without sacrificing depth. She started tracking decision-process metrics (sponsor decision cycle time, security review queue length, procurement queue length) as first-class risks in the RAID Log, not as background friction.

On Cassie's next program - same scope class, same engineering acceleration - the program ran 3.5 weeks ahead of original schedule, not 2. The surrounding processes hadn't gotten faster, but Cassie had gotten better at running them in parallel and earlier. The velocity gain from engineering acceleration mostly stuck.

The traditional pacing pattern is familiar: engineering was the long pole. Sponsor approved, team got staffed, scope and design happened, then engineering did the work - typically the longest phase by a meaningful margin. The TPM's job during the engineering phase was to keep the team unblocked, manage dependencies, surface risks, and prepare surrounding processes (UAT, OCM, training, deployment) for when engineering work landed. Most TPM activities happened in parallel with the long engineering phase, not in the critical path.

What's changing: engineering time is compressing on a meaningful fraction of programs. A feature that took three engineers six weeks now takes two engineers two weeks. A migration that needed eight weeks for cleanup now takes ten days. Not uniform across programs, not as dramatic as some commentary suggests, but real.

What hasn't compressed: sponsor 1:1 cadence, steering committee schedules, procurement contract negotiations, security architecture review queues, legal and compliance review cycles,

vendor onboarding, UAT scheduling. These are bound by human attention and organizational rhythms that don't get faster because engineering got faster.

Three patterns where the new constraint shows up are consistent across programs. First, sponsor decision velocity: engineering builds a thing in two weeks that takes the sponsor four weeks to review and approve. The program slows from engineering pace back to sponsor pace, and now the sponsor is the obvious bottleneck. Second, stakeholder review processes: compliance, legal, security architecture, privacy, and finance reviews used to fit comfortably in the gaps of engineering work; when engineering compresses, they don't compress and become the long pole. Third, procurement and vendor onboarding: engineering can build an integration in days while the procurement cycle to bring the vendor on as approved supplier takes months.

For TPM leaders managing a portfolio, the compounding effect matters at the portfolio level. If five programs each used to have their TPM spend a meaningful fraction managing engineering execution, and that fraction shrinks because engineering is faster, the TPM has new capacity. If it goes to taking on a sixth program at the same intensity, the TPM is operating against the wrong constraint - they were never the bottleneck on those five programs, and adding a sixth doesn't change the underlying capacity of the surrounding decision processes. The right strategic question isn't "can we run more programs with the same headcount" - it's "where is the pacing constraint actually sitting on each of our programs, and where does TPM attention produce the most velocity gain."

Three habits worth developing to stay ahead of this pattern. At program kickoff, run a pre-mortem on decision velocity: ask where this program gets stuck if engineering finishes everything on time but the surrounding processes don't move, and identify those points specifically before they surface. Track decision-process metrics as actual numbers - sponsor decision cycle time, procurement queue length, security review queue - rather than feeling them as background friction. Adjust your own throughput: the activities you personally produce (kickoff materials, comms, status, OCM artifacts) used to fit comfortably in gaps between engineering milestones; on accelerated programs they may not, and a program shouldn't wait on the TPM.

Moves that work:

- Front-load procurement cycles and stakeholder reviews to week 1 of the program, even before engineering starts, so the critical path isn't waiting on queue times that were always long
- Build shorter, decision-ready briefs for sponsors - pre-aligned in 1:1s, written for async review - so the sponsor can process more decisions per week without losing depth
- Track decision-process metrics (sponsor cycle time, security review queue length, procurement lead time) as first-class RAID entries, not background friction
- Parallelize review processes (compliance, legal, security architecture, privacy) in batches ahead of engineering completion, not alongside it

Watch out for:

- Assuming engineering speedup will translate directly to program speedup - Cassie's team recovered 5 weeks of engineering time and kept only 2 weeks of it because the surrounding processes weren't moving
- Being the new pacing constraint yourself - if engineering finishes and the sponsor reviews quickly but the program is waiting on the TPM to produce the next phase of artifacts, the savings evaporated at the wrong place

Bottom line: When engineering compresses, the TPM's job shifts from managing the engineering phase to managing the decision processes surrounding it - and that shift requires front-loading, not just accelerating.

Field Note — Skills that compound, skills that depreciate

Field Note - Skills that compound, skills that depreciate

In short: Senior TPM career growth is largely a function of which skills you invest in - the compounding ones appreciate with each program, while the depreciating ones are increasingly absorbed by automation and produce diminishing returns on new investment.

Three kinds of skills, roughly. Skills that compound (whose value increases as the role evolves). Skills that hold their value (approximately stable). Skills that depreciate (whose value is decreasing as automation absorbs the underlying activity). This is a frame for resource allocation, not a value judgment. Skills that depreciate aren't bad skills - they were valuable when built and may continue to be useful in narrow circumstances. The question is where to put new investment.

The honest framing isn't "AI-resistant skills" vs. "automatable skills" - that's a competition between you and tools, which is the wrong frame. The honest framing is whether the skill's value is increasing or decreasing as the role's mechanics shift.

Han Truong and Olivia Forgione both joined Bristol Financial as TPMs in 2016 - same starting level, similar early careers. By 2026, Han had grown into one of Bristol's top staff TPMs. He ran the most strategically consequential programs, was pulled into early conversations on new initiatives, mentored three junior TPMs deliberately, and was one of two TPMs the CISO would specifically request for the hardest programs. His pattern recognition across program situations was visibly sharper than his peers'. His sponsor relationships were deep.

By 2026, Olivia was a senior TPM, the same level she'd been three years earlier. Her programs ran clean. Her artifacts were always immaculate. Her process discipline was a model others studied. But she wasn't getting pulled into the harder conversations, wasn't running the most consequential programs, and her career had started feeling stuck without her quite knowing why.

Both had worked hard. Both had become better at their jobs over the decade. The difference: Han had invested in compounding skills - pattern recognition, sponsor management, framing under pressure, strategic input on program structure. Olivia had invested in skills that held value - artifact production, process compliance, status reporting. Han's skill profile had appreciated. Olivia's had stayed flat. This isn't about Olivia being a worse TPM. It's about which skills the role rewards differently as it evolves.

Compounding skills tend to share a property: they're built through reflection on cases over time, not through deliberate practice on a defined task. They get better with experience handled deliberately, not just exposure.

Pattern recognition across program situations - recognizing "this is shaping up like a sponsor-going-quiet pattern" or "this scope discovery will surface a re-baselining situation in 60 days" - is built over many years and many programs. Each new pattern recognized adds to the library; the library is the value. Stakeholder relationship judgment - reading whose engagement is real, whose concern is performative, who has informal authority that exceeds their title, when a relationship is shifting in ways that affect the program - is hard to teach, hard to formalize, and increasingly the work other people pay you for.

Framing under pressure - producing the right framing for a hard conversation, in real time, with audience and stakes specifically in mind - is yours in a way AI assistance can't replace. AI tools can help draft framings; the judgment about which framing fits this moment is yours, and it gets better with deliberate work. Strategic input on program structure - judgment about how a program should be scoped, who should sponsor it, what the right phasing is, what risks are worth taking - is increasingly what gets you pulled into early conversations on important programs and distinguishes a senior TPM from a delivery manager.

Tolerance for ambiguity compounds in a particular way: some TPMs become more comfortable with incomplete data and genuinely contested trade-offs over time; others become more anxious. The comfortable ones can take on harder work, which builds more comfort, which compounds. Sponsor management is one of the most direct compounding skills in the role - trust built, pattern of how you handle hard conversations, sponsors who've seen you handle difficult situations well will pull you into harder programs, recommend you to peers, and route important work through you.

Skills that hold their value are the mechanical core of program management - schedule and dependency management, risk identification and tracking, structural artifact production, status reporting framing. These remain necessary; the underlying judgment stays yours while bookkeeping work automates.

Skills that depreciate are where further investment produces diminishing returns. Manual aggregation - pulling data from multiple sources into a single view, compiling cross-program rollups, manually reconciling artifacts - is increasingly automated; invest in the judgment about what should go in the rollup, not in speed of aggregation. Detailed mechanical artifact authoring from a blank page was useful when learning the discipline; spending senior TPM hours on it produces less differentiation than it used to. Process compliance and template adherence - knowing every template's structure cold - is less useful when templates are easily generated and the question is whether the content is right. Routine status meeting facilitation and mechanical reporting cadence were meaningful parts of the job; they increasingly aren't, and reporting work compounds when you're producing framing decisions, not typing.

Three concrete moves over 12-24 months will shift the profile. First, audit your time honestly: for two weeks, track what you're actually spending time on, categorize each activity (compounding, holding value, depreciating), and accept the result - most senior TPMs are surprised by how much of their time goes to depreciating activities. Second, move 5-10% of your time deliberately over 90 days - more 1:1s with stakeholders, more reflection on patterns, more reading outside your immediate work, more quiet thinking time before decisions. Small enough to be sustainable, large enough to produce noticeable change over a year. Third, identify one underdeveloped compounding skill and invest deliberate work there for the next year - pattern recognition, framing, strategic input, or tolerance for ambiguity; one focused area is more valuable than spreading effort thin.

The compounding skills are what unlock the next stage. Mechanical skills get you to senior. Compounding skills get you past it. For staff and principal IC paths, the compounding skills to lead with are pattern recognition, framing, strategic input, and tolerance for ambiguity. For TPM leadership, compounding skills extend to building and managing TPM organizations - hiring, mentoring, scaling judgment across a team.

Some skills the next decade will require don't have names yet - interpreting AI-driven program signals, running programs with AI agents as components rather than just tools, drawing the boundary between what humans should decide and what systems can decide. The discipline: stay attentive to which skills the harder programs are demanding. Notice when your existing toolkit doesn't quite fit a situation. Pay attention to what senior people who are good at the new situations are doing differently. Don't chase every emerging trend, but stay sensitive to the patterns that recur.

Moves that work:

- Audit two weeks of your actual time against the three categories (compounding, holding value, depreciating) before drawing any conclusions - most senior TPMs are surprised by the result

- Move 5-10% of your week from depreciating to compounding activities over 90 days: more stakeholder 1:1s, more pattern reflection, more strategic input opportunities, more deliberate pre-decision thinking time
- Pick one underdeveloped compounding skill (pattern recognition, framing under pressure, strategic input, tolerance for ambiguity) and invest focused deliberate work there for a full year
- Study Han Truong's arc vs. Olivia Forgione's at Bristol Financial as a diagnostic frame: both worked hard; the difference was where investment went

Watch out for:

- Conflating "programs run clean" with "career is growing" - Olivia's programs were model programs and her career had been flat for three years; clean execution at the mechanical level is necessary but not sufficient for the next stage
- Investing new capacity freed by automation back into the same depreciating activities - if AI handles first-draft artifact authoring and you use the saved hour to produce more first-draft artifacts, the compounding effect doesn't transfer

Bottom line: The skills that compound - pattern recognition, stakeholder judgment, framing under pressure, strategic input, sponsor management - are the ones that unlock the next career stage, and they're built through deliberate reflection on cases, not through faster execution of mechanical tasks.

Shared & Cross-cutting · Leadership Notes (6)

Leadership Note — Hiring TPMs at every level

Leadership Note - Hiring TPMs at every level

In short: TPM hiring is one of the highest-leverage decisions a TPM leader makes, and the bar is different in kind - not just degree - at every level.

Hiring TPMs is one of the highest-leverage things you do as a TPM leader, and one of the easiest places to develop bad habits. The bad habits compound - a junior TPM hired with the wrong screen produces a decade of misaligned career growth; a senior TPM hired without rigor on the harder skills costs the organization for years. This note covers what to screen for at each level, the camouflage patterns that fool unwary interviewers, and how to treat hiring as a function rather than a sequence of individual decisions.

TPM hiring is harder than most technical hiring because the role's value is in judgment, and judgment is hard to assess in interview conditions. A senior engineer can be evaluated on coding, system design, and technical depth - measurable, comparable, gameable but with known anti-patterns. A senior TPM has to be evaluated on whether they will handle situations the interview can only describe, with stakeholders the interview can only sketch, under conditions the interview can only approximate. The signal is noisier, the false positives are more expensive, and the camouflage patterns are subtler.

Most TPM hiring rubrics treat the bar as identical at every level, just with more required at higher levels. This is wrong. The bar at junior is different in kind from the bar at senior, which is different in kind from the bar at staff. Evaluating a senior TPM with a richer version of the junior rubric tends to produce hires who are good at what juniors are good at - with more years - which is not what senior actually requires.

Junior TPMs (0-3 years): You are hiring for someone who can absorb the discipline, will show up consistently, has the temperament for ambiguity, and has a baseline of organization and communication strong enough to function. You are not hiring for senior judgment; you are hiring for someone who will develop senior judgment over years. Screen for: communication clarity (can they explain a complex situation in plain language without too much jargon or too little

structure); organization (can they hold multiple threads without dropping them); curiosity about why processes exist, not just compliance with them; and tolerance for ambiguity - not assessed by asking "are you comfortable with ambiguity" but by walking through a deliberately under-specified scenario and watching what they do. Juniors who panic and demand more information will struggle; juniors who form a working hypothesis and start moving while flagging what they do not know will succeed. A specific signal worth weighting: did they ask substantive questions in the interview - about the role, team, org, and work - rather than just "what does a typical day look like?"

Camouflage at junior level: The over-rehearsed candidate presents polished STAR answers and consistent excellence across every question. Probe with follow-ups that go off-script - the strong candidate adjusts smoothly, the rehearsed one repeats the original answer with different framing. The "I have done a lot" junior shows impressive scope on their resume (managed a multi-million dollar budget, led a team of 30) that often signals title inflation. The role they actually did is usually closer to coordinator or analyst. Not disqualifying, but evaluate the actual work, not the framing.

Mid-level TPMs (3-8 years): You are hiring for someone who can run a program end-to-end with limited oversight, has developed pattern recognition on common situations, and has the beginnings of stakeholder management capability. Screen for: demonstrated judgment on hard calls (listen for the texture of decision-making - strong mid-levels describe the considerations weighed, trade-offs accepted, people consulted; weak ones describe the outcome without the reasoning); end-to-end ownership (have they actually closed a program, or just contributed to programs that closed - programs that close cleanly require handling late-stage politics, loose ends, and lessons-learned discipline); pattern recognition starting to form (ask about a pattern they now recognize that they did not see in their first program - strong mid-levels can name one or two, such as "vendor SOWs that look clean at signing usually have one ambiguity that becomes the recovery situation"); and communication with stakeholders above their level (strong candidates have moved past meeting mechanics toward framing issues specifically for what a senior stakeholder needs to act on them).

Camouflage at mid-level: The "lots of programs" candidate has a resume showing many programs of varying scope, none described in detail - they have been on the periphery of a lot of work without owning much. The certification-heavy candidate carries PMP, Scrum Master, SAFe, plus three or four others. Certifications are not disqualifying, but a heavy certification stack at mid-level sometimes signals credentialing rather than experience-building. Weight observed judgment more than the certification list.

Senior TPMs (8-15 years): You are hiring for someone who can run multi-component programs, handle the political dimension competently, deliver bad news to sponsors without losing relationships, and produce artifacts reflecting real strategic thinking rather than just structural completeness. They should also be developing the ability to mentor junior TPMs. Screen for: judgment under genuine difficulty (ask about calls where the right answer was not clear even in retrospect - strong senior candidates have a history of decisions they are now uncertain about, and can articulate why; weak ones describe past decisions as obviously correct, signaling a lack of reflective capacity); political awareness without being political (recognizing the political dimension as one input to a substantively work-focused decision, neither pretending the politics did not exist nor treating them as the primary frame); ability to push back on senior people (ask about a time they disagreed with a senior leader - strong candidates have specific examples where they pushed back, and where they sometimes did not, and can articulate why each call was right); recovery capability (have they been TPM on a program that went badly and helped recover it - one of the highest-signal questions for senior hiring); and mentorship signals (are they articulating what they look for in junior TPMs, what they teach, what is hard to teach).

Camouflage at senior level: The smooth narrator has strong communication and polished stories but resists depth when pushed off their prepared narratives. The "I had to fight" candidate has multiple stories where they were the only one who saw the right thing, fought for it, and were proven right - this often signals an inability to operate within imperfect groups, which is most of senior TPM work. The technical depth flex has the candidate leaning on technical depth to compensate for thinner skills on judgment and political dimensions; ask what they think the role's actual differentiator is.

Staff and Principal TPMs (15+ years): You are hiring for someone who can operate at the program-of-programs level, build TPM capability in others, and contribute strategic input affecting how the function or the broader organization operates. They should have strong opinions formed through extensive experience, plus the calibration to know when to hold those opinions and when to update them. Screen for: strategic input on programs they did not own (can they describe a case where their judgment changed the structure of a program someone else was running - this is the staff-level move mid-levels and seniors cannot yet make); building TPMs who outperform expectations (can they name two or three TPMs who grew under their mentorship, with specifics about what they taught and how); strong opinions with soft attachment (watch whether they hold their position when it is right and update it when new information warrants, neither reflexively agreeing nor reflexively disagreeing); and comfort with their own uncertainty (staff and principal TPMs operating at the right level can articulate where they are still learning, where they have changed their minds, where they hold opinions tentatively).

Camouflage at staff and principal level: The presence-without-substance candidate carries themselves as senior, has the right title history, communicates well - but when probed, the actual substance is mid-level depth dressed up as principal. Real principal-level candidates have rich examples; presence-without-substance candidates have fewer than you would expect for the years. The "I have solved this before" candidate applies confident pattern-matching from previous companies without engaging with what is specific to your context - if their answer to a situation specific to your org is "I have seen this before, here is what we did," without engaging with your context, that is a flag.

The reference call template: For senior+ hires, the reference call is more diagnostic than the interview. Open with context about the role and its specific high-stakes challenges. Ask: "What is [candidate] genuinely best at?" - listen for specifics, not vague praise like "great communicator." Ask: "Where would you not want them?" - the most diagnostic question; wait through the silence. Ask: "What would they need to grow into for the role I am considering them for?" - the growth edges tell you about the gaps and whether the gaps fit the role. Ask: "Have you seen them handle a situation that went badly? What was that like?" - the recovery-pattern question. Avoid yes or no questions. Avoid "would you hire them again" - references almost always say yes. Two patterns worth watching: the reference who is relieved to be asked may be looking to provide real information they could not volunteer; the reference who is careful with words may be signaling a deeper concern through precise language.

When signal is mixed, junior and mid-level uncertainty is usually fine to proceed through if the floor is solid - growth potential determines whether the hire works out. At senior and above, uncertainty is more expensive; the hires you make affect programs, mentorship, and team culture. If uncertain, keep looking. The hardest call is a candidate strong on most dimensions and visibly weak on one - the right answer depends on whether the weakness can be developed (stakeholder relationship skills can be) or is structural (tolerance for ambiguity is harder to teach).

What good leaders do:

- Set distinct bars at junior, mid-level, senior, and staff levels that are different in kind, not just degree - and run separate rubrics for each rather than a universal rubric with a sliding scale
- Institutionalize the reference call with diagnostic questions that elicit texture beyond rehearsed praise, especially the "where would you not want them" question with deliberate silence
- Calibrate the interview team across hires so the function's bar is consistent and individual interviewers are not carrying idiosyncratic standards into decisions

Common traps:

- Evaluating senior TPM candidates using a richer version of the junior rubric, which produces hires who are strong at junior-level skills with more years rather than the qualitatively different judgment senior work requires
- Reading mixed signal optimistically at the senior+ level, which makes structural weaknesses invisible until the hire is integrated and the cost of the mismatch has already compounded

Bottom line: Hiring is a function, not a sequence of individual decisions - TPM leaders who treat it with rigor across clear per-level bars, consistent rubrics, and deliberate calibration build teams that compound in value across the decade.

Leadership Note — TPM org structure

Leadership Note - TPM org structure

In short: How you structure a TPM function shapes nearly everything about what it can do, and most functions are running with structures decided years ago under conditions that no longer fully apply.

How you structure a TPM function shapes nearly everything about what the function can do - what programs it can take on, how TPMs develop, what relationships form with the rest of the organization, and whether the function appreciates or depreciates in value over time. The structural decision is one of the most consequential calls a TPM leader makes, and it is often made early, often without enough deliberation, and rarely revisited even when the conditions that informed the original decision have changed.

This note covers how to think about the structural decision honestly: the two main axes - embedded vs. centralized and generalist vs. specialist - and the trade-offs at each; when to revisit your existing structure; and the discipline of making the call without being captured by either of the common ideologies (centralized PMOs are the only way to scale; embedded TPMs produce the best partnerships).

Embedded vs. centralized: TPMs sit somewhere on a spectrum from fully embedded in product or engineering teams (reporting into those organizations, evaluated against those organizations' goals) to fully centralized in a TPM function (reporting into a central TPM leader, evaluated against TPM-function goals). Most organizations land somewhere in the middle, with various configurations of dotted-line vs. solid-line reporting and various flavors of "embedded but with a community of practice."

The honest trade-offs: Embedded TPMs build deeper context with their teams - they share the same offsites, vocabulary, and incentives, and the relationship between TPM and engineering lead is closer because they are effectively peers. The cost is that the TPM's standards, methods, and judgment drift toward what their immediate team values, which may or may not match what the broader organization needs. Centralized TPMs build deeper TPM craft - they have peers who are TPMs, calibration discussions across programs, shared standards, and deliberate development paths. The cost is that the TPMs are partners-from-the-outside on the

engineering teams they support, and the partnership is harder to make work because the TPM is operating against goals that are not entirely the team's.

The choice is not permanent. Centralized works better when you need consistent program management standards across many teams - regulated industries, security-driven work, large enterprise environments where audit, compliance, and stakeholder management standards have to be roughly uniform. Embedded works better when you need deep partnership with engineering on highly variable work - product organizations where each team's work is structurally different and the TPM's value is in shaping the team's work specifically. Hybrid works better than either extreme in most large organizations: TPMs report through the TPM function for craft development, calibration, and performance, but have a strong dotted-line relationship with engineering leadership for program priorities, day-to-day partnership, and team integration.

What goes wrong with each: Embedded TPMs in organizations that have stopped investing in central craft development become unevaluated and uncalibrated - five years in, each TPM is operating against a different bar, and senior TPMs developed under different teams cannot reliably substitute for each other on a hard program. Centralized TPMs in organizations where the central function is too process-heavy become bureaucratic - standards are imposed rather than negotiated, engineering teams resist working with the TPM function because it feels like a tax, and TPMs themselves become demoralized by enforcing process rather than producing program outcomes.

The right structure shifts over time. An organization that benefited from a strong central PMO during a regulatory-heavy period may benefit from embedded TPMs once the regulatory pressure stabilizes. An organization that had embedded TPMs during fast growth may need a central function once stability and scale become more important than speed and team autonomy.

Generalist vs. specialist: TPMs can be generalists who can run any program type or specialists who focus on a particular domain (security TPMs, infrastructure TPMs, ML TPMs, regulatory TPMs). Most TPM functions have some mix; the question is how heavily to weight specialization.

Generalists are more flexible, can rotate between programs as priorities shift, develop broad pattern recognition that transfers across domains, and are not bottlenecked when their specialty is not in demand. Specialists bring domain depth that generalists cannot match, can run the hardest programs in their domain at higher quality, and develop relationships with domain stakeholders (security architecture, ML engineering, compliance) that generalists have to rebuild on each engagement.

The honest pattern that works in most organizations: generalists at junior and mid level, increasing specialization at senior and above for domains the organization has serious investment in. Junior TPMs benefit from breadth - specializing too early produces narrow growth. Senior TPMs in critical domains benefit from depth - the hardest programs in those domains require accumulated context that takes years to build.

Three traps with specialization: The over-specialization trap has the function specializing too aggressively - a security TPM, infra TPM, ML TPM, regulatory TPM - each of whom can only run one type of program, leaving the function unable to reallocate when the priority mix shifts. The accidental specialist trap has a generalist TPM assigned to two security programs in a row because they are available, becoming the de facto security TPM over two years, with generalist skills atrophying without anyone deciding this should happen. The leader's job is to make this specialization explicit (with deliberate development support) or rotate the TPM out before de facto specialization becomes permanent. The "we need a security TPM" trap has the organization hiring for a specialty as a stand-alone role - this sometimes works, but the new hire

often arrives without the broader TPM craft built from a generalist role first, and struggles to navigate political and stakeholder dimensions because their experience is limited to one domain. Better to develop specialists from inside the generalist bench when possible.

The relationship between structure and TPM development: Junior TPMs need exposure to many situations to build pattern recognition - a heavily centralized function with juniors rotating across programs serves this well; a heavily embedded function where each junior is locked into one team's work bounds their growth to what that team encounters. Mid-level TPMs need end-to-end ownership to develop senior judgment - structures that prevent this (because of escalation patterns, because of how programs are split) slow mid-level development and produce TPMs who cannot quite step up to senior even after years of work. Senior TPMs need access to genuinely difficult work - functions that mostly run routine programs produce senior TPMs whose ceiling is at routine programs. Staff and principal TPMs need scope and access - operating at a level where their judgment shapes more than one program at a time, with portfolio roles, embedded influence on architecture decisions, and formal mentorship of junior TPMs. Structures that do not create this scope cause staff and principal TPMs to plateau or leave.

When to revisit your structure: Most TPM functions are running with structures decided 3-7 years ago, often by someone no longer in the leader role, in response to conditions that no longer fully apply. Three signals warrant a revisit: You cannot reliably substitute one TPM for another - if a TPM goes on leave, retires, or gets pulled to a different priority and no one can step in within reasonable ramp time, the function has drifted into too much local context and too little function-wide consistency, which likely needs more centralization. The TPMs are bored - senior TPMs running the same kind of program for years, mid-level TPMs not getting harder work, junior TPMs stuck in narrow domains signals the structure has stopped producing the right development trajectory. Engineering leadership has been complaining or has stopped complaining - vocal frustration is data; no engagement at all is worse data, signaling the function has been written off as not worth the energy.

The structural revisit is a periodic activity, not continuous - every 2-3 years on a healthy function, more often if conditions are changing rapidly. The discipline is making the question explicit when it is time, not letting structure persist by default.

How to make the structural change land: Lead time matters - people need to know the change is coming, what is changing for them specifically, and what is not. Structural changes announced last week produce attrition and resentment; changes announced months in advance with thoughtful preparation produce adjustment. Identity matters - TPMs who have been "the security TPM" for three years have built identity around that role, and a structural change that dissolves it is not just a reporting change. Acknowledge this directly: help them see what the new role asks of them, what their existing skills bring to it, and what they will be developing into. Existing program continuity matters - time structural changes to align with natural transition points (program closures, fiscal year boundaries, major milestone completions) so the change does not force program-level handoffs on top of organizational disruption.

Two things you do not have to decide: You do not have to commit to one structure permanently - the structure you choose now will be revisited in 3-5 years, and this frees you to make a call that fits current conditions even if you are not sure it will fit future conditions. You do not have to optimize across every dimension at once - most structures are optimized for some things and worse at others, and trying to design a structure that is strong on every dimension produces compromised structures that are not strongly anything.

What good leaders do:

- Choose the embedded vs. centralized and generalist vs. specialist axes deliberately for current conditions rather than inheriting the previous leader's structure by default, and revisit the structure every 2-3 years or when conditions shift materially
- Develop specialists from inside the generalist bench rather than hiring directly for a specialty as a stand-alone role, which tends to produce narrow hires who lack the broader TPM craft to navigate political and stakeholder dimensions
- Time structural changes to natural transition points (program closures, fiscal year boundaries), provide months of lead time rather than last-week announcements, and acknowledge identity disruption explicitly for TPMs whose roles are being reshaped

Common traps:

- Running with a structure decided 3-7 years ago under conditions that no longer apply because revisiting the structure is uncomfortable, which means the function serves yesterday's needs at the cost of today's programs and tomorrow's TPM development
- Over-specializing the function so that each TPM can only run one type of program, leaving no flexibility when the priority mix shifts - most organizations need a few specialists in the highest-leverage domains and generalists for everything else

Bottom line: No structure is right for all conditions, and the leader's job is to keep the structure aligned with what the organization actually needs - treating structure as a tool to be deployed and adjusted rather than a permanent feature of the function.

Leadership Note — Scaling judgment across a team

Leadership Note - Scaling judgment across a team

In short: The hardest leadership transition is from "I make good program calls" to "my team makes good program calls without me in the room," and it requires deliberate apprenticeship rather than documentation or process.

Most TPM leaders make the transition from individual contributor to leader by adding management responsibilities to their existing program work. They keep running programs, they take on people management, they attend leadership meetings. The work is more, the meetings are more, but the day-to-day muscle is not fundamentally different - they are still using their own judgment to make program calls, just on more programs with more reporting overhead.

The harder transition, which most leaders do not fully make until years later, is from "I make good program calls" to "my team makes good program calls without me being in the room." This is the actual leverage of leadership, and it distinguishes leaders whose teams scale from leaders who become bottlenecks. It is also the hardest skill the role requires, because judgment does not transfer through documentation, does not fully transfer through meetings, and does not transfer at all through process compliance.

Why judgment does not transfer through documentation: The instinct, when you realize you cannot be in every program decision, is to write down how you would think about it. Decision trees. Frameworks. Playbooks. Process documents. The artifact then sits in a wiki and TPMs are told to consult it when facing similar situations. This rarely works. First, documentation captures conclusions but not texture - "escalate when the issue requires sponsor-level authority" is a sentence anyone can read, but the judgment about whether a particular issue requires sponsor-level authority requires reading the situation, the relationship, the political moment, and a dozen other things the document cannot capture. The TPM consulting the document gets the rule and not the calibration that turns the rule into action. Second, documentation calcifies - judgment evolves with conditions, but documentation once written tends to be left alone because revising it is work, and the result is that teams start operating against patterns that no longer fit reality. Third, consulting documentation in the moment does not fit how judgment actually works - real-time program decisions require fluid pattern matching that draws on

hundreds of past situations, not lookup against a written rule. By the time a TPM has consulted the document and applied the rule, the moment has often passed or the situation has shifted. Documentation has value for onboarding and reference and capturing decisions that have been made - but it does not substitute for the apprenticeship that produces actual judgment.

What does work - deliberate apprenticeship: The thing that produces consistent judgment across a team is deliberate apprenticeship: senior TPMs making their judgment work visible to junior TPMs, in real time, on real situations. The "see one, do one, teach one" pattern from medical training, applied to TPM craft. Three things have to happen: The senior TPM has to make their thinking visible - not just the conclusions but the considerations weighed, the trade-offs accepted, the things they almost did but decided against, the patterns they were noticing. This is unnatural; most senior TPMs do their thinking internally and surface only the output. Making thinking visible requires deliberate verbalization, which feels uncomfortable until it becomes a habit. The junior TPM has to be in the room - not after the fact reading the decision log, but in the moment when the call is being weighed. This requires the senior TPM to invite them in (often involving rescheduling work to align), the junior to be ready to receive (more about posture than skill), and the leader to design situations where proximity is natural rather than performative. There has to be reflection afterward - the decision was made, the situation played out, what did we learn. This reflective layer turns proximity into pattern recognition; without it the junior was in the room but did not extract the durable lesson.

Three patterns that operationalize deliberate apprenticeship: Pre-decision walkthroughs - when a senior TPM is facing a hard call, they pull a junior TPM into a 30-minute conversation before the call is made: "Here is the situation. Here is what I am thinking. What am I missing?" The junior asks questions, the senior verbalizes, the call ends up being made together. This is one of the highest-leverage activities in scaling judgment, and most TPM leaders do not institutionalize it. Decision review meetings - a small group of TPMs walks through a recent decision someone made, after the fact, with the benefit of how it played out - not as evaluation but as learning: "I did X; here is why; here is how it went; here is what I would do differently." Done well this is the most productive hour on the calendar; done badly (as performance evaluation, as the leader correcting people) it kills the candor that makes it work. Pair-running on hard programs - two TPMs at different levels both work on a particularly hard program, with explicit overlap on the decisions the senior would normally make alone. More expensive than the standard one-TPM-per-program model, and on the hardest programs worth the cost.

What you teach explicitly vs. what only develops through proximity: Some aspects of judgment transfer through documentation, training, and direct teaching - frameworks for thinking through trade-offs, patterns to recognize, specific moves that work in specific situations. Other aspects only develop through proximity: the calibration about how to read a sponsor's tone, the instinct about when something is starting to drift, the framing reflex that produces the right opening sentence in a hard conversation. These require accumulated exposure to many situations. The TPM leader's job is to recognize which kind of skill they are trying to develop and use the right approach. Trying to teach calibration through frameworks produces TPMs who know the frameworks and lack the calibration. Trying to develop framework knowledge through proximity alone produces TPMs who can imitate their mentors without a structured understanding of why their imitations work.

Two failure modes at the extremes: Under-mentoring produces inconsistent judgment - the leader is too busy running their own programs, is not deliberate about apprenticeship, and the team's judgment develops independently. Each TPM forms patterns based on their own programs. The team makes calls inconsistent with each other. Sponsors get different answers from different TPMs. The signal: when you ask three TPMs how they would handle the same situation, you get three substantively different answers. Some variation is healthy; consistent strong divergence signals judgment has scaled poorly. Over-mentoring produces dependent

TPMs - the leader is in every decision, every escalation, every hard call. The team executes but does not develop its own judgment. When the leader is unavailable, the team stalls. When TPMs are promoted, they realize they lack the muscle for harder work because they have always had the leader to fall back on. The signal: when you take a week off things slow down dramatically; when TPMs hit hard situations their first move is to escalate to you rather than work it themselves and bring you the analysis; when a TPM moves to another team or company their performance drops noticeably because the leader's judgment was carrying them.

The norms that protect the calibration: Three norms worth establishing explicitly. Decisions of [type] come to me; decisions of [type] do not - be specific about what types: "Decisions involving formal escalation to a sponsor's peer or above come to me; decisions about how to frame a status report do not." Without explicit norms, TPMs default to either escalating everything or escalating nothing. These norms should adjust as TPMs develop, with explicit conversation about the adjustment. If you are consulting me, bring your analysis first - the TPM who walks in saying "what should I do" is operating under a different model than the TPM who says "here is the situation, here is what I am thinking, here is what I am uncertain about, what am I missing." The second pattern develops judgment; the first outsources it. I will back your call even when I would have called it differently - this is the norm that makes the rest work. If TPMs experience that calls they made differently than the leader would have are quietly second-guessed in retrospect, they will start running every call past the leader before making it, producing dependence. If the leader actively backs the TPM's call publicly while sometimes coaching privately afterward about the alternative framing, the TPM develops confidence to make calls without you. Leaders who pride themselves on their judgment sometimes find this costly to sustain - but the long-term cost of not backing calls is much higher than the short-term cost of backing one you would have made differently.

Day-to-day habits that produce judgment scaling over years: Be explicit about your reasoning, not just your conclusions - when you make a call, narrate the reasoning; when you give feedback on a TPM's call, focus on the reasoning rather than the conclusion (especially when their conclusion was different from yours), because the reasoning is what transfers. Create reflection moments - the post-program retrospective, the decision review meeting, the 1:1 conversation about a recent hard call; these create the structure where pattern extraction happens, and without them situations come and go without producing the durable lesson that becomes judgment. Hold your tongue more often than feels natural - the temptation when you see a TPM about to make a call you would make differently is to redirect them; sometimes that is right when the consequences are too high to absorb, but often it is wrong and the TPM needs to make the call themselves, see how it plays out, and develop their own judgment from the experience. Letting suboptimal calls happen on purpose is part of how judgment scales, and it is one of the hardest disciplines because it requires accepting outcomes that are worse than you would have produced yourself.

The career-arc dimension: Different TPMs at different levels need different things. Junior TPMs need scaffolding - explicit frameworks, deliberate exposure to senior thinking, frequent feedback on the reasoning behind calls; mentorship is more directive at this stage. Mid-level TPMs need challenge - harder programs, situations they have not encountered before, opportunities to make calls without the safety net; mentorship is more about creating exposure than direct teaching. Senior TPMs need peers - calibration discussions with other senior TPMs, exposure to your own judgment work as a peer rather than as a mentor, occasional sounding-board conversations; mentorship at this level is largely lateral, with you facilitating rather than providing it directly. Staff and principal TPMs need scope and visibility - programs that exercise judgment at scale, exposure to organizational decisions that affect their work, your active backing in conversations they are not in; mentorship is mostly about removing constraints and providing air cover. The pattern across these stages: the leader's involvement decreases as

TPMs advance, and the involvement that remains shifts in character from teaching to facilitating to advocating. Leaders who try to mentor staff TPMs the way they mentored juniors produce frustrated staff TPMs and miss the actual leverage at that level.

When the team's judgment is genuinely better than yours: The end state of good judgment scaling is that members of your team make calls in their domain better than you would. This is uncomfortable for leaders who built their identity around being the strongest individual contributor. It is also the goal. A team where the leader is the strongest TPM on every dimension is a team that has not successfully scaled. When you notice this - a TPM on your team consistently making better calls than you would in their domain - the right response is to celebrate it explicitly: "I would have made this differently and I think your call was better. Here is what I learned from how you handled it." This signals that the team's growth past your individual capability is the goal, not a threat. Leaders who cannot acknowledge their team's superiority in some dimensions tend to limit how much their team can grow.

What good leaders do:

- Institutionalize deliberate apprenticeship through pre-decision walkthroughs (30-minute conversations where a senior TPM verbalizes their thinking on a hard call with a junior present), decision review meetings (small group retrospectives on recent decisions, run as learning not evaluation), and pair-running on the hardest programs
- Establish explicit norms about which decision types warrant escalation and which do not, adjust those norms as TPMs develop, and require TPMs to bring their own analysis before consulting - because "what should I do" outsources judgment while "here is what I am thinking, what am I missing" develops it
- Back TPMs' calls publicly even when the call differs from what you would have made, coaching privately on the alternative framing afterward - because leaders who quietly second-guess different-from-theirs calls produce dependent teams that stall when the leader is unavailable

Common traps:

- Trying to scale judgment through documentation (decision trees, playbooks, process documents) rather than apprenticeship - documentation captures conclusions but not the calibration that turns rules into action, calcifies as conditions change, and does not fit how real-time judgment actually works
- Over-mentoring by staying in every decision and escalation, which produces a team that executes but does not develop its own judgment - the signal is that taking a week off causes things to slow down dramatically, and that TPMs' performance drops when they move to teams where the leader's judgment is not carrying them

Bottom line: Scaling judgment is the hardest part of TPM leadership and the one with the most compounding return - leaders who invest in deliberate apprenticeship build functions whose leverage grows non-linearly over years; leaders who do not find their team's scale permanently bounded by their personal involvement.

Leadership Note — Building a PMO from zero

Leadership Note - Building a PMO from zero

In short: The first 90 days of building a PMO are largely deterministic - listen before you build, ship the smallest version that produces value, and treat engineering leadership as partners rather than constituents.

You have taken on the role of building a PMO function that does not yet exist, or rebuilding one that exists in name but has not been working. The mandate sits somewhere on the spectrum from "we need program management discipline" to "we need a real PMO." Your first 90 days will largely determine what the function becomes over the next three years. Most of the calls that

matter most are made early, before there is enough context to make them confidently, and they compound - early structure shapes later structure, early hires shape later hires, early relationships with engineering leadership determine whether the PMO becomes load-bearing or becomes a bottleneck.

This is about that early window: what to require, what to recommend, what to leave alone, the temptation patterns that produce PMOs that look impressive and do not work, the discipline of deciding what NOT to do, and the relationship with engineering leadership that determines whether you are building a function people want to work with or a tax they are trying to route around.

The first 30 days: listening, not building

The instinct when you have been hired or promoted to build a PMO is to start building - standards, templates, processes, governance frameworks. The energy of the new role pushes toward visible early action. Resist this. The first 30 days are for understanding what you are walking into, not for imposing structure on it. The structure you would impose without listening will be calibrated to your assumptions about the organization rather than to the organization's actual situation. Most failed PMO setups fail at this stage - the leader started building before they understood, and the function they built was solving the wrong problems.

Talk to the engineering leaders - the VPs, directors, and senior engineering managers whose teams will be supported by or constrained by the PMO. Each conversation is 45 minutes. Ask: what is working in how programs are run today? What is broken? What have you tried before that did not work? What would you want from a PMO function, and what would you not want? These conversations will tell you more than you expect. Patterns of complaint surface what is actually broken. Patterns of resistance to past PMO attempts surface what will not work going forward. Engineering leaders' hopes - often modest and specific - tell you what would land well early.

Talk to the existing TPMs, if there are any. They have been operating in whatever the current state is. They know what is actually being done, what is officially supposed to be done but is not, and what has been tried and abandoned. Their tactical knowledge is invaluable and they are often eager to share it because they have been operating without leadership direction.

Talk to the senior stakeholders the PMO will serve - sponsors frustrated with how programs are being run, compliance and audit leaders who care about discipline, finance partners who want predictability. Each gives a different angle on what the function is for.

Read the program records. Status reports, post-mortems, lessons learned, retrospectives, cross-program analyses, audit findings. The documents tell you what the organization has noticed about its own program management and what it has tried to fix.

By the end of the first 30 days, you should have a working theory of what the PMO needs to do, what has been tried before, what would land well, and what would produce active resistance. You should not yet have built anything.

The first 60 days: the minimum viable PMO

Once you understand the situation, the second 30 days is about implementing the smallest version of the function that produces value. The temptation here is to define the full function and start building it. The discipline is to define a small initial scope that produces visible value quickly, with explicit room to expand later.

What "minimum viable PMO" means varies by organization, but the pattern usually has three components:

A standard for what programs require what artifacts. Not a forty-page methodology document - a one-page reference. "Programs above [threshold] require a Charter. Programs below [threshold] do not. Charters require these five sections. Status reports cycle weekly or biweekly

depending on program tier. Decisions get logged in this format." Specific, brief, defensible. The TPMs and engineering leaders should be able to read and understand the standard in 10 minutes.

A small set of templates and examples. Not the comprehensive toolkit you will eventually have. Three or four templates, each with one good example - Charter, RAID, status, decisions log. The team uses these as starting points; they do not have to be perfect to be useful.

A cadence of leadership engagement. The senior stakeholders need a way to know what is happening across the program portfolio - a monthly portfolio review with one-page summaries of each program. The cadence is the function's rhythm; it is what makes the PMO visible to the organization beyond individual programs.

What to deliberately NOT do in the first 60 days: do not build elaborate process - the fancy intake process, multi-stage approval gates, and comprehensive governance framework can wait, and most will not be needed at all if the basic standard is working. Do not try to centralize everything. Do not hire a large team early - one or two strong TPMs can run the minimum viable function, and hiring five or ten people in the first 60 days commits you to a structure before you know what structure will work. Do not write the comprehensive playbook - documentation should follow demonstrated practice, not precede it.

The first 90 days: visible value, expanding scope

By day 90, the PMO should be visibly producing value. Programs are being chartered with the new standard, and the charters are visibly better than what existed before - not perfect, but substantively improved. Status across the portfolio is rolling up to leadership in a useful way, not just adding to the email volume. A specific problem the engineering leaders identified in the first-30-days conversations has been visibly addressed. The TPMs are reporting that the new structure is helpful, or at minimum not getting in their way.

If these are not true at day 90, the function is not on the trajectory to become useful - slow down further building and do another round of listening. If they are true, the function has earned the right to expand scope: additional templates, more TPMs, specialized roles where warranted, deeper engagement with high-priority programs. The expansion happens deliberately and incrementally, not through a master plan.

The temptations that produce PMOs that do not work

Three patterns of failure worth naming explicitly because they are seductive enough that careful leaders fall into them.

The over-engineered PMO. The leader, eager to demonstrate that the function is serious, builds a comprehensive framework with multi-stage approval gates, detailed methodology documents, and specialized intake processes. The function is impressive on paper. Engineering leaders quickly figure out how to route around it. The TPMs spend their time on process compliance rather than program outcomes. The signal: engineering leaders are quietly running parallel program structures because they cannot get what they need from the official process; programs hit milestones outside the formal review process; decisions get made informally and documented after the fact.

The PMO-as-tax. The function is set up as something programs have to comply with rather than something that helps them. Charters get filed because they are required, not because they are useful. Status reports are produced for the PMO's reporting cycle, separate from how the program is actually being run. The signal: TPMs and engineering leaders speak about the PMO as something they have to deal with, not something they collaborate with; function-PMO meetings have low engagement; artifacts are produced but not consulted.

The PMO that tries to do the work. The leader, frustrated with how programs are being run, has the PMO start running programs directly rather than supporting the engineering organizations

that own them. PMO TPMs become de facto program owners; engineering leadership disengages because the PMO has taken responsibility. The signal: engineering leaders treat program outcomes as the PMO's responsibility rather than their own; engineering managers are surprised by program-level decisions because they are not in the loop; the PMO TPMs are spread thin running programs that should be running themselves with PMO support.

The relationship with engineering leadership

The single most important variable in whether your PMO succeeds is your working relationship with engineering leadership. If they see the PMO as a partner that helps their organization deliver, the function will work. If they see it as a structure imposed on them, the function will struggle regardless of how well-designed it is.

Spend time with them, not on email - recurring 1:1s with each engineering VP, conversations that are not about specific programs, working through their priorities, concerns, and views on how the engineering organization is running. The relationship is what makes the PMO's structural work land; without it, the structural work is process imposed on people who did not agree to it.

Be useful before you ask for compliance. The first thing the PMO should do is help engineering leaders with something they care about - surface a portfolio-level view they did not have, take a specific operational headache off their plate, provide the structured analysis they have been wanting. After the function has demonstrated usefulness, the structural requirements (charters, status standards) land much better.

Acknowledge when their concerns are right. Engineering leaders sometimes have legitimate concerns about PMO function design. Sometimes the right answer is "you are right, we will change this." Acknowledging this builds the relationship more than holding firm on every point, and produces better function design because engineering leaders often see things you do not.

The longer arc

The first 90 days set the trajectory; years one through three is when the trajectory plays out. Function-wide TPM development is part of the PMO leader's job - the PMO is not just a function that runs programs but the development pipeline for senior TPM capability. PMOs that treat TPMs as fungible execution capacity produce stagnation; PMOs that treat them as developing professionals produce TPMs who become the backbone of the function over the years.

Mature PMOs also provide strategic input on what programs the organization should be running - portfolio strategy, not just program execution. This requires the function to have credibility, which requires demonstrated value over time. And be willing to periodically restructure. The function that worked in year one usually does not fit in year four. Revisiting structure disturbs working patterns but is necessary.

What good leaders do:

- Spend the first 30 days listening to engineering VPs, directors, TPMs, and senior stakeholders before building anything, using 45-minute conversations to surface what is broken, what has been tried, and what would produce active resistance
- Build the minimum viable PMO in days 31-60: a one-page artifact standard, three or four templates with examples, and a monthly portfolio review cadence - explicitly deferring the comprehensive governance framework
- Treat the PMO as a service function rather than a control function, anchoring every new requirement to what engineering leaders themselves said they needed, and pruning requirements twice a year that are no longer producing value

Common traps:

- Building a comprehensive framework with multi-stage approval gates and detailed methodology documents before demonstrating usefulness, producing a function that engineering leaders route around while the TPMs spend their time on process compliance
- Having the PMO take over program ownership rather than supporting engineering organizations, which causes engineering leadership to disengage and makes the PMO responsible for outcomes it cannot actually control

Bottom line: PMOs built carefully and incrementally - listening first, shipping the minimum viable version, earning engineering leadership's trust before asking for compliance - tend to become load-bearing functions over the years, while PMOs built grandly and quickly tend to become hollow shells the organization works around.

Leadership Note — Mentoring at each career stage

Leadership Note - Mentoring at each career stage

In short: The mentorship that develops a junior TPM is fundamentally different from what develops a senior or staff TPM, and leaders who apply the same style across all levels will systematically over-mentor some and under-support others.

The mentorship work for a junior TPM is fundamentally different from the work that develops a mid-level, senior, or staff TPM. The same leader applying the same approach across all levels will produce mismatched results - junior TPMs underdeveloped because they needed more direct teaching than the leader provided, staff TPMs frustrated because they got direct teaching when they needed peer thinking and air cover. Most TPM leaders default to a single mentorship style (often the one that produced their own development), and the default produces strong outcomes for some of their team and weaker outcomes for others.

This is about adjusting your mentorship work to what each person actually needs at their career stage. The pattern shifts dramatically - what worked for a junior TPM stops working at mid-level; what worked for a senior TPM is wrong for a staff TPM - and the discipline is recognizing the shift and adjusting deliberately.

The shape of the shift

At each career stage, the mentorship serves a different developmental need. Junior TPMs need scaffolding - they are building the basic muscles of the role and need explicit structure to attach learning to; the mentorship is more directive, more frequent, more focused on the mechanics. Mid-level TPMs need challenge - they have the basic muscles and need exposure to harder situations to develop the next layer; the mentorship is less about teaching and more about creating opportunities for growth they would not naturally find. Senior TPMs need peer thinking - they have developed enough judgment that the mentorship should feel collaborative rather than directive; the leader's job is to be a sounding board for calls the senior is making, not to make the calls for them. Staff TPMs need visibility and air cover - they are operating at a scope where the leader's main contribution is creating conditions for them to do their work, not teaching them how.

What a junior TPM needs (0-3 years)

A junior TPM is building scaffolding for their judgment. Frequent, explicit feedback on the basics: their first charter, their first status report, their first stakeholder register each gets reviewed in detail with specific feedback focused more on what to consider than on the specific revisions to make - "when you write a status, the question to ask is who is reading this and what do they need to know to act; your draft has a lot of detail; let's walk through what your sponsor would actually need."

Exposure to senior decision-making: the junior should be in the room when a senior TPM is thinking through a hard call - not as a participant but as an observer who can ask questions afterward. "I noticed you weighed three options for how to frame the recovery. How did you

decide which one? What would have changed your mind?" The exposure is more important than the lesson; the lesson develops over time from many exposures.

Direct teaching of frameworks and patterns: RACI rules, RAID Log discipline, the difference between At-Risk and Off-Track, what is in a Charter and why. These transfer through teaching. The junior should not have to derive them from scratch.

Calibration on judgment they cannot yet trust: when the junior makes a call you disagree with, walk them through your thinking - not to override the call but to help them develop the calibration to make better calls later. "I would have framed this differently. Here is why." Specific, recent, with the texture of your reasoning.

What junior TPMs do not need and often get: vague encouragement, complete autonomy on hard situations, mentorship sessions that are mostly about career trajectory rather than current work. Encouragement without specifics does not develop them. Autonomy on situations they are not ready for produces failed programs and damaged confidence.

What a mid-level TPM needs (3-8 years)

A mid-level TPM has the basics. They are now developing pattern recognition, end-to-end ownership, and the beginnings of stakeholder management capability. The mentorship shifts from teaching frameworks to creating challenge and providing reflection space.

They need harder programs than their experience strictly justifies - a recovery, a heavily political stakeholder situation, a vendor problem - with sufficient support to succeed but not so much that the experience is removed. They need reflection space after hard situations: the conversation a few days after the difficult vendor renegotiation, "walk me through what you were thinking; what do you wish you had done differently; what pattern are you starting to see?" - this is what turns experience into pattern recognition.

They need less directive feedback. Mid-levels who are still being told what to do on tactical decisions stop developing their own judgment. "How are you thinking about this?" beats "here is what I would do." And they need honest assessment of their growth edges: by mid-level the strengths and weaknesses are visible; the leader's job is to name them clearly and create development plans for the weaknesses. "Your stakeholder management is strong; your recovery instincts are still developing. Let's get you on a program where the recovery muscle has to grow."

What mid-levels do not need: continued teaching of frameworks they should already have, continued autonomy without challenge, mentorship that focuses only on what they are already good at. The growth at this stage is in addressing what they are not yet good at, and mentorship that avoids the harder conversations produces stagnation.

What a senior TPM needs (8-15 years)

A senior TPM has mature judgment in their primary domain. The mentorship at this level is fundamentally different - it is largely lateral. They need peers more than mentors, and the leader's job shifts from teaching to facilitating.

They need sounding-board conversations: the senior faces a hard call and wants someone to think through it with, not to be told what to do. The conversation that works has them walking through the situation while you ask questions that surface considerations they had not fully weighed, and the call ends up better-informed but theirs. The conversation that does not work is one where you make the call for them, even subtly.

They need exposure to your own judgment work as a peer - sharing a hard call you are facing, asking for their input, treating them as a peer whose perspective matters. This signals that you respect their judgment and treats them as a developing leader rather than an advanced IC. It also produces better calls.

They need calibration on cross-program patterns - "here is something I am noticing across the function; does this fit your read?" - to build their portfolio-level perspective and prepare them for staff-level work. And they need honest acknowledgment of where their experience is now richer than yours: "you have handled more vendor situations than I have; what is your read here?"

What seniors do not need: directive coaching on tactical calls, mentorship that treats them as advanced juniors, performance feedback that focuses on basics they mastered long ago. The senior who is still being mentored as if they were mid-level often leaves the function within a year because they sense - correctly - that they are not being treated at the level they have earned.

What a staff TPM needs (15+ years)

The staff TPM is operating at a level where the leader's role is largely about creating conditions for them to operate effectively. The mentorship is mostly indirect - air cover, scope, visibility, removal of constraints.

They need programs of sufficient scope - programs of programs, strategic initiatives, functions where their pattern recognition produces decisions that affect many people. Without scope at this level, they plateau.

They need air cover in conversations they are not in. The staff TPM made a call you would have made differently. In the conversation with the senior leader questioning it, you back the call. Privately, later, you might walk through the alternative framing. But publicly you support what they decided. This is the highest-leverage thing you do for staff TPMs - and it is the thing many leaders fail at because their instinct to demonstrate their own judgment overrides their willingness to back their staff TPMs' calls.

They need visibility into organizational decisions that affect their work - strategic priorities, headcount calls, structural choices - and sometimes participation in those decisions. And they benefit from mentors outside the function: senior leaders in other organizations, peers at other companies, advisors who have been in the role longer. The leader's job is sometimes to help connect the staff TPM to people who can mentor them in ways the leader cannot.

What staff TPMs do not need: directive coaching on calls within their domain, frequent feedback on tactical execution, mentorship that does not acknowledge the scope they are operating at. These signal that the leader has not adjusted to working with someone at this level, and the cost is high because staff TPMs are harder to replace.

The transitions between levels

The hardest mentorship moments are the transitions between levels. A TPM who was developing well as a mid-level may struggle in their first year as a senior because the mentorship has not shifted with them. A senior promoted to staff may produce thinner work than expected because the leader has not adjusted to backing their calls rather than coaching them.

Acknowledge the transition explicitly: "you are moving into senior work; the mentorship I have been giving you was right for mid-level; it is going to feel different now; I am going to ask more questions and tell you less." Naming the shift makes it land; leaving it implicit means the TPM has to figure out what changed without help.

Adjust before the title catches up. The mentorship style appropriate for the next level often makes sense to start six to twelve months before the formal promotion. Treating a soon-to-be-senior TPM with senior-style mentorship helps them develop into the role rather than waiting until the title forces the adjustment.

Watch for misalignment in the other direction - the senior who is still being mentored as mid-level, the staff TPM who is not getting air cover. These are leadership failures, and they cost the function senior-plus TPMs who leave because they are not being treated at the level they have earned.

A useful frame: at each level, there is something you stop doing. You stop teaching frameworks at mid-level (mostly). You stop tactical coaching at senior level. You stop directive feedback at staff level. The stopping is as important as the doing. Continued teaching at mid-level produces stagnation. Continued tactical coaching at senior level produces frustration. Continued directive feedback at staff level produces resignation. The pattern that worked is exactly the pattern to stop using, which is unintuitive and often gets done late.

When mentorship reveals you have under-supported someone at an earlier stage

Sometimes in working with a senior TPM you will discover gaps that should have been filled at mid-level - the senior who has never had to lead a recovery, the mid-level who never developed pattern recognition because they were rotated too quickly, the junior who never had explicit teaching of basic frameworks because their first leader assumed they would pick it up. Address these honestly with the TPM: "I am noticing you have not had X experience that is typically present at your level; I would like us to find a way to develop that capability; here are some options." Most TPMs respond well when it is framed as developmental rather than punitive. They have often noticed the gap themselves. This is not silently writing off TPMs who developed under suboptimal mentorship - they are not the ones who failed; the development pipeline failed.

What good leaders do:

- Adjust mentorship posture explicitly at each career transition, shifting from directive framework-teaching at junior level to challenge-creation and reflection at mid-level, to sounding-board peer conversations at senior level, to air cover and scope at staff level
- Name the transition out loud when it happens - "you are moving into senior work and the mentorship I have been giving you was right for mid-level; it is going to feel different now" - so the TPM does not have to figure out what changed without help
- Back staff TPMs' calls publicly in conversations with senior leaders, even when you would have decided differently, reserving alternative framing for private 1:1 conversations afterward

Common traps:

- Applying the mentorship style that produced your own development uniformly across all levels, producing junior TPMs who are under-taught basic frameworks, mid-levels who are never challenged with harder programs, and seniors who are frustrated by continued directive coaching
- Missing or delaying the transition adjustment so a newly promoted senior or staff TPM continues to be mentored at the previous level, signaling you have not recognized their growth and accelerating their departure from the function

Bottom line: The highest-leverage mentorship adjustment a TPM leader makes is recognizing what to stop doing at each career transition - stopped framework teaching at mid-level, stopped tactical coaching at senior, stopped directive feedback at staff - because the pattern that worked at the previous level is exactly the pattern that will stall development at the next.

Leadership Note — Performance conversations for TPMs

Leadership Note - Performance conversations for TPMs

In short: Evaluating TPM performance on artifact volume and program outcomes mistakes measurable proxies for the actual job; the work that matters - judgment quality, stakeholder relationship trajectory, and growth pattern - requires sustained attention and harder conversations.

Evaluating TPM work is harder than evaluating most technical work because the role's value is in judgment, and judgment does not reduce cleanly to metrics. Programs land on time and the TPM may have been the reason or may have been incidental to it. Programs land late and the

TPM may have prevented a worse outcome through skill or may have caused the slip through poor execution. Status reports look good and the underlying program may be in trouble; status reports surface trouble and the underlying program may be exactly where it should be. The artifacts that document the work are easier to evaluate than the work itself, and most performance evaluation drifts toward what is measurable rather than what matters.

This is about the discipline of evaluating TPM work in a way that captures the actual job - not about HR processes, performance ratings systems, or the formal review structure your organization uses, but about how to think about TPM performance, what to weight, what to discount, and how to give feedback on the harder dimensions in a way that produces growth rather than confusion.

What gets measured, and what is misleading

Three default metric categories are worth understanding because they are in wide use and systematically distort evaluation.

Program outcomes: did the program land on time, on budget, with scope intact. These look like good performance metrics and are surprisingly weak. A skilled TPM on a structurally difficult program may produce a slip that is the best possible outcome under the conditions; a less-skilled TPM on a well-resourced easy program may land it on time without contributing much. Treating program outcomes as the primary performance signal mistakes situational outcomes for individual contribution. Program outcomes are useful as one input, weighted by the difficulty of the situation - the TPM who delivered a recovery program that was a write-off when they took it on is doing harder work than the TPM who delivered a routine program set up for success.

Artifact quality and volume: does the TPM produce strong charters, status reports, RAID Logs, decision logs. This is more measurable than program outcomes and even more misleading. Strong artifacts can hide weak underlying program execution; weak artifacts can hide strong execution. The artifact is a representation of the work, not the work itself. A leader evaluating primarily on artifacts will systematically underweight the strongest TPMs.

Stakeholder feedback: what do the engineering leaders, sponsors, and other stakeholders say about the TPM. This is more diagnostic than the previous two but has its own problems. Stakeholders who did not get what they wanted from a program will sometimes attribute that to the TPM regardless of whether the TPM was responsible. The pattern of stakeholder feedback over time and across multiple programs is more reliable than any individual data point. The TPM who consistently gets positive feedback from many stakeholders across many programs is genuinely strong. The TPM who consistently gets mixed feedback regardless of program type may have a dimension of their work that is not landing.

What actually matters

Three dimensions capture more of what TPM performance actually is, but are harder to measure.

Judgment quality across decisions: how well did the TPM call the hard situations across the year - the recovery decision that needed to happen and did, the escalation that was not taken when it should have been, the reprioritization that was absorbed when it should have been surfaced. Looking at the year's decisions and asking which were well-called and which were not is harder than looking at metrics, but it is much closer to what the role actually delivers. This evaluation requires either being close enough to the work to have your own read, or being able to interview stakeholders about specific decisions in detail.

Stakeholder relationship trajectory: did the TPM's relationships with key stakeholders strengthen or weaken across the year. Are sponsors who worked with them inviting them into next year's programs? Are engineering leaders specifically requesting them on programs versus accepting them as assigned? The trajectory of relationships is one of the strongest signals of

TPM performance because it integrates many other dimensions - judgment, framing, reliability, political read.

Pattern of growth: is the TPM developing, plateauing, or regressing. The mid-level who is developing senior judgment is on a different trajectory than the mid-level who has been at the same level for two years without visible growth. The senior who is reaching toward staff-level work is contributing differently from the senior who is content at senior level. Growth pattern matters because it predicts future contribution, and TPMs are long-term investments more than short-term outputs.

These dimensions are harder to evaluate than artifact volume or program timing, and they require more sustained attention from the leader. They also produce evaluations that are much closer to the actual contribution.

The artifact production trap

The single most common pattern in TPM performance evaluation is over-rewarding artifact production. The TPM who churns out documentation looks productive; the TPM whose week is more conversation, thinking, and judgment looks less productive. The artifact-heavy TPM gets stronger reviews; the judgment-heavy TPM gets weaker reviews. This pattern is slow-acting but corrosive: over years, it shifts the function toward producing more output and less actual program management.

Two specific moves help. Periodically ask "what did this TPM do this quarter" without looking at the artifact volume - the answer should center on the programs they ran, the situations they handled, the calls they made, the relationships they built; if the answer can only be expressed through documentation produced, the evaluation is incomplete. When reviewing artifacts, evaluate the strategic content, not just the structural completeness - a perfectly formatted Charter that captures shallow strategic thinking is a weak artifact even if it ticks every section; a roughly formatted Charter that captures real strategic depth is a strong artifact even if less polished.

Giving feedback on the harder skills

The skills that matter most - judgment, framing, stakeholder management, political read - are the hardest to give feedback on. The instinct is to retreat to safer ground (artifact quality, process compliance) because feedback on the harder skills feels subjective. Resisting this instinct is one of the most important leadership disciplines.

Anchor in specific decisions: "on the vendor situation in Q2, you escalated to the sponsor at week 4; walk me through what you were weighing; I would have probably absorbed for another two weeks before escalating, here is why." Specific, recent, focused on the reasoning. This allows the TPM to engage with the substance rather than feeling vaguely judged.

Be willing to disagree about the right call. The harder feedback is not "you should have done X" - it is "I would have done X; you did Y; let's talk about whether Y was actually wrong."

Sometimes the TPM's call was right and your read is updating. Sometimes it was wrong and the conversation produces real growth. Either way, treating the call as a discussion rather than a verdict produces better outcomes.

Distinguish judgment errors from execution errors. A TPM who made the right call and executed it imperfectly is in a different developmental position from one who made the wrong call but executed it skillfully. "Your call was right; the execution had specific issues - here they are" is different from "the execution was clean; I would have made a different call - here is why." Conflating the two produces feedback that does not transfer.

What you avoid in performance conversations

Avoid framing weaknesses as personal traits. "You are not detail-oriented" is less useful than "your charters consistently miss specifics that affect downstream execution; let's work on that."

The first feels like a characterization of the person; the second is a specific developmental edge they can address.

Avoid bundling many concerns into one conversation. Performance conversations that surface five different growth areas simultaneously rarely produce growth on any of them - the TPM walks out feeling globally inadequate rather than focused on a specific development. Better to focus on one or two things that matter most.

Avoid mixing recognition and corrective feedback in the same conversation. Some leaders, trying to soften corrective feedback, sandwich it between recognition. The TPM hears the praise, hears the criticism, and forgets both because the structure obscured what mattered. Recognition is its own conversation; corrective feedback is its own conversation; both are honest; neither is hedged through the other.

The conversations TPMs actually need

The growth conversation, twice a year and separate from formal reviews: "here is what I am seeing about your trajectory; here is where I think you are growing; here is what I would recommend you focus on for the next six months; what is your read?" This produces deliberate development; the formal review process tends to produce defensive engagement with ratings.

The hard moment conversation, after a TPM has handled a particularly difficult situation: "walk me through how you were thinking; what worked; what you would do differently; what pattern you are starting to see." This is the reflection conversation that turns experience into pattern recognition. Most TPMs do not get this regularly enough.

The career conversation, once a year or so: "where do you want to be in three years; five years; what is the role you are growing into; what is standing between you and that role?" This conversation orients the TPM's energy toward their long-term trajectory and helps you identify what kinds of programs and exposures would help them.

The recognition conversation: when the TPM has done something genuinely strong, name it specifically and quickly - not in a 1:1 weeks later but in a conversation soon after the work happened. "I want to acknowledge how you handled the recovery situation; specifically, the way you framed the sponsor conversation was excellent; the timing of the surface, the framing, the ask - that landed well." Specific recognition is much more useful than general recognition; it teaches the TPM what is working in a way they can reproduce.

When the conversation is harder

Sometimes the performance conversation is not a growth discussion but a problem discussion - the TPM is underperforming, the relationship has frayed, the trajectory is wrong. These conversations are uncomfortable and often delayed beyond the point where they would have been useful.

Have them earlier than feels natural. The instinct to wait, hope things improve, and give the TPM more time often produces conversations that are too late. By the time the situation is undeniable, the TPM has been operating against unclear standards for months and feedback feels punitive. Earlier conversations, when there is still time to adjust, are kinder and more productive.

Be specific about what is not working: not "your performance is below expectations" but "in three specific situations this quarter your handling produced outcomes that were not where they needed to be - here are the situations, here is what I observed, here is what would have produced better outcomes." Specific feedback is actionable; vague feedback is not.

Name what success looks like, with a timeline: "if by end of next quarter I see [specific patterns], I will feel better about the trajectory; if I am seeing the current patterns continue, we will need a different conversation." This is not punitive; it is clarity. TPMs given clear targets often hit them; TPMs given vague concern often do not.

Close the loop afterward. Whether things improve or do not, the follow-up conversation matters: either "I want to acknowledge what has changed; the trajectory has shifted in the way I was hoping" or "the patterns I named have not shifted; here is what we are going to do." The avoidance pattern - raising concerns and then never closing the loop - is corrosive to trust and to function morale.

What this means for the leader's calendar

Real performance evaluation requires sustained attention to TPMs' work - close enough to their decisions that you can evaluate the quality of their judgment, not just the outcomes. It requires time for the growth conversation, the hard moment conversation, the career conversation, and the recognition conversation - several hours per TPM per year beyond the formal review cycle. And it requires capacity for the harder conversations, which are not compatible with a packed calendar that has no room for difficult discussions.

If your calendar does not have this capacity, your performance evaluation will default to the surface measures because that is what fits in the time available. The investment in actually evaluating TPM performance well is real, and it is part of the broader investment in scaling judgment, mentoring, and building the function.

What good leaders do:

- Evaluate judgment quality across specific decisions - the recovery call that was or was not taken, the escalation that was or was not surfaced - by staying close enough to the work to have a direct read, and weight program outcomes by the difficulty of the situation rather than treating them as primary performance signals
- Give feedback on the harder skills by anchoring in specific recent decisions, being willing to treat the right call as a discussion rather than a verdict, and explicitly distinguishing judgment errors from execution errors
- Conduct the growth conversation twice a year outside the formal review cycle, the hard moment conversation after difficult situations, and the recognition conversation close to the event - each as a standalone conversation, not bundled with other messages

Common traps:

- Over-rewarding artifact production volume because documentation is measurable, which over years shifts the function toward producing output rather than program management, and systematically underweights the strongest TPMs whose work shows up in judgment and relationships rather than document count
- Delaying the harder problem conversations until the situation is undeniable, by which point the TPM has been operating against unclear standards for months and the feedback feels punitive rather than developmental

Bottom line: The performance evaluation work that actually develops TPMs - evaluating judgment quality, tracking stakeholder relationship trajectory, and having the harder conversations early - is time-intensive and largely invisible to anyone outside the leader-TPM relationship, but it is where most of the leverage of leadership shows up, because the function you build over the years is largely the function of the people you developed.

Shared & Cross-cutting · Career & Reference (5)

Reference — Career Map & Reading List for the security/enterprise TPM track

This is a navigational document. The rest of the toolkit gives you the artifacts (Framework), the templates, the examples, and the craft writing (Field Notes and Leadership Notes). What's been missing is a way to orient yourself: where am I in this career arc, which pieces of the toolkit matter most for my level, what should I be reading alongside the toolkit, and what's the next thing to grow into.

This document is that orientation. It walks the security/enterprise TPM career arc from L3 through L7 plus the director/leader track, and at each stage it surfaces what the role demands, which Field Notes and Leadership Notes are most relevant, what's worth reading at that stage, and what skill to focus on developing next. The closing section is a broader reading list organized by domain rather than by level — resources that span career stages or don't fit cleanly to one.

How to use this document

If you're early in your career, read the L3 section carefully and L4 briefly to see what's coming. The Field Notes most relevant at your stage will give you specific craft guidance; the reading recommendations at your stage will give you the foundational frameworks. The other stages aren't useless — but trying to absorb senior or staff content while you're still building L3 muscles produces shallow understanding rather than deep capability.

If you're mid-career, the section for your level is your home base. Read the next-level section to see what you should be growing into; the previous-level section to see what you may have skipped that's worth backfilling. The Field Notes are increasingly relevant as you reach mid-level (most are written for senior IC and above); the Leadership Notes start to matter when you're considering the director track.

If you're senior or above, treat this document as a checklist for what you've absorbed vs. what you haven't. Most senior+ TPMs have gaps in their development that they didn't notice because the gaps weren't blocking their work in the moment. The career map is a way to surface those gaps deliberately.

A note on level numbering

The L3-L7 framing is the FAANG-standard ladder for TPMs (Google, Meta, and many others use this exact range; Amazon uses a +1 inflation at junior levels — Amazon L4 = Google L3 — but converges at senior levels). Many enterprise organizations don't use L# notation at all and use titles directly: TPM I / TPM II / Senior TPM / Staff TPM / Principal TPM. The level numbers and titles map cleanly:

- L3 = TPM I (entry level)
- L4 = TPM II (mid-level)
- L5 = Senior TPM (often a "terminal" level — many TPMs plateau here and that's acceptable)
- L6 = Staff TPM
- L7 = Principal TPM (or Senior Staff TPM)
- L8+ = Director / Senior Director (typically the leader track, with people management responsibilities)

The L1 and L2 levels generally don't exist for TPMs in standard ladders — the discipline starts at L3 because the role assumes some level of professional experience and structural understanding that isn't typical for L1/L2 hires.

Year ranges in this document are approximate. Some TPMs reach L5 at year 6, some at year 10, some never reach it. The level numbers are about scope and capability, not about tenure. A TPM with 12 years of experience who's been doing the same kind of program isn't necessarily L6; they might be L5 with seniority. A TPM with 7 years who's been on harder work and developed deliberately might be operating at L6 already.

Treat the level mapping as guidance about what the role looks like at each scope, not as a strict timeline.

The career arc overview

L3 (TPM I, 0-3 years): Building the basic muscles. Communication, organization, ambiguity tolerance, framework absorption. The role is largely about learning how the discipline works.

L4 (TPM II, 3-7 years): Pattern recognition forms. End-to-end program ownership begins. Stakeholder management starts to develop. The role expands from execution to judgment on tactical calls.

L5 (Senior TPM, 7-12 years): Political dimension becomes central. Recovery capability is expected. Mentorship of junior TPMs begins. The role is expected to deliver hard programs without close oversight, handle difficult sponsor relationships, and contribute strategic input. Many TPMs reach L5 and stay there for the rest of their careers — this is a respectable plateau, not a failure.

L6 (Staff TPM, 10-15+ years): Scope across multiple programs. Strategic input on what programs to run, not just how. You're often the senior-most TPM in your domain. Mentorship of junior and mid-level TPMs is a core responsibility. The transition from L5 to L6 is the most variable in the career arc; some TPMs reach it in their tenth year, some plateau at senior.

L7 (Principal or Senior Staff TPM, 15+ years): Function-level influence. Organizational design contributions. Standards-setting. The role is rare even at the largest companies. Often the senior-most IC TPM in the organization, with influence that extends beyond the formal reporting structure.

Director / Leader track (typically L7-L8): A parallel path that draws from L5-L6 ICs who move into people management. Builds and runs TPM functions, hires TPMs, scales judgment across teams, performance evaluation, strategic engagement with engineering leadership.

Most TPMs progress L3 to L5 at roughly the rates the year boundaries suggest. The transitions from L5 to L6 and from L6 to L7 are increasingly variable; some TPMs make these transitions; many don't. Both senior (L5) and staff (L6) are valid career endpoints.

L3 (TPM I, 0-3 years)

What the role demands at this stage

You are learning the discipline. The work is substantively about absorbing the toolkit's structural artifacts — what's in a Charter, what goes in a RAID Log, how RACI rules work, how status reports communicate. You'll spend significant time producing artifacts under guidance, attending meetings to observe how senior TPMs operate, and gradually taking on small pieces of program work directly.

The most important thing at this stage is not the artifacts you produce but the patterns you start to internalize. Programs have shapes. Stakeholders have predictable behaviors. Risks have categories. The patterns won't be visible to you yet; they're built up over many programs. Your job is to be exposed to enough programs that the patterns start to form.

Field Notes most relevant at L3

Most Field Notes are written for senior+ TPMs and won't fully land at this stage. Two exceptions worth reading early:

FN-RP01 (Building credibility in your first 30 days on a new project) — directly relevant to every new program you're on, even small ones. The discipline of restraint and listening applies at every level.

FN-R04 (Bringing a sponsor bad news) — read this early so the framing is in your toolkit before you need it. The conversation pattern transfers to peer-level communication too.

Leadership Notes are not yet relevant. Read them later, when the leader track becomes a real consideration.

Reading at this stage

The Project Management Body of Knowledge (PMBOK Guide), 7th edition. The standard reference. Read it once carefully. Don't memorize it; absorb the framework. It's the structural

vocabulary that the rest of program management is built on, and not knowing it produces persistent gaps.

The First 90 Days, Michael Watkins. The classic on transitioning into a new role. The principles apply even at the L3 level when joining a new team or project. Read it once, return to it whenever you change roles.

The Phoenix Project, Gene Kim. Fictional but useful. Walks through systems thinking and the dynamics of how technology programs actually unfold in organizations. Easier reading than methodology books and conveys patterns that are hard to absorb from frameworks alone.

Crucial Conversations, Patterson et al. Communication framework that holds up across the career. The core framework — recognizing when conversations are crucial, creating safety, mastering your own stories — is foundational for stakeholder work.

What to focus on developing

Discipline of practice. Show up on time, produce artifacts when committed, follow through on commitments. This is what builds the credibility that lets you take on harder work at L4. TPMs who are sloppy at L3 rarely catch up to peers who were disciplined.

Curiosity about how things work. Ask why, not just what. The L3 TPMs who become strong L4+ TPMs are the ones who are curious about why processes exist, why decisions were made, why stakeholders react the way they do. The ones who treat the work as procedure development don't develop the same depth.

Comfort with ambiguity. Most early career discomfort is about not knowing the right answer. The TPMs who develop best are the ones who learn to function while uncertain, form working hypotheses, ask good questions, and adjust as information arrives. The ones who require certainty before acting plateau early.

L4 (TPM II, 3-7 years)

What the role demands at this stage

You can run a program end-to-end with limited oversight. Pattern recognition is starting to form — you've seen enough situations that some of them feel familiar. Stakeholder management capability is developing; you're handling more of the political dimension yourself rather than escalating it.

The transition that matters at this stage is from "execution under guidance" to "judgment on tactical calls." You make more decisions yourself. You interpret situations rather than describing them. You start to develop your own opinions about how programs should be structured, even if you're not yet running the structural decisions.

Field Notes most relevant at L4

This is where most Field Notes start to land. Read in roughly this order:

FN-R01 through FN-R05 (Recovery & Repair cluster). You'll start handling situations where programs go sideways. The cluster gives you the discipline of recovery before you're in a real recovery situation.

FN-RP02 (Working with combative stakeholders) — at L4+, you'll start handling stakeholder situations directly that previously would have been escalated. This piece teaches the diagnostic discipline that prevents premature escalation.

FN-PN01 and FN-PN03 (Recommending prioritization with data; Negotiating scope with engineering) — both become directly relevant as you take on programs where you're making prioritization recommendations and engaging engineering on scope.

The other Field Notes are useful but more situational; read them as they become relevant.

Reading at this stage

Difficult Conversations, Stone, Patton, and Heen. The natural follow-up to Crucial Conversations. Specifically about the conversations that involve disagreement, blame, and identity — exactly the kind of stakeholder conversations that increase as you approach senior.

Inspired, Marty Cagan. Product context, but the partnership pattern between PM and engineering directly informs how TPMs should work with engineering teams. The "discovery vs. delivery" framing helps you understand engineering's posture.

Steve Sinofsky's writing on shipping (substack, public talks). Real wisdom from a long career running programs. Particularly the writing on leadership transitions, hard decisions, and program structure. Not a single book; sample what's relevant and follow what resonates.

The Mythical Man-Month, Fred Brooks. Classic for a reason. The fundamental insights about software programs (adding people doesn't accelerate; conceptual integrity matters; second-system effects) hold up across decades. Short read with enduring value.

What to focus on developing

End-to-end ownership. Have you actually closed a program, or just contributed to programs that closed? The closure muscle — handling late-stage politics, loose ends, lessons learned — is what distinguishes mid-levels who'll grow into senior from mid-levels who'll plateau.

Stakeholder management at and above your level. Your stakeholder relationships are increasingly with senior people. Start developing the patterns of senior-stakeholder communication: brevity, framing, anticipating concerns. The mid-levels who can't do this stay at mid-level.

Specific judgment on hard calls. Notice when you're making calls that don't have clear right answers. Reflect on what you weighed and how it played out. The pattern recognition that defines senior judgment is built through this kind of deliberate reflection on your own decisions.

L5 (Senior TPM, 7-12 years)

What the role demands at this stage

You can run multi-component programs. The political dimension is central, not adjacent — you're navigating sponsor relationships, stakeholder coalitions, vendor dynamics, cross-organizational politics as the substantive work, not as overhead. Recovery capability is expected; if you haven't been the TPM on a program that went badly and helped recover it, you're not yet operating at L5 even with the years.

You're also expected to mentor junior TPMs. This is when the role starts to require the leadership muscles that will become primary if you move into the staff or director track.

A note on L5 as a "terminal" level: many TPMs reach L5 and stay there for the rest of their careers. This is genuinely fine. L5 senior is a rich, well-compensated role with substantial impact. The transition to L6 staff is harder than the transitions before it, and not every TPM wants to make it. If you're at L5 and content, that's a valid career endpoint, not a failure to advance.

Field Notes most relevant at L5

By this point, all of the Field Notes are relevant. Specific ones to read deeply:

FN-RP03 (When your sponsor goes quiet) — at senior level, you'll have sponsor relationships that span years and that go through periods of disengagement. This piece teaches reading patterns that take a decade to develop on your own.

FN-RP04 (Working across cultures and seniority lines) — most senior+ programs involve global or cross-functional dimensions. The piece's specific moves on the asymmetries of voice, the RACI dynamics when seniority varies, decisions that need to look collaborative — directly applicable.

FN-PN02 (Reprioritizing mid-program) and FN-PN04 (Negotiating with vendors when SOW is failing) — both are situations you'll encounter at senior level with consequences large enough that getting them wrong meaningfully damages your standing.

FN-JP01 (Off-Track / executive intervention required) and FN-JP03 (Saying no to a sponsor) — judgment work that distinguishes senior+ from senior. Read these multiple times; they're worth re-reading every few years.

Reading at this stage

Radical Candor, Kim Scott. The core framework — caring personally + challenging directly — is the management posture that good senior TPMs develop instinctively. Even if you're not yet managing people, the framework helps with how you give feedback to peers and how you receive it from your sponsor.

The Hard Thing About Hard Things, Ben Horowitz. Wisdom from running technology companies. The chapters on layoffs, hard conversations, and leading through crisis are particularly relevant for senior TPMs handling difficult programs.

Lara Hogan's writing on management. Particularly her work on "manager voltron" — building support networks for hard conversations. Useful even before you formally manage anyone.

NIST Cybersecurity Framework and SP 800-53. If you're a security TPM, you have to know these well. Not the entire 800-53 catalog by heart, but enough that you can recognize control families and understand why they're structured the way they are.

What to focus on developing

Recovery capability if you haven't yet developed it. If you haven't been on a real recovery program, deliberately seek one. The recovery muscle is the most expensive thing to be missing at senior level, and it's one of the things most distinguished from mid-level work.

Mentorship. If you're not already mentoring junior TPMs, start. Even informally. The director track requires the muscle, and even if you stay IC, mentorship is part of what makes senior TPMs valuable to their organizations beyond their individual program work.

Strategic input. The transition from L5 to L6 is largely about contributing strategic input on programs you're not running. Practice doing this on programs adjacent to yours — offering perspective, asking good questions, sharing pattern recognition. It builds the muscle that staff-level work requires.

L6 (Staff TPM, 10-15+ years)

What the role demands at this stage

Scope across multiple programs. Strategic input on what programs to run, not just how. You're often the senior-most TPM in your domain, and your judgment shapes more than one program at a time. Mentorship of junior and mid-level TPMs is a core responsibility, not a side activity.

The transition from L5 to L6 is the most variable in the career arc. Some TPMs reach staff in year 10; some plateau at senior for the rest of their careers. The variable is whether you've developed the leverage that staff requires — judgment that scales beyond your direct work, ability to shape programs through input rather than execution, capacity to mentor others to your level of capability.

Field Notes most relevant at L6

All of the Field Notes are relevant. Specifically valuable at this stage:

FN-AM01 through FN-AM06 (Automation & the Modern TPM cluster). Staff TPMs are responsible for thinking about how the role is changing and where to invest their development time. The cluster is largely written for the staff-level reader.

FN-JP02 (When to break ranks with your team) — staff TPMs face situations where they're part of larger team alignments that are wrong about something specific. The piece's discipline about when to break ranks and how matters more at this level than any other.

Leadership Notes (LN01-LN06) start to be relevant if the director track is a consideration. Read at least LN05 (Mentoring at each career stage) regardless of whether you're considering the director track — the framework helps with the mentorship work that's part of staff-level responsibility.

Reading at this stage

An Elegant Puzzle, Will Larson. Specifically about engineering management at scale, but the framing on hiring, organizational design, and managing through ambiguity transfers directly to TPM leadership work. Read it before LN01-LN06 if you're considering the director track.

Staff Engineer, Will Larson. Companion piece for the staff-level IC track. Useful even though it's about engineering, because the IC-leverage patterns at staff level are similar across roles.

The Manager's Path, Camille Fournier. The classic for engineering leadership. Read it if you're considering the director track, even if you don't end up moving into it. The framing of the role is helpful for working with the leaders you'll partner with.

Skin in the Game, Nassim Taleb. Not a TPM book, but the framing on asymmetric incentives, accountability, and decision-making under uncertainty is specifically relevant to staff-level work. Read selectively; the book is uneven, but the relevant chapters are valuable.

What to focus on developing

Strategic communication with senior leadership. Your communication has to operate at a different register than senior-level work. Less detail, more framing. More about what to do than about what's happening. Practice this deliberately; staff TPMs who can't communicate well at this level get bypassed by leaders looking for clarity.

Mentorship at scale. You're now responsible for developing junior and mid-level TPMs in your domain. The deliberate practice of mentorship — making your reasoning visible, creating reflection space for others, calibrating your involvement to each person's needs — becomes a primary responsibility. The L5 to L6 transition is largely won or lost on this dimension.

Pattern recognition across programs. Staff TPMs develop the ability to see patterns that hold across many programs — how vendor relationships tend to evolve, where sponsor disengagement comes from, what early indicators predict program trouble. Building this requires deliberate reflection on patterns you're noticing, not just on individual programs.

L7 (Principal TPM, 15+ years)

What the role demands at this stage

Function-level influence. Organizational design contributions. Standards-setting. You're often the most senior IC TPM in the organization, and your influence extends beyond the formal reporting structure. Junior and mid-level TPMs throughout the function are shaped by your standards even if they don't report to you.

The L7 role is rare even at the largest companies. The role requires both years of accumulated judgment and a specific organizational fit where principal-level IC work is valued. In organizations that don't value senior IC TPM work, L7 TPMs sometimes find themselves underleveraged or pushed toward leader roles they don't want. Many organizations don't have an L7 IC track at all and expect senior staff TPMs to move into the director track.

Field Notes most relevant at L7

Re-read everything periodically. The Field Notes that fully land at L7 may be different from the ones that landed earlier. Specifically:

FN-AM06 (Skills that compound, skills that depreciate). At this level, you're making decisions about your own development that have multi-year implications. The career-arc framing helps.

FN-JP03 (Saying no to a sponsor). At principal level, you're sometimes the only person who'll push back on senior leadership decisions. The framework matters more here than at any earlier stage.

Reading at this stage

The Death of Expertise, Tom Nichols. About how expertise is eroding in many fields and how to maintain credibility as an expert. Specifically relevant for principal TPMs whose value depends on accumulated judgment in a world that increasingly discounts that.

Antifragile, Nassim Taleb. The full version of his thinking on robustness, uncertainty, and decision-making under conditions where outcomes have heavy tails. Useful for the kind of strategic judgment that principal-level work involves.

Selected papers and talks rather than books. By this point in your career, you've absorbed most of the foundational books. The frontier of new thinking is in papers, talks, blog posts from people pushing the field forward. Sample widely; follow the threads that resonate.

What to focus on developing

Voice within the organization. Principal TPMs often have influence beyond their formal authority. Developing the muscle of using that influence well — knowing when to weigh in, knowing how to frame, knowing when to hold back — is the work of this level.

Long-term thinking. The decisions you contribute to at principal level have multi-year consequences. The ability to think on those time horizons, while still engaging with shorter-term work, is what distinguishes principal-level contribution from very-senior contribution.

Succession planning. The principal-level role is one of the rarest in any organization. If you stay in it for years, the organization develops a dependence on your judgment. Deliberate succession planning — developing the next generation who can fill the role — is part of being a responsible principal.

Director / Leader track (L7-L8 typically)

What the role demands

Directors and PMO leaders run TPM functions, hire TPMs, scale judgment across teams, do performance evaluation, and engage strategically with engineering leadership. The work is substantively different from IC work — most of your time is on people, structure, and organizational dynamics rather than on programs directly.

The director track usually starts being a real option at the L5 senior level and becomes the dominant career direction at L6+. Some senior TPMs move into it deliberately; some are promoted into it because they showed aptitude with junior TPMs. The transition is harder than most TPMs expect — the muscles that made you a great senior IC are not the same as the muscles you need as a director.

Many organizations effectively force the director track at the L6/L7 boundary because they don't have a meaningful L7 IC slot. If you're at L6 staff and want to continue advancing without becoming a manager, check carefully whether your organization has a real L7 IC path or whether the only way up is the leader track.

Field Notes still relevant

The Field Notes are still relevant at the director stage, but they shift from being about your own work to being about the work of the people you lead. Re-read them with an eye for "what does this look like in someone I'm leading; how do I help them through this situation." This reframing is the director-track version of the Field Notes.

Leadership Notes at this stage

All six Leadership Notes are written specifically for this stage. Read them in roughly this order: LN04 (Building a PMO from zero) if you're newly in the role or considering it.

LN02 (TPM org structure) and LN03 (Scaling judgment across a team) for the structural and developmental work.

LN01 (Hiring TPMs at every level), LN05 (Mentoring at each career stage), and LN06 (Performance conversations) for the people work that defines the director role over the long term.

Reading at this stage

The director-track reading is largely the management classics:

The Effective Executive, Peter Drucker. The foundational book. Read it once carefully and once a year afterward. The principles — managing your time, deciding what to contribute, building on strengths, making effective decisions — apply at the director level whether you're running a team of 5 or 50.

High Output Management, Andy Grove. Specific frameworks for leadership work — leverage, delegation, performance conversations. Practical and dated in its examples but durable in its principles.

The Five Dysfunctions of a Team, Patrick Lencioni. Fictional but useful. The five dysfunctions framework — absence of trust, fear of conflict, lack of commitment, avoidance of accountability, inattention to results — is a diagnostic tool for team dynamics that holds up across contexts.

Multipliers, Liz Wiseman. The framework on leaders who multiply vs. diminish their teams' capabilities is specifically relevant to TPM leadership. The "diminisher" patterns are easy to fall into without realizing.

Trillion Dollar Coach, Schmidt et al. About Bill Campbell's approach to coaching senior leaders. The patterns transfer to coaching senior TPMs through hard career moments.

What to focus on developing

Building people. The director role's leverage is in the people you develop. Investing time in mentorship, coaching, performance conversations, and structural decisions that help your TPMs grow is the highest-return activity.

Strategic engagement with engineering leadership. Your peer relationships with engineering VPs and directors determine whether your TPM function is load-bearing or peripheral. Develop these relationships deliberately.

Self-management. Director work is harder on you than IC work was — more emotional, more politically charged, more isolating. Developing the practices that sustain you through this — peer support, exercise, reading, time off — is part of being durable in the role.

Closing reading list — by domain rather than by level

Resources that span career stages or don't fit cleanly to one level:

Program management classics

Project Management Body of Knowledge (PMBOK Guide), 7th edition — the standard reference, mentioned at L3 but worth referencing throughout your career.

Strategic Project Management Made Simple, Terry Schmidt — practical framework on the strategic dimension of program management, for TPMs at any level.

Security and regulated industry context

NIST Cybersecurity Framework and SP 800-53 — foundational for security TPMs, mentioned at L5 but worth knowing earlier if you're entering the field.

The CISO Handbook (publicly available drafts) — context on the sponsor's view, useful for understanding what your CISO sponsors are dealing with.

OWASP Top 10 and CWE — security context that helps you ask better questions of engineering teams.

Communication and stakeholder management

Crucial Conversations, Patterson et al. — mentioned at L3, worth re-reading at every stage.

Difficult Conversations, Stone et al. — mentioned at L4, also worth re-reading periodically.

Never Split the Difference, Chris Voss — negotiation tactics from a former FBI hostage negotiator. The frameworks transfer surprisingly well to vendor and stakeholder negotiations.

Influence: The Psychology of Persuasion, Robert Cialdini — foundational on how persuasion actually works. Useful for understanding stakeholder behavior.

Leadership and people development

The Manager's Path, Camille Fournier — for engineering leadership but relevant for the director track.

An Elegant Puzzle, Will Larson — the strategic dimension of engineering leadership, transferable.

Radical Candor, Kim Scott — the management posture for the director track.

The Effective Executive, Peter Drucker — the foundational management text, relevant whenever you have direct or indirect reports.

Multipliers, Liz Wiseman — the multiplier vs. diminisher framework.

AI / modern context

Selected blog posts and papers rather than books. The space is moving too fast for books to be fully current; the most useful content is in essays, posts from practitioners, and well-curated newsletters. Sample what your peers are reading and follow the threads that resonate.

What's missing from this list

Several things deliberately not in this list:

Prescriptive certifications. PMP, CSM, SAFe, and similar certifications have value for some career paths and contexts. They're also overweighted in some hiring processes and underweighted in others. Whether to pursue them depends heavily on your organization and target career path. The list above is about resources that develop judgment regardless of certification structure.

Vendor-specific tooling guides. Specific tools come and go; the discipline persists. The toolkit and these resources are tool-agnostic.

The latest trend books. Most management books with "the new" in the title age poorly. The list above is weighted toward books that have held up over years or decades, not the books currently being marketed heavily. The trend literature is sometimes valuable; it's not the foundation.

How to use this list over time

A pattern that works: read 2-3 books a year deliberately, sampling from the relevant level for your current stage and from the broader domain list. Re-read foundational books every few years; new things land in re-reads that didn't land the first time. Keep a list of resources that come up in conversations with senior peers; those recommendations are often higher signal than published lists.

The TPMs who develop best over decades treat reading as part of the professional discipline rather than as a side activity. Not because reading is the work — it isn't — but because the reading shapes how you think about the work, and how you think about the work eventually shapes the work itself.

Closing thought

This reference is the navigational layer for the rest of the toolkit. The Framework gives you the artifacts. The Templates Pack gives you the patterns. The Examples show what fully-populated artifacts look like. The Field Notes give you craft writing on senior-IC situations. The Leadership Notes give you director-track guidance. This document tells you where you are in that map and what to focus on.

The career arc is long. The skills that compound — judgment, framing, stakeholder relationships, strategic input, mentorship — develop over years through deliberate practice. The toolkit is one input to that practice. The reading list is another. Your own programs and relationships are the most important. Use the toolkit and the reading list to support the deliberate development, but the actual growth happens in your work, with the people you work with, on the programs you're running.

Keep developing. The TPMs who treat their career as a 30-year arc and invest accordingly tend to do their best work in their second and third decades. The TPMs who treat each year as transactional tend to plateau in their first decade and stay there. The arc rewards the long view.

Related artifacts

- All Framework artifacts (#1-#37): the structural reference this document points back to
- All Templates Pack templates: the operational layer
- All 32 Examples: examples in the Project Atlas world

Related Field Notes

- All 22 Field Notes across 5 clusters: the craft writing that this document maps to career stages

Related Leadership Notes

- All 6 Leadership Notes: the director-track guidance referenced at the leader stage of the career map

Keywords: TPM career map, TPM reading list, TPM career arc, L3 to L7 TPM, junior TPM resources, mid-level TPM resources, senior TPM resources, staff TPM resources, principal TPM, TPM director track, PMBOK, First 90 Days, TPM books, what to read TPM, TPM development guide, TPM career stages, TPM level mapping, security TPM resources, enterprise TPM career, FAANG TPM levels, Google TPM ladder, L5 senior TPM, L6 staff TPM, L7 principal TPM, TPM leveling, terminal level

Reference — Building your TPM promotion case (L5 → L6 and L6 → L7)

Reference — Building your promotion case (L5 → L6 and L6 → L7)

This is a companion to the Career Map (REF01). The Career Map tells you what each level looks like and what to develop to grow into it. This document tells you how to actually demonstrate that growth — what evidence promotion processes look for, how to gather it deliberately over the months and years before the promotion conversation, and how to package it when the conversation happens.

This document focuses on two specific transitions: L5 to L6 (senior to staff) and L6 to L7 (staff to principal or senior staff). Both are harder than the transitions before them, in different ways. Both are where most promotion advice falls apart because the patterns that worked at earlier levels don't apply. And both require deliberate evidence-gathering work that has to start well before the promotion cycle, because the kind of evidence these committees want isn't something you can produce in the last quarter before the case is made.

The throughline that anchors everything else

Across every credible source on senior+ promotions — published engineering ladders, staff engineer coaching content, promotion packet guides, real promotion stories from people who've been through the process — the same observation surfaces again and again: promotion

committees don't promote based on potential. They promote based on evidence of current performance at the next level. You operate at the next level for six to twelve months consistently before the title catches up.

This isn't a flaw in the process. It's how the process protects the company from over-leveling people who can't actually do the work, and protects the next-level peers from being calibrated against ICs who haven't yet earned the title. The implication for you, though, is concrete: by the time you're "up for promotion," you should already be doing the work of the next level. The promotion is recognition, not a leap of faith.

This changes how you approach the evidence-gathering. You're not trying to convince the committee that you might be ready. You're documenting that you've already been doing the work. The question shifts from "will I get promoted" to "is the work I'm doing visible enough that the committee will see it as evidence of next-level performance."

L5 to L6: from senior to staff

What actually changes

The L5 to L6 transition is widely considered one of the hardest in tech career arcs, including for TPMs. The reason is that it's not a continuous extension of L5 work — it's a different shape of work entirely.

At L5, you run programs end-to-end. You handle the political dimension. You make tactical calls. Your value is measured by the programs you deliver and the way you deliver them.

At L6, the value shift is from "programs you deliver" to "programs you make possible for others to deliver." The L6 staff TPM creates scope rather than receiving it. They influence multiple programs and teams without formal authority. They uplift other TPMs and engineers in ways that compound across the function. They solve problems other TPMs can't, sometimes by reframing the problem itself.

The senior who runs a great program is doing L5 work. The same person who, having seen the program, identifies a structural pattern that's affecting multiple programs, designs an intervention, and gets it adopted across the function — is doing L6 work. The first activity is execution; the second is leverage.

This is why the transition is hard. The L5 patterns that produced your success — owning the program, driving the details, being central to the work — actively prevent L6 work, which requires letting go of the central role and operating through others. Many TPMs reach L5 and never develop the L6 muscles because the L5 patterns are reinforced every day by the immediate program rewards.

The evidence that matters for L5 to L6

Promotion committees look for specific patterns of evidence. The patterns hold across companies even when the specific competency rubrics differ.

Scope across multiple programs or teams. Not "I ran a complex program," but "my work affected multiple programs that I wasn't directly running." Examples: a planning practice you developed that other TPMs adopted; an architectural decision you contributed to that shaped programs across a domain; an escalation pattern you established that became how the function handles certain situations. The evidence is wider than a single program.

Programs you created, not just ran. Did you identify a problem the organization didn't know it had, build the case for addressing it, charter the program, and make it real? This is the "create scope rather than receive it" pattern. The evidence isn't just that the program existed — it's that it didn't exist before you saw the need.

Uplifting other TPMs and engineers measurably. Mentorship is necessary but not sufficient. The committee wants evidence that people are doing better work because of you specifically. Junior

TPMs you mentored who got promoted (with documented examples of what you taught them). Engineering teams you partnered with who can articulate how your involvement changed how they work. Cross-program practices you established that other TPMs now use. The evidence is testimony, not just activities.

Influence without authority across organizational boundaries. A program you weren't formally responsible for that succeeded partly because of your input. A senior leader outside your reporting chain who would advocate for you because you helped them. A cross-functional dependency you resolved by influence when you had no leverage to compel anyone. The evidence is from people who didn't have to listen to you but did.

Solving problems other TPMs couldn't. The committee wants evidence that the problems you solved required you specifically — not just that they got solved while you were on them. A program that had been failing under previous TPMs that you turned around. A structural problem that had defeated multiple attempts. An ambiguous situation where the right answer wasn't clear, and your judgment produced an outcome that wouldn't have happened with another TPM. This is the "works at L6 scope" signal.

Strategic input on the function or organization. Did you contribute to decisions about how programs get run, what programs the organization should run, how the TPM function operates? Even if you didn't run the decisions, did your input shape them? The evidence here often shows up in retrospect — a strategic shift the org made where you can credibly say "I argued for that direction, and here's the documentation."

What to do over 12-18 months to build this evidence

The pattern that works, drawn from people who've made the L5 to L6 transition successfully:

Start tracking your own work in a way the committee will eventually find useful. A running document of your activities, organized by the competency dimensions of your company's L6 rubric (or, if your company doesn't have one, by the patterns above). Update it monthly. Include links to artifacts, decisions you contributed to, programs you affected, people you helped. The act of maintaining the document forces you to notice the L6-shaped work you're doing and to seek more of it.

Find scope deliberately. Look for problems your organization has that aren't owned. Cross-program patterns nobody is addressing. Operational issues that affect many TPMs but no one is fixing. Structural changes the function needs but hasn't prioritized. Pick one and start working on it. Get your manager's blessing if needed; don't wait for permission to identify and address real problems. This is "create scope" in practice.

Take on a recovery or strategic program with cross-organizational stakes. The kind of work that requires L6-shaped capabilities. If your current programs are routine, find one that isn't, even if it means taking on harder work without immediate compensation reward. The evidence comes from harder work, and harder work isn't always available on the schedule the promotion process wants.

Mentor deliberately, with documented outcomes. Pick one to two junior or mid-level TPMs and invest seriously in their development. The 1:1 patterns from LN05. The decision review practice from LN03. The framing work that you can verbalize and they can absorb. Document what they learned and where they grew. Their growth becomes part of your evidence. This is uncomfortable for some senior TPMs because it feels like taking credit for someone else's work; it isn't. Done well, mentorship is a category of work that produces compound returns, and committees recognize it.

Build cross-organizational relationships before you need them. Senior leaders outside your reporting chain who know your work and would advocate for you. Peer engineering leaders who would describe your collaboration favorably. Senior peers in adjacent functions who could speak

to your work. These relationships take six months minimum to develop in a way that produces real testimony. They cannot be built in the promotion cycle.

Have the explicit conversation with your manager. By the 6-9 month mark before you'd want the title, your manager should know you're targeting L6 and should be working with you on the case. The promotion packet is largely your manager's job to write, with your input. They need time to compile, to socialize the case with their leadership, to ensure the cross-functional support is in place. Managers caught flat-footed at promotion time produce weak packets that fail to land.

Packaging the evidence: the promotion packet

The promotion packet (or case, or memo, or whatever your company calls it) is the document that goes to the promotion committee. Different companies have different formats; the underlying structure is consistent.

What strong packets contain:

The case in three to five sentences at the top. The committee will read dozens of packets. The opening has to land the argument: this person is operating at L6 today, here's the most compelling evidence, here's why the timing is right. If your packet's opening doesn't carry the case, the rest doesn't matter — the committee may not read it as carefully.

A mapping to the formal competency rubric. Most companies have written L6 expectations. Your packet should map your evidence to each expectation explicitly. "Influence across multiple teams: I led the design of [specific cross-org project] that affected [N] teams; here's the documentation [link]; here's the testimony from the engineering leads [link]." Without the explicit mapping, the committee has to do the work of figuring out which evidence supports which competency, and they often won't bother.

Specific examples with measurable outcomes. Vague claims hurt. "I improved cross-team collaboration" is weak. "I designed and rolled out the program-pre-mortem practice that became standard for ML programs across the org; eight programs have used it; the average risk-surface time decreased from week 6 to week 2; here's the artifact and three program leads' testimony" is strong. Specificity is the signal.

Cross-functional testimony. The committee wants voices beyond your manager. Engineering leads, sponsors, peer TPMs, sometimes vendors. Their statements about specific work you did, in their own words. Aim for 3-5 substantive testimonies, not 15 generic ones. Quality dominates quantity here. Soliciting these takes weeks; ask for them six to eight weeks before the packet is due.

Anticipated objections, addressed. Most experienced senior TPMs know roughly what objections might be raised about their case. Address them in the packet. "One question that may come up: have I demonstrated influence across organizations rather than just teams? Here's the evidence on that specifically: [examples]." Addressing objections proactively signals self-awareness and gives the committee a way to respond to skeptics in their own deliberations. Concrete artifacts. Documents you wrote, decisions you contributed to, programs you affected, talks you gave. Linked, accessible, dated. The committee may sample these to verify your claims. Make the verification easy.

What weak packets contain (and why they fail):

Activities without outcomes. "I attended X, I led Y, I participated in Z" — the committee can't tell what changed because of you.

Generic claims without anchoring. "Strong technical leadership" — what does this mean specifically?

Manager-only voice. The case is entirely in your manager's words; no testimony from peers, sponsors, or stakeholders. Committees discount packets that lack independent voices.

Recent work only. Packets that lean heavily on the last quarter signal that the case wasn't being built over time. Strong packets show consistent next-level work over 12+ months.

Compensating language. "While X has had some development areas, they are working on..." — this signals to the committee that the case isn't strong enough on its own. Strong packets don't need compensating language; the evidence speaks.

How to handle a "not yet" outcome

Some L5 to L6 attempts fail. This is not unusual — Sean Goedecke, who was promoted to staff at both Zendesk and GitHub, has written that the staff promotion typically fails the first time. The right response shapes whether the next attempt succeeds.

Get the specific objections in writing or in detail. Vague feedback ("not enough scope yet") is unactionable. Push for specifics: which competency was the gap; what evidence would have closed the gap; what would the committee need to see in the next cycle. This conversation should happen with your manager and ideally with someone who was on the committee.

Build a 6-9 month plan to address the specific gap. Not a vague "do better"; a concrete plan tied to specific work that would produce the missing evidence. Review the plan with your manager. Update it as you go. Document the work as it happens.

Don't backfill stories. The temptation, after a "not yet," is to find work you did before that you didn't include in the packet and re-frame it as evidence for the missing competency. This rarely works. Committees recognize backfilled stories. Better to do the actual work and bring fresh evidence to the next cycle.

Watch for the "permanent senior" pattern. Some companies, after a "not yet," never seriously reconsider you. Others use the failure to inform the next cycle. If after 12 months the conversation hasn't shifted — if you're being told the same things, your manager hasn't engaged seriously, the path forward isn't visible — the honest answer may be that this organization isn't the right place to be promoted to L6. Many staff promotions happen by switching companies, not by internal promotion. This isn't failure; it's recognizing that promotion processes vary in their willingness to elevate, and yours may not be one of the willing ones.

L6 to L7: from staff to principal or senior staff

What actually changes

The L6 to L7 transition is rarer than L5 to L6, often less written about, and more variable across organizations. Some companies don't have a meaningful L7 IC track at all (in which case the transition is effectively into the director track). Some have it only for a tiny number of people (fewer than five in an organization of thousands). Some have a more functional L7 IC role.

When the L7 role does exist, the shape of the work is different from L6 in a specific way: scope expands from cross-team or cross-program to cross-organization or function-wide, and the leverage pattern shifts from "uplifting individuals" to "shaping how the function operates."

L6 staff TPMs influence multiple teams; L7 principal TPMs influence functions. L6 staff TPMs mentor other senior TPMs; L7 principal TPMs shape what the next generation of L6s look like. L6 staff TPMs solve problems other TPMs can't; L7 principal TPMs solve problems the function didn't know it had. L6 staff TPMs work in 6-12 month time horizons; L7 principal TPMs work in 2-5 year horizons.

The evidence that matters for L6 to L7

The evidence patterns that worked for L5 to L6 still apply, but at larger scale. Some additional patterns specific to L7:

Standards-setting that outlasts you. A practice or framework you designed that became how the organization operates, that continues working without you maintaining it. This is harder than it sounds — most "frameworks I built" decay when the original author moves on. L7-grade work has the property of becoming institutional. The evidence: the practice is still in use 12+ months after you stopped actively championing it.

Shaping how the function develops people. You influenced what senior+ TPM development looks like in your organization. You shaped the rubrics. You designed the development paths. You mentored other staff TPMs in ways that affected their judgment. The evidence: function-level patterns that exist because of you specifically.

Cross-organizational influence with senior leaders. The L7 case rests partly on whether senior leaders outside your function know who you are and would advocate for you. VPs and directors in adjacent functions who would describe your contribution to their work. Senior leaders in your function who treat you as a peer rather than as a senior IC. The evidence: testimony from people whose endorsement carries weight at the L8/director level.

Long-horizon thinking that produced specific outcomes. Did you advocate for a direction the organization eventually took? A capability investment that paid off? A risk you flagged years before it materialized? L7 work is partly about being right about things on multi-year time horizons, and the evidence comes in retrospect.

Originality at the institutional level. Some L7 cases include specific intellectual contributions — frameworks you developed that other companies adopted, talks you gave that shifted thinking in the field, methodologies you designed that became standard. This isn't required, but where it exists, it's strong evidence of L7-grade thinking.

Why the L6 to L7 packet is harder to build

Several reasons the L7 case is structurally harder than the L6 case, even for the same person.

The work is harder to attribute. By L7, you're operating through layers of people. The function-level practice that's working well — is that because of you, or because of the L6s and L5s who execute it? Untangling attribution is harder, and committees discount evidence where attribution is unclear.

The time horizons are longer. L6 evidence might be a 12-month story. L7 evidence is often a 3-5 year story. Building it requires sustained focus on the same set of patterns over years, and many TPMs lose continuity (job changes, reorganizations, priority shifts) that interrupts the multi-year evidence-building.

The bar is set by political reality, not just rubric. There may be only a few L7 slots in an organization, and existing L7s may be protective of the title. Even with strong evidence, the case has to navigate the politics of "should we add another L7 right now." This isn't fair, but it's real.

The "not yet" feedback is often genuinely vague. At L5 to L6, "not yet" usually has specific gaps. At L6 to L7, "not yet" sometimes really means "we don't have the appetite to add another L7 this cycle." Specific actionable feedback may not be available, and the path forward may not be visible.

The director track is often the alternative. Many organizations push L6 staff TPMs toward the director track because that's where the additional leverage is, in their view. Resisting this push requires both clear personal preference for IC work and an organization that supports it.

What to do if you're targeting L7

The pattern that works for L7-targeted TPMs:

Confirm the role exists at your organization. Some companies say they have an L7 IC track, but the actual promotions are rare to nonexistent. Talk to people in similar roles. Ask explicitly about

recent L6 to L7 promotions. If the answer is "we have the rubric but it almost never happens," recalibrate your expectations — either move toward the director track, target a different organization, or accept L6 as your terminal level. None of these is a failure; they're realistic responses to organizational reality.

Build the multi-year evidence base. The L7 case requires 3-5 years of consistent next-level work. Start the documentation early. Track the function-level patterns you're shaping. Maintain testimony from senior leaders over time. The packet you'd assemble in year 5 should reflect work you started in year 1.

Find work that's structurally L7-shaped. Not just "more of L6 at higher volume" but genuinely different work: standards you set, function-level practices you designed, multi-year directions you advocated for. If your current role doesn't have access to this kind of work, the L7 case may not be makeable from this seat.

Cultivate sponsorship at L8/director level. Your L7 case will be evaluated by senior people who need to vouch for it. They need to know your work. Building this relationship is multi-year. By the time the case is made, the L8s should already see you as one of their tier of contributor.

Be honest with yourself about whether you want it. L7 work is largely about influence rather than execution, sometimes about strategic judgment in slow-moving decisions, often about long isolation from direct program work. Some senior TPMs love this; some find it draining. If the work itself doesn't appeal, the L7 title isn't a reward — it's a different job that you may not enjoy.

Common mistakes specific to senior+ TPM promotion

A few patterns that consistently produce failed L5 to L6 or L6 to L7 cases, worth flagging because they're easy to fall into without realizing.

Mistaking volume for scope. Running more programs at L5 quality is not L6 work. The committee wants different work, not more work. TPMs who try to scale up their L5 patterns produce thin L6 packets that fail to land.

Optimizing for visibility over substance. Some TPMs focus on getting their work visible rather than on doing harder work. The visibility helps but doesn't substitute. Committees can tell when work is real vs. when it's primarily packaged.

Mentorship without measurable outcomes. "I mentored several junior TPMs" without specific outcomes (who, what they learned, where they grew) reads as activity-without-impact. Strong mentorship evidence is specific and outcome-anchored.

Pet projects misaligned with organizational priority. Some senior TPMs work on technically interesting things that don't map to what the organization values. The work is real, but the committee doesn't recognize it as evidence because it's not advancing the priorities they're being measured on.

Insufficient sponsorship. The case has to be carried by your manager and (at L7) by senior leaders who would advocate for you. If your manager isn't fully on board, or hasn't done the work to socialize the case ahead of the cycle, the packet fails regardless of how strong the evidence is. Sponsorship is structural, not optional.

Surprise timing. Bringing the promotion conversation to your manager three months before the cycle is too late. The work to prepare the packet, gather testimony, address gaps, and socialize the case takes 6-12 months minimum.

Closing thought

Promotion at the L5 to L6 and L6 to L7 levels is structurally harder than the promotions before it, and the difficulty is partly real and partly cultural. The real part: the work is genuinely different, and the evidence patterns require deliberate attention over months and years. The cultural part:

many organizations have politics, ratios, and informal gatekeeping that make these promotions harder than the rubric alone would suggest.

The TPMs who navigate this well share a few patterns. They start the evidence-building work well before the conversation. They build sponsorship across functions. They focus on doing the next-level work, not just performing it. They handle "not yet" feedback as data rather than rejection. They're honest with themselves about whether the work they're doing is genuinely L6 or L7-shaped, and adjust accordingly. And they recognize that promotion is recognition of work already done, not a leap of faith for work they might do.

This document, paired with the Career Map (REF01) and the toolkit content (Field Notes, Leadership Notes, Framework, Templates), should give you the materials to build the case deliberately rather than reactively. The work itself — actually being a senior+ TPM who's earning the next level — is yours. The toolkit and these reference documents are inputs to that work, not substitutes for it.

A note on sources

The patterns described here synthesize publicly available material from Will Larson's StaffEng work (especially the promotion packet guidance), Sean Goedecke's writing on staff promotions at Zendesk and GitHub, the bitlog essay on the multi-year promotion process at Etsy, GitLab's published TPM job family handbook, the Book of TPM, and consensus across multiple senior+ engineer/TPM coaching sources. Specific company processes vary; the underlying patterns are durable across the industry. Where this document differs from any specific source's framing, the difference reflects synthesis across multiple sources rather than disagreement with any one.

Related artifacts

- Charter (#1): the artifact most directly tied to scoping work that becomes promotion evidence
- Decisions & Changes Log (#19): documentation of decisions you contributed to, often referenced in promotion packets
- Stakeholder Register (#3): the relationships that produce cross-functional testimony

Related Field Notes

- FN-AM06 (Skills that compound, skills that depreciate): the long-term skill-investment framing that informs evidence-building
- FN-RP01 (Building credibility in your first 30 days): the credibility patterns that compound into promotion-eligible work
- FN-JP01 ("Executive intervention required"): the kind of judgment work that shows up in L6/L7 promotion packets
- FN-AM01 (What automation actually changes): which skills will appreciate vs. depreciate as you build evidence

Related Leadership Notes

- LN01 (Hiring TPMs at every level): the leveling rubric that hiring uses, mirrored in promotion criteria
- LN03 (Scaling judgment across a team): the judgment-scaling work that becomes L6 mentorship evidence
- LN05 (Mentoring at each career stage): the deliberate practice that produces measurable mentorship outcomes
- LN06 (Performance conversations for TPMs): the inverse view — how managers and leaders evaluate the evidence you're building

Related Reference

- REF01 (Career Map & Reading List): companion document that walks the full career arc and reading list

Keywords: TPM promotion, L5 to L6 promotion, L6 to L7 promotion, senior to staff TPM, staff to principal TPM, promotion evidence, promotion packet, promo packet, building promotion case, TPM promo case, evidence of next level, scope expansion, staff TPM scope, principal TPM scope, promotion committee, promotion process, mapping evidence to rubric, cross-functional testimony, promotion sponsorship, manager sponsorship promotion, not yet promotion feedback, multi-year promotion, terminal level senior, staff promotion fails, principal TPM rare, function-level influence, standards setting, FAANG promotion, GitLab TPM rubric, StaffEng promotion packet, building L6 evidence, building L7 evidence, staff TPM promotion, principal TPM promotion, how to get promoted to staff, how to get promoted to principal, evidence of operating at next level, L6 to L7 transition, L5 to L6 transition, getting promoted as TPM, TPM advancement, advancing to staff, advancing to principal, L6 L7 transition, L5 L6 transition, L6L7, L5L6, transitioning to L6, transitioning to L7, level transition TPM, promotion transition, advancing levels, how do I get promoted to staff TPM, how do I get promoted to principal, how to get to staff, how to get to principal, getting promoted as a TPM, how do I make staff, how do I make principal

Reference — Hiring & Competency Rubric for Program & Project Managers

This rubric is designed for structured, calibrated assessment of program and project manager candidates across levels L3 through L7. It draws on practices from enterprise PMO environments (including security and financial services contexts) but is broadly applicable to any complex delivery organization. Each section provides observable, behavioral criteria to support consistent, evidence-based hiring decisions. Use this rubric before, during, and after interviews to reduce bias and improve signal-to-noise in the evaluation process.

How to use this rubric

Each interviewer scores candidates independently before any debrief discussion. Calibration happens after all scores are locked. This sequence prevents anchoring bias and ensures each panel member contributes a genuine independent signal. Assign each interviewer one or two competency owners so the panel covers the full rubric without redundant coverage.

Scores are 1 through 5 per competency: 1 = significant gap, 2 = below bar, 3 = meets bar, 4 = above bar, 5 = exceptional. Apply the weighted scorecard in Section 6 to derive a total. The decision rule (threshold and must-have floors) is described in Section 6.

Evidence over impression: every score must be anchored to a specific, observable example the candidate provided. If a candidate did not give a concrete example for a competency, that competency cannot be scored above 2. Vague positivity ('seemed sharp', 'great energy') is not evidence and must be challenged in debrief.

Adjust competency weights before the search opens, not after seeing candidates. Weight adjustments should reflect the actual role requirements documented in the job description and agreed by the hiring manager. Retroactive re-weighting to favor a preferred candidate is a process violation.

- Assign competency ownership before interviews: each panelist owns 1-2 competencies and prepares follow-up probes for those areas.
- Use the question bank in Section 5 as a starting point; customise questions to the specific program context.
- Lock individual scores in your ATS or a shared sheet BEFORE the debrief call begins.
- In debrief, resolve disagreements by returning to evidence ('What specific example supports that score?'), not by averaging opinions.
- Flag any 'halo effect' risk: a candidate who is exceptional in one competency but untested in others must not carry an assumed high score across the board.

- For L6-L7 roles, require a written case or take-home scenario in addition to behavioral interviews; add a presentation round for L7.
- Document the rationale for every hire and no-hire decision; retain rubric scores for at least 12 months to enable calibration over time.
- Revisit weights at least annually or whenever the team's strategic priorities shift materially.

Levels at a glance

- Level: L3 | Scope: Single small project, well-defined scope, supervised execution, limited stakeholder surface | Typical title: Associate PM / Junior PM
- Level: L4 | Scope: Full project end-to-end, moderate complexity, owns all delivery artifacts, manages a small team or vendor | Typical title: Project Manager
- Level: L5 | Scope: Complex or cross-team project, technical depth required, influences without authority across multiple work streams | Typical title: Senior PM / Technical Program Manager (TPM)
- Level: L6 | Scope: Multi-project program, owns program roadmap, accountable for aggregate budget and outcomes, leads a team of PMs | Typical title: Program Manager / Senior Program Manager
- Level: L7 | Scope: Portfolio or strategic initiative, executive-level stakeholder relationships, shapes organizational delivery capability, owns program P&L | Typical title: Principal PM / Program Director / VP of PMO

Delivery & Execution

Assesses whether the candidate can drive work to completion reliably, manage scope, and keep delivery on track under real-world constraints. At senior levels, this extends to building delivery systems that work without constant personal intervention.

Level	What strong looks like
L3	Completes assigned tasks on time, escalates blockers promptly, maintains accurate status in tracking tools, does not let small issues compound unnoticed.
L4	Owns the full delivery lifecycle for a project: scope control, milestone tracking, dependency management, and sprint or phase cadence. Can point to a completed project with documented scope changes and variance explanation.
L5	Has delivered a cross-functional project through ambiguity. Demonstrates how they decomposed a complex problem into workable tracks, made real-time scope trade-offs under pressure, and kept velocity despite team or technical disruption.
L6	Runs a program office or delivery rhythm across multiple concurrent projects. Can describe a specific program where they set delivery standards, resolved cross-project dependency conflicts, and reported coherent program status to executives.
L7	Has built or transformed a delivery function. Can articulate the specific changes they made to process, tooling, or structure and quantify the outcome improvement (e.g., on-time delivery rate, cycle time reduction, defect escape rate).

Planning & Estimation

Tests whether the candidate produces plans that are realistic, traceable, and useful - not just presentable. Strong candidates distinguish between initial estimates, committed baselines, and actuals, and can explain variance.

Level	What strong looks like
L3	Can build a simple WBS and Gantt for a bounded project. Understands the difference between effort and duration. Has used at least one planning tool (Jira, MS Project, Smartsheet) hands-on.
L4	Builds and maintains a live project schedule with critical path identified. Adjusts plans based on actuals, not just optimism. Can explain past estimation misses and what they changed afterward.
L5	Has produced estimates for work with high uncertainty (e.g., security remediation, integration projects, new-tech implementation). Uses range-based or three-point estimation. Knows when to use rolling-wave planning and can defend that choice.
L6	Owens program-level roadmaps that span 12-18 months across multiple teams with different velocities. Has managed baseline change control: can describe a program re-plan, what drove it, and how they communicated the change to sponsors.
L7	Sets planning standards for the organization. Can describe how they structured a portfolio planning cadence (e.g., OKR alignment, quarterly business review integration, capacity planning against headcount). Has overseen multi-year program budgets with stage-gate or milestone-based funding.

Risk, Issues & Judgment

Separates candidates who proactively surface and manage risk from those who react to crises. At senior levels, tests whether the candidate can make high-stakes calls with incomplete information and hold that position under pressure.

Level	What strong looks like
L3	Maintains a simple risk and issue log. Escalates the right issues at the right time - does not hoard problems or escalate trivially. Understands the difference between a risk and an issue.
L4	Has managed a project through a material risk event (scope, resource, technical, or vendor). Can describe how they identified the risk early, what mitigation they put in place, and what the outcome was. Risk register is not a compliance artifact for them - it is a working tool.
L5	Proactively identifies risks that others miss (e.g., integration risks in a security tool deployment, third-party API latency under load, compliance gaps in a fintech feature). Has made a judgment call that was later vindicated or learned from. Can articulate the decision logic, not just the outcome.
L6	Has navigated a program-level crisis (e.g., critical vendor failure, regulatory deadline pull-forward, executive sponsor departure). Can describe the triage process, how they stabilized the program, and what lasting governance changes they made as a result.
L7	Makes risk trade-offs at the portfolio level, explicitly balancing delivery risk against strategic opportunity. Has advised a C-level executive on a go/no-go decision and can describe the evidence they presented, the recommendation, and the outcome. Has built organizational risk appetite frameworks, not just individual risk

Level	What strong looks like
	registers.

Stakeholder & Communication

Tests clarity, audience calibration, and the ability to build trust across a diverse stakeholder map. Strong candidates do not just report status - they manage perception, align incentives, and resolve conflict proactively.

Level	What strong looks like
L3	Writes clear, concise status updates. Can run a meeting with an agenda and action log. Does not need prompting to communicate bad news; escalates it cleanly.
L4	Manages a stakeholder map that includes at least one difficult or skeptical party. Can describe how they turned a resistant stakeholder around. Tailors communication format and frequency to audience needs without being asked.
L5	Has managed a stakeholder landscape with significant political complexity (e.g., competing executive sponsors, business unit vs. IT tension, external regulator or auditor). Can describe a specific communication failure and what they changed. Produces executive briefings that are crisp, honest, and decision-oriented.
L6	Owens the program's stakeholder engagement strategy. Has navigated a situation where the program delivered bad news to a C-level audience - can describe how they framed it, what the reaction was, and how they maintained trust. Facilitates cross-organizational alignment, not just communication.
L7	Operates at board and C-suite level. Has built relationships that transcend individual programs - stakeholders seek them out for advice, not just updates. Has managed external stakeholders (regulators, auditors, strategic partners, media) on behalf of the organization.

Financial & Commercial

Tests whether the candidate can own a budget, not just track spend against a number someone else set. At senior levels, extends to commercial acumen, vendor negotiation, and business case construction.

Level	What strong looks like
L3	Understands basic project cost tracking: actuals vs. budget, forecast at completion, variance. Can explain the difference between capital and operational expenditure in general terms.
L4	Has owned a project budget end-to-end. Can walk through a specific budget, explain their forecasting method, describe a variance, and what they did to bring it back in line. Has managed at least one vendor or contractor cost component.
L5	Has built or contributed to a business case with NPV, ROI, or payback period analysis. Has managed a budget with significant uncertainty (e.g., T&M vendor contracts, unknown scope). Can describe a cost trade-off decision they made and the financial logic

Level	What strong looks like
	behind it.
L6	Owns program budget in the range of \$2M-\$20M or equivalent. Has run a re-forecast process mid-program and communicated the change to a finance or executive audience. Has negotiated with vendors on commercial terms - can describe a specific negotiation and what they achieved.
L7	Owns portfolio budget or program P&L at \$20M+ scale. Has structured a business case that secured board-level funding. Has designed program funding models (e.g., milestone-based tranching, chargeback, shared services). Has overseen contract structures (MSA, SOW, SLA) and held vendors accountable to commercial outcomes.

Technical & Domain Fluency

Assesses depth of domain knowledge relevant to the role (security programs, enterprise technology, financial services, etc.). Strong candidates earn credibility with engineers and architects without pretending to be engineers. They know enough to ask the right questions and recognize when they are being misled.

Level	What strong looks like
L3	Understands the basic technical concepts relevant to the team's domain. Knows when to ask questions vs. when to trust the team. Does not make technical commitments without engineering sign-off.
L4	Has delivered a project in the relevant domain (e.g., security tool deployment, cloud migration, data platform, payments integration). Can speak to the key technical risks and constraints of that domain without prompting. Earns credibility with the technical team.
L5	Has deep fluency in at least one relevant domain: e.g., for security programs - identity and access management, vulnerability management, SIEM/SOAR, compliance frameworks (SOC 2, ISO 27001, PCI DSS); for fintech - core banking, payments rails, regulatory capital. Can identify when a technical design choice has downstream program delivery risk.
L6	Has managed a program that spanned multiple technical domains and can describe how they bridged domain knowledge gaps across work streams. Has worked with architects and CTOs as peers. Can review a technical architecture for delivery risk without needing it explained.
L7	Shapes technical strategy as well as delivery. Has influenced build vs. buy decisions, vendor selection, or technology roadmap at the organizational level. Has navigated a program where a fundamental technical assumption proved wrong and can describe how they managed the consequence.

Leadership & People (program/senior)

For L5 and above. Tests whether the candidate develops teams, not just directs them. Strong candidates leave capability behind them; they do not create dependency on their own presence.

Level	What strong looks like
L5	Has informally led or mentored at least one junior PM or analyst. Can describe a specific person they developed and the outcome. Manages up and across effectively without a direct authority position.
L6	Leads a team of 2-6 PMs. Can describe how they set performance expectations, ran 1:1s, handled underperformance, and built team capability over time. Has hired at least one person and can walk through their hiring process and what they look for. Can describe a team conflict they resolved.
L7	Builds organizations, not just teams. Has designed a PMO or delivery function from scratch or restructured an existing one. Can describe the operating model they created, the capability gaps they addressed, and how they measured the outcome. Has managed managers. Has built a talent pipeline, not just filled open roles.

Governance & Method

Tests whether the candidate applies governance as a delivery enabler, not a bureaucratic reflex. Strong candidates know which framework elements to use, when to adapt them, and why. They have opinions grounded in experience, not certification study.

Level	What strong looks like
L3	Familiar with at least one methodology (Agile/Scrum, waterfall, PRINCE2, PMI). Follows the process their team uses. Knows what a project charter, RAID log, and change request are and has used them.
L4	Has applied a methodology to a real project and can describe where it worked and where they adapted it. Has run or participated in steering committee meetings and knows what good governance looks like. Understands change control as a discipline, not just a paperwork step.
L5	Has deliberately selected or adapted a delivery approach for a complex project and can defend that choice. Has operated in a regulated environment (financial services, healthcare, government) where compliance-driven governance was required - e.g., SOX, GDPR, PCI DSS, FCA. Can distinguish between governance that adds value and governance that is theater.
L6	Has designed or implemented program governance: stage gates, program board cadence, escalation paths, decision rights (RACI/DACI), benefit realization tracking. Has introduced a governance change that improved delivery outcomes - can quantify the before/after.
L7	Sets governance standards for the organization. Has established a PMO or Center of Excellence. Has navigated a governance failure (e.g., a program that ran without proper oversight and had to be recovered) and built systemic remediation. Has worked with internal audit or external regulators on delivery governance matters.

Interview question bank

Questions are grouped by competency. Use STAR probing (Situation, Task, Action, Result) for all behavioral questions. Adapt to the target level: probe for program scope at L6-L7, project scope at L4-L5.

- --- DELIVERY & EXECUTION ---
- Tell me about the most complex project you have delivered end-to-end. Walk me through how you structured the delivery, the biggest obstacle you hit, and the final outcome.
- Strong answer includes: specific project scope and timeline, named trade-offs made during execution, quantified outcome (on-time, within budget, measured benefit), honest reflection on what did not go well.
- Red flag: vague or team-attributed success ('we delivered it'), no mention of obstacles or variance, outcome is described but not measured.
- Describe a time you had to descope or delay a deliverable. How did you decide what to cut, and how did you communicate it?
- Strong answer includes: a structured trade-off process (e.g., MoSCoW, value vs. cost analysis), stakeholder alignment before announcement, clear communication of the decision and rationale, minimal downstream damage.
- Red flag: scope was cut without stakeholder agreement, no structured decision logic, candidate positions the cut as someone else's decision.
- --- PLANNING & ESTIMATION ---
- Walk me through how you built the plan for a project where the requirements were not fully defined at the start.
- Strong answer includes: rolling-wave or iterative planning approach, explicit assumptions documented, regular reforecasting cadence, stakeholder alignment on the uncertainty.
- Red flag: built a full Gantt on day one and held it regardless of new information, treated the plan as a contract rather than a tool.
- Tell me about a time your estimate was significantly wrong. What happened and what did you change?
- Strong answer includes: honest acknowledgment of the miss, root cause analysis (e.g., scope growth, technical complexity underestimated, dependency not identified), specific process change made afterward.
- Red flag: blames external factors entirely, no change made, minimizes the miss.
- --- RISK, ISSUES & JUDGMENT ---
- Describe the most serious risk you identified on a project before it became an issue. How did you identify it and what did you do?
- Strong answer includes: proactive identification mechanism (e.g., dependency review, technical spike, stakeholder interview), specific mitigation action taken, outcome versus what would have happened without intervention.
- Red flag: risk was identified late or by someone else, no proactive mechanism described, mitigation was reactive.
- Tell me about a time you had to make a high-stakes decision under significant time pressure with incomplete information. What was the decision and how did you make it?
- Strong answer includes: clear description of what was unknown, structured decision approach (not gut feel alone), explicit acknowledgment of the risk taken, outcome and what they would change.
- Red flag: decision was escalated rather than made, post-hoc rationalization without real decision logic, cannot describe what information was missing.
- --- STAKEHOLDER & COMMUNICATION ---
- Tell me about the most difficult stakeholder relationship you have managed. What made it difficult and how did you handle it?

- Strong answer includes: specific stakeholder and reason for difficulty (competing incentives, lack of trust, political dynamics), concrete actions taken to understand and address the root cause, measurable improvement in the relationship.
- Red flag: blames the stakeholder, no concrete action taken, relationship did not improve or was avoided.
- Describe a time you had to deliver bad news to a senior executive. How did you prepare and what happened?
- Strong answer includes: preparation of the message with options or a remediation plan attached, direct and early delivery (not delayed), maintained trust through transparency, clear on what they controlled vs. did not.
- Red flag: delayed the communication, softened it to the point of obscuring the issue, did not have a mitigation or next-step ready.
- --- FINANCIAL & COMMERCIAL ---
- Walk me through a project budget you owned. What was the total value, how did you forecast, and what was your end variance?
- Strong answer includes: specific dollar figure, monthly or milestone-based forecasting method, identification of a variance event and action taken, final variance within +/-10% or explained if outside that.
- Red flag: has never owned a budget, cannot name a forecasting method, treats budget as someone else's domain.
- Describe a vendor negotiation you led. What were you trying to achieve, how did you approach it, and what was the outcome?
- Strong answer includes: preparation (understanding the vendor's position and constraints, knowing BATNA), specific commercial outcome achieved (price, terms, SLA), maintained workable relationship post-negotiation.
- Red flag: vendor negotiation was handled by procurement without PM involvement, no preparation described, outcome is vague.
- --- TECHNICAL & DOMAIN FLUENCY ---
- Describe a time when a technical assumption your project was built on turned out to be wrong. How did you find out and how did you respond?
- Strong answer includes: proactive technical risk review that surfaced the assumption gap, or honest account of how it emerged, structured recovery plan, involvement of the right technical stakeholders, outcome.
- Red flag: blames the engineers for not flagging it, no involvement in technical risk review, recovery was ad hoc.
- How do you build credibility with an engineering or technical team when you are the PM?
- Strong answer includes: specific behaviors (e.g., learns enough to ask intelligent questions, does not make commitments without sign-off, shields the team from unnecessary process, follows through on commitments), examples from experience.
- Red flag: relies on authority rather than earned trust, cannot describe specific behaviors, mentions micromanagement tactics.
- --- LEADERSHIP & PEOPLE ---
- Tell me about someone you developed or mentored on your team. What specifically did you do and what was the outcome for that person?
- Strong answer includes: specific person (without identifying details), identified development need, structured approach (e.g., stretch assignment, regular coaching, feedback loop), measurable outcome (promotion, capability gain, retention).
- Red flag: development is described as incidental, no specific actions, outcome for the person is not described.

- Describe a time you had to manage underperformance on your team. How did you identify it, what did you do, and what was the outcome?
- Strong answer includes: early identification through clear expectations, direct conversation with the individual, structured improvement plan or re-assignment, honest outcome including if the person left.
- Red flag: avoided the conversation, delegated it entirely to HR, tolerated underperformance indefinitely, outcome is vague.
- --- GOVERNANCE & METHOD ---
- Describe a program or project where the governance structure you inherited was not working. What did you change and why?
- Strong answer includes: specific governance gap identified (e.g., no decision rights, escalation path not clear, steering cadence too infrequent), change made with stakeholder buy-in, measurable improvement in decision speed or delivery outcome.
- Red flag: accepted the broken governance without challenge, describes adding process without removing waste, cannot articulate what the governance change achieved.
- How do you decide how much process is the right amount for a given project?
- Strong answer includes: risk-proportionate approach (higher stakes -> more rigor), size and duration as factors, team maturity considered, can name what they cut on a simple project vs. what they never skip.
- Red flag: applies the same methodology regardless of context, cannot distinguish must-have from nice-to-have governance, equates more documentation with more discipline.

Scoring scorecard

Decision rule: A candidate must score 3 or above on all must-have competencies for the role level. For L4-L5 roles, must-have competencies are Delivery & Execution, Planning & Estimation, Risk/Issues & Judgment, and Stakeholder & Communication. For L6-L7 roles, all competencies except Leadership & People are must-have; Leadership & People is a must-have for any role with direct reports.

Weighted total threshold: L3-L4 pass at ≥ 3.0 weighted total. L5 pass at ≥ 3.3 . L6 pass at ≥ 3.5 . L7 pass at ≥ 3.7 . A weighted total above the threshold with any must-have score below 3 is still a no-hire.

Adjust weights before the search opens and document the rationale. The weights below are recommended defaults; they should shift materially only when the role has an unusually narrow or broad mandate (e.g., a pure internal-delivery PM role may weight Financial & Commercial lower; a vendor-facing program director role may weight it higher).

In the Weighted column, multiply the 1-5 score by the weight and divide by 100 to get a weighted contribution. Sum contributions for the total. Record the calculation in your ATS note or shared scorecard.

- Competency: Delivery & Execution | Weight %: 20
- Competency: Planning & Estimation | Weight %: 15
- Competency: Risk, Issues & Judgment | Weight %: 15
- Competency: Stakeholder & Communication | Weight %: 15
- Competency: Financial & Commercial | Weight %: 10
- Competency: Technical & Domain Fluency | Weight %: 10
- Competency: Leadership & People | Weight %: 8
- Competency: Governance & Method | Weight %: 7
- Competency: TOTAL | Weight %: 100

Red flags & disqualifiers

- Describes past projects as team achievements but takes sole credit for outcomes - cannot separate their contribution from the team's.
- Cannot name specific metrics or outcomes for any project: delivery date, budget variance, defect rate, NPS, revenue impact. 'It went well' is not an outcome.
- Has never personally owned a budget; all financial responsibility was held by someone else in every example given.
- Speaks in methodology jargon (SAFe, PMP, Agile) without being able to describe how they applied it in a specific situation and what trade-offs they made.
- Blames failed projects entirely on external factors: business changed priorities, engineering missed estimates, stakeholders were unaligned. No reflection on their own agency or what they could have done differently.
- Cannot describe a time they pushed back on a senior stakeholder or executive. Every example ends with compliance rather than constructive challenge.
- Has managed only projects in a single domain, size class, or delivery model for their entire career with no demonstrated ability to transfer the skill - particularly problematic at L5 and above.
- At L6-L7: cannot describe building or changing a governance or operating model. Has only executed within systems others created.
- At L6-L7: has never directly managed another PM or project lead. Claims program management experience that, on examination, was a large single project.
- Consistently refers to risk registers and status reports as things they 'maintain' rather than tools they use to make decisions. Treats governance as compliance theater.
- Describes conflict avoidance as stakeholder management: 'I made sure everyone was aligned' with no account of how they resolved actual disagreement.
- Interview answers are entirely theoretical or reference training and certification rather than lived experience. Cannot name the company, approximate timeline, or outcome of any project.
- For roles requiring security or regulated-industry domain knowledge: has never worked in a regulated environment and cannot describe how regulatory requirements change delivery approach.
- Pattern of short tenures (under 18 months) across multiple programs without a credible explanation - raises the question of whether they complete what they start.
- At L5 and above: cannot describe influencing without authority. Every success story relies on having formal power over the team.

Reference — Role Onboarding & Performance Pack (30/60/90)

This pack is issued by your hiring manager on or before Day 1. It defines expectations, deliverables, and success criteria for your first 90 days. The Decipher PMO toolkit underpins every deliverable referenced here - use it as your operating system, not a reference shelf. Your manager will review progress at Day 30, Day 60, and Day 90 against the criteria in this document.

Before Day One - Access and Setup

- Identity and access: corporate SSO provisioned, MFA enrolled, laptop imaged and encrypted
- Project systems: read/write access confirmed in Jira or Azure DevOps (ADO) for all active projects in your portfolio
- Planning tools: Smartsheet or MS Project license activated, workspace/folder shared with your name

- Finance access: project cost center codes confirmed, purchase-order visibility in Oracle/SAP/Coupa or equivalent, expense policy reviewed
- Communication: added to all relevant distribution lists (project, PMO, sponsor, steering committee, all-hands)
- Collaboration: MS Teams or Slack channels joined (project channels, PMO ops channel, escalation channel)
- Document repositories: SharePoint or Confluence space access granted, folder taxonomy reviewed
- Security and compliance: background check complete, NDA signed, any required security clearance initiated or confirmed
- Decipher PMO toolkit: full toolkit downloaded or shared-drive access confirmed - Project Charter, Stakeholder Register, RAID Log, Risk Register, Integrated Plan, Operating Rhythm template, Escalation Framework, Weekly Status template, Program Charter, Roadmap template, Benefits Realization tracker
- Calendar: standing meetings loaded (steering committee, PMO sync, sponsor 1:1, team standups)
- Org chart: current org chart and RACI received from manager
- Onboarding briefing: 60-minute session with manager scheduled for Day 1 morning

First 30 Days - Learn and Orient

Your primary obligation in the first 30 days is to listen, map, and validate - not to fix. Resist the pressure to immediately change processes or challenge decisions. Your credibility is built by demonstrating that you understand context before you act on it. Every conversation is a data point; treat your listening tour as structured research.

By the end of Day 30 you must have a documented, manager-reviewed picture of: the mandate and how success is defined, who holds power and who holds information, the current state of the plan and risks, and the governance structure that exists versus the one that should exist.

- Understand the mandate: read the Program or Project Charter, any prior status reports, board/steering committee decks, and the benefits case - summarize gaps in writing for your manager
- Stakeholder listening tour: schedule 30-45 minute 1:1s with sponsor, business owner, engineering lead, finance BP, key vendor contacts, and PMO peers - use a consistent question set
- Produce a Stakeholder Register (Decipher PMO template) with influence/interest mapping and preliminary engagement strategy
- Document listening-tour notes in a structured format: what each stakeholder believes the project is, what they are worried about, and what they need from you
- Assess the current Integrated Plan: is it baselined, realistic, and owned? Flag if not
- Assess the RAID Log and Risk Register: are they live, owned, and actioned? Flag gaps
- Identify governance gaps: which forums exist, who attends, what decisions get made vs. deferred - document current state
- Draft an Operating Rhythm (Decipher PMO template) for your manager's review - propose cadence, attendees, and agenda structure for each meeting type
- Produce a 30-day summary memo (1-2 pages): mandate clarity, top 5 risks you have already observed, stakeholder health, and your proposed priorities for Days 31-60
- Key relationships to prioritise in this window: sponsor, business owner, engineering lead, and your direct manager (daily or every-other-day check-ins)

Days 31-60 - Take Ownership

You now transition from observer to operator. Every core artifact must be live, owned, and trusted by Day 60. The governance cadence must be running on schedule. Stakeholders should be receiving consistent, reliable status communications. Your manager should no longer need to chase you for updates - you are surfacing them proactively.

Ownership means you are accountable for the accuracy of every artifact. If a number is wrong, it is your number. If a risk is not logged, it is your miss. This window is where professional credibility is established or lost.

- Baseline Integrated Plan: schedule validated with engineering lead and workstream owners, critical path identified, baseline locked in the planning tool
- Project or Program Charter reviewed and confirmed with sponsor - any scope gaps documented and escalated
- RAID Log live: all items have owners, due dates, and status; RAID review included in weekly team meeting
- Risk Register live: top 10 risks scored (probability x impact), mitigation plans assigned, residual risk accepted or escalating
- Operating Rhythm running: first full cycle of standups, weekly status, and steering committee completed to the agreed template
- First clean Weekly Status Report issued using Decipher PMO template: schedule, cost, scope, risk, and issues all RAG-rated with trend arrows
- Escalation Framework documented and socialised: defined thresholds for what gets escalated, to whom, by when, and in what format
- Finance baseline confirmed: budget vs. actuals reconciled with finance BP, forecast-to-complete documented
- Vendor or third-party engagement reviewed: contract obligations understood, delivery milestones in plan, commercial risks logged
- Day 60 check-in with manager: present artifact status, governance health, and updated risk picture - agree priorities for Days 61-90

Days 61-90 - Deliver and Demonstrate

By Day 90 you are no longer ramping - you are delivering. The measure of this window is output: a completed milestone, a defensible forecast, a governance structure that runs without intervention, and stakeholders who trust your numbers. This is where you demonstrate the difference between a capable PM and an exceptional one.

A defensible forecast means you can walk any executive through your schedule, cost, and risk picture in under 10 minutes with no surprises. It means your actuals reconcile to finance, your critical path is current, and your risk-adjusted completion date is documented and understood by the sponsor.

- At least one planned milestone delivered on time, in scope, and within budget - document the outcome formally
- Benefits Realization tracker initiated: leading indicators of value defined, baseline measurements taken, ownership assigned
- Roadmap current and published: rolling 90-day view visible to all stakeholders, major milestones and dependencies clear
- Steering committee running autonomously: agenda, pre-reads, and decision log issued without prompting from sponsor or manager
- Forecast-to-complete defensible: EVM or milestone-based SPI/CPI calculated and trended, recovery plans in place for any amber/red items
- Stakeholder confidence established: sponsor and business owner can state, unprompted, that they trust the PM's picture of the project

- Team health assessed: early indicators of burnout, bottlenecks, or resourcing gaps surfaced and addressed
- 90-day retrospective with manager: honest self-assessment against this pack, agree development areas and next 90-day objectives
- Any outstanding access, tooling, or process gaps from Day 1 fully resolved - no legacy blockers remaining

Key Relationships to Build

Relationship quality is a leading indicator of project health. Build these deliberately and systematically - do not let any of these relationships default to transactional status updates.

- Relationship: Executive Sponsor | Why It Matters: Owns the mandate and budget; your escalation endpoint; their confidence in you determines your autonomy | Cadence: Bi-weekly 1:1; steering committee monthly; ad-hoc for escalations within 24 hours
- Relationship: Business Owner / Product Owner | Why It Matters: Defines scope and acceptance criteria; controls business resources and SMEs; key to benefits realisation | Cadence: Weekly 1:1; present at every status review; joint owner of scope change decisions
- Relationship: Engineering Lead / Tech Lead | Why It Matters: Controls delivery capacity, sequencing, and technical risk; your partner on the critical path | Cadence: Weekly 1:1; daily or every-other-day informal check-in during active delivery sprints
- Relationship: Finance Business Partner | Why It Matters: Controls actuals, forecasts, and PO approvals; your source of truth on cost; can flag issues before they become crises | Cadence: Bi-weekly sync; monthly forecast review; immediate contact on any variance > threshold
- Relationship: Vendor or SI Programme Manager | Why It Matters: Accountable for third-party deliverables; commercial relationship requires proactive management, not reactive chase | Cadence: Weekly status; monthly commercial review; escalation path documented in contract
- Relationship: PMO Lead or Head of PMO | Why It Matters: Governs standards, templates, and portfolio visibility; your support structure and your quality bar | Cadence: Weekly PMO sync; ad-hoc for template or process questions; 30/60/90 reviews
- Relationship: Peer PMs | Why It Matters: Shared resource pools, cross-project dependencies, and organisational knowledge; fastest source of ground truth on how things actually work | Cadence: Informal - at minimum bi-weekly; cross-dependency review monthly

Performance Expectations and KPIs

These KPIs are reviewed at each 30/60/90 checkpoint and then monthly thereafter. Amber on any dimension triggers a documented recovery conversation within 5 business days. Red on any dimension triggers an escalation to the next level of management.

- Dimension: Delivery Predictability | KPI or Signal: Milestone hit rate or Schedule Performance Index (SPI) | Target: $\geq 90\%$ milestones on time; $SPI \geq 0.95$ | How Measured: Integrated Plan vs. actuals; EVM where applicable | Cadence: Weekly status; monthly trend
- Dimension: Cost Performance | KPI or Signal: Cost Performance Index (CPI) or budget variance | Target: $CPI \geq 0.95$; forecast variance within $\pm 5\%$ of approved budget | How Measured: Finance actuals vs. baseline; monthly reconciliation with finance BP | Cadence: Monthly; escalate immediately on $>5\%$ variance
- Dimension: Stakeholder Confidence | KPI or Signal: Sponsor and business owner stated confidence; escalation frequency initiated by others (not by PM) | Target: Sponsor/BO can state confidence $\geq 4/5$ when asked; PM initiates 100% of escalations | How

Measured: Manager skip-level feedback; 30/60/90 stakeholder pulse; escalation log | Cadence: 30/60/90 reviews; ad-hoc sponsor feedback

- Dimension: Governance and RAID Hygiene | KPI or Signal: % of RAID items with owner, due date, and current status; status report on-time rate | Target: 100% RAID items owned and dated; status report issued within 24 hours of cadence deadline | How Measured: RAID log audit; status report issuance log | Cadence: Weekly; RAID reviewed in team meeting
- Dimension: Risk Management | KPI or Signal: % of top-10 risks with active mitigation plans; no surprises (issues that were not in the risk register) | Target: 100% of top-10 risks have mitigation owner and date; zero unlogged surprises in any steering committee | How Measured: Risk register audit; post-meeting issue log | Cadence: Weekly risk review; monthly steering committee
- Dimension: Benefits and Value | KPI or Signal: Leading indicator metrics initiated and baselined; benefits owner assigned | Target: Benefits tracker live by Day 75; at least 1 leading indicator baselined | How Measured: Benefits Realization tracker; business owner sign-off | Cadence: Monthly from Day 60
- Dimension: Team Health | KPI or Signal: Resourcing coverage (no unplanned gaps >1 week); team-reported blockers resolved within SLA | Target: Zero unplanned resource gaps >5 business days; 100% of logged blockers resolved or escalated within 3 business days | How Measured: Resource plan vs. actuals; RAID blocker log | Cadence: Weekly standup; bi-weekly manager review

90-Day Success Criteria

Your manager will conduct formal 30, 60, and 90-day reviews using this document as the scorecard. Between formal reviews, you will have a weekly 1:1 with your manager (30 minutes minimum) focused on blockers, decisions needed, and relationship health - not status updates, which are handled through the written Weekly Status Report. Raise blockers in writing before the 1:1 so the meeting is used for resolution, not discovery. The 90-day review is a two-way conversation: your manager assesses you against these criteria, and you assess what support you need for the next phase. Both outputs are documented.

- All core Decipher PMO artifacts live, owned, and trusted: Project/Program Charter, Stakeholder Register, RAID Log, Risk Register, Integrated Plan, Operating Rhythm, Escalation Framework, Weekly Status, Roadmap, Benefits Realization tracker
- Governance cadence running without prompting: standups, weekly status, steering committee, and any required PMO reporting all on schedule
- Sponsor and business owner have stated, on record, that they trust the PM's project picture
- At least one milestone delivered on time, in scope, and within budget - formally documented
- Forecast-to-complete is defensible: actuals reconcile to finance, critical path is current, risk-adjusted completion date is documented
- No unresolved access, tooling, or process gaps from the onboarding checklist
- Top-10 risks all have active mitigation plans and named owners
- Benefits Realization tracker initiated with at least one baselined leading indicator
- PM has built trusted working relationships with all seven stakeholder groups in the Key Relationships table
- Manager has no unresolved concerns about delivery predictability, stakeholder confidence, or artifact quality going into Month 4

Using the Toolkit in Your First 90 Days

The Decipher PMO toolkit is not optional and is not a bureaucratic overlay - it is the operational infrastructure of this role. Each artifact has a defined moment of first use. Do not skip the early artifacts because the project is already underway; validate, update, and re-baseline them as your first act of ownership.

- Day 1-5 -> Project Charter / Program Charter: read and validate; identify gaps; confirm scope, objectives, success criteria, and sponsor sign-off with your manager
- Day 1-10 -> Stakeholder Register: build or validate using Decipher PMO template; complete influence/interest mapping; define engagement strategy per stakeholder
- Day 5-15 -> Integrated Plan: assess current state; identify if it is baselined and realistic; flag gaps to manager; do not re-plan until you have completed the listening tour
- Day 10-20 -> RAID Log: assess current state; take ownership; ensure every item has an owner, due date, and status; schedule RAID review in team meeting
- Day 10-20 -> Risk Register: assess current state; score top-10 risks; assign mitigation owners; confirm escalation thresholds with sponsor
- Day 15-25 -> Operating Rhythm: draft proposed cadence using Decipher PMO template; review with manager; socialise with stakeholders; launch by Day 30
- Day 20-30 -> Escalation Framework: document thresholds, escalation path, response SLAs, and communication format; get sponsor sign-off
- Day 30 -> Weekly Status Report: first clean issue using Decipher PMO template; all RAG ratings with rationale; no blank fields
- Day 30-45 -> Roadmap: validate or build rolling 90-day view; confirm major milestones and dependencies with engineering lead and business owner
- Day 45-60 -> Integrated Plan baseline locked: schedule confirmed with all workstream owners; critical path documented; baseline approved by sponsor
- Day 60-75 -> Benefits Realization tracker: initiate with business owner; define leading indicators; take baseline measurements; assign ownership of each measure
- Day 75-90 -> First milestone delivery report: formal documentation of delivered outcome against plan; lessons captured; shared with steering committee

Reference — Start Here: Your First Two Weeks

Do not try to use all of it at once. This toolkit is large on purpose - it is a reference, not a checklist. In your first two weeks, stand up a small spine of artifacts that gets you credible and in control; add the rest as the work demands. Use the search, the discipline bands (Project / Program / Shared), and the lifecycle-phase lens to find anything else when you need it.

If you are running a PROJECT - Week 1 (stand up the spine)

- Project Charter - authorize the work: why it exists, scope (and explicit out-of-scope), success criteria, sponsor sign-off.
- Stakeholder Register & Engagement Plan - who matters, their influence/interest, and how you will engage each.
- RACI Matrix - one accountable owner per decision and deliverable; kills the most common failure (ambiguous accountability).
- Project Kickoff Pack - align the team and confirm governance, decision rights, and the first milestone.
- Team Charter & Working Agreements - how the team works: Definition of Ready/Done, decision rights, norms.
- Operating Rhythm & Cadence Map - set the meeting, governance, and reporting rhythm deliberately from day one.

If you are running a PROJECT - Week 2 (make it trackable)

- Integrated Project Plan / Schedule & Milestone Tracker - baseline the milestones; track planned vs forecast.
- RAID Log + Risk Register & Response Plan - start logging and scoring risks and issues now, not later.
- Project Budget (and Cost Management & EVM once baselined) - know your number and how you will track burn.
- Communications Plan - audience-segmented messaging, including escalation/crisis comms.
- Weekly Status Report - start reporting against objective RAG thresholds in week 2; no surprises later.
- Decisions & Changes Log + Escalation Framework - capture decisions with rationale; define escalation tiers and SLAs up front.

If you are running a PROGRAM - Week 1

- Program Charter (Multi-Initiative) - the integrating vision and mandate, not a stack of project charters.
- Program Governance & Integration Management - boards, decision rights, escalation between levels.
- Program Roadmap - the strategic timeline: workstreams, milestones, dependencies, decision points.
- Operating Model Document - if you are standing up the function: value streams, accountabilities, interfaces.

If you are running a PROGRAM - Week 2

- Component Initiatives + Portfolio Dashboard - the live view of components, status, and rollup.
- Program Risk Management + Program-Level RAID - manage systemic and cross-component risk, not just aggregated project risk.
- Cross-Component Dependency Management - the dependencies that no single project owns.
- Program Capacity & Demand Management - balance shared, scarce resources across components.
- Program Benefits Realization + Program Success Metrics/OKRs - baseline the outcomes you will be judged on.

Read these first (craft before templates)

- Field Note - Building credibility in your first 30 days on a new project.
- Field Note - Taking over a strained program (the first 45 days) - if you are inheriting trouble.
- Responsible AI Usage Guardrails - read this before you paste anything into an AI tool, especially in a regulated or security context.
- AI Prompts - Overview - what the prompts can and cannot do, and how to verify their output.

The weekly rhythm to establish

Cadence beats heroics. Lock these in week one so the program runs on rails:

- Weekly: team check-in, RAID/risk review, and a status report against objective RAG thresholds.
- Biweekly or monthly: steering committee / governance board with decisions pre-socialized.
- At each phase boundary: a phase-gate review with explicit entry/exit criteria and a go / no-go.

- Continuously: keep the decisions log and the stakeholder engagement current - they are your memory and your early-warning system.

Where to go next

Once the spine is running, let the work pull in the rest. Use the lifecycle-phase lens to find what each phase needs, the discipline bands to find what is yours, and the full Playbook for the standard, the maturity ladders, and what good looks like. Adapt every artifact to your context - the overlay (your regulator, delivery method, industry, and org) is the judgment the toolkit cannot supply.